국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

시점확인본
2025/04/01
13:15:51
KST
정부시점확인센터

보안 과제( ), 일반 과제(∨) / 공개(∨), 비공개( ), 발간등록번호( )

정보보호핵심원천기술개발 사업 최종보고서

2021-0-00358

AI·빅데이터 기반 사이버 보안 오케스트레이션 및 자동 대응 기술 개발 최종보고서

2025. 02. 28.

주관연구개발기관 / 한국인터넷진흥원
공동연구개발기관 / 성균관대학교 산학협력단
공동연구개발기관 / 국민대학교 산학협력단
공동연구개발기관 / ㈜시큐레이어
공동연구개발기관 / ㈜윈스
공동연구개발기관 / ㈜모비젠
공동연구개발기관 / 한국과학기술정보연구원

과학기술정보통신부
정보통신기획평가원

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

최종보고서

보안등급: 일반[O], 보안[ ]

중앙행정기관명	과학기술정보통신부	사업명	세부사업명	정보보호핵심원천 기술개발사업		
전문기관명	정보통신기획평가원		내역사업명			
공고번호	제2020-0755호	총괄연구개발 식별번호 (해당 시 작성)				
		연구개발과제번호				

기술분류								
기술분류	국가과학기술 표준분류	EE0302	50%	EE0303	30%	EE0301	20%
	ICT 기술분류	SEC0106	80%	SEC0103	10%	SEC0201	10%

총괄연구개발명 (해당 시 작성)	국문				
	영문				
연구개발과제명	국문	AI·빅데이터 기반 사이버 보안 오케스트레이션 및 자동 대응 기술 개발			
	영문	AI·Big data based Cyber Security Orchestration and Automated Response Technology Development			
주관연구개발기관	기관명	한국인터넷진흥원	사업자등록번호	135-82-07931	
	주소	(58324)전남 나주시 진흥길 9	법인등록번호	244271-0006001	
연구책임자	성명	김태은	직위	책임연구원	
	연락처 직장전화	061-820-1273	휴대전화	********	
	연락처 전자우편	tekim31@kisa.or.kr	국가연구자번호	********	
연구개발기간	전체	2021. 04. 01. - 2024. 12. 31. (3년 9개월)			
	단계 (해당 시 작성) 1단계	2021. 04. 01. - 2022. 12. 31. (1년 9개월)			
	단계 (해당 시 작성) 2단계	2023. 01. 01. - 2024. 12. 31. (2년 -개월)			

연구개발비 (단위: 천원)		정부지원 연구개발비	기관부담 연구개발비		그 외 기관 등의 지원금				합계			연구개발비 외 지원금
					지방자치단체		기타( )					
		현금	현금	현물	현금	현물	현금	현물	현금	현물	합계	
총계		8,715,000	88,660	1,302,329					8,803,660	1,302,329	10,105,989	
1단계	1년차	1,900,000	16,300	292,200					1,916,300	292,200	2,208,500	
	2년차	2,500,000	20,100	367,400					2,520,100	367,400	2,887,500	
2단계	1년차	2,500,000	23,300	297,748					2,523,300	297,748	2,821,048	
	2년차	1,815,000	28,960	344,981					1,843,960	344,981	2,188,941	

공동연구개발기관 등 (해당 시 작성)	기관명	책임자	직위	휴대전화	전자우편	역할	기관유형
공동연구개발기관	한국과학기술정보연구원	송중석	센터장	********	song@kisti.re.kr	공동	정부출연연
	㈜시큐레이어	김건우	이사	********	kunwoo.kim@seculayer.com	공동	중소기업
	㈜윈스	주은영	이사	********	expect@wins21.co.kr	공동	중소기업
	㈜모비젠	박관영	팀장	********	kypark@mobigen.com	공동	중소기업
	성균관대학교 산학협력단	박은일	조교수	********	eunilpark@skku.edu	공동	대학
	국민대학교 산학협력단	김환국	조교수	********	rinyfeel@koookmin.ac.kr	공동	대학

연구개발담당자 실무담당자	성명	이새움	직위	책임연구원	
	연락처 직장전화	061-820-1253	휴대전화	********	
	연락처 전자우편	sprout2@kisa.or.kr	국가연구자번호	********	

이 최종보고서에 기재된 내용이 사실임을 확인하며, 만약 사실이 아닌 경우 관련 법령 및 규정에 따라 제재처분 등의 불이익도 감수하겠습니다.

2025 년 02 월 28 일

연구책임자 : 김 태 은 (인)

주관연구개발기관의 장: 이 상 중 (직인)

과학기술정보통신부장관 귀하

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

최종보고서

보안등급: 일반[O], 보안[ ]

중앙행정기관명	과학기술정보통신부	사업명	세부사업명	정보보호핵심원천 기술개발사업	
전문기관명	정보통신기획평가원		내역사업명		
공고번호	제2020-0755호	총괄연구개발 식별번호 (해당 시 작성)			
		연구개발과제번호			

기술분류	국가과학기술 표준분류	EE0302	50%	EE0303	30%	EE0301	20%
	ICT 기술분류	SEC0106	80%	SEC0103	10%	SEC0201	10%

총괄연구개발명 (해당 시 작성)	국문				
	영문				
연구개발과제명	국문	AI·빅데이터 기반 사이버 보안 오케스트레이션 및 자동 대응 기술 개발			
	영문	AI·Big data based Cyber Security Orchestration and Automated Response Technology Development			
주관연구개발기관	기관명	한국인터넷진흥원	사업자등록번호	135-82-07931	
	주소	(58324)전남 나주시 진흥길 9	법인등록번호	244271-0006001	
연구책임자	성명	김태은	직위	책임연구원	
	연락처 직장전화	061-820-1273	휴대전화	********	
	연락처 전자우편	tekim31@kisa.or.kr	국가연구자번호	********	
연구개발기간	전체	2021. 04. 01. - 2024. 12. 31. (3년 9개월)			
	단계 (해당 시 작성) 1단계	2021. 04. 01. - 2022. 12. 31. (1년 9개월)			
	단계 (해당 시 작성) 2단계	2023. 01. 01. - 2024. 12. 31. (2년 -개월)			

연구개발비 (단위: 천원)		정부지원 연구개발비	기관부담 연구개발비		그 외 기관 등의 지원금				합계			연구개발비 외 지원금
					지방자치단체		기타( )					
		현금	현금	현물	현금	현물	현금	현물	현금	현물	합계	
총계		8,715,000	88,660	1,302,329					8,803,660	1,302,329	10,105,989	
1단계	1년차	1,900,000	16,300	292,200					1,916,300	292,200	2,208,500	
	2년차	2,500,000	20,100	367,400					2,520,100	367,400	2,887,500	
2단계	1년차	2,500,000	23,300	297,748					2,523,300	297,748	2,821,048	
	2년차	1,815,000	28,960	344,981					1,843,960	344,981	2,188,941	

공동연구개발기관 등 (해당 시 작성)	기관명	책임자	직위	휴대전화	전자우편	역할	기관유형
공동연구개발기관	한국과학기술정보연구원	송중석	센터장	********	song@kisti.re.kr	공동	정부출연연
	㈜시큐레이어	김건우	이사	********	kunwoo.kim@seculayer.com	공동	중소기업
	㈜윈스	주은영	이사	********	expect@wins21.co.kr	공동	중소기업
	㈜모비젠	박관영	팀장	********	kypark@mobigen.com	공동	중소기업
	성균관대학교 산학협력단	박은일	조교수	********	eunilpark@skku.edu	공동	대학
	국민대학교 산학협력단	김환국	조교수	********	rinyfeel@koookmin.ac.kr	공동	대학

연구개발담당자 실무담당자	성명	이새움	직위	책임연구원	
	연락처 직장전화	061-820-1253	휴대전화	********	
	연락처 전자우편	sprout2@kisa.or.kr	국가연구자번호	********	

이 최종보고서에 기재된 내용이 사실임을 확인하며, 만약 사실이 아닌 경우 관련 법령 및 규정에 따라 제재처분 등의 불이익도 감수하겠습니다.

2025 년 02 월 28 일

연구책임자 : 김 태 은 (인)

주관연구개발기관의 장: 이 상 중 (직인)

과학기술정보통신부장관 귀하

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

최종보고서

보안등급: 일반[O], 보안[ ]

중앙행정기관명	과학기술정보통신부	사업명	세부사업명	정보보호핵심원천 기술개발사업	
전문기관명	정보통신기획평가원		내역사업명		
공고번호	제2020-0755호	총괄연구개발 식별번호 (해당 시 작성)			
		연구개발과제번호			

기술분류							
국가과학기술 표준분류	EE0302	50%	EE0303	30%	EE0301	20%	
ICT 기술분류	SEC0106	80%	SEC0103	10%	SEC0201	10%	

총괄연구개발명 (해당 시 작성)	국문			
	영문			
연구개발과제명	국문	AI·빅데이터 기반 사이버 보안 오케스트레이션 및 자동 대응 기술 개발		
	영문	AI·Big data based Cyber Security Orchestration and Automated Response Technology Development		
주관연구개발기관	기관명	한국인터넷진흥원	사업자등록번호	135-82-07931
	주소	(58324)전남 나주시 진흥길 9	법인등록번호	244271-0006001
연구책임자	성명	김태은	직위	책임연구원
	연락처 직장전화	061-820-1273	휴대전화	********
	연락처 전자우편	tekim31@kisa.or.kr	국가연구자번호	********
연구개발기간	전체	2021. 04. 01. - 2024. 12. 31. (3년 9개월)		
	단계 (해당 시 작성) 1단계	2021. 04. 01. - 2022. 12. 31. (1년 9개월)		
	단계 (해당 시 작성) 2단계	2023. 01. 01. - 2024. 12. 31. (2년 -개월)		

연구개발비 (단위: 천원)		정부지원 연구개발비	기관부담 연구개발비		그 외 기관 등의 지원금				합계			연구개발비 외 지원금
					지방자치단체		기타( )					
		현금	현금	현물	현금	현물	현금	현물	현금	현물	합계	
총계		8,715,000	88,660	1,302,329					8,803,660	1,302,329	10,105,989	
1단계	1년차	1,900,000	16,300	292,200					1,916,300	292,200	2,208,500	
	2년차	2,500,000	20,100	367,400					2,520,100	367,400	2,887,500	
2단계	1년차	2,500,000	23,300	297,748					2,523,300	297,748	2,821,048	
	2년차	1,815,000	28,960	344,981					1,843,960	344,981	2,188,941	

공동연구개발기관 등 (해당 시 작성)	기관명	책임자	직위	휴대전화	전자우편	역할	기관유형
공동연구개발기관	한국과학기술정보연구원	송중석	센터장	********	song@kisti.re.kr	공동	정부출연연
	㈜시큐레이어	김건우	본부장	********	kunwoo.kim@seculayer.com	공동	중소기업
	㈜윈스	주은영	이사	********	expect@wins21.co.kr	공동	중소기업
	㈜모비젠	박관영	팀장	********	kypark@mobigen.com	공동	중소기업
	성균관대학교 산학협력단	박은일	조교수	********	eunilpark@skku.edu	공동	대학
	국민대학교 산학협력단	김환국	조교수	********	rinyfeel@koookmin.ac.kr	공동	대학

연구개발담당자 실무담당자					
성명	이새움	직위	책임연구원		
연락처 직장전화	061-820-1253	휴대전화	********		
연락처 전자우편	sprout2@kisa.or.kr	국가연구자번호	********		

이 최종보고서에 기재된 내용이 사실임을 확인하며, 만약 사실이 아닌 경우 관련 법령 및 규정에 따라 제재처분 등의 불이익도 감수하겠습니다.

2025 년 02 월 28 일

연구책임자: 김 태 은 (인)
주관연구개발기관의 장: 이 상 중 (직인)
공동연구개발기관의 장: 이 식 (직인) / 한국과학기술정보연구원

과학기술정보통신부장관 귀하

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

최종보고서

보안등급: 일반[O], 보안[ ]

중앙행정기관명	과학기술정보통신부	사업명 / 세부사업명	정보보호핵심원천 기술개발사업
전문기관명	정보통신기획평가원	내역사업명	
공고번호	제2020-0755호	총괄연구개발 식별번호 (해당 시 작성)	
		연구개발과제번호	

기술분류								
국가과학기술 표준분류	EE0302	50%	EE0303	30%	EE0301	20%
ICT 기술분류	SEC0106	80%	SEC0103	10%	SEC0201	10%

총괄연구개발명 (해당 시 작성)	국문	
	영문	
연구개발과제명	국문	AI·빅데이터 기반 사이버 보안 오케스트레이션 및 자동 대응 기술 개발
	영문	AI·Big data based Cyber Security Orchestration and Automated Response Technology Development

주관연구개발기관	기관명	한국인터넷진흥원	사업자등록번호	135-82-07931
	주소	(58324)전남 나주시 진흥길 9	법인등록번호	244271-0006001
연구책임자	성명	김태은	직위	책임연구원
	연락처 직장전화	061-820-1273	휴대전화	********
	연락처 전자우편	tekim31@kisa.or.kr	국가연구자번호	********

연구개발기간	전체		2021. 04. 01. - 2024. 12. 31. (3년 9개월)
	단계 (해당 시 작성)	1단계	2021. 04. 01. - 2022. 12. 31. (1년 9개월)
		2단계	2023. 01. 01. - 2024. 12. 31. (2년 -개월)

연구개발비 (단위: 천원)		정부지원 연구개발비	기관부담 연구개발비		그 외 기관 등의 지원금				합계			연구개발비 외 지원금
					지방자치단체		기타( )					
		현금	현금	현물	현금	현물	현금	현물	현금	현물	합계	
총계		8,715,000	88,660	1,302,329					8,803,660	1,302,329	10,105,989	
1단계	1년차	1,900,000	16,300	292,200					1,916,300	292,200	2,208,500	
	2년차	2,500,000	20,100	367,400					2,520,100	367,400	2,887,500	
2단계	1년차	2,500,000	23,300	297,748					2,523,300	297,748	2,821,048	
	2년차	1,815,000	28,960	344,981					1,843,960	344,981	2,188,941	

공동연구개발기관 등 (해당 시 작성)	기관명	책임자	직위	휴대전화	전자우편	역할	기관유형
공동연구개발기관	한국과학기술정보연구원	송충석	센터장	********	song@kisti.re.kr	공동	정부출연연
	㈜시큐레이어	김건우	본부장	********	kunwoo.kim@seculayer.com	공동	중소기업
	㈜윈스	주은영	이사	********	expect@wins21.co.kr	공동	중소기업
	㈜모비젠	박관영	팀장	********	kypark@mobigen.com	공동	중소기업
	성균관대학교 산학협력단	박은일	조교수	********	eunilpark@skku.edu	공동	대학
	국민대학교 산학협력단	김환국	조교수	********	rinyfeel@koookmin.ac.kr	공동	대학

연구개발담당자 실무담당자	성명	이새움	직위	책임연구원	
	연락처 직장전화	061-820-1253	휴대전화	********	
	연락처 전자우편	sprout2@kisa.or.kr	국가연구자번호	********	

이 최종보고서에 기재된 내용이 사실임을 확인하며, 만약 사실이 아닌 경우 관련 법령 및 규정에 따라 제재처분 등의 불이익도 감수하겠습니다.

2025 년 02 월 28 일

연구책임자: 김 태 은 (인)
주관연구개발기관의 장: 이 상 중 (직인)
공동연구개발기관의 장: 전 주 호 (직인) ㈜시큐레이어

과학기술정보통신부장관 귀하

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

최종보고서

보안등급: 일반[O], 보안[ ]

중앙행정기관명	과학기술정보통신부	사업명	세부사업명	정보보호핵심원천 기술개발사업	
전문기관명	정보통신기획평가원		내역사업명		
공고번호	제2020-0755호	총괄연구개발 식별번호 (해당 시 작성)			
		연구개발과제번호			

기술분류	국가과학기술 표준분류	EE0302	50%	EE0303	30%	EE0301	20%
	ICT 기술분류	SEC0106	80%	SEC0103	10%	SEC0201	10%

총괄연구개발명 (해당 시 작성)	국문				
	영문				
연구개발과제명	국문	AI·빅데이터 기반 사이버 보안 오케스트레이션 및 자동 대응 기술 개발			
	영문	AI·Big data based Cyber Security Orchestration and Automated Response Technology Development			
주관연구개발기관	기관명	한국인터넷진흥원	사업자등록번호	135-82-07931	
	주소	(58324)전남 나주시 진흥길 9	법인등록번호	244271-0006001	
연구책임자	성명	김태은	직위	책임연구원	
	연락처 직장전화	061-820-1273	휴대전화	********	
	연락처 전자우편	tekim31@kisa.or.kr	국가연구자번호	********	
연구개발기간	전체	2021. 04. 01. - 2024. 12. 31. (3년 9개월)			
	단계 (해당 시 작성) 1단계	2021. 04. 01. - 2022. 12. 31. (1년 9개월)			
	단계 (해당 시 작성) 2단계	2023. 01. 01. - 2024. 12. 31. (2년 -개월)			

연구개발비 (단위: 천원)		정부지원 연구개발비	기관부담 연구개발비		그 외 기관 등의 지원금				합계			연구개발비 외 지원금
			지방자치단체		기타( )							
		현금	현금	현물	현금	현물	현금	현물	현금	현물	합계	
총계		8,715,000	88,660	1,302,329					8,803,660	1,302,329	10,105,989	
1단계	1년차	1,900,000	16,300	292,200					1,916,300	292,200	2,208,500	
	2년차	2,500,000	20,100	367,400					2,520,100	367,400	2,887,500	
2단계	1년차	2,500,000	23,300	297,748					2,523,300	297,748	2,821,048	
	2년차	1,815,000	28,960	344,981					1,843,960	344,981	2,188,941	

공동연구개발기관 등 (해당 시 작성)	기관명	책임자	직위	휴대전화	전자우편	역할	기관유형
공동연구개발기관	한국과학기술정보연구원	송중석	센터장	********	song@kisti.re.kr	공동	정부출연연
	㈜시큐레이어	김건우	본부장	********	kunwoo.kim@seculayer.com	공동	중소기업
	㈜윈스	주은영	이사	********	expect@wins21.co.kr	공동	중소기업
	㈜모비젠	박관영	팀장	********	kypark@mobigen.com	공동	중소기업
	성균관대학교 산학협력단	박은일	조교수	********	eunilpark@skku.edu	공동	대학
	국민대학교 산학협력단	김환국	조교수	********	rinyfeel@koookmin.ac.kr	공동	대학

연구개발담당자 실무담당자		성명	이새움	직위	책임연구원
	연락처	직장전화	061-820-1253	휴대전화	********
	연락처	전자우편	sprout2@kisa.or.kr	국가연구자번호	********

이 최종보고서에 기재된 내용이 사실임을 확인하며, 만약 사실이 아닌 경우 관련 법령 및 규정에 따라 제재처분 등의 불이익도 감수하겠습니다.

2025 년 02 월 28 일

연구책임자: 김 태 은 (인)
주관연구개발기관의 장: 이 상 중 (직인)
공동연구개발기관의 장: 김 보 연 (직인) ㈜윈스

과학기술정보통신부장관 귀하

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

최종보고서

보안등급: 일반[O], 보안[ ]

중앙행정기관명	과학기술정보통신부	사업명	세부사업명	정보보호핵심원천기술개발사업	
전문기관명	정보통신기획평가원		내역사업명		
공고번호	제2020-0755호	총괄연구개발 식별번호 (해당 시 작성)			
		연구개발과제번호			

기술분류							
국가과학기술 표준분류	EE0302	50%	EE0303	30%	EE0301	20%
ICT 기술분류	SEC0106	80%	SEC0103	10%	SEC0201	10%

총괄연구개발명 (해당 시 작성)	국문				
	영문				
연구개발과제명	국문	AI·빅데이터 기반 사이버 보안 오케스트레이션 및 자동 대응 기술 개발			
	영문	AI·Big data based Cyber Security Orchestration and Automated Response Technology Development			
주관연구개발기관	기관명	한국인터넷진흥원	사업자등록번호	135-82-07931	
	주소	(58324)전남 나주시 진흥길 9	법인등록번호	244271-0006001	
연구책임자	성명	김태은	직위	책임연구원	
	연락처 직장전화	061-820-1273	휴대전화	********	
	연락처 전자우편	tekim31@kisa.or.kr	국가연구자번호	********	
연구개발기간	전체	2021. 04. 01. - 2024. 12. 31. (3년 9개월)			
	단계 (해당 시 작성) 1단계	2021. 04. 01. - 2022. 12. 31. (1년 9개월)			
	2단계	2023. 01. 01. - 2024. 12. 31. (2년 -개월)			

연구개발비 (단위: 천원)		정부지원 연구개발비	기관부담 연구개발비		그 외 기관 등의 지원금				합계			연구개발비 외 지원금
					지방자치단체		기타( )					
		현금	현금	현물	현금	현물	현금	현물	현금	현물	합계	
총계		8,715,000	88,660	1,302,329					8,803,660	1,302,329	10,105,989	
1단계	1년차	1,900,000	16,300	292,200					1,916,300	292,200	2,208,500	
	2년차	2,500,000	20,100	367,400					2,520,100	367,400	2,887,500	
2단계	1년차	2,500,000	23,300	297,748					2,523,300	297,748	2,821,048	
	2년차	1,815,000	28,960	344,981					1,843,960	344,981	2,188,941	

공동연구개발기관 등 (해당 시 작성)	기관명	책임자	직위	휴대전화	전자우편	역할	기관유형
공동연구개발기관	한국과학기술정보연구원	송중석	센터장	********	song@kisti.re.kr	공동	정부출연연
	㈜시큐레이어	김건우	본부장	********	kunwoo.kim@seculayer.com	공동	중소기업
	㈜윈스	주은영	이사	********	expect@wins21.co.kr	공동	중소기업
	㈜모비젠	박관영	팀장	********	kypark@mobigen.com	공동	중소기업
	성균관대학교 산학협력단	박은일	조교수	********	eunilpark@skku.edu	공동	대학
	국민대학교 산학협력단	김환국	조교수	********	rinyfeel@koookmin.ac.kr	공동	대학

연구개발담당자 실무담당자				
성명	이새움	직위	책임연구원	
연락처 직장전화	061-820-1253	휴대전화	********	
연락처 전자우편	sprout2@kisa.or.kr	국가연구자번호	********	

이 최종보고서에 기재된 내용이 사실임을 확인하며, 만약 사실이 아닌 경우 관련 법령 및 규정에 따라 제재처분 등의 불이익도 감수하겠습니다.

2025 년 02 월 28 일

연구책임자: 김 태 은 (인)
주관연구개발기관의 장: 이 상 중 (직인)
공동연구개발기관의 장: 김 태 수 (직인) / 모비젠

과학기술정보통신부장관 귀하

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

최종보고서

보안등급: 일반[O], 보안[ ]

중앙행정기관명	과학기술정보통신부	사업명 / 세부사업명	정보보호핵심원천 기술개발사업
전문기관명	정보통신기획평가원	내역사업명	
공고번호	제2020-0755호	총괄연구개발 식별번호 (해당 시 작성)	
		연구개발과제번호	

기술분류								
국가과학기술 표준분류	EE0302	50%	EE0303	30%	EE0301	20%		
ICT 기술분류	SEC0106	80%	SEC0103	10%	SEC0201	10%		

총괄연구개발명 (해당 시 작성)	국문				
	영문				
연구개발과제명	국문	AI·빅데이터 기반 사이버 보안 오케스트레이션 및 자동 대응 기술 개발			
	영문	AI·Big data based Cyber Security Orchestration and Automated Response Technology Development			
주관연구개발기관	기관명	한국인터넷진흥원	사업자등록번호	135-82-07931	
	주소	(58324)전남 나주시 진흥길 9	법인등록번호	244271-0006001	
연구책임자	성명	김태은	직위	책임연구원	
	연락처 직장전화	061-820-1273	휴대전화	********	
	연락처 전자우편	tekim31@kisa.or.kr	국가연구자번호	********	

연구개발기간	전체		2021. 04. 01. - 2024. 12. 31. (3년 9개월)
	단계 (해당 시 작성)	1단계	2021. 04. 01. - 2022. 12. 31. (1년 9개월)
		2단계	2023. 01. 01. - 2024. 12. 31. (2년 -개월)

연구개발비 (단위: 천원)		정부지원 연구개발비	기관부담 연구개발비		그 외 기관 등의 지원금				합계			연구개발비 외 지원금
					지방자치단체		기타( )					
		현금	현금	현물	현금	현물	현금	현물	현금	현물	합계	
총계		8,715,000	88,660	1,302,329					8,803,660	1,302,329	10,105,989	
1단계	1년차	1,900,000	16,300	292,200					1,916,300	292,200	2,208,500	
	2년차	2,500,000	20,100	367,400					2,520,100	367,400	2,887,500	
2단계	1년차	2,500,000	23,300	297,748					2,523,300	297,748	2,821,048	
	2년차	1,815,000	28,960	344,981					1,843,960	344,981	2,188,941	

공동연구개발기관 등 (해당 시 작성)	기관명	책임자	직위	휴대전화	전자우편	역할	기관유형
공동연구개발기관	한국과학기술정보연구원	송중석	센터장	********	song@kisti.re.kr	공동	정부출연연
	㈜시큐레이어	김건우	본부장	********	kunwoo.kim@seculayer.com	공동	중소기업
	㈜윈스	주은영	이사	********	expect@wins21.co.kr	공동	중소기업
	㈜모비젠	박관영	팀장	********	kypark@mobigen.com	공동	중소기업
	성균관대학교 산학협력단	박은일	조교수	********	eunilpark@skku.edu	공동	대학
	국민대학교 산학협력단	김환국	조교수	********	rinyfeel@koookmin.ac.kr	공동	대학

연구개발담당자 실무담당자	성명	이새움	직위	책임연구원	
	연락처 직장전화	061-820-1253	휴대전화	********	
	연락처 전자우편	sprout2@kisa.or.kr	국가연구자번호	********	

이 최종보고서에 기재된 내용이 사실임을 확인하며, 만약 사실이 아닌 경우 관련 법령 및 규정에 따라 제재처분 등의 불이익도 감수하겠습니다.

2025 년 02 월 28 일

연구책임자: 김 태 은 (인)

주관연구개발기관의 장: 이 상 중 (직인)

공동연구개발기관의 장: 구 자 춘 (직인) / 성균관대학교 산학협력단

과학기술정보통신부장관 귀하

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

최종보고서

보안등급: 일반[O], 보안[ ]

중앙행정기관명	과학기술정보통신부	사업명	세부사업명	정보보호핵심원천 기술개발사업	
전문기관명	정보통신기획평가원		내역사업명		
공고번호	제2020-0755호	총괄연구개발 식별번호 (해당 시 작성)			
		연구개발과제번호			

기술분류								
국가과학기술 표준분류	EE0302	50%	EE0303	30%	EE0301	20%		
ICT 기술분류	SEC0106	80%	SEC0103	10%	SEC0201	10%		

총괄연구개발명 (해당 시 작성)	국문			
	영문			
연구개발과제명	국문	AI·빅데이터 기반 사이버 보안 오케스트레이션 및 자동 대응 기술 개발		
	영문	AI·Big data based Cyber Security Orchestration and Automated Response Technology Development		
주관연구개발기관	기관명	한국인터넷진흥원	사업자등록번호	135-82-07931
	주소	(58324)전남 나주시 진흥길 9	법인등록번호	244271-0006001
연구책임자	성명	김태은	직위	책임연구원
	연락처 직장전화	061-820-1273	휴대전화	********
	연락처 전자우편	tekim31@kisa.or.kr	국가연구자번호	********
연구개발기간	전체	2021. 04. 01. - 2024. 12. 31. (3년 9개월)		
	단계 (해당 시 작성) 1단계	2021. 04. 01. - 2022. 12. 31. (1년 9개월)		
	단계 (해당 시 작성) 2단계	2023. 01. 01. - 2024. 12. 31. (2년 -개월)		

연구개발비 (단위: 천원)		정부지원 연구개발비	기관부담 연구개발비		그 외 기관 등의 지원금				합계			연구개발비 외 지원금
					지방자치단체		기타( )					
		현금	현금	현물	현금	현물	현금	현물	현금	현물	합계	
총계		8,715,000	88,660	1,302,329					8,803,660	1,302,329	10,105,989	
1단계	1년차	1,900,000	16,300	292,200					1,916,300	292,200	2,208,500	
	2년차	2,500,000	20,100	367,400					2,520,100	367,400	2,887,500	
2단계	1년차	2,500,000	23,300	297,748					2,523,300	297,748	2,821,048	
	2년차	1,815,000	28,960	344,981					1,843,960	344,981	2,188,941	

공동연구개발기관 등 (해당 시 작성)	기관명	책임자	직위	휴대전화	전자우편	역할	기관유형
공동연구개발기관	한국과학기술정보연구원	송중석	센터장	********	song@kisti.re.kr	공동	정부출연연
	㈜시큐레이어	김건우	본부장	********	kunwoo.kim@seculayer.com	공동	중소기업
	㈜윈스	주은영	이사	********	expect@wins21.co.kr	공동	중소기업
	㈜모비젠	박관형	팀장	********	kypark@mobigen.com	공동	중소기업
	성균관대학교 산학협력단	박은일	조교수	********	eunilpark@skku.edu	공동	대학
	국민대학교 산학협력단	김환국	조교수	********	rinyfeel@koookmin.ac.kr	공동	대학

연구개발담당자 실무담당자	성명	이새움	직위	책임연구원	
	연락처 직장전화	061-820-1253	휴대전화	********	
	연락처 전자우편	sprout2@kisa.or.kr	국가연구자번호	********	

이 최종보고서에 기재된 내용이 사실임을 확인하며, 만약 사실이 아닌 경우 관련 법령 및 규정에 따라 제재처분 등의 불이익도 감수하겠습니다.

2025 년 02 월 28 일

연구책임자: 김 태 은 (인)
주관연구개발기관의 장: 이 상 중 (직인)
공동연구개발기관의 장: 이 인 형 (직인) /국민대학교 산학협력단

과학기술정보통신부장관 귀하

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

< 요 약 문 >

※ 요약문은 5쪽 이내로 작성합니다.

세부사업명		정보보호핵심원천 기술개발사업			총괄연구개발 식별번호 (해당 시 작성)			
내역사업명					연구개발과제번호		2021-0-00358	
기술분류	국가과학기술 표준분류	EE0302	50%	EE0303	30%	EE0301	20%	
	ICT 기술분류	SEC0106	80%	SEC0103	10%	SEC0201	10%	
총괄연구개발명 (해당 시 작성)								
연구개발과제명		AI·빅데이터 기반 사이버 보안 오케스트레이션 및 자동 대응 기술 개발						
전체 연구개발 기간		2021. 04. 01. - 2024. 12. 31.						
총 연구개발비		총 9,988,265 천원 (정부지원연구개발비 : 8,650,000 천원, 기관부담연구개발비 : 1,338,265 천원)						
연구개발단계		기초[ ] 응용[√] 개발[ ] 기타(위 3가지에 해당되지 않는 경우)[ ]			기술성숙도 (해당 시 기재)		착수시점 기준(4) 종료시점 목표(6)	
연구개발과제 유형 (해당 시 작성)		-						
연구개발과제 특성 (해당 시 작성)		-						

연구개발 목표 및 내용

최종 목표

o 보안관제센터의 탐지 - 위협분석 - 대응 全 업무 프로세스를 자동화하는 보안관제 오케스트레이션 및 대응 자동화 기술 개발

- (연동·탐지) 이기종 보안 장비 연동 API(공개) 및 이상행위 탐지 기술
- (위협분석·자동화) 빅데이터 기반 全 주기적 사이버 보안관제 업무 프로세스를 위한 플레이북 생성 및 자동화 기술
- (의사결정) SOC에 특화된 AI 기반 보안사고 대응 의사결정 지원 및 판단 기술
- (대응) 이기종 보안 장비의 보안사고 자동 대응 기술
- (실증) 보안관제센터 대상 보안관제 오케스트레이션 및 대응 자동화 기술 실증

<최종 목표 기술의 구성도>

전체 내용

o 최종 목표 결과물 및 주요 기능

- **(연동·탐지)** 이기종 보안 장비 연동 API 및 이상행위 탐지 기술
  - · 이기종 보안 장비 데이터 수집 및 보안 정책 적용 API
  - · 보안관제 빅데이터 기반 이기종 보안 장비 데이터의 정규화·분류 및 이상행위 탐지
  - · AI·빅데이터 기반 이기종 보안 장비 이상행위 탐지 성능 향상
  - · 국내외 공개 보안 위협 인텔리전스 정보 수집
- **(위협분석·자동화)** 빅데이터 기반 全 주기적 사이버 보안관제 업무 프로세스를 위한 플레이북 생성 및 자동화 기술
  - · 공개 보안 위협 인텔리전스 정보 및 MITRE ATT&CK Matrix 기반 TTP 생성
  - · TTP 정보 기반 이상행위 탐지 자산의 분석 방법·절차 및 위협 인자 식별
  - · 보안 관제 플레이북 자동 생성·실행·검증·관리 기술

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- **(의사결정)** SOC에 특화된 AI 기반 보안사고 대응 의사결정 지원 및 판단 기술
  · 플레이북을 통한 자동화 분석 절차의 관리 및 시각화
  · 이기종 보안 장비 데이터 및 TTP 정보의 연관정보 가시화
  · 신속한 의사결정 지원을 위한 고성능 AI 분석 모델 및 활용
  · AI 기반 최적 의사결정 자동 추천 및 대응 정책 관리·검증
- **(대응)** 이기종 보안 장비의 보안사고 자동 대응 기술
  · 이기종 보안 장비의 보안사고 자동 대응(탐지·차단 정책 적용) 및 검증
  · 사이버 보안관제 업무 프로세스 전반에 대한 정량적 측정
  · SOC 통합 운영 및 자동화 플랫폼
- **(실증)** 공공·민간 SOC 대상 보안관제 오케스트레이션 및 대응 자동화 기술 실증
  · 이기종 보안 장비 연동 → 이상 탐지 → 분석 자동화 → 의사결정 → 대응 全 과정의 요소기술 실증 ☞ **공공 보안관제센터 실데이터(탐지·분석·대응) 활용**
  · 국가과학기술연구망(KREONET)을 활용한 SOC 통합 운영 및 자동화 플랫폼 실증
  · 공공·민간 보안관제센터와 협업을 통한 SOC 통합 운영 및 자동화 플랫폼 실증

o 주요 성능치

주요성능	단위	개발 목표치			
		1차년도 (2021년)	2차년도 (2022년)	3차년도 (2023년)	4차년도 (2024년)
AI 기반 이상행위 탐지 정확도	AUC	0.75	0.85	0.90	0.95
침해사고 대응 절차 자동화 수행 시간	분	-	-	25	15
보안 위협 분석 및 대응 플레이북	개	-	200	450	720
최적 의사결정을 위한 이벤트 중요도 산정/분류 정확도	Accuracy	-	-	0.75	0.85

o 핵심 기술

- AI·빅데이터 기반 보안 위협 이상행위 탐지 기술 (세계 Top 1위)
- TTP 기반 보안 위협 대응 플레이북 자동 생성·관리 기술 (세계 Top 2위)
- AI 기반 보안사고 대응 의사결정 지원 및 판단 기술 (국내 최초)
- 이기종 보안 장비 자동 대응(정책 적용) 기술 (국내 최초)

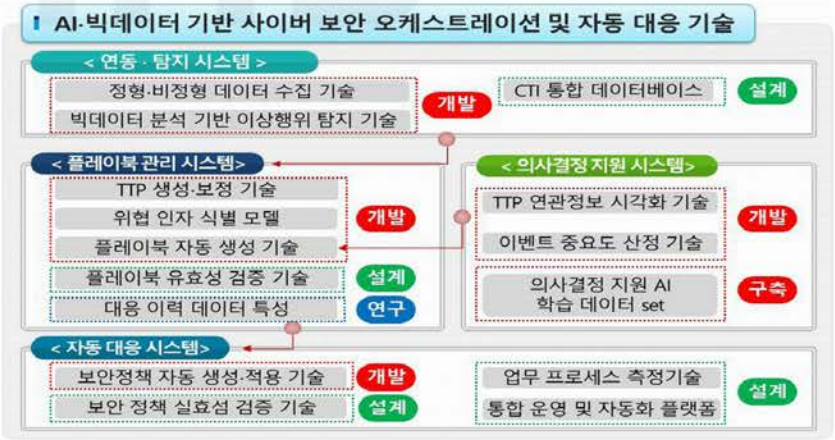
1단계

목표

<1단계 주요 목표 : 원천기술 확보>

· 1차년도 목표: 보안관제 프로세스 자동화 핵심 원천기술 연구·설계

· 2차년도 목표: 보안관제 프로세스 자동화 핵심 원천기술 개발



<1단계 연구·개발 목표>

o 보안관제센터의 탐지 – 위협분석 – 대응 全 업무 프로세스를 자동화하는 보안관제 오케스트레이션 및 대응 자동화 요소기술 개발

- (연동·탐지) 보안 관제 빅데이터 연관분석 기반 이상행위 탐지 기술
- (위협분석·자동화) TTP 기반 위협 인자 식별 및 위협 대응 플레이북 자동 생성 요소 기술
- (의사결정) SOC에 특화된 시각화 및 AI 기반 의사결정 요소 기술
- (대응) 보안사고 자동 대응 및 검증 요소 기술

내용

o 1단계 목표 결과물 및 주요 기능

- **(연동·탐지)** 보안 관제 빅데이터 연관분석 기반 이상행위 탐지 기술
  · 이기종 보안 장비 데이터 수집 및 보안 정책 적용 기능
  · 보안 관제 빅데이터 기반 이상행위 탐지 기능
- **(위협분석·자동화)** TTP 기반 위협 인자 식별 및 위협 대응 플레이북 자동 생성 요소 기술
  · TTP 정보 기반 이상행위 탐지 자산의 분석 방법·절차 및 위협인자 식별 기능

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

· 보안 관제 환경 및 템플릿 기반 플레이북 자동 생성 기능
– **(의사결정)** SOC에 특화된 시각화 및 AI 기반 의사결정 요소 기술
· TTP 연관정보 및 플레이북 시각화·관리 기능
· 신속한 의사결정 지원을 위한 AI 분석 데이터셋 구축
· AI 기반 최적 의사결정 자동 추천 기능
– **(대응)** 보안사고 자동 대응 및 검증 요소 기술
· 이기종 보안 장비별 보안 정책(탐지·차단) 자동 생성·적용 기능
· 보안관제 업무 프로세스 평가를 위한 정량적 측정 기능

o **주요 성능치**

주요성능	단위	개발 목표치	
		1차년도 (2021년)	2차년도 (2022년)
AI 기반 이상행위 탐지 정확도	AUC	0.75	0.85
보안 위협 분석 및 대응 플레이북	개	–	200

2단계

목표

<2단계 주요 목표 : 응용연구 및 실증>
· **3차년도 목표 : SOC 통합 운영 및 자동화 플랫폼 개발 및 요소기술 실증**
· **4차년도 목표 : 성능 고도화(알고리즘·AI 등) 및 통합 플랫폼 실증**

<2단계 연구·개발 목표>

o **보안관제센터의 탐지 – 위협분석 – 대응 全 업무 프로세스를 자동화하는 보안관제 오케스트레이션 및 대응 자동화 기술 개발 + 실증**
– (연동·탐지) 이기종 보안 장비 연동 API(공개) 및 이상행위 탐지 기술
– (위협분석·자동화) 빅데이터 기반 全 주기적 사이버 보안관제 업무 프로세스를 위한 플레이북 생성 및 자동화 기술
– (의사결정) SOC에 특화된 AI 기반 보안사고 대응 의사결정 지원 및 판단 기술
– (대응) 이기종 보안 장비의 보안사고 자동 대응 기술

내용

o **주요 기능(또는 규격)**
– **(연동·탐지)** 이기종 보안 장비 연동 API(공개) 및 이상행위 탐지 기술
· 이기종 보안 장비 데이터 수집 및 보안 정책 적용 API
· 보안 관제 빅데이터 기반의 이기종 보안 장비 데이터 정규화·분류 및 이상행위 탐지(연관 분석) 기능
· AI·빅데이터 기반 이기종 보안 장비 이상행위 탐지 성능 향상
· 국내외 공개 보안 위협 인텔리전스 정보 수집 기능
– **(위협분석·자동화)** 빅데이터 기반 全 주기적 사이버 보안관제 업무 프로세스를 위한 플레이북 생성 및 자동화 기술
· 공개 보안 위협 인텔리전스 정보(KrCERT 분석 보고서, OSINT 등) 및 MITRE ATT&CK Matrix 기반 TTP 생성 기능
· TTP 정보 기반 이상행위 탐지 자산의 분석 방법·절차 및 위협 인자 식별 기능
· 보안 관제 플레이북 자동 생성·실행·검증·관리 기술
– **(의사결정)** SOC에 특화된 AI 기반 보안사고 대응 의사결정 지원 및 판단 기술
· 플레이북을 통한 자동화 분석 절차 관리 및 시각화 기능
· 이기종 보안 장비 데이터 및 TTP 정보의 연관정보 가시화 기능
· 신속한 의사결정 지원을 위한 고성능 AI 분석 모델 및 활용 기능
· AI 기반 최적 의사결정 자동 추천 및 대응 정책 관리·검증 기능

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- **(대응)** 이기종 보안 장비의 보안사고 자동 대응 기술
  · 이기종 보안 장비의 보안사고 자동 대응 및 검증 기능
  · 사이버 보안관제 업무 프로세스 전반에 대한 정량적 측정 기능
  · SOC 통합 운영 및 자동화 플랫폼
- **(실증)** SOC 대상 보안관제 오케스트레이션 및 대응 요소 기술 실증
  · 이기종 보안 장비 연동·탐지 및 자동 대응 요소 기술 실증
  · 보안 관제 플레이북 자동 생성 및 의사결정 자동 추천 기술 실증
  · 국가과학기술연구망을 활용한 SOC 통합 플랫폼 요소기술 실증

o 주요 성능치

주요성능	단위	개발 목표치	
		3차년도 (2023년)	최종 (2024년)
AI 기반 이상행위 탐지 정확도	AUC	0.90	0.95
침해사고 대응 절차 자동화 수행 시간	분	25	15
보안 위협 분석 및 대응 플레이북	개	450	720
최적 의사결정을 위한 이벤트 중요도 산정/분류 정확도	Accuracy	0.75	0.85

연구개발성과

□ **정성적 연구개발 성과**

o 이기종 보안장비 연동 API 공개 및 이상행위 탐지 모델 고도화 (완료,100%)
- 이기종 보안 장비 데이터 정규화 및 대응 정책 적용 API 개발 · 공개
- AI · 빅데이터 기반 이기종 보안 장비 이상행위 탐지 성능 향상 기술 고도화 개발
- 공개 보안 위협 인텔리전스 정보 수집 기술 고도화

o 보안 위협 분석 및 대응을 위한 플레이북 자동 생성 기술 고도화 (완료,100%)
- 보안 관제 플레이북 자동 생성 기술 고도화
- 보안 관제 플레이북 검증 · 관리 기술 고도화

o AI 기반 의사결정 추천 기술 및 분석 모델 고도화 (완료,100%)
- AI 기반 최적 의사결정 자동 추천 기술 고도화
- 사이버 보안관제 업무 프로세스 평가 및 정량적 측정 기술 개발

o SOC 통합 운영 및 자동화 플랫폼 고도화 (완료,100%)
- SOC 통합 운영 및 자동화 플랫폼 실증 기반 고도화

o AI·빅데이터 기반 사이버 보안 오케스트레이션 및 자동 대응 통합 기술 실증 (완료,100%)
- 보안관제센터 오케스트레이션 및 자동 대응 플랫폼의 보안관제센터 실증

<정량 성과지표별 기대효과>

성과지표명	최종 성과 (2021~2024)
논문 평균 mrnIF	69.37
국내 특허 출원	19건
국내 특허 등록	12건
국제 특허 출원	9건
국제 특허 등록	2건
소프트웨어 등록	16건
특허 등급	BB
기술이전	37건
기술료	303백만원
시제품	15건
기술문서	43건
성과홍보	14건

연구개발성과 활용계획 및 기대 효과

o 활용계획

① K-사이버방역 등의 정부 정책과 연계하여 민간분야 보안 사각지대 해소를 위해 활용
- **(정책적 활용)** 국가 CERT의 침해사고대응을 위한 분석·대응 환경의 자동화 및 중소기업의 사이버공격 대응을 위한 관제 서비스 지원
- **(공공·민간 활용)** 사이버 침해사고 공동대응 업무협약을 맺은 유관기관 등 보안관제센터를 운영하는 기관을 통한 기술 실증 및 보급·확산을 통한 기술 활용

② 공동연구개발기관에서 운영하는 보안관제센터 등에 직접 활용
- 사이버 보안 자동대응 통합 플랫폼에 대한 최적의 성능·검증을 위해 공동연구개발기관

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

에서 운영하는 보안관제센터를 통한 실증환경 구축 및 활용
- 사이버 보안 자동대응 기술개발을 통해 획득한 위협정보 및 AI 이상행위 탐지 기술 등을 官/産/學/研 에 공유하여 국가 차원의 사이버 안보 공동연구체계 구축에 활용
- 국가사이버안보센터 및 각급 보안관제센터를 중심으로 지능화된 사이버공격에 대한 대응력 향상을 위하여 보안관제 全 업무 프로세스를 자동화하는데 활용

③ 통합 자동관제 침해 대응 자동화 플랫폼을 활용한 관제 서비스 제공 사업화
- (사업화–관제 서비스) 통합 자동관제 기반의 침해 대응 자동화 플랫폼을 이용한 관제 서비스 제공 ☞ 예상 수요처 : 기존 보안관제센터 390개 고객사 및 이통사 등

④ AI·빅데이터 기반의 SOAR 제품을 활용하여 내부 정보 유출방지, 금융 이상거래 탐지 및 자동화 대응 시스템의 사업화
- (사업화–내부 정보 유출 방지) 내부자에 의한 개인정보 유출 및 조직 내부 중요 정보에 대한 유출 탐지와 자동화 대응을 수행하는 SOAR 시스템
- (사업화–금융 이상거래 탐지 및 자동화 대응) 금융 거래 시 빅데이터 기반의 이상거래를 탐지하는 AI 기술을 도입하고 추가인증, 거래 차단과 같은 대응을 자동화하는 금융 이상거래 탐지 및 대응 시스템으로의 활용

o 기대효과

① 기술적 측면
- 공공 보안관제, 연구기관, 산업계의 연구·개발 협업을 통한 순환 구조[수요자 기술 요구 → 연구·개발 → 실증 → 상용화] 기반의 **국가 기술 경쟁력 확보**
- AI 기반 이상행위 탐지 기술, 보안관제 全 업무 프로세스 자동화 연구 결과의 상용화로 국가 인프라 보안을 위한 보안관제센터 핵심**기술 국산화**
- 수천만 건의 사이버 위협정보를 실시간으로 판별 및 보안관제 운영 자동화를 이루어 기존 인력 기반 체계에서 AI 시스템 기반의 **新 정보보호 시장 개척** 기대
- AI·빅데이터 기반으로 신·변종적인 이상행위 공격에 대해 신속·정확하게 대응이 가능하여 **선제적으로 사이버 위협을 예방**하는 善순환 효과를 기대

② 경제적·산업적 측면
- 연구·개발 완료 후 정책적 기술 보급·활용 단계에서 기술개발 참여기업 및 기술이전 기업의 사업 참여 확대를 통해 **보안 산업육성** 기대
- 본 과제의 경쟁 분야인 사이버 보안 관제 오케스트레이션 및 자동 대응 시장에서 연구 결과물을 활용한 선도적인 기술을 기반으로 세계 보안관제 시장에서 약 3,000억 규모의 **경제적 파급효과 창출** 전망

③ 사회적 측면
- **(국민 편익)** 지능화된 사이버 위협의 선제적 대응으로 관제 사각지대(민간 소외 중소기업 등) 피해 최소화, 원천기술 확보를 통한 해외 기술 사용료 절감 등 기대
- 이기종 보안장비 위협 인텔리전스 정보를 기반으로 현재와 미래 위협에 대한 선제적·입체적 대응을 통해 **보안수준을 향상하고 국가 신뢰도 제고**에 기여
- 고성능 AI 기반 이상행위 탐지 기술을 토대로 신속·정확한 사이버 위협분석을 통해 보안사고 복구에 소요되는 막대한 **사회적 비용 절감**에 기여
- 공공·민간에서 보안관제센터를 운영하고 있는 기관의 보안관제 품질을 향상시킴으로써 **보안관제 산업 구조를 개선**할 수 있음(인력 양성 및 전문성 향상 등)

연구개발성과의 비공개여부 및 사유	–

연구개발성과의 등록·기탁 건수	논문	특허	보고서 원문	연구시설·장비	기술요약 정보	소프트웨어	표준	생명자원		화합물	신품종	
								생명정보	생물자원		정보	실물

연구시설·장비 종합정보시스템 등록 현황	구입기관	연구시설·장비명	규격(모델명)	수량	구입연월일	구입가격(천원)	구입처(전화)	비고(설치장소)	ZEUS 등록번호

국문핵심어 (5개 이내)	보안 관제	인공지능	빅 데이터	자동화	위협 분석
영문핵심어 (5개 이내)	Security Monitoring	Artificial Intelligence	Big data	Automation	Threat analysis

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

<목 차>

1. 연구개발과제의 개요..... 16

2. 연구개발과제의 수행 과정 및 수행 내용..... 18

3. 연구개발과제의 수행 결과 및 목표 달성 정도..... 379

4. 목표 미달 또는 미흡한 사항에 대한 원인분석 399

5. 연구개발성과의 관련 분야에 대한 기여 정도..... 399

6. 연구개발성과의 관리 및 활용 계획..... 400

7. 연구개발성과에 대한 후속연구 및 추가 개발 계획 407

8. 연구개발비 사용실적 408

붙임1. 사업화대상기술별 기술명세서..... 416

붙임2. 자체 보안관리 진단표..... 425

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

1. 연구개발과제의 개요

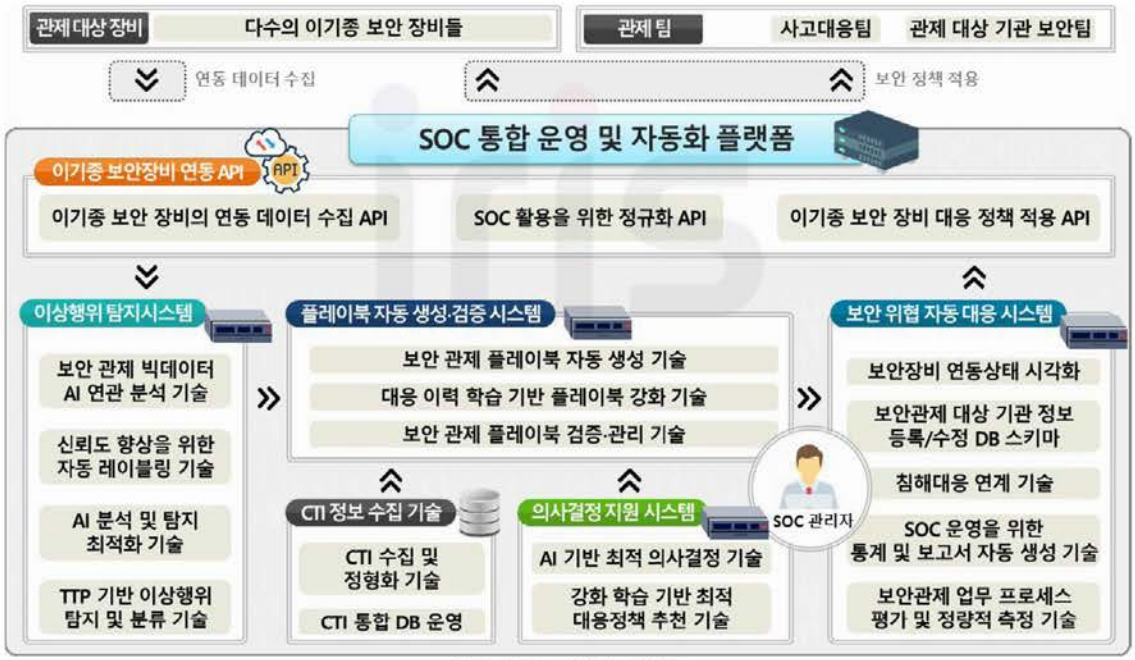
1) 기술의 개념

o 사이버공격에 대한 선제적 대응을 위해 **보안관제센터(SOC : Security Operation Center)** 全 **업무 프로세스의 자동화(탐지→위협분석→대응)** 및 **대규모 사이버 위협 의심 정보를 자동 분류·대응** 할 수 있는 사이버 보안 자동 대응(오케스트레이션) 기술 개발을 목적으로 함

※ SOAR(Security Orchestration, Automation and Response) : IT 보안 분야의 숙련된 기술자 부족으로 신속한 침해사고 발생 시 즉각적으로 대응할 수 있는 자동화 기술이 대안으로 제시됨(Gartner, 2017)

- **(주요 기능)** ①보안관제 업무 통합 관리 및 반복적인 업무의 자동화 수행(SOA)
  ②보안 위협 대응에 필요한 표준 절차 제공 및 자동 대응 연계(SIRP)
  ③보안 위협 인텔리전스 정보를 활용한 위험도 산정 및 취약 자산 탐지(TIP)
  ④다양한 보안관제 활용 솔루션(탐지, 차단 제품 등) 연동

※ SOA : Security Orchestration and Automation / SIRP : Security Incident Response Platforms / TIP : Threat Intelligence Platforms



<최종 목표 기술의 구성도>

2) 기술 개발 배경 및 필요성

o **(보안위협의 진화)** 사이버 보안 위협은 '20년 전후하여 대규모 테라급 공격으로 규모가 확대되고, AI 등 신기술로 무장한 5세대 사이버공격으로 진화함

- 공격자는 AI를 적용한 도구를 활용하여 공격 비용의 감소와 공격의 속도 향상을 바탕으로 한 정교한 사이버 공격을 수행
- 테라급의 정교한 사이버 공격에 대응하기 위한 전문 보안 인력 및 기술력은 부족한 상황으로, 문제 해결을 위해 빅데이터와 AI 기술을 활용한 보안 기술이 요구됨

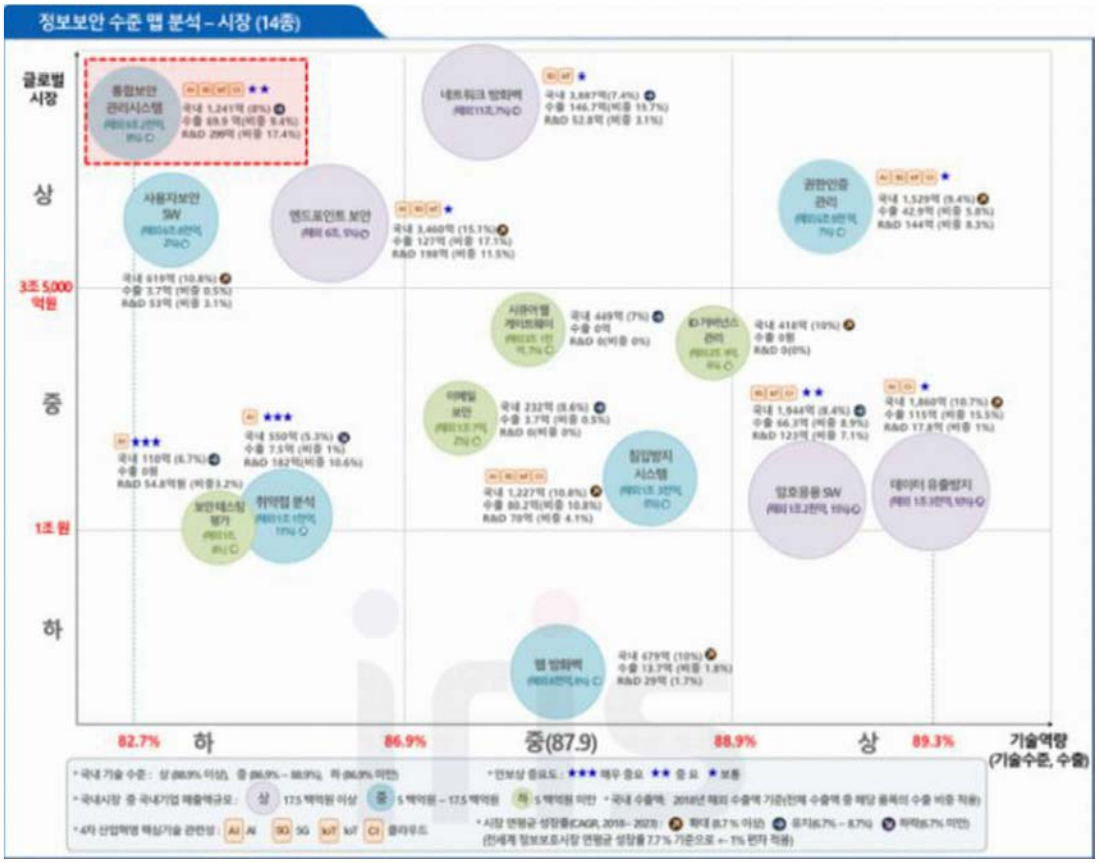
o **(정보보호 기술 경쟁력)** 보안관제와 관련된 통합보안 관리시스템의 기술 수준은

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

'상' 으로 기술력이 높고 규모가 큰 반면, 국내 통합보안 관리시스템 분야의 기술 수준은 '하' 로 기술력이 낮으며 수출 규모가 낮은 것으로 분석됨 ☞ **AI 도입 지연**

※ "중기(2020-2022) 정보보호 R&D 투자 전략(안)", (과학기술정보통신부, 2020)

- 글로벌 시장에서는 '18년도부터 공공, 금융, 제조 등 다양한 분야에서 SOAR에 대한 관심이 높아지고 있으나, 국내 환경에서는 도입 및 기술 검증이 부족함



<글로벌 시장 대비 국내 기술 수준 맵, 과학기술정보통신부(2020)>

o **(정부 정책)** 신규 정보통신시설(스마트시티, 자율주행차 등)에 대한 보안관제 확대 등 따라 국가 사이버 위협 대응력 강화를 위한 사이버 보안관제 자동화(SOAR) 원천기술 확보 필요 ☞ **K-사이버방역**

- 지능화된 사이버 위협에 대한 선제적 대응으로 관제 사각지대(민간 소외 중소기업 등) 피해 최소화, 원천기술 확보를 통한 해외 기술 사용료 절감, 기술 국산화를 통한 국내 시장 활성화 필요

< 디지털 뉴딜 4대 분야 12개 추진과제 >

D.N.A. 생태계 강화	교육인프라 디지털 전환	비대면 산업 육성	SOC 디지털화
① 데이터 구축·개방·활용	⑤ 초중고 디지털 기반 교육 인프라 조성	⑦ 스마트 의료·돌봄 인프라	⑩ 4대 분야 핵심인프라 디지털 관리체계 구축
② 전 산업 5G·AI 융합 확산	⑥ 전국 대학, 직업훈련기관 온라인 교육 강화	⑧ 중소기업 원격근무 확산	⑪ 도시산단 공간 디지털 혁신
③ 5G·AI 기반 지능형(AI) 정부		⑨ 소상공인 온라인 비즈니스 지원	⑫ 스마트 물류체계 구축
④ K-사이버 방역 체계			

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

2. 연구개발과제의 수행 과정 및 수행 내용

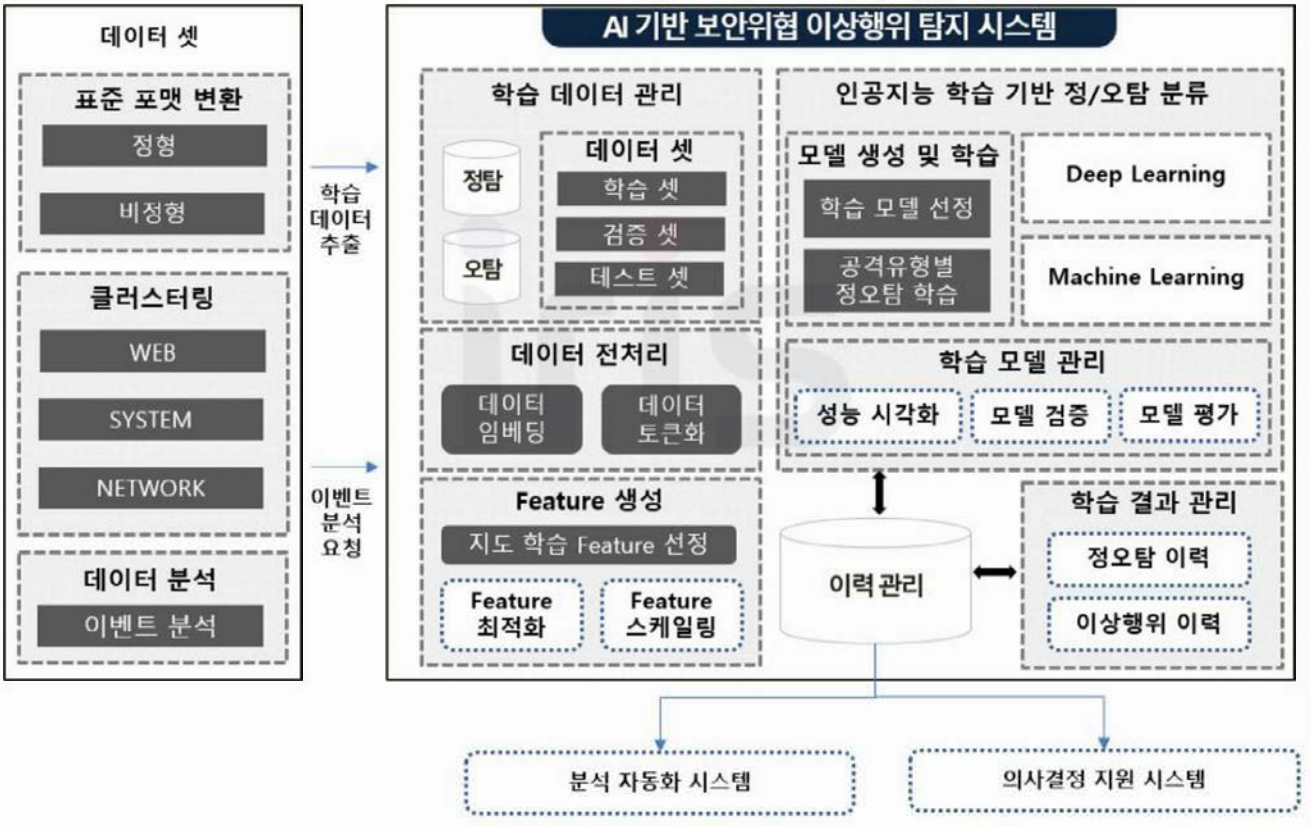
2-1. 1차년도 연구 수행 내용 및 성과

상세 추진 내용 ① 이기종 보안장비 연동 및 보안위협 이상행위 탐지 기술

□ 개발 기술 개요

o (개발목표) 이기종 보안 장비 연동 및 이상행위 탐지 기술 설계 및 개발

1) 이기종 보안 장비 데이터 수집 및 보안 정책 적용 기술 연구 및 설계
2) 보안 관제 빅데이터 기반 이상행위 탐지 요소 기술 설계 및 개발
3) AI·빅데이터 기반 이기종 보안 장비 이상행위 탐지 성능 향상 기술 연구
4) 공개 보안 위협 인텔리전스 기반 침해사고 지표 정보 수집 연구



〈시스템 개념도〉

o (추진실적) 이기종 보안 장비 연동 및 이상행위 탐지 요소 기술 설계 및 개발

- 이기종 보안 장비 데이터 수집 및 보안 정책 적용 기술 연구 완료 개발목표 1
- 보안 관제 빅데이터 기반 이상행위 탐지 요소 기술 설계 완료 개발목표 2
- 보안 관제 빅데이터 기반 이상행위 탐지 요소 기술 개발 중 개발목표 2
- AI·빅데이터 기반 이기종 보안 장비 이상행위 탐지 성능 향상 기술 연구 완료 개발목표 3
- 공개 보안 위협 인텔리전스 기반 침해사고 지표 정보 수집 연구 완료 개발목표 4

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

□ 이기종 보안 장비 데이터 수집 및 보안 정책 적용 기술 연구

연구목표	이기종 보안 장비 데이터 수집 및 보안 정책 적용 기술 연구

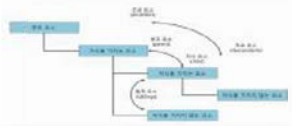
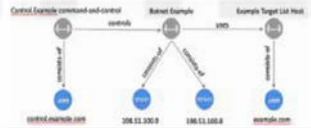
세부 내용	1) 표준 연동 프로토콜(XML, STIX2.1, RDF 등) 규격 및 특징 연구
	2) 이기종 보안 장비의 정형·비정형 데이터 종류 및 특징 연구
	3) 정형·비정형 데이터 수집 및 보안 정책 적용 기술 연구 및 설계

□ 이기종 보안 장비 데이터 수집 및 보안 정책 적용 기술 연구 세부 내용

1) 표준 연동 프로토콜(XML, STIX2.1, RDF 등) 규격 및 특징 연구

o 표준 연동 프로토콜의 규격 및 특징 분석

<표준 연동 프로토콜별 특징 분석>

XML (eXtensible Markup Language)	STIX (Structured Threat Information eXpression)	RDF (Resource Description Framework)
• W3C 표준 권고안으로 텍스트 기반의 마크업 언어 • 다른 시스템끼리 손쉽게 데이터 교환 가능 • 확장성이 높음 • 데이터를 전달하고 저장하는 목적 • 트리 구조로 구성됨	• OASIS에서 발표 • 사이버 위협 정보를 표현하는 표준화된 언어 • '19년 7월 2.1 규격 나옴 • JSON 포맷으로 작성 • STIX 2.0에 신규 오브젝트 및 피처 등이 추가	• W3C에서 정의 • 웹 Resource에 대한 Metadata 표현 • 그래프 구조를 가짐 • Turtle, XML로 표현
		

o STIX 2.1 특징 연구

- 18개의 도메인 개체로 정의
- 새로운 개체 추가됨 (그룹화, 인프라, 국제화, 위치, 악성코드 분석, 참고, 의견)
- 새로운 개념 추가 (자신감)
- 특정 개체 속성이름 충돌 보완 (디렉토리, 파일, 프로세스, 레지스트리)
- 악성코드 및 모든 SCO(Stix Cyber-observable Objects)의 중대 변화
- 도메인, IPv4-addr, IPv6-addr에서 일부 SCO 관계를 참조화
- STIX 2.1에 대한 상세 분석 수행
  - ·STIX 2.0 대비 그룹화, 인프라, 국제화, 위치, 악성코드 분석, 참고 의견 등 새로운 개체 추가됨
  - ·STIX 2.0 대비 자신감과 같은 새로운 개념이 추가
  - ·특정 개체 속성 이름 충돌 보완 (디렉토리, 파일, 프로세스, 레지스트리)
  - ·악성코드 및 모든 SCO(STIX Cyber-observable Objects)의 변화
  - ·도메인, IPv4 주소, IPv6 주소에서 일부 SCO 관계를 참조화

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

o STIX 2.1 도메인 개체 중 정책 공유로 활용 가능한 개체

- Indicator

* 패턴 유형으로 활용 가능한 어휘 목록 중 Snort, Yara 패턴 활용 가능

Vocabulary Summary	
stix, pcre, sigma, snort, suricata, yara	
Vocabulary Value	**Description**
stix	Specifies the STIX pattern language defined in section 9.
pcre	Specifies the Perl Compatible Regular Expressions language [PCRE].
sigma	Specifies the SIGMA language.
snort	Specifies the SNORT language [SNORT].
suricata	Specifies the SURICATA language [Suricata].
yara	Specifies the YARA language [YARA].

{
"type": "indicator",
"spec_version": "2.1",
"id": "indicator--8e2e2d2b-17d4-4cbf-938f-98ee46b3cd3f",
"created_by_ref": "identity--f431f809-377b-45e0-aa1c-6a4751cae5ff",
"created": "2021-04-06T20:03:48.000Z",
"modified": "2021-04-06T20:03:48.000Z",
"indicator_types": ["malicious-activity"],
"name": "Poison Ivy Malware",
"description": "This file is part of Poison Ivy",
"pattern": "[file:hashes.'SHA-256' = '4bac27393bdd9777ce02453256c5577cd02275510b2227f473d03f533924f877']",
"pattern_type": "stix",
"valid_from": "2021-01-01T00:00:00Z"
}
{
"type": "indicator",
"spec_version": "2.1",
"id": "indicator--8e2e2d2b-17d4-4cbf-938f-98ee46b3cd3f",
"created_by_ref": "identity--f431f809-377b-45e0-aa1c-6a4751cae5ff",
"created": "2021-04-06T20:03:48.000Z",
"modified": "2021-04-06T20:03:48.000Z",
"indicator_types": ["malicious-activity"],

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

“name“: “Poison Ivy Malware“,
“description“: “This file is part of Poison Ivy“,
“pattern“: “[’alert tcp any any -> any any (content:“ABC“; content:“DEF“; distance:1;)’]“,
“pattern_type“: “snort“,
“valid_from“: “2021-01-01T00:00:00Z“
}
{
“type“: “indicator“,
“spec_version“: “2.1“,
“id“: “indicator--567b201c-4fd5-4bde-a5db-42abc340807a“,
“created_by_ref“: “identity--f431f809-377b-45e0-aa1c-6a4751cae5ff“,
“created“: “2021-06-20T15:16:56.987Z“,
“description“: “This is just an example.“,
“modified“: “2021-06-20T15:16:56.987Z“,
“name“: “silent_banker“,
“pattern“: “\nrule silent_banker : banker\n{\n meta:\n description = \“This is just an example\“\n thread_level = 3\n in_the_wild = true\n\n strings:\n $a = {6A 40 68 00 30 00 00 6A 14 8D 91}\n $b = {8D 4D B0 2B C1 83 C0 27 99 6A 4E 59 F7 F9}\n $c = \“UVODFRYSIHLNWPEJXQZAKCBGMT\“\n\n condition:\n $a or $b or $c\n}\n“,
“pattern_type“: “yara“,
“valid_from“: “2021-06-20T15:16:56.987616Z“
}

o STIX 2.1 SCO 개체중 정책 공유로 활용 가능한 개체
- 평판정보로 공유 가능한 개체
- Domain-name
- URL
- IPv4-addr
- IPv6-addr

Basic FQDN

{
“type“: “domain-name“,
“spec_version“: “2.1“,
“id“: “domain-name--3c10e93f-798e-5a26-a0c1-08156efab7f5“,
“value“: “example.com“,
“resolves_to_refs“: [“ipv4-addr--ff26c055-6336-5bc5-b98d-13d6226742dd“]
}

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

Typical URL


```
{
  “type“: “url“,
  “spec_version“: “2.1“,
  “id“: “url--c1477287-23ac-5971-a010-5c287877fa60“,
  “value“: “https://example.com/research/index.html“
}
```


IPv4 Single Address


```
{
  “type“: “ipv4-addr“,
  “spec_version“: “2.1“,
  “id“: “ipv4-addr--ff26c055-6336-5bc5-b98d-13d6226742dd“,
  “value“: “198.51.100.3“
}
```


IPv4 CIDR Block


```
{
  “type“: “ipv4-addr“,
  “spec_version“: “2.1“,
  “id“: “ipv4-addr--5853f6a4-638f-5b4e-9b0f-ded361ae3812“,
  “value“: “198.51.100.0/24“
}
```


IPv6 Single Address


```
{
  “type“: “ipv6-addr“,
  “spec_version“: “2.1“,
  “id“: “ipv6-addr--1e61d36c-a16c-53b7-a80f-2a00161c96b1“,
  “value“: “2001:0db8:85a3:0000:0000:8a2e:0370:7334“
}
```


IPv6 CIDR block


```
{
  “type“: “ipv6-addr“,
  “spec_version“: “2.1“,
  “id“: “ipv6-addr--5daf7456-8863-5481-9d42-237d477697f4“,
  “value“: “2001:0db8::/96“
}
```

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

2) 이기종 보안 장비의 정형·비정형 데이터 종류 및 특징 연구

o 보안 센서 장비 유형별 로그 정보를 식별하고 특징을 추출하여 정형 데이터로 변환

- 정형 데이터의 특징
  - · 이기종 로그를 하나의 정형화된 포맷으로 관리하므로 분석에 용이
  - · 5 Tuple (source ip, source port, destination ip, destination port, protocol) 기준으로 모니터링이 가능
  - · 각 데이터의 조합으로 일관된 통계 및 보고서를 생성할 수 있음
- 비정형 데이터 예시 (FW 데이터)

<FW의 업체별 로그 정보>

업체별 제품 종류	샘플 로그
Fortigate FW	20170323090913.89591 0 211.37.97.251 <189>date=2017-03-23 time=09:09:39 devname=Work-FW1 devid=FG1K5D3I14802392 logid=0000000013 type=traffic subtype=forward level=notice vd=root srcip=13.14.4.4 srcport=46348 srcintf="port36" dstip=174.20.120.1 dstport=53 dstintf="port34" sessionid=921914784 status=accept policyid=631 dstcountry="Reserved" srccountry="Reserved" trandisp=noop service=DNS proto=17 duration=30 sentbyte=69 rcvdbyte=85 sentpkt=1 rcvdpkt=1
Juniper FW	20170209151810.901089 0 211.43.191.126 <133>MSS_IDC_FW: NetScreen device_id=MSS_IDC_FW [Root]system-notification-00257(traffic): start_time="2017-02-09 15:17:43" duration=1 policy_id=16 service=https proto=6 src zone=V1-Trust dst zone=V1-Untrust action=Permit sent=848 rcvd=1194 src=213.43.191.70 dst=214.108.67.141 src_port=56753 dst_port=443 src-xlated ip=211.43.191.70 port=56753 dst-xlated ip=210.108.67.141 port=443 session_id=116495 reason=Close - TCP FIN
SecuiMF2	20170810095952.87376 0 10.10.240.12 <14>1 2017-08-10T00:59:51.240742Z [fw4_allow] [10.10.240.12]2017-08-10 09:54:37,2017-08-10 09:59:38,301,MD11_E_SPAY_PUB_FW1,46,-,113.111.175.142,,59240,14.63.206.141,443,TCP,EXT,eth8,12,17,2050,13057, ,3Way OK / FIN2 [SAF:SAF],-
Axgate FW	20170307093705.324068 0 211.37.121.164 <134>Mar 07 09:33:14 INCROSS-Tstore kernel: ver:2,stime:2017-03-07 09:33:14,etime:-,src:113.113.178.12,dst:214.205.34.76,sport:41603,dport:5358,action:drop,proto:6,rule_id:0,message:Session denied (in:eth1[untrust]->out:eth0[trust]) (N/A -:-)
Sniper NGFW	<5>1 2021-02-05T15:03:10.707695+09:00 Sniper Sniper - - - [NGFW-LOG@5 company="WINS" timestamp="1612504990.707695" event="1" level="2" user="" sip="213.207.27.12" sport="4562" dip="224.111.126.29" dport="161" nat_sip="" nat_sport="0" nat_dip="" nat_dport="0" protocol="17" mgt_ip="192.168.0.1" desc="Allow(Create) PID[9] ID[32bc]"]

- 비정형 데이터의 특징 분석
  - · 제품별 로그 생성 포맷이 모두 다름
  - · 이기종 장비에서 발생하는 로그는 서로 다른 형태로 작성되어 있기 때문에 자동화된 분석을 수행이 어려움
  - · 동일 필드에 대하여 표현 방식이 상이함

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

<업체별 출발지 IP 표현 양식>

업체별 제품 종류	출발지 IP
Fortigate FW	srcip=13.14.4.4
Juniper FW	src=213.43.191.70
SecuiMF2	“,“ 단위의 구분
AxgateFW	src:113.113.178.12
SniperNGFW	sip=“213.207.27.12“

3) 정형·비정형 데이터 수집 및 보안 정책 적용 기술 연구 및 설계

o 정형/비정형 데이터 수집 기술 연구 및 설계
- 보안센서 장비의 로그 정보는 SNMP Trap, SNMP Get, Syslog 프로토콜로 수집
- 수집된 로그 정보는 빅데이터 처리를 위해 하둡 파일 시스템으로 저장
- 비정형 데이터의 정형화를 위한 필드 파싱 규칙
  - 3가지 룰을 기반으로 필드 파싱 규칙 생성
  - 구분자 기반 : 구분자를 기반으로 데이터를 파싱하여 정형화된 데이터를 생성
  - 텍스트 매칭 기반 : 시작 문자열과 끝 문자열을 지정하고 사이에 있는 데이터를 파싱하여 정형화된 데이터를 생성

timestamp=“1612504990.707695“ [로그값] →
Start pattern: timestamp= “, End pattern: ” [정규화 규칙]
→ 1612504990.707695 [정규화 결과]

  - 구분자 + 텍스트 매칭 기반 : 앞선 두 개의 룰을 모두 적용하여 비정형 데이터를 정형화된 데이터로 생성

o 보안 정책 적용 기술 연구 및 설계
- Indicator 개체 활용 : 패턴 유형으로 활용 가능한 어휘 목록 중 Snort, Yara 패턴 활용 가능

Vocabulary Summary	
stix, pcre, sigma, snort, suricata, yara	
Vocabulary Value	**Description**
stix	Specifies the STIX pattern language defined in section 9.
pcre	Specifies the Perl Compatible Regular Expressions language [PCRE].
sigma	Specifies the SIGMA language.
snort	Specifies the SNORT language [SNORT].
suricata	Specifies the SURICATA language [Suricata].
yara	Specifies the YARA language [YARA].

<Indicator의 pattern_type 정보>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- 각 pattern_type 별 정책 공유 활용 예시

STIX 적용 예시


```
{
  "type": "indicator",
  "spec_version": "2.1",
  "id": "indicator--8e2e2d2b-17d4-4cbf-938f-98ee46b3cd3f",
  "created_by_ref": "identity--f431f809-377b-45e0-aa1c-6a4751cae5ff",
  "created": "2021-04-06T20:03:48.000Z",
  "modified": "2021-04-06T20:03:48.000Z",
  "indicator_types": ["malicious-activity"],
  "name": "Poison Ivy Malware",
  "description": "This file is part of Poison Ivy",
  "pattern": "[ file:hashes.'SHA-256' = '4bac27393bdd9777ce02453256c5577cd02275510b2227f473d03f533924f877' ]",
  "pattern_type": "stix",
  "valid_from": "2021-01-01T00:00:00Z"
}
```


Snort 적용 예시


```
{
  "type": "indicator",
  "spec_version": "2.1",
  "id": "indicator--8e2e2d2b-17d4-4cbf-938f-98ee46b3cd3f",
  "created_by_ref": "identity--f431f809-377b-45e0-aa1c-6a4751cae5ff",
  "created": "2021-04-06T20:03:48.000Z",
  "modified": "2021-04-06T20:03:48.000Z",
  "indicator_types": ["malicious-activity"],
  "name": "Poison Ivy Malware",
  "description": "This file is part of Poison Ivy",
  "pattern": "['alert tcp any any -> any any (content:"ABC"; content:"DEF"; distance:1;)']",
  "pattern_type": "snort",
  "valid_from": "2021-01-01T00:00:00Z"
}
```


Yara 적용 예시


```
{
"type": "indicator",
"spec_version": "2.1",
"id": "indicator--567b201c-4fd5-4bde-a5db-42abc340807a",
  "created_by_ref": "identity--f431f809-377b-45e0-aa1c-6a4751cae5ff",
"created": "2021-06-20T15:16:56.987Z",
"description": "This is just an example.",
"modified": "2021-06-20T15:16:56.987Z",
"name": "silent_banker",
"pattern": "\nrule silent_banker : banker\n{\n meta:\n description = \"This is just an example\"\n thread_level = 3\n in_the_wild = true\n\n strings:\n $a = {6A 40 68 00 30 00 00 6A 14 8D 91}\n $b = {8D 4D B0 2B C1 83 C0 27 99 6A 4E 59 F7 F9}\n $c = \"UVODFRYSIHLNWPEJXQZAKCBGMT\"\n\n condition:\n $a or $b or $c\n}\n",
"pattern_type": "yara",
"valid_from": "2021-06-20T15:16:56.987616Z"
}
```


<Indicator 타입의 pattern_type에 따른 정책 정보 공유 활용 예시>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- STIX 2.1 SCO 개체 중 정책 공유로 활용 가능한 개체
  - 평판 정보로 공유 가능한 개체 식별

FQDN

```
{
 "type": "domain-name",
 "spec_version": "2.1",
 "id": "domain-name--3c10e93f-798e-5a26-a0c1-08156efab7f5",
 "value": "example.com",
 "resolves_to_refs": ["ipv4-addr--ff26c055-6336-5bc5-b98d-13d6226742dd"]
}
```

URL

```
{
 "type": "url",
 "spec_version": "2.1",
 "id": "url--c1477287-23ac-5971-a010-5c287877fa60",
 "value": "https://example.com/research/index.html"
}
```

IPv4

```
{
 "type": "ipv4-addr",
 "spec_version": "2.1",
 "id": "ipv4-addr--ff26c055-6336-5bc5-b98d-13d6226742dd",
 "value": "198.51.100.3"
}
```

IPv4 CIDR

```
{
 "type": "ipv4-addr",
 "spec_version": "2.1",
 "id": "ipv4-addr--5853f6a4-638f-5b4e-9b0f-ded361ae3812",
 "value": "198.51.100.0/24"
}
```

IPv6

```
{
 "type": "ipv6-addr",
 "spec_version": "2.1",
 "id": "ipv6-addr--1e61d36c-a16c-53b7-a80f-2a00161c96b1",
 "value": "2001:0db8:85a3:0000:0000:8a2e:0370:7334"
}
```

IPv6 CIDR

```
{
 "type": "ipv6-addr",
 "spec_version": "2.1",
 "id": "ipv6-addr--5daf7456-8863-5481-9d42-237d477697f4",
 "value": "2001:0db8::/96"
}
```

<평판 정보로 활용 가능한 개체 및 활용 예시>

- TAXII 프로토콜(서버)을 이용한 정보 공유
  - TAXII(Trusted Automated Exchange of Intelligence Information) v2.0은 HTTPS 프로토콜을 기본 통신 프로토콜로 정의
  - 인증서 기반 2-way 상호 인증 기능을 이용한 HTTPS RESTful로 공유 정보의 암호화 지원 가능
  - TAXII v2.0 API

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

□ 보안 관제 빅데이터 기반 이상행위 탐지 요소 기술 설계 및 개발

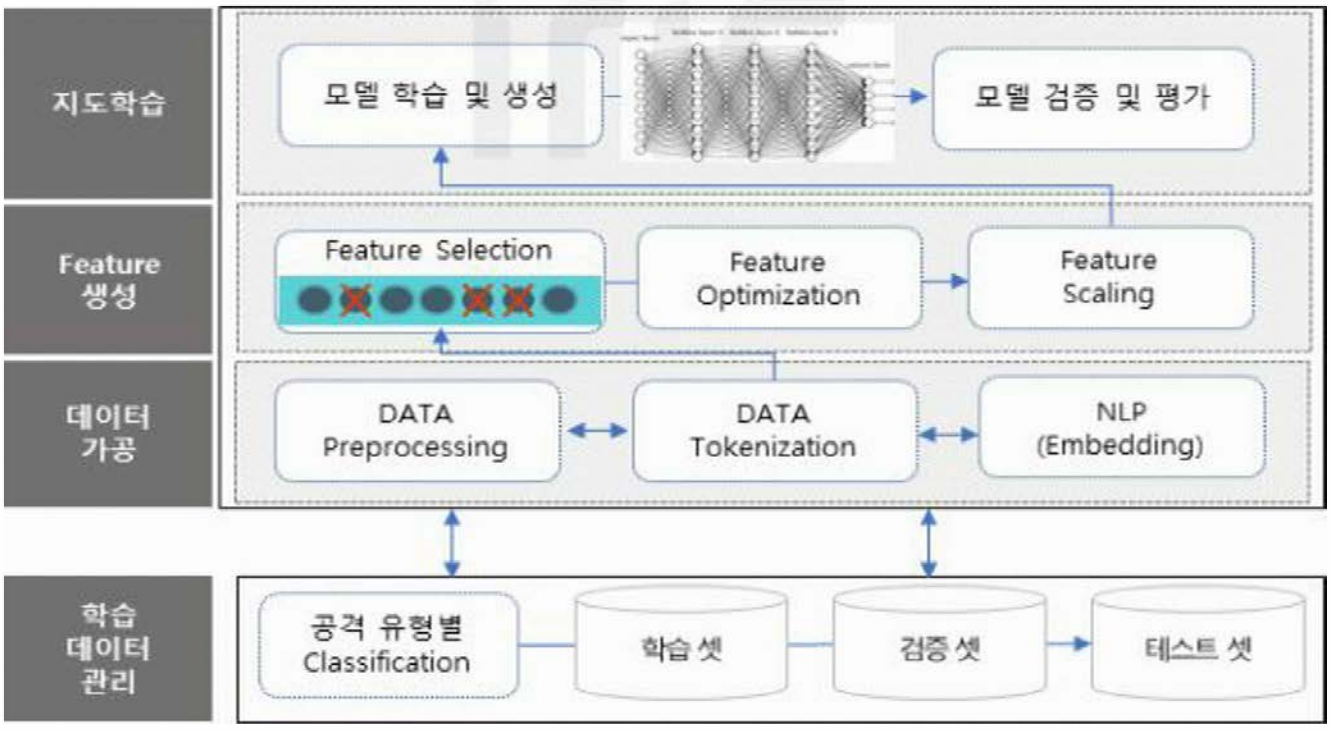
개발목표	보안 관제 빅데이터 기반 이상행위 탐지 요소 기술 설계 및 개발

세부 내용	1) 보안 관제 빅데이터 기반 이상행위 탐지 요소 기술 요구사항 분석 및 설계
	2) 보안 관제 빅데이터 기반 이상행위 탐지 요소 기술 개발

□ 보안 관제 빅데이터 기반 이상행위 탐지 요소 기술 개발 세부 내용

1) 보안 관제 빅데이터 기반 이상행위 탐지 요소 기술 요구사항 분석 및 설계

o 보안 관제 빅데이터 이상행위 탐지를 위한 기능 요구사항 정의
- **(데이터셋 구축)** 보안 관제 빅데이터 구축 및 학습 데이터셋 생성
- **(데이터셋 관리)** AI 학습을 위한 탐지명, 사용 목적 기준 데이터 분류 체계 수립
- **(데이터 정규화)** 데이터셋 정규화를 통해 후보 Feature 셋 생성
- **(데이터 가공)** 머신러닝, 딥러닝 학습을 위한 데이터 전처리 및 임베딩
- **(학습 모델 생성)** 레이블링 데이터 기반 정오탐 자동 분류 모델 생성
- **(학습 모델 평가)** 테스트 데이터를 통한 AI 모델 검증 및 평가
- **(이력 관리)** 학습에 사용한 데이터셋 및 예측 결과 데이터 이력 관리



<AI 기반 정오탐 이진분류 기능 요구사항 정의>

o 보안 관제 빅데이터 기반 인공지능 데이터셋 구축
- '18년~'19년 탐지 보안 관제 이벤트 기준 학습 데이터셋 구축
  · KISTI 과학기술사이버안전센터의 네트워크 관제 데이터(3천만 건) 활용
- 지도학습 기반 이진 분류를 위한 학습 데이터셋 정·오탐 레이블링

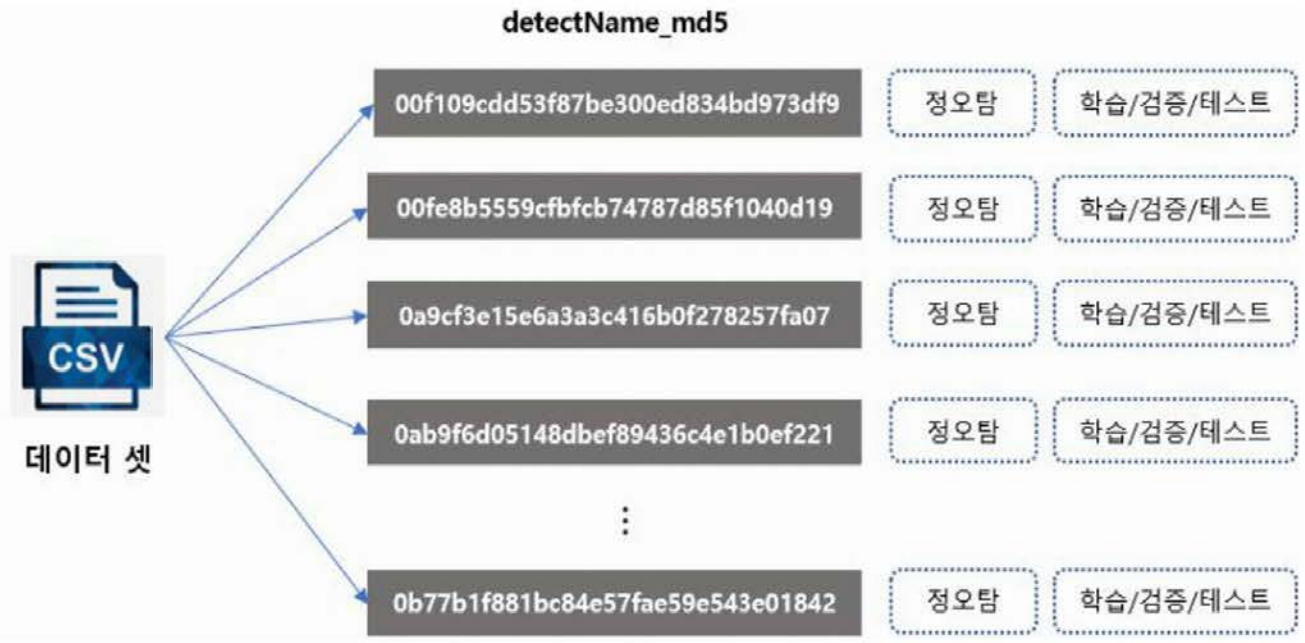
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

o 학습 대상 보안 이벤트 확장성 지원을 위한 데이터셋 정규화
- 보안 장비 벤더별로 상이한 학습 데이터 파일 포맷을 CSV로 통일
- 보안 이벤트 필드를 통일 규격으로 정규화하여 일관된 Feature 후보군 생성

<데이터셋 정규화>

필드명(Eng)	필드명(Kor)	설명
DetectStartTime	탐지시작시간	· 공격이 탐지된 시간
DetectEndTime	탐지종료시간	· 공격이 종료된 시간
SrcIP	출발지주소	· 공격자 IP 주소
SrcPort	출발지포트	· 공격자의 Port
DstIP	목적지주소	· 희생자(도착지)의 IP
DstPort	목적지포트	· 희생자(도착지)의 Port
DirectionType	패킷방향	· 공격 방향
PROTOCOL	프로토콜	· 통신 프로토콜
EventType	이벤트유형	· 보안 이벤트 유형
DetectName	탐지명	· 탐지명
PacketSize	패킷길이	· 패킷 길이(byte)
LABEL	레이블	· 레이블링 정보
PAYLOAD	페이로드	· 공격 데이터

o 인공지능 데이터 분류를 위한 데이터셋 분류 체계 수립
- 보안 이벤트 유형 및 공격 탐지명 기준 보안 관제 이벤트 데이터 분류
- 정오탐 레이블링 데이터 기준 데이터 분류
- 인공지능 사용 목적(학습/검증/테스트)에 따른 데이터 분류

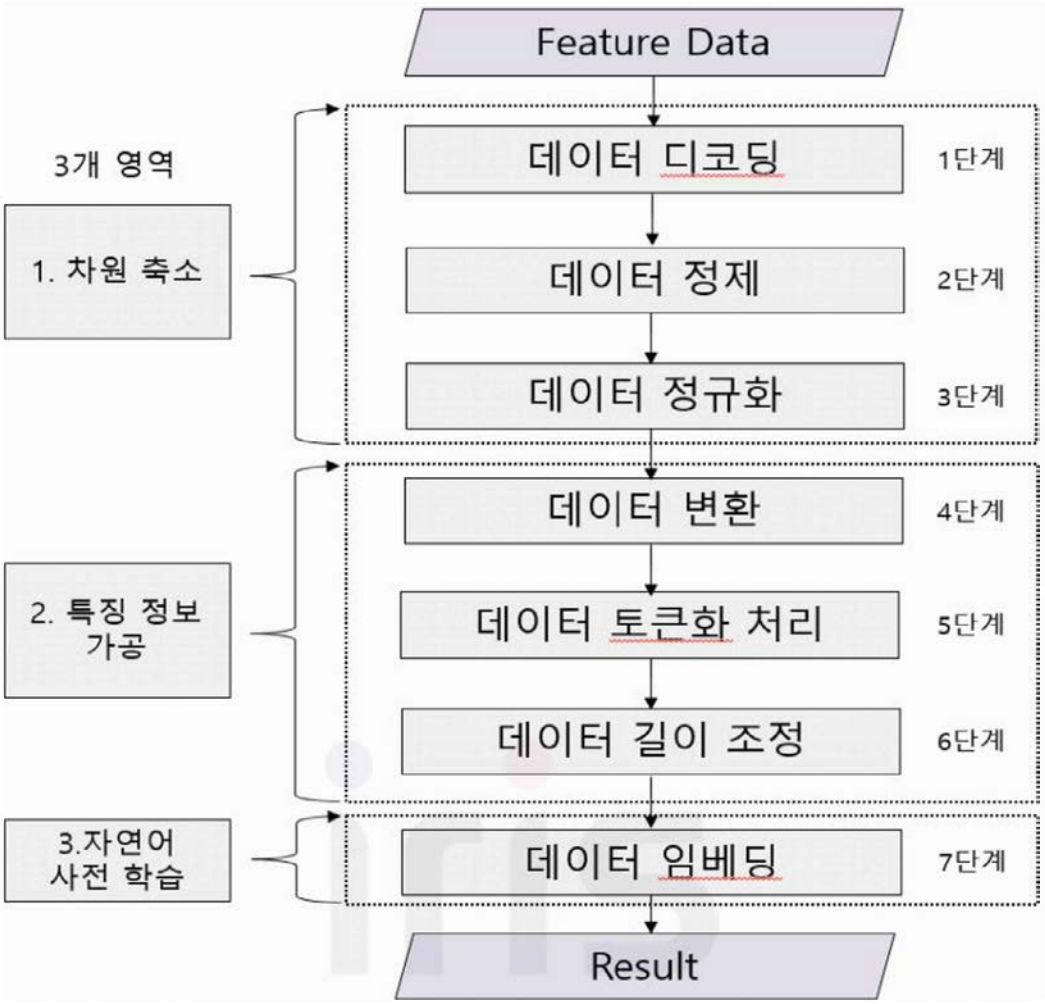


<데이터셋 분류 체계 수립>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

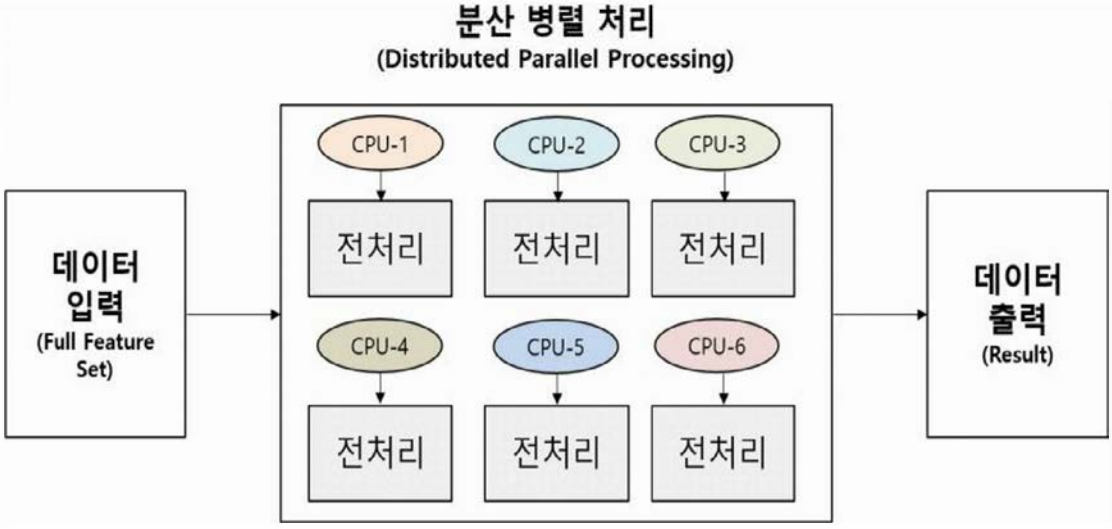
o 학습, 검증, 테스트 입력 데이터 생성을 위한 데이터 전처리

- 차원축소, 특징정보 가공, 자연어 사전학습 등 3개 영역의 7단계 전처리 수행



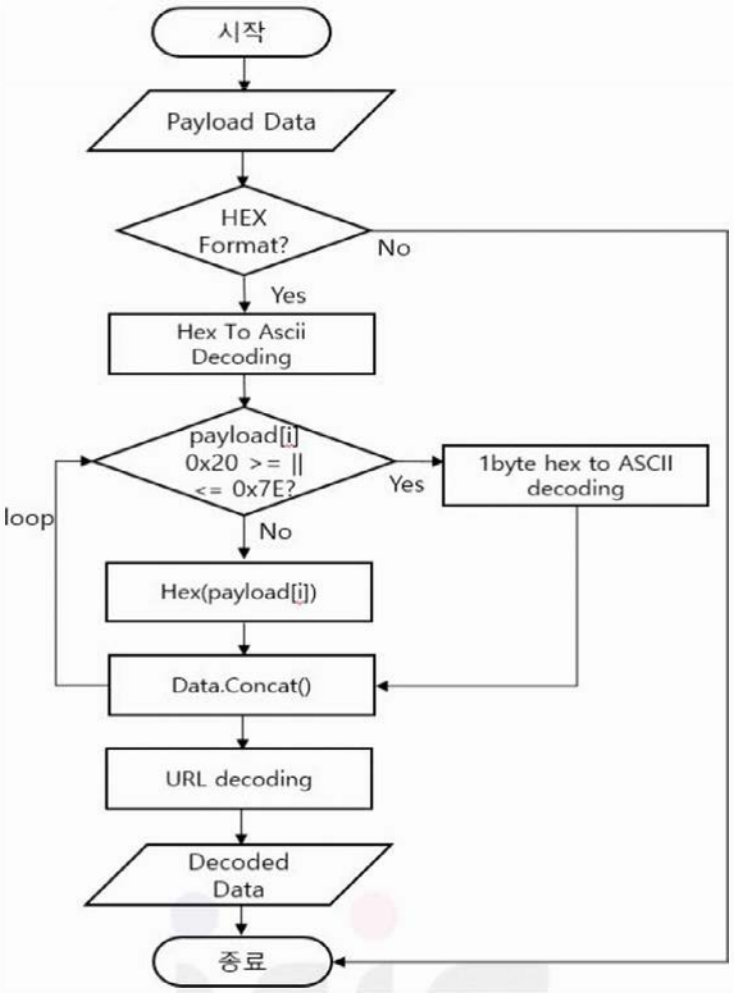
<데이터 전처리 순서도>

- 신속한 전처리 성능 확보를 위한 분산 병렬 처리 기반 전처리 모듈 설계



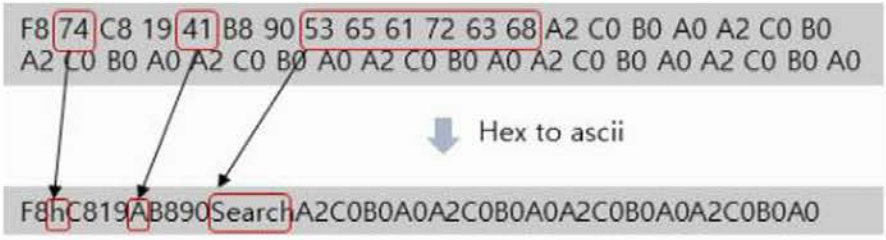
- 페이로드 자연어 처리를 위한 데이터 디코딩 처리 알고리즘 설계

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



<데이터 디코딩 알고리즘>

- 페이로드 디코딩을 통한 학습 차원(Dimension) 축소 및 자연어 반환



<16진수 데이터 아스키 변환>

- 후보 Feature 중 데이터 범위가 다양하게 나타날 수 있는 공격 탐지 시간 정보는 24시간 기준 시간 범위(새벽/오전/오후/저녁)를 분류하여 변환

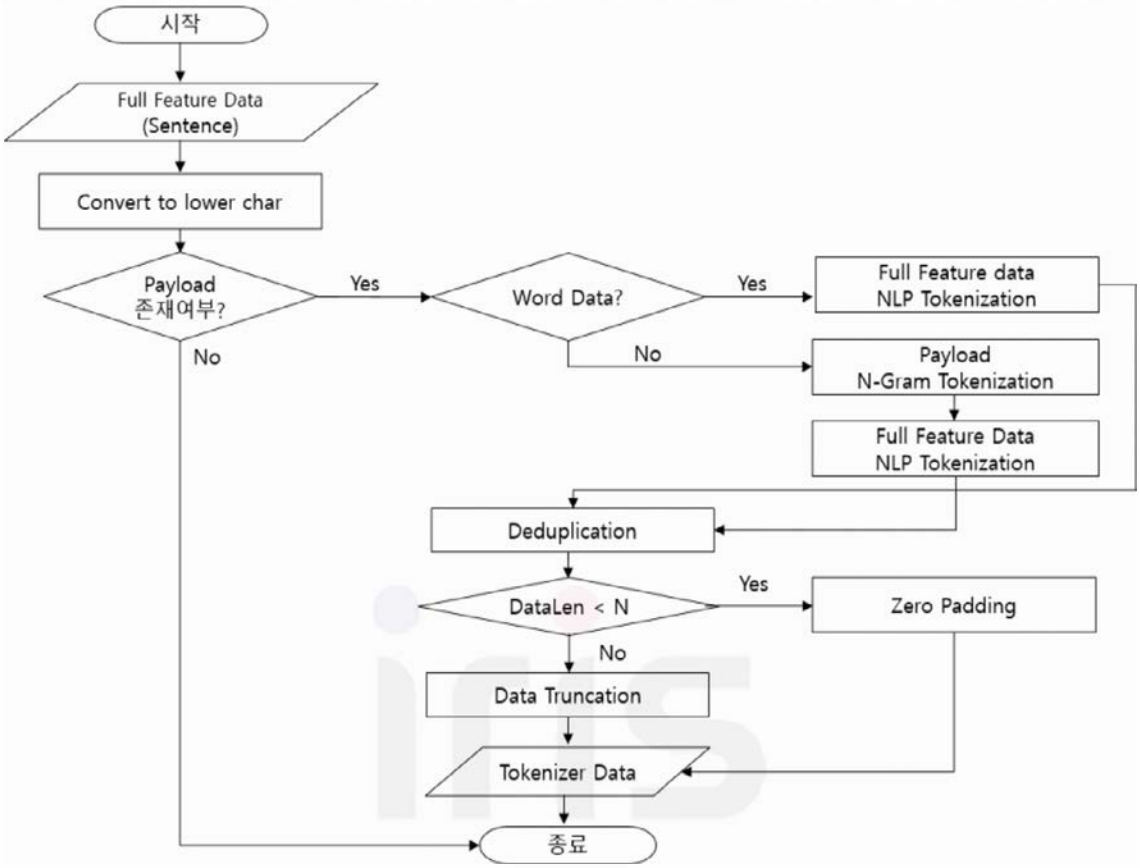
구분	기준	변환값
새벽	0시~5시	timedawn
오전	5시~12시	timeam
오후	12시~18시	timepm
저녁	18시~24시	timenight

- 페이로드 데이터에 존재하는 특수문자는 단어 단위 토큰화를 위해 값을 변환

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

· 특수문자 정규화 테이블을 생성하여 특수문자를 단어로 변환
· 두 기호 이상의 특수기호(/**/ 등)의 값들을 먼저 대체
· 변환할 때는 값의 앞뒤에 스페이스를 삽입하여 스페이스 기반 토큰화 사전 처리

- 보안 이벤트 자연어 처리 및 학습 입력을 위한 데이터 토큰화 수행



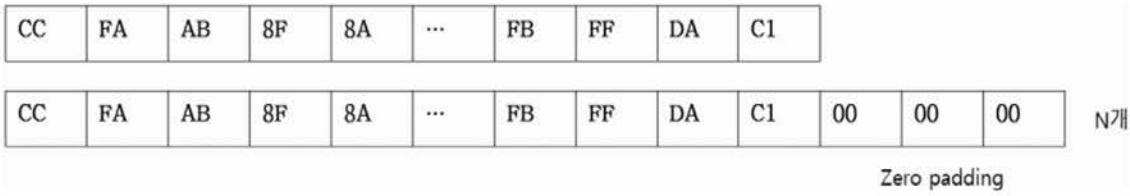
<데이터 토큰화 알고리즘>

- 동일 워드 및 특수기호가 2번 이상 연속적으로 반복되는 경우 Dimension 축소 및 복잡도 감소를 위해 Deduplication 구현
  · Deduplication은 문장의 앞부터 순차적으로 검색하여 중복 단어 여부 검증

DATA	id=1 union select **NULL,NULL,NULL,NULL** where 1=2--
Tokenizer	id = 1 union select **NULL NULL NULL NULL** where 1 = 2 --
Deduplication	id = 1 union select **NULL** where 1 = 2 --

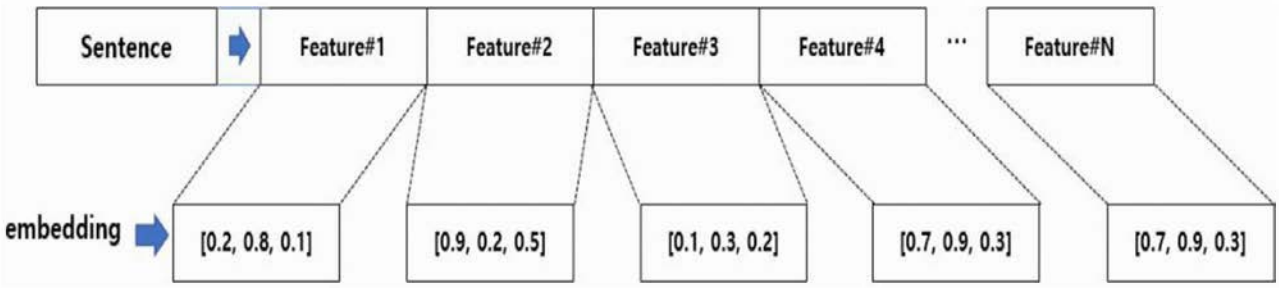
- 보안 이벤트 유형별로 적정한 크기의 고정된 토큰 개수(N)를 정의
  · N보다 작은 경우 뒷부분에 부족한 만큼의 Zero Padding
  · N보다 큰 경우 레이블링에 사용된 데이터(탐지 패턴 등)이 삭제되어 노이즈가 발생하지 않도록 Truncation 처리

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



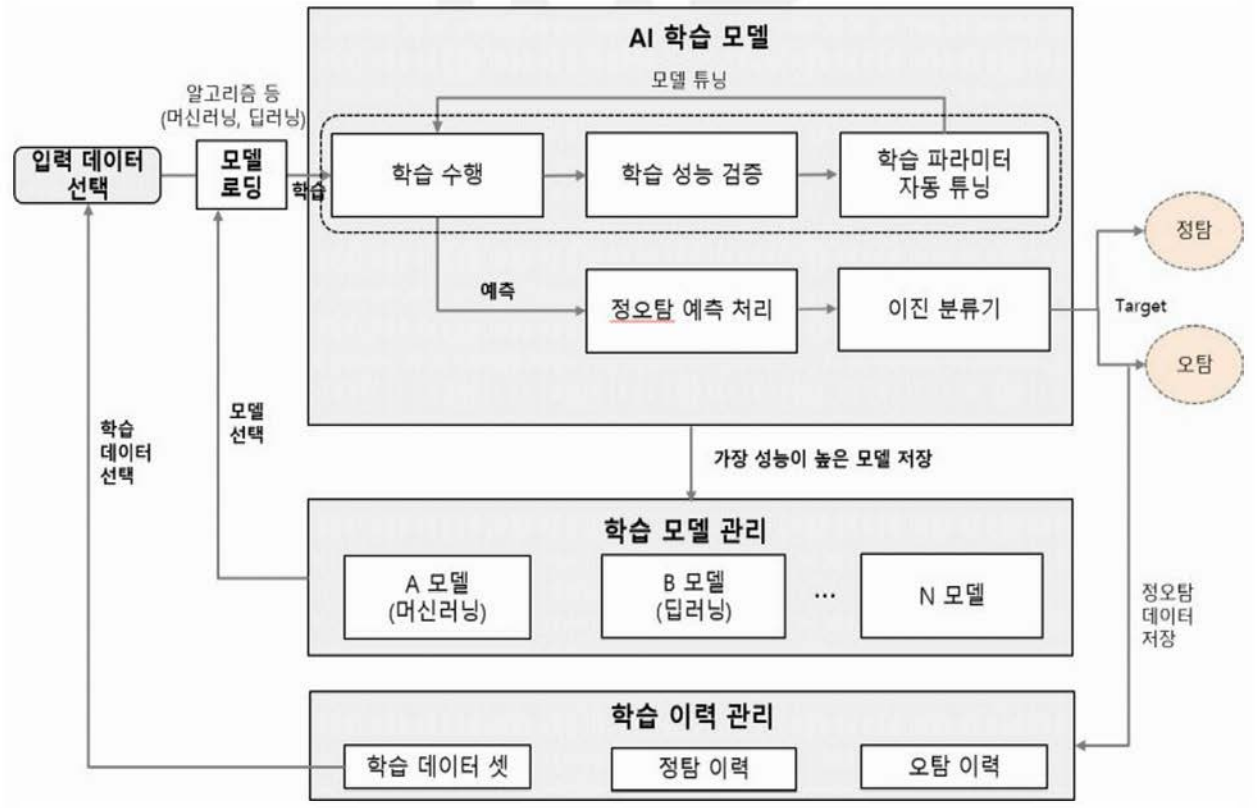
<Padding 구현>

- 데이터 임베딩을 위해 Feature를 하나의 문장(Sentence)을 구성
  · getsim 등의 오픈소스 라이브러리를 이용하여 Doc2Vec, FastText, Word2Vec을 각 지도 학습 모델에 적용



<데이터 임베딩>

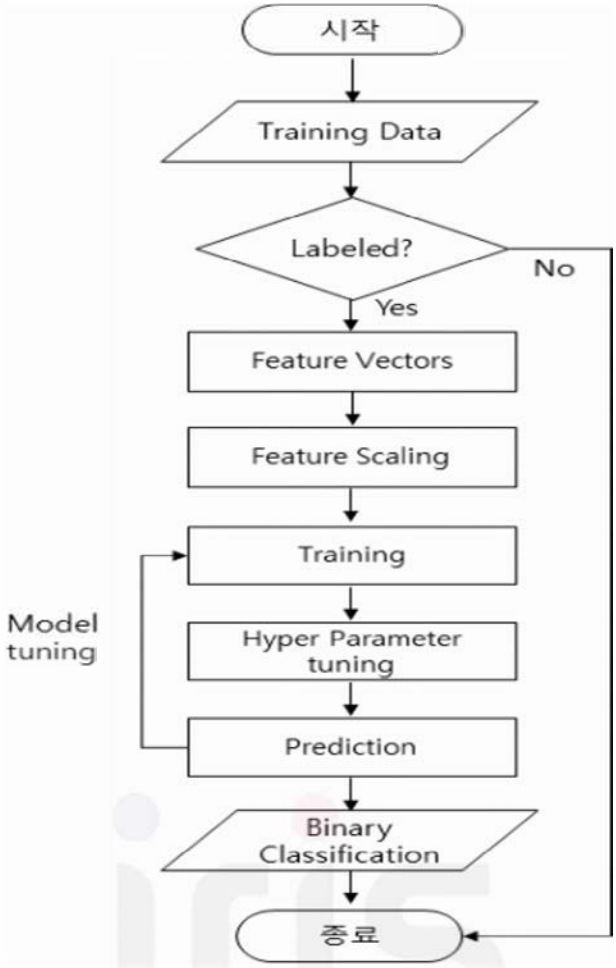
o 정오탐 이진 분류를 위한 지도학습 기반 머신러닝 모델 및 딥러닝 모델 개발
  - 학습에 대한 예측값은 이진 분류(Binary Classification)를 사용
  - 지도학습의 전체 과정을 파이프 라인을 통해 관리



<지도학습 기반 정오탐 분류 모델 구성도>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- 지도학습 기반 정오탐 바이너리 분류 알고리즘 설계



〈지도학습 모델 학습 알고리즘〉

- 학습 데이터에 최적화된 하이퍼 파라미터 설정
- Bayesian Optimization을 통해 최적의 하이퍼 파라미터 자동 세팅
  · 앙상블 알고리즘 하이퍼 파라미터 항목

No	하이퍼 파라미터	설명
1	learning_rate	학습률
2	n_estimators	결정트리의 개수를 지정
3	max_depth	트리의 최대 깊이
4	min_child_weight	child에서 필요한 가중치의 최소 합
5	gamma	분할을 위한 최소 손실 감소를 지정
6	reg_alpha	regularization 적용 값
7	subsample	트리를 만들 때 데이터에서 사용할 행의 비율
8	colsample_bytree	각 트리마다 Feature 샘플링 비율

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

· 딥러닝 알고리즘 하이퍼 파라미터 항목

No	하이퍼 파라미터	설명
1	Hidden layer	Hidden layer 개수
2	Neurons	뉴런 개수
3	Dropout Ratio	설정한 비율만큼 뉴런을 랜덤하게 삭제
4	Gate Activation	Gate의 Activation 함수(tanh, relu, linear 등)
5	Recurrent Activation	순환망의 Activation 함수
6	Batch Size	Batch마다 주는 데이터 세트의 크기
7	Epochs	학습 횟수
8	Window Size	고정된 훈련 단위의 크기
9	Sequence Length	시퀀스형 데이터의 길이
10	Output Dimension	출력 차원
11	Optimizer	학습 성능 향상을 위한 최적화 알고리즘
12	Loss Function	실제값과 예측값의 차이를 수치화하는 함수

- 학습 성능 검증 및 평가
  · matplot 오픈 라이브러리를 통해 학습 성능의 시각화 구현
  · 이상행위 탐지 정확도(AUC 0.75 이상) 자체 성능 시험 평가('21.11월)

2) 보안 관제 빅데이터 기반 이상행위 탐지 요소 기술 개발

o 인공지능 데이터셋(KISTI IDS 탐지 이벤트) 분석
- AI 모델의 학습 및 검증을 위한 데이터셋 검증에 활용
- 데이터셋의 정탐/오탐 학습 데이터 선정 시 과적합 및 편향이 발생할 수 있는 요소를 고려하여 분류 수행

o 주요 공격 유형별 탐지 데이터 통계 분석

<주요 공격 유형 별 정/오탐 통계 분석>

attackType \ analysis Result	정탐	오탐	분석필요	미분석	기타	합계
0 지정하지 않음	6,266,239	34,830,835	0	0	0	41,097,074
1 웜바이러스	158,984	111,376	0	0	0	270,360
2 웹 취약점	260,390	134,161	0	0	0	394,551
3 시스템 취약점	29,380	144	0	0	0	29,524
4 스캐닝	21	0	0	0	0	21
5 기타	0	0	0	0	0	0
기타	0	0	0	0	0	0
합계	6,454,624	3,5076,516	0	0	0	41,791,530

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- 탐지명 별 탐지 데이터 통계 분석

<탐지명에 따른 정/오탐 통계 분석>

analysis Result / detectName_md5	정탐	오탐	분석필요	미분석	기타	합계
001bf6eb1a161e6a3945a10d3a7149d5	0	43	0	0	0	43
005b145f94c553a769f35035d42ab99d	0	31,624	0	0	0	31,624
007953027a4c82d78c890b091b069aa6	0	11	0	0	0	11
ff113249fe416d4954ab213579a2f274	0	32	0	0	0	32
ff15ed8474e5a996eb4cf7ad7fd18742	2	19	0	0	0	21
ff3f4b5c12e4c6f18cb70423c987fb73	5	53	0	0	0	58
이하생략	-	-	-	-	-	-
합계	6,454,624	3,5076,516	0	0	0	41,791,530

o AI 모델의 탐지 데이터 선별

- AI 모델의 학습 데이터 활용 범위 선정: 다음 세 가지 조건을 만족하는 데이터를 학습 데이터로 활용
  - 이벤트 개수가 1000개 이상
  - 이벤트의 analysis Result 라벨로부터 계산한 min(정탐, 오탐) / (정탐+오탐) 값이 0.01 이상 (즉, 정탐과 오탐 라벨의 비율이 0.01 미만으로 imbalance되지 않음)
  - 이벤트의 payload를 대상으로 전처리 모듈을 실행하였을 때, 아스키 문자의 비율이 80% 이상인 이벤트가 전체 이벤트 중 75% 이상

<AI 모델의 학습 데이터로 활용할 데이터셋>

연번	detectName_md5	정탐	오탐	합계	정탐/오탐 비율
1	103e5a9a1e3f74d3d459bf52fcf42518	23,553	4,266	27,819	0.1533484
2	1966270273df8144a03451a88a8bdc2f	61,408	1,855	63,263	0.0293220
3	330b62744b65b54593d726f974034596	575	1,756	2,331	0.2466752
4	4359c02e182d2fd7bb58128cc29dce7e	381	16,476	16,857	0.0226018
5	614614e2cbf454899bf3175c6d2668d5	570	15,021	15,591	0.0365595
6	8048469afae611668ba35c639b958b63	28,689	244,244	272,933	0.1051137
7	8e73b75e2e068dd35dd1126cfc82cf76	11,409	38,777	50,186	0.2273343
8	902969863f9a8c69041e5037fb7f0d7b	624	2,812	3,436	0.1816065
9	9f4cc8b72f49e9c3f0720d4545be44d3	2,452	782	3,234	0.2418058
10	a771c708c14e999c0833df8d3068fb21	231	804	1,035	0.2231884
11	af6b61e4cba4736af99374e02f7743e6	717	43,267	43,984	0.0163013
12	b51a349dd5369669173341286e17f060	95,981	3,083,193	3,179,174	0.0301905
13	f3ad7297c6f1e2528c1a46262d3239f5	3,135	319	3,454	0.0923566
합계		229,725	3,453,572	3,683,297	0.0623690

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- 전체 AI 모델의 학습/검증/시험을 위한 데이터는 다음과 같은 비율로 수행

<선정된 데이터셋에 대한 학습/검증/시험 셋 활용 비율>

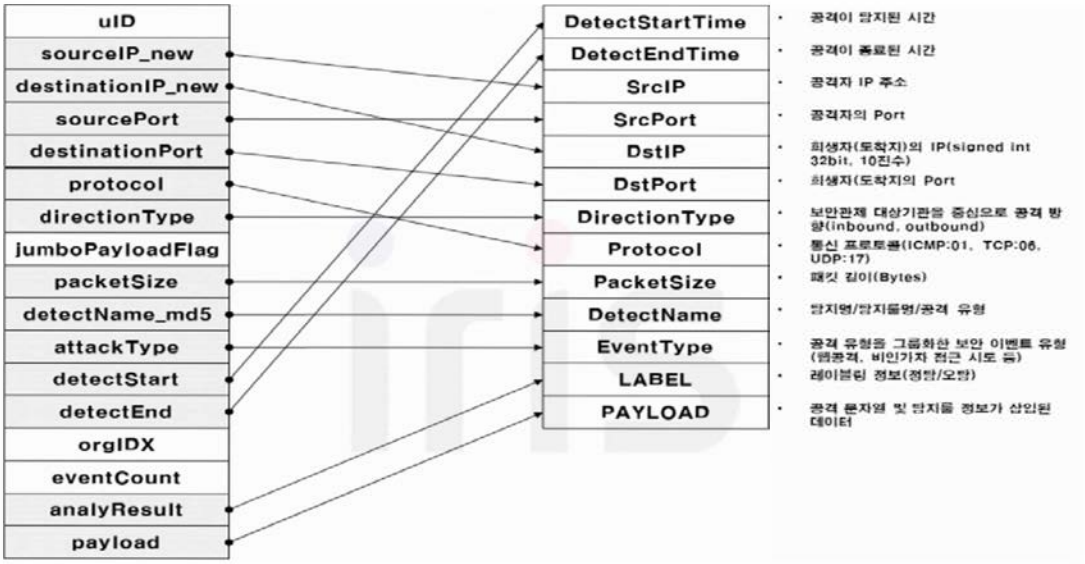
o 보안 관제 이벤트 AI 학습을 위한 데이터 전처리 모듈 개발

- 데이터셋 정규화

① 표준 필드 정의를 통해 중복 필드 제거 및 최적화된 Feature 후보군을 선정

② 원본 데이터셋 값을 추출하여 TSV 파일로 생성

③ 원본 데이터에 대한 정규화 매핑 룰



<데이터셋 매핑 룰>

- 페이로드 데이터 디코딩

① 페이로드 데이터 HEX를 ASCII 데이터로 디코딩하고, ASCII 디코딩 이후 데이터에 0x00~0x1F 이거나 0x7F 이상인 Byte는 헥스 값(예: 8F)을 그대로 유지한다. 예를 들어 페이로드가 " 41804215 "일 경우 " A80B15 "로 변환 후 URL Decoding을 수행한다.

② NULL 데이터 및 정탐 분류에 직접적인 관련성이 없는 불용어를 제거한다.

· 필드에 NULL 데이터가 존재하는 행은 제거

· PAYLOAD 데이터에서 정탐 분류에 직접적인 영향을 주지 않는 데이터(불필요한 공백 등)를 정의하여 삭제

· 분류에 직접적인 영향을 주지 않는 데이터는 제거

* 두 번 이상 연속되는 공백 데이터

* 두 번 이상 반복되는 동일 단어 및 특수문자 데이터

* Unicode 데이터

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

③ 데이터 범위가 다양하게 나타날 수 있는 컬럼은 공격자의 활동 시간, 위치 등의 패턴이 최대한 Feature에 반영할 수 있도록 데이터를 변환한다.

- (탐지 시간) 공격 탐지 시간 정보는 24시간 기준 시간 범위(새벽/오전/오후/저녁)를 분류하여 변환
- 디코딩 이후 PAYLOAD 데이터에 존재하는 특수문자는 단어 단위 토큰화를 위해 변환 순서 필드를 참고하여 값을 변환
- 변환순서 필드를 참고하여 먼저 두 기호 이상의 특수기호(/**/ 등)의 값들을 검색하여 대체하고 이후 한 개로 이뤄진 특수기호를 대체
- 변환할 때는 변환 값 앞쪽 및 뒤쪽에 각각 스페이스를 삽입하여 토큰화가 스페이스 기반으로 잘 처리될 수 있도록 수행

- 데이터 토큰화

① 토큰화 이후 동일 워드 및 특수기호가 2번 이상 연속적으로 반복되는 경우에만 Dimension 축소 및 복잡도 감소를 위해 Deduplication한다. Deduplication 처리는 문장의 앞쪽부터 순차적으로 검색하여 중복 단어 여부를 검증한다.

② 만약 PAYLOAD에 ASCII 범위(0x80보다 큰)를 벗어난 BYTE 문자들이 존재할 경우, BYTE 문자열들을 문장으로 간주하여 N-Gram 기반으로 토큰화시킨 후 전체 문장을 다시 토큰화한다.

③ 분리한 각각의 토큰은 곧 Feature 데이터이자 차원수이며 AI 모델에 입력하기 위해 Feature 개수(차원)가 이벤트별로 동일해야 하므로 앞서 분류한 보안 이벤트 그룹별 적정한 크기의 고정된 토큰 개수(N)를 정의한다. N값은 문장 길이의 최대값이거나 평균값일 수 있다. N보다 작은 경우, 뒷부분에 부족한 만큼 Zero Padding한다. 만약 Truncation을 해야 할 경우, 레이블링에 사용된 데이터(탐지 패턴 등)가 삭제되어 노이즈가 발생하지 않도록 적정한 N값을 설정한다.

<데이터 전처리 후 결과 예시>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

전처리 결과물

post fslz index dotz php http fslz 1 dotz 0 host clnz rule dotz kias dotz re dotz kr cookie clnz phpsessid eqz 44ndmhr53sqv5mhcpdn9qvl175 connection clnz close user minusz agent clnz mozilla fslz 5 dotz 0 opnz windows nt 6 dotz 3 scoz wow64 clsz applewebkit fslz 537 dotz 36 opnz khtml like gecko clsz chrome fslz 55 dotz 0 dotz 2883 dotz 87 ubrowser fslz 6 dotz 2 dotz 3964 dotz 2 safari fslz 537 dotz 36 accept clnz application fslz json text fslz javascript astarz comst scoz q eqz 0 dotz 01 x minusz ajaxpro minusz method clnz serversidesavepost accept minusz language clnz en minusz us en scoz q eqz 0 dotz 5 accept minusz encoding clnz gzip deflate dnt clnz 1 referer clnz http rule dotz kias dotz re dotz kr fslz origin clnz http rule dotz kias dotz re dotz kr x minusz requested minusz with clnz xmlhttprequest content minusz type clnz application fslz x minusz www minusz form minusz urlencoded content minusz length clnz 308 lthz qmaz xml version assgdq 1 dotz 0 dqutz encoding assgdq utf minusz 8 dqutz qmaz gthz lthz methodcall gthz lthz params gthz lthz _filter clsopn excz opbz cdata opbz widget_login cpbz gthz clstag _filter gthz lthz user_id clsopn excz opbz cdata opbz joeannharries8965998 cpbz gthz clstag user_id gthz lthz password clsopn excz opbz cdata opbz rbf6f7fsa cpbz gthz clstag password gthz lthz module clsopn excz opbz cdata opbz member cpbz gthz clstag module gthz lthz act clsopn excz opbz cdata opbz procmemberlogin cpbz gthz clstag act gthz clstag params gthz clstag methodcall gthz timepm

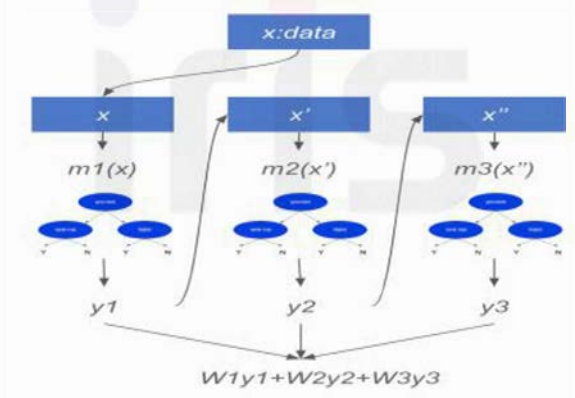
토큰화 결과

['post', 'fslz', 'index', 'dotz', 'php', 'http', 'fslz', '1', 'dotz', '0', 'host', 'clnz', 'rule', 'dotz', 'kias', 'dotz', 're', 'dotz', 'kr', 'cookie', 'clnz', 'phpsessid', 'eqz', '44ndmhr53sqv5mhcpdn9qvl175', 'connection', 'clnz', 'close', 'user', 'minusz', 'agent', 'clnz', 'mozilla', 'fslz', '5', 'dotz', '0', 'opnz', 'windows', 'nt', '6', 'dotz', '3', 'scoz', 'wow64', 'clsz', 'applewebkit', 'fslz', '537', 'dotz', '36', 'opnz', 'khtml', 'like', 'gecko', 'clsz', 'chrome', 'fslz', '55', 'dotz', '0', 'dotz', '2883', 'dotz', '87', 'ubrowser', 'fslz', '6', 'dotz', '2', 'dotz', '3964', 'dotz', '2', 'safari', 'fslz', '537', 'dotz', '36', 'accept', 'clnz', 'application', 'fslz', 'json', 'text', 'fslz', 'javascript', 'astarz', 'comst', 'scoz', 'q', 'eqz', '0', 'dotz', '01', 'x', 'minusz', 'ajaxpro', 'minusz', 'method', 'clnz', 'serversidesavepost', 'accept', 'minusz', 'language', 'clnz', 'en', 'minusz', 'us', 'en', 'scoz', 'q', 'eqz', '0', 'dotz', '5', 'accept', 'minusz', 'encoding', 'clnz', 'gzip', 'deflate', 'dnt', 'clnz', '1', 'referer', 'clnz', 'http', 'rule', 'dotz', 'kias', 'dotz', 're', 'dotz', 'kr', 'fslz', 'origin', 'clnz', 'http', 'rule', 'dotz', 'kias', 'dotz', 're', 'dotz', 'kr', 'x', 'minusz', 'requested', 'minusz', 'with', 'clnz', 'xmlhttprequest', 'content', 'minusz', 'type', 'clnz', 'application', 'fslz', 'x', 'minusz', 'www', 'minusz', 'form', 'minusz', 'urlencoded', 'content', 'minusz', 'length', 'clnz', '308', 'lthz', 'qmaz', 'xml', 'version', 'assgdq', '1', 'dotz', '0', 'dqutz', 'encoding', 'assgdq', 'utf', 'minusz', '8', 'dqutz', 'qmaz', 'gthz', 'lthz', 'methodcall', 'gthz', 'lthz', 'params', 'gthz', 'lthz', '_filter', 'clsopn', 'excz', 'opbz', 'cdata', 'opbz', 'widget_login', 'cpbz', 'gthz', 'clstag', '_filter', 'gthz', 'lthz', 'user_id', 'clsopn', 'excz', 'opbz', 'cdata', 'opbz', 'joeannharries8965998', 'cpbz', 'gthz', 'clstag', 'user_id', 'gthz', 'lthz', 'password', 'clsopn', 'excz', 'opbz', 'cdata', 'opbz', 'rbf6f7fsa', 'cpbz', 'gthz', 'clstag', 'password', 'gthz', 'lthz', 'module', 'clsopn', 'excz', 'opbz', 'cdata', 'opbz', 'member', 'cpbz', 'gthz', 'clstag', 'module', 'gthz', 'lthz', 'act', 'clsopn', 'excz', 'opbz', 'cdata', 'opbz', 'procmemberlogin', 'cpbz', 'gthz', 'clstag', 'act', 'gthz', 'clstag', 'params', 'gthz', 'clstag', 'methodcall', 'gthz', 'timepm']

<전처리 후 토큰화 결과>

o 보안 관제 이벤트 정오탐 분류를 위한 머신러닝 모델 개발

- 머신러닝 모델은 Boosting 계열의 앙상블 알고리즘을 이용하여 개발



<앙상블 모델>

- Boosting 알고리즘은 이전 모델에서 분류가 잘못된 데이터일 경우 다음 모델에서 해당 데이터에 대한 가중치를 높여 다음 예측 모델의 정확도를 높이는 알고리즘
- 학습 성능이 뛰어나고 보편적인 모델인 XGBoost를 이용
- 손실 함수는 이진 분류를 위한 BCE로 설정
- 토큰화된 데이터셋을 TF-IDF(Term Frequency-Inverse Document Frequency)를 이용하여 임베딩

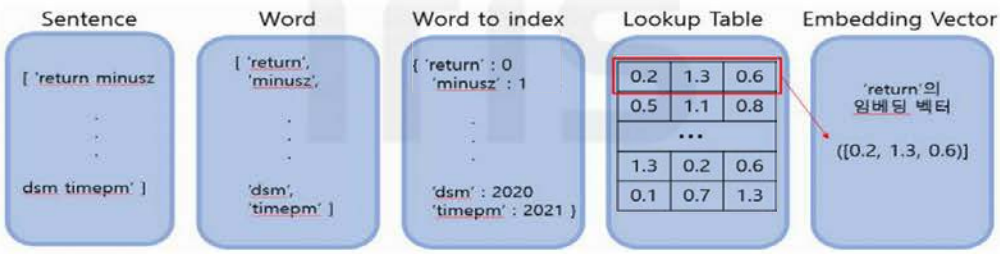
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

<탐지명에 따른 XGBoost 결과>

No	detectName	정확도	정밀도	재현율	AUC
1	1966270273df8144a03451a88a8bdc2f	0.999842	0.999837	1	0.997403
2	f3ad7297c6f1e2528c1a46262d3239f5	1	1	1	1
3	103e5a9a1e3f74d3d459bf52fcf42518	0.999461	1	0.999359	0.99968
4	9f4cc8b72f49e9c3f0720d4545be44d3	0.995363	0.997938	0.995885	0.994837
5	330b62744b65b54593d726f974034596	0.989293	0.972222	0.981308	0.986488
6	8e73b75e2e068dd35dd1126cfc82cf76	0.998605	0.99395	1	0.999095
7	a771c708c14e999c0833df8d3068fb21	0.961353	0.956522	0.88	0.933631
8	902969863f9a8c69041e5037fb7f0d7b	1	1	1	1
9	8048469afae611668ba35c639b958b63	0.895671	0	0	0.5
10	614614e2cbf454899bf3175c6d2668d5	0.999679	0.990291	1	0.999834
11	b51a349dd5369669173341286e17f060	0.999994	0.999896	0.999896	0.999946
12	4359c02e182d2fd7bb58128cc29dce7e	0.998517	1	0.931507	0.965753
13	af6b61e4cba4736af99374e02f7743e6	0.998295	0.93617	0.956522	0.977741
평균					0.98

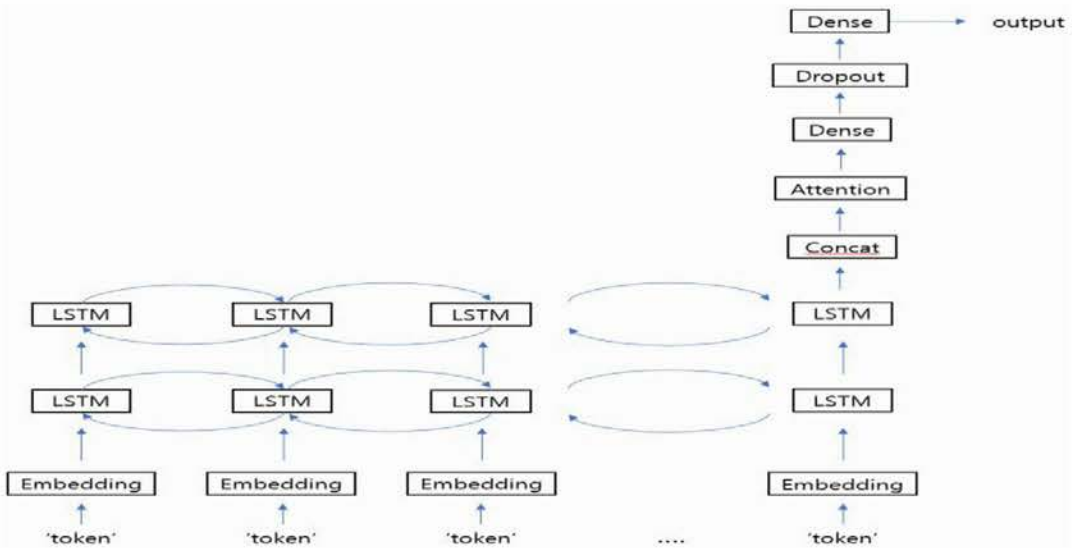
o 보안 관제 이벤트 정오탐 분류를 위한 딥러닝 모델 개발

- 임베딩 모델 개발 진행 중 : getsim 등의 오픈소스 라이브러리를 이용하고 Word2Vec, FastText, Doc2Vec을 적용



<임베딩 모델 예시>

- 순환 신경망 모델을 적용하여 개발 진행 중



<순환 신경망 모델>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- 데이터 학습은 양방향 학습(Bidirectional)을 이용
- 학습 시 중요 단어에 집중하기 위한 Attention 기술 적용
- Bidirectional-LSTM을 2개의 층으로 쌓은 stacked bi-LSTM 모델을 사용
- 출력물의 은닉 상태를 attention 층을 통과한 후 2개의 linear 층을 통과
- 은닉층의 활성화 함수는 Leaky Relu 함수를 설정
- 출력층은 이진 분류를 할 수 있는 Sigmoid 함수를 설정

<탐지명에 따른 결과 (Doc2Vec 임베딩 사용)>

No	detectName	정확도	정밀도	재현율	AUC
1	1966270273df8144a03451a88a8bdc2f	1	0.999919	0.999921	0.999959
2	f3ad7297c6f1e2528c1a46262d3239f5	0.993475	0.996727	0.991317	0.973363
3	103e5a9a1e3f74d3d459bf52fcf42518	1	1	1	1
4	9f4cc8b72f49e9c3f0720d4545be44d3	0.997942	0.995893	0.995363	0.994822
5	330b62744b65b54593d726f974034596	0.991379	0.991379	0.995717	0.994265
6	8e73b75e2e068dd35dd1126cfc82cf76	1	1	1	1
7	a771c708c14e999c0833df8d3068fb21	0.868421	0.825	0.942029	0.89753
8	902969863f9a8c69041e5037fb7f0d7b	1	1	1	1
9	8048469afae611668ba35c639b958b63	0	0	0.895781	0.5
10	614614e2cbf454899bf3175c6d2668d5	0.961165	0.970588	0.997755	0.984631
11	b51a349dd5369669173341286e17f060	0.999994	0.999896	0.999896	0.999946
12	4359c02e182d2fd7bb58128cc29dce7e	0.854	0.957746	0.995552	0.977056
13	af6b61e4cba4736af99374e02f7743e6	0.848921	0.951613	0.996931	0.974596
평균					0.94

o AI 기반 이상행위 탐지 정확도 성능 검증 모듈 개발

- 오차행렬(Confusion matrix) 기반 성능 검증 모듈
  - 정밀도(Precision) : 모델이 True라고 분류(탐지)한 것 중에서 실제 True인 것의 비율

    정밀도 = (TP) / (TP+FP)
  - 재현율(Recall): 실제 True인 것 중에서 모델이 True라고 예측한 것의 비율

    재현율 = (TP) / (TP+FN)
  - 정확도(Accuracy): 실제 True인 것 중에서 모델이 True라고 예측한 것과 실제 False인 것 중에서 모델이 False라고 예측한 경우의 비율

    정확도 = (TP + TN) / (TP + FN + FP + TN)

- ROC(Receiver Operating Characteristic) 곡선 기반 성능 검증 모듈
  - 민감도(Sensitivity) : 실제 True 중 모델이 True라 예측한 비율

    민감도 = (TP) / (TP+FN)
  - 특이도(Specificity) : 실제 False 중 모델이 False라 예측한 비율

    특이도 = (TN) / (TN+FP)

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

· AUC(Area Under the Curve) : 민감도를 y축, (1-특이도)를 x축으로 한 ROC 그래프에서 그래프 아래의 면적

□ AI · 빅데이터 기반 이기종 보안 장비 이상행위 탐지 성능 향상 기술 연구

연구목표	AI · 빅데이터 기반 이기종 보안 장비 이상행위 탐지 성능 향상 기술 연구

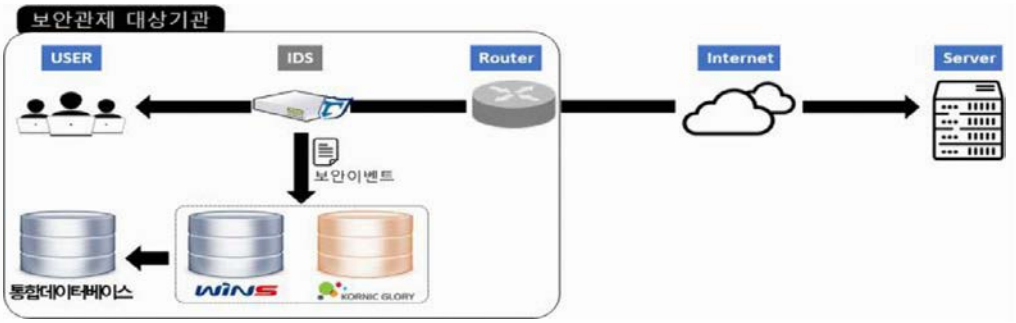
세부 내용	1) 이상행위 위협 특징 기반 데이터셋 구조 분석
	2) 이상행위 탐지 성능 향상을 위한 데이터 전처리 및 정규화 기술 설계 · 개발
	3) 이상행위 탐지 성능 향상을 위한 사용자 정의(User-defined) 연관 데이터 필드 추출 기술 설계 · 개발

□ AI · 빅데이터 기반 이기종 보안 장비 이상행위 탐지 성능 향상 기술 연구

1) 이상행위 위협 특징 기반 데이터셋 구조 분석

IDS를 통한 데이터 수집 → 데이터 특징 분석 → 이상탐지 연구에 필요한 데이터 선택 → 통합 DB 구축

o 이기종 보안장비 선정 및 보안이벤트 구조 분석
- 국내 기업 2개(㈜코닉글로리, ㈜윈스)의 IDS를 선정
- 각각의 IDS를 실 네트워크에 설치 및 보안이벤트 수집
- IDS로부터 탐지된 보안이벤트 저장 방식 및 구조 분석
- 두 타입의 IDS에서 이상행위 탐지 연구에 필요한 데이터만을 추출하여 하나의 통합 데이터베이스 구축



2) 이상행위 탐지 성능 향상을 위한 데이터 전처리 및 정규화 기술 설계 · 개발

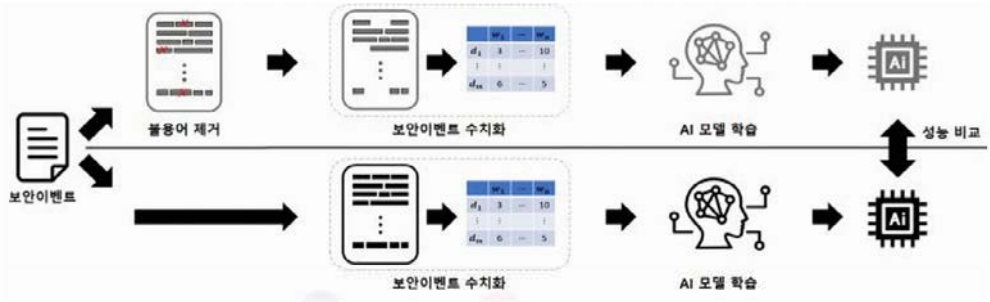
o 페이로드 전처리 방법 설계 및 개발
- 이상행위 탐지 및 정·오탐 판단에 영향을 주지 않는 불용어들을 정의하고 이를 페이로드에서 제거
- 개인정보(주민등록번호, 여권번호, 외국인 등록번호, E-mail, 전화번호), IP, 탐지패턴 등과 같이 외부 유출 시 2차 피해로 이어질 수 있는 민감 정보들을 선별하고 이를 제거

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- TF-IDF, BM25, Word2Vec 등의 보안이벤트를 수치화 할 수 있는 방법 적용
- 페이로드를 학습·분류 AI 모델을 만들기 위한 학습 데이터셋 구축

성능측정 1: 불용어 제거 전·후 AI 모델의 분류 성능

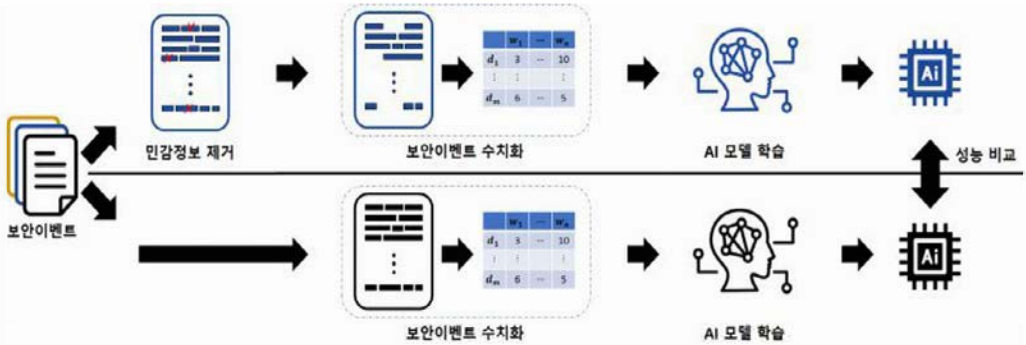
- 시험 항목 : 불용어 처리 모듈의 성능 측정
- 시험 대상 : 旣 수집 및 레이블링된 보안이벤트
- 시험 환경 : Windows 10, 메모리 128G, Inter i9-10900K
- 시험 도구 : 개발 도구(python)
- 시험 절차 :
  ① 불용어 처리 전 보안이벤트를 수치화 후 AI 모델 학습(모델 1)
  ② 불용어 처리 후 보안이벤트를 수치화 후 AI 모델 학습(모델 2)
  ③ 모델 1과 모델 2를 동일한 테스트 데이터셋으로 검증
  ④ confusion matrix를 통한 모델 1, 모델 2의 성능 비교



- 시험 결과 : 약 10종의 보안이벤트 테스트 결과 5% 이상 분류 정확도 향상
- 향후 계획 : 지속적인 테스트 및 실증을 통한 불용어 처리 모듈 고도화 수행

성능측정 2: 민감정보 제거 전·후 AI 모델의 분류 성능

- 시험 항목 : 민감정보 제거 모듈의 성능 측정
- 시험 대상 : 旣 수집 및 레이블링된 보안이벤트
- 시험 환경 : Windows 10, 메모리 128G, Inter i9-10900K
- 시험 도구 : 개발 도구(python)
- 시험 절차 :
  ① 페이로드를 포함하고 있는 보안이벤트 1종 선택
  ② 민감정보 제거 전 보안이벤트를 수치화 후 AI 모델 학습(모델 1)
  ③ 민감정보 제거 후 보안이벤트를 수치화 후 AI 모델 학습(모델 2)
  ④ 모델 1과 모델 2를 동일한 테스트 데이터셋으로 검증
  ⑤ confusion matrix를 통한 모델 1, 모델 2의 성능 비교
  ⑥ 보안이벤트를 변경하면서 ②~⑤을 반복적으로 수행



국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

▸ 시험 결과 : 약 10종의 보안이벤트 테스트 결과 성능 차이가 미비함을 확인

1597			
		정탐	오탐
학습		5,810	27,907
테스트		11,178	16,409
	익명화 X	익명화 O	성능 비교
Accuracy	0.99902	0.99888	-0.00014
Precision	0.99866	0.99882	0.00016
Recall	0.99893	0.99874	-0.00019
F1-score	0.99879	0.99878	-0.00001

1620			
		정탐	오탐
학습		15,779	134,334
테스트		12,910	109,910
	익명화 X	익명화 O	성능 비교
Accuracy	1.00000	1.00000	0.00000
Precision	1.00000	1.00000	0.00000
Recall	1.00000	1.00000	0.00000
F1-score	1.00000	1.00000	0.00000

0446			
		정탐	오탐
학습		6,275	21,327
테스트		5,134	17,450
	익명화 X	익명화 O	성능 비교
Accuracy	0.99987	0.99973	-0.00013
Precision	1.00000	0.99994	-0.00006
Recall	0.99983	0.99971	-0.00011
F1-score	0.99991	0.99983	-0.00009

0346			
		정탐	오탐
학습		1,712	16,726
테스트		1,400	13,686
	익명화 X	익명화 O	성능 비교
Accuracy	0.90435	0.90567	0.00133
Precision	0.94768	0.95616	0.00848
Recall	0.94692	0.94083	-0.00609
F1-score	0.94730	0.94843	0.00113

2201			
		정탐	오탐
학습		6,930	24,442
테스트		5,670	19,999
	익명화 X	익명화 O	성능 비교
Accuracy	0.99720	0.99505	-0.00214
Precision	0.99810	0.99620	-0.00190
Recall	0.99830	0.99745	-0.00085
F1-score	0.99820	0.99682	-0.00138

2198			
		정탐	오탐
학습		12,655	9,798
테스트		10,355	8,017
	익명화 X	익명화 O	성능 비교
Accuracy	1.00000	1.00000	0.00000
Precision	1.00000	1.00000	0.00000
Recall	1.00000	1.00000	0.00000
F1-score	1.00000	1.00000	0.00000

2255			
		정탐	오탐
학습		20,321	2,828,809
테스트		16,626	2,314,482
	익명화 X	익명화 O	성능 비교
Accuracy	0.99396	0.99292	-0.00104
Precision	0.29586	0.01522	-0.28064
Recall	0.67467	0.67109	-0.00358
F1-score	0.41134	0.02976	-0.38158

2254			
		정탐	오탐
학습		24,593	284,855
테스트		95,981	3,083,193
	익명화 X	익명화 O	성능 비교
Accuracy	0.96176	0.92688	-0.03487
Precision	0.98575	0.98783	0.00208
Recall	0.44042	0.29075	-0.14967
F1-score	0.60882	0.44927	-0.15955

2249			
		정탐	오탐
학습		9,343	58,758
테스트		5,928	49,791
	익명화 X	익명화 O	성능 비교
Accuracy	0.95906	0.96782	0.00876
Precision	0.98650	0.98465	-0.00186
Recall	0.72655	0.77424	0.04769
F1-score	0.83680	0.86686	0.03006

2210			
		정탐	오탐
학습		316	966
테스트		259	790
	익명화 X	익명화 O	성능 비교
Accuracy	0.93327	0.93232	-0.00095
Precision	0.96329	0.96329	0.00000
Recall	0.94888	0.94770	-0.00118
F1-score	0.95603	0.95543	-0.00060

▸ 향후 계획 : 더욱 다양한 종의 보안이벤트에 대해서 테스트 수행 예정

3) 이상행위 탐지 성능 향상을 위한 사용자 정의(User-defined) 연관 데이터필드 추출 기술 설계・개발

o 페이로드 기반 특징 정의

- 페이로드에 존재하는 전체 캐릭터(character) 개수 대비 화면에 출력 가능한 캐릭터(printable character) 개수/비율

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- 페이로드에 존재하는 전체 캐릭터(character) 개수 대비 화면에 출력 불가능한 캐릭터(unprintable character) 개수/비율

- 특정 기간 중에 탐지된 보안이벤트의 단어들을 추출하여 WORD2VEC
  ⇒ 윈도우 사이즈, 벡터 사이즈, 알고리즘을 다양하게 시도하여 WORD 사전 구성

- 동일 이벤트별 페이로드 기반 TF(Term frequency)
  ⇒ 사전에 정의된 불용어를 보안이벤트에서 제거
  ⇒ 보안이벤트를 이벤트명별로 그룹핑
  ⇒ 그룹별 TF 생성

- 동일 이벤트별 페이로드 기반 DF(Document Frequency)
  ⇒ 사전에 정의된 불용어를 보안이벤트에서 제거
  ⇒ 보안이벤트를 이벤트명별로 그룹핑
  ⇒ 그룹별 DF 생성

- 동일 이벤트별 페이로드 기반 TF-IDF(Term Frequency-Inverse Document Frequency)
  ⇒ 사전에 정의된 불용어를 보안이벤트에서 제거
  ⇒ 보안이벤트를 이벤트명별로 그룹핑
  ⇒ 그룹별 TF-IDF 생성

- 기타 페이로드로부터 추출 가능한 특징
  ⇒ IDS/IPS에서 제공하지 않지만 보안이벤트 정·오탐 판단의 근거가 될 수 있는 특징 선별
  ⇒ TCP flag, TTL, sequence number, fragment size, fragment offset 등

o 통계 기반의 특징 정의
- 기준필드, 기간/건수, 조건식, 대상필드, 종류/건수/비율/분산 입력 시 추출 가능한 특징의 예 도출
- 조건에 따른 DB 쿼리(query) 설계 및 테스트

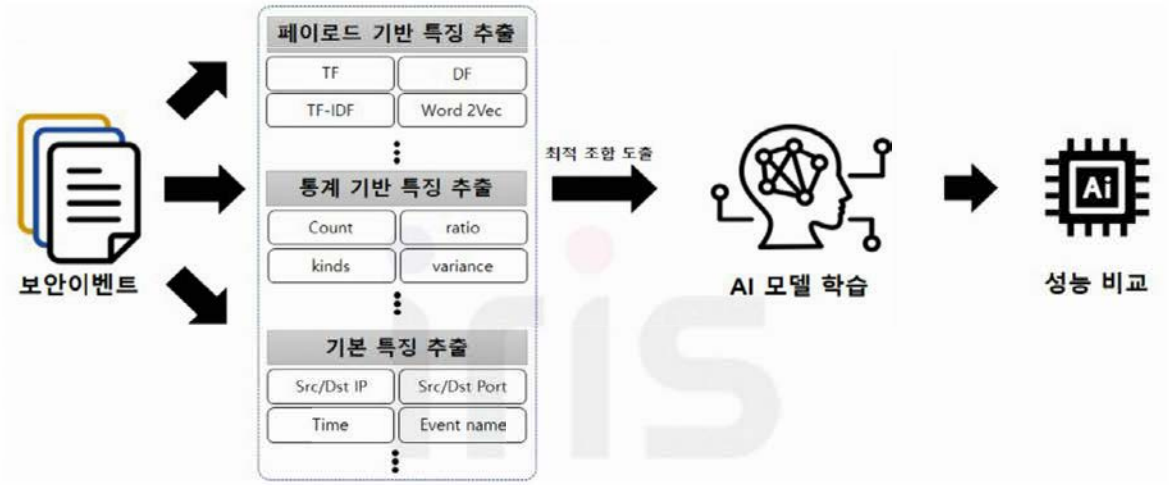
<예시 ①>

기 간	현재 보안이벤트 발생 시점으로부터 이전 5분 이내
조 건 식	발생한 보안이벤트 중 destination ip가 현재 보안이벤트의 destination ip와 동일한
대상필드	이벤트들의 이벤트 명
종 류	종류
생성쿼리	**SELECT** DISTINCT event_name **FROM** Log_Table **WHERE** destination ip = 현재 보안이벤트의 destination ip and datetime between (현재시간) and (현재시간 -5분)

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

<예시 ②>

기 간	현재 보안이벤트 이전 500개의
조 건 식	보안이벤트 중 source port가 1024 이하인
대상필드	보안이벤트
종 류	건 수
생성쿼리	SELECT count(A.event_name) FROM {SELECT event_name FROM Log_Table A WHERE datetime >= 현 시점 ORDER BY datetime ASC LIMIT 500} WHERE source port <= 1024



□ 공개 보안 위협 인텔리전스 기반 침해사고 지표 정보 수집 연구

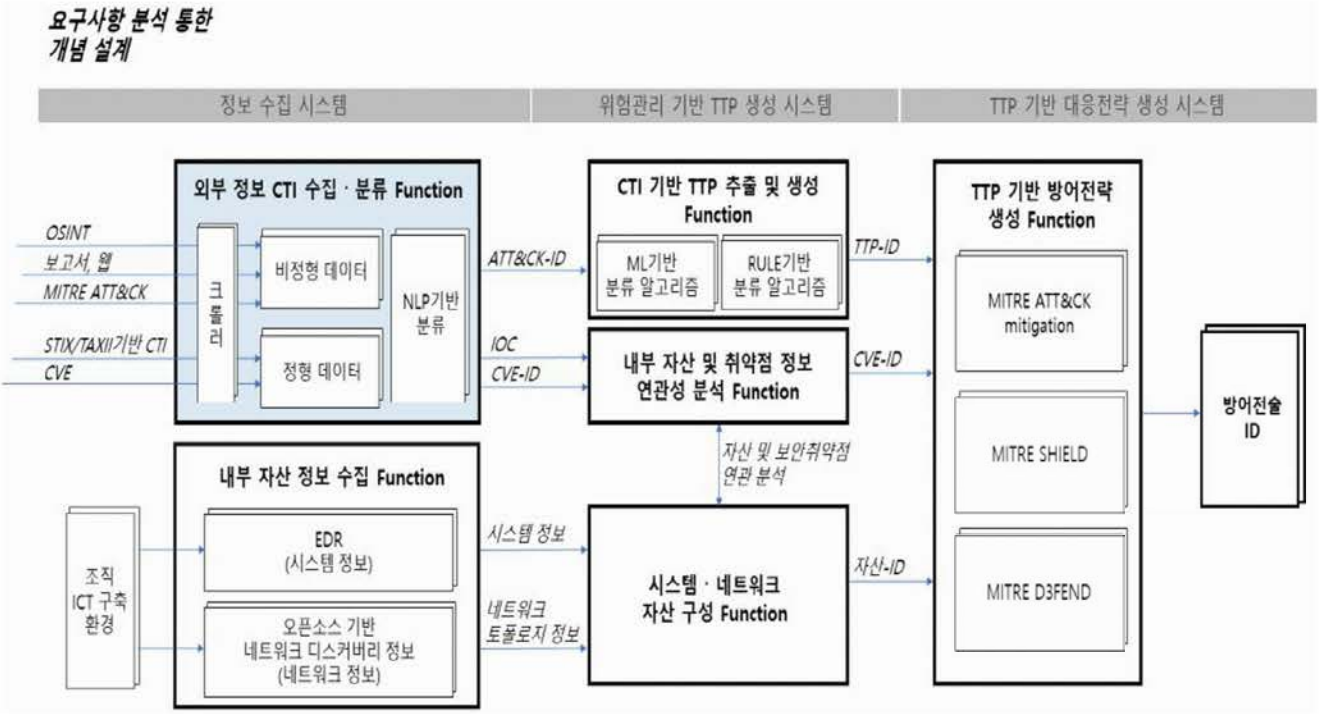
연구목표	공개 보안 위협 인텔리전스 기반 침해사고 지표 정보 수집 연구

세부 내용	
	1) 보안 위협 정보 유형 분석 및 분류 모델 연구
	2) 보안 위협 정보 수집 도구 및 요구사항 분석
	3) STIX/TAXII 기반 보안 위협 인텔리전스 정보 수집 및 정형화 기술 연구

1) 보안 위협 정보 유형 분석 및 분류 모델 연구

o CTI 정보 수집, TTP 기반 위협 인자·내부 자산 식별 및 방어 전략 생성 모델 개념 설계
- 3가지 서브 시스템 구성 : 정보 수집 시스템, 위험관리 기반 TTP 생성 시스템, TTP 기반 대응전략 생성 시스템으로 구성

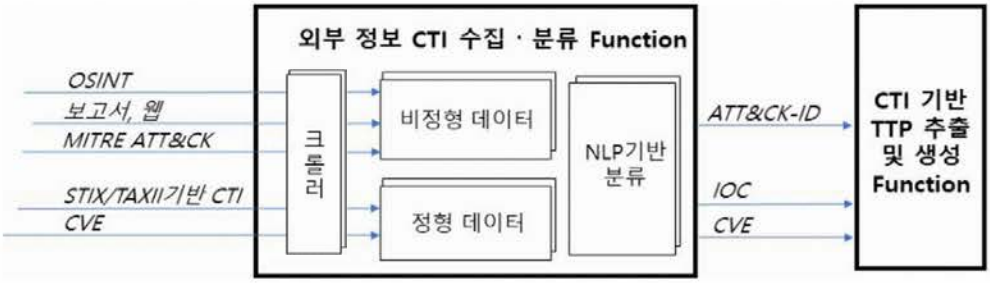
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



서브 시스템	주요 내용	입력	출력
정보 수집 시스템	외부 CTI 정보 수집 및 분류	비정형 데이터	ATT&CK 및 TTP 정보
		정형 데이터	CVE, IOC
	내부 자산 수집	EDR, 오픈소스 정보	시스템/네트워크 정보
위험관리 기반 TTP 생성 시스템	CTI 기반 TTP 추출 및 생성	ATT&CK/TTP 정보	TTP ID
	시스템/네트워크 자산 구성	시스템/네트워크 정보	자산 ID
	내부 자산 및 취약점 연관성 분석	자산 정보, 취약점 ID	CVE ID
TTP 기반 대응 전략 생성 시스템	MITRE ATT&CK Mitigations 전략 생성	TTP ID, 자산 ID, CVE ID	방어 전술 ID
	MITRE Shield 전략 생성		
	MITRE D3fend 전략 생성		

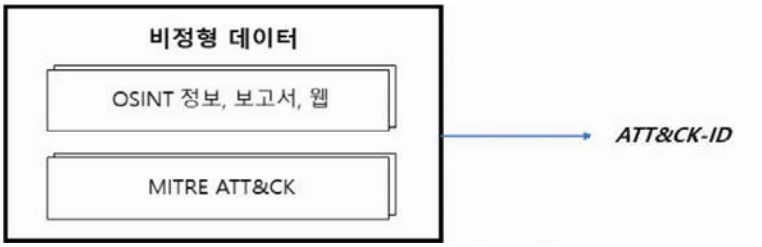
o CTI 정보 수집 및 분류 Function 개념 설계

- (입력 정보) 정형 데이터(CVE, MITRE ATT&CK, STIX/TAXII 기반 CTI) 및 비정형 데이터(OSINT, 보고서, 웹 등) 수집
- (보안 위협 정보 분류) 머신러닝 기반의 위협 정보 분석 및 분류 모듈
  - 자연어 처리 및 TF-IDF 가중치 모델을 바탕으로 데이터의 중요도 분석
  - 분석된 데이터 중요도 기반 분류 모듈 output 생성
- (출력 정보) MITRE의 ATT&CK-ID, 침해사고 지표(IOC) 데이터(IP, 도메인, URL 정보 등), 보안 취약점(CVE)을 출력으로 함



국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

2) (비정형 데이터) 보안 위협 정보 수집 도구 및 요구사항 분석



o 오픈소스 OSINT(공개 보안 위협) 기반 비정형 데이터 정보 수집 기술 조사

- 오픈소스 기반 OSINT 도구 : Shodan, metasploit, Aircrack-ng 등 8종

OSINT Tools	주요 내용
OSINT Framework	OSINT 정보를 수집하기 위한 도구를 디렉토리(목록) 형태로 제공하는 웹사이트
SpiderFoot	개인, 네트워크 및 비즈니스 데이터 소스에서 데이터를 스크래핑하는 OSINT 도구
Google Dorks	해킹 관련된 정보를 검색하고 수집하는 구글 검색 엔진
Shodan	IoT 기기 정보 검색 엔진(라우터, 스위치, FTP, 특정 웹 서버 정보, 취약점 검색)
Maltego	정보 수집 및 그래픽 상관분석을 위한 OSINT 도구
Metasploit	네트워크 취약점과 이 취약점을 익스플로잇 시킬 수 있는 침투 테스팅 도구
Recon-ng	파이썬 개발한 오픈소스 웹 정찰 도구
Aicrack-ng	와이파이 무선 네트워크의 보안 테스팅 및 크래킹 도구

- OSINT 기반 비정형 데이터 수집 정보 요구사항 분석

· OSINT Tools 별로 수집 가능한 비정형 데이터 유형 분석

※ 사용자 정보, 이메일 주소, DNS 정보, IP 주소 등 32개 정보 수집 가능

Data type	Subdata Type	Web
User name	Username Search Engines	Namechk, KnowEm, NameCheckr 외 7개
	Specific Sites	Amazon Usernames, Amazon Wishlists 외 4개
Email Address	Email Search	ThatsThem, Hunter, MailDB 외 8개
	Common Email Formats	Corporatate Email Formats, Email Format 외 3개
	Email Verification	MailTester, VarifyEmail, Email Validator 외 4개
	Other Subdata Type (3) : Breach Data, Spam Reputation Lists, Mail Blaklists	
Domain Name	Whois Records	DNStable, domainIQ, Who.is, IP2WHOIS 외 15개
	Subdomains	Aquatone, Google Subdomains, XRay 외 15개
	Discovery	Shodan, Kraken, SameID, AnalyzeID 외 4개
	Other Subdata Type (13) : Certificate Search, PassiveDNS, Reputation 등	
IP Address	Geolocation	MaxMind Demo, IP Fingerprint, My IP Address 외 8개
	Host / Port Discovery	Spyse, Shodan, Scans.io, Nmap, Scanless 외 4개
	IPv4	ASlookup.com, Onyphe, IPv4 CIDR Report 외 4개
	Other Subdata Type (9) : IPv6, BGP, Reputation, Blacklists, IP Loggers 등	
Dark Web	General Info	Reddit Deep Web, Reddit Onions, Reddit Darknet
	Clients	Tor Download, I2P Anonymous Network
	Discovery	OnionScan, TorBot, Tor Scan, Onioff 외 3개
	Other Subdata Type (2) : TOR Search, TOR Directories 등	

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

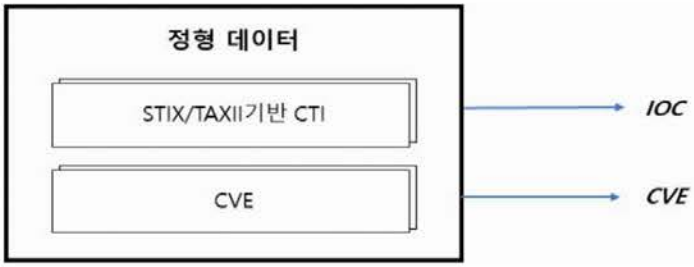
o 보고서 및 웹의 비정형 위협정보 수집 및 추출 기술 조사
- 딥러닝 기술을 이용한 위협정보 추출
  · 양방향 LSTM과 CRF 모델을 결합한 BI-LSTM-CRF 모델
    ※ 비정형 데이터를 입력받아 위협정보로 판단되는 키워드 탐지
- 정규 표현식을 이용한 위협정보 추출
  · 딥러닝 모델이 불필요한 경우(ex. CVE 정보)
    ※ CVE의 경우 정규식만으로 높은 정확도를 판별 가능
    ※ 딥러닝 모델의 예측값에 규칙 기반 후처리를 사용하여 추출 수행

o MITRE ATT&CK 및 TTP 정보 수집 분석
- 공격 관점 TTP를 정리한 MITRE ATT&CK Enterprise Matrix 기준 14개의 전술(tactics)과 185개의 기술(techniques), 367개의 하위 기술(sub-techniques) 분석

전술 이름	설명	하위 기술
정찰 (Reconnaissance)	공격 대상 선정 작업 수행. 침투 목표 기업의 정보 수집 (다크웹, 구글링 등 검색 엔진 활동, 공개된 내부 조직도 정보 등)	10
자원 개발 (Resource Development)	공격에 활용할 공격 인프라 구축 단계(또는 내부의 다른 시스템으로 이동하기 위한 준비), 접근 권한 정보(관리자 계정 정보) 수집, 공개된 해킹 도구 및 취약점 POC 코드, 취약점 분석	7
초기 접근 단계 (Initial Access)	네트워크 진입을 위해 사용자 환경에 대한 정보 취득 (스피어 피싱 기법 등 내부망 침투하기 위한 접근 시도)	9
실행 (Execution)	공격자가 원격제어 악성코드를 통해 공격자가 원하는 CMD 명령을 실행하기 위한 행동	12
지속 (Persistence)	공격 기반을 유지하고 시스템에 지속적으로 접근하기 위한 행동(감염 PC의 원격제어의 지속적 유지를 위해 레지스트리 등록을 통한 자동실행 기능 포함	19
권한 상승 (Privilege Escalation)	공격자가 시스템이나 네트워크에서 높은 권한(관리자 계정)을 얻기 위한 행동	13
방어 회피 (Defense Evasion)	공격자가 기업 내부 침입한 오랜 시간 동안 보안장비에 의해 탐지 당하는 것을 피하거나 우회하기 위해 공격행위 노출을 최소화 행동 (악성코드 난독화, 공격자 IP 주소 위장, 공격의 흔적을 제거하는 행위 등)	39
접속 자격 증명 (Credential Access)	시스템, 도메인 서비스, 자격증명 등을 접근하거나 제어하기 위한 행동(계정정보 탈취를 위해 공격자는 키로깅, 패스워드 크랙, 암호가 저장된 파일 탈취 등)	15
탐색(Discovery)	시스템 및 내부 네트워크의 정보를 얻기 위한 행동 (내부 정찰)	27
내부 확산 (Lateral Movement)	최초 침투 후 제어권 확보한 PC와 연결된 네트워크상의 원격 시스템에 접근하기 위한 행동(사전에 탈취한 내부 직원을 위장한 피싱 메일을 발송하는 방법을 통해 측면 이동을 시도)	9
내부 정보 수집 (Collection)	공격 목적이나 관련 정보가 포함된 데이터를 수집하기 위한 행동 (감염 PC를 통해 기업 내부 중요 정보를 수집, 감염 PC에서 키로깅 기능을 사용, 추가 계정정보를 탈취 등)	17
명령 및 제어(C&C)	공격자가 침입한 대상 네트워크 내부 시스템과 통신하며 제어하기 위한 행동	16
유출(Exfiltration)	공격자가 기업 내부 네트워크에서 데이터를 훔치기 위한 행동	9
임팩트(Impact)	공격 목표의 가용성 및 무결성을 손상 (시스템 파괴 등)	13

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

3) (정형 데이터) STIX/TAXII 기반 보안 위협 인텔리전스 정보 수집 및 정형화 기술 연구



o STIX/TAXII 기반 IOC 정보 수집 및 정형화 기술 방안 분석

- STIX/TAXII 기반 IOC 및 위협 정보 추출 기능 요구사항 분석

・STIX 2.1의 도메인 객체 구성 분석

객체	설명
Attack Pattern	공격자가 목표물을 손상시키려고 시도하는 방법을 설명하는 TTP의 형식
Campaign	특정 목표를 대상으로 일정 기간 동안 발생하는 일단의 악의적 활동 또는 공격을 설명하는 악의적 동작의 집합
Course of Action	공격을 예방하거나 진행 중인 공격에 대응하기 위해 실행한 작업
Grouping	STIX Bundle과 달리 참조된 STIX 객체가 공유 컨텍스트를 가지고 있음을 명시적으로 주장
Identity	실제 개인, 조직 또는 그룹은 물론 개인, 조직 또는 그룹의 부류를 표현
Indicator	악의적 사이버 활동을 검색하는데 사용할 수 있는 패턴 포함
Infrastructure	TTP의 일종으로 특정 목적을 지원하기 위한 시스템, 소프트웨어 서비스 또는 관련 물리적 및 가상의 리소스
Intrusion Set	단일 조직이 지휘한다고 판단되는 공통 속성을 가진 악의적 동작과 리소스의 그룹화된 집합체
Location	지리적 위치로, 주로 다른 SDO에 컨텍스트를 제공하는 데 사용
Malware	TTP의 일종으로 피해자의 시스템에 대한 기밀성, 무결성 및 가용성을 훼손하거나, 붕괴시킬 의도를 가지고 시스템에 삽입하는 프로그램
Malware Analysis	악성 프로그램에 대해 수행된 특정 정적 및 동적 분석의 메타데이터나 결과
Note	추가 분석 및 컨텍스트를 제공하는 정보 텍스트
Observed Data	IP 주소, 네크워크 연결, 파일 또는 레지스트리 키의 관측 정보를 포함하여 시스템과 네트워크에 대해 관측한 정보 전달
Opinion	다른 엔티티가 생성한 STIX 객체의 정보 정확성에 대한 평가
Report	멀웨어 또는 컨텍스트 관련 세부 정보 포함 공격 기법에 대한 설명과 같이 하나 이상의 주제에 초점을 맞춘 위협 인텔리전스 모음
Threat Actor	악의적인 의도를 가지고 운영된다고 판단되는 개인 또는 그룹
Tool	위협 행위자가 공격을 수행하기 위해 사용할 수 있는 합법적인 소프트웨어
Vulnerability	해커가 시스템 또는 네트워크에 대한 액세스 권한을 얻기 위해 직접 사용할 수 있는 소프트웨어의 취약한 부분

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

· STIX 2.1의 도메인 객체 구성 분석

객체	설명
Relationship	서로 어떻게 연관되어 있는지 설명하기 위해 SDO와 SCO를 연결하기 위해 사용
Sighting	CTI에서 무언가(Indicator, malware, tool, threat actor 등) 발견되었음을 의미

o 보안 취약점 정보(CVE) 수집 및 정형화 기술 방안 분석

- CVE와 MITRE ATT&CK 프레임워크 간 매핑 테이블 작성을 위한 CVE 수집 가능 데이터 분석

CVE 내 수집 데이터		설명
CVE	ID	[CVE 접두사(Prefix)-연도-순서번호]로 구성된 CVE 식별자
	Description	CVE 세부 설명 (취약점 키워드, 플랫폼, 취약점 상태 등 포함)
CVSS	Score	보안 취약점 위험도 평가 표준
	Vector	CVSS 지표 정보(공격벡터, 공격복잡도, 요구권한, 사용자 상호작용 등)
CWE-ID		해당 CVE와 관계된 약점 식별자
CPE 정보		Cutomer Premiss Equipment, 고객 소유 장치

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

상세 추진 내용 ② 위협 분석 자동화 기술

□ 개발 기술 개요

o (개발목표) 위협 분석 자동화 기술 설계

1) 공개 보안 위협 인텔리전스 정보 및 MITRE ATT&CK Matrix 기반 TTP 생성 기술 연구 및 설계
2) TTP 정보 기반 위협 인자 및 자산 식별 기술 설계
3) 보안 관제 플레이북 자동 생성 기술 연구 및 설계
4) 보안 관제 플레이북 검증·관리 기술 연구
5) 플레이북을 통한 자동화 분석 절차 관리 및 시각화 기술 설계

o (추진실적) 위협 분석 자동화 기술 요구사항 분석 및 설계 완료

- TTP 생성 및 위협 인자·자산 식별 기술 요구사항 분석 완료 **개발목표 1, 2**
- 보안 관제 플레이북 생성·검증·실행 기술 요구사항 분석 완료 **개발목표 3, 4**
- 위협 분석 자동화 기술 설계 완료 **개발목표 3, 4, 5**

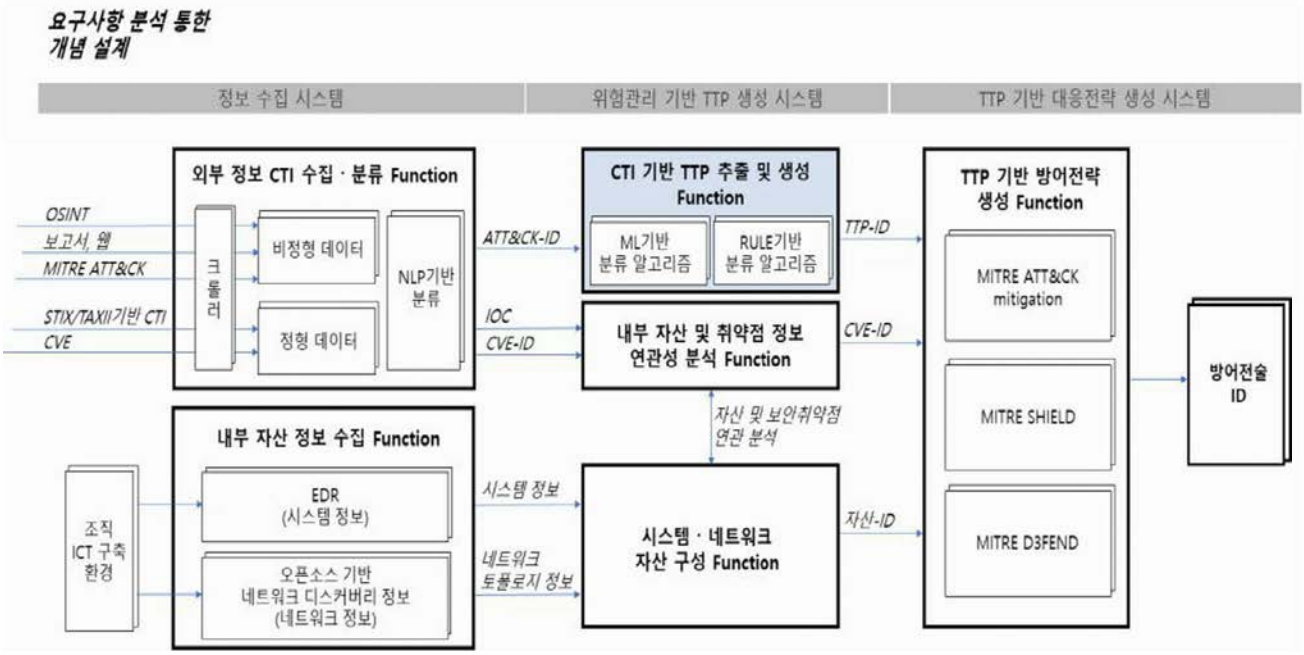
□ TTP 생성 및 위협 인자·자산 식별 기술 요구사항 분석

연구목표	TTP 생성 기술 및 TTP 기반 위협 인자·자산 식별 기술 요구사항 분석

세부 내용	
	1) CTI 기반 TTP 정보 추출·생성 기술 요구사항 분석
	2) TTP 기반 위협 인자 식별 기술 요구사항 분석

□ TTP 생성 및 위협 인자·자산 식별 기술 요구사항 분석 세부 내용

1) CTI 기반 TTP 정보 추출·생성 기술 요구사항 분석



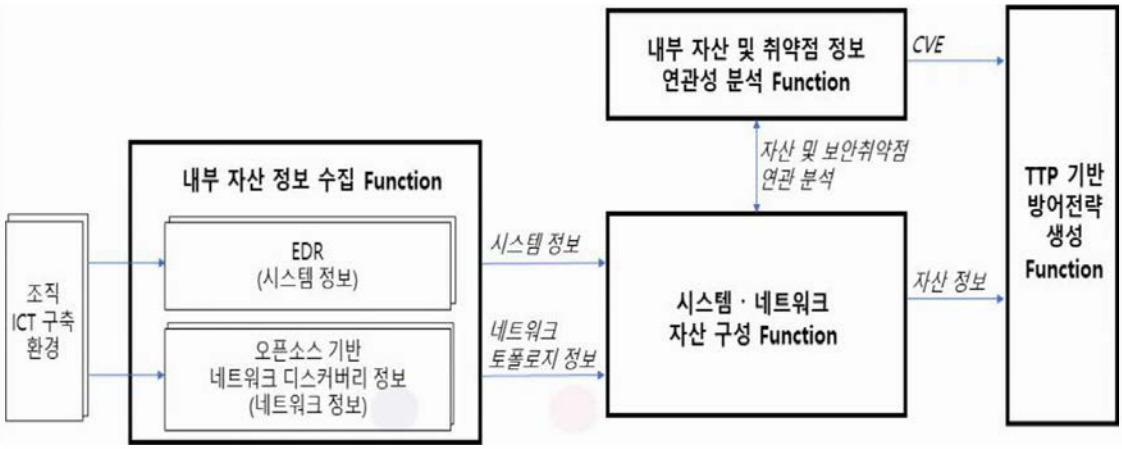
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

o CTI 기반 TTP 정보 추출·생성 요구사항 분석 및 개념 설계

- (입력 정보) 외부 정보 CTI 수집 Function의 출력 정보(IOC, ATT&CK ID)를 CTI 기반 TTP 추출·생성 Function의 입력으로 함
- (TTP 추출·생성) ML 및 Rule 기반 분류 알고리즘을 통한 TTP 정보 추출
- (출력 정보) MITRE ATT&CK의 TTP-ID를 출력으로 함

2) TTP 기반 위협 인자 식별 기술 요구사항 분석

o 내부 자산 디스커버링 및 구성 요구사항 분석 및 개념 설계



- (입력 정보) EDR과 오픈소스를 사용하여 수집한 각 조직의 ICT 구축 환경의 내부 자산을 입력으로 함
- (내부 자산 구성) EDR 및 오픈소스를 활용을 통한 내부 자산 디스커버링 수행 후 시스템 정보 및 네트워크 토폴로지 수집 정보 요구사항 분석
  · 시스템 정보 수집 : EDR(Endpoint Detection Response) 활용 방안 분석

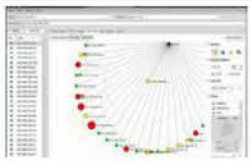
접근 방법	설명
EDR	EDR 장비에서 수집되는 정보 예시: 3개 플랫폼(Windows, Linux, MacOS)의 총 48종 데이터 소스 (Process Monitoring, API monitoring 등)

데이터 소스 (예시)	기술 개수	데이터 소스 (예시)	기술 개수
Process Monitoring	149	Windows Error Reporting	4
File monitoring	86	Email gateway	3
Process command-line parameters	82	Kernel drivers	3
API monitoring	36	Services	3
Process use of network	34	Third-party application logs	3
Windows Registry	34	BIOS	2
Packet capture	31	Detonation chamber	2
Authentication logs	28	Environment variable	2
Netflow/Enclave netflow	23	Host network interface	2
Binary file metadata	17	Mail server	2
DLL monitoring	16	MBR	2

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

데이터 소스 (예시)	기술 개수	데이터 소스 (예시)	기술 개수
Network protocol analysis	16	Access Tokens	1
Windows event logs	14	Asset Management	1
Loaded DLLs	12	Browser extensions	1
System calls	9	Digital Certificate Logs	1
Malware reverse engineering	8	DNS records	1
SSL/TLS inspection	8	EFI	1
Anti-virus	6	Named Pipes	1
Data loss prevention	6	PowerShell logs	1
Application Logs	5	Sensor health and status	1
Network device logs	4	VBR	1
Network intrusion detection system	4	Web application firewall logs	1
User interface	4	Web logs	1
Web proxy	4	WMI Objects	1

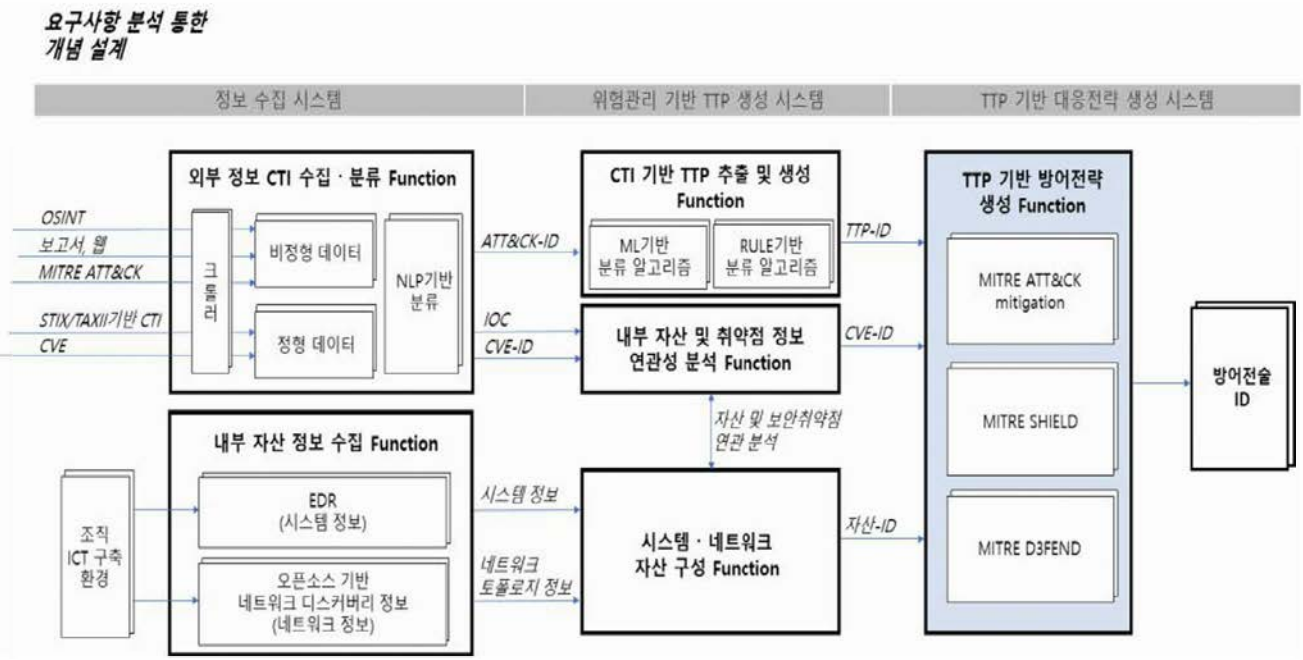
· 네트워크 토폴로지 정보: 오픈소스(Solarwinds, Device42, ZenMap) 활용 방안 분석 및 도구 분석

접근 방법	설명	
Solarwinds	네트워크 장치 스캐너를 통한 네트워크 장치 모니터링, 검색, 토폴로지 매핑 툴	
Device42	전력 모니터링·제어 모듈, 환경 모니터링, IP 주소 관리, 암호 관리, 심층 애플리케이션 관계 매핑 툴	
ZenMap	포트 스캐닝, 특정 IP에 대한 오픈 포트 점검 툴	

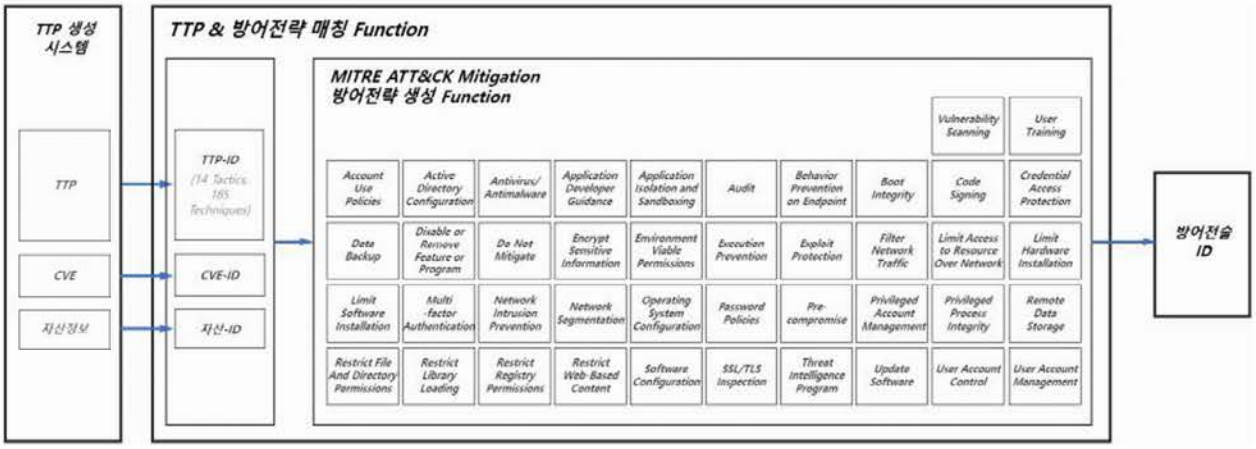
- (내부 자산 및 CVE 연관성 분석) 시스템/네트워크 자산 및 보안취약점 연관 분석으로 CVE-ID 도출
- (출력 정보) 각 조직 내부 자산의 시스템/네트워크 자산 구성 및 연관 취약점 정보(자산-ID, CVE-ID)를 출력으로 함

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

o TTP 기반 대응전략 생성 시스템 요구사항 분석 및 개념 설계



- (입력 정보) CTI 기반 TTP 추출·생성 Function의 TTP-ID, CVE DB의 CVE=ID, 내부 자산 정보 구성 Function의 시스템/네트워크 자산-ID를 입력으로 함
- (방어 전략) MITRE의 3개 방어 전략(ATT&CK Mitigations, SHEILD, D3FEND) 분석
  · MITRE ATT&CK Mitigations : 42개의 Mitigations로 구성. MITRE ATT&CK의 각 기술에 Mapping되어 있음
  ※ Mitigation Name : Account Use Policies, Active Directory Configuration 등



Mitigations 전술	설명	Attack ID 개수
계정 사용 정책	로그인 시도 잠금, 특정 로그인 시간 등과 같은 계정 사용과 관련된 기능을 구성	4
액티브 디렉토리 구성	특정 기술의 사용을 방지하도록 액티브 디렉토리를 구성	11
안티 멀웨어	서명 또는 휴리스틱을 사용하여 악성 소프트웨어를 탐지	11

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

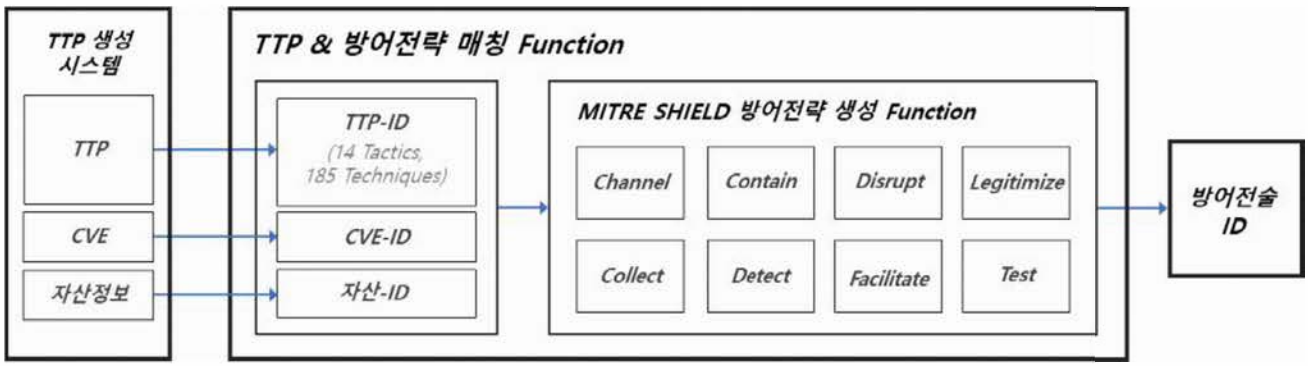
Mitigations 전술	설명	Attack ID 개수
애플리케이션 개발자 지침	공격자가 이용할 수 있는 보안 취약점 도입을 피하기 위해 애플리케이션 개발자에게 제공되는 모든 지침 또는 교육을 설명	3
애플리케이션 격리 및 샌드박싱	엔드포인트 시스템에 있거나 엔트포인트 시스템으로 전송 중인 가상 환경으로 코드 실행을 제한	12
감사	잠재적인 약점을 식별하기 위해 시스템, 권한, 안전하지 않은 소프트웨어, 안전하지 않은 구성 등에 대한 감사 또는 스캔을 수행	59
엔드포인트의 행동 방지	기능을 사용하여 엔드포인트 시스템에서 의심스러운 행동 패턴이 발생하지 않도록 방지	14
부팅 무결성 체크	안전한 방법을 사용하여 시스템을 부팅하고 운영 체제 및 로딩 메커니즘의 무결성을 확인	11
코드 서명	신뢰할 수 없는 코드가 실행되는 것을 방지하기 위해 디지털 서명 확인으로 바이너리 및 애플리케이션 무결성을 강화	17
자격증명 액세스 보호	공격자의 성공적인 자격증명 액세스를 방지하는 기능을 사용	8
데이터 백업	최종 사용자 시스템 및 중요 서버에서 데이터 백업을 가져와 저장	9
기능·프로그램 비활성화/제거	공격자의 남용을 방지하기 위해 불필요하고 잠재적으로 취약한 소프트웨어에 대한 액세스를 제거하거나 거부	47
완화 금지	완화가 손상 위험을 증가시킬 수 있으므로 완화가 권장되지 않는 기술을 연관시키는 것	2
민감한 정보 암호화	강력한 암호화로 민감한 정보를 보호	28
환경 변수 수정 방지	권한이 없는 사용자 및 그룹에 의한 환경 변수 수정을 방지	2
실행 방지	응용 프로그램 제어 및/또는 스크립트 차단을 통해 시스템에서 코드 실행을 차단	55
익스플로잇 보호	소프트웨어 악용이 발생하거나 이를 나타낼 수 있는 조건을 감지하고 차단	11
네트워크 트래픽 필터링	네트워크 어플라이언스를 사용하여 수신 또는 송신 트래픽을 필터링하고 프로토콜 기반 필터링을 수행	38
네트워크 리소스 액세스 제한	파일 공유에 대한 액세스, 시스템에 대한 원격 액세스, 불필요한 서비스를 방지	14
하드웨어 설치 제한	사용자 또는 그룹이 USB 장치를 포함하여 시스템에 승인되지 않은 하드웨어를 설치하거나 사용하지 못하도록 차단	4
소프트웨어 설치 제한	사용자 또는 그룹이 승인되지 않은 소프트웨어를 설치하지 못하도록 차단	6
다단계 인증	두 개 이상의 증거를 사용하여 시스템을 인증	34
네트워크 침입 방지	침입 탐지 서명을 사용하여 네트워크 경계에서 트래픽을 차단	54
네트워크 세그먼테이션	중요한 시스템, 기능 또는 리소스를 격리하기 위해 네트워크 섹션을 설계	35
운영 체제 구성	기술에 대한 시스템 강화를 초래하는 운영 체제 또는 운영 체제의 공통 기능과 관련된 구성 변경을 수행	35
비밀번호 정책	계정에 대한 보안 암호 정책을 설정하고 시행	42
사전 타협	정찰 및 자원 개발 기술과 같이 적이 초기 접근 권한을 획득하기 전에 발생하는 기술에 적용되는 모든 해당 완화 활동에 사용	75
특수 권한 및 계정 관리	SYSTEM 및 루트를 포함하여 권한 있는 계정과 관련된 생성, 수정, 사용 및 권한을 관리	98
특수 권한 및 프로세스 무결성	보호된 프로세스 라이트, 프로세스 주입 방지 방어 또는 기타 프로세스 무결성 시행 조치를 통해 중요한 시스템 구성 요소와 상호 작용하는 데 사용할 수 있는 높은 권한으로 프로세스를 보호	7

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

Mitigations 전술	설명	Attack ID 개수
원격 데이터 저장	침입탐지 로그 데이터나 민감한 정보의 노출을 방지하기 위해 접근을 더 잘 통제할 수 있는 원격 보안 로그 및 민감한 파일 저장소를 사용	7
파일 및 디렉토리 권한 제한	사용자 또는 권한 있는 계정에 국한되지 않는 디렉토리 및 파일 권한을 설정하여 액세스를 제한	53
라이브러리 로드 제한	적절한 라이브러리 로딩 메커니즘을 구성하고 잠재적인 취약한 소프트웨어를 조사하여 신뢰할 수 없는 코드를 로드하기 위해 운영 체제 및 소프트웨어에서 라이브러리 로딩 메커니즘의 남용을 방지	3
레지스트리 권한 제한	Windows 레지스트리에서 특정 하이브 또는 키를 수정하는 기능을 제한	15
웹 기반 콘텐츠 제한	특정 웹사이트 사용 제한, 다운로드/첨부 파일 차단, 자바스크립트 차단, 브라우저 확장 프로그램 제한	22
소프트웨어 구성	소프트웨어 작동 방식과 관련된 보안 위험을 완화하기 위해 소프트웨어(운영 체제 제외)에 대한 구성 변경을 구현	23
SSL/TLS 검사	SSL/TLS 세션을 중단하고 검사하여 공격자의 활동에 대해 암호화된 웹 트래픽을 확인	4
위협 인텔리전스 프로그램	위협 인텔리전스 프로그램은 조직이 자체 위협 인텔리전스 정보를 생성하고 추세를 추적하여 위험을 완화하기 위한 방어 우선 순위를 알려주는 데 도움	4
소프트웨어 업데이트	악용 위험을 완화하기 위해 정기적인 소프트웨어 업데이트를 수행	30
사용자 계정 제어	공격자가 높은 프로세스 액세스 권한을 얻을 위험을 완화하도록 Windows 사용자 계정 컨트롤을 구성	8
사용자 계정 관리	사용자 계정과 관련된 생성, 수정, 사용 및 권한을 관리	71
사용자 교육	성공적인 스피어피싱, 사회 공학 및 사용자 상호작용과 관련된 기타 기술의 위험을 줄이기 위해 공격자의 액세스 또는 조작 시도를 인식하도록 사용자를 교육	35
취약점 스캐닝	취약점 검색은 잠재적으로 악용 가능한 소프트웨어 취약점을 찾아 수정하는 데 사용	5

· MITRE Shield : 방어자 관점의 8개 전술과 135개 기술로 구성

※ tactics : Channel, Collection, Contain, Detection, Disrupt, Facilitate 등



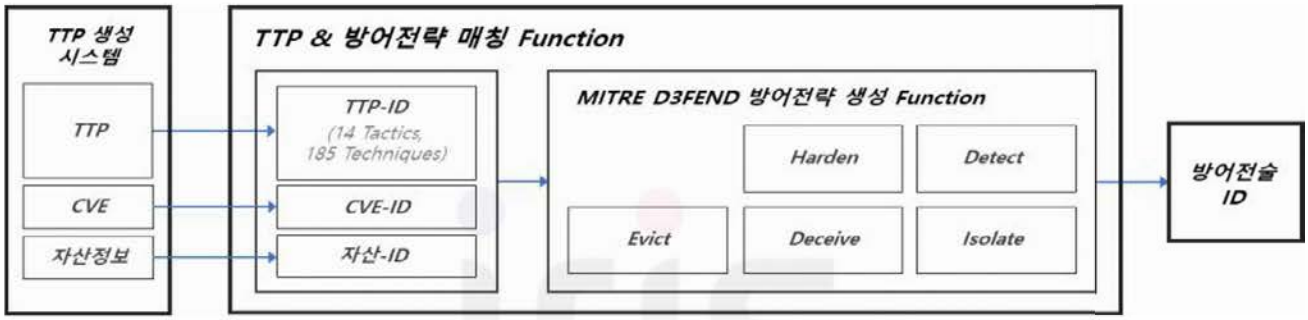
전술 이름	설명	하위 기술
경로 유인 (Channel)	공격자를 중요한 시스템이나 네트워크 세그먼트에서 벗어나 유인 시스템이나 강화된 장치로 유인하는 데 사용	19
정보 수집 (Collect)	공격자 또는 적대적인 활동에 대한 정보를 수집하여 다른 방어에 정보를 제공하는 데 사용	19

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

전술 이름	설명	하위 기술
진압 (Contain)	운영 위치에 따라 특정 서브넷 또는 시스템에 액세스하지 못하도록 하는 등 공격자가 특정 경계 또는 제약 조건을 벗어나는 것을 방지하기 위해 사용	11
탐지 (Detect)	공격자가 시스템이나 리소스를 건드릴 때 경고하는 트립와이어를 도입하여 공격자 탐지 수행	23
임무 방해 (Disrupt)	공격자의 임무의 일부 또는 전부를 수행하는 것을 차단하거나 방지하기 위해 사용	16
촉진 (Facilitate)	공격자들이 그들의 임무의 일부 또는 전부를 수행할 수 있도록 하기 위해 사용	16
정당화 (Legitimize)	사용자 계정, 파일 등 공격자가 원하는 콘텐츠를 포함시켜 공격자가 허위 구성 요소가 진짜라는 것으로 믿게 함	12
Test	공격자의 관심사, 능력, 행위, 동기 등을 관찰하는데 사용	19

· MITRE D3FEND : 방어자 관점의 5개 전술과 17개의 기술로 구성

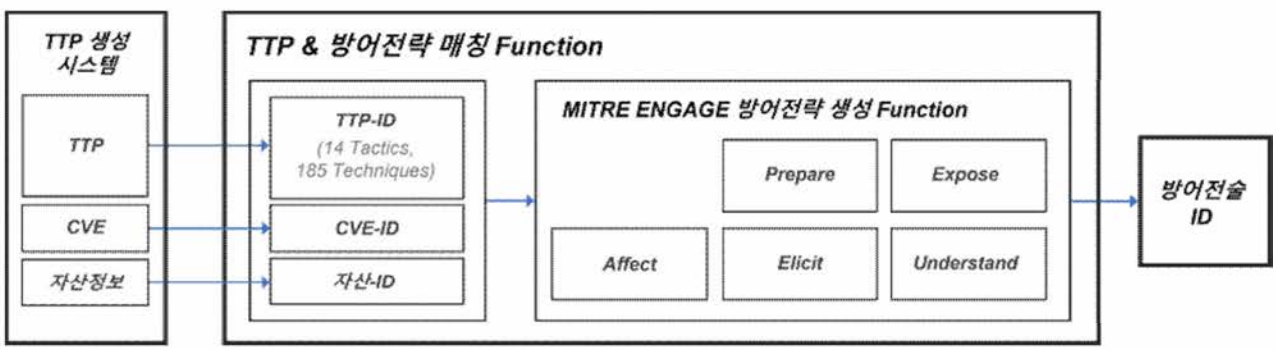
※ tactics : Harden, Detect, Isolate, Deceive, Evict



전술 이름	설명	하위 기술
Harden	컴퓨터 네트워크 공격 기회 비용을 증가시키기 위한 방어 전술	4
Detect	컴퓨터 네트워크에서 공격자의 액세스 또는 무단 활동을 식별 및 탐지하기 위한 방어 전술	7
Isolate	시스템에 논리적 또는 물리적 장벽을 만들어 공격자들이 추가 액세스를 일으키는 기회를 줄이기 위한 방어 전술	2
Deceive	잠재적인 공격자 관찰이나 통제된 환경에 접근하도록 광고, 유인 및 허용하는데 사용하는 방어 전술	2
Evict	컴퓨터 네트워크에서 공격자를 제거하는 데 사용하는 방어 전술	2

· MITRE ENGAGE : 방어자 관점의 5개 목표와 31개의 활동으로 구성

※ Goal : Prepare, Expose, Affect, Elicit, Understand



국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

목표 이름	설명	하위 활동
Prepare	방어자가 작전을 통해 달성하고자 하는 바에 대해 생각하도록 도움	5
Expose	진행 중인 공격자의 존재를 밝힘	7
Affect	공격자의 작전에 부정적인 영향을 미침	17
Elicit	공격자의 전술, 기술 및 절차에 대해 알아냄	14
Understand	방어자가 방어자의 자세를 개선하기 위해 배운 지식을 포착하고 활용 및 정제	4

- (출력 정보) TTP-ID, CVE-ID 및 자산-ID에 적합한 방어 전략 및 전술 ID(3가지 방어 전략 중 선택. 예를 들어, Shield의 'DTE0003') 생성

□ 보안 관제 플레이북 생성·검증·실행 기술 요구사항 분석

연구목표	플레이북 자동 생성/검증·관리/실행 모듈별 기능 요구사항 분석

세부 내용	
	1) 플레이북 자동 생성 모듈의 기능 요구사항 분석
	2) 플레이북 검증·관리 모듈의 기능 요구사항 분석
	3) 플레이북 실행 모듈의 기능 요구사항 분석

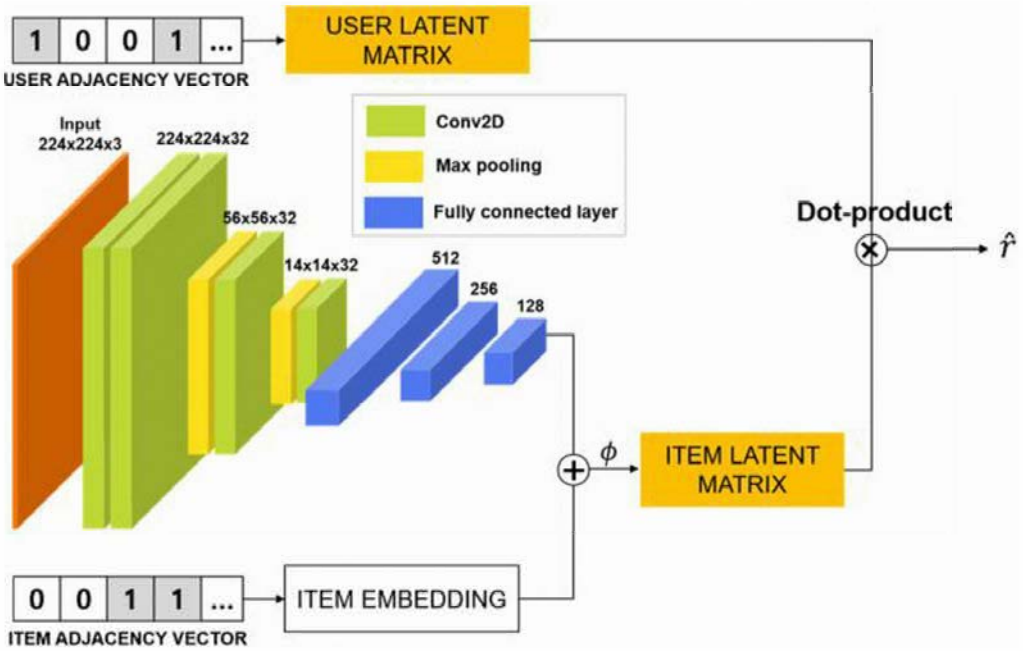
□ 보안 관제 플레이북 생성·검증·실행 기술 요구사항 분석 세부 내용

1) 플레이북 자동 생성 모듈의 기능 요구사항 분석

o 플레이북 자동 생성 AI 학습 모델 요구사항 분석

- Graph Theory 및 RL 기반의 플레이북 자동 생성 방법론
  > 플레이북 자동 생성 방법론으로 제시된 Graph Theory에서는 데이터에서 추출한 컴포넌트를 노드로 지정하고, 노드와 노드 사이의 관계는 엣지로 표현
  > 엣지와 노드로 구성되는 그래프 통해 계산적으로 표현함으로써 신경망에 적용
  * Matrix Factorization
  · m개의 event와 n개의 action에 대하여 이를 $m \times n$의 형태의 벡터 R로 나타냈을 때, 오차함수를 최소화하는 k 요인 벡터를 찾는 것
  · event-action 행렬을 event와 action의 잠재행렬(latent matrix)로 매핑하여 평가하지 않은 action에 대해서도 추정 가능
  · 모든 event에 대하여 모든 대응의 점수를 매기는 것은 불가능하기 때문에 실제 행렬 R은 대부분 희소 행렬(sparse matrix)로 구성

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



<Matrix factorization 구조도>

```
def single_layer_mf_image_withbias(n_users, n_items, n_factors):
    item_input = Input(shape=[1])
    item_embedding = Embedding(n_items, n_factors, embeddings_regularizer=l2(1e-5))(item_input)
    item_vec = Flatten()(item_embedding)

    image_input = Input(shape=(224,224,3))
    imgflow = tf.keras.layers.Conv2D(32,(3,3),padding='same',activation = 'relu')(image_input)
    imgflow = tf.keras.layers.Conv2D(32,(3,3),padding='same',activation = 'relu')(imgflow)
    imgflow = MaxPooling2D(pool_size=(4,4))(imgflow)
    imgflow = Dropout(0.25)(imgflow)

    imgflow = tf.keras.layers.Conv2D(32,(3,3),padding='same',activation = 'relu')(imgflow)
    imgflow = MaxPooling2D(pool_size=(4,4))(imgflow)
    imgflow = Dropout(0.25)(imgflow)

    imgflow = tf.keras.layers.Conv2D(32,(3,3),padding='same',activation = 'relu')(imgflow)
    imgflow = Dropout(0.25)(imgflow)
```

<Matrix factorization 실행 코드 예시(일부)>

* 특이값 분해 (Singular Value Decomposition, SVD)

· Matrix factorization 문제를 해결하는 방법 중 하나로, 이를 위해 SVD는 행렬 R을 3개의 행렬 곱인 $U\Sigma V^T$로 나타냄

· U : 역행렬이 대칭 행렬인 m x m 크기의 행렬로, event와 latent factor 간의 관계를 나타냄

· Σ : 비 대각 성분이 0인 m x n크기의 행렬로, latent factor의 중요도를 나타냄

· V^T : 역행렬이 대칭 행렬인 n x n 크기의 행렬로, action과 latent matrix 간의 관계를 나타냄

· Latent factor는 event와 action이 가지는 특성을 의미

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

```
def SVD_image_withbias(n_users, n_items, n_factors):
    item_input = Input(shape=[1])
    item_embedding = Embedding(n_items, n_factors, embeddings_regularizer=l2(1e-5))(item_input)
    item_vec = Flatten()(item_embedding)

    image_input = Input(shape=(224,224,3))
    imgflow = tf.keras.layers.Conv2D(32,(3,3),padding='same',activation = 'relu')(image_input)
    imgflow = tf.keras.layers.Conv2D(32,(3,3),padding='same',activation = 'relu')(imgflow)
    imgflow = MaxPooling2D(pool_size=(4,4))(imgflow)
    imgflow = Dropout(0.25)(imgflow)

    imgflow = tf.keras.layers.Conv2D(32,(3,3),padding='same',activation = 'relu')(imgflow)
    imgflow = MaxPooling2D(pool_size=(4,4))(imgflow)
    imgflow = Dropout(0.25)(imgflow)

    imgflow = tf.keras.layers.Conv2D(32,(3,3),padding='same',activation = 'relu')(imgflow)
    imgflow = Dropout(0.25)(imgflow)
```

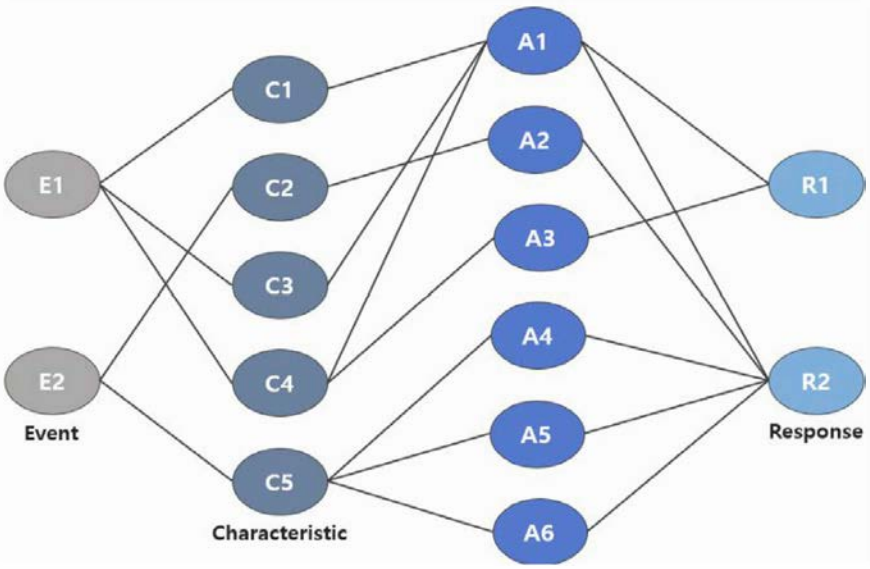
<특이값 분해 실행 코드 예시 (일부)>

① 상황, 분석 이력, 대응 이력 데이터에서 컴포넌트를 추출한 후, 이를 바탕으로 노드 생성

* 현재 보안관제 대응이록의 경우 분류 없이 자유 형식의 텍스트로 기록되어 있으며, 추후 분석 작업과의 연계를 위해 근거, 결과, 판단에 대한 구조화를 위한 기본적인 분류 방안 연구 예정

② 순차 대응이력을 기반으로 노드와 노드 사이의 엣지를 연결하여 그래프 생성

* 그래프 설계는 아래의 그래프 구조 설계와 같이 2-depth 및 3-depth 등의 구조적 확장 가능



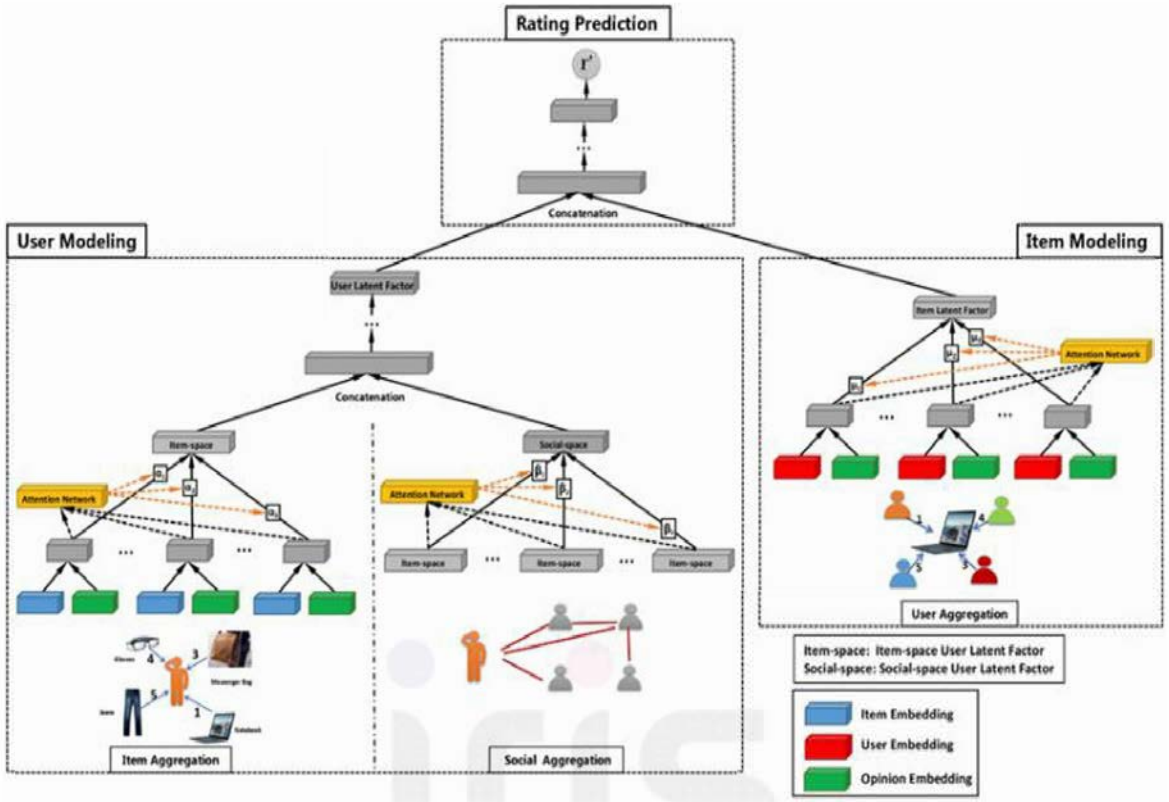
<플레이북 그래프 구조 설계>

③ 신경망을 활용하여 엣지의 누적을 통해 그래프를 학습한 후, 연결성이 높은 노드를 선정

* 코사인 유사도를 사용하여 고정된 프로세스가 아닌 유동적인 action을 기반으로 노드 선정함. event 간 유사도와 하나의 event에 대한 action 들의 유사한 정도를 구함으로써 새로운 event가 들어올 시 기존 event와의 코사인 유사도를 통해 가장 유사한 response를 연결할 수 있음

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

* 그래프 신경망 (Graph Neural Network, GNN)
  - 그래프에 직접 적용할 수 있는 신경망(Neural Network)
  - 그래프에 있는 Node 사이의 관계를 모델링하고, 그에 대한 임베딩 형태의 표현을 생성하기 위해 이웃 node 간의 정보를 집계하는 과정 반복



<그래프 신경망 기반 추천 시스템 구조도>

  - Node 사이 연결 관계와 이웃 node의 상태를 이용하여 업데이트 후 마지막 상태를 통해 예측 업무 수행
  - 모든 Node 간의 관계 정보를 담고 있도록 데이터를 표현하기 위해 인접 행렬(Adjacency matrix)로 나타낼 수 있음
  - Node 간의 관계 정보 이외에도 node 자체가 가지고 있는 feature 정보를 표현하기 위해 feature matrix를 사용하여 나타냄
  - GNN task
    - Node Classification : 점들을 분류하는 문제 (ex. 페이스북 친구 추천)
    - Link Prediction : 그래프의 점들 사이의 관계를 파악하여 두 점 사이의 연관성을 예측 (ex. 추천 시스템)
    - Graph Classification : 그래프를 여러 카테고리로 분류 (ex. 단백질의 분자 구조 예측)

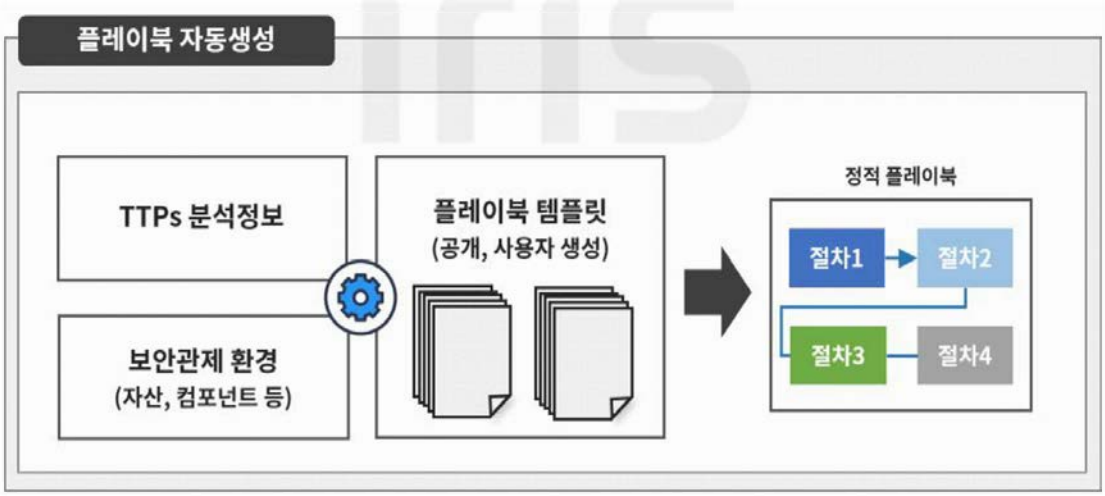
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

```python
class GGNNSparse(ggnn_base.GGNNBase):
    def forward(self, graphs: graph_as_adj_list.DirectedGraphAsAdjList):

        hidden = graphs.node_features
        num_nodes = hidden.shape[0]

        for t in range(self.params.num_layers):
            message = torch.zeros(num_nodes, self.params.hlayer_size,
                                  device=str(hidden.device),
                                  dtype=data_types.TORCH_FLT)

            for edge_name, projection in self.get_edge_names_and_projections():
                adj_list = graphs.edge_type_to_adjacency_list_map[edge_name]
                if adj_list is None:
                    continue  # no edges of this type
                projected_feats = projection(hidden)
                #todo: potentially wasteful doing this projection on all nodes (ie many may not
                # be connected by all kinds of edge) -- less concerned about this for molecules
                message.index_add_(0, adj_list[0], projected_feats.index_select(0, adj_list[1]))

            hidden = self.GRU_hidden(message, hidden)

        return graph_as_adj_list.DirectedGraphAsAdjList(hidden, graphs.edge_type_to_adjacency_list_map, graphs.no
```

<그래프 신경망 실행 코드 예시 (일부)>

④ 연결성 높은 노드들을 바탕으로 플레이북을 생성 및 추천함으로써 이벤트에 대응하기 위한 최선의 대응 정책을 제시

* 대응 추천 시 현재 상황 및 이전 행위 결과를 바탕으로 분석가에게 다음으로 해야 할 행위의 우선순위와 Top-K를 동시에 제시하는 모델 설계 예정



<플레이북 자동 생성 프로세스>

o 플레이북 유효성 검증 요청 기능 요구사항 분석

- 플레이북 유효성 검증 요청 기능 필요성 분석

> 기존의 플레이북 생성과 검증 방식은 관제원의 인터뷰 내용과 SOC 보안관제 업무 정의서 등을 활용하여 플레이북 담당 인력이 직접 수동으로 생성하면서 플레이북의 절차 및 실행 가능성 검증을 수행함

> 본 과제에서는 플레이북의 생성 절차와 검증 절차를 단계적으로 나누어서 진행함으로써 AI 모델의 수행 목적을 정확하게 정의하여 연구를 진행함

> 유효성 검증 기능의 경우, 별도의 모듈에서 진행함으로써 플레이북 자동 생성 AI 모델의 수행 목표를 간소화하고, 학습용 데이터를 간소화할 수 있음

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- 플레이북 유효성 검증 요청 기능의 기능 요구사항 분석
  요구사항 ① : 생성된 플레이북에 대한 유효성 검증 요청 메시지 전송 기능 필요

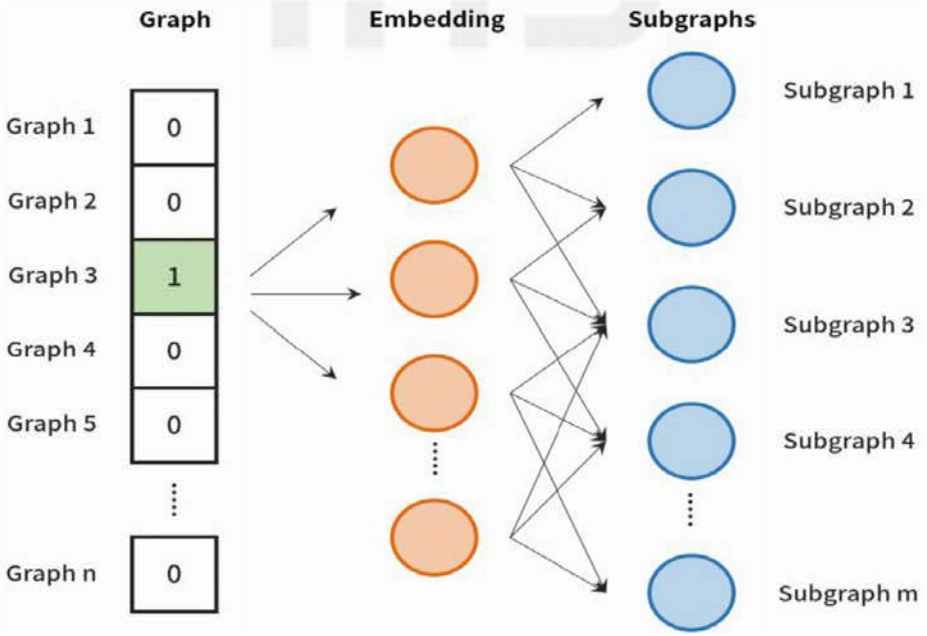
- 플레이북 유효성 검증 요청 필수 메시지 유형

구분	메시지
요청 송신	플레이북 유효성 검증 요청 메시지 ID
	메시지 생성 시간
	플레이북 유효성 검증대상 플레이북 조회용 ID

2) 플레이북 검증·관리 모듈의 기능 요구사항 분석

o 플레이북 유효성 검증 기능 요구사항 분석
- 유사도 분석을 통한 플레이북 유효성 검증 방법론
  > 전문가 플레이북과 자동 생성된 플레이북 간 유사도를 측정하기 위해 코사인 유사도를 사용하여 두 그래프 임베딩 간의 유사도를 정하는 방식
  * 그래프 임베딩 유사도 및 컴포넌트 유사도 등 추가 유사도 탐색 방안 분석

① 그래프 데이터의 차원을 축소하여 벡터공간에 압축적으로 표현하는 임베딩을 수행하기 위해 그래프 전체를 벡터로 표현하는 그래프 임베딩 작업을 수행하여 그래프 수준에서의 비교를 통한 유사도를 측정



<그래프 임베딩의 단계별 구성>

* 다양한 그래프 임베딩 방법론 중 가장 우수한 성능을 보이는 Graph2vec 적용 예정
* Graph2vec은 세 단계로 구성되며, 그래프의 모든 뿌리가 있는 부분 그래프를 샘플링하고 레이블을 재지정하여 그 결과로 m개의 서브 그래프를 얻음
  이후 입력된 그래프에 부분 그래프가 있을 확률을 계산하는 skip-gram 모델을 학습한

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

후 그래프 아이디가 원-핫 인코딩되어 들어오면 임베딩 계산 수행
Graph2vec은 부분 그래프를 예측하기 때문에 두 그래프가 비슷한 그래프를 가지게 될 경우, 즉 비슷한 구조를 가지면 비슷한 임베딩이 도출

② 생성된 그래프 임베딩을 바탕으로 코사인 유사도를 통해 유사도를 측정

$$similarity = \cos(\theta) = \frac{A \cdot B}{\|A\|\|B\|} = \frac{\sum_{i=1}^{n} A_i B_i}{\sqrt{\sum_{i=1}^{n} A_i^2}\sqrt{\sum_{i=1}^{n} B_i^2}}$$

<코사인 유사도 계산 수식>

* 코사인 유사도는 두 벡터 간 코사인 각도를 통해 두 벡터의 유사한 정도를 의미하는 것으로, 그래프 임베딩은 그래프가 완전히 일치하지 않더라도 그래프 내 존재하는 노드 간의 관계를 벡터공간에 나타내기 때문에 관계가 유사한 노드일수록 높은 유사도를 보임

- Flow 기반 컴포넌트 간 Input·Output 정보 Validation 체크 기능
  > 플레이북 컴포넌트 Input·Output 명세서 정의

<컴포넌트 정의 및 Input·Output Type 연구 - 93종 中 16종 예시>

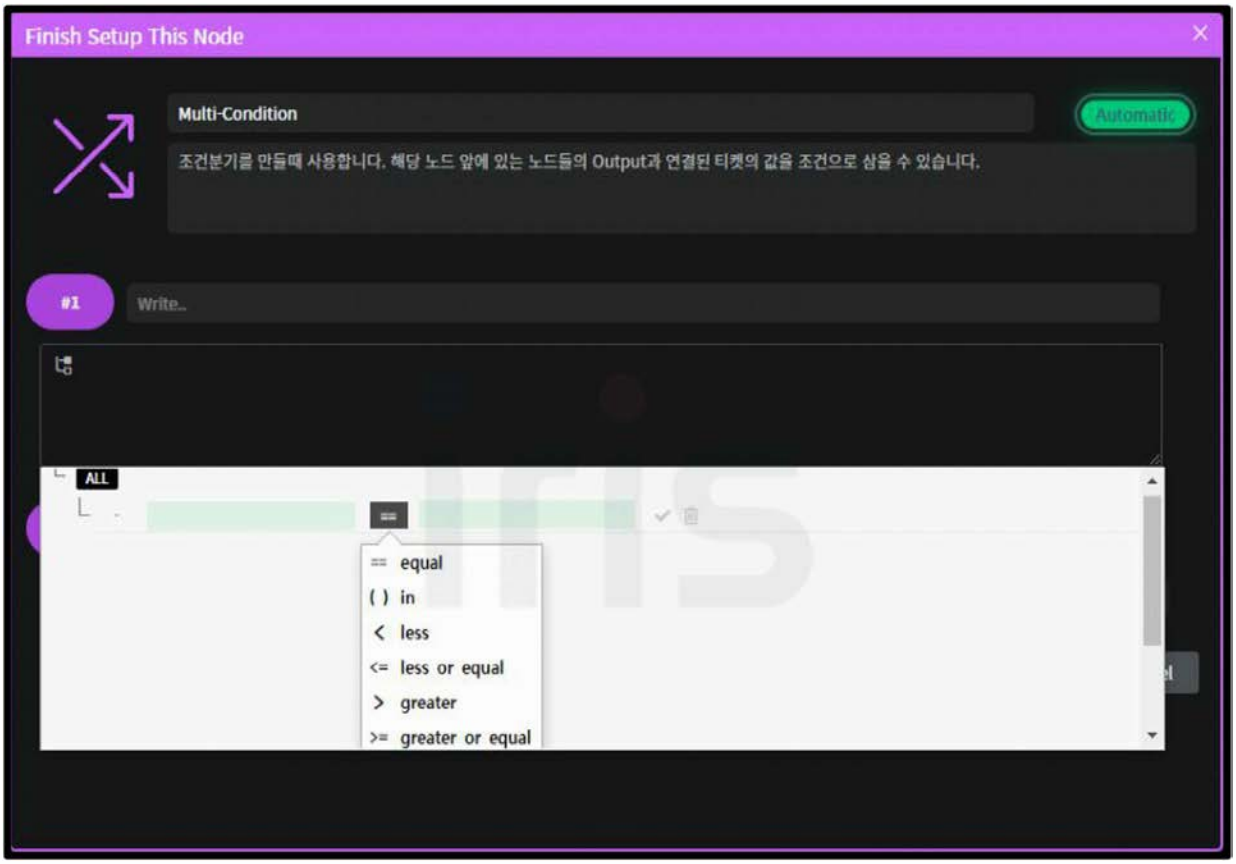
Component Name	컴포넌트 설명	기능 항목	Input	Output
Akamai	위협 정보 분석	Scan IP	String[]	threatYN, score, regdt, detail
ADuseIPDB	위협 정보 분석	Scan IP	String[]	
DShield	위협 정보 분석	Get Ip Info	String[]	
UrlScanIo	URL/Website scanner, 위협 정보 분석	Url Check	String[]	
ESTsecurity Threat Inside	위협 정보 분석	Scan FILE	String[]	
		Scan IP		
		Scan MALWARE		
		Scan MD5		
		Scan SHA1		
		Scan SHA256		
		Scan URL		
MAXMIND GeoIP	IP GEO 분석	Get Ip Info	String	nation, city, 위경도, IDC
History	eyeCloudSOAR 기처리 위협정보 분석	Get History	String	ticket info count
		Get History Info		
		Get Ticket Info		
		Search History		

> 분기 컴포넌트 내 사용자 정의 분기 조건 설정 및 구동 간 조건 식별 기능 연구

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

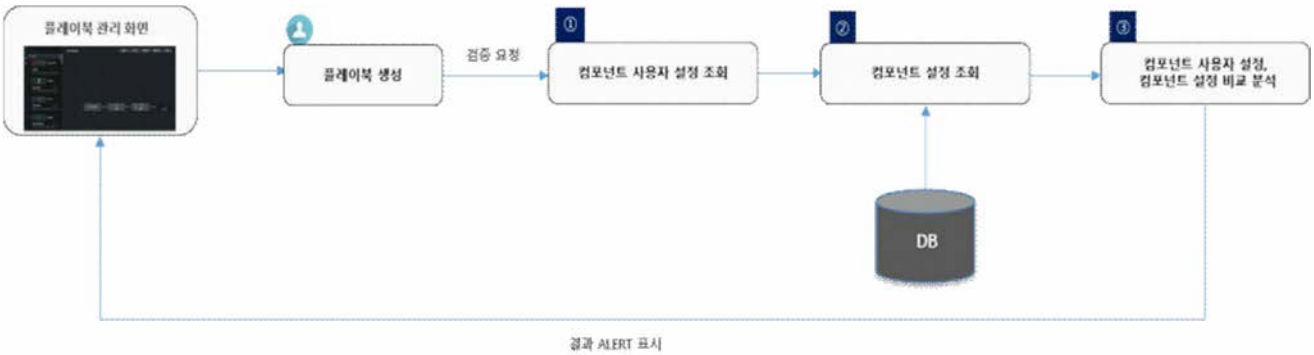
<분기 컴포넌트 조건절 정의>

조건분기	도식	설명
equal	==	같은 값
in	0	포함 값
less	<	작은 값
less or equal	<=	작거나 같은 값
greater	>	큰 값
greater or equal	>=	크거나 같은 값
between	~	사이의 값
wildcard	*!?	특수문자 포함 값



<분기 컴포넌트 조건절 설정 UI>

> Flow 기반 컴포넌트 간 Input·Output 정보 Validation 체크 프로세스 정의



<컴포넌트 Input · Output 정보 Validation 체크 프로세스>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

o 플레이북 및 컴포넌트 자동 관리 기능 요구사항 분석

- 플레이북 및 컴포넌트 태그 생성 기능의 필요성 분석

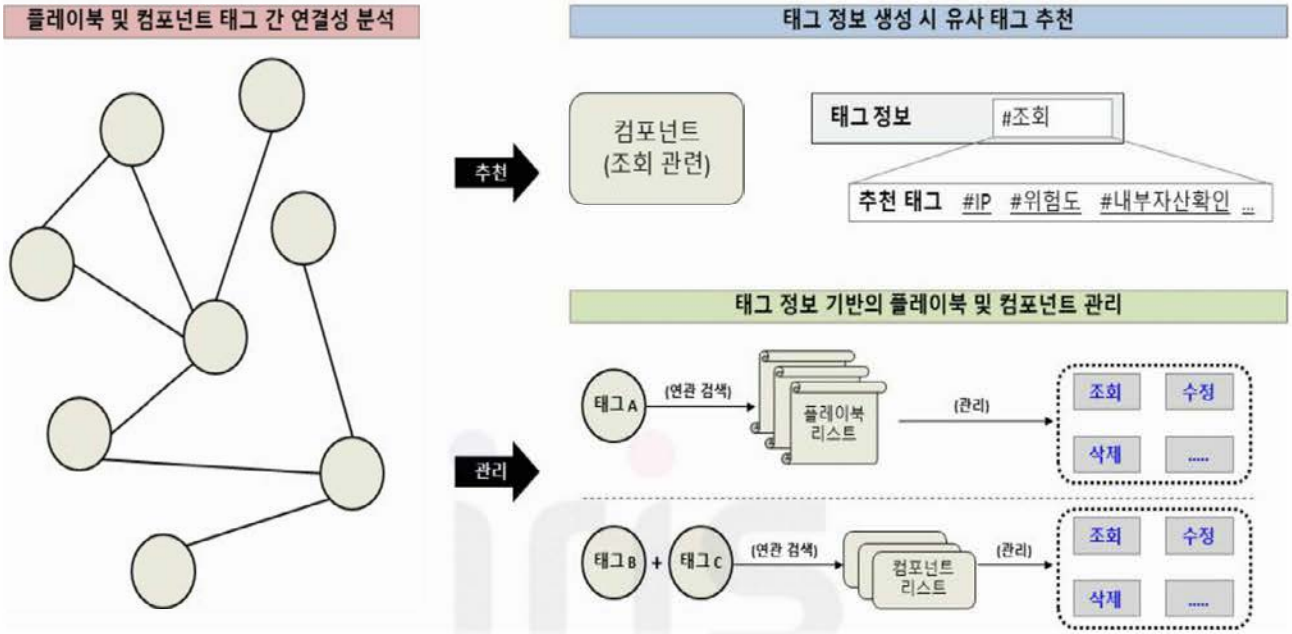
  > 플레이북 및 컴포넌트의 역할과 특성을 나타내는 태그를 저장하고 관리하는 기능을 통해 조회·갱신·삭제·추천 등 관리에 활용

- 플레이북 및 컴포넌트 태그 생성 기능의 기능 요구사항 분석

  요구사항 ① : 태그 정보들에 대한 연결성 분석 기능

  요구사항 ② : 태그 정보 입력 시 유사한 태그 추천 기능

  요구사항 ③ : 태그 정보를 기반으로 플레이북 및 컴포넌트 관리 기능



<플레이북 및 컴포넌트 자동 관리 기능 개요도>

3) 플레이북 실행 모듈의 기능 요구사항 분석

o 우선처리 이벤트 선정 요청 기능 요구사항 분석

- 우선처리 이벤트 선정 요청의 필요성 분석

  > SOC로 유입되는 수많은 이벤트 중 위험도·대응시간·분석난이도 등과 같은 요소들을 고려하여 이벤트 처리 순서를 결정함으로써 동일한 시간 대비 높은 안전성을 확보하기 위해 우선처리 이벤트 선정 요청 기능을 도입

- 우선처리 이벤트 선정 요청 기능 발생 조건 분석

  > 우선처리 이벤트 선정 요청은 두 가지(α, β) 버전이 존재

  > 우선처리 이벤트 선정 요청-α 기능 발생 조건

  : 일정 시간 동안 많은 양의 이벤트가 유입되어 플레이북 실행 우선순위가 필요한 경우

  > 우선처리 이벤트 선정 요청-β 기능 발생 조건

  : 플레이북 실행 중, 관제원의 승인이나 직접적인 분석 과정이 필요하거나 플레이북 실행 중에 오류로 인해 진행이 멈춰있는 경우와 같이 관제원 개입이 필요한 경우

- 우선처리 이벤트 선정 요청 기능의 기능 요구사항 분석

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

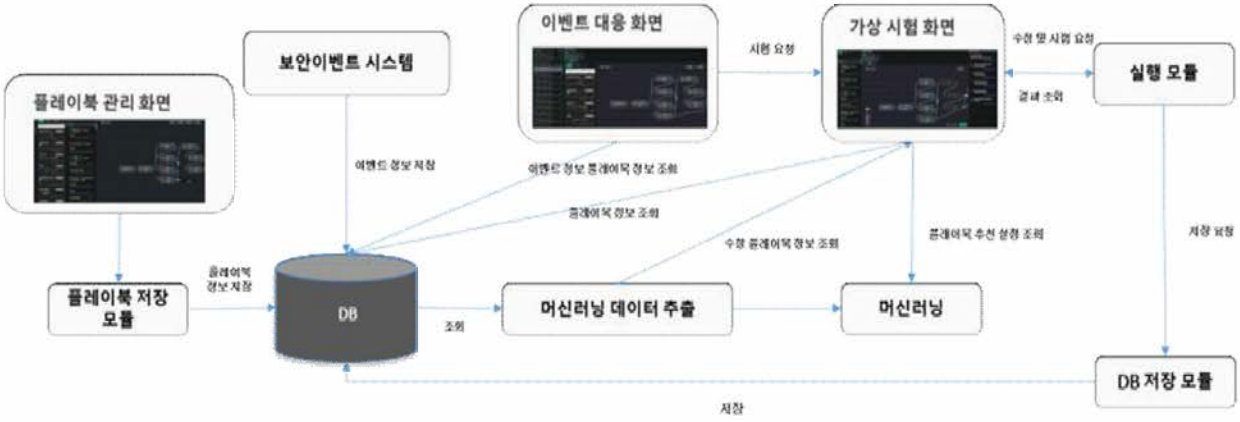
요구사항 ① : 우선처리 이벤트 선정 요청 메시지 전송 기능
요구사항 ② : 우선처리 이벤트 선정 요청 결과 수신 기능

- 우선처리 이벤트 선정 요청-α,β 필수 메시지 유형 분석

우선처리 이벤트 선정-α	
구분	**메시지**
요청 송신	우선처리 이벤트 선정-α 요청 메시지 ID
	메시지 생성 시간
	우선처리 이벤트 선정-α 대상 리스트
결과 수신	우선처리 이벤트 선정-α 결과 메시지 ID
	메시지 생성 시간
	우선처리 이벤트 선정-α 요청 메시지 ID
	우선처리 이벤트 선정-α 결과 코드
	우선처리 이벤트 선정-α 결과 리스트

우선처리 이벤트 선정-β	
구분	**메시지**
요청 송신	우선처리 이벤트 선정-β 요청 메시지 ID
	메시지 생성 시간
	우선처리 이벤트 선정-β 대상 리스트
결과 수신	우선처리 이벤트 선정-β 결과 메시지 ID
	메시지 생성 시간
	우선처리 이벤트 선정-β 요청 메시지 ID
	우선처리 이벤트 선정-β 결과 코드
	우선처리 이벤트 선정-β 결과 리스트

o 플레이북 자동 실행 기능 요구사항 분석
- 연관 플레이북 및 추천 플레이북 기능
> 가상화 기반 플레이북 추천 구동 연구 및 설계



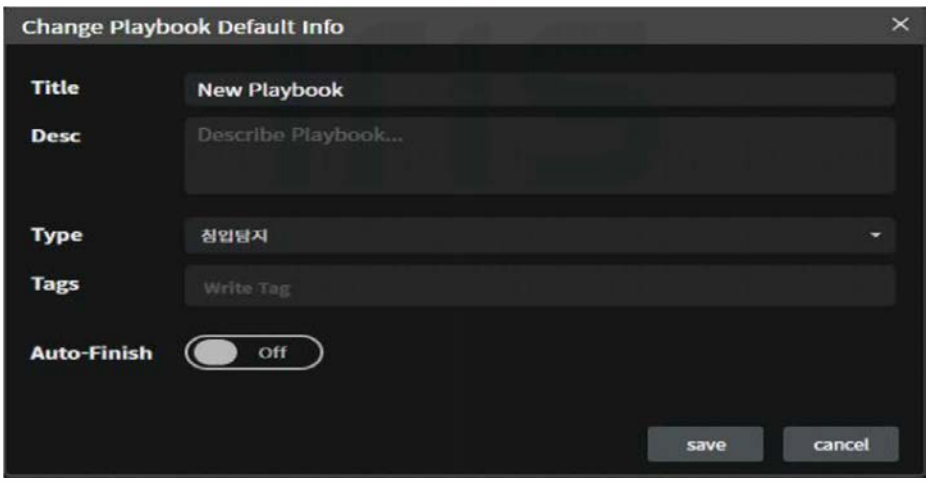
<가상화 기반 플레이북 추천 구동 구성도>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

> 이벤트 위협유형 분류 및 분류별 위협 Indicator 추출 방안 연구
: 사용자 정의 위협 Indicator 관리 기능 설계

<위협 Indicator 노드 관리>

> 이벤트 위협유형 분류 간 해시태그형 플레이북 관리 기능 연구



<플레이북 해시태그 정보 관리>

> 가상화 기반 플레이북 추천 UI 화면 구성도 설계

<플레이북 추천 UI 설계>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

> 플레이북 대상 머신러닝 기반 유클리디안 유사도 측정 기법 적용 연구

유클리디안 유사도 = 1 / (유클리디안 거리 + 1e-05)

$$\|\mathbf{p}-\mathbf{q}\| = \sqrt{(\mathbf{p}-\mathbf{q})\cdot(\mathbf{p}-\mathbf{q})} = \sqrt{\|\mathbf{p}\|^2 + \|\mathbf{q}\|^2 - 2\mathbf{p}\cdot\mathbf{q}}.$$

<유클리디안 유사도 계산식>

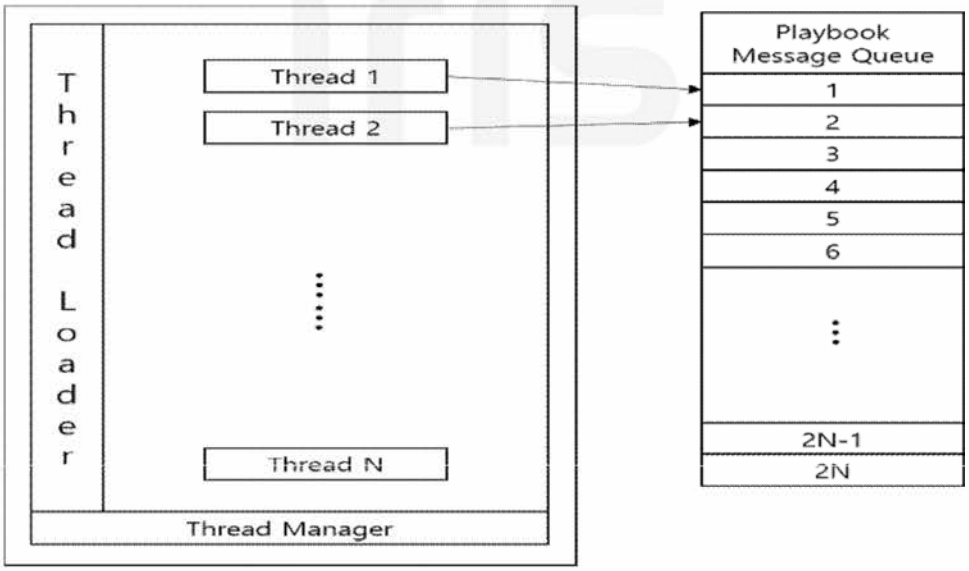
> 이벤트 위협유형별 유사도 측정 지표 정의 및 연구

	ip	src_ip	dstn_ip	웹 해킹 침해사고 대응	라우터 차단	라우터 차단 플레이북	웹 해킹 침해사고	low	middle	high
현재 데이터 여부(Y)	1	0	0	1	0	0	1	1	0	0
현재 데이터 여부(N)_1	1	0	0	1	0	0	1	0	0	1
현재 데이터 여부(N)_2	1	0	0	0	1	1	0	1	0	0
현재 데이터 여부(N)_3	0	0	1	0	1	1	0	0	1	0

<위협이벤트 유사도 측정 지표>

- 단일 이벤트 대상 멀티(병렬·직렬 구조) 플레이북 구동 기능

> 스레드 기반 병렬 및 직렬 구조의 멀티 플레이북 구동 기법 연구



<스레드 기반 플레이북 메시지 큐 처리 프로세스>

o 최적 대응방안 추천 요청 기능 요구사항 분석

- 최적 대응방안 추천 요청 기능의 필요성 분석

> 보안 이벤트에 대한 분석 결과에 따라 대응 절차는 아래와 같은 다양한 이유들로 인해 변화할 수 있음

① 특정 기간 동안에 별도의 대응 방안이 요구되는 경우 발생

② 2곳 이상의 보안관제를 다루는 SOC 환경에서 동일한 이벤트에 대하여 보안관제 대상마다 대응 절차가 다름

③ 2곳 이상의 보안관제를 다루는 SOC 환경에서 동일한 이벤트에 대하여 보안관제

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

대상마다 대응 절차는 동일하지만 컴포넌트가 다름

> 위와 같이 시기와 대상마다 대응 방안이 유동적으로 변화하기 때문에 최적 대응 방안을 추천하는 기능이 필요

- 최적 대응방안 추천 요청 기능의 기능 요구사항 분석

요구사항 ① : 최적 대응방안 추천 요청 메시지 전송 기능

요구사항 ② : 최적 대응방안 추천 요청 결과 수신 기능

- 최적 대응방안 추천 요청 필수 메시지 유형 분석

구분	메시지
요청 송신	최적 대응방안 추천 요청 메시지 ID
	메시지 생성 시간
	현재 처리중인 이벤트 ID
	현재 처리중인 플레이북 ID
결과 수신	최적 대응방안 추천 결과 메시지 ID
	메시지 생성 시간
	최적 대응방안 추천 요청 메시지 ID
	최적 대응방안 추천 결과 코드
	최적 대응방안 추천 결과 정보

o 플레이북 실행 결과 전송 기능 요구사항 분석

- 플레이북 실행 결과 전송 기능의 필요성 분석

> 플레이북의 실행 결과 데이터를 현재 운영 중인 SOC 환경에 가장 적합한 플레이북으로 재생성하기 위한 강화학습 모델의 학습 데이터로 활용하기 위해 해당 데이터를 데이터 저장소에 전송하는 기능을 도입

- 플레이북 실행 결과 전송 기능의 기능 요구사항 분석

요구사항 ① : 플레이북 실행 결과 데이터 종합 기능

요구사항 ② : 플레이북 실행 결과 전송 기능

- 플레이북 실행 결과 전송 필수 메시지 유형 분석

구분	메시지
결과 송신	플레이북 실행 결과 전송 메시지 ID
	메시지 생성 시간
	실행 종료한 플레이북 ID
	플레이북 실행 결과 데이터 insert query

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

□ 위협 분석 자동화 기술 설계

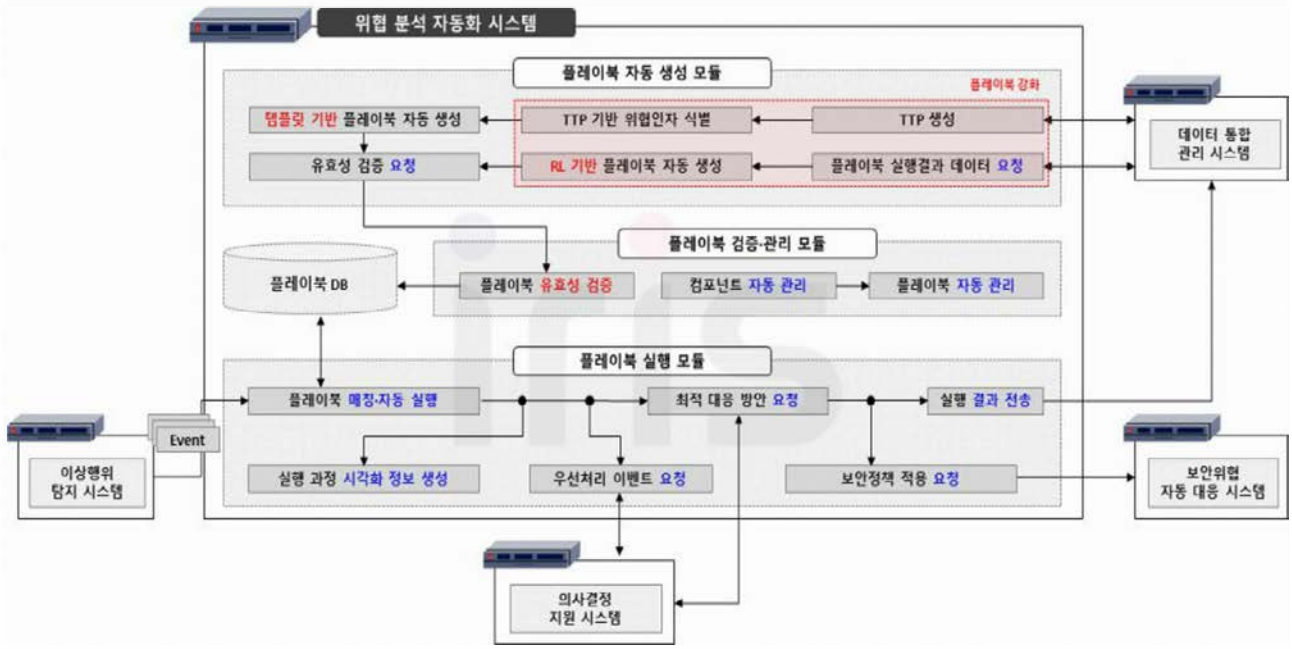
연구목표	보안 관제 플레이북 생성·검증·실행 기술 설계

세부 내용	1) 위협 분석 자동화 시스템의 전체 구성도 설계
	2) 플레이북 자동 생성 기술 설계
	3) 플레이북 검증·관리 기술 설계
	4) 플레이북 실행 기술 설계

□ 보안 관제 플레이북 생성·검증·실행 기술 설계 세부 내용

1) 위협 분석 자동화 시스템 전체 구성도 설계

o 위협 분석 자동화 시스템 개요



<위협 분석 자동화 시스템 전체 구성도>

- (기능 1) ML 기반의 플레이북 자동 생성
  > Graph Theory 및 RL 기반의 컴포넌트 선정과 순서 배치와 보안관제 전문가의 평가 데이터 중심으로 생성
- (기능 2) 자동 생성된 플레이북에 대한 유효성 검증 및 관리
  > 기존 플레이북과의 유사도/시뮬레이션/실증 데이터 기반 플레이북 유효성 검증
- (기능 3) 탐지 이벤트에 대한 자동화된 상세 분석을 위한 플레이북 매칭
  > 이벤트별로 사전에 정의된 플레이북을 매칭하고 자동으로 실행
- (기능 4) 탐지 이벤트 우선처리 및 최적 대응 방안 요청
  > 관제원의 개입이 필요한 이벤트에 대한 우선처리 순서를 의사결정 지원 시스템에 요청
  > 이벤트 분석 결과에 따른 최적의 대응 방안을 의사결정 지원 시스템에 요청

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

<플레이북 자동 생성 모듈의 기능>

주요 기능	설명
플레이북 템플릿 생성	· 대응이력 데이터를 활용하여 플레이북 템플릿을 생성하는 기능
TTP 생성 및 TTP 기반 위협인자 식별	· 위협 자산을 식별하기 위하여 TTP 생성 및 분석하는 기능
템플릿 기반 플레이북 자동 생성	· AI 학습 모델을 활용하여 템플릿 기반의 플레이북을 생성하는 기능
플레이북 실행 결과 데이터 요청	· 플레이북 강화에 필요한 플레이북 실행 결과 데이터 요청 기능
RL 기반 플레이북 자동 생성	· SOAR 운영 중 플레이북 실행 결과 데이터를 활용한 플레이북 강화 기능
플레이북 유효성 검증 요청	· 플레이북 검증/관리 모듈에 플레이북의 유효성 검증을 요청하는 기능

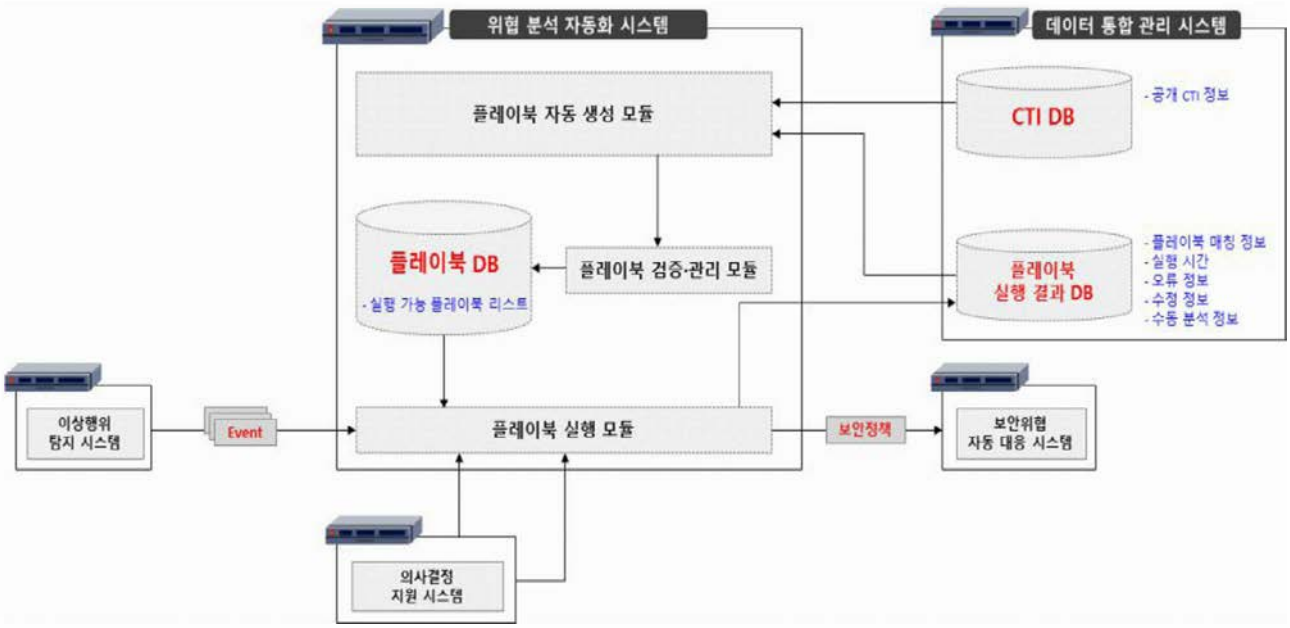
<플레이북 검증 · 관리 모듈의 기능>

주요 기능	설명
플레이북 유효성 검증	· 자동으로 생성된 플레이북에 대한 유효성을 검증하는 기능 (①유사도 분석 ② 시뮬레이션 ③보안관제 실증 데이터)
컴포넌트 및 플레이북 자동 관리	· 컴포넌트 또는 플레이북에 대한 관리 이벤트 발생(수정·삭제·변경 등)을 대응하기 위한 기능 · 컴포넌트에 태그 정보를 삽입하고, UL 모델 기반으로 컴포넌트 클러스터링을 수행

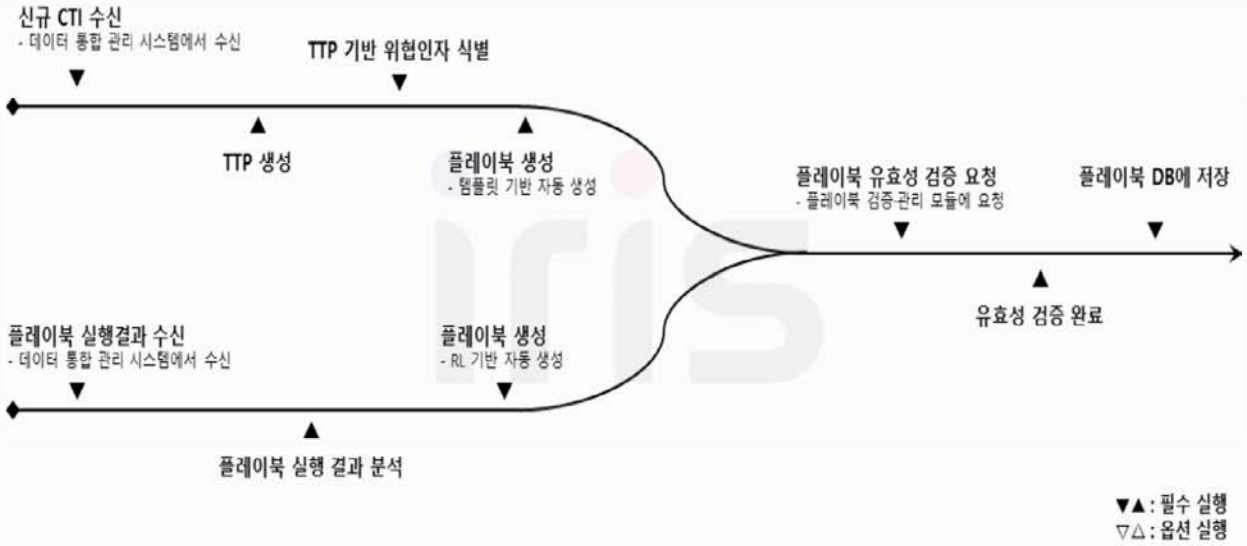
<플레이북 자동 실행 모듈의 기능>

주요 기능	설명
플레이북 자동 매칭	· 이벤트별 실행해야 할 플레이북을 검색하고 매칭하는 기능
우선처리 이벤트 요청	· 분석 대기 중인 이벤트들 중 우선적으로 처리해야 할 이벤트의 선정을 요청하는 기능
최적 대응 방안 요청	· 의사결정 지원 시스템에 최적 대응 방안을 요청하는 기능
보안 정책 적용 요청	· 최적 대응 방안 중 보안 장비에 보안 정책을 적용해야하는 경우에 이를 요청하는 기능
플레이북 실행 결과 전송	· 플레이북 강화에 필요한 플레이북 실행 결과 데이터를 데이터 통합 관리 시스템의 저장소로 전송하는 기능

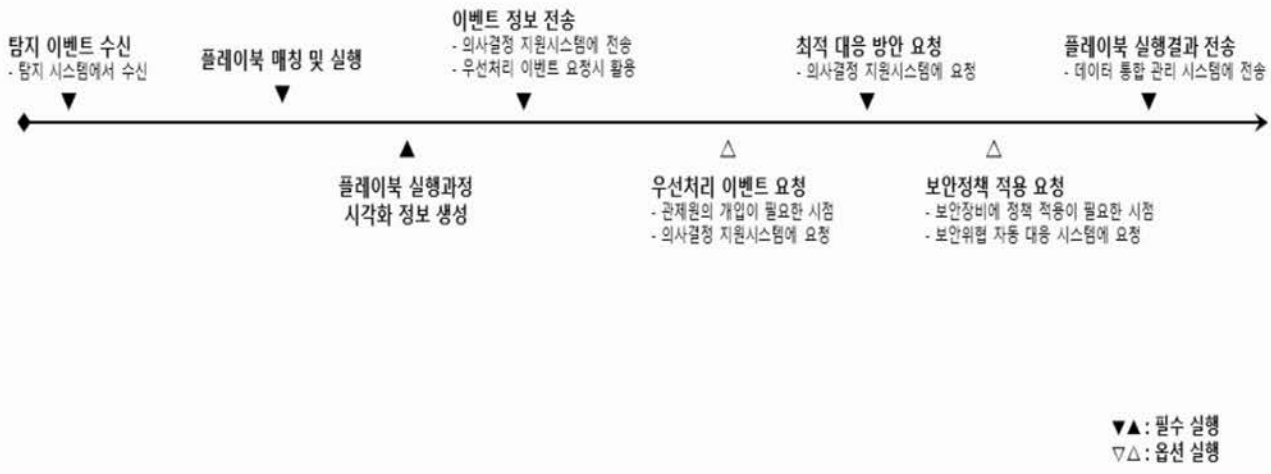
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



<위협 분석 자동화 시스템의 주요 정보 관리 구조>



<시스템 입력 정보 및 실행 흐름 - 플레이북 자동 생성 및 검증>

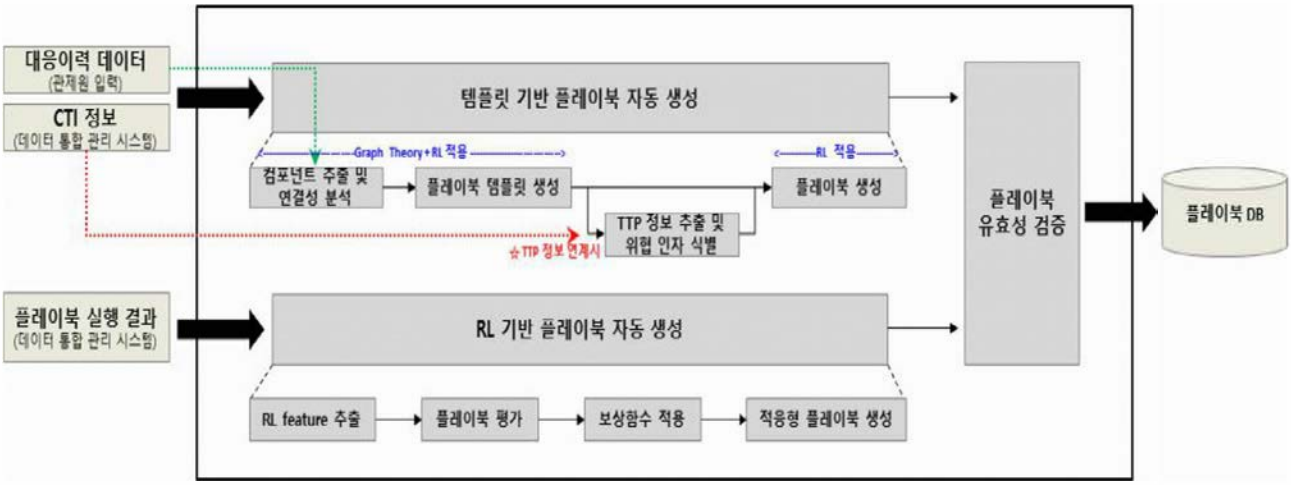


<시스템 입력 정보 및 실행 흐름 - 플레이북 실행>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

o 주요 데이터 흐름 및 주요 기능

- 플레이북 자동 생성 및 검증 절차에서의 주요 데이터 흐름 및 주요 기능



<주요 데이터 흐름 - 플레이북 자동 생성 및 검증>

> 주요 입·출력 데이터

(입력 1) 대응이력 데이터 (관제원 입력)

(입력 2) CTI 정보 (데이터 통합 관리 시스템)

(입력 3) 플레이북 실행 결과 (데이터 통합 관리 시스템)

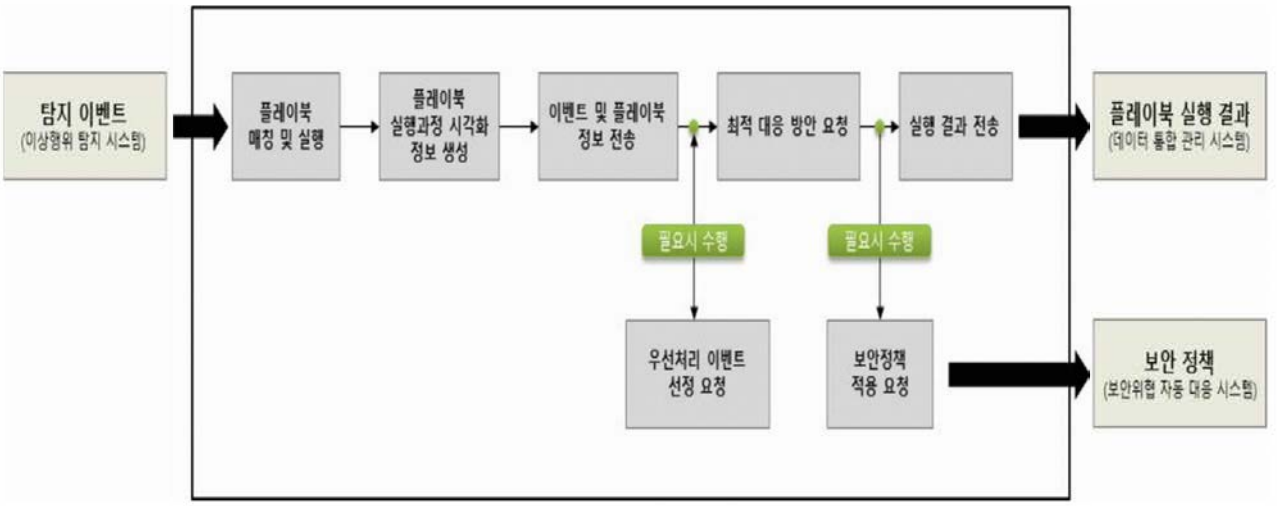
(출력 1) 플레이북 (DB 저장)

> 주요 기능 및 설명

주요 기능	설명
컴포넌트 추출 및 연결성 분석	· 대응이력 데이터 내 컴포넌트 정보와 컴포넌트 간 연결성 정보 생성
플레이북 템플릿 생성	· 대응이력 데이터 기반으로 플레이북 템플릿 생성
TTP 정보 추출 및 위협 인자 식별	· CTI 정보로 TTP 정보를 추출하고, 이를 기반으로 위협 인자를 식별
플레이북 생성	· 템플릿 기반 플레이북 자동 생성
RL feature 추출	· 플레이북 실행 결과 중 RL에 필요한 feature 추출
플레이북 평가	· 플레이북 실행 결과에 대하여 전문가의 평가 데이터 수집
보상함수 적용	· 전문가의 평가 데이터가 높아지는 방향으로 보상함수 적용
적응형 플레이북 생성	· 플레이북 실행(운영) 데이터를 바탕으로 SOC 환경에 적합한 플레이북 생성

- 플레이북 실행 절차에서의 주요 데이터 흐름 및 주요 기능

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



<주요 데이터 흐름 - 플레이북 실행>

> 주요 입·출력 데이터

(입력 1) 탐지 이벤트 (이상행위 탐지 시스템)

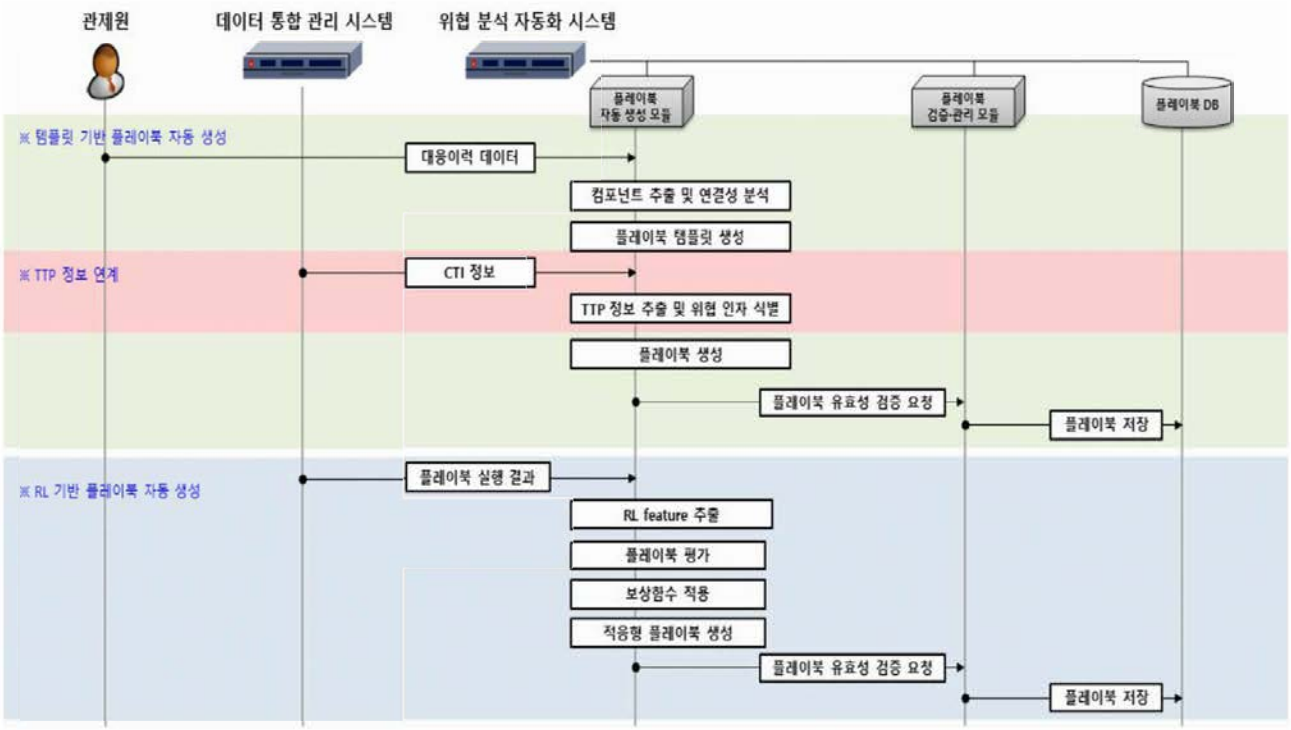
(출력 1) 플레이북 실행 결과 (데이터 통합 관리 시스템)

(출력 2) 보안 정책 (보안위협 자동 대응 시스템)

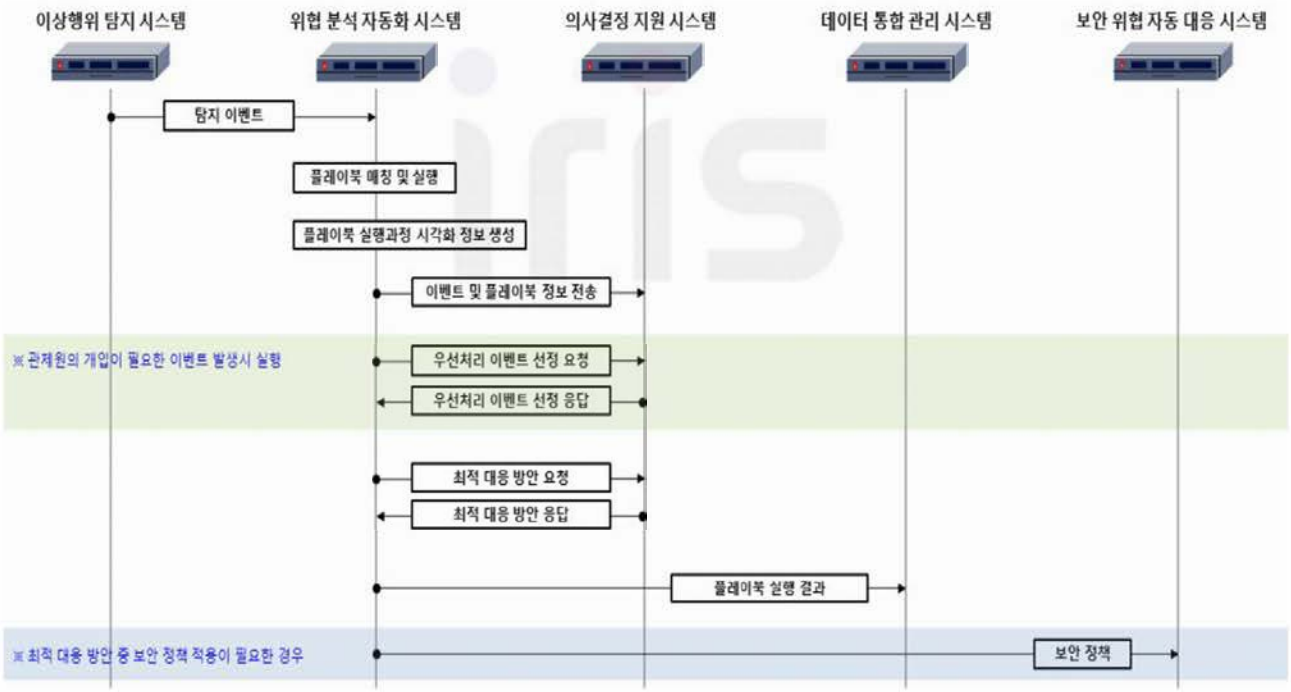
> 주요 기능 및 설명

주요 기능	설명
플레이북 매칭 및 실행	· 탐지 이벤트를 대응하기 위한 플레이북을 매칭하고 자동 실행
플레이북 실행 과정 시각화	· 플레이북 실행 과정 모니터링을 위한 시각화
이벤트 및 플레이북 정보 전송	· 우선처리 이벤트 선정 요청 발생을 대비한 이벤트 및 플레이북 매칭 정보 전송
우선처리 이벤트 선정 요청	· 관제원의 개입이 필요한 상황 발생 시 우선으로 처리할 이벤트를 선정하는 기능 요청
최적 대응 방안 요청	· 분석이 완료된 위협에 대한 최적의 대응 방안을 요청
보안정책 적용 요청	· 최적 대응 방안 중 보안 장비에 보안 정책 설정이 필요한 경우, 해당 정책의 적용을 요청
실행 결과 전송	· 플레이북의 실행 중 발생하였던 모든 정보들을 전송

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



<시점별 정보 생성 및 흐름 - 플레이북 자동 생성 및 검증>

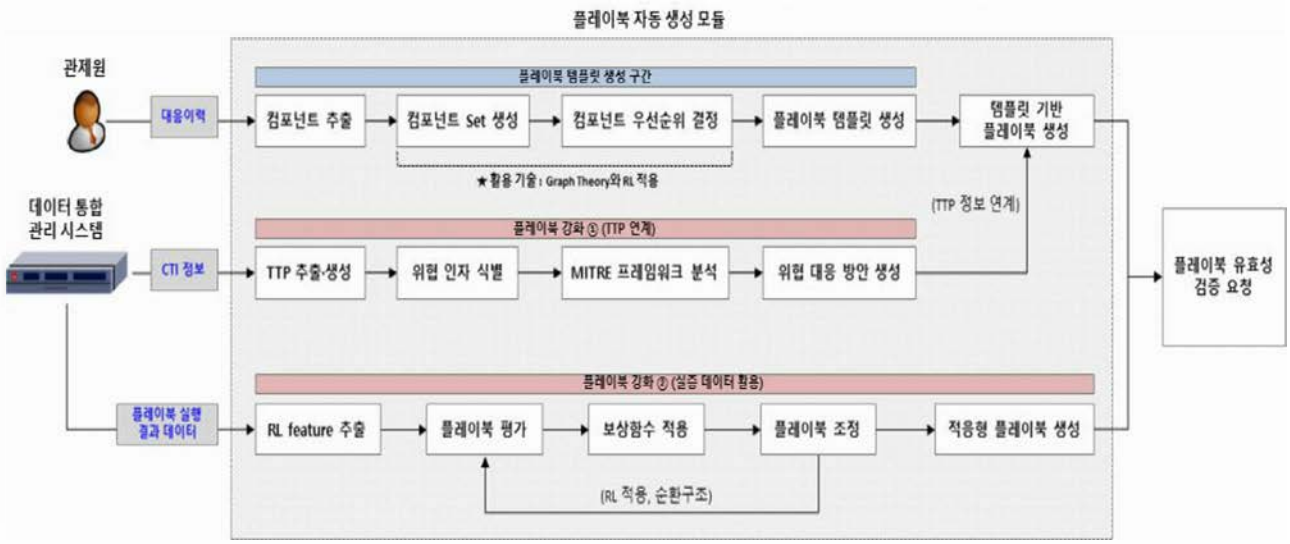


<시점별 정보 생성 및 흐름 - 플레이북 자동 생성 및 검증>

2) 플레이북 자동 생성 기술 설계

o 플레이북 자동 생성 모듈 구성도 설계

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



o 플레이북 자동 생성 모듈의 주요 기능 정의

- 컴포넌트 추출
  > 대응이력 데이터 내 대응행위들을 컴포넌트로 추출

- 컴포넌트 Set 생성
  > Graph Theory 기반으로 Node(컴포넌트) 간 연결성을 분석하여 컴포넌트 셋 생성

- 컴포넌트 순서 배치
  > RL 기반으로 컴포넌트의 순서를 결정 - 보상 함수의 목표(개발 초기) : 기존에 존재하는 전문가들의 대응을 모사
  > 보상 함수의 목표(개발 완료 후 지속 운영 이후) : 전문가들의 평가 점수

- 플레이북 템플릿 생성
  > 컴포넌트 추출 및 순서 배치 결과를 통해 위협 대응의 일반적인 절차(플레이북 템플릿) 생성

- 위협정보 분석 및 TTP-ID 생성
  > 이미 알려진 공개 위협 인텔리전스에서 TTP 정보* 추출 및 TTP ID 생성
  * TTP는 전략(Tactics), 기술(Techniques), 절차(Procedures)를 의미

- 내부 자산 위협 인자 식별 및 자산 ID 생성
  > 위 TTP를 기반으로 보호 대상 네트워크 환경에 대입하여 위험한 포인트를 식별

- 방어 전략 ID 생성
  > 공격법과 방어법에 대한 프레임워크를 제공하는 MITRE 프레임워크 분석 (알려진 공격법에 대한 방어법 등이 매핑되어 있음)

- MITRE 프레임워크 기반 대응 전략 생성

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

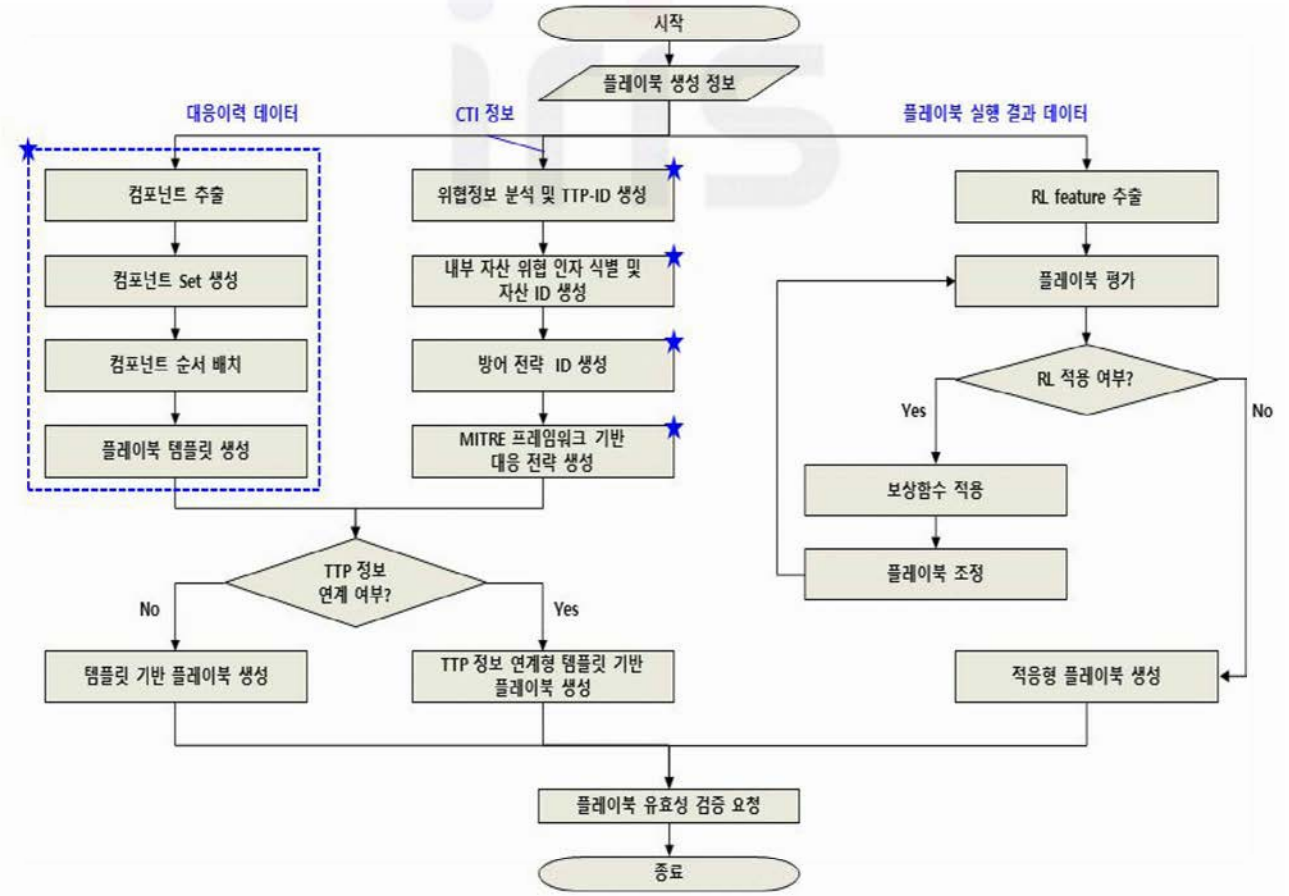
> TTP 기반으로 보호 대상 네트워크 환경에 가장 적합한 대응 방안을 생성

- 템플릿 기반 플레이북 생성
  > 위협 대응의 일반적인 절차(플레이북 템플릿)를 기반으로 상세한 작업을 정의하여 플레이북을 생성
  (TTP 정보를 고려하여 생성할 수 있음)

- 플레이북 강화 ②의 강화학습 과정- 플레이북 실행 결과 데이터를 활용
  > 실행 이력을 바탕으로 플레이북을 조정하는 과정
  > 보상함수의 목표는 운영 중인 환경별로 다르게 설정 가능

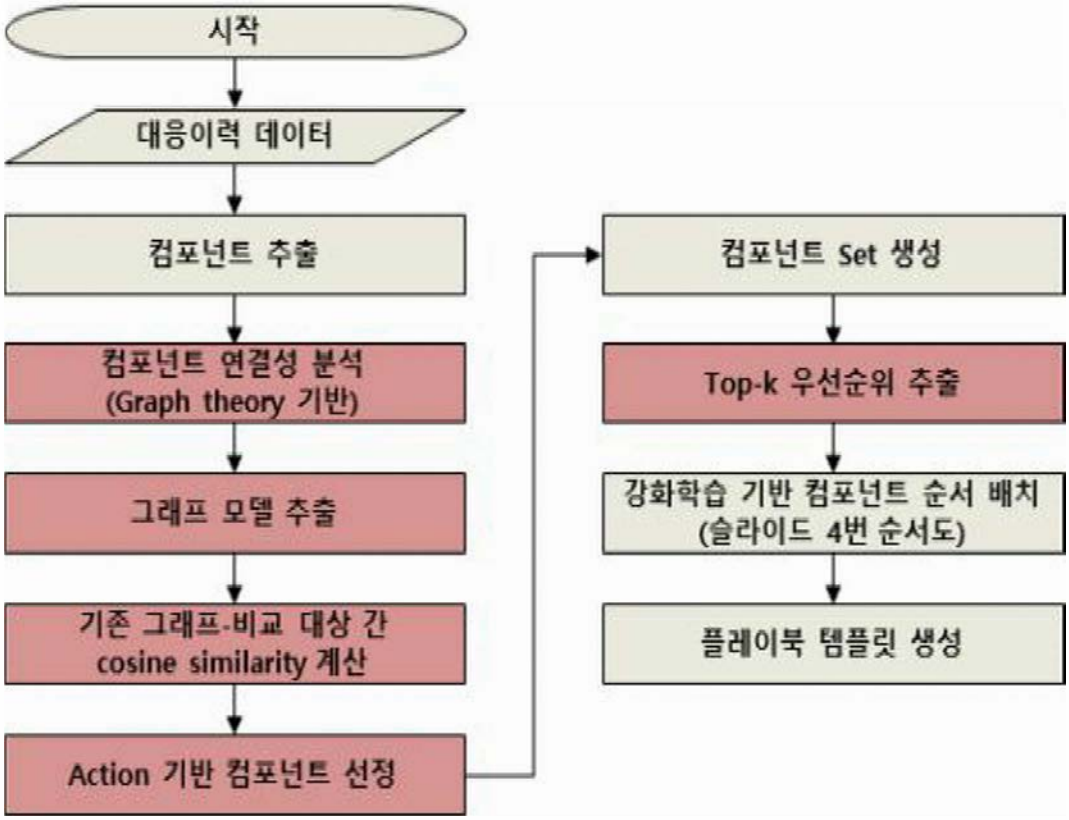
- 적응형 플레이북 생성
  > 플레이북 강화 ② 과정을 통해 운영 중인 환경에 적합하도록 플레이북이 재조정된 결과(적응형 플레이북)

o 플레이북 자동 생성 모듈의 동작 순서도 설계
- 플레이북 생성 정보의 유형에 따라 동작 순서가 결정

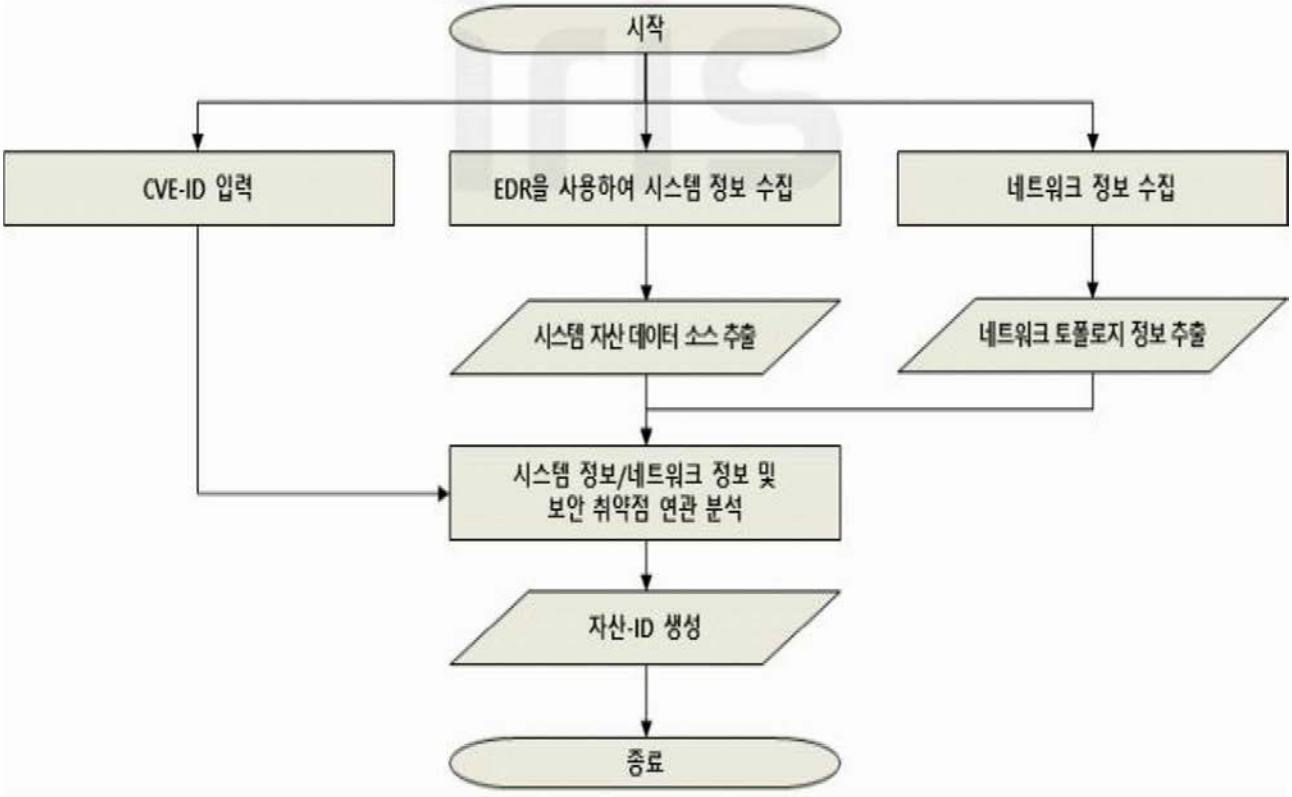


<플레이북 자동 생성 모듈의 동작 순서도>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

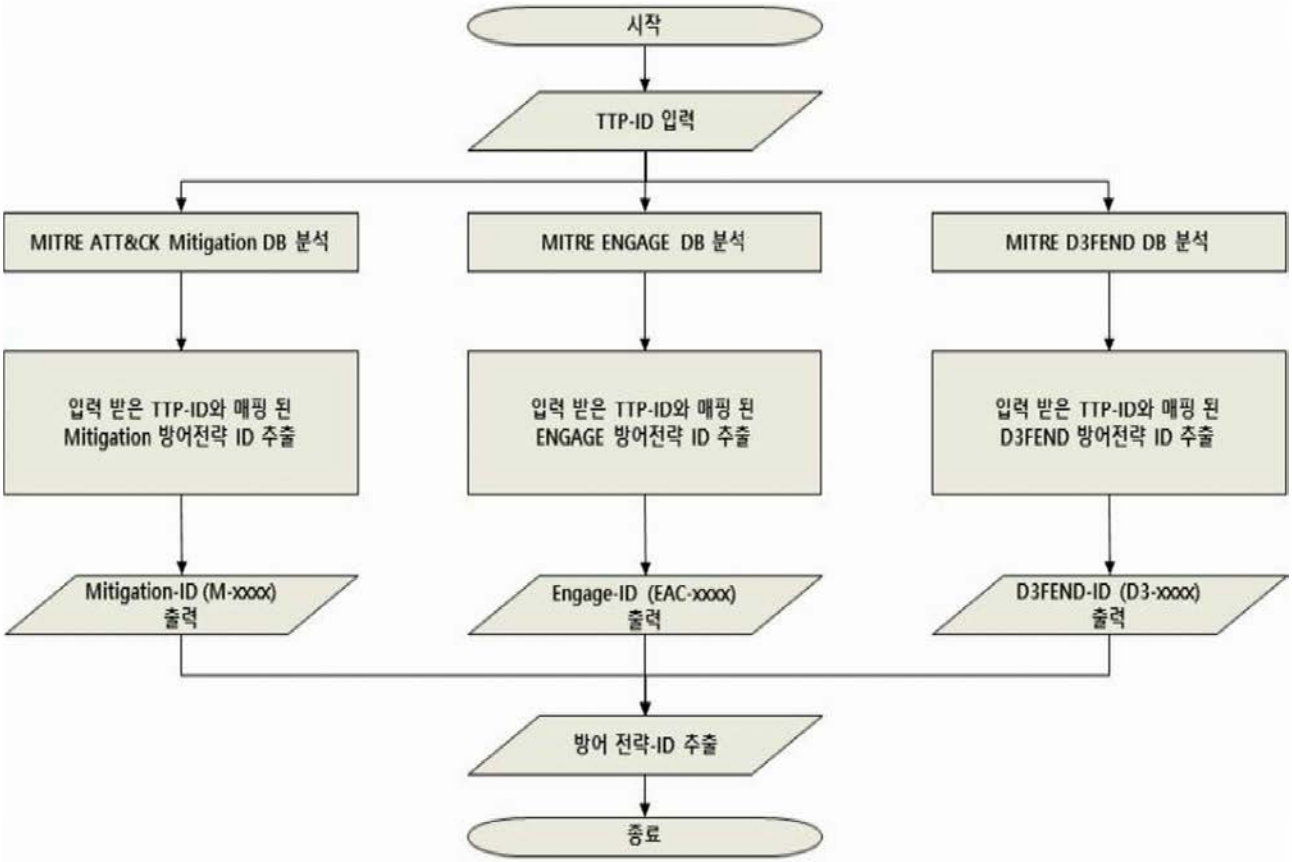


<플레이북 자동 생성 모듈 - 플레이북 템플릿 생성 상세 순서도>

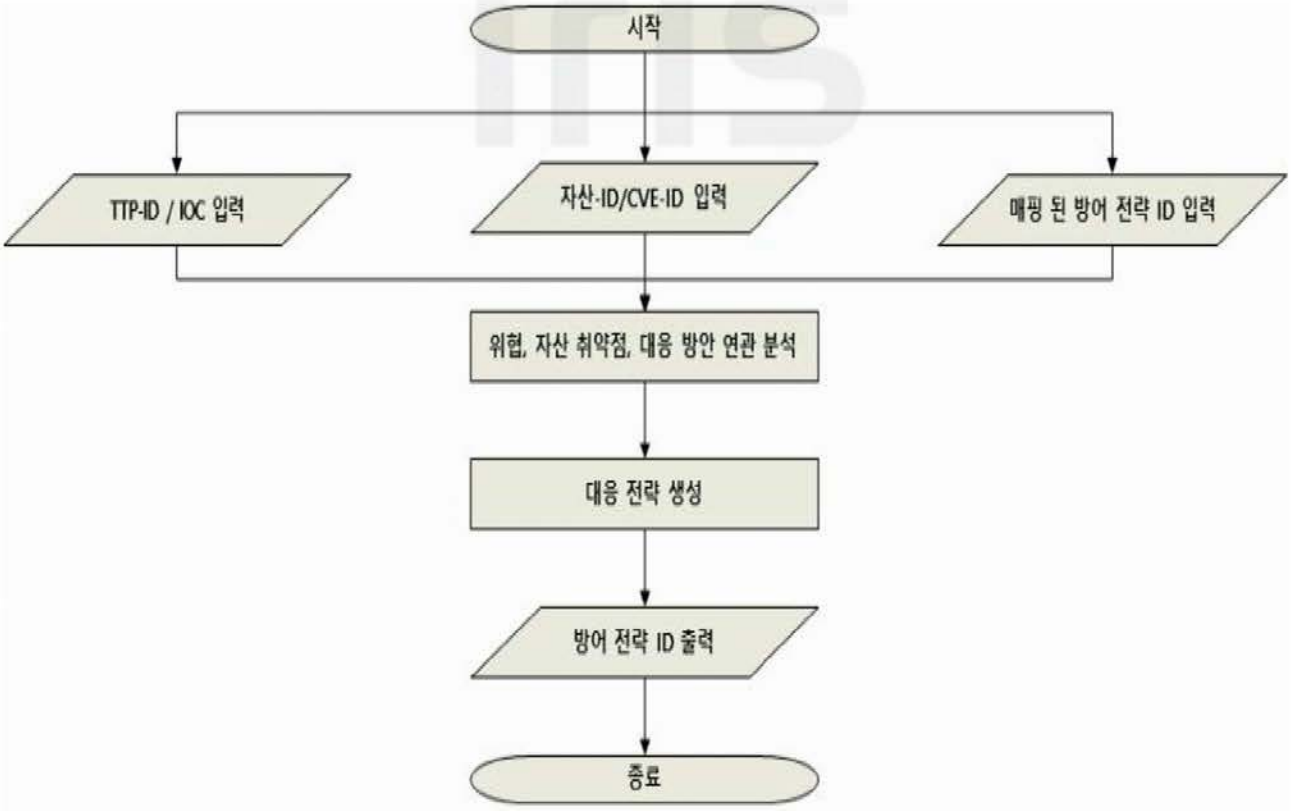


<플레이북 자동 생성 모듈 - 내부 자산 위협 인자 식별 및 ID 생성 상세 순서도>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



<플레이북 자동 생성 모듈 - 방어 전략 ID 추출 상세 순서도>

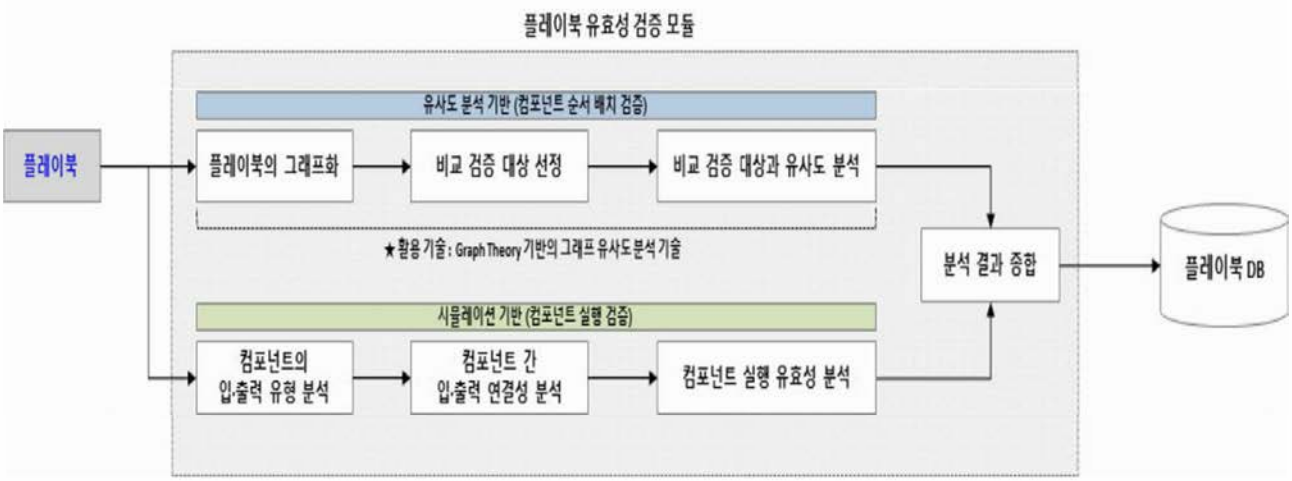


<플레이북 자동 생성 모듈 - MITRE 프레임워크 기반 대응 전략 상세 순서도>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

3) 플레이북 검증·관리 기술 설계

o 플레이북 검증·관리 모듈 구성도 설계



o 플레이북 검증·관리 모듈의 주요 기능 정의

- 플레이북의 그래프화
  > Graph Theory 기반으로 Graph 유사도 분석을 수행하기 위해 플레이북을 Graph로 변환

- 비교 검증 대상 선정
  > 유효성 검증 대상의 플레이북과 유사도 분석을 수행할 비교 검증 대상
  > (비교 검증 대상 선정) 전문가를 통해 이미 수집·생성한 플레이북을 선정

- 비교 검증 대상과 유사도 분석
  > 유효성 검증 대상 플레이북의 Graph와 비교 검증 대상 플레이북의 Graph 유사도 분석

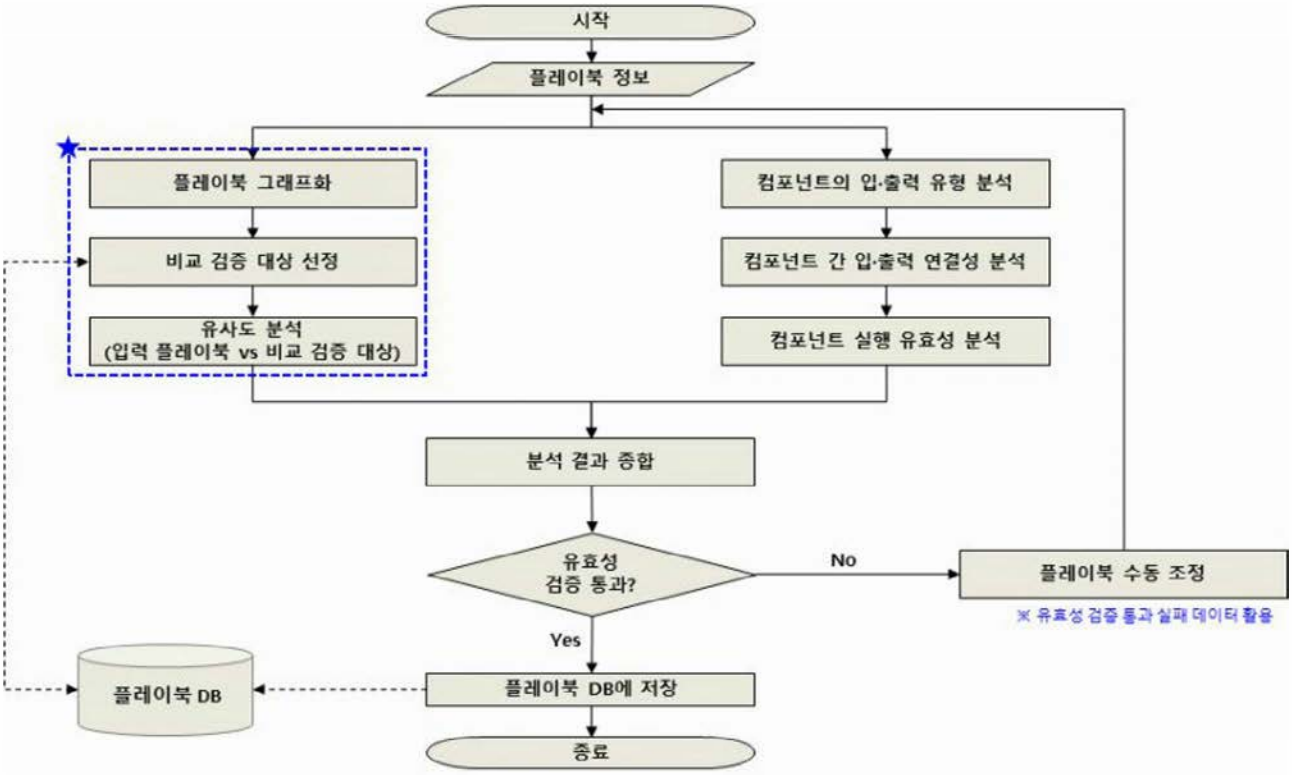
- 컴포넌트 입·출력 유형 분석
  > 컴포넌트의 입력 정보 및 출력 정보의 유형을 분석

- 컴포넌트 간 입·출력 연결성 분석
  > 컴포넌트와 컴포넌트 사이에 입력 정보 및 출력 정보 연결성 분석
  (예시) 컴포넌트가 [A] → [B] 순으로 연결되어 있다면, [A]의 출력값이 [B]의 입력값으로 연결이 가능한지 분석

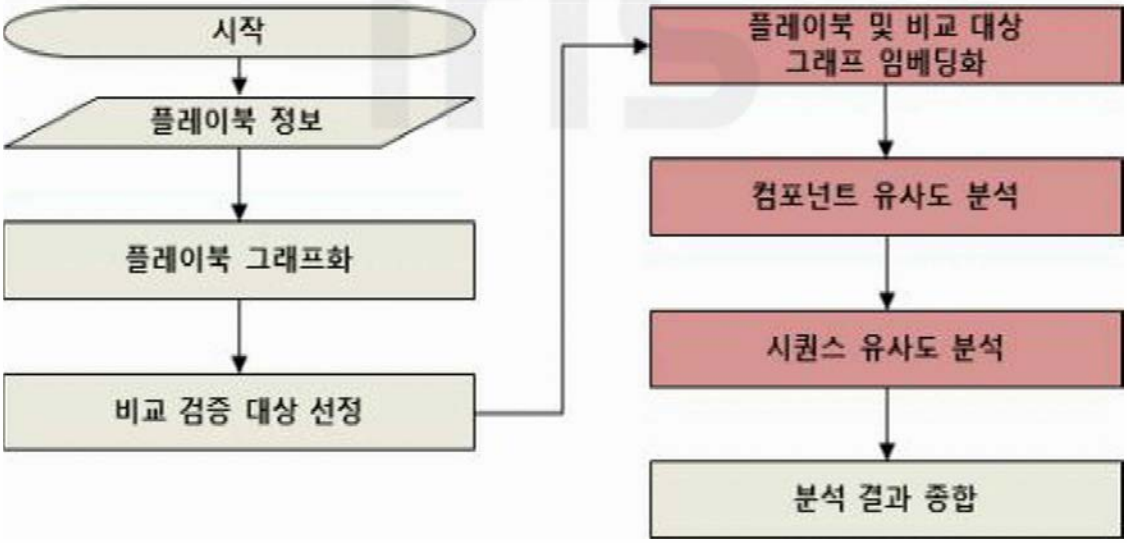
- 컴포넌트 실행 유효성 분석
  > 실제로 컴포넌트를 실행하여, 컴포넌트의 실행 여부와 컴포넌트 간 연결성을 분석

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

o 플레이북 검증·관리 모듈의 동작 순서도 설계



<플레이북 검증 · 관리 모듈의 동작 순서도>



<플레이북 검증 · 관리 모듈 - 유사도 분석 기반 상세 순서도>

- 플레이북 및 비교 대상 그래프 임베딩화
  > 그래프 수준에서의 유사도 측정을 위한 임베딩 작업
  > 플레이북 그래프와 선정된 비교 검증 대상을 벡터 형태의 임베딩으로 표현

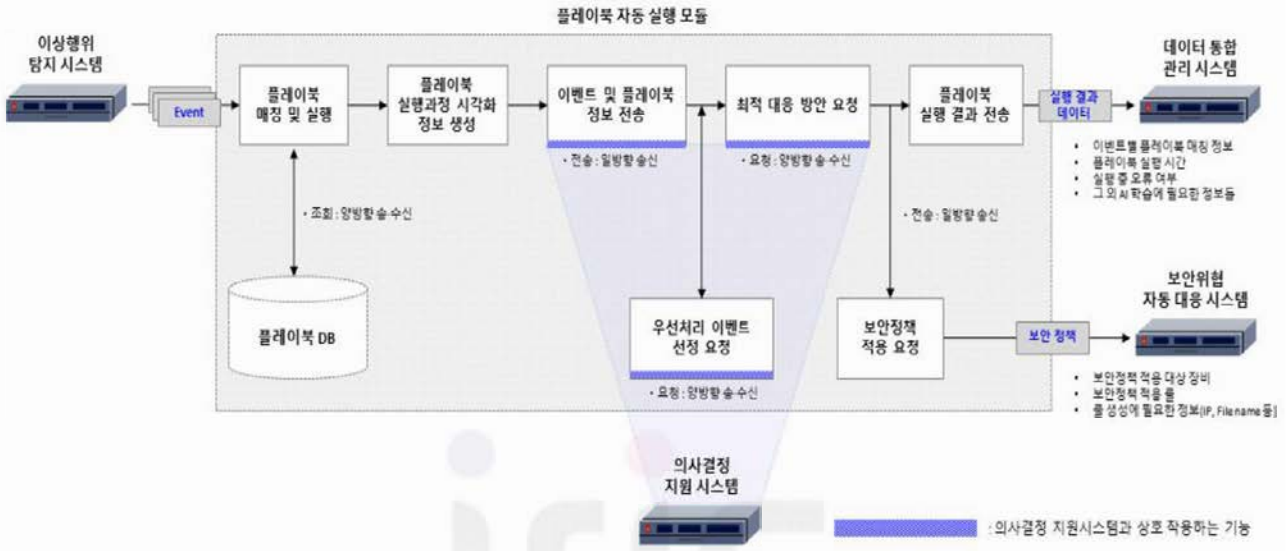
- 컴포넌트 유사도 분석
  > 유효성 검증 대상 플레이북의 Graph와 비교 검증 대상 플레이북의 Graph에서 각 컴포넌트 간의 코사인 유사도를 분석

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- 시퀀스 유사도 분석
  > 컴포넌트들의 연속적인 배치에 해당하는 시퀀스(Sequence)
  > 유효성 검증 대상 플레이북의 Graph와 비교 검증 대상 플레이북의 Graph에서 두 시퀀스 간 유사도를 분석

4) 플레이북 실행 기술 설계

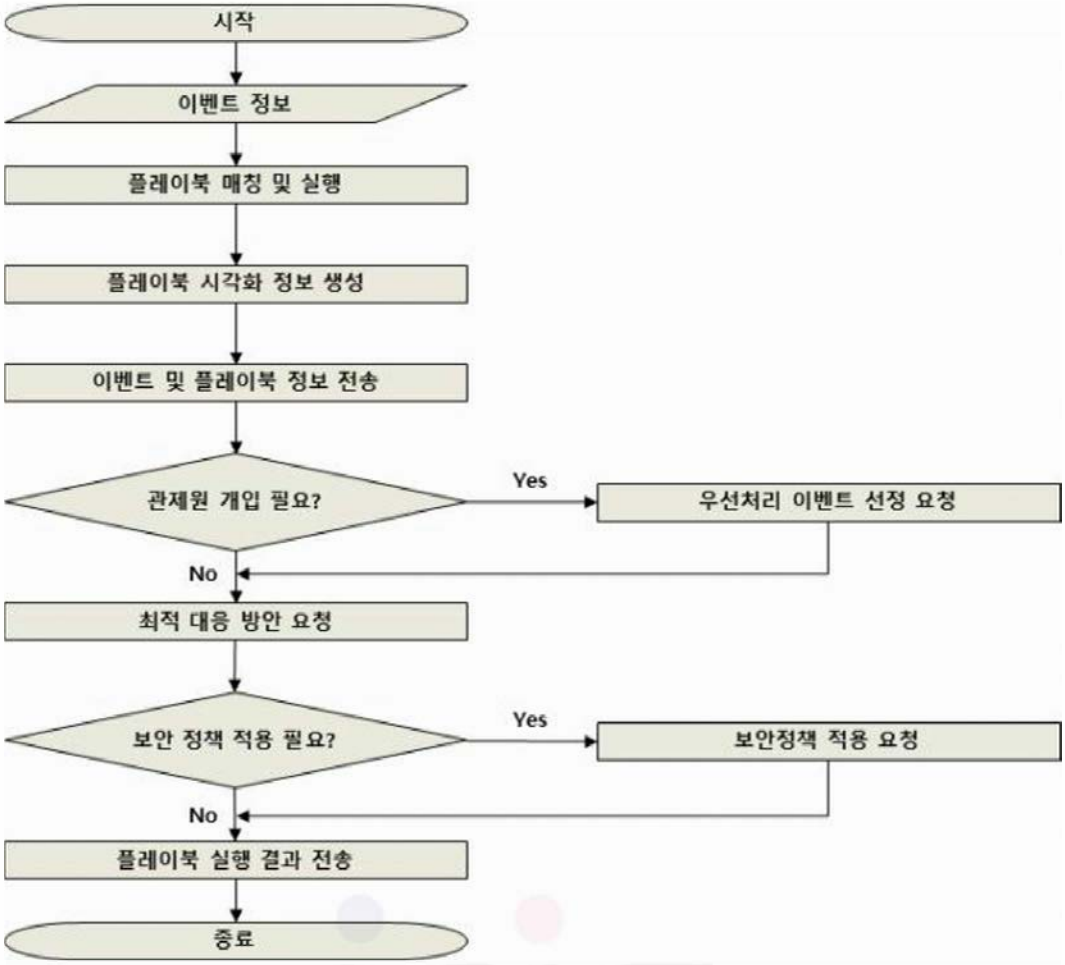
o 플레이북 실행 모듈 구성도 설계



o 플레이북 실행 모듈의 주요 기능 정의
- 플레이북 매칭 및 실행
  > 보안 이벤트 발생 시 해당 이벤트에 대한 분석·대응에 가장 적합한 플레이북을 매칭하고 자동으로 실행을 수행
- 우선처리 이벤트 선정 요청
  > 관제원 개입이 필요한 상황 발생 시 우선적으로 처리할 이벤트를 선정 요청하기 위해 의사결정 지원 시스템과 상호작용하는 기능
- 보안정책 적용 요청
  > 최적 대응방안 중에 보안장비에 보안정책을 적용해야 할 필요가 있을 때, 보안정책을 전달하기 위해 보안 위협 자동 대응 시스템과 상호작용을 하는 기능
- 플레이북 실행 결과 전송
  > 플레이북 실행 결과 데이터를 AI 모델의 학습 데이터(적응형 플레이북 생성 모델, 최적 대응 방안 추천 모델 등)에 활용하기 위해 데이터 통합 관리 시스템과 상호작용을 하는 기능

o 플레이북 실행 모듈의 동작 순서도 설계
- 탐지 이벤트가 발생하면 주요 기능들을 순차적으로 진행하며, 관제원의 개입이 필요하거나 보안 정책 적용이 필요한 경우에만 각각 의사결정 지원시스템 및 보안 위협 자동 대응 시스템과 상호작용을 수행

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



〈플레이북 실행 모듈의 동작 순서도〉

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

상세 추진 내용 ③ 의사결정 지원 기술

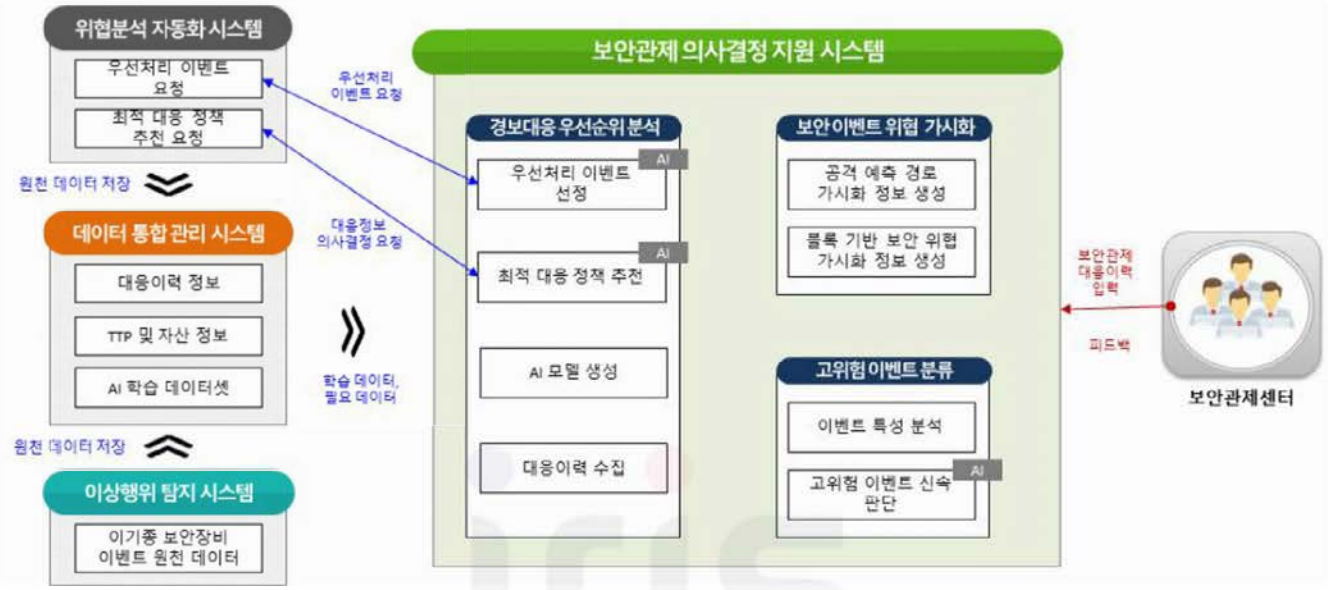
□ 개발 기술 개요

o (개발목표) SOC 활용 시각화 및 AI 기반 의사결정 요소 기술 설계

1) 이기종 보안 장비 데이터 및 TTP 연관정보 가시화 기술 설계

2) 신속한 의사결정 지원을 위한 고성능 AI 분석 모델 설계

3) AI 기반 최적 의사결정 자동 추천 모델 연구 및 설계



<보안관제 의사결정 지원 기술 개념도>

o (추진실적) SOC 활용 시각화 및 AI 기반 의사결정 요소 기술 요구사항 분석 및 설계

- 보안 위협 정보 가시화 기술 요구사항 분석 및 설계 완료 **개발목표 1**
- 고위험 이벤트 신속 분류 기술 요구사항 분석 및 설계 완료 **개발목표 2**
- 경보대응 우선순위 분석 기술 요구사항 분석 및 설계 완료 **개발목표 3**
- 보안관제 대응이력 수집 기술 요구사항 분석 및 설계 완료 **추가수행**
- 데이터 통합 관리 기술 개발 요구사항 분석 및 설계 완료 **추가수행**

□ SOC 활용 시각화 및 AI 기반 의사결정 요소 기술 요구사항 분석

연구목표	SOC 활용 시각화 및 AI 기반 의사결정 요소 기술 요구사항 분석

세부 내용	1) 보안 위협 정보 가시화 기술 요구사항 분석
	2) 고위험 이벤트 신속 분류 기술 요구사항 분석
	3) 경보대응 우선순위 분석 기술 요구사항 분석
	4) (추가수행) 보안관제 대응이력 수집 기술 요구사항 분석
	5) (추가수행) 데이터 통합 관리 기술 요구사항 분석

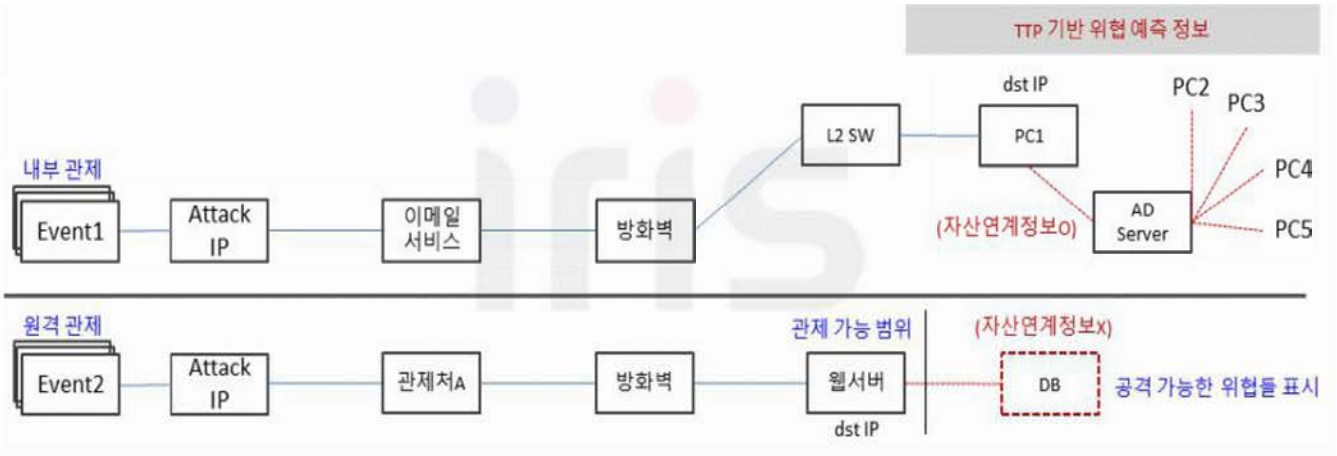
□ SOC 활용 시각화 및 AI 기반 의사결정 요소 기술 요구사항 분석 세부 내용

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

1) 보안 위협 정보 가시화 기술 요구사항 분석

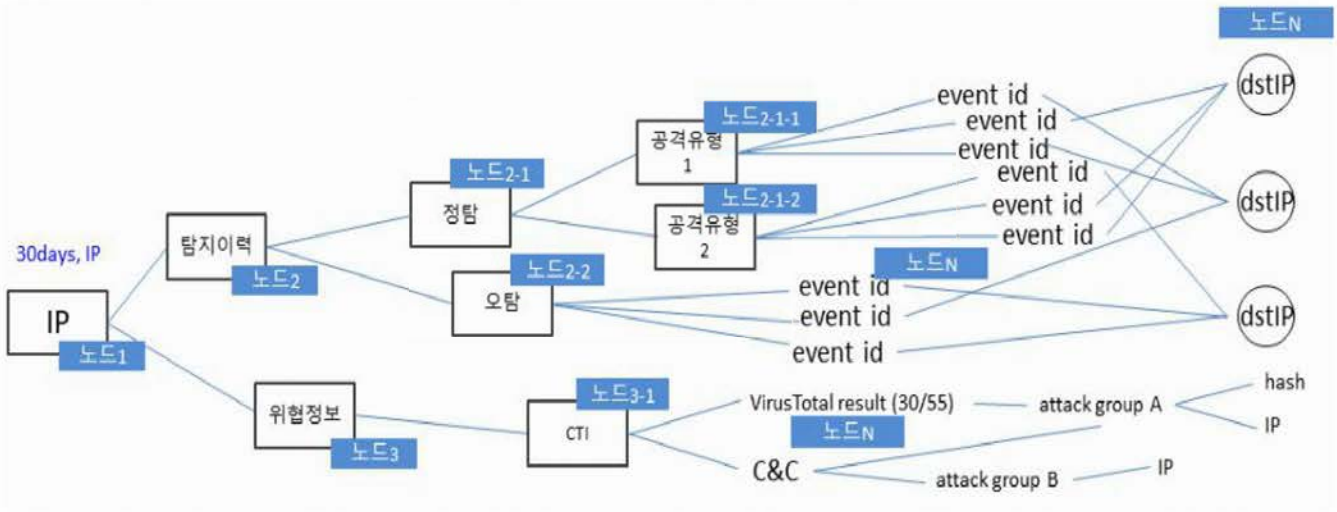
o 데이터 및 TTP 정보 간 연관성 분석 기능 요구사항 분석

- 내부 자산 정보 수집 방안
  - · 사용자 입력 기반 내부 자산 정보 수집
  - · 발생 이벤트, 네트워크 스캐닝 분석 기반 내부 자산 정보 수집
- 연관 분석 필요 데이터 정의
  - · 이벤트 정보(출발지/도착지 IP, Port, 공격 유형, 정/오탐 결과, hash 등)
  - · 자산 정보(시스템 IP, 단발 IP, 자산별 중요도 등)
  - · 내부 위협 정보(과거 침해사고 이력 등)
  - · IoC 기반 외부 위협 정보(공격 IP, C&C IP, hash 등)
  - · TTPs 기반 외부 위협 정보(공격 전술)
- 이벤트 연관 분석 기반 위협 정보 가시화를 위한 시나리오 2건 도출
  - · 공격 이벤트 및 TTP 연관 분석을 통한 공격 경로 예측 시나리오
    ※ 파견관제, 원격관제 등 관제 유형별 보안 위협 가시화



<위협 정보 가시화 시나리오 1>

· 사용자 입력 블록 기반의 맞춤형 보안 위협 가시화 시나리오



<위협 정보 가시화 시나리오 2>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

o 네트워크 데이터 시각화 라이브러리 분석
- D3(Data-Driven Documents)
  · 웹 브라우저상에서 동적이고 인터렉티브한 정보 시각화를 구현하기 위한 자바스크립트 라이브러리
  · SVG와 HTML5, CSS 등 웹 표준에 기반하여 구현된 라이브러리
  · 수백 개의 API 기능이 존재하며, 12개의 논리적 단위로 분류
  · SVG 속성에 데이터를 쉽게 매핑할 수 있으며, 도구의 확장성이 뛰어남
- Sigma.js
  · Canvas 및 WebGL을 기반으로 다양한 플러그인을 제공하는 시각화 도구
  · 웹 페이지에서 대화형 네트워크 맵을 공유하거나 네트워크 데이터베이스를 동적으로 탐색하도록 설계
- vis.js
  · 동적 브라우저 기반 자바스크립트 시각화 라이브러리
  · 많은 양의 동적 데이터 처리, 데이터 조작 및 상호작용이 가능하도록 설계
  · DataSet, Timeline, Network, Graph2d, Graph3d 요소로 구성

2) 고위험 이벤트 신속 분류 기술 요구사항 분석

o 보안관제 이벤트 유형 분류 요구사항
- 이벤트의 탐지 유형을 3종으로 분류 완료
  · signature, flooding, scanning
- 이벤트의 공격 유형을 6종으로 분류 완료
  · 단순침입시도, 서비스 거부, 웜/바이러스, 자료훼손 및 유출, 경유지 악용, 홈페이지 변조
  ※ 본 분류는 과제를 진행함에 있어 변경될 수 있음
- 이벤트의 탐지 유형 및 공격 유형에 따라 보안이벤트 분류
- 분류된 보안이벤트의 필드별 통계(최곳값, 최젓값, 평균값, 중간값, 최빈값 등)
- 분류된 보안이벤트의 페이로드 내 문자열 추출
- LCS(Longest Common String)알고리즘을 통한 최장 문자열 탐색 기술 분석
- 이벤트 주기성, 반복성 등 시간적 특징 추출 기술 조사

o 보안이벤트 페이로드에 따른 유형 분류 요구사항
- 페이로드에 따른 서비스 및 공격 유형 분류 기술 조사
- 공격 유형별 IP, Port, 페이로드 특정 문자열/패턴(PCRE) 등의 특징 추출 방법 조사 및 검증
- 공격 벡터 및 공격 벡터별 대응 방안 조사

o 서로 다른 보안이벤트들 간의 연관 특징 분석 요구사항
- 보안이벤트들 간 연관성 분석 방법론 조사

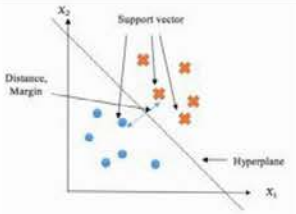
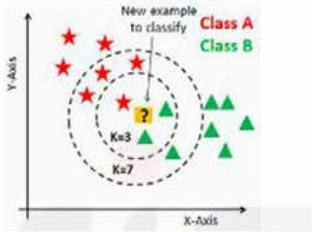
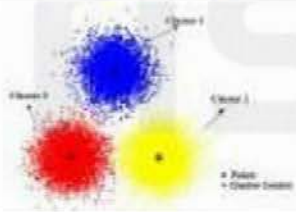
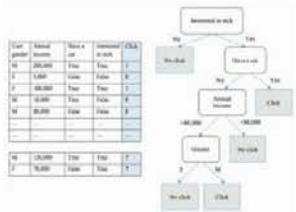
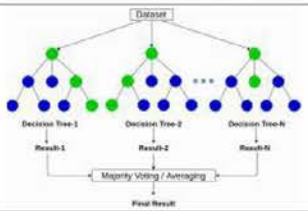
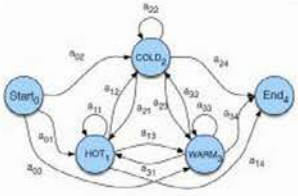
3) 경보대응 우선순위 분석 기술 요구사항 분석

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

o AI 기반 최적 의사결정 자동 추천 모델 연구

- 보안관제 관련 비신경망 계열 인공지능 모델
  - 주로 System Intrusion 탐지 문제에 대한 기계학습 기반 분류 알고리즘들이 다양하게 적용되고 있음
  - 상태 데이터에 대한 라벨(예 : 침투 = 1, 일반 상태 = 0)을 바탕으로 지도 학습계열 기법이 주를 이루고 있으나, 비지도 학습을 이용해 특성을 추출하거나 선택하여 분류 성능을 높이는 방법도 존재

<보안관제 관련 비신경망 계열 인공지능 모델 종류>

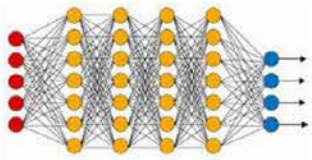
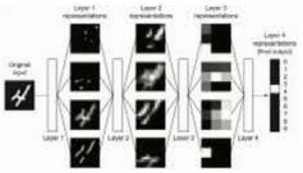
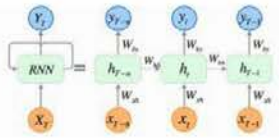
알고리즘	대표 그림	특징
SVM (Kotpalliwar 2015, Pervez 2014, Yan 2010, Li 2012, Raman 2019, Xie 2014)		클래스별 데이터를 가장 잘 구분하는 최적의 하이퍼플레인 (Hyperplane)을 결정
KNN (Shapoorifard 2017, Vishwakarma 2017)		가장 가까운 K개 데이터를 바탕으로 클래스를 결정
K-means Clustering (Lin 2015)		각 데이터에 대해 K개 그룹의 각 중심점과의 거리를 구하고 가장 가까운 곳에 할당
Decision Tree (Moon 2017, Ingre 2017, Malik 2018)		전체 데이터를 클래스별로 잘 분류할 수 있는 규칙(특성, 조건)을 따라 트리를 구성
Random Forest (Zhan 2008)		여러 의사 결정 트리 분류기 모델을 조합해 사용하는 배깅(Bagging) 알고리즘
Hidden Markov Model (Ariu 2011, Aarnes 2006)		두 상태 간의 전이 확률을 바탕으로 현재 상태에서 다음 발생할 확률 높은 상태를 결정

- 보안관제 관련 신경망 계열 인공지능 모델
  - DNN부터 CNN, RNN 등 다양한 딥러닝 모델 구조들이 사용되고 있음
  - 비신경망 계열 기계학습 모델과 비슷하게 주로 Intrusion 탐지에 대해 적용되었고,

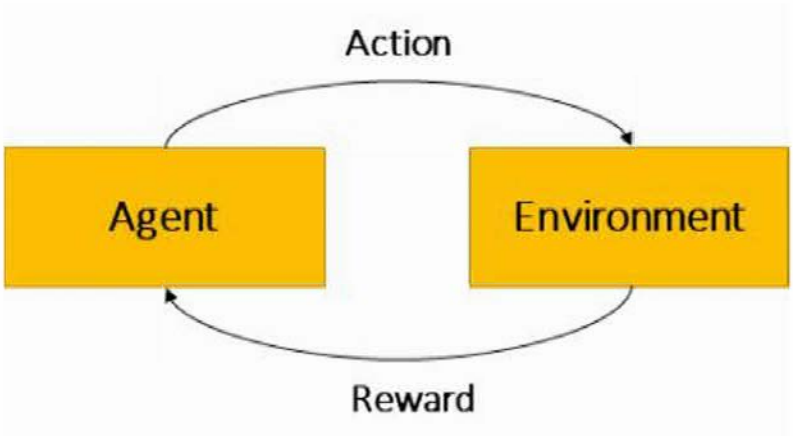
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

Malware detection이나 Attack classification에도 사용되기도 함

<보안관제 관련 신경망 계열 인공지능 모델 종류>

알고리즘	대표 그림	특징
Deep Neural Network (DNN) (Jo 2015)		여러 퍼셉트론(Perceptron)으로 구성된 레이어를 두 개 이상 사용해 더 좋을 표상(Representation)을 찾아가며 학습
Convolutional Neural Network (CNN) (Kolosnjaji 2016, Wang 2017)		합성곱(Convolution) 연산을 하는 커널들로 레이어를 구성하고, 그러한 레이어를 여러 개 사용하여 최종 예측 값을 만들어 냄
Recurrent Neural Netowkr (RNN) (Alrawashdeh 2016, Yin 2017, Kim 2016, Almiani 2019)		시점 별로 달라지는 값을 모델에 순차적으로 입력하며, 현재까지 입력된 값을 바탕으로 출력 결정

- 보안관제 관련 심층 강화학습 모델 연구
  - Jamming, Spoofing, Phishing 등과 같은 보안 사고 탐제 문제에 강화학습이 활발하게 적용되고 있음
  - 세부 방법으로는 LSTM, CNN 구조를 가지는 **DQN**이나 **A3C** 알고리즘들이 많이 사용되고 있음
  - 강화 학습은 어떤 환경에서 어떤 행동을 수행하였을 때 그것이 잘한 행동인지 잘못된 행동인지를 판단하고 보상(또는 벌칙)을 주는 것을 반복하여 학습시키는 기계학습 방법론임
  - ‘Agent’와 ‘Environment’로 구성되어 있으며, Agent는 특정 환경에서 행동을 결정하고, 환경은 그 결정에 대한 보상을 결정



<강화학습 개념>

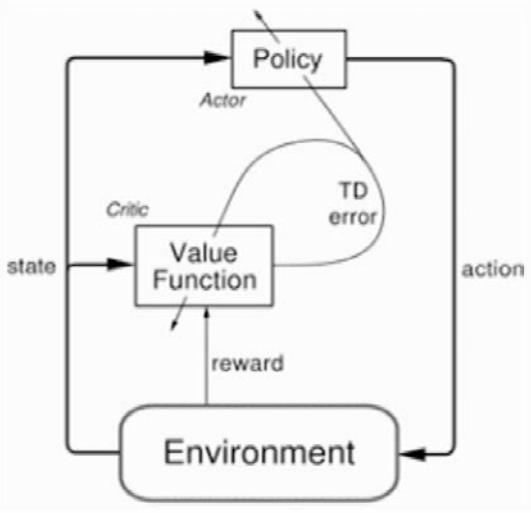
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- Agent가 특정 상태에서 수행할 행동의 확률을 표현한 것이 '정책', 현재 상태에서 향후 일련의 행동을 수행했을 때 얻을 것으로 기대되는 보상의 총량에 대한 기댓값을 '가치'라 부름
- 강화학습은 크게 '예측'과 '제어' 두 가지 과정을 거쳐 학습이 진행되는데, 예측은 에이전트가 주어진 정책을 따라 환경과 소통했을 때 얻어지는 결과를 바탕으로 가치 함수를 학습시키는 것을 말하며, 제어는 예측을 통해 얻어진 가치 함수를 바탕으로 정책을 학습하는 것을 말함
- 강화학습 알고리즘 방법 중 시간차 예측(Temporal-difference prediction) 방법은 몬테카를로 예측 방법과 다르게 전체 에피소드가 끝나지 않아도 매 시점마다 가치 함수를 업데이트 하도록 하는 특징이 있음

$$V(S_t) = V(S_t) + \alpha(R_{t+1} + \gamma V(S_{t+1}) - V(S_t))$$

<시간차 업데이트 함수>

- 시간차 제어 방법으로는 행동하는 정책과 학습하는 정책이 동일한 on-policy 방법인 SARSA(state-action-reward-state-action)와 행동하는 정책과 학습하는 정책이 서로 다른 Off-policy 방법인 Q-Learning이 있으며, 이때 Q-Learning에서 Q 함수를 심층 신경망으로 사용한 것을 DQN(Deep Q-Network)이라고 부름
- Q-Learning과 비슷하지만 Q 함수를 학습하고 Q값이 높은 행동을 취하는 방식과 달리 정책 경사(Policy Gradient) 방법은 행동의 확률 자체를 직접 학습해 사용하며, 액터 크리틱 (Actor-Critic) 방법은 Q-Learning과 정책 경사를 조합한 방법임



<Actor-Critic 방법>

- 액터 크리틱 방법의 기대 출력값에 행동에 따른 개선 정도를 추가로 반영한 것이 A2C(Advantage Actor-Critic) 방법이며, 여기에 에이전트가 여러 환경에서 동시에 행동을 수행하고 학습하는 비동기 개념을 추가한 것이 **A3C(Asynchronous Advantage Actor-Critic)** 방법임

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- **정리** : 보안 관제 분야에 다양한 인공지능 모델이 사용하고 있으나, 주로 Intrusion 탐지나 Attack 분류 문제에 적용됨. 본 과제에서 다루는 사고 발생 시 전문가의 대응 관점에서 보면 사고 발생 인지나 공격 유형을 알아도 더 세부적인 일련의 과정을 필요로 함. 이러한 일련의 대응 과정을 학습하기 위해서는 상태별 최적의 행동을 선택하는 강화학습이 적절함

o 우선 처리 이벤트 중요도 산정 및 자동 분류 기능 요구사항 분석
- 인공지능 방법론 중 지도학습 기반 기계학습 방법과 강화학습 방법 두 가지 방향이 적용 가능할 것으로 보임
- 하나의 강화학습 모델로 최적 대응 정책 추천 기능까지 포괄하여 두 문제를 일관성 있게 해결하는 모델을 만들 수도 있어 강화학습을 적용하는 것을 먼저 고려함
- 최적 대응을 결정하는 강화학습 모델을 만들고, 그 모델이 입력되는 상황에 맞춰 추천하는 대응 시퀀스 결과를 보고, 그 대응이 어떤 이벤트에 대해 수행되는 이벤트인지를 이전 이력 데이터를 바탕으로 도출하여 이벤트 중요도를 산정
- 최적 대응과 우선처리 할 이벤트를 판단하는 문제는 서로 관련이 있기 때문에 각 문제를 하나의 모델로 푸는 것이 모순된 결과가 나오지 않을 수 있어 보여 먼저는 하나의 강화학습 모델로 풀고자 함
- 향후 성능 비교를 위해 지도학습 기반 모델을 별도로 우선처리 이벤트 판별 문제를 위해 만들어 보는 것도 가능

o 최적 대응 정책 추천 기능 요구사항 분석
- 필요한 데이터로는 이상적으로는 보안 관제 상태 데이터와 전문가 대응, 그리고 대응에 대한 평가 데이터가 필요함
  · 상태 데이터는 Raw Packet과 같이 현재 상태를 나타내며 주요 특성을 추출해 사용할 수 있는 데이터
  · 전문가 대응은 위의 상태 데이터에서 전문가가 수행한 액션의 시퀀스
  · 평가 데이터는 전문가가 대응한 결과에 대한 평가
- 데이터 확보 상황에 따라 강화학습 모델 설계는 달라질 수 있음

  · 상태 데이터 확보 가능한 경우 (예)

상태	현재 로우 패킷 + 이전 대응 + 이전 대응에 대한 결과
액션	선택 가능한 대응들
에이전트	현재 상태와 이전 대응을 바탕으로 다음 대응을 선택
보상함수	. 1안 전문가가 할법한 대응 (혹은 플레이북에서 할법한 대응) - 같은 상황에서 전문가의 실제 대응들과의 유사도 - 그래프 이론 바탕으로 기존 플레이북들의 컴퍼넌트 간 연결성 분석 결과를 보상함수에 반영 가능 . 2안 가장 효과적인 대응 - 각 대응에 대한 평가 데이터를 보상함수로 사용하여 좋은 평가를 받은 대응을 선택할 수 있도록 학습 - 대응에 대한 전문가 평가 점수 데이터 추가 필요함 . 3안 1안과 2안을 조합하여 보상함수 설계

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

· 상태 데이터 확보 어려운 경우 (예)

상태	공격 유형 + 이전 대응 + 이전 대응에 대한 결과
액션	선택 가능한 대응들
에이전트	다음 대응을 선택
보상함수	(보상 함수는 앞과 동일함) . 1안: 전문가가 합법한 대응 (혹은 플레이북에서 합법한 대응) - 같은 상황에서 전문가의 실제 대응들과의 유사도 - 그래프 이론 바탕으로 기존 플레이북들의 컴퍼넌트 간 연결성 분석 결과를 보상함수에 반영 가능 . 2안: 가장 효과적인 대응 - 각 대응에 대한 평가 데이터를 보상함수로 사용하여 좋은 평가를 받은 대응을 선택할 수 있도록 학습 - 대응에 대한 전문가 평가 점수 데이터 추가 필요함 . 3안: 1안과 2안을 조합하여 보상함수 설계

- 상태 데이터 없이 강화학습 모델을 만드는 경우, 다음 대응을 결정할 때 구체적인 관제 데이터를 보고 판단은 하지 않고 바로 직전에 선택한 대응을 바탕으로 결정함
- 즉, 구체적인 상태에 상관없이 플레이북이나 전문가 대응과 유사한 결정을 하도록 학습되는 제약이 있을 수 있음
- 따라서 되도록 구체적인 상태 데이터를 입력으로 하여 모델을 만드는 방향으로 노력할 필요가 있음

o 보안관제 경보 대응 우선순위 관련 논문 국외 7건, 국내 4건, 국내 특허 5건 분석

- (국외/논문/2017) Supervised PU Learning for Cyber Security Event Prioritization
  · 사이버 보안 이벤트 우선순위 지정을 위한 지도 PU(Positive-Unlabeled) 학습
  · P : 양성 샘플(분석가의 주석, 위험호스트), U : 레이블되지 않은 샘플
  · P 샘플에 클레스 레이블 1 지정 → U 샘플에 클래스 레이블 0 지정 → P와 U 모두 m개의 부스트랩 샘플 생성 → 부스트랩 샘플에 대해 각각의 분류기 생성
- (국외/논문/2017) A Generic Approach to Big Data Alarm Prioritization
  · 빅데이터 경보 우선순위 지정에 대한 일반적인 접근 방식
  · 실제 경보를 확인하고 우선순위 지정, 보안전문가가 로그 분석
  · Rapid Miner 도구에서 ID3 의사결정 트리 모델을 사용하여 모델 구현
- (국외/논문/2017) Risk Assessment and Alert Prioritization for Intrusion Detection Systems
  · 침입 탐지 시스템에 대한 위험 평가 및 경고 우선순위 지정
  · 데이터셋 : KDD Cup 99
  · 위험평가 방식 : 조치 우선순위(1~3), 시스템 중요도(1~5), 경보 신뢰성(1~10), 경보 심각도(1~4)
  · (관련연구) 경고우선순위 기존연구 : 정적, 공격 사전, 사고 후 우선순위 지정
  · (관련연구) Dondo et al. : 잠재적인 공격을 컴퓨터 네트워크 자산과 연관 방식
  · (관련연구) Porras et al. : 성공 가능성, 표적 중요성, 공격 유형 관심도를 기준으로 경보 순위(베이지안 네트워크 모델 사용)

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

  - (관련연구) Qin과 Lee : 공격의 심각도와 네트워크 및 호스트에 대한 경고 관련성 기반으로 계산
- (국외/논문/2019) Automated Event Prioritization for Security Operation Center using Deep Learning
  - 그래픽 분석, 심층 신경망 모델을 사용하여 이벤트 분류
  - 데이터셋 : SOD(Security On-Demand) 회사 데이터 (IEEE BigData 2019 Cup: Suspicious Network Event Recognition)
  - 데이터 전처리 : 원핫 인코딩을 통해 변환
  - 피처 : 4:12이벤트의 첫 발생 요일(Mon, Tue, Wed, Thurs, Fri, Sat, Sun), 경고 심각도(시스템기반)(1~5), 공급업체, 심각도 범주
  - IP 유형 분류, 시간 데이터 이용, 전처리 데이터와 연계하여 시각화
  - DNN 모델 사용 (다층 신경망으로 알려진 피드포워드 신경망 사용, 3개 은닉, 1개 출력)
- (국외/논문/2019) Design and Evaluation of an Approach for Feedback-Based Adaptation of Incident Prioritization
  - 사고 우선순위의 피드백 기반 적응을 위한 접근 방식의 설계 및 평가
  - 분석가로부터 피드백 수집, 우선순위 모델에 대한 개선 사항을 자동으로 생성 및 평가
  - 잘못 설정된 우선순위를 피드백, 모델트리 사용
- (국외/논문/2020) New approach for threat classification and security risk estimations based on security event management
  - 보안 이벤트 관리 기반 위협 분류 및 보안 위험 추정
  - 데이터 전처리 → STRIDE 모델 기반 위협 분류 → Bug bar 기반 우선순위 결정 → 데이터 마이닝(Bayes Net, IBK, SMO) → 검증
  - SMOTE, RUS 기술 조합으로 데이터 불균형 처리
- (국외/논문/2021) AI/ML in Security Orchestration, Automation and Response : Future Research Directions
  - SOAR 제품, 학술연구 동향 등 전반적인 내용 포함
  - Siemplify의 SOAR 플랫폼
  - 기계 학습 활용 경고의 우선순위 지정, 사례에 최고의 분석가 할당
  - 분석가의 케이스 대기열을 지속적으로 분석하여 우선순위 지정(중요한 케이스 우선 해결)
  - 과거 악의적인 것으로 간주된 사례와 유사한 사례에 더 높은 우선순위 할당
  - 이전에 가양성으로 플래그가 지정된 사례와 유사한 사례에 낮은 우선순위 할당
  - SOAR에 강화학습(RL) 적용 연구 필요, 특히 DRL에 대한 영역
  - RL 모델 : PG, DQN, Double DQN, Dueling DQN, Actor-Critic, Asynchronous Advantage, A3C, A2C, SAC, DDPG, PPO
- (국내/논문/2015) 보안 취약점 중요도 평가 체계 연구
  - SW 보안 취약점 중요도 정량 평가 체계 제안
  - 출현도, 시스템 중요도, 기술적 영향, 공격 난이도, 대응 난이도, 발굴 수준으로 평가
- (국내/논문/2016) 위협 모델링을 활용한 보안관제센터의 위험 요소 분석에 관한 연구

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

  - 위협 분석(STRIDE 모델링-6가지) → 위험 평가(공격트리-공격자의 최종 목표 도식화) → 위험 우선순위(DREAD 기법 사용)
- (국내/논문/2016) 이기종 보안시스템의 통합 보안관리 방안에 관한 연구
  - 보안 시스템들의 주요 방어 목적에 따라 공격 유형을 토픽화하여 대량 이벤트를 효과적으로 축약
  - 생성된 토픽이벤트의 중요도 및 연관성 분석으로 신뢰성 높임 (①보안 이벤트 등급, ②IP 위협지수, ③보안시스템 중요도)
- (국내/논문/2019) 기계학습 기반 침해사고 경보 위험도 예측
  - IPS 기준 8가지 학습 데이터 피처 선정 (탐지 근거가 되는 Payload(RAW Packet) 수집은 필수 사항)
  - 유사, 중복필드에 대한 처리를 통한 최적화된 학습 제공 (통계적 유사 필드 분석 기법 적용)
  - 데이터 중요도, 예측 모델 기여도에 따라 가중치 부여 (분석가 경험에 따라 특정 필드에 대한 중요도 부여)
  - 앙상블 모델을 사용하여 정확도 향상 (CATBoost, Stochastic Gradient Descent)
- (국내/특허/2020/이글루시큐리티) 공격빈도, 자산중요도 및 취약 정도에 따른 위험지수 보정시스템 및 그 방법
  - (기존) 관리자가 초기에 설정한 위험지수 값이 유지되므로, 변화하는 정량적 지표 반영 X, 신뢰도 ↓
  - (개선) 시간, 날짜에 따라 자산 및 위협유형별 이벤트량 변화에 따라 위험지수 산출 가능, 신뢰도 ↑
  - 정보자산가치(상/중/하), 자산 취약도(양호/취약), 기준치 산출(단위 시간당 보안이벤트 수)을 통해 위험지수 보정
- (국내/특허/2021/시큐레이어) 이벤트 룰셋 및 위협 인텔리전스(Threat Intelligence)를 참조로 하여 이벤트 위험도를 계산함으로써 시스템에 발생한 이벤트들의 위험도를 분석할 수 있도록 지원하는 방법 및 이를 이용한 장치
  - 이벤트 출현도(3개), 이벤트 영향도(3개), 공격난이도(5개), 대응난이도(2개)로 위험도 평가
  - 취약점 점수 = 출현도 X 영향도 X 공격 난이도, 위험도 점수 = 취약점 점수 * 0.8 + 대응 난이도 * 0.2
- (국내/특허/2020/이글루시큐리티) 머신러닝을 이용한 대응 자동화 프로세스의 승인 절차 개선 시스템 및 그 방법
  - 다양한 보안 위협에 대한 대응 프로세스 자동화 낮은 수준의 보안 이벤트는 사람의 도움 없이 처리
  - 플레이북 내 액션데이터 학습하여 승인 절차 예측 (분석가의 피드백을 통해 모델 갱신)
  - 플레이북의 액션데이터에 대한 승인 데이터를 라벨링 데이터로 함, 학습모델 생성
- (국내/특허/2021/SKT) 머신러닝 기반 보안관제 장치 및 방법
  - 탐지 이벤트에 대하여 머신러닝 기반 추론 모델 이용하여 이벤트 대응 방안 자동 추론
  - 초기학습, 증분학습, 갱신학습으로 구분, 추론 모델은 각각 다르게 선택
  - 추론 모델 출력은 로지스틱 함수(시그모이드) 구현, 추론된 대응 방안에 대한 예측 확률을 회귀분석 기반으로 재조정

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- 저신뢰도 이벤트 DB를 구축하여, 온라인 리트레이닝 수행
- 저신뢰도 이벤트 및 대응 방안 라벨 기반 증분학습 수행 (추가 데이터 이용 리트레이닝 → 학습 모델 파라미터 업데이트)
- 이벤트의 보안 위협과 대응 방안의 신뢰도 임계치에 따라 다른 대응 선택
- ex) 탐지 이벤트가 보안 위협 → 고객 통보 미실행 추론 → 고객 통보 생략 → IP 블랙리스트 등록

- (국내/특허/2021/로그프레소) 위협 대응 자동화 방법
  - 이벤트 위협 대응 자동화에 대한 일반적인 방법론 제시
  - 데이터 수신 → 위협탐지 및 티켓 생성 → 위협분류, 위협지표 추출 → 워크플로우 실행 → 테스크 결과 취합 → 범주형 변수/ 수치형 변수 취합 → 판정 결과 입력 → AI 학습 실행 → AI 모델 생성
  - 구체적인 피처, AI 모델 등은 언급 없음
  - 알림 태스크 : 위협 사실을 관리자에게 알림(이메일, 문자, 슬랙, 잔디 등)

o 보안 이벤트 우선처리 학습을 위한 데이터 특성값 분석
- 이벤트 자체 정보, 이벤트 위험도, 플레이북, 사용자 피드백 대상 특성값 추출

<이벤트 데이터 특성값 추출>

4) (추가수행) 보안관제 대응이력 데이터 수집 기술 요구사항 분석

o 보안관제 대응이력 수동 수집 요구사항
- 정형화되지 않은 보안 관제원의 위협 이벤트 분석 및 대응 과정에 대한 이력을 수집하기 위해 엑셀 시트 기반의 기록 양식 필요
- 보안관제 센터의 특성과 관제원의 노하우에 따라 동일 이벤트에 대한 분석 및 대응 절차가 상이하기 때문에 다양한 곳에서 데이터 수집 필요

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

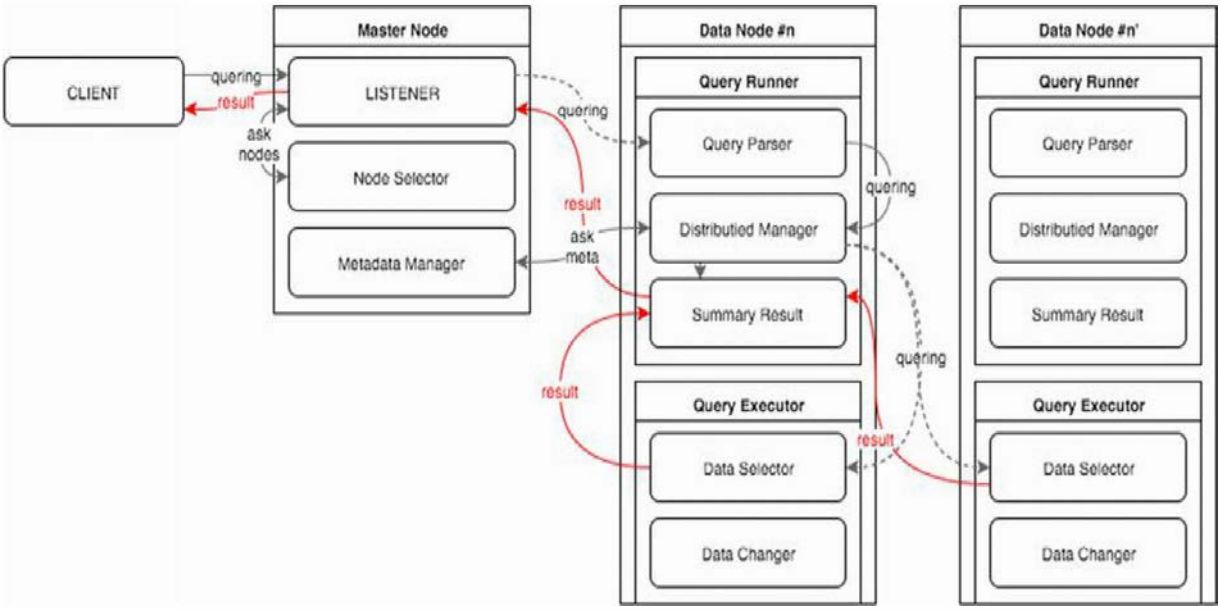
- 보안관제원의 대응이력 데이터는 본 과제의 위협 분석 자동화, 의사결정 지원 기술에서 사용하는 강화학습의 중요 데이터로 사용
- 통합 플랫폼 내에 웹 GUI 기능을 통한 수동 입력 과정 변경 필요
- 강화학습의 기초 데이터로 활용하기 위해 14가지의 대응이력 수집 필드 정의

<보안관제 대응이력 수집 필드>

No	구분	설명	예시
1	탐지시간 및 조치시간	- 이벤트 탐지 및 조치 시간	2021-10-03 12:00
2	장비명	- 이벤트가 발생한 보안 장비명	IDS
3	위협·공격 유형	- 8가지 위협 공격 유형	웜 바이러스
4	공격·탐지 명	- 이벤트가 탐지된 패턴명	웜 바이러스 피해
5	위험도	- 이벤트의 위험도(장비 또는 관제원)	중(또는 6)
6	분류	- 분석, 대응 구분	분석
7	순서	- 분석 순서, 대응 순서	3
8	행위	- 보안관제원의 분석 행위	공격자 IP 이력 조회
9	도구명	- 분석에 사용된 도구명	virustotal
10	분석 대상	- 분석에 사용된 대상	공격자 IP
11	대응 대상	- 대응이 필요한 대상(기관, 장비 등)	OOO 기관
12	판단 근거	- 분석 도구의 결과 판단 근거	조회 결과
13	결과	- 분석 결과	악성 IP
14	판단	- 분석에 대한 관제원의 판단 근거	C&C 서버 이력 존재

5) (추가수행) 데이터 통합 관리 기술 요구사항 분석

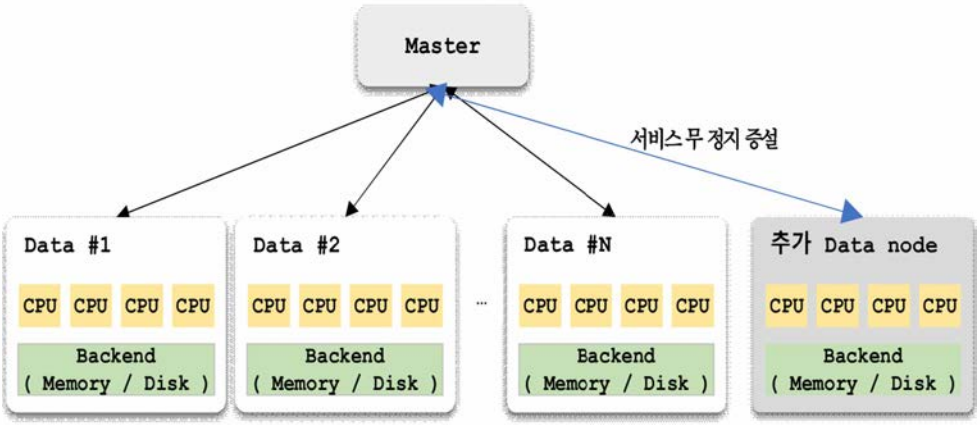
o 학습 데이터 수집 및 관리 기능 요구사항 분석
- 분산 처리를 통한 대용량 데이터 실시간 수집, 저장, 검색 성능



<분산 처리 구조 시스템>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

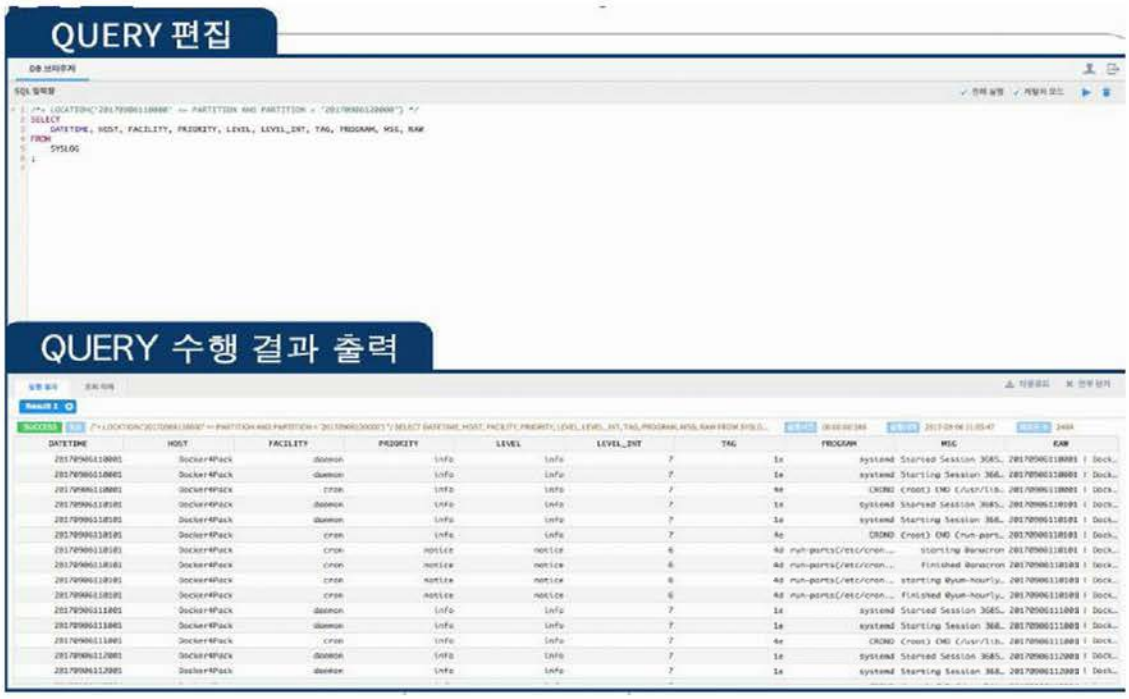
- 데이터 증가에 따른 손쉬운 시스템 용량 증설
- 24시간 보안 관제 업무 특성에 따른 무정지 서비스 보장



<서비스 무정지 시스템 증설 개념도>

- 데이터 통합 관리에 따른 데이터 접근 제어, 데이터 검색, 분석 기능
- 이기종 보안 장비별 이벤트와 플레이북 실행 결과, 대응 이력 결과 수집
- 강화학습 모델 입력 데이터 수집, 적재, 업데이트

o 데이터 연동 API 및 웹 관리 기능
- 통합 데이터 테이블 정보 조회 및 신규 테이블 생성 관리 UI
- SQL session 현황 관리 및 실행 정보 관리 UI
- 사용자의 접근 권한 등 사용자 정보 관리 UI
- SQL을 통한 데이터 검색, 수정, 삭제 관리 UI



<통합 데이터 관리 UI 예시>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- 시스템 자원(CPU, Memory, Disk) 사용률 모니터링 UI

<시스템 모니터링 UI 예시>

- RESTful API를 통한 데이터 연동 인터페이스
  - 이기종 보안 이벤트 수집 주기, 데이터 포맷, 보관 기간 등을 정의 및 API를 통한 수집
  - 플레이북 실행 결과, 대응이력, 의사결정 결과 데이터의 수집 주기, 데이터 포맷, 보관 기간 정의 및 API를 통한 수집

□ SOC 활용 시각화 및 AI 기반 의사결정 요소 기술 설계

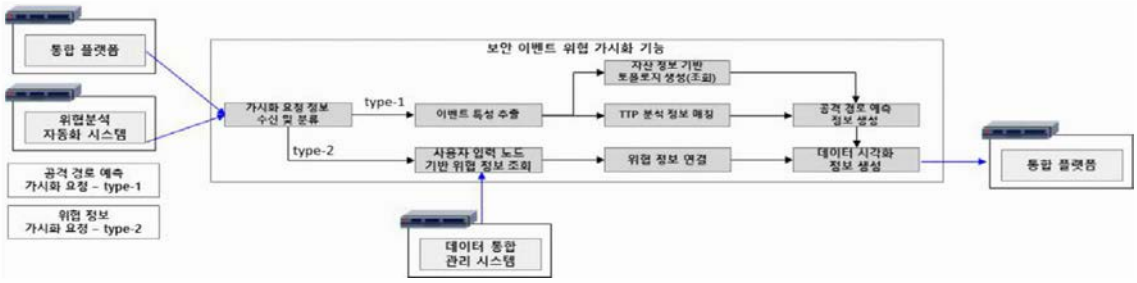
연구목표	SOC 활용 시각화 및 AI 기반 의사결정 요소 기술 설계

세부 내용	1) 보안 위협 정보 가시화 기술 설계
	2) 고위험 이벤트 신속 분류 기술 설계
	3) 경보대응 우선순위 분석 기술 설계
	4) (추가수행) 보안관제 대응이력 수집 기술 설계
	5) (추가수행) 데이터 통합 관리 기술 설계

□ SOC 활용 시각화 및 AI 기반 의사결정 요소 기술 설계 세부 내용

1) 보안 위협 정보 가시화 기술 설계

o 연관분석 정보 가시화 기술 세부 기능

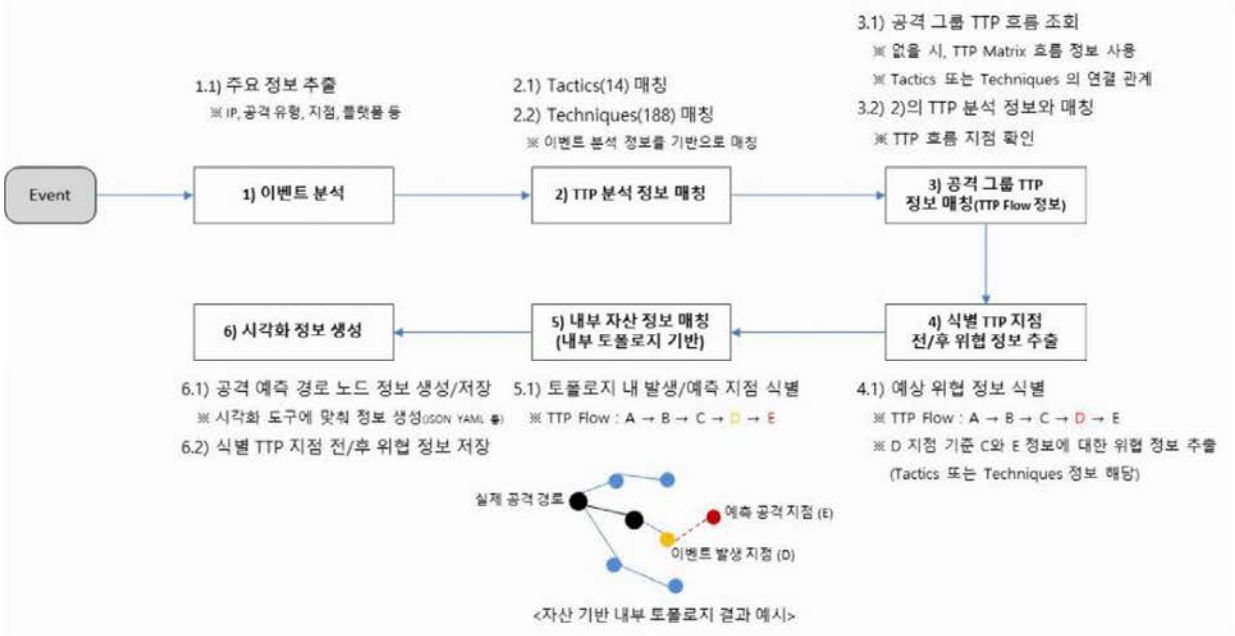


<보안 이벤트 위협 가시화 기능 구성도>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

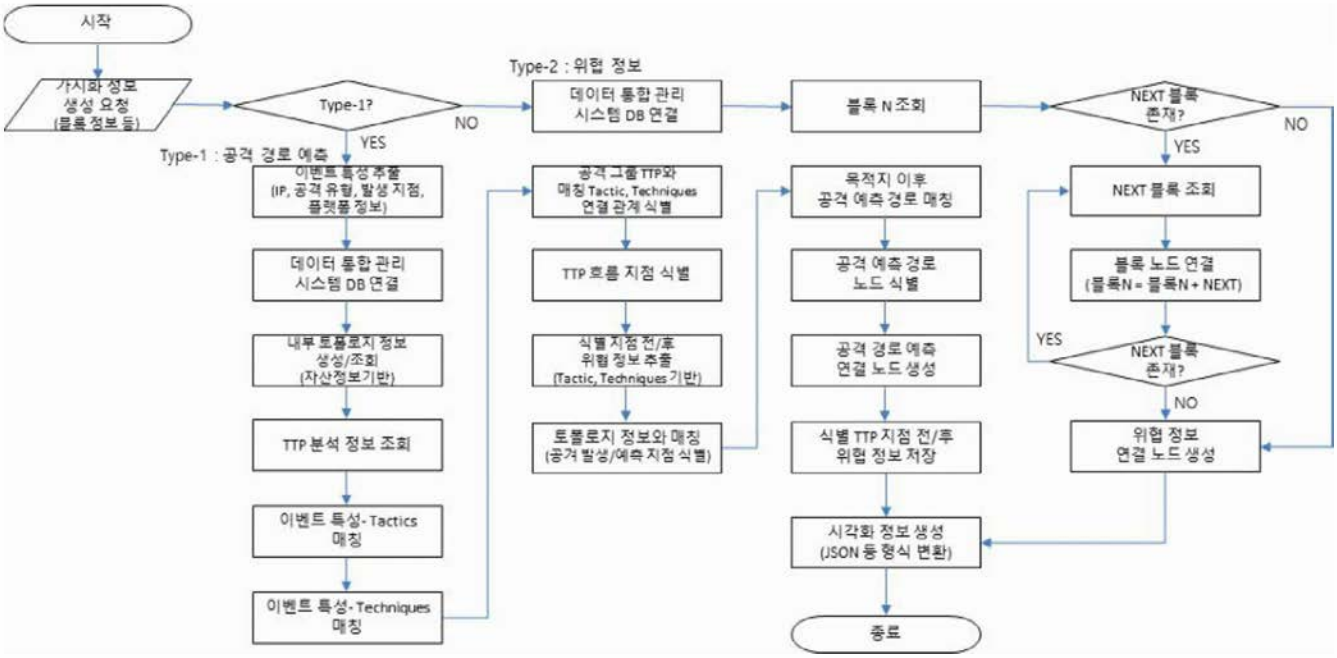
- (기능 1) 가시화 요청 정보 수신 및 분류
  - 통합 플랫폼, 위협분석 자동화 시스템으로부터 입력 데이터 수신
  - 위의 시스템에서 사용자의 요청(클릭) 발생 시 연관분석 정보 가시화 진행
  - 공격 경로 예측 가시화, 위협 정보 가시화 두 가지 유형 입력 처리
- (기능 2) 이벤트 특성 추출
  - 입력된 이벤트에서 IP, 공격 유형 등 특성 데이터 추출
- (기능 3) 자산 정보 기반 토폴로지 생성
  - 사전에 구성된 내부 네트워크 토폴로지 정보가 존재하면 데이터를 조회
  - 토폴로지 정보가 없다면, 사용자 입력 기반으로 작성된 자산 정보를 이용하여 네트워크 토폴로지 생성
- (기능 4) TTP 분석 정보 조회 및 매칭
  - 데이터 통합 관리 시스템에 저장된 TTP 분석 정보 조회
  - 기능 2에서 추출된 특성 데이터와 TTP 분석 정보의 매칭 수행
- (기능 5) 공격 경로 예측 정보 생성
  - 기능 3에서 생성/조회한 네트워크 토폴로지와 기능 4에서 매칭된 데이터를 결합하여 위협 이벤트의 실행 경로와 예측된 공격 경로 정보 생성
- (기능 6) 사용자 입력 블록 기반 위협 정보 조회
  - 사용자로부터 입력받은 블록 정보를 기반으로 데이터 통합 관리 시스템에서 위협 정보 조회 및 저장

    ※ 블록 정보 : IP, 탐지이력, 위협 정보, 공격 유형 등
- (기능 7) 위협 정보 연결
  - 기능 6에서 저장된 데이터를 기반으로 블록 순서에 따라 노드 생성 및 연결
- (기능 8) 데이터 시각화
  - 사용자 입력에 따라 생성된 기능 5 또는 기능 6의 정보(유형1 또는 유형2)를 시각화하기 위해 데이터 형식 변환
  - 공개된 네트워크 데이터 시각화 라이브러리를 통해 변환된 데이터 시각화



<TTP 분석 정보 기반 공격 예측 경로 생성 과정>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



<보안 이벤트 위협 가시화 정보 생성 순서도>

<사용자 입력 노드 데이터/필드 정의>

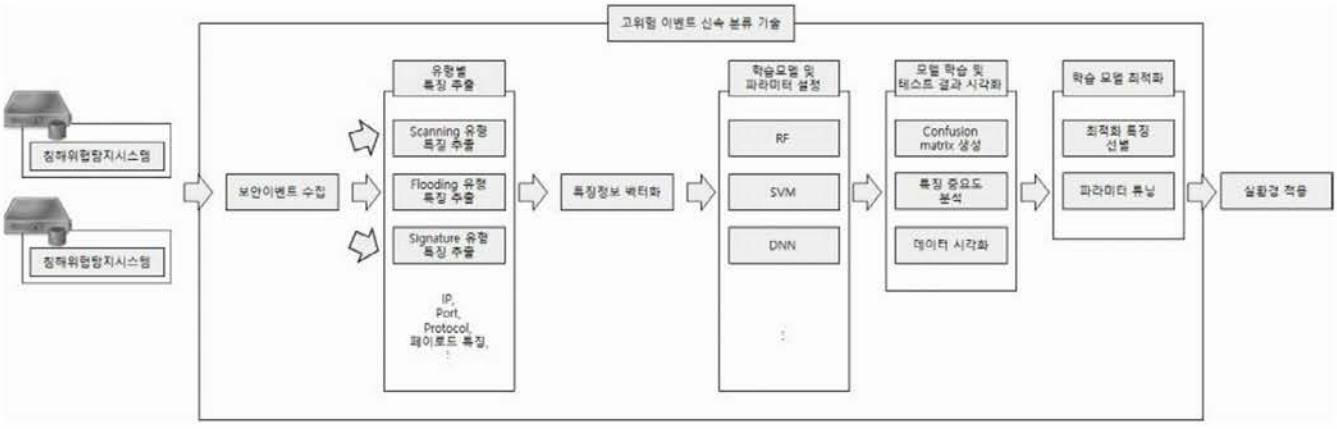
구분	노드명	설명	타입(DB)	예시	비고
이벤트 패킷 정보	event_id	이벤트 ID	INT		
	src_ip	출발지 IP	VARCHAR	192.168.0.1	
	dst_ip	목적지 IP	VARCHAR	10.10.1.1	
	src_port	출발지 Port	SMALLINT	80	
	dst_port	목적지 Port	SMALLINT	443	
	pattern_name	탐지 패턴명	VARCHAR		
	detect_time	탐지 시간	DATETIME	2021-09-28 15:34:00	
	event_count	이벤트 수	SMALLINT	5	
	attack_type	공격 유형	VARCHAR	시스템 취약점 공격	
	attack_type_detail	공격 유형(세부)	VARCHAR	단순 침입 시도	
	binary_hash	바이너리 파일 해쉬	VARCHAR		MD5 or SHA512
	detect_result	정탐, 오탐	VARCHAR	정탐 or 오탐	
외부 위협 정보	cti_id	위협정보식별자	INT		
	cti_attack_ip	공격자 IP	VARCHAR	10.10.1.1	
	cti_c2_ip	C&C 서버 IP	VARCHAR	192.168.0.1	
	cti_domain	공격자 도메인	VARCHAR	attack.co.kr	
	cti_binary_hash	바이너리 파일 해쉬	VARCHAR		MD5 or SHA512
	cti_attack_group	공격 그룹명	VARCHAR	Lazarus	
	cti_virustotal_count	바이러스토탈 탐지수	SMALLINT	30	30/50

2) 고위험 이벤트 신속 분류 기술 설계

o 신속한 의사결정 지원을 위한 고성능 AI 분석 모델 개발 기술

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- (기능 1) 보안이벤트 수집 기능
  - 침해위협탐지 시스템에서 보안이벤트를 실시간 or 주기적으로 수집
  - 수집된 보안이벤트명에 따라 이벤트 유형 분류(scanning, flooding, signature)
- (기능 2) 보안이벤트의 유형별 특징 추출
  - 단일 이벤트에서 추출 가능한 IP, Port, Protocol, 페이로드 특징(문자열, 문자열 패턴, 페이로드 엔트로피, 특정 문자열 출현 빈도(TF), 전체 페이로드 길이 대비 출력 가능한 문자열 비율) 등의 정보 추출
  - IP와 무관하게 단위 시간동안 수집된 보안이벤트 그룹에서 추출 가능한 정보 추출 (특정 문자열을 포함하는 보안이벤트 출현 빈도(DF), 이벤트들의 발생 주기성, 이벤트들의 간격, 서로 다른 이벤트들 간의 연관성 등의 정보 추출)
  - 동일 IP에서 수집된 보안이벤트들 간의 연계성 분석
- (기능 3) 특징정보 벡터화
  - 정수형 데이터 필드 → 별도의 가공과정 없이 사용
    → 필드별로 정규화
  - 문자열형 데이터필드 → 암호학적 해시(MD5)를 통해 정수로 변환하여 사용
    → Word2Vec, TF-IDF, BM25 등의 벡터화 알고리즘 사용
  - 범주형 데이터필드 → One-Hot encoding, Label encoding 수행 후 사용
- (기능 4) 학습모델 및 파라미터 설정 기능
  - 학습모델에 따른 파라미터들을 UI/UX 상에서 설정하는 기능
    ※ 금년도에는 RandomForest, SVM, DNN 등의 일부 모델만 활용
- (기능 5) 모델 학습 및 테스트 결과 시각화
  - 모델 학습 결과를 confusion matrix로 표현(accuracy, precision, recall, F1-score 함께 표시)
  - 모델의 학습 결과 시각화
  - 모델에 따라 feature importance 표현
- (기능 6) 학습모델 최적화 및 적용 기능
  - 기능 5의 결과를 분석하여 유의미한 특징 추출 및 모델 최적화
  - 실환경 적용 및 실증 결과 조회



<고위험 이벤트 신속 분류 기술 구성도>

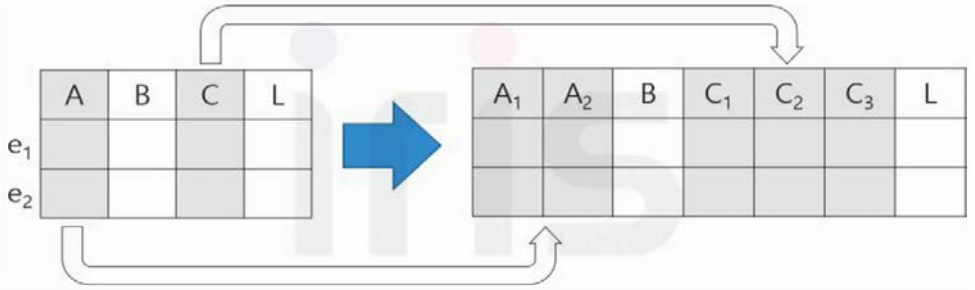
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

o 신속한 의사결정 지원을 위한 고성능 AI 분석 모델 개발 기술 테스트 결과

- (실험 1) IPS 로그에서 추출 가능한 이벤트 메타정보 학습
  - IPS 로그에서 추출 가능한 이벤트 메타정보 학습
    - ▸ 정수형 데이터필드 → 별도의 가공과정 없이 사용
    - ▸ 문자열형 데이터필드 → 암호학적 해시(MD5)를 통해 정수로 변환하여 사용
  - 랜덤포레스트(RandomForest) 분류기를 통해 보안이벤트 정·오탐 분류
    - ▸ 다수의 의사결정나무(Decision Tree) 예측 결과를 종합하여 최종 예측값 결정
  - 약 70만 개 테스트 데이터에 대해 97% 정확도 성능

- (실험 2) 보안이벤트 페이로드 DF(Document Frequency) 특징정보 학습모델
  - 보안이벤트 메타정보 학습모델과 동일 특징정보 및 분류기 사용
  - 보안이벤트의 정·오탐이 페이로드 내 특정 단어에 의해 결정됨을 활용

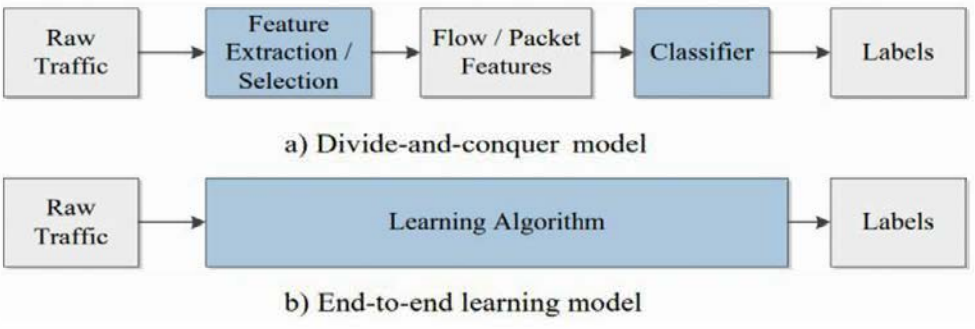
  예시) HTTP 상태코드 : "200" (정상 연결) → 정탐 / "300" (리다이렉션) → 오탐
  - ASCII 변환된 페이로드 내 단어의 DF 값을 활용한 특징정보 추가학습
    - ▸ 학습데이터 내 DF 값 상위 100개 단어의 출현여부 학습
    - ▸ 단순 문자열을 100개 정수값으로 확장함으로써 특징정보 의미 확장



<데이터필드 확장을 통한 특징정보 의미 확장>

  - 약 70만 개 테스트데이터에 대해 99% 정확도 성능

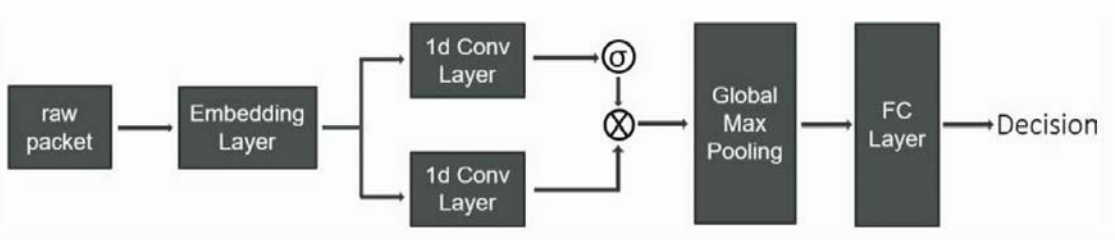
- (실험 3) 보안이벤트 특징 자동 학습모델(1d-comv 모델 사용)
  - 보안이벤트를 종단간 학습(End-to-End Learning) 기법을 활용하여 모델에 학습
    - ▸ 별도의 특징추출·가공과정 없이 인공지능 모델의 입력으로 사용
    - ▸ 특징추출·가공과정에 소요되는 인적·시간적 자원에 대한 절약 가능



<기존 분류기 생성과정(a)과 종단간 학습을 통한 분류기 생성과정(b)>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

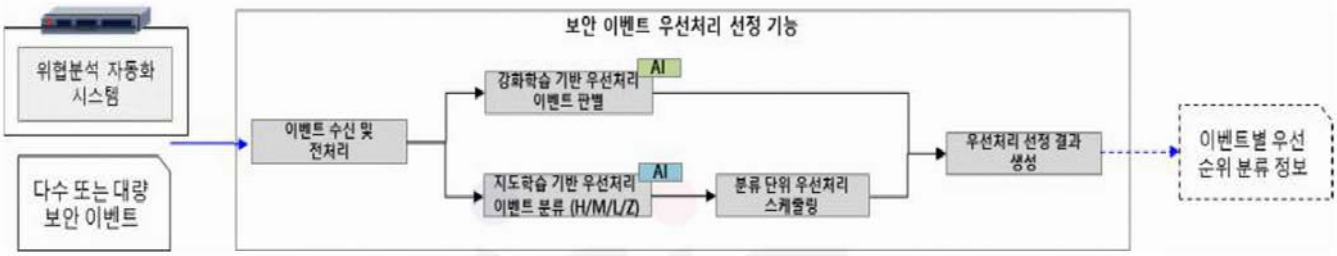
- 원본 페이로드 자체를 학습하여 모델이 보안이벤트 특징을 자동으로 학습하도록 유도
- 약 1,500만 개 테스트데이터에 대해 99% 정확도 성능



<보안이벤트 특징 자동 학습모델 전체 구조>

3) 경보대응 우선순위 분석 기술 설계

3-1) 우선처리 이벤트 선정 기능



<우선처리 이벤트 선정 기능 구성도>

o (기능 1) 이벤트 수신 및 전처리
  - 위협분석 자동화 시스템으로부터 요청 이벤트(우선순위 선정) 수신
  - AI 모델(강화학습, 지도학습)에 적용하기 위해 이벤트 데이터 전처리
o (기능 2) 강화학습 기반 우선처리 이벤트 판별
  - 전처리 된 데이터를 분석하여 강화학습 모델이 우선순위 판정을 하는데 사용할 입력 특성 추출을 위해 주어진 이벤트 발생 시간, 수, 패킷 크기, 이벤트 유형, 지속 시간 등에 데이터 변환/조합과 같은 특성 공학 기법을 적용
  - 추출한 특성값의 방법 1 혹은 방법 2 방식 및 강화학습 모델을 통한 최적의 이벤트 결정
    - 방법 1 : (강화학습 모델의 액션 값으로 이벤트-대응 Pair를 사용하는 경우) 추출한 특성값을 학습된 강화학습 모델에 입력하면, 모델 내부 정책 신경망에 전달되어 현재 입력된 이벤트 상황에서 가장 우선 처리해야 할 이벤트와 그에 대한 대응(액션) 값을 출력함. 이런 방식의 원활한 수행을 위해서는 해당 데이터셋에 복수의 이벤트가 동시 발생한 상황에서 전문가가 어떤 이벤트를 우선하여 어떤 대응했는지에 대한 이력을 포함되어 있어야 함
    - 방법2 : (강화학습 모델의 액션 값으로 대응을 사용하는 경우) 이 방법의 강화학습 모델은 단일 이벤트를 처리하는 모델로, 이벤트 발생 시 그에 대한 특성값을 입력으로 최적의 대응을 출력함. 여러 건의 이벤트가 동시 수신된 상황에서 각 이벤트별로 특성 추출부터 모델 입력/출력이 수행되어 각 이벤트에 대한 강화학습 모델 기반의 최적 대응을 출력함. 출력된 대응 및 기존 대응 이력 DB 통계 분석 결과를 바탕으로 어떤 대응이 우선적으로

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

이루어지는지 기준으로 가장 먼저 해야 할 대응을 결정하고, 이에 매핑된 이벤트가 최종 우선처리 이벤트로 선정됨

- 강화학습 모델은 3-3에서 별도의 학습 과정을 통해 생성

o (기능 3) 지도학습 기반 우선처리 이벤트 분류

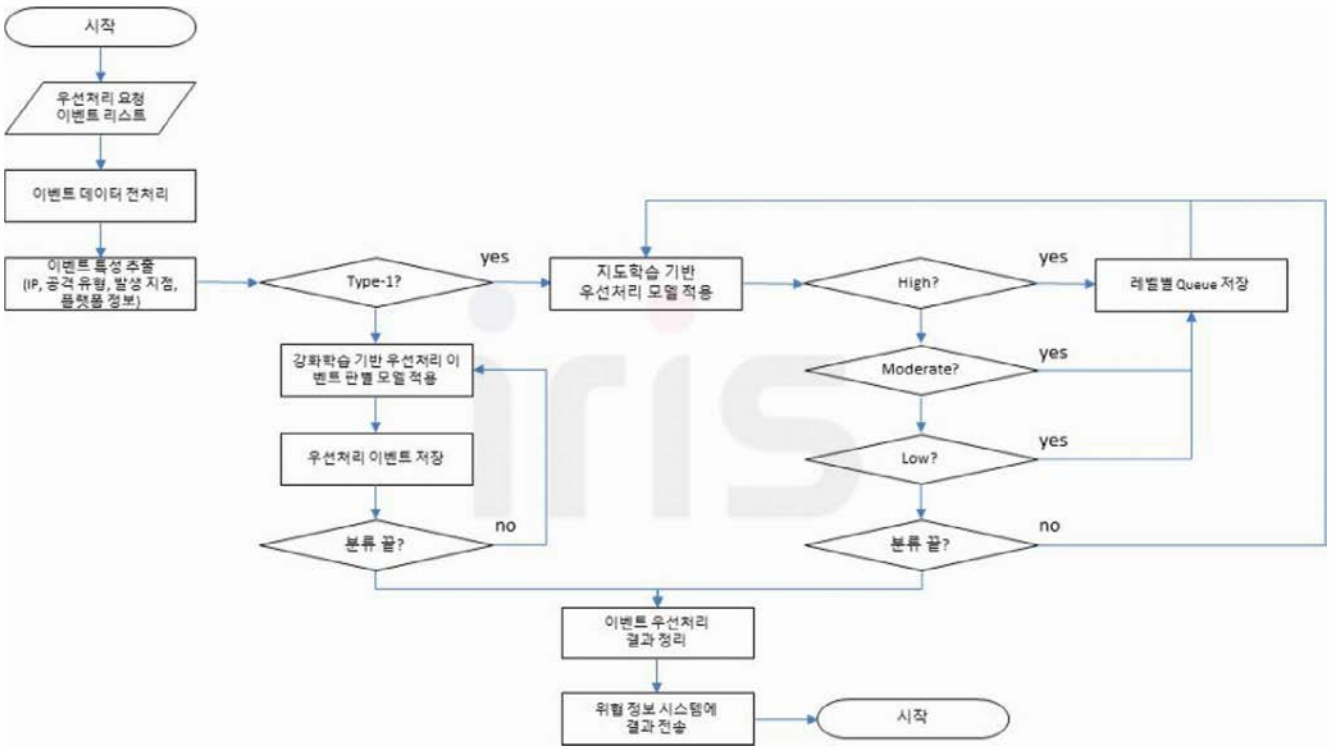
- 전처리 된 데이터를 지도학습 기반 분류기에 입력하여 우선처리 분류 결과 출력
- 지도학습 모델은 3-3에서 별도의 학습 과정을 통해 생성

o (기능 3) 분류 단위 우선처리 스케줄링

- 기능 2에서 high, moderate, low 단위로 분류된 이벤트 저장
- 이벤트 발생시간, 중요도 등을 기준으로 효율적인 처리 스케줄링 수행

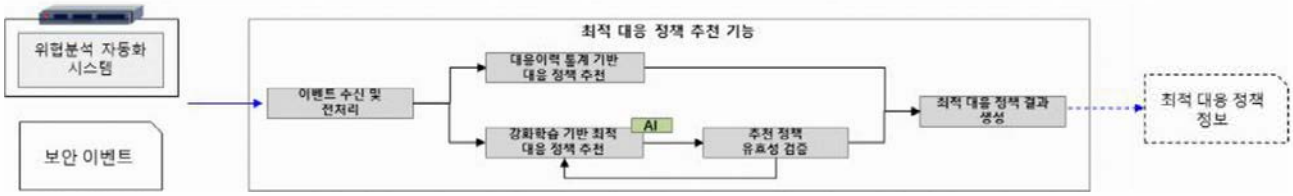
o (기능 4) 우선처리 결과 전송

- 위협 이벤트의 우선처리 결과 리스트를 위협 분석 자동화 시스템에 전송



<우선처리 이벤트 선정 기능 순서도>

3-2) 최적 대응 정책 추천 기능



<최적 대응 정책 추천 기능 구성도>

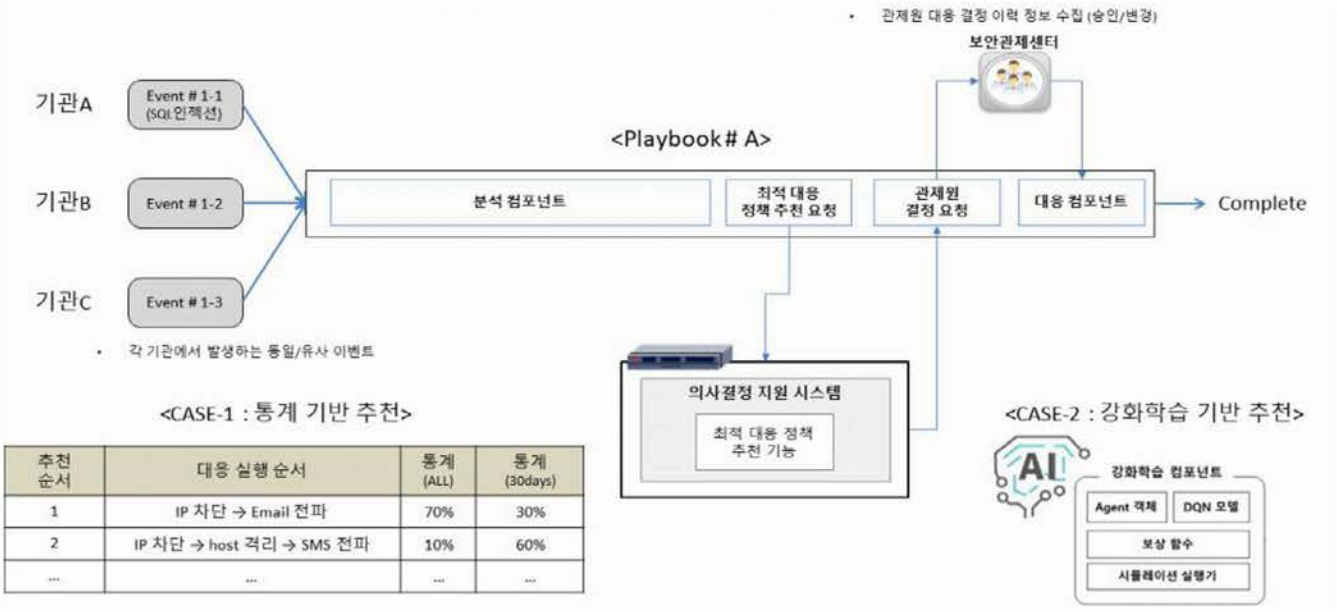
o (기능 1) 이벤트 수신 및 전처리

- 위협분석 자동화 시스템으로부터 요청 이벤트(최적 대응 정책 요청) 수신
- AI 모델(강화학습)에 적용하기 위해 이벤트 데이터 전처리

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

o (기능 2) 강화학습 기반 최적 대응 정책 추천
  - 전처리 된 데이터를 강화학습 모델 기반 추천기에 입력하여 최적 대응 정책 추천
  - 강화학습 모델은 3-1 ‘강화학습 기반 우선처리 이벤트 판별’에서 방법 2로 설명한 방식으로 작동함 (단일 이벤트에 대하여 관련 이벤트 자체 정보를 바탕으로 강화학습 모델은 최적의 대응을 결정)
o (기능 3) 통계 기반 대응 정책 추천
  - 보안 관제원의 과거 대응이력 결과에 대한 통계화된 정보 제공
o (기능 4) 대응 정책 유효성 검증
  - 현재 추천 대응 정책이 적용 가능한지에 대한 시스템 상태 점검
  - 대응 정책 추천 전송 이후 피드백 결과를 기반으로 유효성 여부 확인
o (기능 5) 최적 대응 정책 추천 결과 전송
  - 최적 대응 정책 추천 리스트를 위협 분석 자동화 시스템에 전송

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



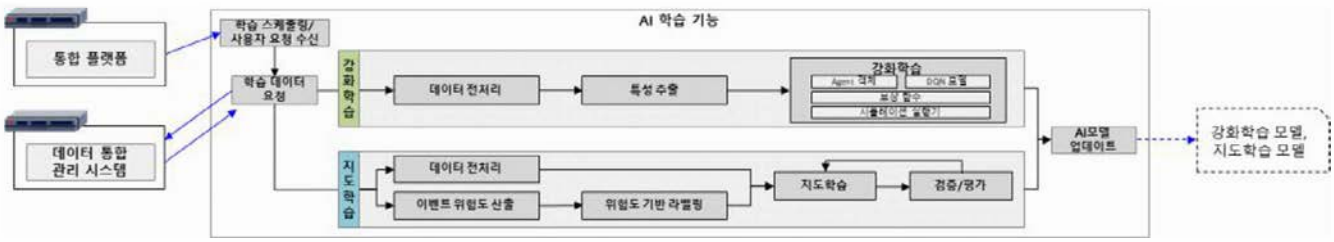
추천 순서	대응 실행 순서	통계 (ALL)	통계 (30days)
1	IP 차단 → Email 전파	70%	30%
2	IP 차단 → host 격리 → SMS 전파	10%	60%
...	...	...	...

<최적 대응 정책 추천 개념도>

<보안관제 대응 유형 정의>

분류	세부 유형	비고
1. 티켓팅(Ticketing)	SOC Ticket	자동처리 불가 이벤트에 대해 티켓 발행
2. 차단(Block)	IP	-
	Port	-
	Hash	MD5, SHA-256 등
	Binary	악성코드 등
3. 격리(Isolate)	Host IP	감염 단말/서버 IP
	Internal Network	내부 네트워크 대역
4. 알림(Notifications)	Email	-
	SMS	-
	Messenger	slack, band 등 메신저
5. 위협 공유 (Threat Sharing)	Internal CTI	자체/상용 CTI 솔루션
	External CTI	KISA_C-TAS, NCSC_NCTI
6. 예방(Prevetion)	IP	조직 내 피해 발생은 없으나, 위협이벤트 분석 결과 차후 예방조치가 필요한 대응
	Port	-
	Hash	-
	Binary	-

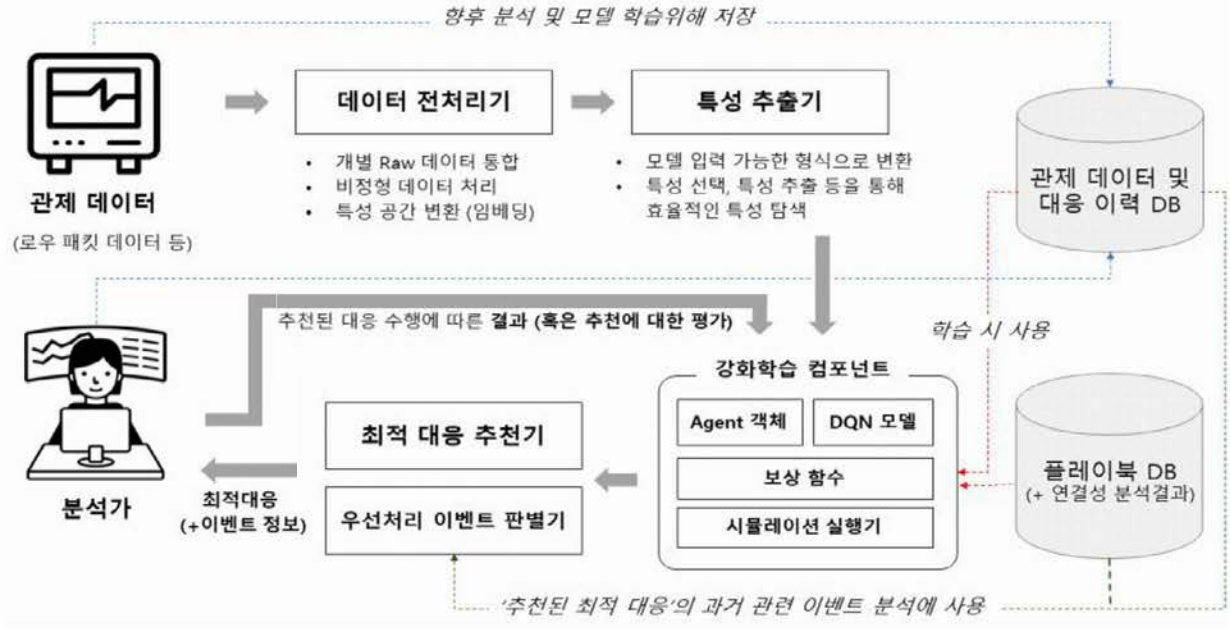
3-3) AI 학습 기능



<AI 학습 기능 구성도>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

o (기능 1) 학습 데이터 수신
  - 사용자 요청 또는 스케줄링 된 정보를 기반으로 학습 데이터 수신
o (기능 2-1) 데이터 전처리
  - 다양한 소스에서 들어오는 개별 Raw 데이터를 통합하고, 비정형 데이터 처리, 특성 공간 변환 등 이후 과정에서 데이터를 처리 가능한 형태로 변환하는 과정 수행
o (기능 2-2) 특성 추출
  - 강화학습 모델에서 학습이 용이한 형태로 입력된 데이터를 가공하고 특성을 추출하는 과정을 수행
o (기능 2-3) 강화학습
  - DQN(Deep Q Network)을 학습하기 위한 Agent 객체, 보상 함수 등을 포함하고 있으며, 관제 데이터 및 대응 이력 DB와 플레이북 DB 정보를 활용하여 보상함수를 계산하여 학습을 진행
  - 모델 입력 특성은 대응 이력 DB 및 이벤트 자체 정보 바탕으로 추출한 값들로 구성하며, 모델 출력으로 3-1에서 언급한 방법 1 및 방법 2에 따라 우선처리 이벤트-최적대응 혹은 주어진 이벤트-최적대응으로 구성
  - 대응 이력 DB에서 이벤트 발생부터 대응 결과까지를 하나의 에피소드로 구분하여 시뮬레이션 실행기가 어떤 이벤트를 발생시키고 DQN의 정책 신경망을 바탕으로 가장 최적의 액션(대응)을 선택했을 때 이러한 선택이 얼마나 실제 전문가와 비슷했는지 혹은 기존 플레이북 특성과는 얼마나 유사한지 등을 보상함수로 평가
  - 평가된 보상함수 값을 바탕으로 기존 정책 신경망을 업데이트하고 이러한 과정을 에피소드별로 반복하여 전문가의 행동을 점차 모사해 가도록 학습을 수행
  - DQN 모델의 학습이 끝나면 강화학습 컴포넌트에 입력된 데이터에 대하여 현재 입력 상태에서 가능한 대응 액션별 확률 및 가치값을 반환



< 강화학습 기반 의사결정 지원 개념도 >

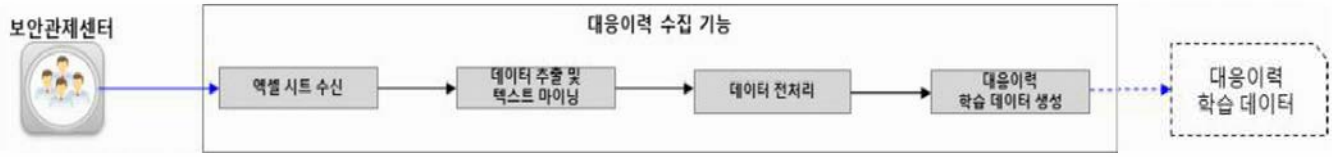
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

o (기능3-1) 데이터 전처리
  - 다양한 소스에서 들어오는 개별 Raw 데이터를 통합하고, 비정형 데이터 처리, 특성 공간 변환 등 이후 과정에서 데이터를 처리 가능한 형태로 변환하는 과정 수행
o (기능3-2) 이벤트 위험도 산출
  - 이벤트 데이터를 기준으로 침해사고 이력, 내부 자산정보, CTI 정보 등 다양한 정보를 활용하여 위험도 점수 산출
o (기능3-3) 위험도 기반 라벨링
  - 학습 데이터 전체에 대해 위험도를 산출하여 각각 3단계(high, moderate, low) 라벨링 수행
  - 라벨링 정보는 지도학습 정답셋으로 사용
o (기능3-4) 지도학습
  - 다중 분류 지도학습 알고리즘을 이용하여 이벤트에서 추출된 다양한 피처 정보를 기반으로 최적 학습 수행
o (기능3-5) 검증 및 평가
  - 지도학습 결과 데이터와 평가 데이터를 기반으로 지도학습 모델 검증 및 평가 수행
o (기능4) 피드백 수신 및 저장
  - 분석가는 최적 대응과 이벤트 정보를 받아 그 대응을 수행하고, 그 수행에 따른 결과(예: IP 조회 대응 행동의 결과로 의심 IP 발견)를 강화학습 컴포넌트에 전달하여 다음 대응을 추천 받음

<DREAD 위협 모델 기반 위험도 산출 점수>

구분/점수	예상피해 (D)	재현성 용이성 (R)	공격 용이성 (E)	영향을 받는 사용자 (A)	발견 용이성 (D)
설명	피해 범위는?	공격 확률은?	공격을 위한 노력은?	피해를 받는 범위는?	공격 발견이 쉬운가?
0	없음	없음	없음	없음	없음
4	사소한 정보 유출	재현 어려움	전문가	적은 비율의 사용자	소수 제품에서 사용
7	민감한 정보 유출	재현은 가능하지만 여러조건필요	숙련자	일부 사용자	일부 제품에서 사용
10	시스템 장악	매번 재현 가능	초보도 가능 (짧은시간내에가능)	모든 사용자, 주요 고객	많은 제품에서 사용

4) (추가수행) 보안관제 대응이력 데이터 수집 기술 설계



<대응이력 수집 기능 구성도>

o (기능1) 엑셀 시트 수신
  - 보안관제원으로부터 작성된 엑셀 시트 대응이력 양식 수신(엑셀 파일)
o (기능2) 데이터 추출 및 텍스트 마이닝

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- 엑셀 시트에 정의된 행(row) 값을 식별하고, 이벤트 ID 또는 No를 기준으로 데이터 추출
- 분석 대응 행(row)의 ①분석 행위, ②판단 근거, ③결과 항목에 대하여 의미/구문 분석을 위해 텍스트 마이닝 수행

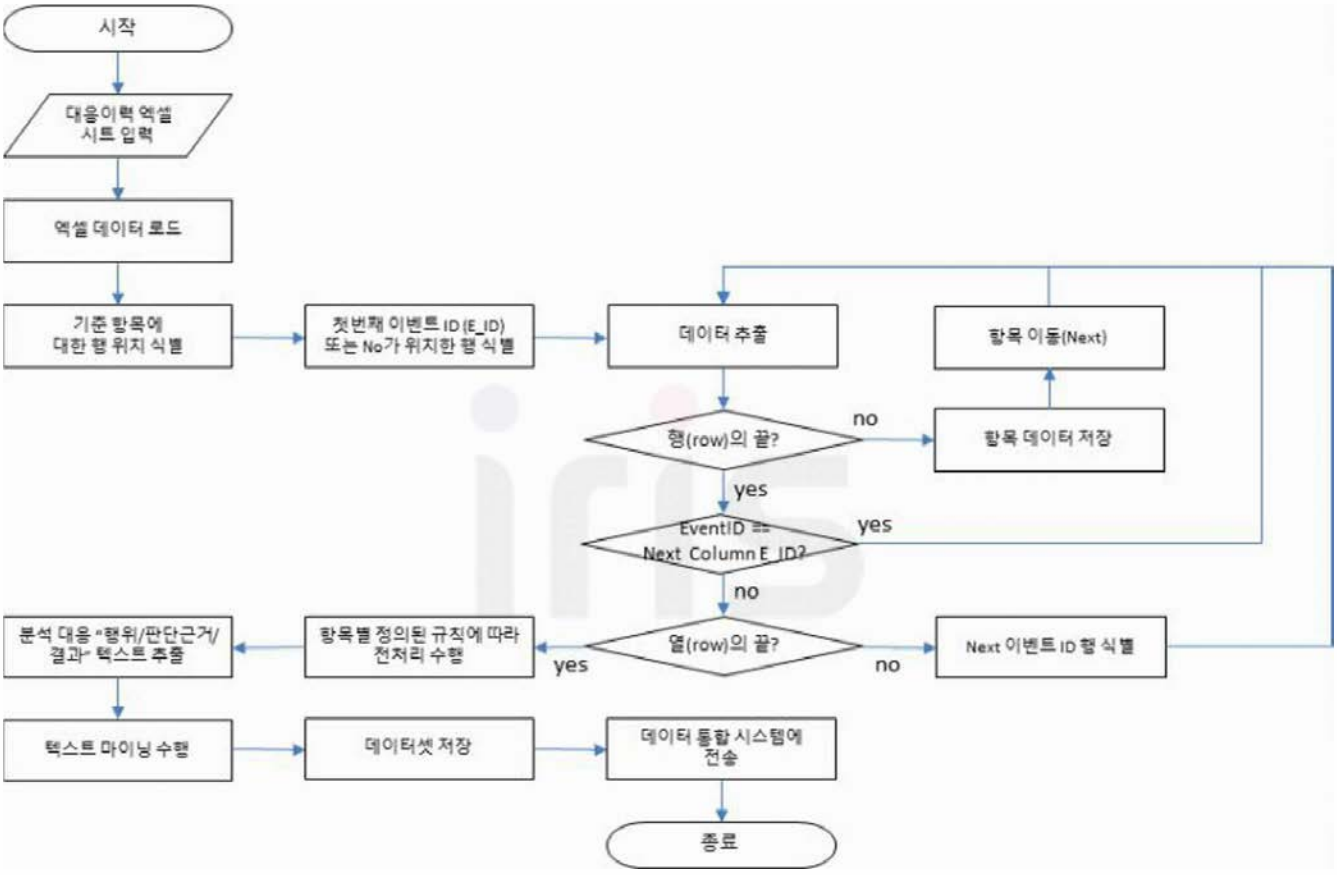
o (기능3) 데이터 전처리

- 정의된 AI 알고리즘에서 사용하는 요구사항에 맞춰 항목별 데이터 전처리 수행

※ 탐지시간 및 조치시간, 장비명, 위협·공격 유형, 공격·탐지 명, 위험도, 분류, 순서, 행위, 도구명, 분석 대상, 대응 대상, 판단 근거, 결과, 판단 데이터

o (기능4) 대응이력 학습 데이터 생성

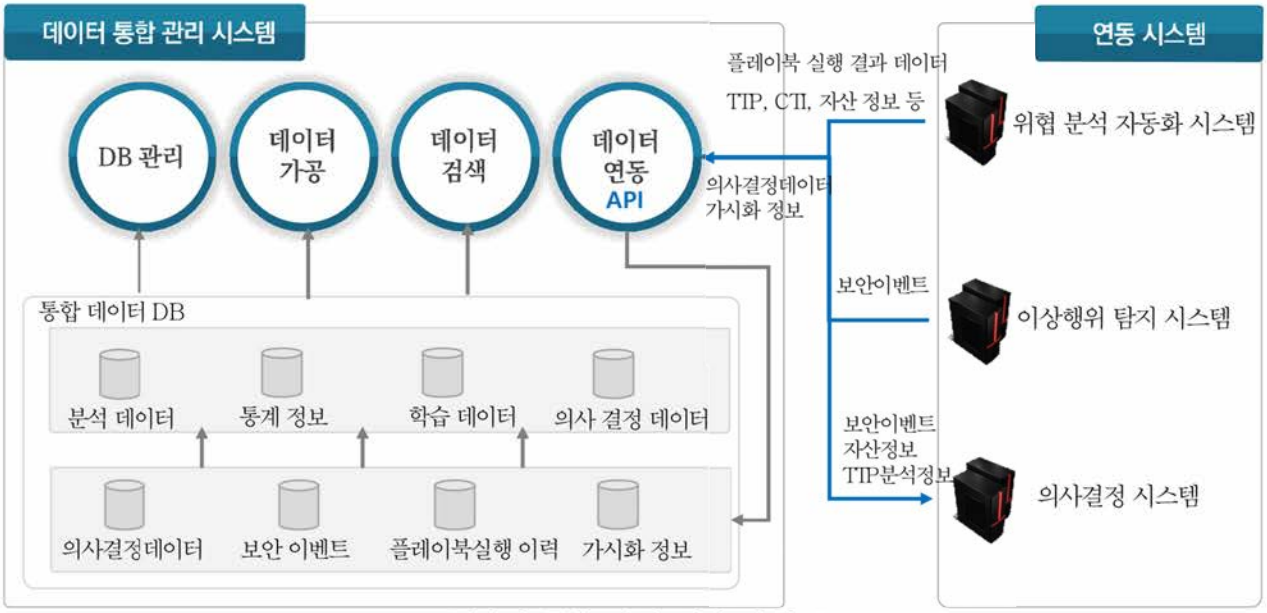
- 데이터 통합 관리 시스템에 저장할 포맷으로 학습 데이터 생성



<대응이력 수집 기능 순서도>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

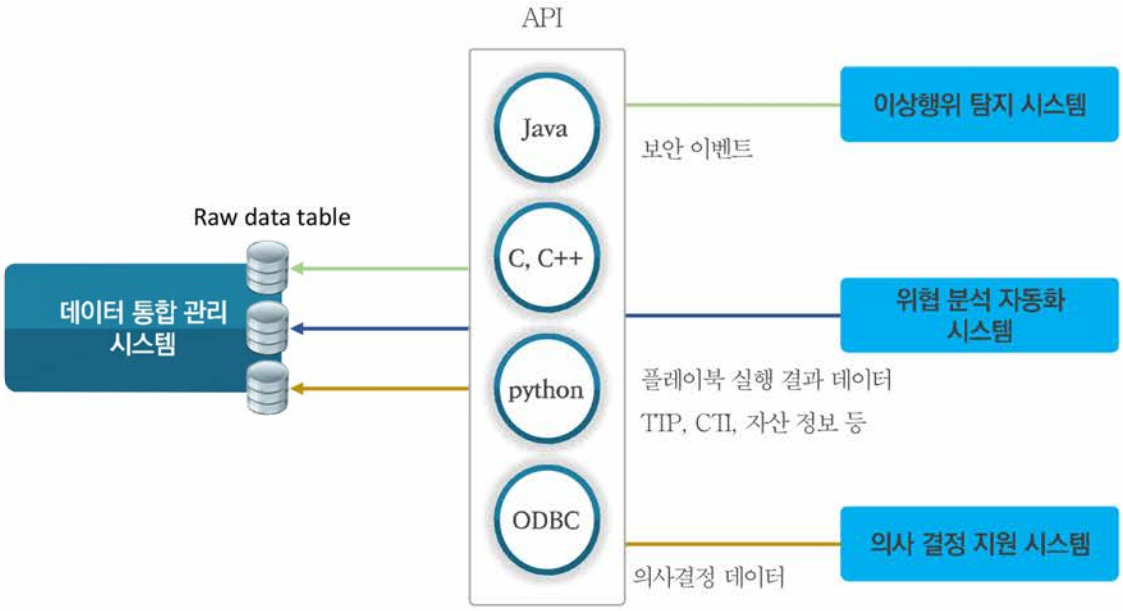
5) (추가수행) 데이터 통합 관리 기술 설계



<데이터 통합 관리 기술 개념도>

o (기능1) 데이터 수집
- 위협분석 자동화, 이상행위탐지, 의사결정지원 시스템으로부터 원천 데이터 수집

o (기능2) API 기반 데이터 연동
- API를 이용하여 외부, 내부 시스템 데이터 송/수신
- 연동 대상 시스템에 API 관련 파일과 매뉴얼, raw data table 스키마 제공
- API를 이용해 raw data table에 데이터 insert

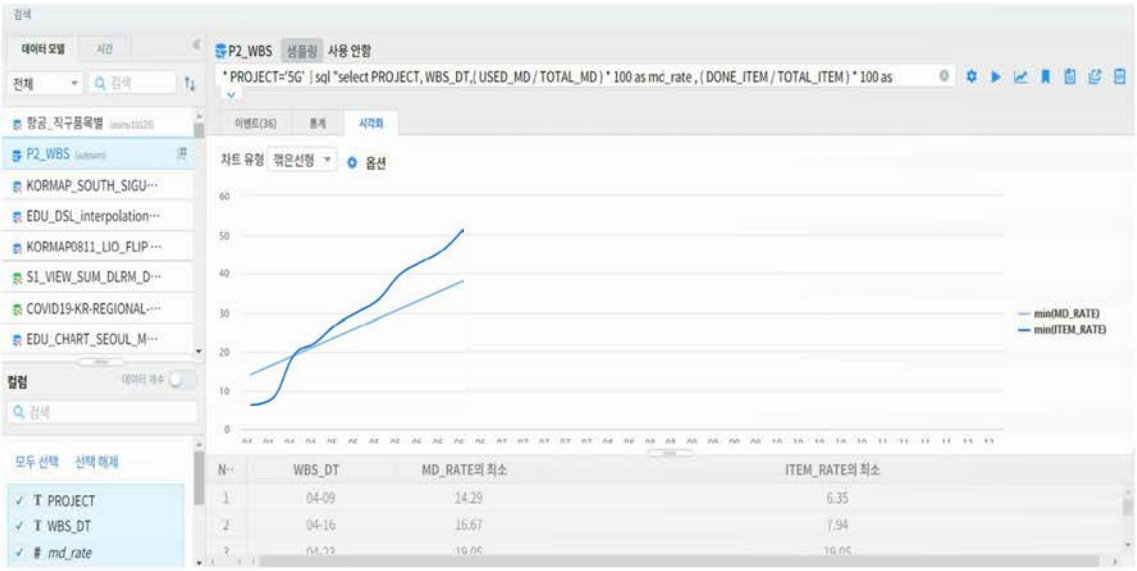


<API 구성>

o (기능3) 수집 데이터 분류, 가공
- 수집된 원천 데이터를 분류하고, AI 학습을 위해 가공

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

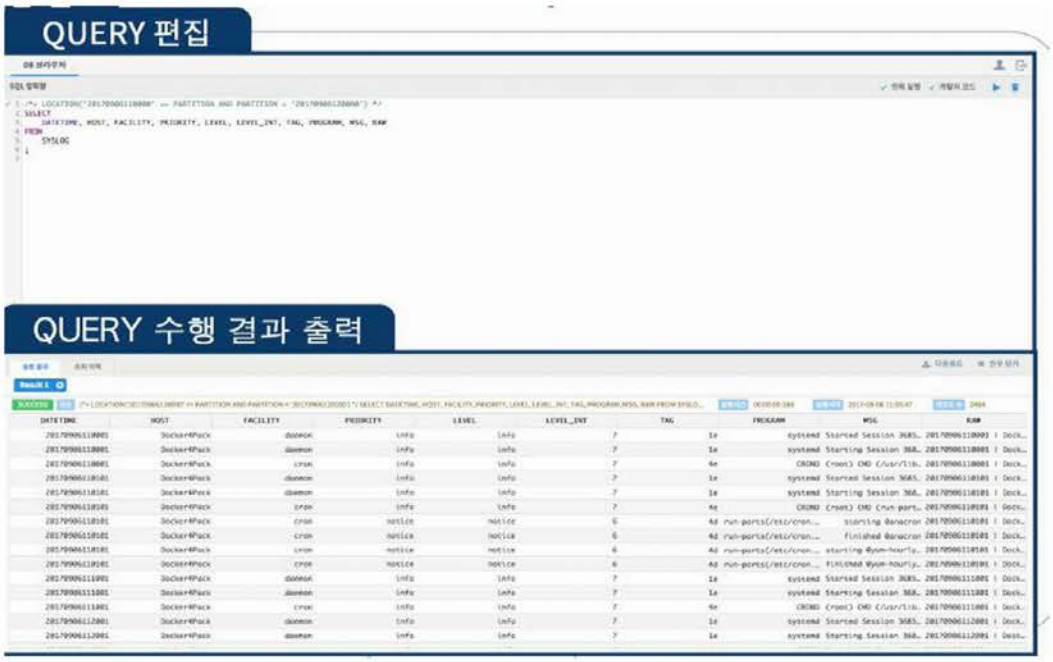
o (기능4) 데이터 검색, 수정, 삭제



<데이터 검색 및 결과 시각화 예시 화면>

- 외부에서 데이터 통합 관리 시스템에 저장된 원천, 학습 데이터를 검색, 수정 삭제
- SQL을 통한 데이터 검색 및 결과 조회

o (기능5) 통합 데이터 관리
- 효율적인 데이터 관리를 위한 테이블 생성, 삭제, 관리
- UI를 통한 테이블 생성,삭제,조회,데이터 추가,삭제,수정 (insert, delete, update)



<테이블 관리 화면 예시>

o (기능6) 데이터 통합 관리 시스템 모니터링
- 저장된 통합 데이터 현황, 자원 사용률 등 DB 시스템 관리

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

상세 추진 내용 ④ 보안사고 자동 대응 및 검증 기술

□ 개발 기술 개요

o (개발목표) 보안사고 자동 대응 및 검증 기술 연구 및 설계
  1) 이기종 보안 장비별 보안 정책(탐지・차단) 자동 생성・적용 기술 설계
  2) 이기종 보안 장비 탐지・차단 정책 실효성 검증 기술 연구

o (추진실적) 보안 위협 자동 대응 기술 연구 및 요구사항 분석
  - 보안 위협 대응 정책 생성 및 실효성 검증 기술 연구 및 설계 중 **개발목표 1, 2**

□ 보안 위협 대응 정책 생성 및 실효성 검증 기술 연구 및 설계

연구목표	이기종 보안 장비별 보안 정책 생성 및 실효성 검증 기술 연구 및 설계

세부 내용	
	1) 이기종 보안 장비별 보안 정책(탐지・차단) 자동 생성・적용 기술 설계
	2) 이기종 보안 장비 탐지・차단 정책 실효성 검증 기술 연구

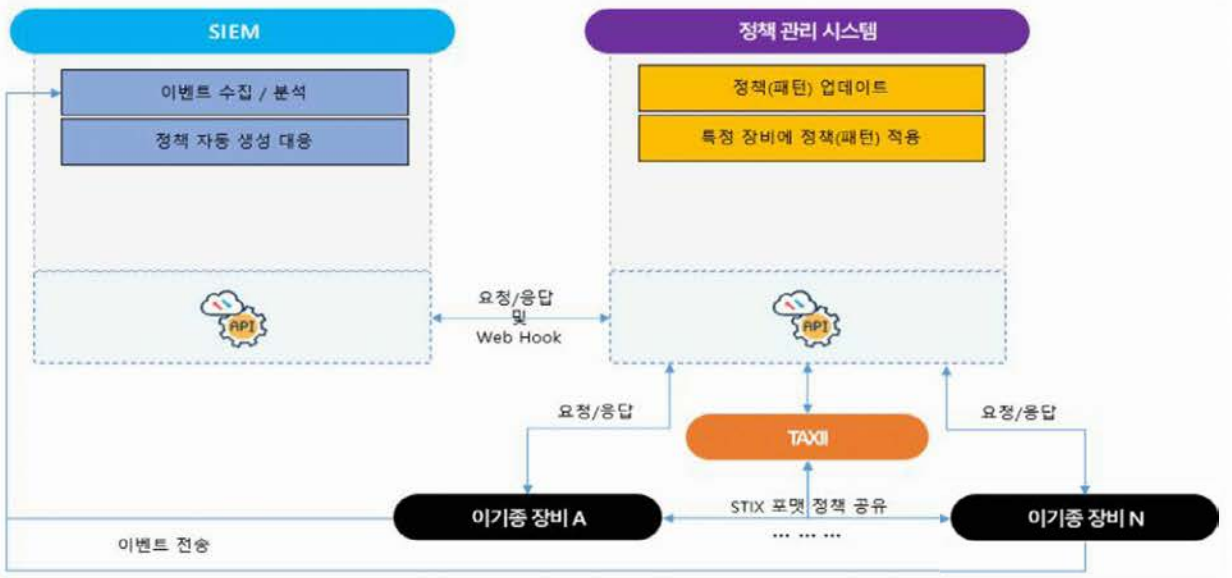
□ 보안 위협 대응 정책 생성 및 실효성 검증 기술 연구 및 설계 세부 내용

1) 이기종 보안 장비별 보안 정책(탐지・차단) 자동 생성・적용 기술 설계

o 보안장비 보안 정책 자동 적용 관련 인증 방식 연구
  - ID/PW 기반 인증 및 보안 인증키(토큰) 기반 인증 사용
    : 로그인(ID/PW) -> 안랩(FW), 라우터, 시큐아이(FW)
    : 보안 인증키(토큰) -> 안랩(FW), 파이오링크(WAF), 펜타시큐리티(WAF) 등
  - 라우터 장비는 쉘을 통한 접속을 통해 보안 정책 적용
    : 쉘 스크립트를 통해 로그인 절차를 진행하고 세션 종료하는 방식을 사용

o 보안장비 보안 정책 배포를 위한 보안 정책 관리 시스템 구성 설계
  - 보안장비 제공 정책정보 API(Restful API, STIX/TAXII)를 통한 외부 연계
  - 보안장비 센서가 외부 연계 API 기반 패킷으로 정책 관리 시스템에 정책 요청
  - 정책 관리 시스템은 인증 프로토콜로 센서에 정책 전송
  - 보안 정책 중복 적용 방지를 위해 정책 적용/해지 전 조회 프로세스를 수행

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



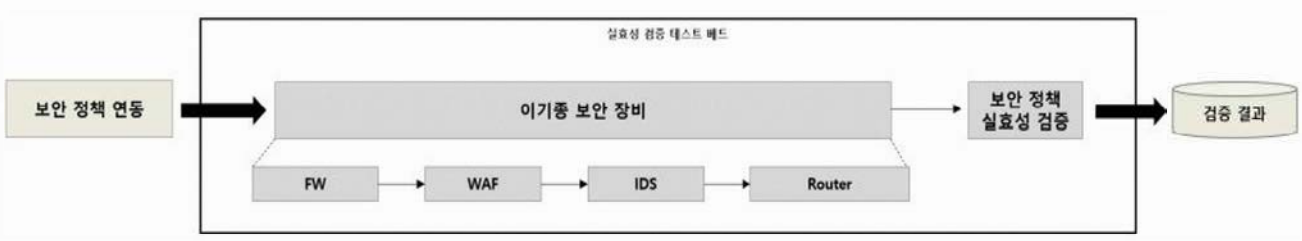
<SIEM과 정책관리시스템간의 정책 정보 공유 방안>

o 보안장비 보안 정책 생성 및 공유
- 자체 OPEN API를 이용한 자사 장비의 정책 정보 공유
  · SIEM을 통한 이기종 장비로부터 수집 분석을 통해 정책(패턴)을 자동 생성
  · SIEM에서 특정 이벤트에 대한 방어 정책 생성 시, 정책 관리 시스템에 전달하고, 자사 장비에 대해서는 pooling 방식으로 정책 배포

o 보안 정책 적용 승인 메커니즘 연구
- (사례 1) SOAR 시스템에서 선 자동차단 후 보안 담당자의 차단 정보 확인 검토
- (사례 2) 자동 차단 정책 적용 전 승인/검토/확인 컴포넌트에서 대기 후 검토 요청

2) 이기종 보안 장비 탐지·차단 정책 실효성 검증 기술 연구

o 보안 장비 정책 실효성 검증을 위한 테스트 베드 인프라 환경 구축 연구
- 보안 장비 구축을 통한 정책 자동 적용 테스트 베드 환경 마련
- 사용자 분석 기반 보안 위협 탐지·차단 정책 실효성 검증



<실효성 검증 환경 구축>

- 보안장비 보안 정책 자동 적용 및 해제 정책 관리
  · 보안 정책 적용 시 차단정보가 보안장비에 기존재한다면, 차단정책 적용 무시
  · 보안 정책 해제 시 정책 정보가 보안장비에 존재하지 않으면, 해제 적용 무시

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

2-2. 2차년도 연구 수행 내용 및 성과

□ 개발 기술 개요

o (개발목표) 보안 관제 빅데이터 연관분석 기반 이상행위 탐지 기술 개발

1) 이기종 보안 장비 데이터 수집 및 보안 정책 적용 기술 개발
2) 보안 관제 빅데이터 기반 이상행위 탐지 기술 개발 및 고도화
3) AI·빅데이터 기반 이기종 보안 장비 이상행위 탐지 성능 향상 기술 설계

o (추진실적) 보안 관제 빅데이터 연관분석 기반 이상행위 탐지 기술 개발 완료

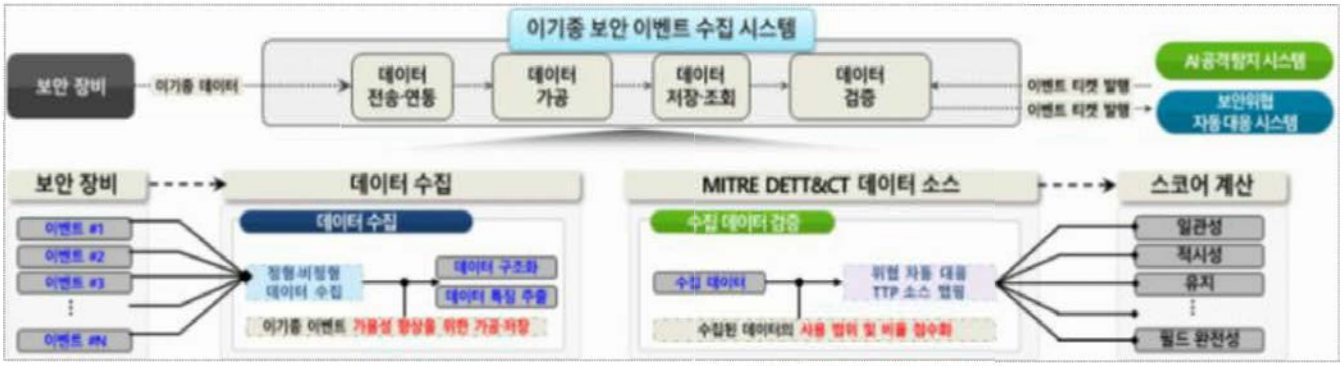
- 이기종 보안 장비 데이터 수집 및 보안 정책 적용 기술 개발 완료 **개발목표 1**
- 보안 관제 빅데이터 기반 이상행위 탐지 기술 개발 및 고도화 완료 **개발목표 2**
- AI·빅데이터 기반 이기종 보안 장비 이상행위 탐지 성능 향상 기술 설계 완료 **개발목표 3**

개발목표 ①	이기종 보안 장비 데이터 수집 및 보안 정책 적용 기술 연구

세부 내용	1) 이기종 보안 장비 정형·비정형 데이터 수집 기술 개발
	2) 이기종 보안 장비 수집 데이터 정규화 기술 개발
	3) 이기종 보안 장비별 보안 정책 적용 기술 개발

1) 이기종 보안 장비 정형·비정형 데이터 수집 기술 개발

o 이기종 보안 이벤트 수집 시스템 개요



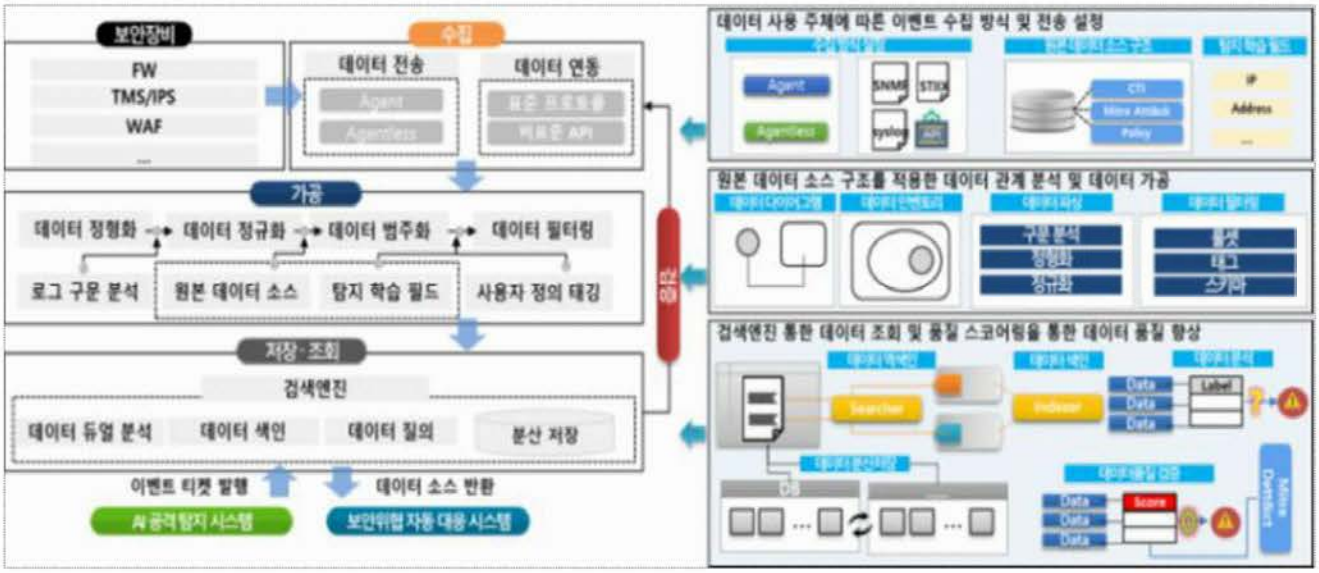
<이기종 보안 이벤트 수집 시스템 개요>

- '이기종 보안 이벤트 수집 시스템'은 관제 대상 이기종 보안 장비로부터 이기종 이벤트를 수집·가공하고, 이를 타 시스템에 제공하기 위한 이벤트 저장·조회 시스템
- 관제 대상 이기종 보안 장비로부터 수집한 데이터의 규격을 통일하고 빅데이터 분석 및 분산 저장 후 이벤트 티켓 발행 형태로 실시간 검색·조회
- 실증처로부터 수집한 데이터셋은 End-point 수집·분석 등 보안 이벤트 다양성의 고도화를 위해 활용
- 관제 대상 이기종 보안 장비로 부터 데이터를 수집하여, 데이터를 가공 및 상관 분석 후 분산 DB에 저장

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- 이후 AI 기반 위협 탐지 및 위협 분석 자동화 시스템 등간의 정의된 이벤트 티켓룰에 따라 티켓을 발행하는 조회 시스템을 수행

o 이기종 보안 이벤트 수집 시스템 목표 구성



<이기종 보안 이벤트 수집 시스템 상위 구조>

- 이기종 보안 이벤트 수집 시스템 단계별 동작
  ① Agent / Agentless 방식을 통해 표준 프로토콜 및 비표준 API을 이용하여 보안 관제 대상 장비로 부터 보안 이벤트를 수집
  ② Grok 로그 구문 분석을 통해 데이터 구조를 정형화하고, 공통 필드(예: 도착지 IP ⇔ s_ip 로 표기 통일 등)를 통해 데이터를 정규화
  ③ 유형별 (①장비 ②공격유형(대・중・소) ③ TTP 정보 (MITRE 社 Attacker Tactics) 이벤트를 분류하고, TTP (MITRE 社) 정보 기반 공격 유형 ID를 부여
  ④ 관제원이 설정한 이벤트 정책, 관제룰에 의해 필요한 이벤트를 추출(필터링)하여 키: 데이터 형태(색인)로 분산 저장
  ⑤ 이벤트 듀얼 분석(단일 이벤트, 다중 이벤트 상관 분석)을 통해 이벤트 티켓을 발행하며, In-Memory 형태의 실시간 처리와 주기를 가지는 시간 단위 수준의 일괄 처리인 배치 처리를 수행
  ⑥ AI 공격 탐지 시스템 및 위협 분석 자동화 시스템은 필요 데이터를 조회
  ⑦ 인덱서/역인덱서 처리를 통해 검색 결과 반환 후 상위 해당 시스템이 활용
  ⑧ 탐지이벤트와 TTP 맵핑을 통한 MITRE DeTT&CT 기술에 따라, 수집 데이터를 가시적으로 확인하고 관제원은 수집률을 판단하여 수집 방식(범위 및 기간, 개수 등) 조정(추가 및 삭제) 수행

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

2) 이기종 보안 장비 수집 데이터 정규화 기술 개발

o 이기종 보안 이벤트 정규화

- 룰 패턴에 따라 데이터의 종속 의미를 가지는 공통 집합으로 분류하고 필드명 통일 기능 개발
- Grok 로그 구문 분석을 통해 데이터 구조를 **정형화**하고, 공통 필드(예: 도착지 IP ⇔ s_ip 로 표기 통일 등)를 통해 데이터 **정규화**
- 다양한 보안장비들과 서버 등 수많은 연동대상으로부터 수집한 로그 중에서 원하는 데이터를 일관되고 유연하게 찾고, 상관분석 시 동일 필드 승계를 위해 수행
- 공통 스키마 정의 순서는 ① 보안 로그 필드 요소 추출 → ② 필드 병합 → ③ 로그 데이터 테이블 생성 → ④ 공통 필드 정의 순으로 수행

STEP 1) 각 장비별, 대상별 보안 로그 필드 병합 요소를 추출하여 종합

STEP 2) 상위 단계의 필드에서 동일한 의미를 가지는 필드를 하나의 그룹으로 병합

〈로그 병합 필드〉

시스템	필드 병합 요소
FW 로그	Sensor IP, Time, Source IP, Destination IP, Destination Port, Protocol, Direction, Action (Accept/Deny) 등
IDS 로그	Sensor IP, Time, Source IP, Destination IP, Destination Port, Protocol, Direction, Signature 등
WEB 로그	Sensor IP, Time, Source IP, Destination IP, Destination Port, Protocol, Method (GET/POST), URL, Result Code 등

STEP 3) 로그 데이터가 동일하게 가지는 대분류 테이블 구조를 하위 5개 그룹(이벤트 정보, 장비 정보, 출발지 정보, 목적지 정보, 세부 정보)으로 분류

〈로그 데이터 테이블 구조 (예시)〉

로그 데이터 테이블 구조

이벤트 정보
Sequence
Category
Event time
...
count
accidentType
attackType
RuleID

장비 정보
sequence
...
sensor id

출발지 정보
sequence
...
source addr
source port

목적지 정보
sequence
...
destination addr
destination port

세부 정보
sequence
logging time
...
protocol
User id
method
status
size
msg

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

STEP 4) 상위 단계의 필드에서 동일한 의미를 가지는 필드를 정의된 공통 필드명으로 지정

※ 데이터 공통 필드 **※ 공격 유형, 관제원의 판단, 공격 방향 등에 따라 달라질 수 있음**

※ 데이터 타입이 정수일 경우, 필드 설명에 매핑 된 **정수 값**으로 표기

<공통 필드>

<table>
<tr><th>No</th><th>필드명</th><th>데이터 타입</th><th>필드설명</th></tr>
<tr><td>1</td><td>accidentType</td><td>숫자</td><td>국정원에서 지정한 사고의 유형 7가지이며, 실제 시스템에서 어떤 피해가 발생했느냐 정도, 해당 값은 보안 관제 요원 지정
같은 보안 이벤트라 할지라도 공격유형(원인), 공격방향, 관제원의 판단에 따라 다른 값들을 가질 수 있음.
ex) flooding attack (공격 원인)
→ 대상기관 (발생) : 웜 바이러스
→ 대상기관 (피해) : 서비스 거부
<table>
<tr><th>값</th><th>명칭</th><th>설명</th></tr>
<tr><td>0</td><td>지정안함</td><td>-</td></tr>
<tr><td>1</td><td>웜바이러스 피해</td><td>기관내의 PC에서 웜바이러스가 발견되었을 경우</td></tr>
<tr><td>2</td><td>자료훼손 및 유출</td><td>내부 시스템의 자료가 변조되었거나, 대량의 데이터가 외부로 무단송신 된 흔적이 발견되었을 경우</td></tr>
<tr><td>3</td><td>경유지 악용</td><td>타기관으로부터 해킹시도 항의를 받았거나, 시스템 점검 중 해킹흔적 또는 해킹툴이 설치되어 타시스템에 접속한 기록이 발견되었을 경우</td></tr>
<tr><td>4</td><td>홈페이지 변조</td><td>기관의 홈페이지 서버 또는 네트워크 이상으로 인해 홈페이지 접속이 불가능 할 경우</td></tr>
<tr><td>5</td><td>서비스거부 공격 피해</td><td>불특정 다수의 IP로부터 접속시도 또는 대량 트래픽이 일시에 유입될 경우</td></tr>
<tr><td>6</td><td>단순침입시도</td><td>지속적인 스캐닝 공격이 발생할 경우</td></tr>
<tr><td>7</td><td>기타</td><td>위 사고유형에 포함되지 않을 경우</td></tr>
</table></td></tr>
<tr><td>2</td><td>analy.result</td><td>숫자</td><td>SIEM에서 분석한 분석결과(label)
1 : 정탐 2 : 오탐 3 : 분석필요 4 : 미분석</td></tr>
<tr><td>3</td><td>attack.type</td><td>숫자</td><td>어떠한 원인으로 발생한 공격인지를 보안관제요원의 판단에 따라 지정한 값
0: 기타 및 미지정 1 : 네트워크 침입 2 : 비인가 접근 3 : 서비스 거부 4 : 악성 코드 5 : 웹 해킹 6: 유해 IP 7: 정보수집 8: 해킹메일 9: 홈페이지 위변조</td></tr>
<tr><td>4</td><td>time.stamp</td><td>문자열</td><td>수집 일시 (탐지 시간)</td></tr>
<tr><td>5</td><td>device.type</td><td>숫자</td><td>장비 분류 코드
<table>
<tr><td>1: FireWall</td><td>2: UTM</td></tr>
<tr><td>3: IPS</td><td>4: DDX</td></tr>
<tr><td>5: WAF</td><td>6: APT</td></tr>
<tr><td>7: Log</td><td>8: 기타</td></tr>
</table></td></tr>
<tr><td>6</td><td>sensor.id</td><td>문자열</td><td>이벤트 수집(연동) 장비 ID</td></tr>
<tr><td>7</td><td>device.name</td><td>문자열</td><td>보안(탐지) 장비 이름, 제품명</td></tr>
<tr><td>8</td><td>log.type</td><td>문자열</td><td>로그 구분 (네트워크 프로토콜 통신 계층)
로그를 수신할 때 사용하는 프로토콜 정보(syslog , SNMP)</td></tr>
<tr><td>9</td><td>s.ip</td><td>숫자</td><td>공격자(출발지)의 IP</td></tr>
<tr><td>10</td><td>s.port</td><td>숫자</td><td>공격자(출발지)의 Port</td></tr>
<tr><td>11</td><td>stdr.port</td><td>숫자</td><td>공격의 원인이 되는 Port
보안관제 요원의 판단에 의해 명시되는 필드로 보통은 Well-Known port를 기준으로 삼거나 대상기관쪽 port를 지정</td></tr>
</table>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

<table>
<tr><td>12</td><td>d.ip</td><td>문자열</td><td>희생자(도착지)의 IP</td></tr>
<tr><td>13</td><td>d.port</td><td>숫자</td><td>희생자(도착지)의 Port</td></tr>
<tr><td>14</td><td>action</td><td>숫자</td><td>보안공격 대응 (detect/block) 패킷 처리 상태 값
0: 미분류 1: Allow 2: Denied 3: Expire 4: alarm 5: defense</td></tr>
<tr><td>15</td><td>policy</td><td>문자열</td><td>이벤트 처리를 위한 정책명</td></tr>
<tr><td>16</td><td>s.country</td><td>문자열</td><td>공격자(출발지)의 IP 국가</td></tr>
<tr><td>17</td><td>d.country</td><td>문자열</td><td>희생자(도착지)의 IP의 국가</td></tr>
<tr><td>18</td><td>in.out</td><td>문자열</td><td>보안관제 대상기관을 중심으로 공격 방향 결정 (10가지 구분)
(0 : inboud, 1: DMZ, 2: outbound) 통신방향
1: 내부 → 내부 : in(00) | 6: 외부 → DMZ : in(21)
2: 내부 → 외부 : out(02) | 7: DMZ → 내부 : in(10)
3: 내부 → DMZ : out(01) | 8: DMZ → 외부 : out(12)
4: 외부 → 내부 : in(20) | 9: DMZ → DMZ : in(11)
5: 외부 → 외부 : out(22) | 0: 알 수 없음</td></tr>
<tr><td>19</td><td>risk</td><td>숫자</td><td>제품에서 정의하는 위험도
0: 정보, 1: 높음, 2: 중간, 3: 낮음</td></tr>
<tr><td>20</td><td>pkt.size</td><td>숫자</td><td>요청 패킷 크기 (byte) (null 값은 0으로 치환)</td></tr>
<tr><td>21</td><td>payload</td><td rowspan="2">문자열</td><td>이벤트를 발생시킨 원인이 되는 데이터
헤더를 포함한 HEX 페이로드</td></tr>
<tr><td>22</td><td>dec.payload</td><td>헤더가 제외, ASCII로 표현된 페이로드</td></tr>
<tr><td>23</td><td>duration</td><td>문자열</td><td>접속 유지 시간</td></tr>
<tr><td>24</td><td>event.count</td><td>숫자</td><td>시도 이벤트 개수 (총합)</td></tr>
<tr><td>25</td><td>atdate</td><td>문자열</td><td>DB에 데이터가 입력된 시간</td></tr>
<tr><td>26</td><td>auto.email</td><td>숫자</td><td>자동으로 메일을 발송할 것인지 결정하는 플래그
0: 발송안함 1: 발송함</td></tr>
<tr><td>27</td><td>auto.vfy.</td><td>숫자</td><td>보안이벤트의 자동처리 및 검증을 수행했는지 체크하는 플래그
0: 검증 안함 1: 검증 함</td></tr>
<tr><td>28</td><td>agg.count</td><td>문자열</td><td>축약 시 합쳐진 보안이벤트의 개수</td></tr>
<tr><td>29</td><td>hit.count</td><td>문자열</td><td>관제룰 적용으로 세어진 보안이벤트 개수</td></tr>
<tr><td>30</td><td>event.type</td><td>숫자</td><td>이벤트 유형
<table>
<tr><th>값</th><th>명칭</th><th>설명</th></tr>
<tr><td>1</td><td>scanning</td><td>하나의 IP에서 짧은 시간동안 여러 IP 또는 Port에 패킷을 보낸 보안이벤트</td></tr>
<tr><td>2</td><td>flooding</td><td>하나의 IP로 짧은 시간동안 다량의 패킷을 보낸 보안이벤트</td></tr>
<tr><td>3</td><td>signature</td><td>특정 RegExp와 일치하여 탐지된 보안이벤트</td></tr>
<tr><td>4</td><td>Threshold</td><td>임계치 기반 탐지된 보안이벤트</td></tr>
</table></td></tr>
<tr><td>31</td><td>j.payload</td><td>숫자</td><td>포함된 페이로드가 점보페이로드인지 확인하는 플래그
0: 일반 1:점보</td></tr>
<tr><td>32</td><td>meta.type</td><td>문자열</td><td>MITRE에서 분류한 공격 전략, 공격 유형과 매칭
<table>
<tr><th>ID</th><th>명칭</th><th>설명</th></tr>
<tr><td>TA0001</td><td>Intial access</td><td>네트워크 침입</td></tr>
<tr><td>TA0002</td><td>Execution</td><td>악성코드 실행</td></tr>
<tr><td>TA0003</td><td>Persistence</td><td>공격 실행을 위한 기반 획득 시도</td></tr>
<tr><td>TA0004</td><td>Privilege Escalation</td><td>상위 권한을 획득 하려는 시도</td></tr>
<tr><td>TA0005</td><td>Defense Evasion</td><td>탐지되는 것을 회피하려는 시도</td></tr>
<tr><td>TA0006</td><td>Credential Access</td><td>계정 이름과 암호를 훔치려는 시도</td></tr>
<tr><td>TA0007</td><td>Discovery</td><td>희생자의 환경을 파악 하려는 시도</td></tr>
<tr><td>TA0008</td><td>Lateral movement</td><td>공격을 위한 거점 기반 마련 시도</td></tr>
<tr><td>TA0009</td><td>Collection</td><td>공격을 위한 관련 데이터를 수집 시도</td></tr>
<tr><td>TA0010</td><td>Command and Control</td><td>손상된 시스템을 통한 환경 통제 시도</td></tr>
<tr><td>TA0011</td><td>Exhilaration</td><td>데이터 유출 시도</td></tr>
<tr><td>TA0012</td><td>Impact</td><td>시스템과 데이터 조작, 중단, 파괴 시도</td></tr>
<tr><td>TA0013</td><td>Resource-Development</td><td>공격을 수행하는데 이용할 수 있는 자원 구축 시도</td></tr>
<tr><td>TA0014</td><td>Reconnaissance</td><td>향후 작전을 계획하는 데 사용할 수 있</td></tr>
</table></td></tr>
</table>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

			는 정보를 수집 시도
33	org.idx	문자열	대상기관 인덱스
34	protocol	숫자	패킷 전송에 사용된 프로토콜 (ICMP:01, TCP:06, UDP:17)
35	status	문자열	현재 보안이벤트 처리 현황 0: 미진행 1: 진행: 티켓 발급
36	update	문자열	DB가 업데이트된 시간
37	group.id	문자열	Tenant ID (Device와 IP Pool Group 정보를 쌍으로 묶어서 관리)
38	ckc	숫자	사이버 킬 체인 정보 (매핑 된 정수 값으로 표기) 0: unknown / 1: Reconnaissance 2: Weaponization / 3: Delivery 4: Exploitation / 5: Installation 6: Command & Control / 7: Attack on Objectives
39	s.time	타임스탬프	탐지 시작 시간 타임스탬프(이벤트를 보낸 연동장비 기준), 없을 시 0
40	e.time	타임스탬프	탐지 종료 시간(이벤트 시간), 없을 시 0
41	log.sip	숫자	로그 소스 IP
42	signature	문자열	탐지룰셋 명
43	highlight	숫자	위험도 level 0~10
44	category	숫자	카테고리 대분류 (공격 대상 기준)
45	minor	숫자	카테고리 소분류 (대분류에 따라 의미 다름)
46	flag	숫자	0 고정 (미사용)
47	msg	문자열	수신한 로그에서 추가 정보를 표기하기 위한 목적
48	pool.id	숫자	IP 대역 관리 ID
49	pool_gid	숫자	IP Pool이 속한 IP Pool Group의 ID (IP Pool 을 묶어서 관리하는 목적)
50	cve.code	숫자	CVE값을 표기 (Maria DB의 mapping table을 참고하여 값을 표현)
51	data.type	숫자	데이터 유형을 표현 0: Event 1:FWall
52	is.profile	숫자	프로파일 사용 여부 0 = 미사용, 1 <= 프로파일 정책에 매칭된 로그 개수 (profile_log_id_list에 is_profile 개수만큼 id가 들어감)
53	profile.list	문자열 리스트	프로파일 ID 들을 리스트로 담고 있음 (이때의 ID는 각 데이터리소스의 ID값을 사용함)
54	profile.id	숫자	프로파일 정책 ID (이때의 ID는 각 프로시지의 ID값을 사용함)
55	profile.name	문자열	프로파일명
56	ai.flg	숫자	AI 분석 필요 여부 (0 = 불필요, 1 <= AI 분석 필요)
57	ip.type	숫자	ipv4: 4, ipv6: 6 가중치: deviceIp (1), srcIp(2), dstIp(4)
58	opt0	문자열	APTX에서 분석한 악성파일 유형
59	opt1	문자열	APTX에서 분석한 악성파일의 점수
60	opt2	문자열	탐지 이벤트의 Raw 데이터
61	opt3	문자열	송신자의 IP 평판 정보
62	opt4	문자열	목적지 IP의 평판 정보
63	opt5	문자열	서비스 매칭 결과(src_port) 및 어플리케이션 정보,reserve
64	opt6	문자열	서비스 매칭 결과(dst_port) 및 어플리케이션 정보,reserve
65	opt7	문자열	reserved
66	opt8	문자열	reserved
67	opt9	문자열	reserved
68	opt10	문자열	reserved
69	host.name	문자열	호스트 이름

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

70	logging.time	문자열	로깅시간 (로그 기록 탐지 시작부터 종료까지의 시간)
71	urlhost	문자열	서비스를 요청하는 값
72	urlpath	문자열	서비스를 요청하기 이전의 유입 경로
73	payload.len	숫자	페이로드 길이
74	pro.name	문자열	프로세스 이름
75	device.ver	문자열	보안 장비 버전
76	policy.num	숫자	정책 번호
77	app.ver	문자열	앱 버전
78	enc	문자열	암호화 알고리즘
79	rx.Inf	문자열	Rx (수신자 방향) 인터페이스
80	tx.Inf	문자열	Tx (송신자 방향) 인터페이스
81	tcp.f	숫자	TCP 플래그
82	method	문자열	요청 형식
83	http.status	문자열	요청에 대한 응답 값
84	client	문자열	user-agent를 담은 부분
85	query	문자열	실제 요청을 하는 파라미터 값
86	payload.f	문자열	payload 기반 이벤트 플래그
87	log.name	문자열	로그 소스 이름

- 개발 수행 결과는 다음과 같으며, 해당 개발은 **원격 개발 서버의 CLI로 개발 수행**
  ① 보안 로그 수집 adaptor, ② 정규화 파서 실행 ③ 웹 페이지 UI를 통한 확인

Step 1. 보안 로그 수집 adaptor를 통한 로그 수집 기능 활성화 수행

Step 2. 원본로그 (실증데이터*) CSV 형태로 개발 서버에 업로드 하여, 자동 수집

※ 원격관제기관(2곳) 보안장비(7종)의 원본로그를 수집하여, 샘플 추출에 따라 공통 필드를 재정의

```
1 연구용 SOAR
[kisa@localhost ~]$ cat /CloudESM/app/agent/conf/initial_adaptors
add SystemMornitor SMS_LOG 60 0

add DataDeleteAdaptor SECURITY_LOG /CloudESM/data/processing/RE_SEND_DATA .DAT 500 60 0

add DataResenderAdaptor SECURITY_LOG /CloudESM/data/processing/RE_SEND_DATA .DAT 0 0

add WtmpAdaptor SYSTEM_LOG last[\s]-100 01 60 0
add DirFileSleepAdaptor SECURITY_LOG /CloudESM/data/processing/eqp_log done 10000 500 0
add DirFileSleepAdaptor SECURITY_LOG /CloudESM/data/processing/kisa done 10000 500 0
```

<원본로그 수집 adaptor 실행>

Step 3. 정규화 파서를 통한 (표 8)에 따른 공통 필드를 적용

```
[kisa@localhost ~]$ cat /CloudESM/app/generator/sample/E_2010031516002
#######################################################################
# Tag Example
#######################################################################
# - [[@src_ip]] : Source IP(It is created using the asset.ip.range and external.ip.range configuration va
lues.)
# - [[@src_port]] : Source Port(It is created using the famous.dstn.port setting value.)
# - [[@dstn_ip]] : Destination IP(It is created using the asset.ip.range and external.ip.range configurat
ion values.)
# - [[@dstn_port]] : Destination Port(It is created using the famous.dstn.port setting value.)
# - [[@eqp_dt(yyyy-MM-dd HH:mm:ss)]] : Format Time. ex> yyyyMMddHHmmss, yyyy/MM/dd HH:mm:ss
# - [[@eqp_dt(unix_timestamp)]] : Unix Time
# - [[@random(500000,600000)]] : Random Number
# - [[@select(Y|N|...)]] : It is generated by randomly selecting among the strings inputted as delimiters
. Separator is pipe(|).
#######################################################################
0|53018000|[[@eqp_dt(yyyyMMddHHmmss)]]|[[@eqp_dt(yyyyMMddHHmmss)]]|[[@eqp_dt(yyyyMMddHHmmss)]]|192.168.1.
22|2|[[@src_ip]]|0|UDP|[[@dstn_ip]]|80|0|0|0|HTTP_Unknown_Protocol|||1|0|0||||
0|53018000|[[@eqp_dt(yyyyMMddHHmmss)]]|[[@eqp_dt(yyyyMMddHHmmss)]]|[[@eqp_dt(yyyyMMddHHmmss)]]|192.168.1.
22|2|[[@src_ip]]|0|UDP|[[@dstn_ip]]|52454|0|0|0|TCP_Invalid_SACK|||1|0|0||||
<12>stime:20220810003136,etime:20220810003144,group:65535,object:65535,devicecode:2038,ipversion:4,srcip:
1.1.1.1,dstip:2.2.2.2,srcport:443,dstrport:50001,protocol:17,categoryid:00001,signatureid:0000100001,sign
aturename:event001,direction:32,detectcnt:1,trycnt:49,datasize:10927,pktsize:223,bps:10927,pps:6,risk:1,a
larm:0,defense:N,attinfo:,srccountry:US,dstcountry:ZZ
```

<원본로그 정규화 수행>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

Step 4. WEB UI를 통해 이기종 보안 이벤트 수집 이력을 확인하고, 필드 및 장비에 따라 정규화 결과를 재정렬하여 조회

<이기종 보안 이벤트 수집 로그 검색>

<필드 및 장비별 이벤트 확인>

Step 5. 원본 로그의 오른쪽 하단 화살표를 클릭하여, 정규화 결과와 해당 정규화 수행 상세 결과를 조회

<정규화 결과 확인>

o 이기종 보안 이벤트 연동 API 개발

- 이기종 보안 장비 이벤트 로그 송수신 모듈 개발

```
openssl req -nodes -newkey rsa:2048 -keyout key.pem -out cert.csr -subj
"/C=KR/ST=Seoul/L=Seoul/O=SetSecurity/OU=Security/CN=openapi"
sleep 1
openssl req -x509 -key key.pem -in cert.csr -out cert.pem -days 365
sleep 1
rm -rf cert.csr
```

<연동 API 서버 내 SSL 인증서 생성>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

```
ssl_context = ssl .SSLContext (ssl .PROTOCOL_TLS )
    ssl_context    .load_cert_chain    (certfile    ="pem/cert.pem",keyfile
="pem/key.pem")
  app .run (host='0.0.0.0',port=5000,ssl_context=ssl_context )
```

<API 서버 HTTPS 적용>

```
oad_root_certificates (*ctx );
  std ::ifstream ifs (path );
  std ::stringstream ss ;
  ss << ifs .rdbuf ();
  std ::string cert (ss .str ());
  boost ::system ::error_code ec ;
  (*ctx ).add_certificate_authority (boost ::asio ::buffer (cert .data
(), cert .size ()), ec );
  if (ec )return false ;
```

<모듈(클라이언트) SSL Clients를 통해 호출>

- Condition문을 통한 송수신 스케줄링 기법 구현

```
std ::mutex mutex ;
  std ::unique_lock <std ::mutex >lock (mutex );
  std ::condition_variable condition ;
  while (condition .wait_for (lock , std ::chrono ::seconds (10))== sto
::cv_status ::timeout ){ /* TO DO */ }
```

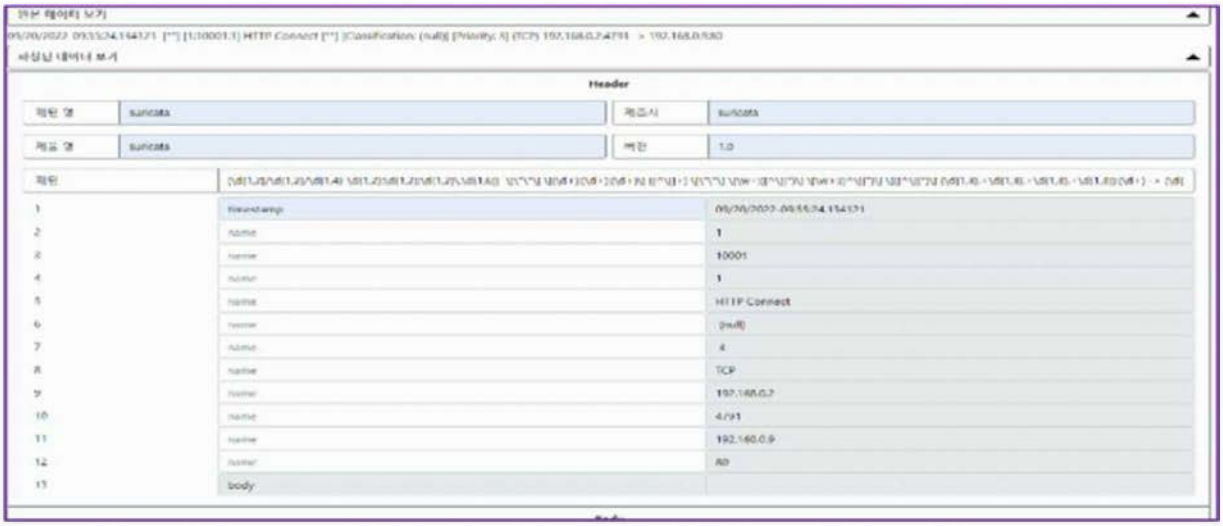
<모듈 내 송수신 주기 10초 설정 화면>

- API를 통해 들어온 이기종 보안 장비 로그 정규화 기능 개발

※ 다음과 같은 3가지 룰 기반으로 정규화 진행

1. IP 형식이 .(dot)이 아닐 경우 변환
2. ISO 시간 포맷이 아닌 경우 변환
3. 필드 맨 종결문자를 하이픈(-) 삽입

· 데이터 포맷 파악이 불가능 할 경우 정규표현식 기반 사용자 정의를 통해 정규화 시도



< 정규 표현식을 이용한 사용자 정의 예시 >

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- API를 통해 정규화가 진행된 보안 장비 로그 STIX 및 SYSLOG 형태 변환 기능 개발

<STIX 형태 변환 기능 개발>

<SYSLOG 형태 변환 기능 개발>

3) 이기종 보안 장비별 보안 정책 적용 기술 개발

o 보안 정책 적용을 위한 REST API 및 ConsoleAPI Interface 설계 및 개발

- 이기종 보안 장비 벤더사의 REST API 명세서를 입력 받아 보안 정책을 적용하는 Interface 개발
- SSH접속 등 Console API 접속 방법 및 Console API(명령어)를 실행시켜 보안 정책을 적용하는 Interface 개발
- 이기종 보안 장비 벤더사 REST API 및 Console API 명세서 등록을 위한 템플릿 설계 및 개발

<벤더사 REST API 명세서 등록을 위한 Interface 템플릿 예시>

API Name	URL	METHOD	Header Parameter	Body Parameter	Cookie Parameter
example-login	http://www.example.com/api/v1/login	POST		{“user“:“admin“,“password“:“12345“}	
example-rule	http://www.example.com/api/v1/vendor/api	POST	{“X-CSRF-TOKEN“:csrf_access_token}		{“access_token_cookie“:access_token_cookie}

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

<벤더사 Console API 명세서 등록을 위한 Interface 템플릿 예시>

Vendor_Name	Name	Required	Value
example-A	--type	Yes	rest
	--mode	Yes	run
	--api_name	Yes	ip_block_api
	--paran	No	
example-B	--type	Yes	Console
	--mode	Yes	on
	--api_name	Yes	alert_api
	--paran	Yes	101

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

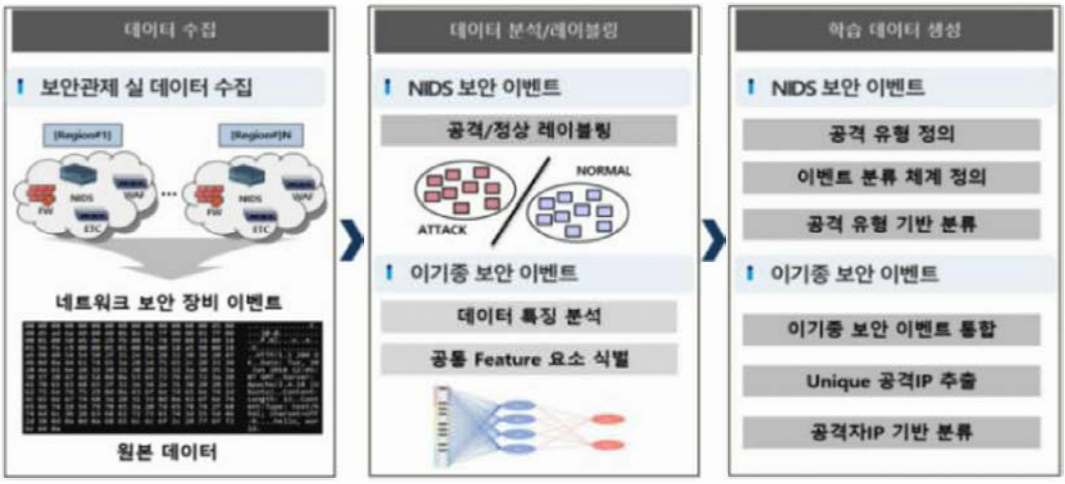
개발목표 ②	보안 관제 빅데이터 기반 이상행위 탐지 기술 개발 및 고도화

세부 내용	1) 특성 가공 정보의 머신러닝 기반 정형·비정형 보안 위협 데이터 간 연관성 분석 기술 개발
	2) 딥러닝 기반 자연어처리 모델과 유사도 분석을 통한 보안장비 이벤트 이상행위 탐지 기술 고도화

<AI 기반 이상행위 탐지 시스템 아키텍처>

1) 특성 가공 정보의 머신러닝 기반 정형·비정형 보안위협 데이터 간 연관성 분석 기술 개발

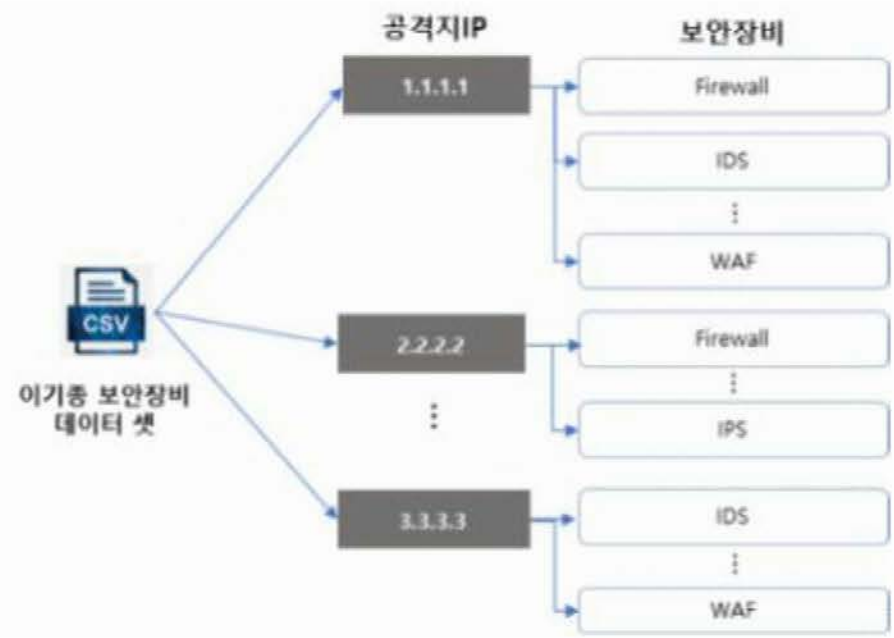
o 관제센터를 통한 실 환경 이기종 보안 이벤트 데이터 수집 및 레이블링
- (데이터 수집) 정형・비정형 이기종 보안 장비(5개)의 총 이벤트 1억10만건 수집
- (데이터분석/레이블링) 지도 학습을 위한 공격/정상 이벤트 레이블링
- (학습 데이터 생성) IDS 및 이기종 보안 이벤트 기반 학습 데이터셋 생성



<데이터 수집 분석 절차>

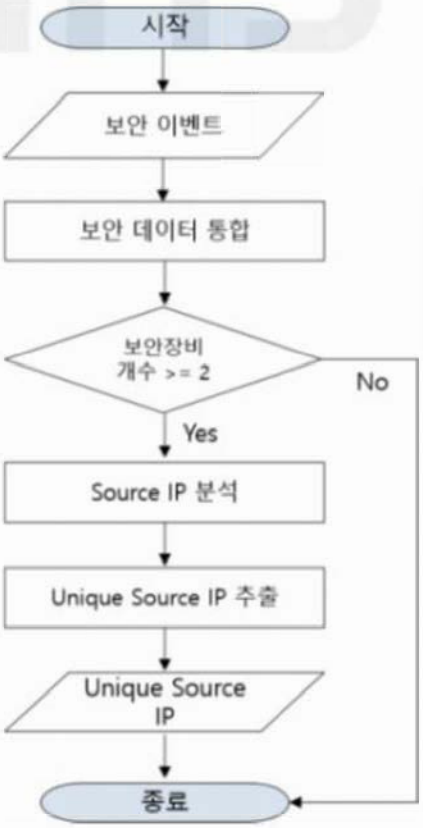
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

o 특성 가공을 위한 공격자 IP 기준 이기종 보안 장비 이벤트 분류



<공격자IP 기준 이기종 보안 장비 이벤트 분류>

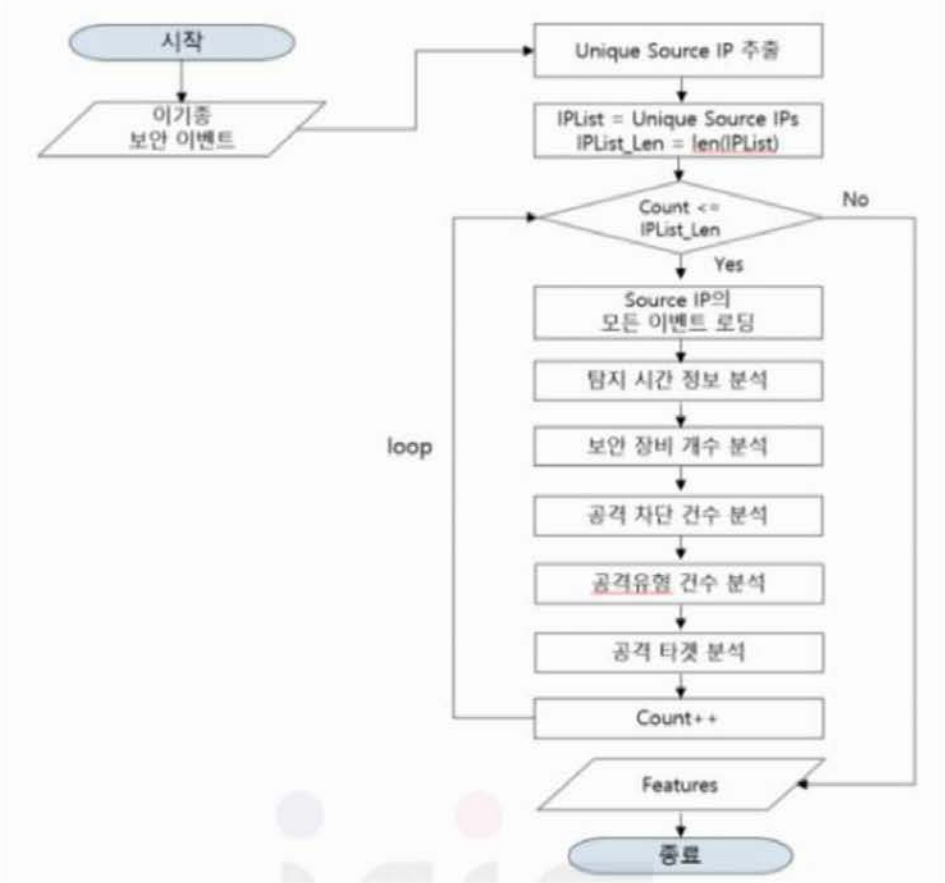
o 이기종 보안 이벤트의 사이버 위협 정보 연관 분석 기반 특성(Feature) 데이터 생성
- 유사 공격 유형 그룹화를 통한 Unique Attack IP 추출 순서도



<Unique attack IP 추출 순서도>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- 이기종 보안 이벤트 기반 특성(Feature) 가공 알고리즘 순서도



<이기종 보안 이벤트 기반 특성 정보 가공 순서도>

- 이기종 보안 이벤트 기반 특성(Feature) 가공 데이터

<특성(Feature) 가공 데이터 목록>

ID	Feature Name	Description	비고
F1	attackIP	- (정의) 공격지 IP - (활용) KEY, INDEX	공통
F2	sCountry	- (정의) 공격지 IP 국가 -(활용) 중국, 러시아 등 주요 공격 국가 식별	공통
F3	DetectionPeriod	- (정의) 총 탐지 기간 - (활용) 공격 기간	공통
F4	Dawn	-(정의) 새벽 시간대 탐지 이벤트 개수 - (활용) 공격 시간	공통
F5	attackTypes	- (정의) 탐지 공격 유형 개수 - (활용) 다양한 공격 실행 여부	공통
F6	methodTypes	- (정의) 공격 방법 개수 - (활용) 다양한 공격 실행 여부	공통
F7	DeviceCount	- (정의) 탐지된 보안장비 대수 - (활용) 공격 범위	공통
F8	DropCount	- (정의) 방화벽 차단 건수 - (활용) 유해/악성 IP 여부	방화벽
F9	TargetIP	- (정의) 공격 대상 개수 - (활용) 다양한 공격 실행 여부	공통

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

F10	webATTACKs	- (정의) 웹 공격 탐지 개수 - (활용) 웹 스캔, 정밀 공격 등 공격 유형 식별	공통

2) 딥러닝 기반 자연어처리 모델과 유사도 분석을 통한 보안장비 이벤트 이상행위 탐지 기술 고도화

o 사이버 공격 유형 별 학습 데이터 확대 수집 및 분류 체계 정의

<공격 유형 기반 분류 체계>

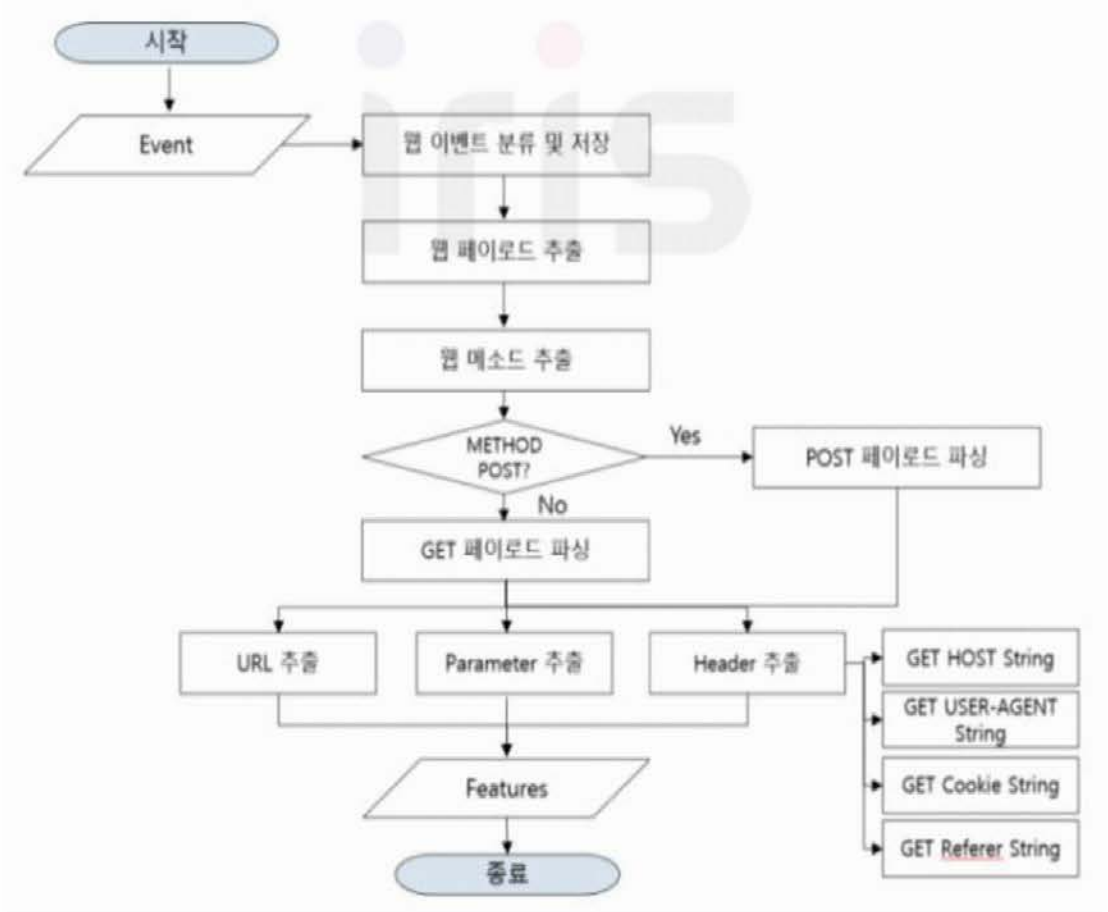
중분류	정탐	오탐	설명
Alert-PAT	-	1	의심 가는 패턴들을 탐지하기 위한 탐지 룰셋, 공격인지 아닌지 추가적인 확인 필요
Application	-	324,677	특정 어플리케이션에서 발생하는 패턴들을 탐지하기 위한 탐지 룰셋
Brute Force	-	1,375,243	brute force(무차별 대입 공격)을 탐지하기 위한 탐지 룰셋, 임계치 기반의 이벤트 이거나 특정 서비스를 지속적으로 사용할 때 탐지 됨
Command Injection	-	21,141	악성 쉘 명령어 삽입 공격을 탐지하기 위한 탐지 룰셋, Windows or Linux계열의 시스템 명령어를 탐지
DDOS	-	206,146	임계치 기반의 공격을 탐지하기 위한 탐지 룰셋
DoS	-	1,635,805	임계치 기반의 공격을 탐지하기 위한 탐지 룰셋
Scan	-	8,022,924	임계치 기반의 공격(Scan공격)을 탐지하기 위한 탐지 패턴, DDoS, DoS, Brute Force와 유사
Attack-IP	44,913	4,635,186	특정 공격자 IP로 알려진 IP를 탐지하는 탐지 룰셋
Attack-PAT	5,998	623,627	특정 공격자가 사용했던 패턴들을 탐지하기 위한 탐지 룰셋
IP-PAT	34	332,746	특정 IP(공격자, 공격의심자, 경유지 등)를 탐지하기 위한 탐지 패턴, Attack-IP와 유사
Relay-IP	32,500	15,191,764	경유지 IP로 사용된 이력이 있는 IP를 탐지하기 위한 탐지 룰셋
Relay-PAT	157	26,786	경유지로 사용된 탐지하기 위한 탐지 룰셋
Mail-IP	193	198,526	악성 또는 스팸 메일 발송 이력이 있는 특정 IP를 탐지하기 위한 탐지 룰셋
Mail-PAT	2,594	1,122,346	악성 또는 스팸 메일에서 발생하는 특정 패턴을 탐지하기 위한 탐지 룰셋
Malware	-	1,753	멀웨어를 탐지하기 위한 탐지 룰셋, Malware-IP와 Malware-PAT를 포함
Malware-IP	2,009	51,777,691	멀웨어 배포지 또는 C2서버와 관련된 IP들을 탐지하기 위한 탐지 룰셋
Malware-PAT	6,222,518	3,206,290	멀웨어가 사용하는 특정 패턴을 탐지하기 위한 탐지 룰셋
MET-PAT	5,733	3,167	Met파일과 관련된 악성코드 및 공격 패턴들을 탐지하기 위한 탐지 룰셋
Worm	-	3,597	특정 웜 바이러스들을 탐지하기 위한 탐지 룰셋
Miner	-	8,769	암호화폐 채굴과 관련된 패턴(문자열 패턴, IP)등을

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

			탐지하기 위한 탐지 룰셋
RansomWare	-	37,022	랜섬웨어와 관련있는 패턴들(문자열 패턴, IP)을 탐지하기 위한 탐지 룰셋
RAT-PAT	13	229,066	Remote Access Trojan의 약어로 트로이목마 악성코드와 관련된 패턴을 탐지하기 위한 탐지 룰셋
SQL Injection	-	2,550	SQL구문 삽입을 탐지하기 위해 SQL과 관련된 문자열들을 탐지하기 위한 탐지 룰셋
User-Agent	2,699	35,248	특정 User-Agent를 탐지하기 위한 탐지 룰셋, ex) paros
Web Injection	2	574,977	XSS, Code, Web Shell등 웹에서 발생가능한 악성 명령어 삽입과 관련된 패턴들을 탐지하기 위한 탐지 룰셋
Web Server	8	3,696,871	웹서버의 취약점(원격 코드 실행, 취약한 업데이트, 취약점이 발견된 소프트웨어를 사용하는 웹서버 등)을 노리는 공격들을 탐지하기 위한 탐지 룰셋
Web-PAT	454,602	15,149,370	웹에서의 특정 패턴을 탐지하기 위한 탐지 룰셋
WebShell-PAT	20	52,892	웹쉘과 관련된 패턴을 탐지하기 위한 탐지 룰셋

o 보안 이벤트 학습 성능 향상을 위한 페이로드 토큰화 기술 개발

- 웹 페이로드 데이터 세그멘테이션 알고리즘 순서도



<웹 페이로드 세그먼테이션 순서도>

- 웹 페이로드 데이터 세그멘테이션 구현

· HTTP 포맷(메소드, URL, Parameter, 헤더 등) 기준 페이로드 분할

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

C	D	E	F	G	H	I
get	/com/filedown.do	atchfileid "><javascript alert(string.fromcharcod	pms.	kr	mozilla/5.0 (window	http://	c.re.lnm_transi
get	/com/filedown.do	atchfileid "><javascript alert(string.fromcharcod	pms.	kr	mozilla/5.0 (window	http://	c.re.lnm_transi
get	/com/filedown.do	atchfileid "><javascript alert(string.fromcharcod	pms.	kr	mozilla/5.0 (window	http://	c.re.lnm_transi
get	/com/filedown.do	atchfileid "><javascript alert(string.fromcharcod	pms.	kr	mozilla/5.0 (window	http://	c.re.lnm_transi
get	/mail/autocomplete.crd	domain undefined language undefined cmd me	bigp	.re.kr	mozilla/4.0 (compat	http://	ofac _ga=ga1.3
get	/modules.php	name your account	scier	.kr	mozilla/5.0 (window	http://	ofac _ga=ga1.3
get	/modules.php	name your account	kofa		mozilla/5.0 (window	http://	ofac _ga=ga1.3
get	/	programcat "><script >alert(string.fromcharcod	www	.net	mozilla/5.0 (window	http://	ofac phpsessid
get	/locationbased.php	title >"><script>alert('pwnd')</script>	crez		mozilla/4.0 (compat	http://	ofac _gid=ga1.
get	/	programcat "><script >alert(string.fromcharcod	www	.net	mozilla/5.0 (window	http://	ofac phpsessid
get	/com/filedown.do	atchfileid "><script >alert(string.fromcharcode(I	pms.	kr	mozilla/5.0 (window	http://	ofac jsessionid
get	/ ed8ab9eab5 8ab9eab5ac b9eab	term slug "><script >alert(string.fromcharcode(I	www	ill.com	mozilla/5.0 (window	http://	nces jsessionid
get	/cr-includes/download.php	mode "><script >alert(string.fromcharcode(88,8	www	.net	mozilla/5.0 (window	http://	nces phpsessid
get	/	a <script>alert(openbugbounty)	www	.net	mozilla/5.0 (window	http://	nces phpsessid
get	/	programcat "><script >alert(string.fromcharcod	www	.net	mozilla/5.0 (window	http://	one phpsessid
get	/cr-includes/download.php	mode "><script >alert(string.fromcharcode(88,8	www	.net	mozilla/5.0 (window	http://	one phpsessid
get	/com/filedown.do	atchfileid "><script >alert(string.fromcharcode(I	pms.	kr	mozilla/5.0 (window	http://	one jsessionid
get	/	programcat "><script >alert(string.fromcharcod	www	.net	mozilla/5.0 (window	http://	one phpsessid
get	/cr-includes/download.php	mode "><script >alert(string.fromcharcode(88,8	www	.net	mozilla/5.0 (window	http://	one phpsessid

<웹 페이로드 세그먼테이션 예시>

- 분할한 HTTP 데이터는 각 필드별로 특성 데이터로 사용할 수 있어 노이즈 제거가 필요한 데이터를 식별이 용이
- 학습에 방해요소가 되는 노이즈 데이터(정상 데이터이나 데이터의 다양성이 높은 경우 등)을 분석하여 제거

· 노이즈가 발생하는 데이터는 유저 에이전트, 세션 ID 등이 있음

- Subword Tokenizer를 위한 BPE(Byte Pair Encoding) 토큰화 구현
  - 학습 대상 데이터(페이로드)에 대한 BPE 훈련 Cache를 json 형태로 저장
    → (입력정보) Payload Data
    → (출력정보) BPE Token Cache File


```
"normalizer": null,
"pre_tokenizer": {
  "type": "Whitespace"
},
"post_processor": null,
"decoder": null,
"model": {
  "type": "BPE",
  "dropout": null,
  "unk_token": "<UNK>",
  "continuing_subword_prefix": null,
  "end_of_word_suffix": null,
  "fuse_unk": false,
  "vocab": {
    "<UNK>": 0,
    "<CLS>": 1,
    "<SEP>": 2,
    "<PAD>": 3,
    "<MASK>": 4,
    "\u0000": 5,
    "\u0001": 6,
    "\u0002": 7,
    "\u0003": 8,
    "\u0004": 9,
```

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- 페이로드 특수문자 토큰화를 위한 WordPunct 토큰화 구현

→ (입력정보) ASCII Data

```
GET /_Lib_Proxy_Url/http://resolver.ebsxxxx.com/openurl?&sid=naver&atitle=Facile
preparation of floatable high surface area activated carbon monolith from waste printing paper and
coal tar pitch&title=Cellulose&volume=25&issue=6&date=2018&spage=3571
&issn=0969-0239 HTTP/1.1
```

→ (출력정보) Token Data

```
['GET', '/', '_Lib_Proxy_Url', '/', 'http', '://', 'resolver', '.', 'ebscohost', '.', 'com', '/', 'openurl', '?&', 'sid',
'=', 'naver', '&', 'atitle', '=', 'Facile', 'preparation', 'of', 'floatable', 'high', 'surface', 'area', 'activated',
'carbon', 'monolith', 'from', 'waste', 'printing', 'paper', 'and', 'coal', 'tar', 'pitch', '&', 'title', '=',
'Cellulose', '&', 'volume', '=', '25', '&', 'issue', '=', '6', '&', 'date', '=', '2018', '&', 'spage', '=', '3571',
'&', 'issn', '=', '0969', '-', '0239', 'HTTP', '/', '1', '.', '1']
```

o 딥러닝 기반 사이버 공격 페이로드 자연어 처리 모델 개발

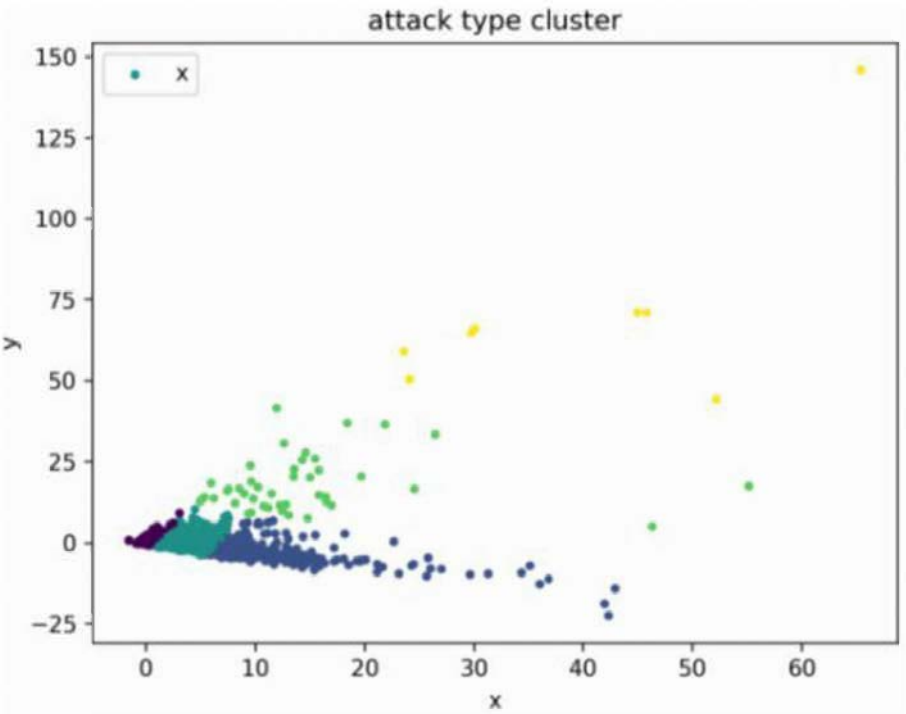
- BERT 알고리즘을 이용한 딥러닝 기반 자연어 전처리 모델 구현
  - · BERT Built-in Embedding(bert-large-uncased 등 10개)를 통한 페이로드 임베딩
  - · SentenceTransformer API를 통한 페이로드 임베딩
  - · 임베딩 속도 향상을 위한 CUDA GPU 기능 탑재

o 유사 사이버 공격 유형 분석을 위한 유사도 분석 기술 개발

- KMeans 클러스터링 알고리즘을 통한 유사 공격자 및 이상행위 유형 분류

→ (입력정보) 이기종 보안 이벤트 기반 특성 가공 데이터

→ (출력정보) 유사 공격자 및 비정상 행위 식별



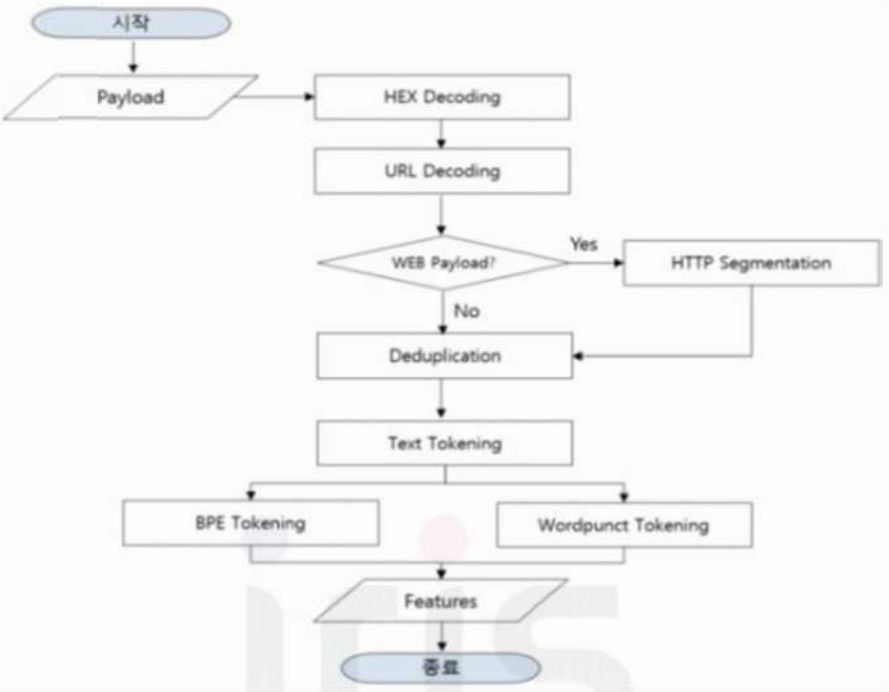
<공격 유형 클러스터링 가시화>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

o 보안장비 이벤트 이상행위 탐지 기술 고도화

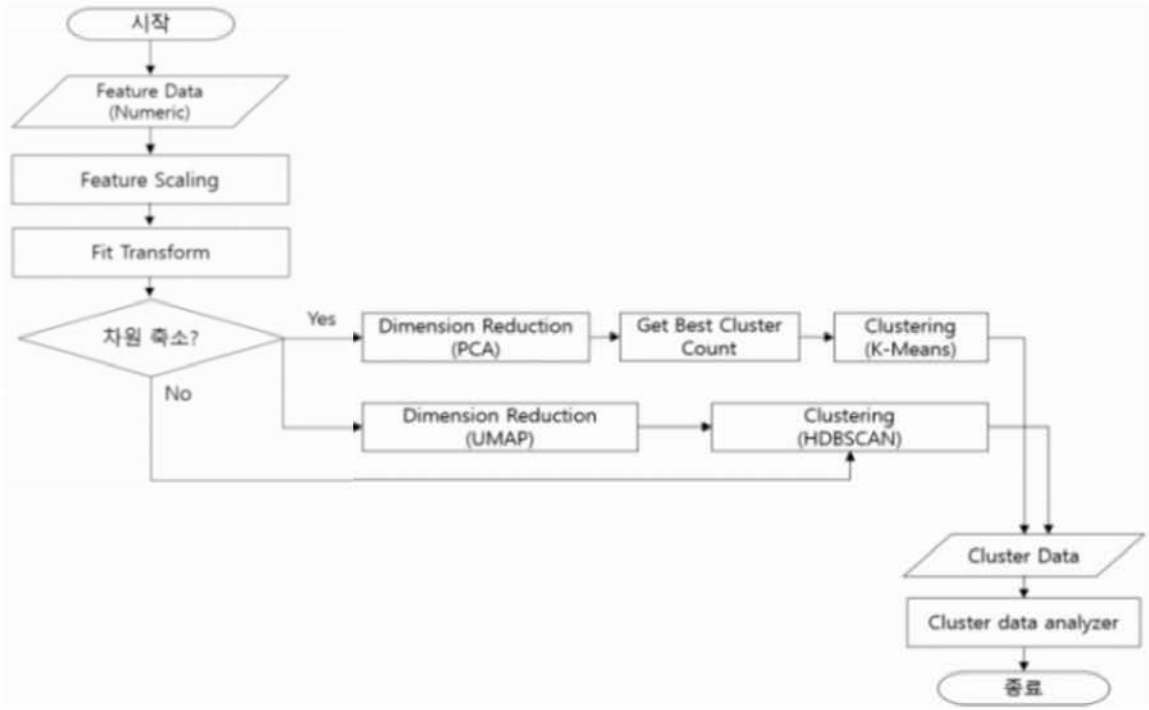
- AI 기반 이상행위 탐지 시스템 고도화 구성
  · (고도화 요소) 데이터 분류, 전처리, 특성 가공, AI 모델 및 파라미터 최적화 등

- 보안 이벤트 학습 데이터 전처리 고도화
  · 기존 코드에 신규 개발한 토큰화(BPE, HTTP Segmentation, Wordpunct) 방식 추가



<데이터 전처리 고도화 순서도>

- 비지도 학습 기반 유사 공격 자동 분류 알고리즘

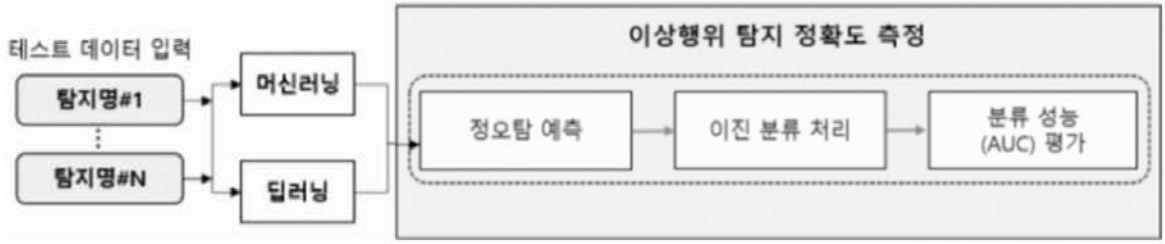


<비지도 학습 기반 유사 공격 클러스터링 순서도>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

o 테스트 데이터를 통해 고도화한 AI 모델 검증 및 평가

- AI 기반 이상행위 탐지 정확도 자체 시험 환경 구성
  - 표본 데이터로부터 시험용 데이터(정탐·오탐 이벤트)를 생성
  - 시스템 내 성능 테스트 대상 Test Data Set을 설치
  - 기존 학습된 정보를 모두 삭제하고 신규 학습을 진행
  - 머신러닝 모델과 딥러닝 모델에 대해 Test Data Set을 입력하여 탐지명별 정오탐 이진 분류 정확도 성능(AUC)을 측정
  - 탐지명별 측정한 결과를 평균하여 AUC 성능 측정 결과를 산출



<이상행위 탐지 정확도(AUC) 테스트 절차>

- AI 기반 이상행위 탐지 정확도 시험 평가 방법

<자체 시험 평가 절차 및 방법>

제목	AI 기반 이상행위 탐지 정확도 성능(AUC) 측정
주요 내용	o 학습 대상 이벤트 분류별 AI 기반 이상행위 탐지 정확도(AUC) 측정 o 시험 대상 데이터들에 대한 AUC 평균값을 측정
시험 방법	o Input 데이터 명세 - IDS 보안 관제 정·오탐 이벤트 o Output 데이터 명세 (1) 학습 대상 이벤트 분류별 부스팅(RandomForest, CatBoost, LightGBM) 3개 모델과 딥러닝(Bi-GRU) 모델의 이상행위 탐지 정확도(AUC) 측정 (2) 분류별 AUC 성능치에 대한 평균값 o 시험환경 세팅 (1) 부스팅·딥러닝 SW와 테스트용 데이터를 설치한다. (2) 기존에 학습한 정보를 모두 삭제하고 신규 학습을 진행한다. o 시험 절차 (1) 중분류된 분류된 이벤트 데이터를 전처리한다. 명령어: python nlp_parser.py -- input-csv [데이터셋 경로] -- output-csv [출력경로] --method "nlp word punct bpe" (2) 학습데이터와 시험데이터를 7:3으로 임의로 선택하고, 학습데이터는 검증데이터는 학습데이터 중에서 20%를 선별한다. (3) 학습에 사용할 훈령용 Feature 데이터를 시험 모델에 입력한다. (4) 부스팅 및 딥러닝 모델로 학습데이터에 대한 학습을 진행하고, 검증을 진행한다.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

(5) 시험데이터를 대상으로 시험을 진행한 후 AUC를 측정한다.
명령어:python optuna.py —input-path [전처리된 데이터셋 경로] res-path [출력경로] —model [모델명] --feat-type payload --gpu True --trial 10

<RandomForest 모델 하이퍼파라미터>

항목	값
n_estimators	3045
max_depth	52
max_leaf_nodes	6505
preprocessnames	bpe
tfidf_max_features	12848

<LigthGBM 모델 하이퍼파라미터>

항목	값
num_iterations	100
learning_rate	0.1
lambda_l1	0.05485736497869557
lambda_l2	0.0003065936182189033
num_leaves	59
feature_fraction	0.5188377188557745
bagging_fraction	0.8563184273193752
bagging_freq	2
min_data_in_leaf	13
preprocessnames	bpe
tfidf_max_features	13165

(6) output 디렉토리에 생성된 결과 파일을 확인하여 AUC를 확인한다.

점검 기준	o AI 기반 이상행위 탐지 정확도 측정 결과 확인 - 학습 대상 중분류별 부스팅과 딥러닝 모델의 AUC 평균값을 확인

- 5개 사이버 공격 유형(웹 공격, 악성메일 등)의 이상행위 탐지 정확도(AUC) 시험 평가 결과

· RandomForest 모델 **(AUC 0.985)**

name	model	tp	tn	fp	fn	accurac	precisio	recall	F1Score	AUC
Relay-PAT_pre.txt	rf	30	5357	1	0	0.999814	0.967742	1	0.983607	1
web	rf									
Attack-PAT_pre.txt	rf	1136	124775	1	13	0.999889	0.99912	0.988686	0.993876	0.999998
MET-PAT_pre.txt	rf	1119	603	53	5	0.967416	0.954778	0.995552	0.974739	0.969
Mail-PAT_pre.txt	rf	382	215186	4	66	0.999675	0.989637	0.852679	0.916067	0.998234

· LightGBM 모델 **(AUC 0.99)**

name	model	tp	tn	fp	fn	accurac	precisio	recall	F1Score	AUC
Relay-PAT_pre.txt	lgbm	30	5358	0	0	1	1	1	1	1
web	lgbm	106453	2925738	3289	4579	0.997412	0.97003	0.95876	0.964362	0.999868
Attack-PAT_pre.txt	lgbm	1139	124774	2	10	0.999905	0.998247	0.991297	0.99476	0.999892
MET-PAT_pre.txt	lgbm	976	627	29	148	0.900562	0.971144	0.868327	0.916862	0.985967
Mail-PAT_pre.txt	lgbm	354	215164	26	94	0.999444	0.931579	0.790179	0.855072	0.99618

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

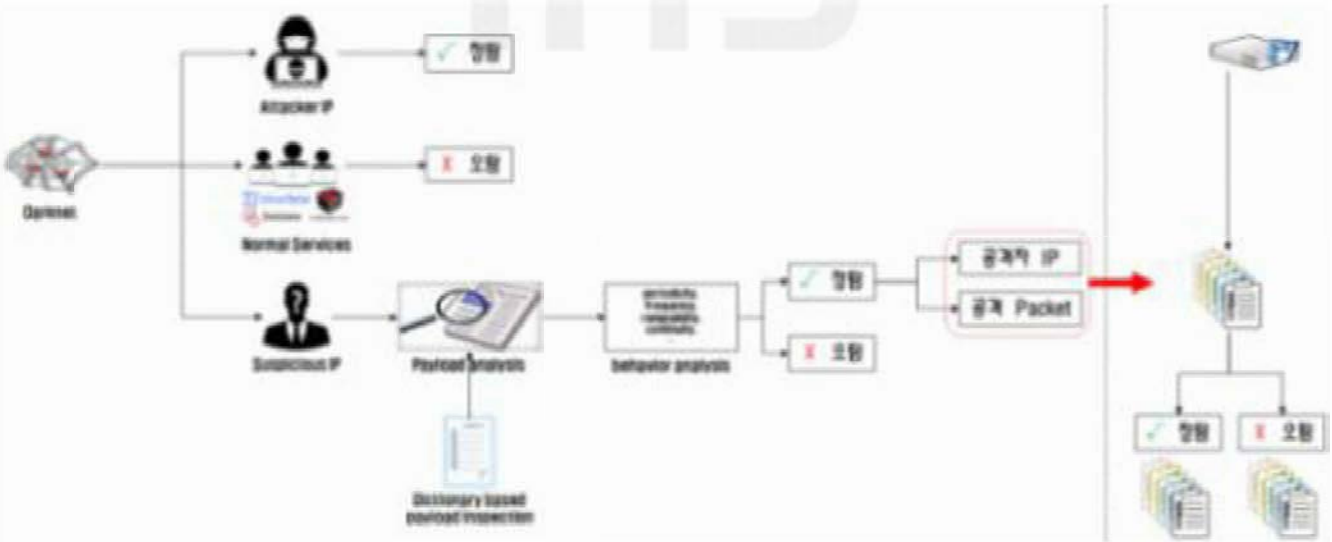
개발목표 ③	AI·빅데이터 기반 이기종 보안 장비 이상행위 탐지 성능 향상 기술 설계

세부 내용	1) 이기종 보안장비 데이터 高신뢰/자동 레이블링 모듈 설계 및 정·오탐 분류
	2) 이기종 보안장비 데이터 高신뢰/자동 레이블링 모듈 구현 및 성능 테스트
	3) 비지도학습 기반 이상행위 탐지 모델 학습 및 핵심 특징 분석/추출
	4) 지도학습 기반 이상행위 탐지 모델 학습 및 최적 하이퍼 파라미터 도출
	5) 이상행위 탐지 정확도 향상을 위한 불균형 데이터 최적 활용 방안 도출

1) 이기종 보안장비 데이터 高신뢰/자동 레이블링 모듈 설계 및 정·오탐 분류

o IDS 및 다크넷을 활용한 유사도 기반의 자동 레이블링 모듈 설계
- 상호 연관분석이 가능한 이기종 보안데이터 선정(IDS & 다크넷)
- 다크넷에 탐지된 IP를 3종류로 분류
  ⇒ 알려진 정상 scanning IP를 정상, 旣 공격이력이 있는 IP는 공격자 IP, 그 외는 공격 의심 IP로 분류

  ※ Miss configuration과 같은 경우로 일회성으로 유입되는 패킷은 정상으로 분류
- 공격의심 IP의 페이로드 분석 및 행위 분석을 통한 비정상 IP 분류
  ⇒ 다크넷으로 유입된 패킷의 페이로드에 공격 관련 시그니처(signature) 존재여부 확인
  ⇒ 공격의심 IP의 접근 주기·빈도·범위·연속성을 통하여 정상 및 공격자 IP를 분류
  ⇒ 공격자 IP 및 공격자 IP 패킷의 페이로드를 CTI로 활용하여 他장비 보안로그의 정·오탐 분류에 활용



2) 이기종 보안장비 데이터 高신뢰/자동 레이블링 모듈 구현 및 성능 테스트

o 다크넷 패킷 레이블링 모듈 구현 및 성능 테스트
- 다크넷 레이블링 및 공격 관련 데이터 추출 모듈 성능 테스트
  ⇒ 다크넷을 활용하여 구축한 CTI의 정확도 점검
  ⇒ 자체적으로 구축한 다크넷 기반의 CTI를 보안관제 요원 또는 외부 CTI를 통해 검증

o 다크넷에서 추출된 데이터 기반의 IDS 정·오탐 분류기 구현 및 성능 테스트

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- 다크넷에서 추출된 공격자 IP기반의 IDS 보안이벤트 필터링
  ⇒ 공격자 IP에서 유입된 패킷 정밀 분석 수행
- 다크넷에서 추출된 공격자 패킷을 기반으로 IDS 보안이벤트들과의 유사도 분석 및 레이블 보정
  ⇒ 레이블 보정 전후 AI모델의 성능 비교 테스트 수행

3) 비지도학습 기반 이상행위 탐지 모델 학습 및 핵심 특징 분석/추출

o 비지도학습 기반 이상행위 탐지 모델을 생성하기 위한 핵심 특징 정의
- 패킷의 헤더 및 페이로드에서 직접적으로 추출 가능한 정보 외 이상행위를 특정할 수 있는 특징들을 추가로 정의하고 이를 추출
- 페이로드의 구성, 빈도 등과 같이 페이로드와 관련된 특징들을 정의 및 활용
- 또한, 특정 다수의 조건이 제시되었을 때 에서 추출 가능한 통계적 특징들을 통하여 이상행위 탐지에 활용

	특징	비고
페이로드 기반 특징	페이로드 구성 비율	• 페이로드에 존재하는 전체 캐릭터 개수 대비 화면에 출력 가능한 캐릭터 개수/비율
		• 페이로드에 존재하는 전체 캐릭터 개수 대비 화면에 출력 불가능한 캐릭터 개수/비율
	특정 기간 중에 탐지된 보안이벤트의 단어들을 추출하여 WORD2VEC	• 윈도우 사이즈, 벡터 사이즈, 알고리즘을 다양하게 시도하여 WORD 사전 구축
	동일 이벤트별 페이로드 기반 TF (Term Frequency)	• 사전에 정의된 불용어를 보안이벤트에서 제거 • 보안이벤트를 이벤트명별로 그룹핑 • 그룹별 TF 생성
	동일 이벤트별 페이로드 기반 DF (Document Frequency)	• 사전에 정의된 불용어를 보안이벤트에서 제거 • 보안이벤트를 이벤트명 별로 그룹핑 • 그룹별 DF 생성
	동일 이벤트별 페이로드 기반 TF-IDF (Term Frequency-Inverse Document Frequency)	• 사전에 정의된 불용어를 보안이벤트에서 제거 • 보안이벤트를 이벤트명별로 그룹핑 • 그룹별 TF-IDF 생성
	기타 페이로드로부터 추출 가능한 특징	• IDS/IPS에서 제공하지 않지만 보안이벤트 정·오탐 판단의 근거가 될 수 있는 특징 선별 • TCP flag, sequence number, fragment size, TTL, fragment offset 등
통계 기반 특징	기준필드, 기간/건수, 조건식, 대상필드, 종류/건수/비율/분산 입력 시 추출 가능한 특징의 예 도출	
	조건에 따른 DB 쿼리(query) 설계 및 테스트	• 예시 ①, ② 참고

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

<예시 ①>

기 간	현재 보안이벤트 발생 시점으로부터 이전 5분 이내
조 건 식	발생한 보안이벤트 중 destination ip가 현재 보안이벤트의 destination ip와 동일한
대상필드	이벤트들의 이벤트 명
종 류	종류
생성쿼리	**SELECT** DISTINCT event_name **FROM** Log_Table **WHERE** destination ip = 현재 보안이벤트의 destination ip and datetime between (현재시간) and (현재시간 -5분)

<예시 ②>

기 간	현재 보안이벤트 이전 500개의
조 건 식	보안이벤트 중 source port가 1024이하인
대상필드	보안이벤트
종 류	건 수
생성쿼리	**SELECT** count(A.event_name) **FROM** {SELECT event_name FROM Log_Table A WHERE datetime >= 현 시점 ORDER BY datetime ASC LIMIT 500} **WHERE** source port <= 1024

o 보안관제 이벤트 핵심 특징 기반 최적의 비지도학습 알고리즘 연구

- 정·오탐 레이블이 편향된 보안이벤트 유형선별 및 비지도학습 기반 이상행위 탐지

⇒ 상기 정의된 페이로드 및 통계 기반 특징 활용

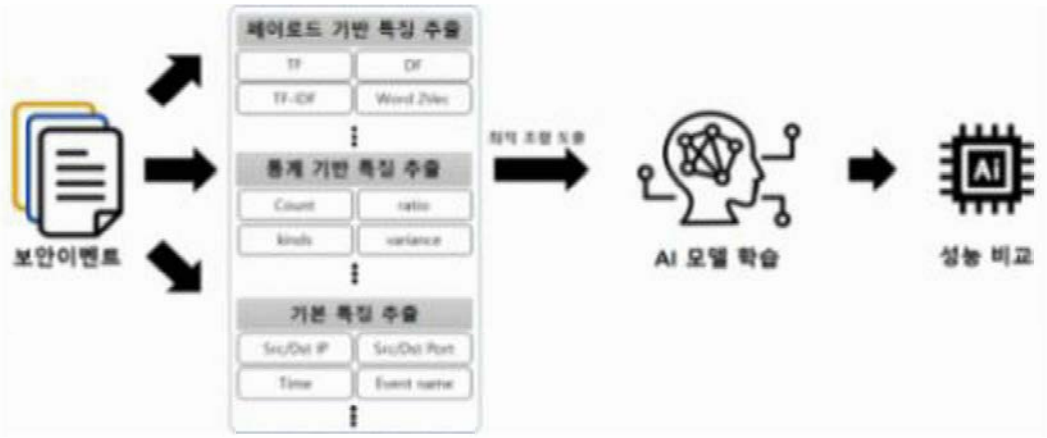
※ 대소 관계가 의미없는 카테고리형 특징은 사전 설계된 매핑 테이블, 암호학적 해시 등을 통하여 수치로 변환

⇒ 사용된 보안이벤트 특징조합별 비지도학습 기반 이상행위 탐지 AI 모델 성능 비교

⇒ 사용된 비지도학습 알고리즘별(DBscan, KMeans) 이상행위 탐지 AI 모델 성능 비교

⇒ 탐지성능에 대한 수치적 해석 이외에도 학습 결과 시각화를 통해 실효성 확인

※ 주성분분석(PCA), t-SNE 알고리즘 등을 통해 AI 모델 학습결과 시각화



<AI 기반 보안이벤트 이상행위 탐지 모델 학습>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

4) 지도학습 기반 이상행위 탐지 모델 학습 및 최적 하이퍼 파라미터 도출

o 보안관제 이벤트 메타정보 학습을 위한 최적의 지도학습 알고리즘 연구

- 전통적인 지도학습 알고리즘을 통한 보안이벤트 정·오탐 분류 모델

⇒ 보안이벤트 메타정보는 행과 열로 표현되는 테이블형 데이터(Tabular Data)

※ 각 행은 보안이벤트 레코드를 나타내며 각 열은 보안이벤트 속성을 나타냄

⇒ 테이블형 데이터와 같은 정형데이터 분류 문제에서는 심층신경망 기반 지도학습 알고리즘보다 트리 기반 지도학습 알고리즘을 통한 AI 모델 학습이 상대적으로 우수한 성능을 보임

※ 단일트리학습(DecisionTree)과 앙상블 기법(RandomForest, Xgboost, LightGBM) 간 성능 비교 실험으로 RandomForest가 가장 우수한 성능을 보임을 확인

⇒ 지도학습 기반 이상행위 탐지 모델 하이퍼 파라미터 조정 실험을 통해 가장 우수한 성능을 보인 알고리즘(RandomForest) 기준 최적의 하이퍼 파라미터 도출

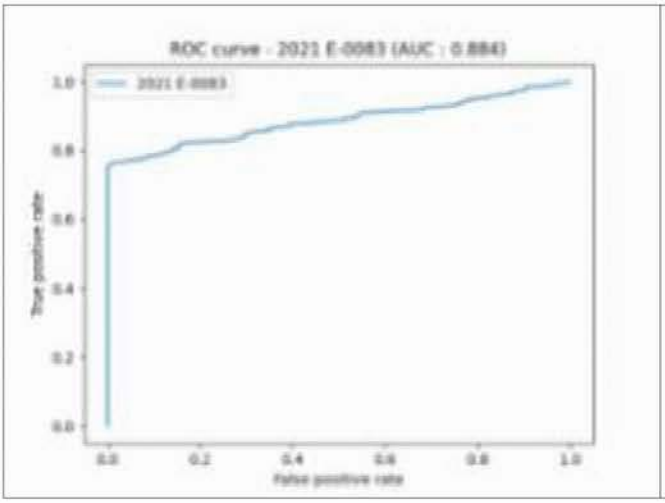
▸ python 기계학습 라이브러리 scikit-learn이 제공하는 트리기반 알고리즘에서 조정 가능한 하이퍼 파라미터 *4종에 대한 최적 값 도출

* max_depth, min_samples_leaf, max_samples_split, n_estimators

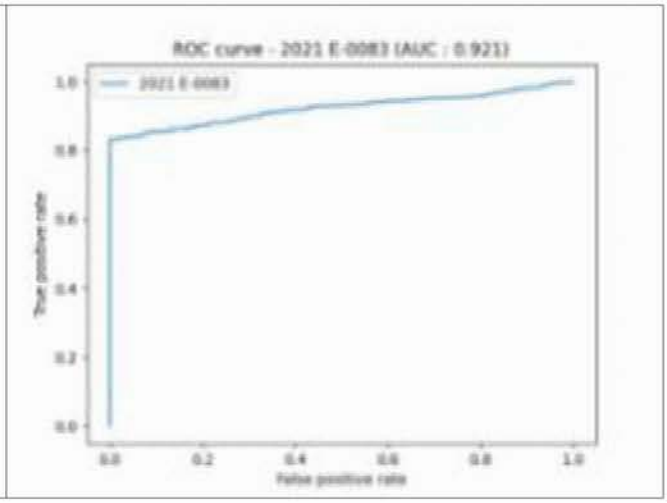
▸ 앙상블 기법의 하위트리 개수를 결정하는 'n_estimators' 값에 따라 AI모델 성능이 유의미하게 변화하였으며, 이외에는 성능 변동 미미함

<하위트리 개수 변화에 따른 이상행위 탐지 AI 모델 성능 비교>

n_estimators	정확도	AUC	F1-score
20	89.054	0.902	0.914
300	**90.755**	**0.917**	**0.928**
500	90.062	0.910	0.923

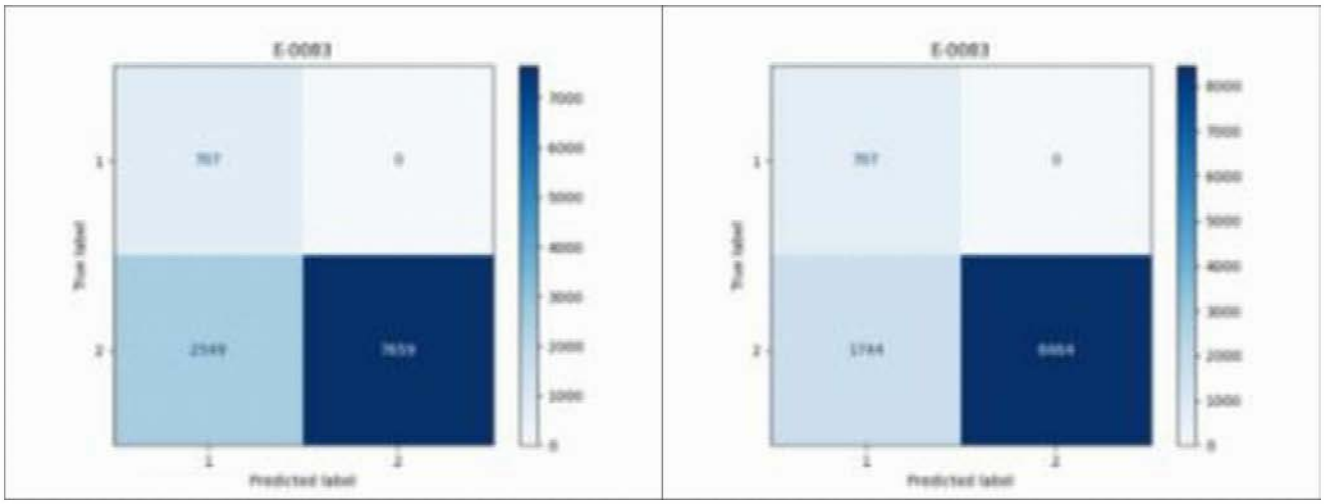


<이상행위 탐지 모델 학습결과 ROC커브 (하위트리 20개)>



<이상행위 탐지 모델 학습결과 ROC커브 (하위트리 300개)>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



<이상행위 탐지 모델 학습결과 혼동행렬 (하위트리 20개)>

<이상행위 탐지 모델 학습결과 혼동행렬 (하위트리 300개)>

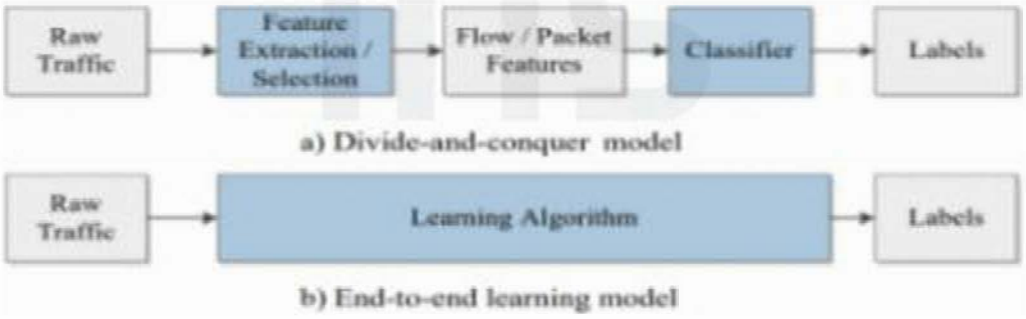
o 보안관제 이벤트 페이로드 정보 학습을 위한 최적의 지도학습 알고리즘 연구

- 종단간(End-to-End) 학습을 통한 페이로드 기반 보안이벤트 특징 자동 학습모델

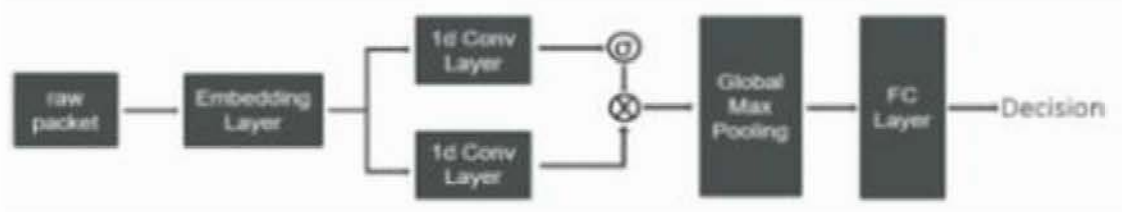
⇒ 보안이벤트 페이로드를 별도의 특징추출·가공 과정 없이 AI모델의 입력으로 사용

⇒ 특징추출·가공 과정에 소요되는 인적·시간적 자원 절약 가능

⇒ GatedCNN 구조를 통해 원본 페이로드를 가공 없이 학습하여 AI모델이 보안이벤트 중요 특징을 자동 학습하도록 유도



<기존 분류기 생성과정(a)과 종단간 학습을 통한 분류기 생성과정(b)>



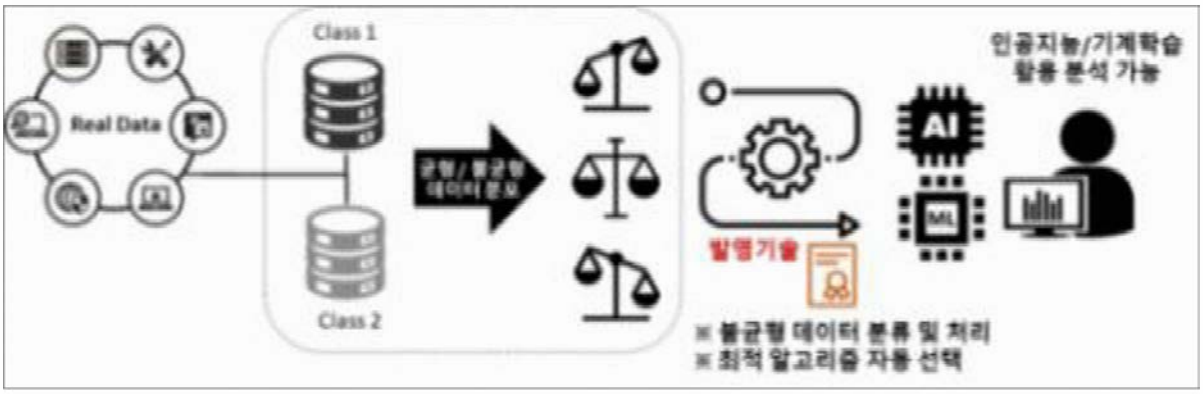
<보안이벤트 특징 자동 학습모델 전체 구조(GatedCNN)>

5) 이상행위 탐지 정확도 향상을 위한 불균형 데이터 최적 활용 방안 도출

o 불균형 데이터 레이블 분포 기반 최적 인공지능 모델 생성 알고리즘 자동선택 방법

- 보유 데이터의 레이블 분포에 따라 최적 학습 알고리즘 자동 선택

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



<사용자의 목적 및 데이터 분포를 종합적으로 고려한 최적 알고리즘 자동 적용>

- 전체 데이터를 수집 현황에 따라 3가지 그룹으로 분류

그룹1. 하나의 레이블만 존재 ⇒ 단일 레이블 분포

- 단일 레이블은 지도학습 알고리즘을 통해 학습이 불가능하므로 클러스터링, 유사도 분석 알고리즘, 비지도학습 알고리즘 추천 및 적용
- 신규 데이터 유입 시 유사도 비교 혹은 비지도학습 모델을 통해 레이블 결정

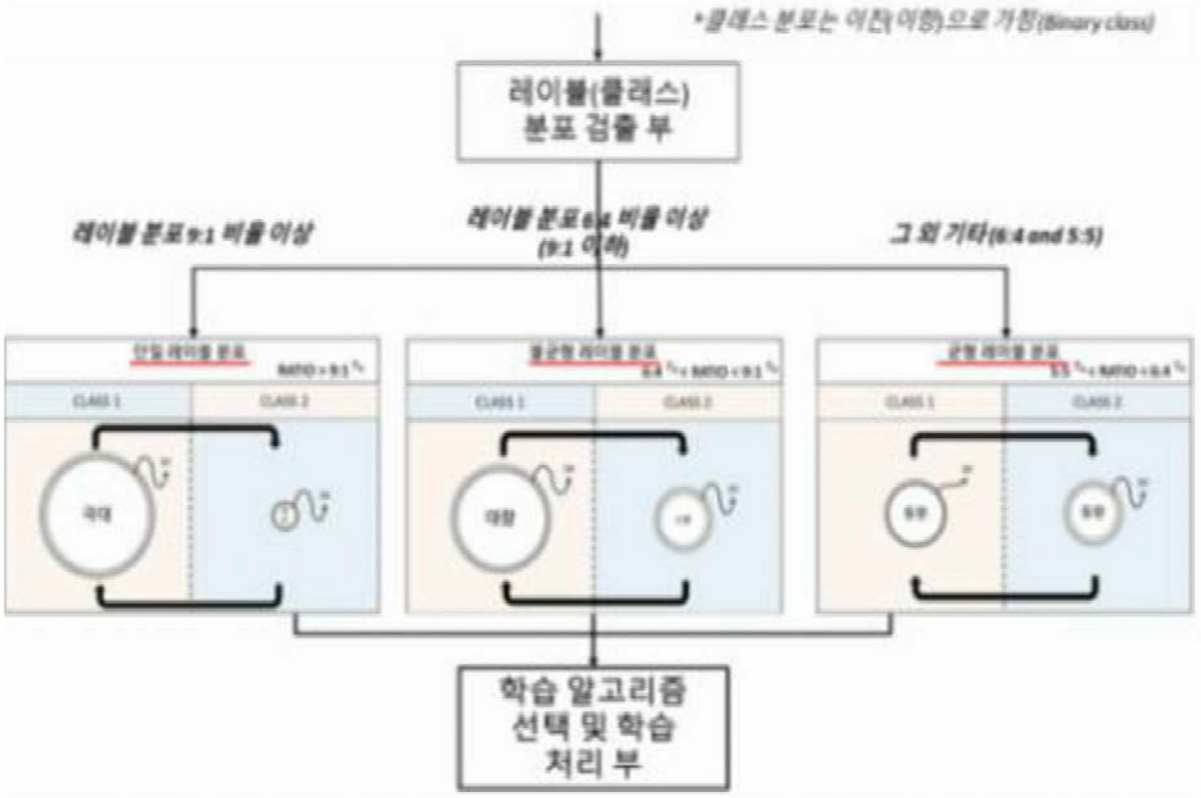
그룹2. 두 레이블의 데이터가 균등 ⇒ 균형 레이블 분포

- 전통적인 지도학습 알고리즘 추천 및 적용

※ SVM, DT, DNN, CNN, ...

그룹3. 두 레이블의 데이터가 불균등 ⇒ 불균형 레이블 분포

- 가. 오버/언더샘플링을 통해 그룹1 또는 그룹2와 같은 방법으로 학습



<인공지능 알고리즘 적용 방안 개념도>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

세부 기술 ② TTP 기반 위협 인자 식별 및 위협 대응 플레이북 자동 생성 요소 기술 개발

□ 개발 기술 개요

o (개발목표) TTP 기반 위협 인자 식별 및 위협 대응 플레이북 자동 생성 요소 기술 개발

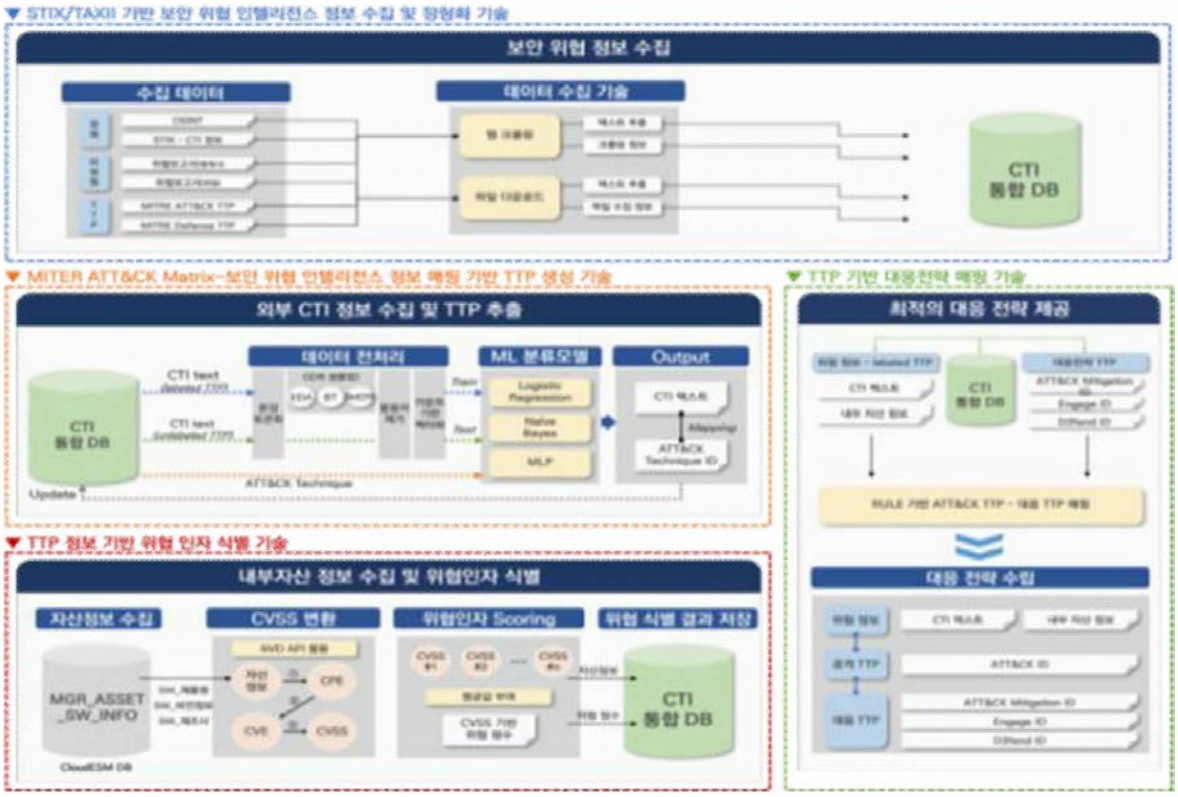
1) 공개 보안 위협 인텔리전스 정보 수집 기술 설계
2) TTP 기반 위협 위협 인자 식별 기술 개발
3) 보안 관제 플레이북 자동 생성 기술 연구 및 개발
4) 보안 관제 플레이북 검증·관리 기술 설계 및 개발
5) 플레이북 시각화 및 관리 기술 개발

o (추진실적) TTP 기반 위협 인자 식별 및 위협 대응 플레이북 자동 생성 요소 기술 개발 완료

- 공개 보안 위협 인텔리전스 정보 수집 기술 설계 완료 **개발목표 1**
- TTP 기반 위협 위협 인자 식별 기술 개발 완료 **개발목표 2**
- 보안 관제 플레이북 자동 생성 기술 연구 및 개발 완료 **개발목표 3**
- 보안 관제 플레이북 검증·관리 기술 설계 및 개발 완료 **개발목표 4**
- 플레이북 시각화 및 관리 기술 개발 완료 **개발목표 5**

개발목표 ①	공개 보안 위협 인텔리전스 정보 수집 기술 설계

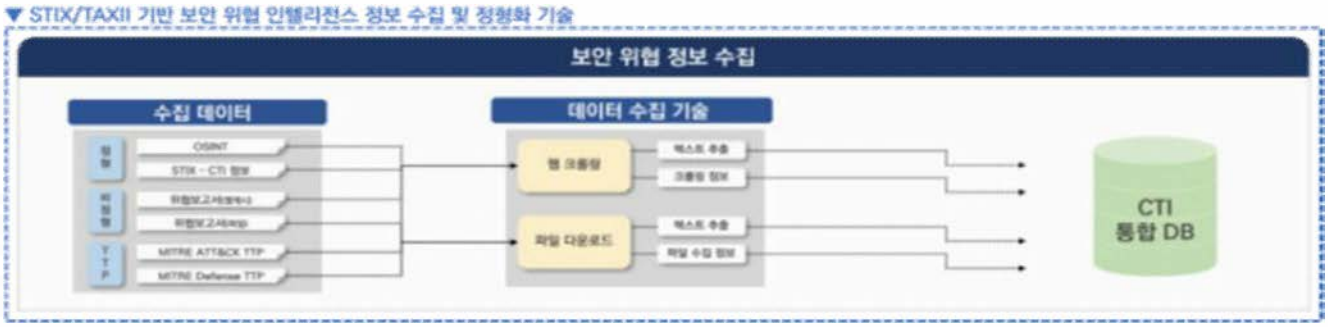
세부 내용	1) STIX/TAXII 기반 보안 위협 인텔리전스 정보 수집 및 정형화 기술 설계
	2) 보안 위협 인텔리전스 통합 데이터베이스 설계



<공개 보안 위협 인텔리전스 정보 수집 및 위협 인자 식별 기술 전체 개념도>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

1) STIX/TAXII 기반 보안 위협 인텔리전스 정보 수집 및 정형화 기술 설계



<STIX/TAXII 기반 보안 위협 인텔리전스 정보 수집 및 정형화 기술 개념도>

o 보안 위협 인텔리전스 정보 데이터 선정

- (수집 데이터) 정형 데이터 2종, 비정형 데이터 1종, TTP 관련 데이터 4종으로 정의

데이터 구분	데이터 종류
정형 데이터	OSINT
	STIX 기반 CTI 정보
비정형 데이터	국내외 위협 보고서
TTP 정보	MITRE ATT&CK TTP
	MITRE ATT&CK Mitigation TTP
	MITRE D3FEND TTP
	MITRE ENGAGE TTP

o 정형 데이터 수집 기술 설계

- (수집 목적) TTP 분류 모델의 성능향상을 위한 훈련 데이터로 사용
- (수집 데이터 ①) OSINT-IOC(Indicators of Compromise) 정보
  · Black List IP, URL, HASH 등
- (수집 데이터 ① - 수집기술 ①) OSINT 수집 툴을 사용하여 OSINT 정보 수집
  · OSINT 수집 툴 : Maltego, Shodan, Goodle darks 등
- (수집 데이터 ① - 수집기술 ②) 주로 사용되는 레퍼런스에서 크롤링 또는 직접 수집
  · 주로 사용되는 레퍼런스 : URL haus, Twitter, Phish, Malware Report(github) 등
- (수집 데이터 ②) STIX 기반의 CTI 위협 정보 수집 및 필요 데이터 추출
  · 국내 C-TAS 등과 같은 공공기관에서 공유되는 침해사고 정보 수집
- (수집 데이터 ② - 수집기술 ①) MITRE-github에서 STIX 샘플 데이터 수집
  · 공공기관-침해사고 데이터 수집 전 샘플 데이터를 통해 수집 데이터 정리

<정형 데이터 - STIX 샘플 데이터 수집 정보>

파일명	수집 데이터	데이터 예시	
enterprise-attack.json	attack-pattern	attack-pattern—10d5f3b7-6be6-4da5-9a77-0f1e2bbfcc44	Technique ID
	x-mitre-tactic	x-mitre-tactic--d108ce10-2419-4cf9-a774-46161d6c6cfe	Tactic ID
	course-of-action	course-of-action--676975b9-7e8e-463d-a31e-4ed2ecbfed81	Mitigation ID

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

o 비정형 데이터 수집 기술 설계

- (수집 목적) TTP 분류 모델의 성능향상을 위한 훈련 데이터로 사용
- (수집 데이터) TTP 레이블이 포함/포함되지 않은 국내외 위협 보고서
  · .docx, .pdf, .html 형식의 위협보고서 파일을 수집하여 텍스트만 추출
  · 첨부파일로 업로드된 위협 보고서와 웹 페이지 게시된 위협보고서 두 가지로 구분
- (수집 기술 ①) 첨부파일로 업로드 된 위협 보고서 수집 방법
  · 주기적으로 보안 위협 관련 보고서를 업로드 해주는 사이트에서 직접 다운로드
- (수집 기술 ②) 웹 페이지 게시 위협보고서 수집 방법
  · 웹 크롤링을 통해 html 변환하여 텍스트 내용 추출

o TTP 관련 데이터 수집 기술 설계

- (수집 목적) 수집 위협 정보의 공통 구조 변환 위한 MITRE-공격/대응 전략 수집
- (수집 데이터) MITRE 제공해주는 공격 및 방어 전략 정형화 정보
  · ATT&CK, ATT&CK MITIGATION, D3FEND, ENGAGE 정보 수집
- (수집 기술 ①) 제공되는 JSON 파일을 사용한 수집
  · MITRE github에서 제공해주는 JSON 파일을 직접 수집하여 필요 데이터 추출
- (수집 기술 ②) 웹 크롤링 기술을 사용한 수집 방법
  · 공격-대응 전략 간 Mapping 정보 등과 같은 JSON 파일 내 포함되지 않은 데이터 수집을 위해 해당 웹사이트에서 관련 정보 크롤링하여 필요 데이터 수집

<공격 전략 기반 TTP 관련 데이터 수집 정보>

데이터 분류	파일명	수집 데이터		데이터 예시
공격 전략 기반 TTP	enterprise -attack-10.0.json	technique_name		"/etc/passwd and /etc/shadow"
		technique_id		"T1003.008"
		description		"Adversaries may attempt to..."
		reference	source_name	"Linux Password and Shadow..."
			external_id	"The Linux Documentation..."
			url	"https://www.tldp.org/LDP/..."
		tactics_name		"credential-access"

<대응 전략 기반 TTP 관련 데이터 수집 정보>

데이터 분류	대응 전략	수집 데이터	데이터 예시
대응 전략 기반 TTP	ATT&CK Mitigation	mitigation name	"Account Use Policies"
		mitigation id	"M1036"
		description	"Configure feature related..."
		mapping_att&ck id	["T1110" , "T1621" , ...]
	ENGAGE	engage name	"Security Controls"
		engage id	"EAC0018"
		description	"Alter security controls to..."
		mapping_att&ck id	["T1548" , "" ,...]
	D3FEND	d3fend name	"URL Analysis"
		d3fend id	D3-UA
		description	"Determining if a URL is be..."
		mapping_att&ck id	["T1566.002" , "T1204.001" ...]

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

2) 보안 위협 인텔리전스 통합 데이터베이스 설계

o 보안 위협 인텔리전스 통합 데이터베이스 시스템 환경 및 테이블 설계
- 사용 데이터베이스 시스템: MySQL
- 전체 테이블 구성

<보안 위협 인텔리전스 통합 데이터베이스 구성도>

- ATTACK_LIST 테이블
  - (목적) CTI 정보에 대한 TTP 매칭 및 대응전략 매핑 - ATT&CK TTP 정보 저장
  - technique_id(PK) : MITRE ATT&CK의 Technique ID 저장
  - technique_name : MITRE ATT&CK의 Technique name 저장
  - tactic_id : 해당 Technique 상위 단계인 tactic id 저장
  - tactic_name : 해당 Technique 상위 단계인 tactic name 저장
  - attack_version: MITRE ATT&CK의 수집 당시 버전 정보 저장

no	field	description	type	length	default
1	technique_id	MITRE ATT&CK Technique ID	char	10	
2	technique_name	MITRE ATT&CK Technique Name	varchar	60	
3	tactic_id	MITRE ATT&CK Tactic ID	char	10	
4	tactic_name	MITRE ATT&CK Tactic Name	varchar	30	
5	attack_version	MITRE ATT&CK VERSION	varchar	10	

- MITIGATION_LIST 테이블
  - (목적) CTI 정보에 대한 TTP 매칭 및 대응전략 매핑 - MITIGATION 정보 저장
  - mitigation_id : MITRE ATT&CK Mitigation id 저장
  - mitigation_name : MITRE ATT&CK Mitigation name 저장
  - mitigation_version : MITRE ATT&CK Mitigation의 수집 당시 버전 정보 저장

no	field	description	type	length	default
1	mitigation_id	MITRE ATT&CK Mitigation ID	char	10	
2	mitigation_name	MITRE ATT&CK Mitigation Name	varchar	60	
3	mitigation_version	MITRE ATT&CK Mitigation version	varchar	10	

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- D3FEND_LIST 테이블
  - (목적) CTI 정보에 대한 TTP 매칭 및 대응전략 매핑 - D3FEND 정보 저장
  - d3fend_id : MITRE d3fend id 저장
  - d3fend_name : MITRE d3fend name 저장
  - d3fend_version : MITRE d3fend의 수집 당시 버전 정보 저장

no	field	description	type	length	default
1	d3fend_id	MITRE d3fend ID	char	10	
2	d3fend_name	MITRE d3fend Name	varchar	60	
3	d3fend_version	MITRE d3fend version	varchar	10	

- ENGAGE_LIST 테이블
  - (목적) CTI 정보에 대한 TTP 매칭 및 대응전략 매핑 - ENGAGE 정보 저장
  - engage_id : MITRE engage id 저장
  - engage_name : MITRE engage name 저장
  - engage_version: MITRE engage 수집 당시 버전 정보 저장

no	field	description	type	length	default
1	engage_id	MITRE engage ID	char	10	
2	engage_name	MITRE engage Name	varchar	60	
3	engage_version	MITRE engage version	varchar	10	

- ATTACK_MITIGATION_MAPPING 테이블
  - (목적) ATT&CK Technique ID와 매핑된 Mitigation ID 1대1 저장
  - attack_id : MITRE ATT&CK Technique id 저장
  - mapping_miti : Technique과 매핑된 MITRE ATT&CK Mitigation id 저장

no	field	description	type	length	default
1	attack_id	(ref. ATTACK_LIST.technique_id)	char	10	
2	mapping_miti	(ref. MITIGATION_LIST.mitigation_id)	char	60	

- ATTACK_ENGAGE_MAPPING 테이블
  - (목적) ATT&CK Technique ID와 매핑된 ENGAGE ID 1대1 저장
  - attack_id : MITRE ATT&CK Technique id 저장
  - mapping_engage : Technique과 매핑된 MITRE Engage id 저장

no	field	description	type	length	default
1	attack_id	(ref. ATTACK_LIST.technique_id)	char	10	
2	mapping_engage	(ref. ENGAGE_LIST. engage_id)	char	10	

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- ATTACK_D3FEND_MAPPING 테이블
  - (목적) ATT&CK Technique ID와 매핑된 D3FEND ID 1대1 저장
  - attack_id : MITRE ATT&CK Technique id 저장
  - mapping_d3fend : Technique과 매핑된 MITRE D3fend id 저장

no	field	description	type	length	default
1	attack_id	(ref. ATTACK_LIST.technique_id)	char	10	
2	mapping_d3fend	(ref. D3FEND_LIST. d3fend_id)	char	10	

- CTI_INFO 테이블
  - (목적) 외부 위협정보 수집 및 TTP 추출을 위한 필요데이터인 CTI 데이터 저장
  - id(PK) : 수집한 CTI 정보 별 unique ID 값 부여
  - cti_title : 수집한 CTI 데이터의 제목 저장
  - file_path : CTI 데이터 저장 경로
  - collect_date : 수집 날짜 저장
  - create_date : CTI 생성 날짜

no	field	description	type	length	default
1	id	CTI ID	int	10	
2	cti_title	CTI 파일 이름	varchar	200	
3	file_path	저장경로	varchar	200	
4	collect_date	CTI 수집 날짜	date		
5	create_date	CTI 생성 날짜	date		

- CTI_TTP_MATCH 테이블
  - (목적) 수집한 CTI 데이터의 sentence 단위로 TTP ID 매칭한 결과 저장
  - sentence_id(PK) : CTI - 문장 단위별 unique ID 값 부여
  - cti_id : 수집한 CTI 정보의 ID 값 (ref: CTI_INFO.id)
  - cti_sentence : CTI 데이터 내 문장 단위 텍스트
  - match_technique : cti_sentence와 매칭된 TTP (ref: ATTACK_LIST.technique_id)

no	field	description	type	length	default
1	sentence_id	CTI_sentence 별 ID	int	10	
2	cti_id	(ref: CTI_INFO.id)	int	10	
3	cti_sentence	CTI text	text	-	
4	match_technique	매칭된 TTP ID	char	10	

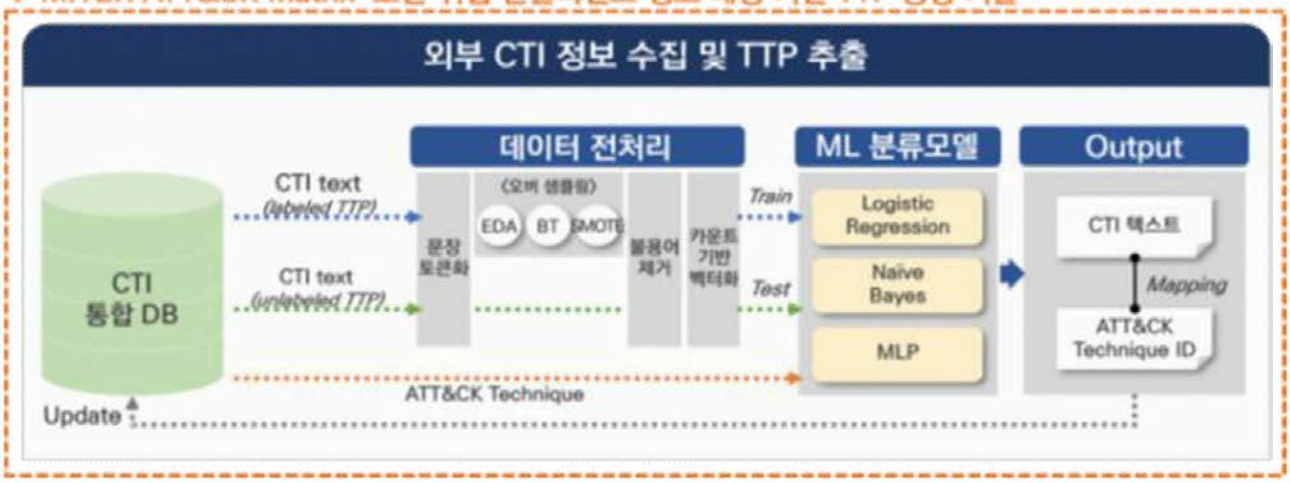
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

개발목표 ②	TTP 기반 위협 위협 인자 식별 기술 개발 완료

세부 내용	1) ATT&CK Matrix-보안 위협 인텔리전스 정보 매핑 기반 TTP 생성 기술 개발
	2) TTP 정보 기반 위협 인자 식별 기술 개발

1) MITRE ATT&CK Matrix-보안 위협 인텔리전스 정보 매핑 기반 TTP 생성 기술 개발

▼ MITER ATT&CK Matrix-보안 위협 인텔리전스 정보 매핑 기반 TTP 생성 기술



<MITRE ATT&CK Matrix-보안 위협 인텔리전스 정보 매핑 기반 TTP 생성 기술 개념도>

o 보안 위협 인텔리전스 정보 매핑 기반 TTP 생성 기술 관련 선행 연구 분석

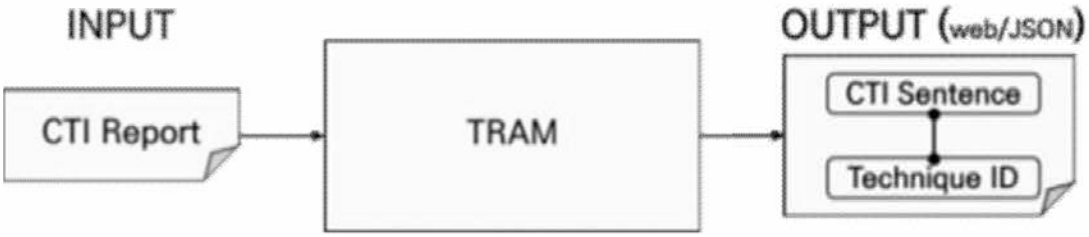
<보안 위협 인텔리전스 정보 매핑 기반 TTP 생성 기술 관련 선행 연구 >

Works	Objectives	Input	Approaches	Metrics	Performance
G.Huari	CTI Report -> CAPEC -> STIX Conversion	DOC	NLP and ML	PoC	187 techniques 19 Tactics
rcATT	CTI Report -> TTP Classification	DOC	TF-IDF, Word2Vec/AdaBoost	ACC	Tactics: 79.3% Techniques: 72.22%
G.Avoade	CTI Report -> TTP ATT&CK action	DOC	Similarity (TF-IDF)	ACC	Tactics: 63% Kill-Chain: 96.3%
A.Naikanlahiji	CTI Report -> TTP keywords	DOC	Similarity (TF-IDF)	PoC	445 reports
N.Kim	CTI Reprot -> IoC	DOC	NLP (SyntexNet)	F1	Keyword Extraction: 76%
Y.You	CTI Report -> TTP classification	SEN	Sentence-BERT embeddings/LSTM Classifier	F1	TTP level: 91%
TRAM	CTI Report -> TTP classification	SEN	Basic ML (LR, NB, MLP)	F1	Techniques: 50%~60%

*DOC-Document Type, SEN-Sentence Type

o 보안 위협 인텔리전스 정보 매핑 기반 TTP 생성 기술 설계
- (설계 방향) 선행 연구 모델을 베이스 모델로 하여 성능 개선 목표
- 베이스 모델로 선정한 선행 연구 모델인 TRAM 분석

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



<베이스 모델(TRAM) 개념도>

- (베이스 모델) MITRE TRAM - MITRE CTID에서 제공하는 오픈소스
- (분류 모델 훈련 데이터셋) X: 1,410 CTI sentence, Y: 100 Technique ID
- (분류 모델) Logistic Regression/Naive Bayes/MLP Classifier
- (성능 결과) 50~60% (Micro F1-score 기준)

- 베이스 모델을 기반으로 한 성능 개선 모델 설계
  - (분류 모델 훈련 데이터셋) TRAM 훈련 데이터셋 및 추가 수집 데이터셋
  - (분류 모델) Logistic Regression/Naive Bayes/MLP Classifier
  - (성능 개선 목표) 기존 베이스모델의 성능 결과보다 20% 이상 증가
  - (성능 개선 방법) 작은 크기의 데이터셋으로 인한 성능 이슈를 해결하기 위해 데이터 증강기법 및 오버샘플링을 사용하여 분류 모델의 성능을 개선

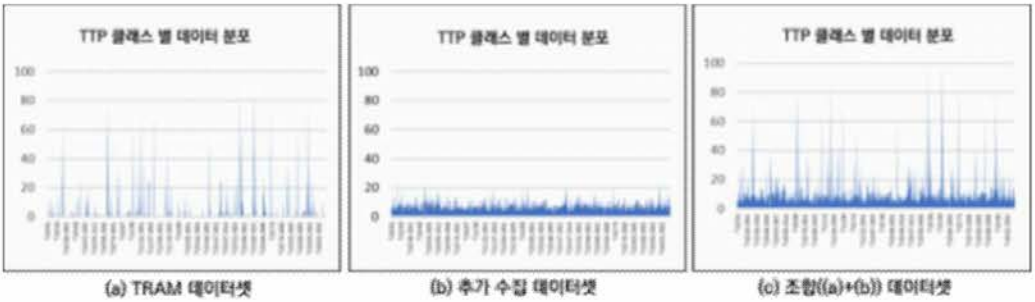
o 기존 모델 보완 구현 결과
- 분류 모델 훈련을 위한 데이터셋 구축
  - 총 3가지 데이터셋으로 구성 : TRAM / Our / Combined Datasets

<데이터셋별 피처 구성>

데이터셋	X (=sentence)	Y (=technique ID)	X per Y	
			최솟값	최댓값
TRAM 데이터셋	1,410	100	1	95
Our 데이터셋	4,250	578	1	24
Combined 데이터셋	5,660	578	2	103

- (TRAM 데이터셋) MITRE의 TRAM 모델의 훈련 데이터셋
  ※ 1,410개의 CTI 텍스트 문장과 100개의 ATT&CK Technique 사용
- (Our 데이터셋) MITRE ATT&CK에서 제공하는 Technique별 설명 수집
  ※ 4,250개의 CTI 텍스트 문장과 578개의 ATT&CK Technique 사용
- (Combined 데이터셋) 두 가지 데이터셋을 합친 데이터셋
  ※ 5,560개의 CTI 텍스트 문장과 578개의 ATT&CK Technique 사용

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

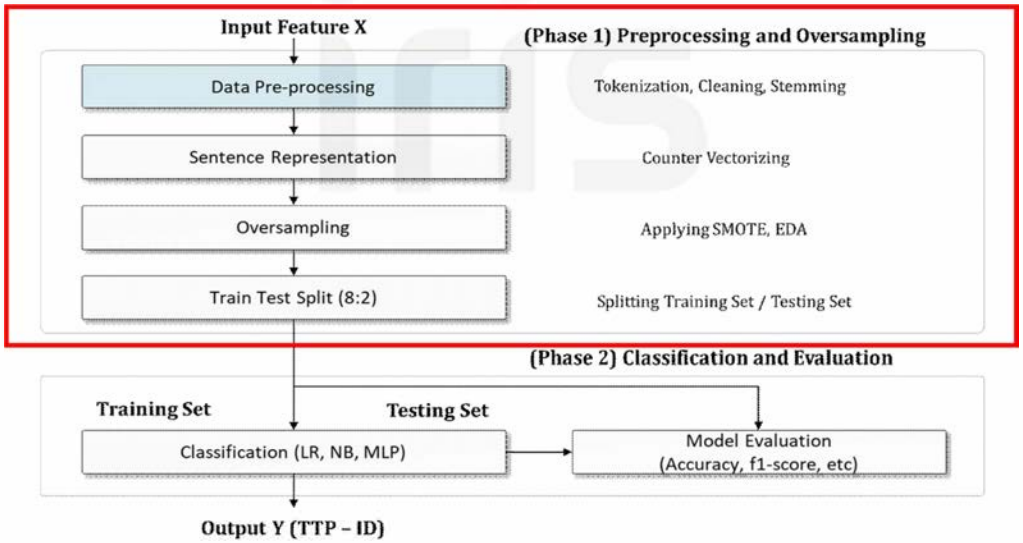


<훈련 데이터셋 TTP 클래스별 데이터 분포도>

<훈련 데이터셋 구성>

	X = technique id	Y = text
데이터셋 예시	T1189	"We believe this access was abused, for example by inserting malicious scripts in the..."
	T1071	"The initial DNS query sent by the payload to obtain the system specific identifier uses the..."
	T1036	"When the shellcode embedded within the malicious EPS is executed, the following..."
	T1548	"Adversaries may circumvent mechanisms designed to control elevate privileges to gain..."

- 분류 모델 성능 향상을 위한 3가지 데이터 전처리 방법 사용



<보안 위협 정보-TTP 생성을 위한 분류 모델 프로시저>

· 3가지 데이터 증강기법(리샘플링, SMOTE, EDA+BT)을 사용을 통해 훈련 데이터셋 증강 후 분류 모델 훈련을 진행하여 가장 높은 성능을 보이는 증강기법을 최종 모델에 적용

※ 리샘플링: 데이터를 단순 배수로서 증가

※ SMOTE: K-NN 알고리즘을 사용하여 인스턴스 수가 적은 클래스의 샘플을 추출하여 랜덤 값을 추가하여 새로운 인스턴스를 생성

※ EDA: 문장 내 동의어 대체, 임의 단어 삭제, 단어 재배치 등을 통해 새로운 인스턴스를 생성

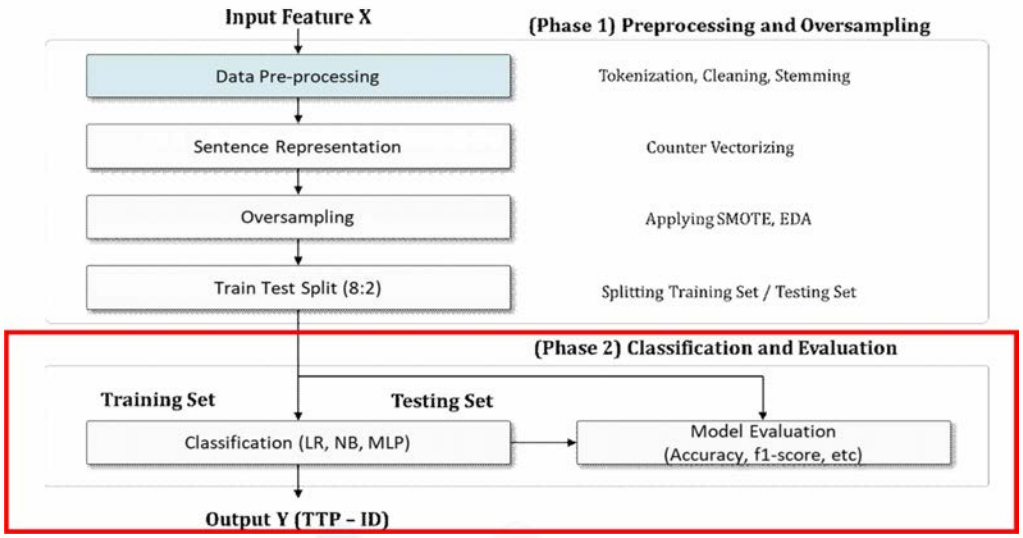
※ Back Translation: 원본 문장을 번역 후 역번역 진행하여 문장 형식이 완벽하지 않은, 노이즈를 갖고 있는 새로운 인스턴스 생성

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

<데이터 증강 기법별 데이터 변화>

데이터셋	Origin	Resampling	EDA+BT
TRAM 데이터셋	1,410	11,280	30,160
Our 데이터셋	4,250	34,000	84,870
Combined 데이터셋	5,660	45,280	115,030

- 머신러닝 기술을 이용한 CTI 정보 - TTP 매핑



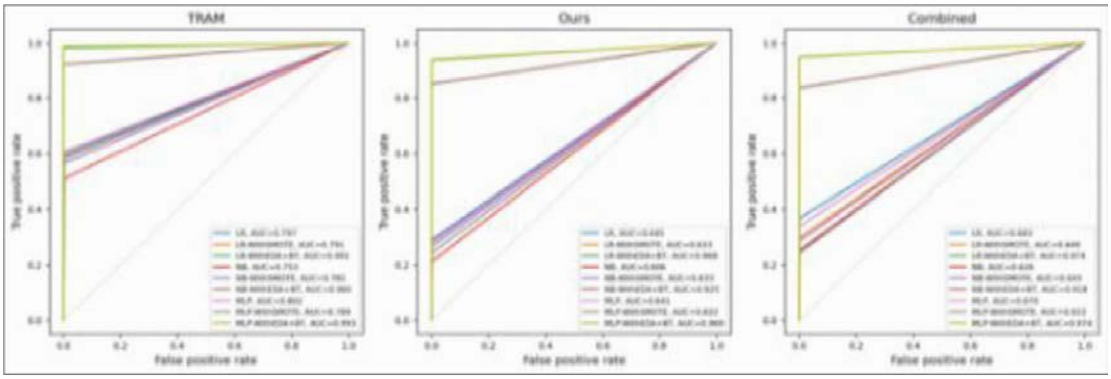
<보안 위협 정보-TTP 생성을 위한 분류 모델 프로시저>

· 3가지 분류모델 (Logistic Regression, Naive Bayes, MLP)을 사용하여 입력된 CTI 텍스트에 대한 ATT&CK TTP ID 예측 결과 추출

- 평가 방법 및 성능 결과

·(평가 방법) Micro F1-Score 및 Accuracy 점수를 통한 성능 평가, 기존 모델 비교

·(성능 결과) 베이스 모델 대비 20~30% 성능 증가



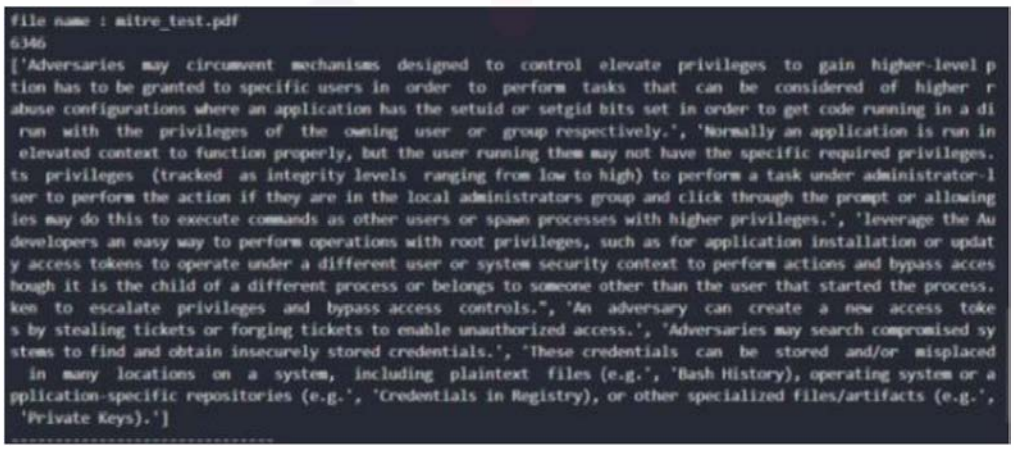
<데이터셋 별 BASE/SMOTE/EDA+BT 실험 결과 - ROC >

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

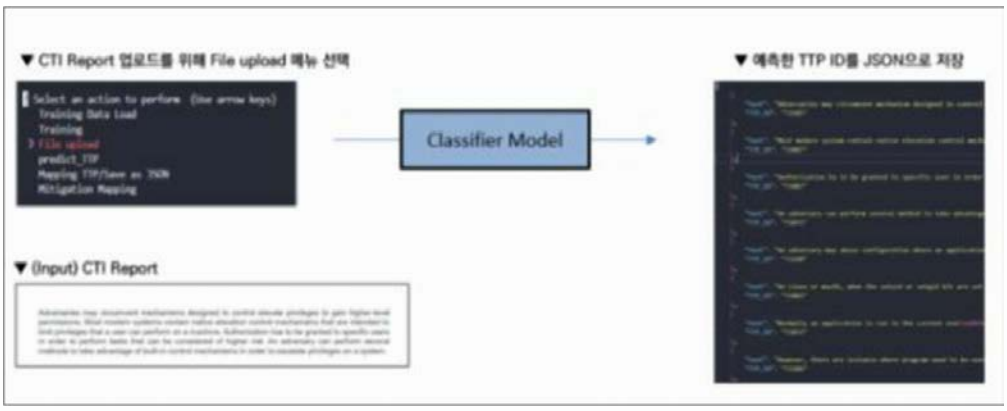
<데이터셋별 BASE/SMOTE/EDA+BT 실험 결과>

Models		TRAM Dataset			Our Dataset			Combined Dataset		
		ACC	F1	AUC	ACC	F1	AUC	ACC	F1	AUC
Base Model	LR	59.6	59.6	0.797	29.1	29.1	0.645	36.8	36.8	0.684
	NB	51.0	51.0	0.753	21.3	21.3	0.606	25.3	25.3	0.626
	MLP	61.3	61.3	0.808	27.9	27.9	0.647	35.6	35.6	0.668
	AVG	57.3	57.3	0.786	26.1	26.1	0.633	32.6	32.6	0.659
with SMOTE	LR	58.5	58.5	0.791	26.8	26.8	0.634	29.9	29.9	0.649
	NB	56.5	56.5	0.781	26.8	26.8	0.634	28.8	28.8	0.644
	MLP	58.2	58.2	0.791	25.7	25.7	0.620	26.2	26.2	0.627
	AVG	57.7	57.7	0.788	26.4	26.4	0.629	28.3	28.3	0.640
with EDA + BT	LR	98.2	98.2	0.991	93.6	93.6	0.968	94.8	94.8	0.974
	NB	92.1	92.1	0.960	85.1	85.1	0.925	83.6	83.6	0.918
	MLP	98.8	98.8	0.994	93.7	93.7	0.969	95.0	95.0	0.975
	AVG	96.4	96.4	0.982	90.8	90.8	0.954	91.1	91.1	0.956

- 비정형 보안 위협 인텔리전스 정보를 이용한 TTP 매핑 입출력 결과
  - 위협 보고서 파일 유형별 입력 시 텍스트 추출 결과
  - CTI 텍스트 문장 별로 예측된 TTP ID 결과를 JSON 형식으로 생성



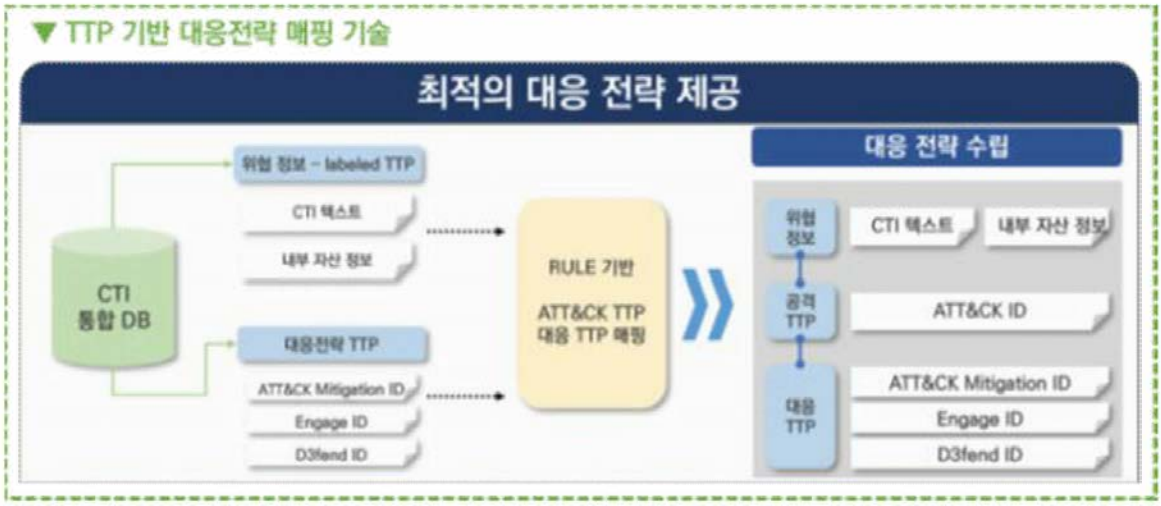
<위협보고서(PDF) 텍스트 추출 결과>



<CTI Report 업로드 및 CTI Sentence별 TTP ID 예측 결과 저장>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

o TTP 기반 대응전략 매핑 기술 설계



<TTP 기반 대응전략 매핑 기술 개념도>

- CTI 정보와 위협 자산정보에 매핑 된 TTP ID*와 대응 전략 ID를 자동으로 매핑

  * 보안 위협 인텔리전스 정보 매핑 기반 TTP 생성 기술과 TTP 정보 기반 위협 인자 식별 기술에서의 출력 결과

- 각 대응 전략별 ATT&CK Technique ID와 매핑 결과
  - Mitigation 매핑 결과: 42개의 Mitigation과 1026개의 ATT&CK Technique 매핑
  - Engage 매핑 결과: 22개의 Engage와 733개의 ATT&CK Technique 매핑
  - D3fend 매핑 결과: 51개의 D3fend와 1523개의 ATT&CK Technique 매핑

    ※ D3fend의 경우 총 85개의 technique 중 51개의 technique만 ATT&CK Technique과 매핑됨

<대응 전략 별 ATT&CK Technique ID 매핑 결과 예시>

구분	대응전략 ID	대응전략 ID 개수	Attack technique ID	Technique ID 개수
Mitigation	M1013	42	T1078, T1574, T1574.002	1,026
	M1015		T1003, T1003.005, T1003.006, T1072,...	
	M1016		T1190, T1195, T1195.001, T1195.002,...	
Engage	EAC0001	22	T1007, T1016, T1033, T1049,...	733
	EAC 0005		T1003, T1005, T1007, T1011, T1012,...	
	EAC 0013		T1027, T1047, T1092, T1204, T1216,...	
D3fend	D3-SAOR	51	T1211, T1190, T1055.012,...	1,523
	D3-SFCV		T1203, T1212, T1211,...	
	D3-PSEP		T1211, T1190, T1055.012,...	

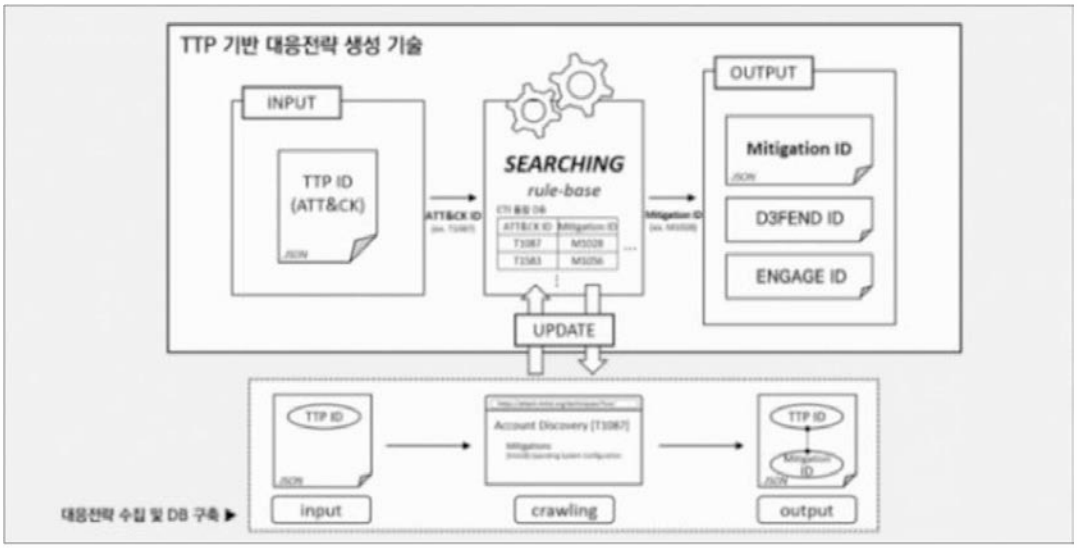
- (대응전략 ID 검색 모듈) 입력된 TTP ID(Technique ID)에 매핑된 대응전략 제공
  - 입력 정보: ATT&CK Technique ID
  - 출력 정보: 입력 받은 ATT&CK Technique ID에 매핑된 대응전략 ID

    ※ 대응전략 ID: MITRE에서 제공하는 Mitigation, Engage, D3FEND의 technique ID

<TTP 기반 대응전략 매핑 기술 입출력 정보>

입력 정보		출력 정보		
text	mapping_TTP_ID	Mitigation	Engage	D3fend
"Adversaries may circumvent..."	T1105	M1031,...	EAC0016,...	D3-CSPP,...
"These credential can be stored..."	T1003	M1015,...	EAC0005,...	D3-CAA,...
"The KDC is responsible for..."	T1087	M1028,...	EAC0014,...	D3-AL,...

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

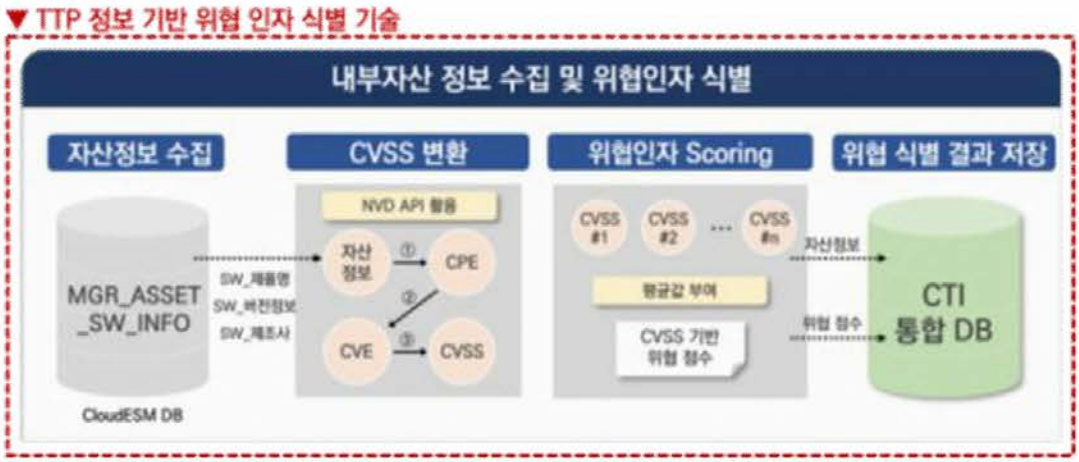


<TTP 기반 대응전략 생성 기술 세부 개념도>

o TTP 기반 대응전략 생성 기술 구현 결과

<TTP 기반 대응전략 생성 기술 구현 결과>

2) TTP 정보 기반 위협 인자 식별 기술 개발



<TTP 정보 기반 위협 인자 식별 기술 개념도>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

o TTP 정보 기반 위협 인자 식별 기술 설계

- (설계 목표) 자산 DB에 저장된 비정형 자산 정보를 정형화된 MITRE 보안 취약점 정보 구조(CPE, CVE, CVSS)로 자동으로 변환
- 입력 정보
  - 자산정보-CPE 변환을 위한 필수 자산 정보 : vendor, product, version
- 위협 인자 식별 방법
  - 수집된 내부자산의 위협 인자 식별을 위한 CPE-CVE-CVSS 변환
  - CVSS 점수를 통한 위협인자 Scoring
- 출력 정보
  - 수집된 내부 자산 정보와 해당 자산의 위협 점수

o TTP 정보 기반 위협 인자 식별 기술 구현

- 내부 자산정보 중 필수 수집 정보 정의
  - 필수 수집 정보 정의를 위해 자산정보-CPE 변환을 위한 CPE 구조 분석
  - (CPE 구조) cpe:cpe_version:part:vendor:product:version:update:edition:*:*:*:*
  - (CPE 예시) cpe:2.3:a:microsoft:internet_explorer:8.0.6001:beta:*:*:*:*:*

<CPE 구조 및 예시>

CPE 포함 정보	설명	예시
part	'a' : application / 'o' : operating system / 'h' : hardware devices	a
vendor	제품을 제조하거나 만든 사람 및 조직	microsoft
product	제품의 가장 일반적이고 인식 가능한 이름	internet_explorer
version	제품의 특정 릴리스 버전	8.0.6001
update	제품의 특정 업데이트, 포인트 릴리스 등	beta
other	edition, language, sw_edition, target_sw, target_hw, other	

  - CPE 구조로 변환하기 위한 최소 정보 및 수집 가능한 정보 리스트를 제조사(vendor), 제품명(product), 버전(version)으로 정의
  - 제조사, 제품명, 버전 정보를 기반으로 일치하는 CPE 검색

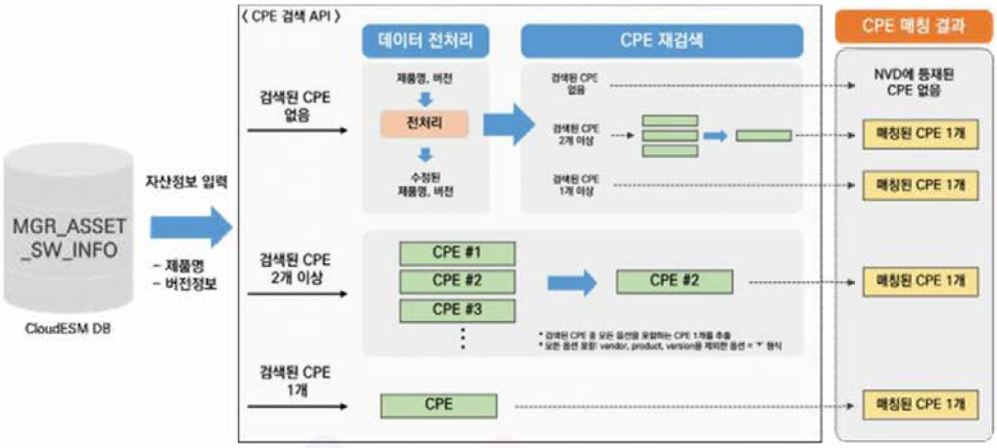
- 필수 수집 정보 리스트를 기반으로 한 내부 자산정보 수집 DB 구성
  - 제조사, 제품명, 버전 정보를 포함하는 MGR_ASSET_SW_INFO 테이블 구성
  - (sw_vendor) 제품의 제조사 정보 저장
  - (sw_version) 제품의 버전 정보 저장
  - (sw_prdouct) 제품의 제품명 정보 저장

sw_vendor	sw_version	sw_product	ip	asset_id
CentOS	15.8	cscope	59.18.107.244	23509377352728582
CentOS	1.9.20130304	byacc	59.18.107.244	23509377352728582
CentOS	1.20.4	xorg-x11-server-common	59.18.107.244	23509377352728582
CentOS	5.9	ncurses-base	59.18.107.244	23509377352728582
CentOS	2.0.10	swig	59.18.107.244	23509377352728582
CentOS	6.2.8	authconfig	59.18.107.244	23509377352728582
CentOS	5.8	ctags	59.18.107.244	23509377352728582
CentOS	10.0	basesystem	59.18.107.244	23509377352728582

<CloudESM 데이터베이스의 MGR_ASSET_SW_INFO테이블>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- 내부자산 정보 추출 및 CPE 변환 기능 구현
  - NVD에서 제공하는 검색 API를 활용하여 내부자산정보(제품명, 버전)와 일치하는 CPE 추출
  - 가장 유사도가 높은 CPE를 추출하기 위해 제조사, 제품명과 버전이 일치하고, 그 외 추가 옵션들은 모든 옵션을 포함하도록 "*" 을 취하여 CPE 선택
  - CPE 검색 API를 통해 1차 검색 후 검색된 CPE가 없는 자산정보의 경우, 전처리 과정을 통해 제품명 또는 버전을 수정하여 CPE 매칭 결과 개선



<자산정보 입력에 따른 CPE 매칭 결과>

  - 약 1,800개 DB 데이터 중 오류/중복값 제거 후 총 589개의 자산 정보 데이터를 검색 API를 활용하여 CPE를 추출한 결과 253개의 자산정보에 대해서 CPE 추출

<DB 데이터 내 총 자산 정보 중 CPE 매칭 비율>

DB 내 총 자산 수 (오류/중복값 제거)	589
CPE 매칭된 자산 수 (매칭 비율)	253(43%)
CPE 추출이 안된 비매칭 자산 수	336

  - 비매칭된 자산 336개를 NVD CPE Search 웹페이지를 통해 검색하여 CPE 존재유무 확인한 결과, 300개의 자산정보는 CPE가 없다는 것을 확인

<비매칭 자산 336개에 대한 비매칭 원인 리스트 및 CPE 존재 유무>

CPE 검색 비매칭 원인	총 개수	CPE O	CPE X
제품명에 '-' (하이픈)을 포함하고 있는 경우	164	7	157
버전에 '버전' 과 '업데이트' 가 포함되어 있는 경우	0	0	0
버전이 '날짜형식' 으로 되어 있는 경우	1	1	0
제품명이 약어로 되어있는 경우	1	1	0
제품명에 버전이 같이 포함되어 있는 경우	5	5	0
제품명에 해당 문자가 포함되어 있지만 배열이 다른 경우	2	2	0
CPE 상 제품명에 추가 단어가 붙어있는 경우	9	8	1
제품명에 특정 단어가 붙어있는 경우 (lib-)	55	6	49
위 케이스 외에 검색이 안된 경우	99	6	93
총합	336	36	300

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

· 총 자산 중 CPE가 있는 자산을 기준으로 87%의 CPE 매칭률 도출

※ DB에 저장된 총 자산 정보(오류/중복값 제거) : 589개

※ CPE를 가지고 있는 자산 정보 : 289개 (검색 API를 통한 CPE 추출 자산: 253개 + 웹검색을 통한 CPE 확인 자산 : 36개)

※ DB 데이터 중 CPE를 가지고 있는 자산을 기준으로 한 매칭률 : 87% (289개 중 253개 매칭)

<CPE가 있는 자산정보 수 기준의 CPE 매칭률>

총 자산 정보 수	CPE가 있는 자산	CPE 매칭된 자산 수	매칭률
589	289	253	87%

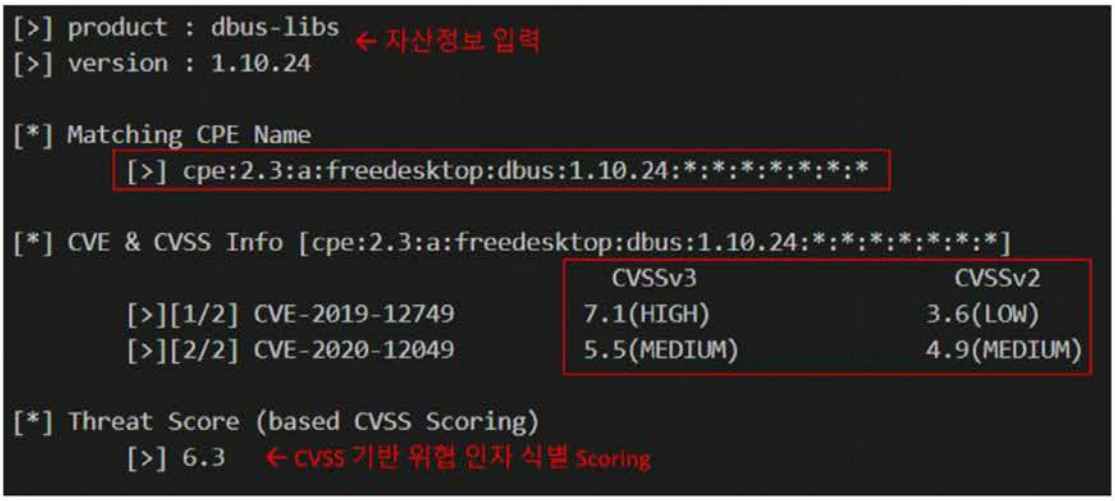
- CVSS 점수 추출을 위한 CPE-CVE-CVSS 변환 기능 구현

· NVD에서 제공하는 검색 API를 활용하여 CPE 변환 기능을 통해 추출된 CPE와 관련된 CVE를 검색하여 반환

· NVD에서 제공하는 검색 API를 활용하여 CVE 변환 기능을 통해 추출된 CVE와 매핑된 CVSS 검색하여 반환

<세부 기능별 입력값 및 출력값 예시>

세부 기능	입력값		출력값	
자산정보-CPE 변환 기능	제품명	'patch'	CPE	'cpe:2.3:a:gnu:patch:2.7.1:*:*:*:*:*:*:*'
	버전	'2.7.1'		
CPE-CVE 추출 기능	CPE	'cpe:2.3:a:gnu:patch:2.7.1:*:*:*:*:*:*:*'	CVE	'CVE-2015-1196'
				'CVE-2014-9637'
				...
CVE-CVSS 추출 기능	CVE	'CVE-2015-1196'	CVSS V3	None (None)
			CVSS V2	4.3 (MEDIUM)
		'CVE-2014-9637'	CVSS V3	5.5 (MEDIUM)
			CVSS V2	7.1 (HIGH)
		...	...	...

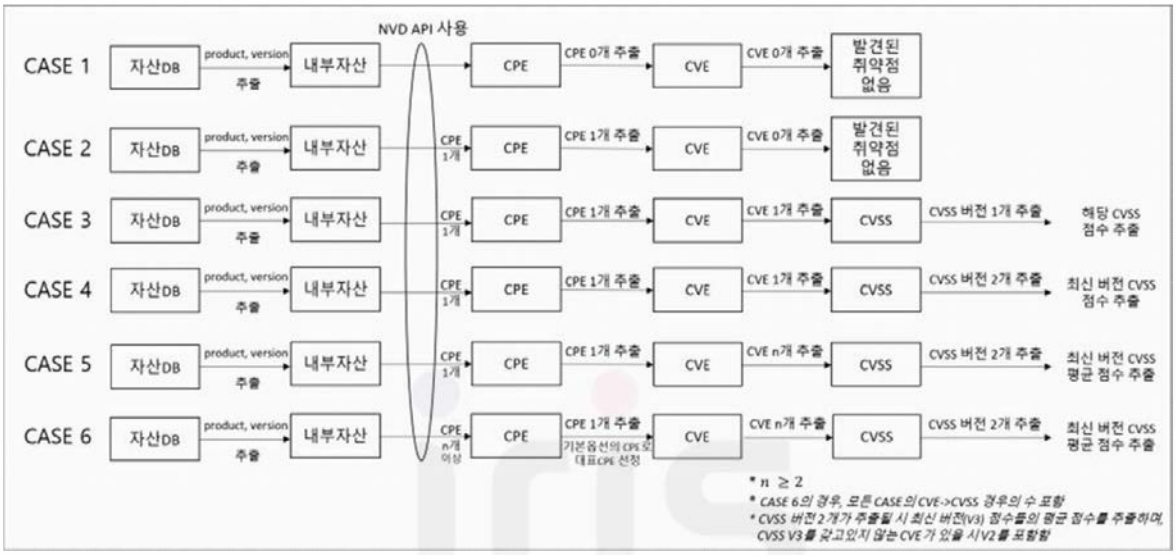


<CPE-CVE-CVSS 변환 기능 구현 결과 화면>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- CVSS 기반 위협 인자 식별 Scoring 기능 구현
  - 자산정보에 대한 CPE-CVE-CVSS 변환 기능을 통해 추출된 CVSS Scoring 점수들을 평균 내어 해당 자산의 위협 점수로서 산정
  - 불규칙성을 갖는 추출된 CVSS 값들은 정규분포의 형태를 띄우고 있음
  - 데이터의 불규칙성이 정규분포를 따르고 있으면, 최소제곱법이 가장 좋은 추정법이고, 그 결과 평균값이 좋은 추정법이 될 수 있음

- CPE-CVE-CVSS 변환 기능 및 CVSS 기반 위협 인자 식별 Scoring 기능 Case 별 구현 결과
  - 각 세부 기능 단계 추출 결과에 따라 6가지 CASE 정의



<CASE 1 2 3 4 5 6 자산DB product, version 추출 내부자산 CPE CPE 0개 추출 CVE CVE 0개 추출 발견된 취약점 없음 CPE 1개 추출 CVE 1개 추출 CVSS CVSS 버전 1개 추출 해당 CVSS 점수 추출 CVSS 버전 2개 추출 최신 버전 CVSS 점수 추출 CVE n개 추출 최신 버전 CVSS 평균 점수 추출 CPE n개 이상 기본옵션의 CPE로 대표CPE 선정 NVD API 사용 * n ≥ 2 * CASE 6의 경우, 모든 CASE의 CVE->CVSS 경우의 수 포함 * CVSS 버전 2개가 추출될 시 최신 버전(V3) 점수들의 평균 점수를 추출하며, CVSS V3를 갖고있지 않는 CVE가 있을 시 V2를 포함함>

<케이스별 CVSS Scoring 흐름도>

- (CASE 1) 내부자산 정보에 매칭된 CPE 0개 추출에 따른 CVE, CVSS 0개 추출
  ※ 내부자산에 매칭되는 CPE 값이 없으므로 해당 자산은 위협자산이 아닌 것으로 판단
- (CASE 2) 내부자산 정보에 매칭된 CPE 1개, CVE 0개 추출, CVSS 0개 추출
  ※ 내부자산에 매칭되는 CPE 값은 있지만, 매핑된 CVE, CVSS 값이 없으므로 취약점 없는 자산으로 판단

```
[*] CPE Name List
[>] product : logrotate
[>] version : 3.8.6
      ******[1/1] cpe:2.3:a:logrotate_project:logrotate:3.8.6:*:*:*:*:*:*:*

[*] CVE & CVSS Info [cpe:2.3:a:logrotate_project:logrotate:3.8.6:*:*:*:*:*:*:*]
[*] CVE is null...
```

<CASE 2 결과 화면: CPE 1개 추출 및 CVE, CVSS 0개 추출>

<NVD-Search 웹페이지에서 검색 시에도 CVE, CVSS 0개 추출 확인>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

· (CASE 3) 내부자산 정보에 매칭된 CPE 1개, CVE 1개 추출, CVSS 버전 1개 추출

※ CPE, CVE가 각 1개씩 추출되었으며, CVE의 매칭된 CVSS 또한 CVSSv3 또는 CVSSv2 중 1개의 버전 값만 추출되어 해당 CVSS 버전의 scoring 점수를 자산의 위협 점수로서 선정

```
[>] product : gzip
[>] version : 1.5

[*] Matching CPE Name
       [>] cpe:2.3:a:gnu:gzip:1.5:*:*:*:*:*:*:*

[*] CVE & CVSS Info [cpe:2.3:a:gnu:gzip:1.5:*:*:*:*:*:*:*]
                                    CVSSv3              CVSSv2
       [>][1/1] CVE-2022-1271       8.8(HIGH)           None(None)

[*] Threat Score (based CVSS Scoring)
       [>] 8.8
```

<CASE 3 결과 화면: CPE, CVE, CVSS 1개 추출>

· (CASE 4) 내부자산 정보에 매칭된 CPE 1개, CVE 1개 추출, CVSS 버전 2개 추출

※ CPE, CVE가 각 1개씩 추출되었으며, CVE의 매칭된 CVSS는 CVSSv3과 CVSSv2가 모두 추출되었으므로, 가장 최신 버전인 v3의 점수를 자산의 위협 점수로서 선정

```
[>] product : authconfig
[>] version : 6.2.8

[*] Matching CPE Name
       [>] cpe:2.3:a:authconfig_project:authconfig:6.2.8:*:*:*:*:*:*:*

[*] CVE & CVSS Info [cpe:2.3:a:authconfig_project:authconfig:6.2.8:*:*:*:*:*:*:*]
                                    CVSSv3              CVSSv2
       [>][1/1] CVE-2017-7488       4.3(MEDIUM)         4.0(MEDIUM)

[*] Threat Score (based CVSS Scoring)
       [>] 4.3
```

<CASE 4 결과 화면: CPE, CVE 1개 추출, CVSS 버전 2개 추출>

· (CASE 5) 내부자산 정보에 매칭된 CPE 1개, CVE, CVSS 각각 2개 이상 추출

※ CPE는 1개가 추출되었으며, CVE가 2개 이상, 각 CVE의 매칭된 CVSS 값이 2개 이상 추출되어 CVE 당 CVSS의 최신 버전인 V3 점수들의 평균값을 자산의 위협 점수로서 선정하며, CVSS V3 점수를 갖고있지 않은 CVE의 경우 CVSS V2의 점수를 더하여 평균값 산출

```
[>] product : patch
[>] version : 2.7.1

[*] Matching CPE Name
       [>] cpe:2.3:a:gnu:patch:2.7.1:*:*:*:*:*:*:*

[*] CVE & CVSS Info [cpe:2.3:a:gnu:patch:2.7.1:*:*:*:*:*:*:*]
                                    CVSSv3              CVSSv2
       [>][1/10] CVE-2015-1196      None(None)          4.3(MEDIUM)
       [>][2/10] CVE-2014-9637      5.5(MEDIUM)         7.1(HIGH)
       [>][3/10] CVE-2015-1395      7.5(HIGH)           7.8(HIGH)
       [>][4/10] CVE-2016-10713     5.5(MEDIUM)         4.3(MEDIUM)
       [>][5/10] CVE-2018-6951      7.5(HIGH)           5.0(MEDIUM)
       [>][6/10] CVE-2018-6952      7.5(HIGH)           5.0(MEDIUM)
       [>][7/10] CVE-2019-13636     5.9(MEDIUM)         5.8(MEDIUM)
       [>][8/10] CVE-2018-20969     7.8(HIGH)           9.3(HIGH)
       [>][9/10] CVE-2015-1396      7.5(HIGH)           6.4(MEDIUM)
       [>][10/10] CVE-2019-20633    5.5(MEDIUM)         4.3(MEDIUM)

[*] Threat Score (based CVSS Scoring)
       [>] 6.45
```

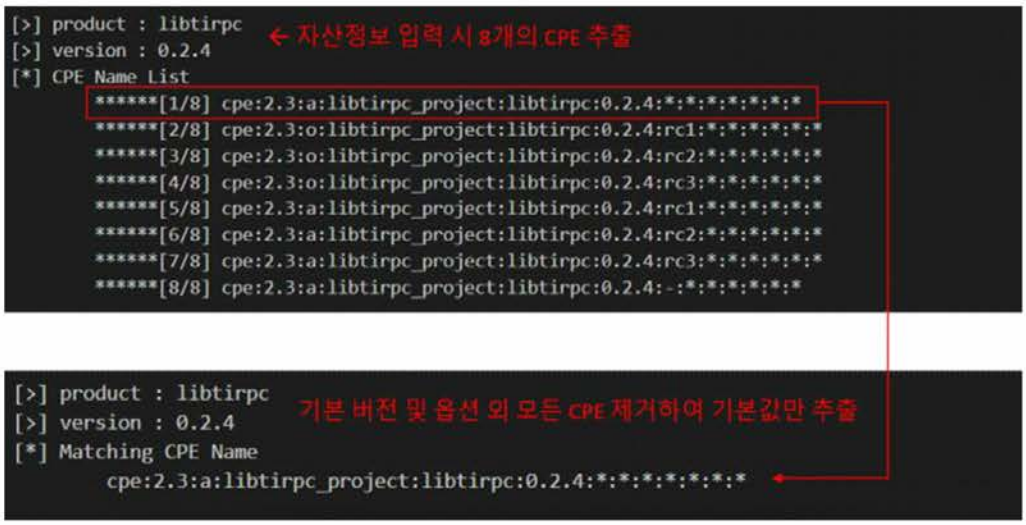
<CASE 5 결과 화면: CPE 1개 추출, CVE, CVSS 2개 이상 추출>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

· (CASE 6) 내부자산 정보에 매칭된 CPE 2개 이상 추출

※ CPE가 2개 이상 추출되었을 때, CPE에서 제조사, 제품명, 버전 정보를 제외한 기타 옵션들은 "*" 로 처리하여 가장 기본값인 CPE 1개 추출

※ CPE 추출 기능 외 CVE-CVSS Case들의 경우 CASE 1~5와 동일하게 적용



<CASE 6 결과 화면: CPE 2개 이상 추출 시 기본옵션을 가진 CPE로 매칭>

o TTP 정보 기반 위협 인자 식별 기술 전체 입출력 결과

- (입력 정보) 제품명(sw_product), 버전(sw_version)
- (출력 정보) 자산정보(vendor, product, version, asset_id, ip), CPE, CVSS 기반 위협 인자 스코어링 점수
- DB에 저장된 내부자산 정보를 쿼리를 통해 검색 API에 입력
  · CloudESM 데이터베이스의 MGR_ASSET_SW_INFO 테이블에서 쿼리를 이용하여 내부 자산 정보 데이터를 입력
- CVSS 기반 위협인자 scoring 기능 결과 출력 및 JSON 저장


```
{
    "sw_vendor": "CentOS",
    "sw_product": "gzip",
    "sw_version": "1.5",
    "asset_id": "23509377352728582",
    "ip": "59.18.107.244",
    "cpe": "cpe:2.3:a:gnu:gzip:1.5:*:*:*:*:*:*:*",
    "Threat Score": 8.8
},
{
    "sw_vendor": "CentOS",
    "sw_product": "patch",
    "sw_version": "2.7.1",
    "asset_id": "23509377352728582",
    "ip": "59.18.107.244",
    "cpe": "cpe:2.3:a:gnu:patch:2.7.1:*:*:*:*:*:*:*",
    "Threat Score": 6.45
},
{
    "sw_vendor": "CentOS",
    "sw_product": "authconfig",
    "sw_version": "6.2.8",
    "asset_id": "23509377352728582",
    "ip": "59.18.107.244",
    "cpe": "cpe:2.3:a:authconfig_project:authconfig:6.2.8:*:*:*:*:*:*:*",
    "Threat Score": 4.3
},
```


<TTP 정보 기반 위협 인자 식별 기술 JSON 저장 결과>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

개발목표 ③	보안 관제 플레이북 자동 생성 기술 연구 및 개발

세부 내용	1) 보안 관제 환경 및 템플릿 기반 플레이북 자동 생성 기술 개발
	2) 보안 위협의 대응 이력 학습을 위한 보안 관제 데이터 특성 연구

1) 보안 관제 환경 및 템플릿 기반 플레이북 자동 생성 기술 개발

o 플레이북 자동 생성 AI 학습 모델 개발

- 그래프 기반 AI 모델 개발

> 인접행렬(Adjacency matrix) 형태의 그래프와 정점의 속성 정보를 입력으로 받음.

> GNN 및 GraphRec 기반의 그래프 신경망을 이용하여 이웃 노드 간의 정보를 집계(aggregation)하고 업데이트 하는 과정을 반복하여 수행

> 연결성이 높은 노드를 바탕으로 플레이북 생성 및 추천을 수행하여 공격 이벤트에 대응하기 위한 최선의 대응 정책을 제시

```
# Model for recommendation
# init: definition of layers
# forward: definition of functions
class Model(nn.Module):
    def __init__(self, nfeat, nhid, nclass, dropout):
        super(Model, self).__init__()

        # graph embedding
        self.gcn = GCN(nfeat, nhid, dropout)

        # classifier
        # used three fully connected layers
        self.classifier = nn.Sequential(
            nn.Linear(nhid, nhid),
            nn.ReLU(),
            nn.Linear(nhid, nhid),
            nn.ReLU(),
            nn.Linear(nhid, nclass)
        )

    def forward(self, x, adj):
        emb = self.gcn(x, adj)
        out = self.classifier(emb)

        return out
```

< GNN 그래프 신경망 실행 코드 예시 (일부) >

```
def GraphRec(args, df_train, df_test, EventData=False, ResponseData=False, Graph=False):
    batch_size = args.batch_size
    epochs = args.epochs
    lr = args.learning_rate
    ew = args.ew
    rw = args.rw

    EVENT_NUM = df_train.event_id.nunique() # 3
    RESPONSE_NUM = df_train.response_id.nunique() # 13

    AdjacencyEvent = np.zeros((EVENT_NUM, RESPONSE_NUM), dtype=np.float32)
    DegreeEvent = np.zeros((EVENT_NUM, 1), dtype=np.float32)

    AdjacencyResponse = np.zeros((RESPONSE_NUM, EVENT_NUM), dtype=np.float32)
    DegreeResponse =  np.zeros((RESPONSE_NUM, 1), dtype=np.float32)

    for index, row in df_train.iterrows():
        eventid = int(row['event_id'])
        responseid = int(row['response_id'])

        AdjacencyEvent[eventid][responseid] = row['rating']/110.0
        AdjacencyResponse[responseid][eventid] = row['rating']/110.0

        DegreeEvent[eventid][0] += 1
        DegreeResponse[responseid][0] += 1
```

< GraphRec 그래프 신경망 실행 코드 예시 (일부) >

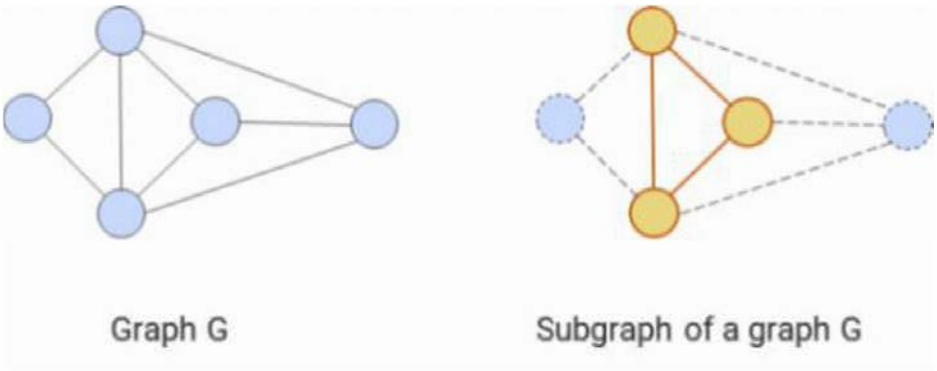
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- 부분 그래프 기능 기반 추천 기능 개발

> 공격 이벤트 유형에 대한 부분 그래프를 추출 후, 각 공격 이벤트의 부분 그래프에 존재하는 대응 절차를 예측

* 부분 그래프 (Sub-graph)

- 임의의 그래프에 대하여 일부 노드와 엣지로만 구성된 그래프
- 부분 그래프 매칭을 통해 공격 이벤트에 특화된 플레이북 결과물 생성 가능



< 전체 그래프와 부분 그래프 >

> 대응 추천 시, 부분 그래프 기반 및 전체 그래프 기반 두 가지 대응 절차를 플레이북으로 생성

> 각 이벤트에 해당하는 부분 그래프에 존재하는 대응 절차가 없을 시 전체 그래프 기반의 대응 절차를 플레이북으로 생성

- (예시) 전체 그래프 기반의 대응 절차는 'entire' 로 표현

```
if matched < 2: # base_seq is not exist in sub-graph => print based on entire graph
    alter_len = len(event)-matched-1 # matched == 0 => print two sequences
    for j in range(alter_len):
        res_id = event[j]

        base_seq = df_dict[df_dict['response_id'] == res_id]['response_seq'].values[0]
        print(" * (entire)", " ".join(map(str, base_seq)))

        check_exchange = exchange_seq(idx, base_seq, event_resseq_dict, df_dict)
        check_branch = branch_seq(idx, base_seq, event_resseq_dict, df_dict)

        if (check_exchange is not None) and len(check_exchange) != 0 and check_exchange != base_seq:
            print("   └(exchangeable) {}".format(check_exchange))

        if (check_branch is not None) and len(check_branch) != 0 and check_branch != base_seq:
            if type(check_branch[0]) == list: # check_branch = [[...], [...]], 즉 branch 가 발생하는
                for i in range(len(check_branch)):
                    print("   └(branch) {}".format(check_branch[i]))

            else:  # check_branch = [. . .], 즉 branch 가 발생하는 seq 가 여러 개인 경우
                print("   └(branch) {}".format(check_branch))
```

< 부분 그래프 기반 추천 표현 기능 예시 (일부) >

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

```
top-k response for event 28
 •   2 3 13
 • (entire) 2 3 13
top-k response for event 29
 •   2 3 18 16
 • (entire) 2 3 13
    └(branch) [2, 3, 18]
top-k response for event 30
 • (entire) 2 6 13
 • (entire) 2 11 6
top-k response for event 31
 •   2 6 13
 • (entire) 2 6 13
```

< 부분 그래프 기반 추천 표현 결과 예시 (일부) >

- 모델 결과 데이터 품질 상향을 위한 방향성 및 분기 기능 개발

> top-k 추천 시 교환이 가능한 컴포넌트 혹은 분기가 발생하는 경우, 컴포넌트 순서정보를 반영하여 결과를 생성하도록 하는 기능

> (기능1) 교환 가능성

· 기존의 대응 이력을 기반으로 교환 가능한 컴포넌트가 존재할 경우, 교환 가능한 컴포넌트를 괄호 안에 표현

```
def exchange_seq(base_seq, res_dict):
    if len(base_seq) == 1:
        return base_seq

    # check exchangeability based on dictionary from the dataset
    for i in res_dict:
        compare_seq = np.array(list(res_dict[i].values())).flatten().tolist()

        # make intersection list
        intersect = list(set(base_seq)&set(compare_seq))
        if len(intersect) > 1 and base_seq != compare_seq: # if compare_seq is exchangeable
            intersectlist1 = []
            intersectlist2 = []

            # using double for loop to consider the orders of intersection
            for i in range(len(base_seq)):
                for j in range(len(compare_seq)):
                    if base_seq[i] == compare_seq[j]: intersectlist1.append(base_seq[i])

            for i in range(len(compare_seq)):
                for j in range(len(base_seq)):
                    if compare_seq[i] == base_seq[j]: intersectlist2.append(compare_seq[i])
```

< 교환가능성 실행 코드 예시 (일부) >

·(예시) 테스트코드 결과로 <10 17 4 1 2>가 나왔을 시 4와 1이 교환 가능할 경우, 교환 가능함을 표현하는 'exchangeable' 와 함께 결과 출력을 <10 17 4(1) 1(4) 2>의 형태로 표현

```
top-3 response for event 0
  1. 10 13 9 0 4 2
  2. (branch) 10 17(13) 4 2
  3. 8
top-3 response for event 1
  1. (exchangeable) 10 17 4(1) 1(4) 2
  2. (branch) 10 4 2 11(5,9,12)
  3. 8
top-3 response for event 2
  1. 10 4 2 9 8
  2. (exchangeable) 10 1(4) 3 4(1) 16
  3. 8
```

< 교환가능성 실행 코드 예시(일부) >

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

> (기능2) 분기 발생

· 분기가 발생하는 컴포넌트가 존재할 경우, 분기를 이루는 대응 절차들을 표현

```
def branch_seq(base_seq, res_dict):
    compare_seqs = []

    # check branch sequences based on dictionary from the dataset
    for i in res_dict:
        compare_seq = np.array(list(res_dict[i].values())).flatten().tolist()

        # make intersection list
        intersect = list(set(base_seq) & set(compare_seq))

        if len(compare_seq) == len(base_seq) and len(intersect) == len(base_seq)-1:
            diff_base = list(set(base_seq)-set(compare_seq))[0]
            diff_compare = list(set(compare_seq)-set(base_seq))[0]
            if base_seq.index(diff_base) == compare_seq.index(diff_compare):  # append similar
                if compare_seq not in compare_seqs: compare_seqs.append(compare_seq)

    branch_str = str()

    # print branch
    if len(compare_seqs) == 1:  # single sequence that forms branch
        for j in range(len(base_seq)):
            diff = list(set(compare_seqs[0]) - set(base_seq))[0]
            if base_seq[j] == list(set(base_seq) - set(compare_seqs[0]))[0]:
                branch_str += str(base_seq[j]) + "(" + str(diff) + ") "
            else:
                branch_str += str(base_seq[j]) + " "
```

< 분기 실행 코드 예시 (일부) >

· (예시) 테스트코드 결과로 '10 17 4 2'가 나왔을 경우 '10-13-4' 의 분기가 발생할 시, 분기가 발생함을 표현하는 'branch'와 함께 분기가 발생하는 대응 절차를 출력

```
top-3 response for event 0
  1. 10 13 9 0 4 2
  2. (branch) 10 17(13) 4 2
  3. 8
top-3 response for event 1
  1. (exchangeable) 10 17 4(1) 1(4) 2
  2. (branch) 10 4 2 11(5,9,12)
  3. 8
top-3 response for event 2
  1. 10 4 2 9 8
  2. (exchangeable) 10 1(4) 3 4(1) 16
  3. 8
```

< 분기 실행 결과 예시 (일부) >

2) 보안 위협의 대응 이력 학습을 위한 보안 관제 데이터 특성 연구

o AI 학습 모델 적용 위한 데이터 전처리

- 보안관제 대응이력 기반 보안위협 이벤트 및 대응 절차 추출

  전처리 ① : 공격 이벤트 발생 건에 대한 공격·탐지명 및 행위 종류를 문자열 형태의 고유 ID값에서 숫자형 카테고리값으로 변환하기 위한 라벨 인코딩 수행

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

	occur_date	event	event_id	response	response_id
0	2021-08-03 14:15	웜 바이러스 피해	worm	Darknet으로 접속한 IP의 기관 조회	attconf
1	2021-08-03 14:15	웜 바이러스 피해	worm	도착지 Port번호 확인	portconf
2	2021-08-03 14:15	웜 바이러스 피해	worm	탐지로그 개수 확인	logconf
3	2021-08-03 15:54	웜 바이러스 피해	worm	메일 및 SMS을 통한 사고사례 통보	notice
4	2021-08-03 22:24	단순침입시도	intru	탐지 패턴명 확인	pattconf

< 문자열 형태의 ID 값을 가진 대응이력 데이터 예시 (일부) >

	occur_date	event_id	response_seq	response_id
0	2021-08-03 14:15	2	[4, 11, 7]	11
1	2021-08-03 15:54	2	[8]	14
2	2021-08-03 22:24	1	[10, 17, 4, 1, 2]	4
3	2021-08-04 10:30	1	[8]	14
4	2021-08-06 7:56	2	[10, 1, 3, 4, 16]	0

< 라벨 인코딩을 수행한 대응이력 데이터 예시 (일부) >

전처리 ② : 공격 이벤트 발생 건 별 공격·탐지명과 그에 대한 대응행위 절차를 각 키(key)-값(value) 쌍으로 매핑하는 사전(dictionary) 형태로 저장

```
{'2021-08-03 14:15': {'worm': [4, 11, 7]},
 '2021-08-03 15:54': {'worm': [8]},
 '2021-08-03 22:24': {'intru': [10, 17, 4, 1, 2]},
 '2021-08-04 10:30': {'intru': [8]},
 '2021-08-06 7:56': {'worm': [10, 1, 3, 4, 16]},
 '2021-08-09 16:03': {'worm': [8]},
 '2021-08-10 22:17': {'databr': [10, 13, 9, 0, 4, 2]},
 '2021-08-11 9:05': {'databr': [10, 13, 9, 0, 4, 2]},
 '2021-08-11 10:48': {'databr': [8]},
 '2021-08-11 14:37': {'databr': [8]},
 '2021-08-23 22:44': {'databr': [10, 17, 4, 2]},
 '2021-08-24 16:27': {'databr': [8]},
 '2021-08-25 22:18': {'databr': [10, 4, 2, 5]},
 '2021-08-27 15:55': {'databr': [8]},
 '2021-08-27 19:36': {'intru': [10, 17, 4, 2]},
```

< 사전 형태의 공격 이벤트 발생 건 별 공격·탐지명 및 대응행위 절차 예시 (일부) >

전처리 ③ : 사전(dictionary) 형태로 매핑된 공격·탐지명과 대응행위 절차를 Pandas 라이브러리의 Dataframe 형태로 저장

전처리 ④ : 각 공격 이벤트에 발생했던 모든 대응 절차들을 모아 한 번에 접근할 수 있도록 사전(dictionary) 형태로 저장

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

```
{34: [14, 41, 13, 43, 44, 47],
 32: [44],
 41: [1, 4, 2, 44, 8, 3],
 13: [45, 47, 41],
 12: [44, 47, 41],
 35: [44, 46],
 33: [44, 43, 41, 42],
 31: [43, 47, 44],
 14: [25],
 37: [19],
 10: [10, 0],
 48: [25, 38, 23, 48, 34, 28, 30, 44],
```

< 사전 형태의 각 공격 이벤트에 대한 모든 대응행위 절차 예시 (일부) >

o 대응이력 데이터 특성 분석

- 대응이력 데이터 내 컴포넌트 정보와 컴포넌트 간 연결성의 이해를 위하여 사회보장원 대응이력 기반 샘플 데이터(5,717건)에 대한 특성 분석을 수행

- 공격 이벤트의 특성 분석

> 공격에 대한 관제룰명(detection rule)을 기준으로 분류한 공격·탐지 컴포넌트 52종으로 구성

> 최다 발생 공격 이벤트

· 웹어플리케이션 취약점 공격시도 탐지(ISAC룰셋) - 410회

· 해외IP에서 거점시스템 접속 시도 - 301회

· 단일 IP에서 3가지 이상의 웹공격의 탐지 - 214회

- 대응의 특성 분석

> 대응 행위 컴포넌트 19종 및 발생한 이벤트에 대하여 행위 컴포넌트들이 실행된 대응 절차 51종으로 구성

> 최다 발생 대응 행위 컴포넌트

· 공격 시도 탐지 - 1,868회

· 공격 유효성 확인 - 1,288회

· 목적지 IP의 정보공유 요청 - 1,096회

> 최다 발생 대응 절차

· (공격 시도 탐지) -> (공격 유효성 확인) -> (목적지 IP의 정보공유 요청) - 639회

· (공격 시도 탐지) -> (공격 유효성 확인) -> (공격 시도에 포함된 URL 확인) -> (악성 URL 신고) - 268회

· (공격 시도 탐지) -> (지속적인 접근 확인) -182회

> 대응 절차 내 행위 컴포넌트 분석

· 대응 절차 51종 가운데, '공격 시도 탐지' 컴포넌트를 최초로 실행하는 절차가 49종, '목적지 IP의 정보공유 요청' 컴포넌트를 최후로 실행하는 절차가 20종으로 가장 다수임을 확인.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

개발목표 ④	보안 관제 플레이북 검증·관리 기술 설계 및 개발

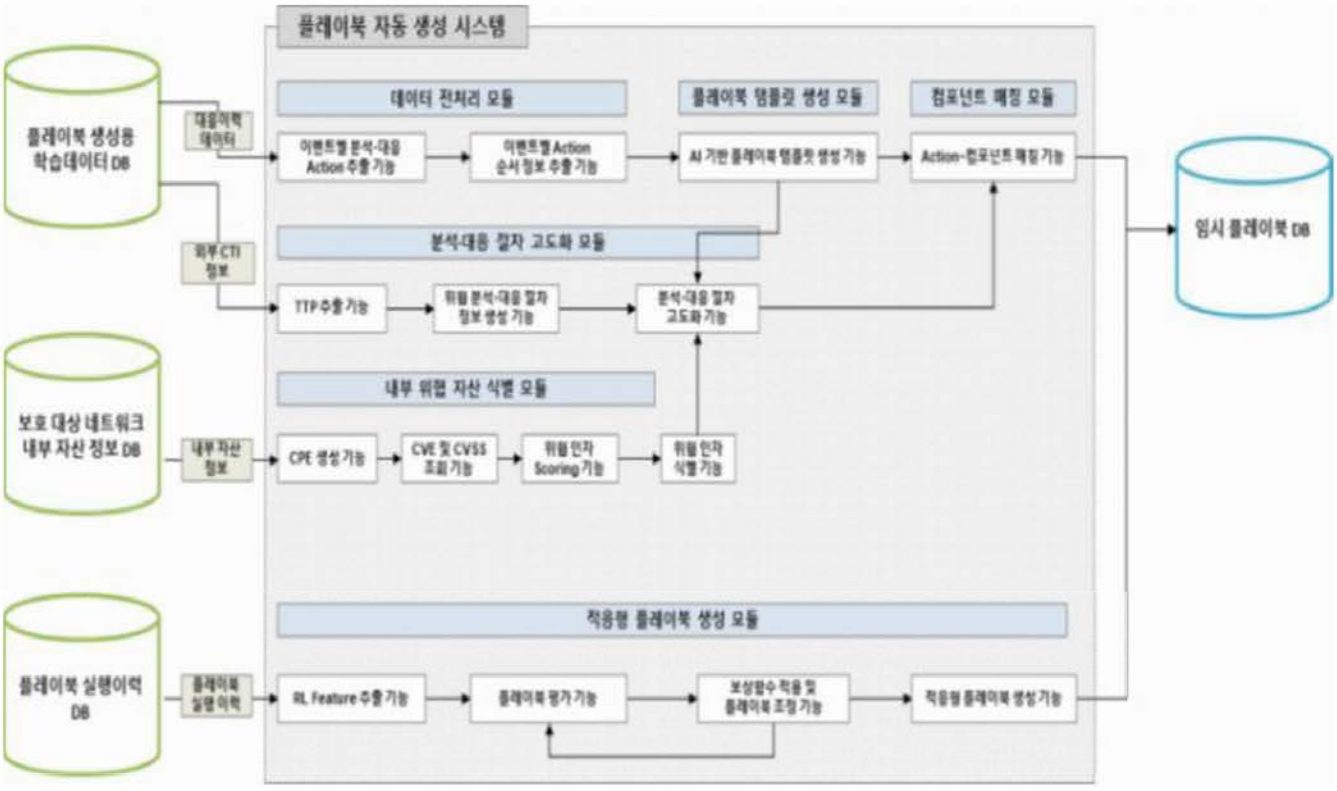
세부 내용	1) 자동 생성 플레이북의 유효성 검증 기술 설계
	2) 보안 관제 환경에 따른 플레이북 통합 관리 기술 개발

1) 자동 생성 플레이북의 유효성 검증 기술 설계

o 플레이북 자동 생성 및 유효성 검증용 데이터베이스

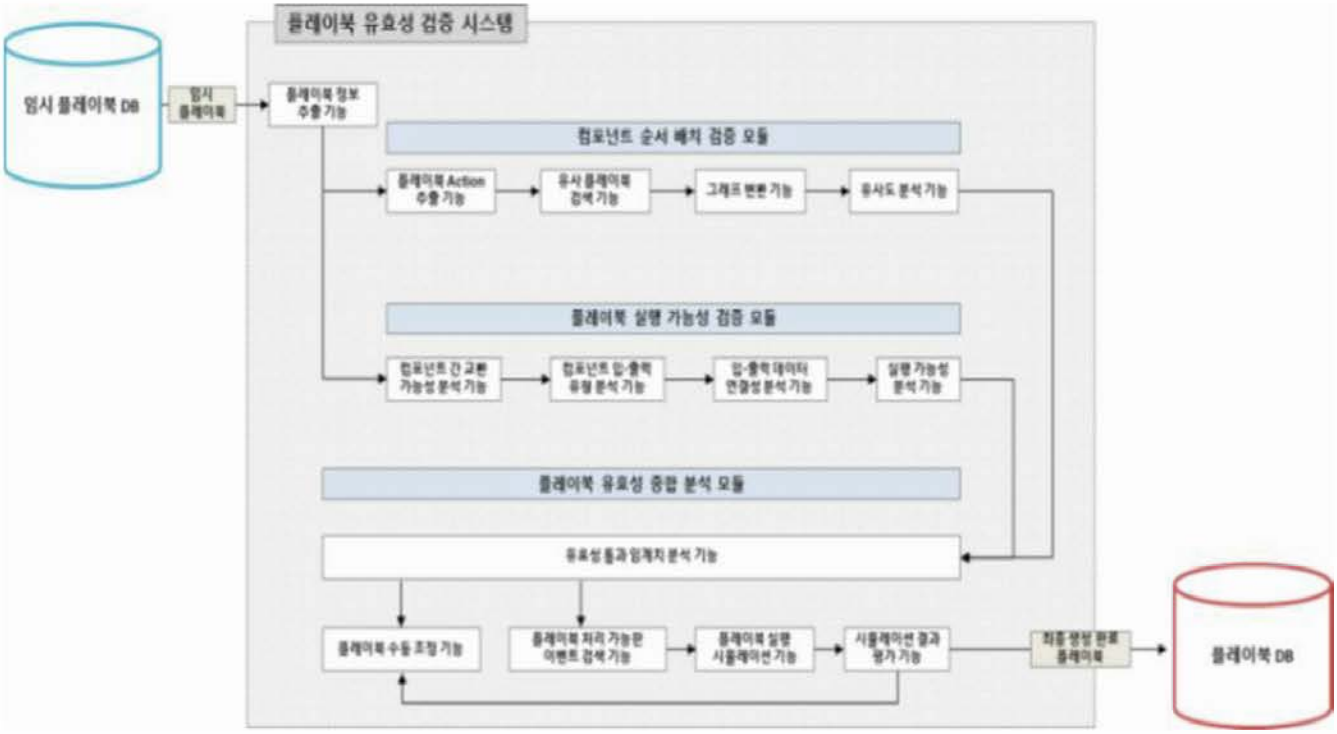
No.	데이터베이스명	저장 데이터
1	플레이북 생성용 학습데이터 DB	· SOC의 이벤트 대응이력 데이터 · 외부에서 수집한 CTI 정보
2	보호대상 네트워크 내부 자산 정보 DB	· 보호 대상 네트워크 시스템의 역할 · 설치 및 운영 중인 OS, SW Name, SW Version 등
3	플레이북 실행이력 DB	· 플레이북 실행 중 발생했던 오류 · 관제원의 수정사항 등
4	임시 플레이북 DB	· 자동 생성된 플레이북 (유효성 검증 필요 단계)
5	플레이북 DB	· 최종 생성 완료 플레이북 (유효성 검증 통과)

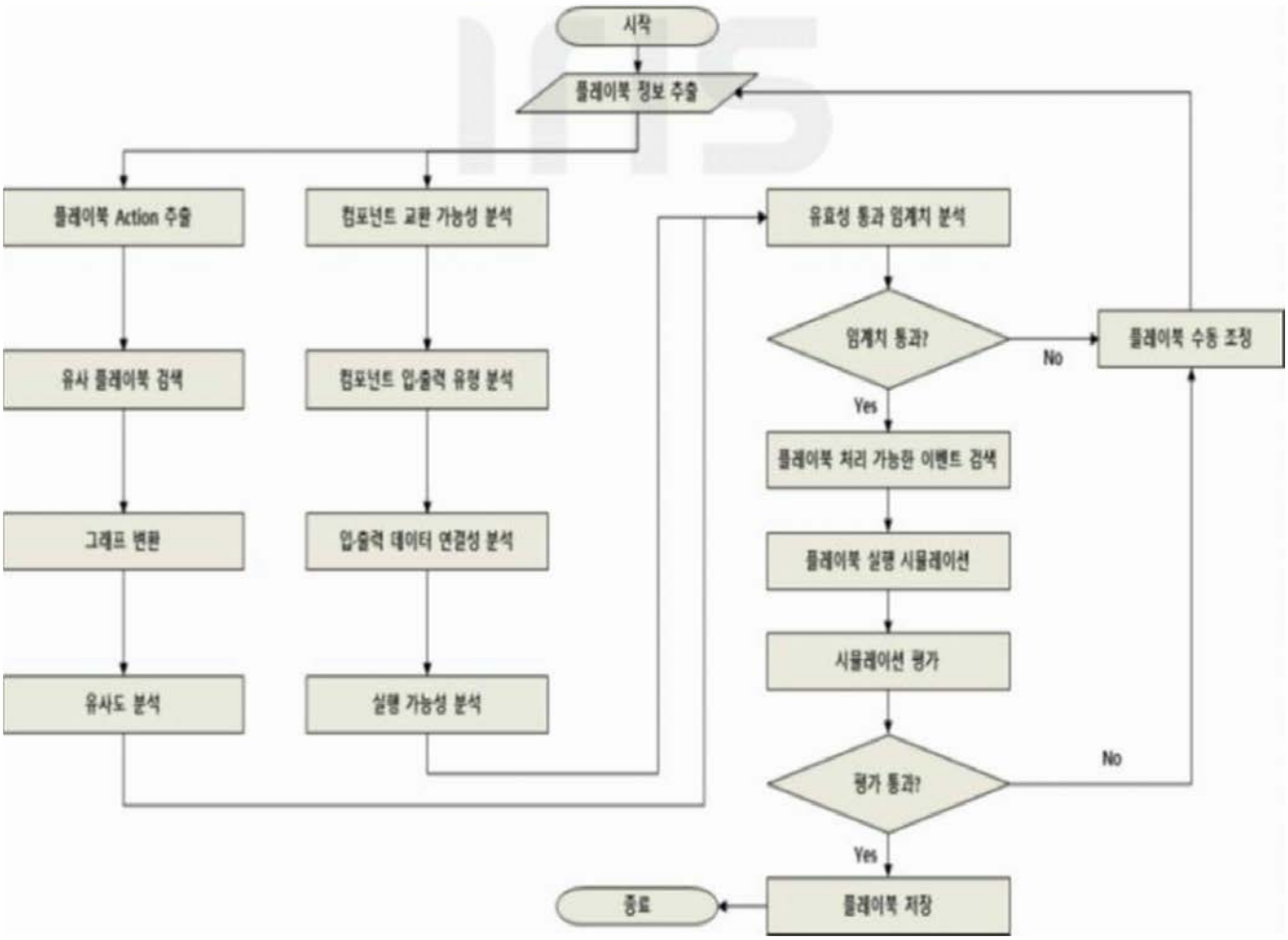
o 플레이북 자동 생성 기능 설계



국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

o 자동 생성 플레이북의 유효성 검증 기능 설계



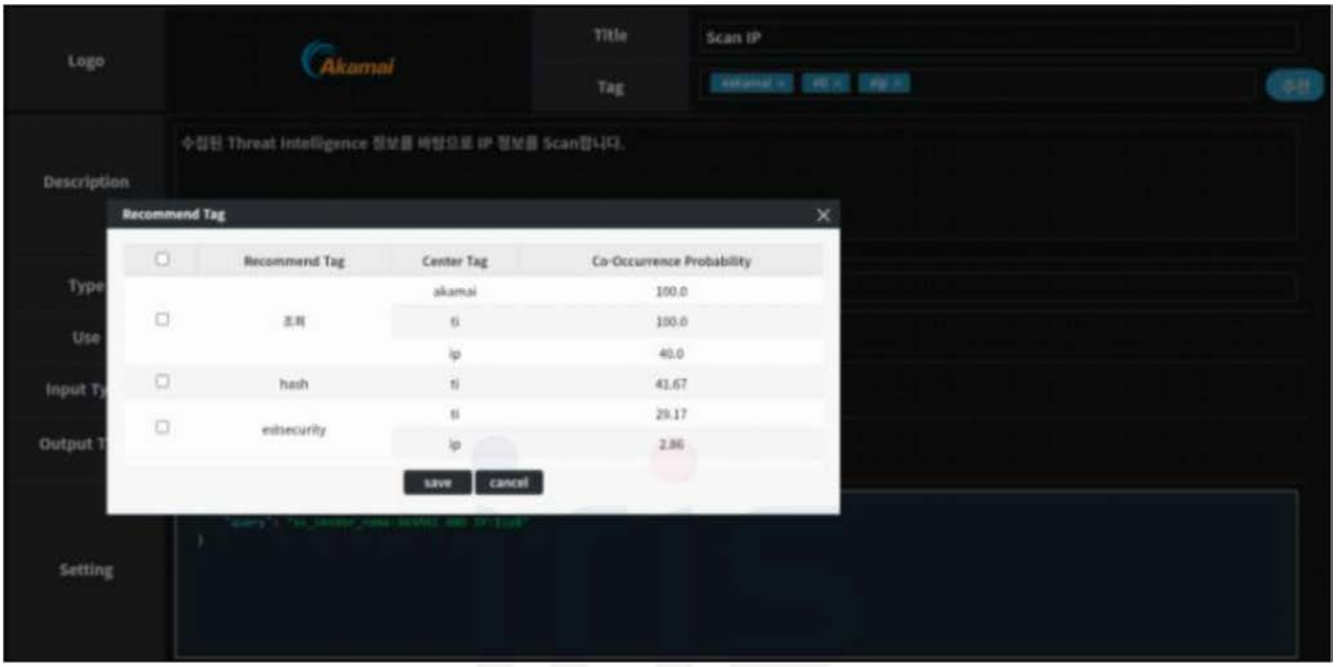


국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

2) 보안 관제 환경에 따른 플레이북 통합 관리 기술 개발

o 플레이북 및 컴포넌트 관리 태그 추천 기능 개발

- (배경 ①) SOC 운영이 지속될수록 관리 대상 플레이북 및 컴포넌트 개수 증가
- (배경 ②) 플레이북 및 컴포넌트의 역할 및 특성을 나타내는 태그 정보를 활용하여 특정 플레이북 및 컴포넌트 조회를 통한 관리 효율성 증가
- (개발 ①) 태그 정보 저장 · 관리 기능 및 동시 출현 결과 기반 태그 추천 기능 개발
- (개발 ②) 태그 정보 기반 플레이북 · 컴포넌트 검색 기능 개발



<태그 정보 기입 및 태그 추천 기능 예시 화면>

<태그 정보 기반 플레이북 · 컴포넌트 검색 기능 예시 화면('조회' 컴포넌트 검색)>

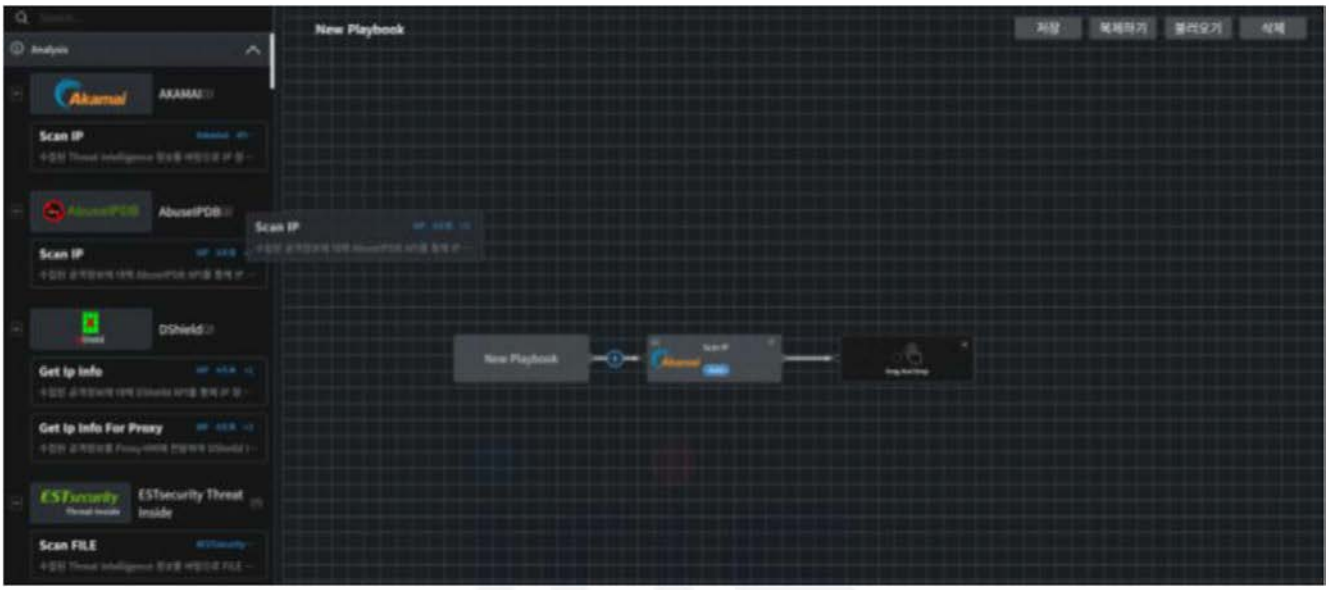
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

개발목표 ⑤	플레이북 시각화 및 관리 기술 개발

세부 내용	1) 사용자 정의 기반 보안 관제 플레이북 생성 및 관리 도구 개발
	2) 플레이북 요소 기술 실시간 수행 결과 시각화 도구 개발

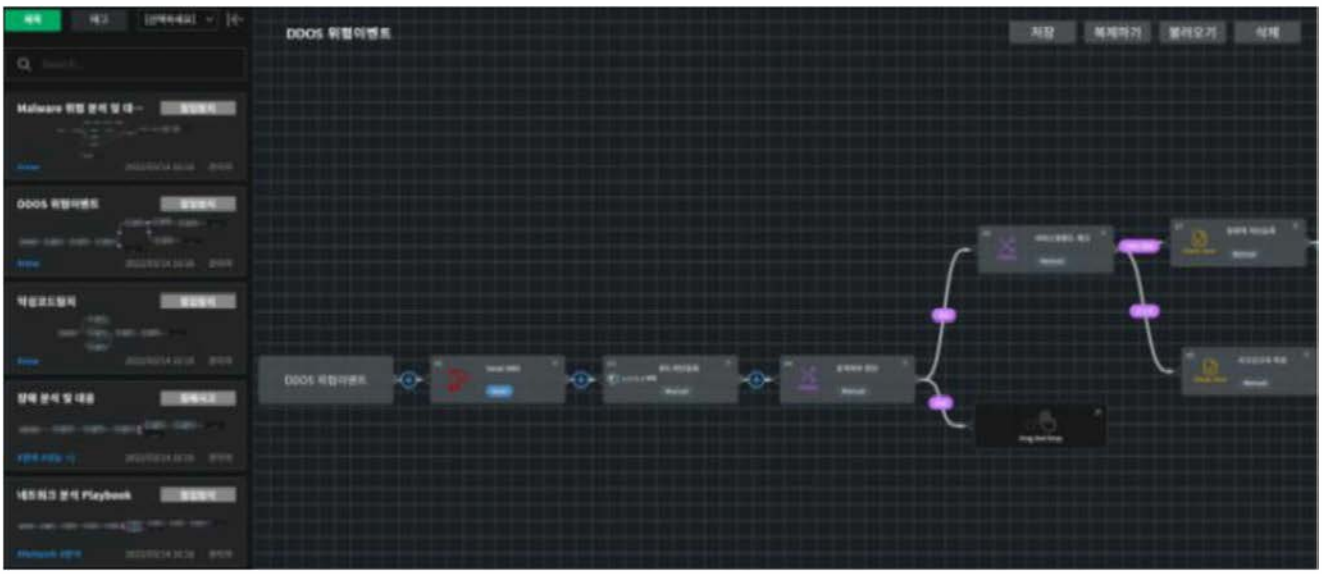
1) 사용자 정의 기반 보안 관제 플레이북 생성 및 관리 도구 개발

o 사용자 정의 기반 플레이북 생성 기능 개발



<사용자의 Drag & Drop으로 플레이북 생성 예시 화면>

o 플레이북 관리 기능 개발



<생성 완료된 플레이북 관리 예시 화면>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

2) 플레이북 요소 기술 실시간 수행 결과 시각화 도구 개발

o 플레이북 실행 이력 정보 관리 기능 개발

- 플레이북 생성 시간 정보
- 플레이북 최신 업데이트 시간 정보
- 플레이북 평균 · 최소 · 최장 실행 시간 정보
- 플레이북별 대기 · 실행 · 완료 · 실패 이력 정보
- 플레이북 내 컴포넌트 그룹 구성 정보(분석 · 알림 · 대응 · 유틸 · 분기)
- 플레이북이 처리한 이벤트 카운트 정보

<플레이북 실행 이력 정보 관리 기능 예시 화면>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

세부 기술 ③ SOC 활용 시각화 및 AI 기반 의사결정 요소 기술 개발

□ 개발 기술 개요

o (개발목표) SOC 활용 시각화 및 AI 기반 의사결정 요소 기술 개발

1) TTP 연관정보 시각화 기술 개발
2) 신속한 의사결정 지원을 위한 AI 분석 데이터셋 구축
3) AI 기반 최적 의사결정 자동 추천 기술 개발

o (추진실적) SOC 활용 시각화 및 AI 기반 의사결정 요소 기술 개발 완료

- 이기종 보안 장비 데이터 및 TTP 연관정보 가시화 기술 설계 및 개발 완료 **개발목표 1**
- 신속한 의사결정 지원을 위한 AI 분석 데이터셋 구축 완료 **개발목표 2**
- AI 기반 최적 의사결정 자동 추천 기술 개발 완료 **개발목표 3**

개발목표 ①	TTP 연관정보 시각화 기술 개발

세부 내용	
	1) 이기종 보안 장비 데이터 및 TTP 연관정보 가시화 기술 설계
	2) 이기종 보안 장비 데이터 및 TTP 연관정보 가시화 기술 개발

1) 이기종 보안 장비 데이터 및 TTP 연관정보 가시화 기술 설계

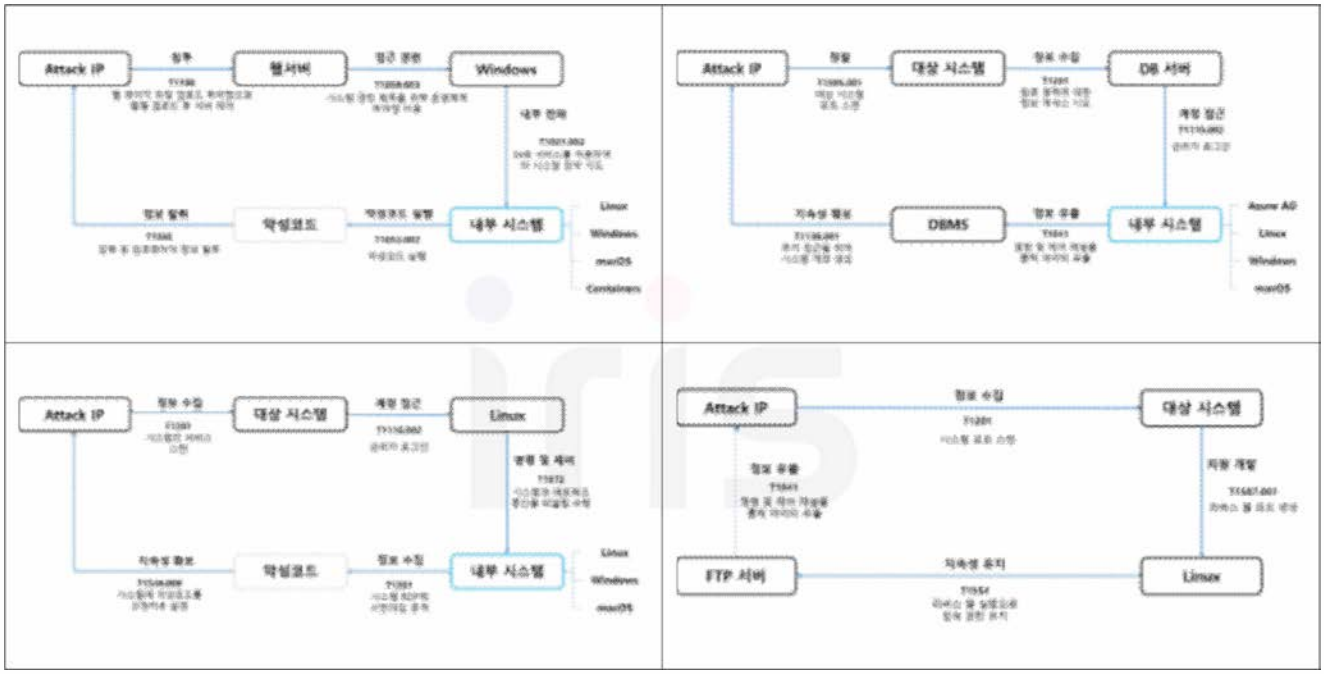
o 보안 위협 이벤트별 공격 예측 경로 분석

- 웹 페이지를 이용하여 서버 권한 탈취 후 시스템 장악 시도
  - 침투(T1190) : 공격자는 소프트웨어, 데이터 또는 명령을 사용하여 인터넷 접속 컴퓨터 또는 프로그램의 취약점을 이용하여 의도하지 않은 동작이나 예기치 않은 동작을 일으키려고 시도함
  - 접근 권한(T1059.003) : 공격자는 시스템 권환 획득을 위해 윈도우즈 명령쉘을 악용하여 사용자 목록 확인함
  - 내부 전파(T1021.002) : 공격자는 유효한 계정을 사용하여 서버 메시지 블록(SMB)을 사용하여 원격 네트워크 공유와 상호 작용하여 타 시스템 장악 시도함
  - 악성코드 실행(T1053.002) : at 유틸리티를 이용하여 악성코드의 최초 또는 반복 실행을 위한 태스크 스케줄링을 수행함

    ※ at 유틸리티는 윈도우즈, 리눅스, macOS 내에서 지정된 시간과 날짜에 작업을 예약하기 위한 실행 파일로 존재함
  - 정보 탈취(T1560) : 데이터를 압축 및/또는 암호화할 수 있음. 데이터를 압축하면 수집된 데이터를 난독화하고 네트워크를 통해 전송되는 데이터 양을 최소화할 수 있으며 암호화는 유출된 정보를 탐지로부터 숨기거나 방어자에 의한 검사 시 눈에 띄지 않기 위해 사용함
- 게시판 업로드 취약점을 악용하여 랜섬웨어 감염 시도
  - 침투(T1190) : 공격자는 소프트웨어, 데이터 또는 명령을 사용하여 프로그램의 취약점을 이용하여 예기치 않은 동작을 일으키려고 시도함. 게시판의 업로드 취약점 등을 웹쉘을 업로드하고 이를 통해 내부 환경 파악 및 추가 웹쉘 업로드 시도함

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- 권한 상승(T1068) : 공격자는 권한을 상승시키기 위해 소프트웨어 취약점을 이용하는데 이는 상대방이 프로그램, 서비스 또는 운영체제 소프트웨어 또는 커널 자체의 프로그래밍 오류를 이용하여 상대방에 제어하는 코드를 실행할 때 발생할 수 있음
- 권한 유지(T1548.001) : 다른 사용자 컨텍스트에서 코드를 실행하기 위해 응용 프로그램에서 setuid 또는 setgid 비트가 설정되어 있는 구성을 악용함
- 추적 회피(T1070.002) : 리눅스 및 macOS는 시스템 로그를 통해 시스템 또는 사용자가 시작한 작업을 추적할 수 있기에 공격자는 침입의 증거를 숨기기 위해 시스템 로그 삭제를 시도함
- 계정 확보(T1056.001) : 공격자는 사용자가 입력한 자격 증명을 가로채기 위해 사용자 키 입력을 기록할 수 있는데 키 로깅은 OS 자격 정보 덤핑 작업이 효과적이지 않을 때 새로운 접근 기회의 자격 정보를 취득하기 위해 사용될 수 있음
- 정보 탈취(T1486) : 로컬 및 원격 드라이브의 파일 또는 데이터를 암호화하고 암호 해독 키에 대한 액세스를 보류함으로써 저장된 데이터에 액세스할 수 없도록 함



<보안 이벤트별 공격 예측 경로 예시>

- 윈도우 환경에서 취약점을 악용하여 시스템 암호화 시도
  - 침투(T1190) : 공격자는 소프트웨어, 데이터 또는 명령을 사용하여 프로그램의 취약점을 이용하여 예기치 않은 동작을 일으키려고 시도함
  - 권한 상승(T1068) : 공격자는 권한을 상승시키기 위해 소프트웨어 취약점을 이용함
  - 계정 생성(T1136.001) : 공격자는 공격 대상 시스템에 대한 액세스를 유지하기 위해 로컬 계정을 생성할 수 있음. 로컬 계정은 원격 지원 또는 서비스 관리 등을 위해 설정한 계정으로 충분한 수준의 접근권을 가지면 'net user /add' 명령어를 사용하여 로컬 계정 생성을 시도함
  - 파일 삭제(T1070.004) : Malware, 툴 등이 공격자에 의해 시스템에 작성된 경우 네트워크 내에서 수행된 작업과 방법을 나타내는 흔적이 남을 수 있어 침입 중에 삭제를 시도함
  - 정보 탈취(T1587.001) : 공격자는 malware를 개발하여 원격 머신의 제어 유지, 방어 회피 및 타협 후 동작을 실행하기 위한 수단을 만들 수 있음

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- 정보 탈취(T1486) : 로컬 및 원격 드라이브의 파일 또는 데이터를 암호화하고 암호 해독 키에 대한 액세스를 보류함으로써 저장된 데이터에 액세스할 수 없도록 함

- SMB 프로토콜 취약점을 악용하여 시스템 장악 및 확대 시도
  - 대상 탐색(T1135) : 윈도우즈 네트워크를 통한 파일 공유는 SMB 프로토콜을 통해 수행되는데 네트워크에는 공유 네트워크 드라이브 및 폴더가 포함되어 있어 다양한 시스템의 파일 디렉토리를 탐색하여 원격 소프트웨어 악용에 취약할 수 있는 대상을 탐색을 시도함
  - 권한 상승(T1203) : 공격자는 클라이언트 응용 프로그램의 소프트웨어 취약점을 이용하여 코드 실행하여 원격 시스템에 대한 액세스를 시도함
  - 공격 수행(T1496) : 서버와 클라우드 기반 시스템 혹은 사용자 엔드포인트를 손상시켜 시스템 리소스를 가로채 가상화폐 네트워크의 트랜잭션을 검증하고 가상화폐 획득을 시도할 수 있음
  - 내부 확산(T1210) : 공격자는 네트워크 내에서 원격 서비스를 악용하여 내부 시스템에 대한 무단 액세스 획득을 시도함
  - 파일 삭제(T1070.004) : 멀웨어, 툴 등이 공격자에 의해 시스템에 작성된 경우 네트워크 내에서 수행된 작업과 방법을 나타내는 흔적이 남을 수 있어 침입 중에 삭제를 시도함
- 취약한 접근제어 설정을 악용하여 데이터 유출 시도
  - 정찰(T1595.001) : 공격자는 IP를 스캔하여 공격 대상자 네트워크 정보(현재 사용중인 IP 주소 및 이러한 주소가 할당된 호스트에 대한 자세한 정보 등) 수집을 시도함
  - 정보 수집(T1201) : 기업 네트워크 또는 클라우드 환경에서 사용되는 암호 정책(추측하거나 Brute Force를 통해 알아내기 어려운 패스워드를 강제하는 방법)에 대한 세부 정보에 접근을 시도함
  - 계정 접근(T1110.002) : 공격자는 암호 해시 등의 인증 정보를 얻을 때 암호 크래킹을 사용하여 일반 텍스트 암호와 같은 사용 가능한 인증 정보를 복구하려고 시도함
  - 정보 유출(T1041) : 공격자는 기존 명령 및 제어 채널을 통해 데이터를 유출함으로써 획득을 시도함
  - 지속성 확보(T1136.001) : 공격자는 공격 대상 시스템에 대한 액세스를 유지하기 위해 로컬 계정(원격 지원 또는 서비스 관리 등을 위해 설정한 계정) 생성을 시도함
- SSH 서비스 취약점을 악용하여 내부망 시스템 장악 시도
  - 정보 수집(T1201) : 기업 네트워크 또는 클라우드 환경에서 사용되는 암호 정책에 대한 세부 정보 접근을 시도함
  - 계정 접근(T1110.002) : 공격자는 암호 해시 등의 인증 정보를 얻을 때 암호 크래킹을 사용하여 일반 텍스트 암호와 같은 사용 가능한 인증 정보를 복구하려고 시도함
  - 명령 및 제어(T1572) : 공격자는 별도의 프로토콜 내에서 시스템과 네트워크 통신을 터널링하여 탐지/네트워크 필터링을 방지하거나 도달할 수 없는 시스템에 액세스를 시도함
  - 정보 수집(T1201) : 기업 네트워크 또는 클라우드 환경에서 사용되는 암호 정책에 대한 세부 정보 접근을 시도함
  - 지속성 확보(T1546.008) : 공격자는 접근성 기능(고정키)에 의해 트리거되는 악의적인 콘텐츠를 실행함으로서 지속성을 확립하거나 권한 상승을 시도함
- 취약한 FTP 설정을 악용하여 내부 시스템 접근 시도

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- 정보 수집(T1201) : 기업 네트워크 또는 클라우드 환경에서 사용되는 암호 정책에 대한 세부 정보 접근을 시도함
- 정보 탈취(T1587.001) : 공격자는 malware를 개발하여 원격 머신의 제어 유지, 방어 회피 및 타협 후 동작을 실행하기 위한 수단을 만들 수 있음
- 지속성 유지(T1554) : 공격자는 클라이언트의 소프트웨어 바이너리를 수정하여 시스템에 대한 지속적인 액세스 설정을 시도함
- 유출(T1041) : 공격자는 기존 명령 및 제어 채널을 통해 데이터를 유출함으로써 획득을 시도함

2) 이기종 보안 장비 데이터 및 TTP 연관정보 가시화 기술 개발

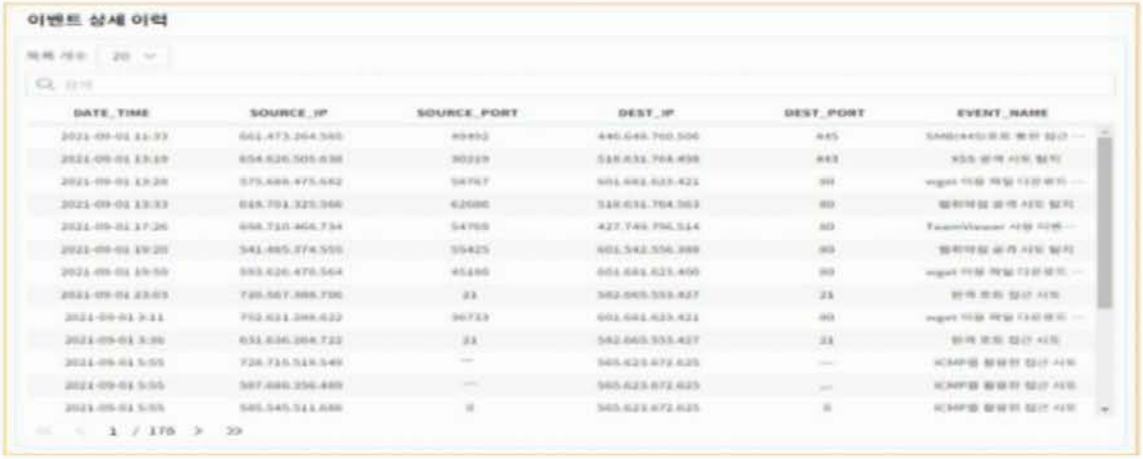
o 특정 발신지 보안 이벤트 상세 내역 가시화

- 보안 이벤트 발생 이력 정보 생성
  - 메모리 DB에 보안 이벤트 발생 이력 저장 및 이벤트 발생 시각, 발신지 IP에 대한 Index 생성

```
def main():
        if(len(sys.argv) != 3):
                print ("Usage : setRedis.py file table")
                sys.exit()

        fileName = sys.argv[1]
        tableName = sys.argv[2]

        confObj = configparser.ConfigParser()
        confObj.read('/home/soar/config/config.ini')

        address = confObj.get("Redis", "Address")
        (ip,port) = re.split(":",address)
        clr = redis.Redis(host=ip, port=port, db=0,charset="utf-8",decode_responses=True)

        fp = open(fileName,'r')

        for line in fp:
                (key,value) = re.split(",",line[:-1])

                values = clr.hset(tableName, key, value)
                print(values,id,value)
```

<메모리DB 데이터 저장 예시>

- 보안 이벤트 상세 내역 조회 기능
  - 특정 발신지 IP에 대한 보안 이벤트 상세 내역 가시화 기능 개발



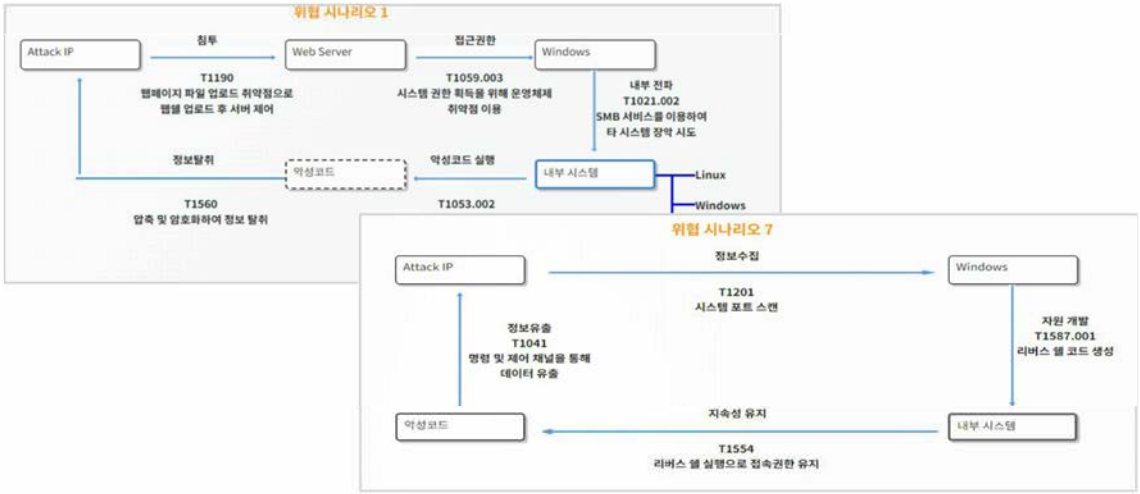
<보안 이벤트 상세 내역 조회 UI 예시>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

o 보안 이벤트 유형별 위협 가시화

- 보안 이벤트별 공격 경로 정보 생성

· 메모리 DB에 보안 이벤트별 공격 경로 정보 생성 및 이벤트에 대한 Index 생성



<보안 위협 정보 가시화 시나리오 예시>

- 보안 이벤트별 위협 가시화 기능

· 특정 보안 이벤트에 대한 공격 경로 정보 가시화 기능 개발

<보안 위협 정보 가시화 UI 예시>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

개발목표 ②	신속한 의사결정 지원을 위한 AI 분석 데이터셋 구축

세부 내용	1) 대용량 보안관제 이벤트의 특징 중요도 분석 및 추출 기술 개발
	2) 알려진 공격의 신속한 대응을 위한 보안관제 이벤트 유형별 학습 데이터 셋 구축
	3) 의사결정 신속성 향상을 위한 중요 위험 보안이벤트 학습 데이터셋 구축

1) 대용량 보안관제 이벤트의 특징 중요도 분석 및 추출 기술 개발

o 단일 값으로 표현되는 보안이벤트 메타정보를 다중 값으로 변환하여 추출하는 특징정보 확장기법을 통해 보안이벤트 정·오탐 분류모델 성능 개선

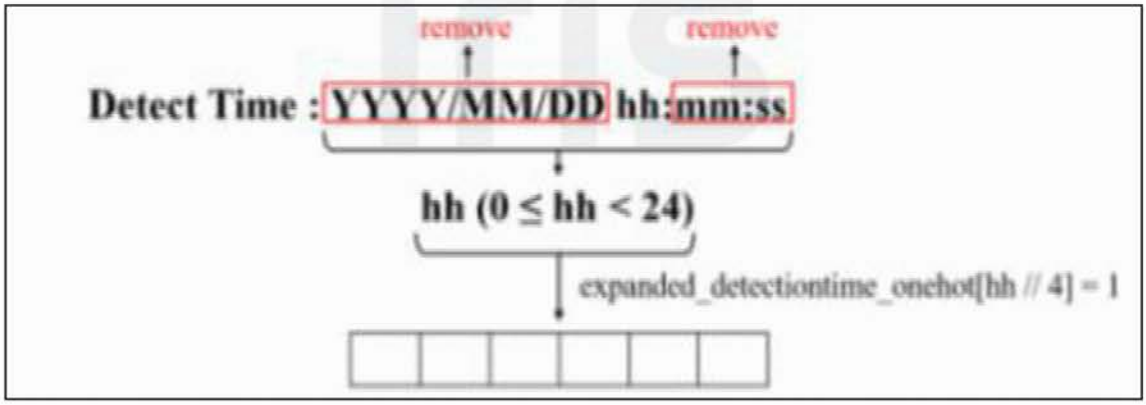
- 實 보안관제 환경적용을 고려하여 대용량 보안관제 이벤트 행위 특성을 효율적으로 표현할 수 있는 저비용·고효율 특징정보 확장기법 연구

- 시간정보 확장을 통한 AI 모델 정확도 향상 연구

⇒ 사용자의 반복되는 일일 업무 프로세스에 의해 주기적인 오탐이벤트가 발생하는 특성과 보안이 취약해지는 업무시간 외 시간대에 정탐이벤트가 발생하는 특성을 이용하여 탐지시각 정보를 주요 특징으로 활용

⇒ 하루(24시간)를 4시간씩 6개 시간대로 등분하여 원핫(one-hot) 벡터 생성

※ [0:00 ~ 04:00], [04:00 ~ 08:00], ..., [20:00 ~ 24:00]



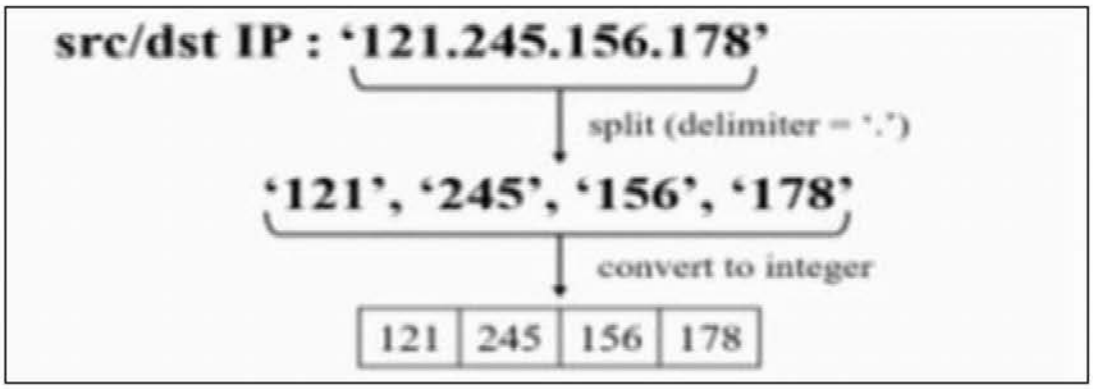
<탐지시간 정보 확장 과정>

- IP정보 확장 통한 AI 모델 정확도 향상 연구

⇒ 공격자가 일반적으로 N:1 혹은 N:N 통신으로 공격대상 시스템에 접근 시도하는 특성을 이용

⇒ IP 주소를 옥텟 단위로 구분하여 4개의 값으로 입력함으로써 정·오탐 분류모델이 특정 IP 주소를 학습하기보다 IP 주소 대역을 학습할 수 있도록 하여 일반화 성능 향상

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



〈출발지・목적지 IP 정보 확장 과정〉

2) 알려진 공격의 신속한 대응을 위한 보안관제 이벤트 유형별 학습 데이터셋 구축

o 보안관제 노하우 기반 데이터정제 기술 적용으로 양질의 학습데이터셋 구축

- 데이터 특성이 보존된 보안전문지식 기반 데이터 전처리 기술 연구

⇒ 보안관제 인력의 정·오탐 판단 노하우를 AI모델에 반영하고, 학습에 불필요한 데이터(불용어)를 정의 및 제거함으로써 모델의 성능을 향상

⇒ 보안이벤트 디코딩(Hex→ASCII변환), 학습에 불필요한 정보(개인정보, 불필요한 특수문자 등) 및 불용어 제거, 적절한 길이로 분절 등의 절차를 통하여 보안이벤트 벡터 생성

〈전처리 기술 적용 결과 예시〉

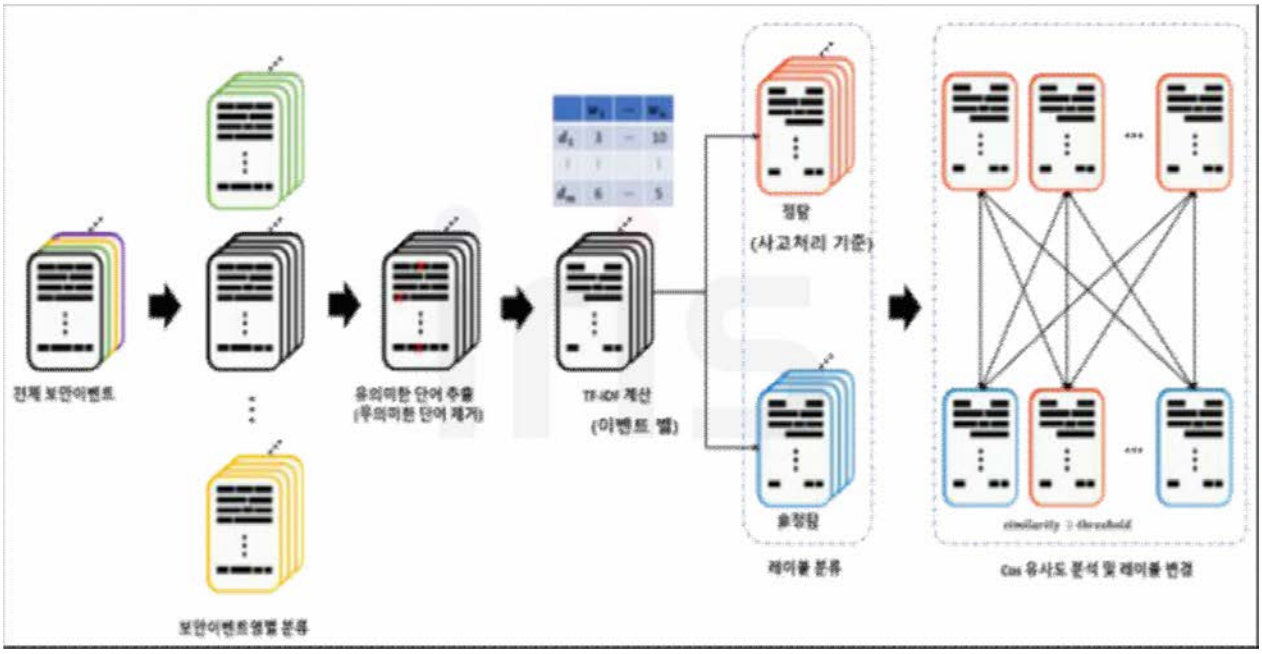
- 보안이벤트 벡터 간 유사도 비교를 통해 데이터 일관성이 확보된 학습데이터 구축

⇒ 기존 보안관제 체계에서는 동일한 보안이벤트임에도 불구하고 분석가의 분석능력, 분석타이밍 등의 이유로 상이한 분석결과가 도출될 수 있으며, 이러한 분석결과를 기반으로 AI모델을 학습할 경우 학습의 성능이 저하됨

⇒ 따라서, 일관성있는 학습데이터를 확보하기 위해 實 운영중인 보안관제센터의 사고처리 이력을 기준으로 페이로드간의 유사도를 비교하여 분석결과(레이블)을 보정

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

<사고처리 이력 기반 데이터셋 일관성 확보 개념 및 절차>



<데이터셋 일관성 확보를 위한 유사도 비교 과정>

o 학습데이터 공개 시 발생할 수 있는 민감정보·개인정보의 유·노출 위험 차단 및 안전성 확보를 위한 비식별화·익명화 수행

- 민감정보(IP, 탐지명, 탐지규칙 등)에 대한 비식별화

⇒ IP의 경우 대상을 특정지을 수 있는 식별정보로 활용될 수 있기에 비식별화를 적용하되, AI 탐지모델의 학습성능 보장을 위해 Locality를 고려하여 비식별화 수행

⇒ 탐지규칙명의 경우 국가정보보안 기본지침(제133조)에 의해 국가정보자료로 관리되며 유·노출이 금지되므로 MD5 Hashing을 통해 직접적인 노출을 원천 차단

⇒ 탐지규칙의 경우 PCRE의 특성상 연결공격(linkage attack)에 노출될 우려가 있으므로 탐지규칙 전체에 대해 치환 혹은 제거 수행

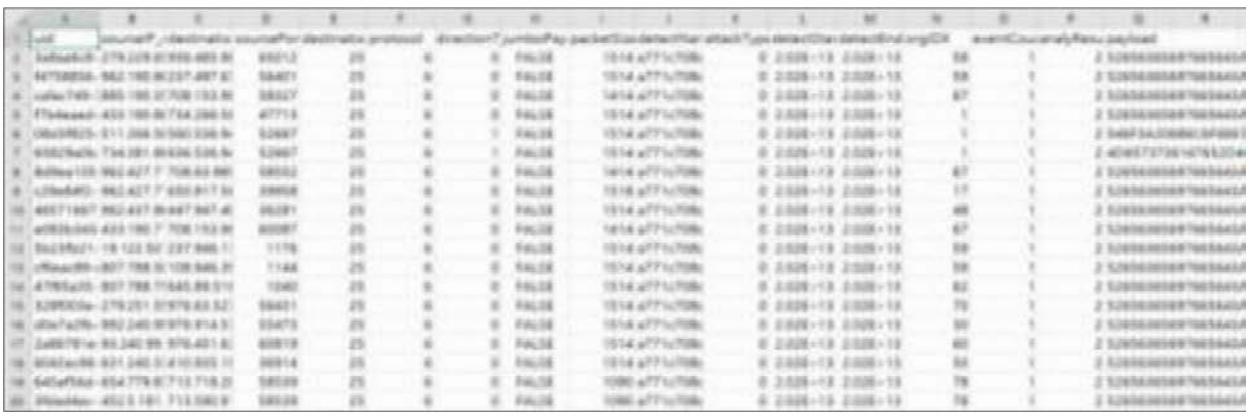
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

<데이터셋 특징 내역 및 비식별처리 필요 항목>

- 개인정보(이름, 주민등록번호, 전화번호, 여권번호, 이메일 등) 익명화 및 불용어 제거
  ⇒ 개인 및 단체를 특정할 수 있는 개인정보는 정규표현식을 활용하여 제거 또는 랜덤한 데이터로 치환
  ⇒ 학습데이터에 불필요한 데이터(불용어)를 제거하여 학습데이터의 품질 향상

<개인정보 비식별화 수행 방법 - 개인정보>

구분	종류	전처리 수행 방법	비고
개인정보	주민등록번호, 여권번호, 전화번호	개인정보 포맷과 일치하는 문자열 제거 ※ 정규표현식 활용	
	이름, 이메일	검출된 정보는 랜덤한 데이터로 치환 ※ 정규표현식 활용	
민감정보	탐지패턴	NLTK(자연어 처리도구) 라이브러리를 사용하여 탐지 패턴에 사용된 단어와 유사 단어로 치환	국가 공공분야 사이버보안 민감정보
불용어		연속된 공백·특수문자, ASCII 범위 외 문자, 정·오탐 판단 근거로 활용되지 않는 문자열 등을 제거	



<학습데이터셋 구축 결과 예시>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

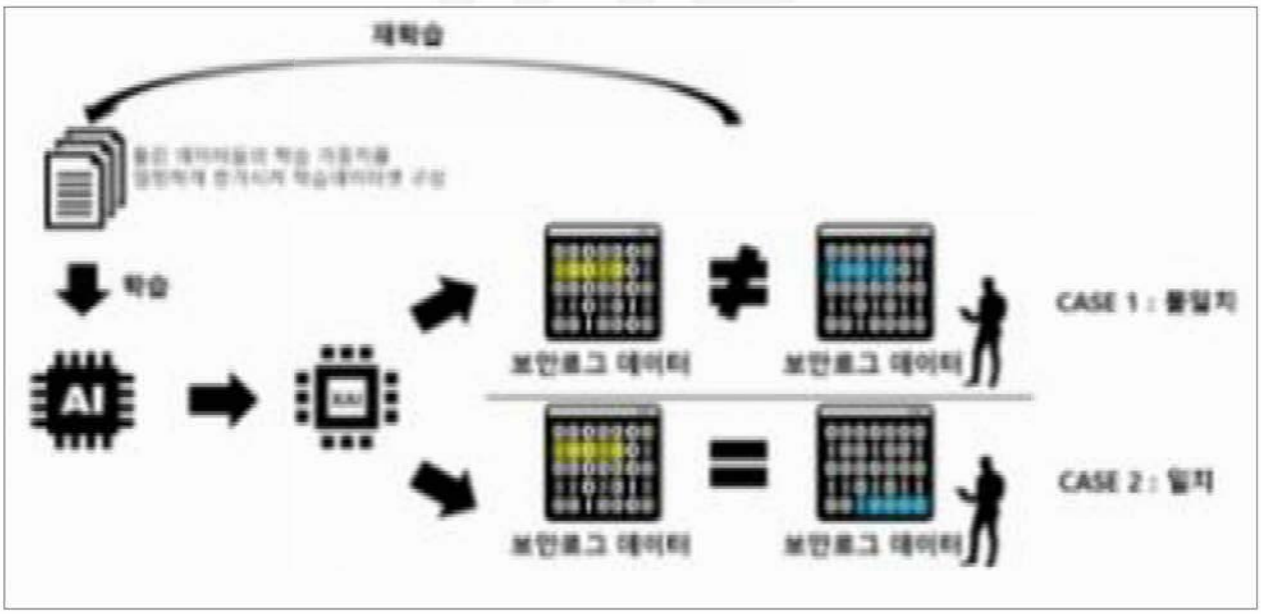
3) 의사결정 신속성 향상을 위한 중요 위험 보안이벤트 학습 데이터셋 구축

o 설명가능한 인공지능(eXplainable AI, XAI)을 활용한 보안이벤트 분석기술의 개발이 활발히 이루어지고 있음

- 보안관제 분야에서의 AI모델의 블랙박스적 특징은 사고원인 파악 및 최적의 의사결정을 내리는데 어려움을 야기함
  ⇒ 實 관제환경에서 AI모델을 적용하기 위해서는 정·오탐 판단근거가 반드시 수반되어야함
  ⇒ 적절한 판단 근거없이 도출된 정·오탐 결과를 검증하는데 소요되는 시간은 보안이벤트를 처음부터 분석하는 시간과 다름이 없음
- 또한, XAI모델은 AI모델이 사용자의 의도에 따라 학습되었는지 검증할 수 있는 도구로써 활용 가능하기에 AI모델의 신뢰성 검증을 위해 필수적으로 요구되는 기술임

o 보안이벤트별 정·오탐 분류 핵심요소가 태깅(Tagging)된 XAI 검증 데이터셋 구축

- AI모델 성능 검증을 위해 단순 수치적 해석뿐만 아니라 AI모델의 판단근거 분석이 필요
- 이러한 AI모델의 판단근거 분석을 신속·정확하게 수행하기 위해서는 고품질의 데이터셋을 기반으로 자동 수행할 필요가 있음
  ⇒ 보안관제 전문 인력이 태깅한 정·오탐 핵심요소들과 XAI가 도출한 핵심 판단 근거들을 비교하여 AI모델의 신뢰도를 검증
  ⇒ XAI가 제공하는 AI모델 탐지근거와 관제요원의 탐지근거 비교를 통해 서로 상이할 경우 학습데이터 재구성 및 학습 가중치를 조정하여 학습 데이터셋 재구성



<XAI 검증 데이터셋 구축 개념도>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

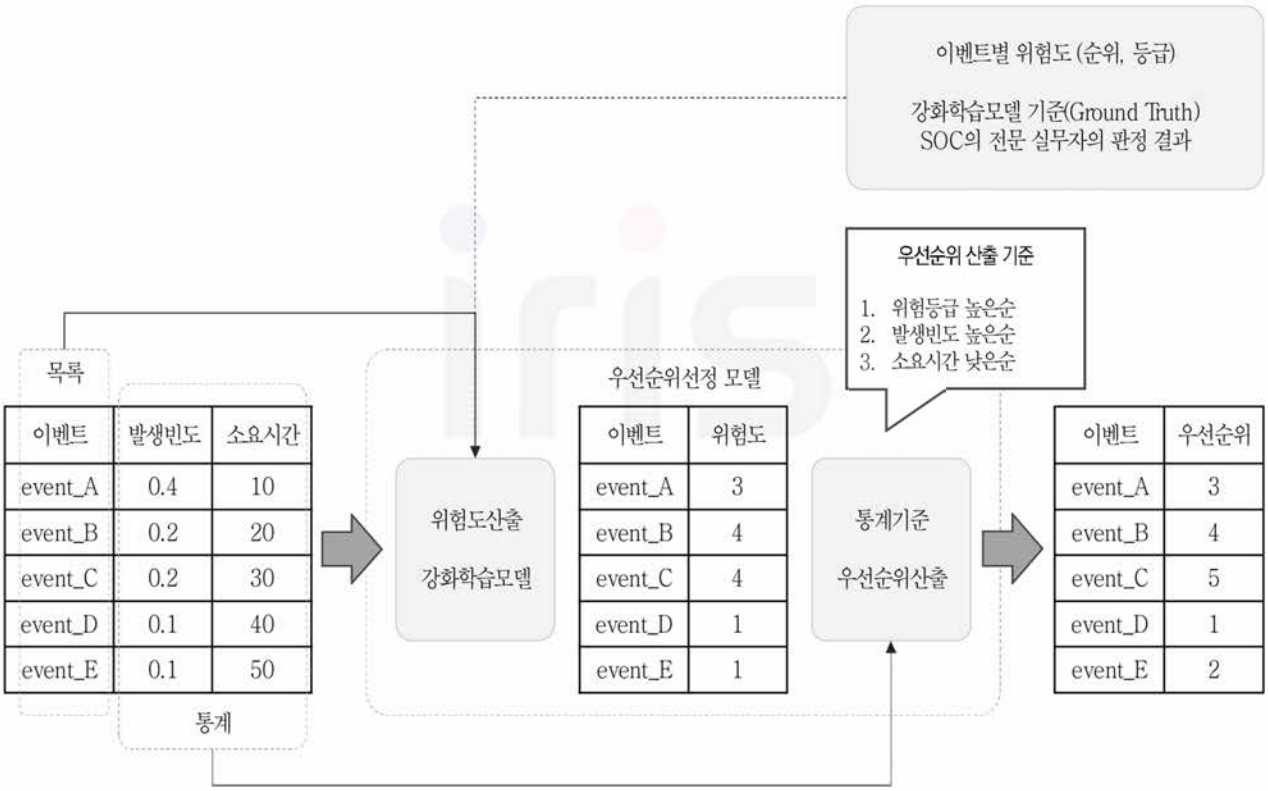
개발목표 ③	AI 기반 최적 의사결정 자동 추천 기술 개발

세부 내용	1) 강화학습 모델 기반 우선처리 이벤트 중요도 산정 및 자동 분류 기술 개발
	2) 강화학습 모델 기반 최적 대응 정책 추천 기술 개발
	3) 보안 관제 경보·대응 우선순위 부여 기술 개발

1) 강화 학습 기반 우선처리 이벤트 중요도 산정 및 자동 분류 모델 고도화 개발

o 모델 개요

- 다수의 보안 이벤트들을 대상으로 SOC의 전문인력의 판정 결과 데이터 대상으로 강화학습 모델을 개발하여 처리 우선순위 산출 자동화
- 이벤트별 위험도의 산출은 강화학습모델을 활용하고, 산출된 위험도와 시의성있는 통계 결과를 조합하여 최종 우선순위를 산출



이벤트	발생빈도	소요시간
event_A	0.4	10
event_B	0.2	20
event_C	0.2	30
event_D	0.1	40
event_E	0.1	50

이벤트	위험도
event_A	3
event_B	4
event_C	4
event_D	1
event_E	1

이벤트	우선순위
event_A	3
event_B	4
event_C	5
event_D	1
event_E	2

<우선 순위 선정 모델 개념도>

o 우선순위를 부여한 이벤트 반환 강화학습을 위한 데이터 전처리

- 이벤트 및 대응 데이터는 사전 학습된 DQN 모델을 통해 매칭되도록 설계
  - 이벤트 목록(event_id_list)은 다양한 보안 이벤트를 나타내는 고유 ID 집합을 의미
  - 대응 목록(response_id_list)은 각 이벤트에 대한 다중 대응 방안의 집합임
  - 따라서, 총 데이터 샘플 수는 len(event_id_list)개 이며,
  - 사용자는 선호하는 대응 조치(response_id)를 제공할 수 있으며, 해당 데이터는 학습된 모델의 기본 추천 결과에 우선적으로 반영

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

```
# 학습에 사용한 event_list
event_id_list = ['access',
 'bshell',
 'cheditor',
 'connect',
 'curl',
 'dbport',
 'dpage',
 'drupal',
 'exploit',
 'fckeditor',
 'flood',
 'icmp',
 'joomla'
```

```
# 학습에 사용한 response_list
response_id_list = [['log_connect_record_request', 'access_control_set_recomm', 'pw_c
 ['log_connect_record_request', 'src_ip_block_recomm', 'server_security_set_recomm'],
 ['malicious_code_get_request', 'malicious_page_restric_recomm', 'pc_close_exam_recom
 ['malicious_code_infec_check_request', 'malicious_code_get_request', 'security_updat
 ['multi_auth_recomm', 'src_ip_block_recomm'],
 ['multi_auth_recomm', 'sw_delete_recomm', 'normal_comm_check_request', 'src_ip_info_
 ['normal_comm_check_request', 'pc_close_exam_recomm', 'src_ip_info_request'],
 ['normal_comm_check_request', 'src_ip_block_recomm', 'remote_port_block_recomm'],
 ['normal_comm_check_request', 'src_ip_info_request'],
 ['pw_change_recomm', 'network_isolate_recomm', 'multi_auth_recomm', 'security_update
 ['security_update_recomm', 'sys_log_request', 'malicious_code_infect_request', 'sign
 ['src_ip_block_recomm', 'dst_ip_info_request'],
 ['src_ip_block_recomm', 'malicious_url_block_recomm', 'dst_ip_info_request'],
 ['threshold_set_recomm', 'src_ip_block_recomm', 'dst_ip_info_request'],
 ['tmp_access_block_recomm', 'normal_comm_check_request', 'src_ip_block_recomm', 'dst
 ['tmp_access_block_recomm', 'src_ip_block_recomm'],
 ['vulnerability_check_recomm', 'src_ip_block_recomm', 'dst_ip_info_request', 'securi
 ['vulnerability_check_recomm', 'src_ip_block_recomm', 'malicious_url_block_recomm']]
```

< 우선순위를 고려한 강화학습을 위한 데이터 전처리 코드 예시 >

o 강화학습을 위한 데이터 특징

- 학습 데이터의 성격에 따라서 강화학습(위험도 산출)에 사용되는 항목들과 서비스(우선순위 산출)에 사용되는 항옥들로 구분
- 강화학습(위험도 산출) 사용 항목 : 이벤트별 정적 속성, priority(레이블)
- 서비스(우선순위 산출) 사용 항목 : 이벤트별 정적 속성 및 동적 속성(소요시간), priority(레이블)
- 강화학습 환경은 기존 적응형 플레이북 강화학습 모델 환경을 기반으로 사용하고, 환경 클래스는 기존 DQN 기반 학습 환경에서 확장
  - 기존 학습된 모델(iqn_response_model) 불러오기
  - 사용자 입력 이벤트와 대응을 추가로 처리할 수 있도록 구성

항목	사용구분		설명
	모델	서비스	
event_id	O	O	54개의 위협 이벤트 식별자(wget, xss, php, …)
event_desc	X	X	이벤트 설명(참고 정보)
threat_id	X	X	분류코드로 공격 유형에 따라 일부 중복될 수 있음
risk	O	O	이벤트별 위험도 (Ground Truth), 4개 값으로 등급 개념
fre_ratio	O	O	발생빈도로 높을수록 우선순위를 높임
pp_mtime	X	O	pp_mtime(분)x60 + pp_stime(초) → 초단위 단일 항목 변환 (동일 위험도, 동일 발생빈도일 경우 소요시간이 작은 이벤트부터 처리)
pp_stime	X	O	
priority	O	O	대응 우선순위, 입력 이벤트들의 위험도, 발생빈도, 소요시간 순으로 정렬한 결과

<학습 데이터 필드 및 feature>

```
# 저장한 모델 불러오기
new_model = tf.keras.models.load_model('iqn_response_model')
```

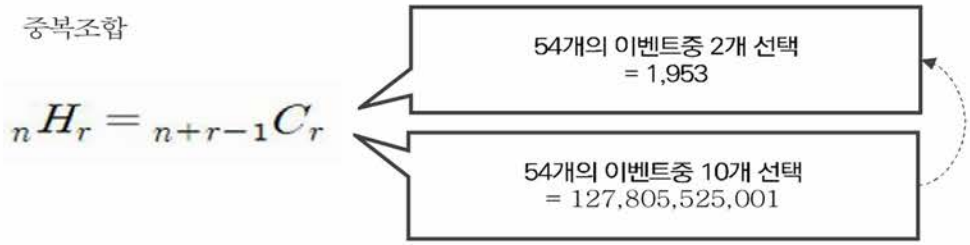
< 기존 적응형 플레이북 강화학습 모델 환경 사용 코드 예시 >

o 강화 학습 적용 방안

- risk(위험도) : SOC 전문인력들이 판단한 이벤트간의 중요도값
- 강화학습모델은 다수의 이벤트들을 입력 받은 후 이벤트들의 위험도 순서를 출력

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- 해결하려고 하는 문제를 다수 이벤트들을 대상으로 위험도의 순서를 맞추었을 때, 보상(Reward)이 제공되는 강화학습 모델로 설정
- 동시에 입력되는 최대 이벤트의 개수에 따라서 학습범위가 달라짐



- 사용자 선호 보안관제 경보·대응 우선순위 반영
  - 기존 DQN 기반 강화학습 모델을 확장하여 사용자 입력값 우선 처리
  - 사용자가 선호하는 대응 시퀀스 집합(my_response_id)이 주어진 경우, 이 집합을 우선적으로 출력
  - 선호 대응 시퀀스가 없을 경우, 기존 학습된 모델 결과를 사용

```
# event_id 입력
event_id = 'connect'
# 내가 선호하는 response_id 리스트 형태로 입력 (개수 제한 없음, 1개도 가능하며 없는 경우 빈 리스트)
my_response_id = ['src_ip_block_recomm']
```

< 사용자 선호 보안 관제 경보·대응 우선순위 반영 코드 예시 >

- 사용자 선호를 고려한 이벤트 중요도 산정 및 자동 분류 예시
  - 이벤트 입력 (예: “connect “)
  - 선호 대응 시퀀스 (예: [’tmp_access_block_recomm’, ’normal_comm_check_request’, ’src_ip_block_recomm’])
  - 사용자가 선호하는 대응 시퀀스가 모델의 출력 상단에 위치

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

```
# 선호하는 리스트를 맨 앞에 두기 위해서 사용
# 기존의 response_id 결과를 복사해서 사용
out = response_id.copy()
# reponse_id 하나씩 꺼내서 내가 선호하는 response_id에 해당하는지 확인
for response in out:
    if response in my_response_id:
        # 내가 선호하는 response_id에 해당하는게 있으면 해당 response_id를 삭제
        response_id.remove(response)
        # 가장 앞에 내가 선호하는 response_id를 다시 추가
        response_id.insert(0, response)
```

```
response_id
```

```
['src_ip_block_recomm',
 'vulnerability_check_recomm',
 'dst_ip_info_request',
 'security_update_recomm']
```

< 사용자 선호를 고려한 이벤트 중요도 산정 및 자동 분류 예시 >

o 모델 성능 측정

- 정확하게 우선 순위가 일치할 경우에만 점수를 부여하는 기존 모델 성능 측정 방법의 문제점을 보완

▪ n=이벤트개수, i : 이벤트별 순서 (1~n), y_i : i 번째 이벤트의 실제순위, $\hat{y}_i$: i번째 이벤트의 예측순위

$$\frac{1}{n}\sum_{i=1}^{n}\frac{\sum_{1}^{i}(y_i == \hat{y}_i)}{i}$$

i번째 이벤트까지의 일치 여부의 합계

<기존 모델 정확도 측정 식>

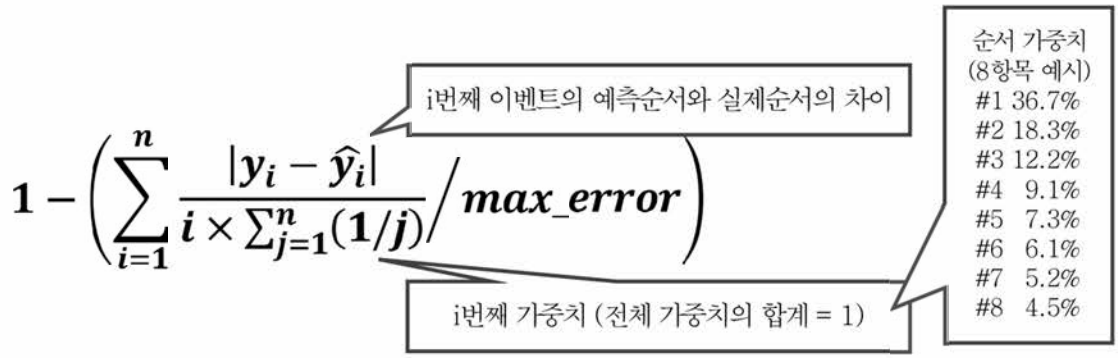
- 예측 순서와 정답 순서의 차이를 반영하여 맞으면 1 틀리면 0을 부여했던 방식을 개선하여 예측 순서가 정답 순서에 얼마나 근접하는지 측정하고 평가하도록 보완
- 이벤트들의 순서에 따른 가중치 반영

▪ n=이벤트개수, i : 이벤트별 순서 (1~n), y_i : i 번째 이벤트의 실제순위, $\hat{y}_i$: i번째 이벤트의 예측순위

n개의 이벤트 기준 최대오차

$$max_error = \sum_{i=1}^{n}\frac{|y_i - \hat{y}_i|}{i \times \sum_{j=1}^{n}(1/j)}$$

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



$$1 - \left(\sum_{i=1}^{n} \frac{|y_i - \hat{y}_i|}{i \times \sum_{j=1}^{n} (1/j)} \Big/ max_error \right)$$

<개선된 모델 정확도 측정 식>

```
def get_prediction_score2(true, pred, max_error):
    num_event = len(true)
    max_cell_error = num_event-1 # Max cell error

    div_weight = 0
    for i in range(num_event):
        div_weight += 1/(i+1)

    tot_error = 0

    for i, x in enumerate(zip(true, pred)):
        cell_error = np.abs(x[0]-x[1])
        cell_weight = (1/(i+1))/div_weight
        # print(cell_weight)
        tot_error += cell_error*cell_weight
    return 1-(tot_error/max_error)
```

<우선순위 예측 정확도 측정 함수>

- 정답을 알고 있는 3개~10개의 이벤트들을 이용하여 학습용 데이터셋 생성
- 학습용 데이터셋을 대상으로 반복적으로 학습 및 정확도 측정

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

	PRED1	PRED2	PRED3	PRED4	PRED5	PRED6	PRED7	PRED8	PRED9	PRED10	TRUE1	TRUE2	TRUE3	TRUE4	TRUE5	TRUE6
0	viewer	drupal	fckeditor	spring	cheditor	ashell	hijack	guzzle	bforce	nmap	viewer	drupal	fckeditor	spring	cheditor	ashell
1	wget	icmp	p2p	tport	log4j	connect	fckeditor	cheditor	ashell	nmap	wget	icmp	p2p	tport	connect	log4j
2	wget	smb	adware	scfunc	gmeditor	ashell	wshell	vpn	guzzle	tomcat	wget	smb	adware	scfunc	ashell	gmeditor
3	icmp	viewer	web	sql	drupal	spring	gmeditor	bshell	fortios	bforce	icmp	viewer	web	sql	drupal	spring
4	dbport	ssl	fckeditor	mchange	scfunc	bshell	wshell	guzzle	tomcat	fortios	ssl	dbport	fckeditor	mchange	bshell	scfunc
...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...
95	curl	smtp	exploit	web	drupal	xss	spring	gmeditor	score	scan	curl	smtp	exploit	web	xss	drupal
96	wget	ssl	p2p	kswitch	flood	scfunc	gmeditor	laravel	dauth	scan	wget	ssl	p2p	kswitch	flood	scfunc
97	curl	smtp	adware	tport	connect	scfunc	wshell	score	bforce	scan	curl	smtp	adware	tport	connect	scfunc
98	curl	kswitch	web	xss	mine	score	bshell	guzzle	wscan	nmap	curl	kswitch	web	xss	mine	bshell
99	curl	p2p	smtp	tport	spring	dpage	flood	nshell	php	dauth	curl	p2p	smtp	tport	spring	dpage

<예측 이벤트 순서와 정답 이벤트 순서의 데이터 프레임>

2) 강화 학습 기반 최적 대응 정책 추천 기술 고도화 개발

o 모델 개요

- 에이전트(추천모델)가 각 상태에서 가장 큰 보상을 얻을 수 있도록 학습
- 모델 없이 학습하는 강화 학습 기법 중 하나인 Q 러닝(Q-learning) 선정
- Q 러닝은 주어진 상태에서 주어진 행동 수행으로 얻을 수 있는 효용의 기대값을 예측하는 함수인 Q 함수를 학습
- 주어진 상태에서 어떤 행동을 수행할지 나타내는 규칙인 최적 정책을 학습

o 학습 데이터

- 특정 SOC를 대상으로 일정 기간 발생한 보안 이벤트에 대한 대응 내역을 수집하여 학습에 필요한 필드를 구성하고 가공

event_id	event	reponse_id	response
wget	wget 이용 파일 다운로드 공격 시도	src_ip_block_recomm	공격지 IP 차단 정책 적용 권고
wget	wget 이용 파일 다운로드 공격 시도	malicious_urlblock_recomm	악성 URL 차단 정책 적용 권고
…	…	…	…
wget	wget 이용 파일 다운로드 공격 시도	dst_ip_info_request	목적지 IP 정보공유 요청
rport	원격 포트 접근 시도	tmp_access_block_recomm	임시 접근 허용 차단 권고
rport	원격 포트 접근 시도	normal_comm_check_request	정상 통신 여부 확인 요청
…	…	…	…
rport	원격 포트 접근 시도	remote_port_info_request	원격포트 정보공유 요청
icmp	ICMP를 활용한 접근 시도	threshold_set_recomm	임계치 설정 권고
icmp	ICMP를 활용한 접근 시도	src_ip_block_recomm	공격지 IP 차단 정책 적용 권고
icmp	ICMP를 활용한 접근 시도	dst_ip_info_request	목적지 IP 정보공유 요청
…	…	…	…

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

o 데이터 전처리

- 학습하는 대상인 에이전트가 필요한 정보를 학습 데이터로부터 전처리 작업을 통해 매트릭스 형태로 가공

Event	Event_id	Risk	pp_mtime	pp_stime	Freq
ICMP를 활용한 거점 시스템 접근 시도	E001	7.6	10	45	182
SSL VPN 로그인 페이지 노출	E002	7.6	13	16	113
wget 이용 파일 다운로드 공격 시도	E003	7.6	18	54	279

대응정책 추천을 위한 이벤트 feature를 활용한 전처리

	feature1	feature2	feature3	feature4
E001	value	value	value	Value
E002	value	value	value	value
⋮	0	0	0	0
	...	...	...	...

전체 이벤트 개수(54) x feature(4) 개수 행렬

o 강화 학습 적용 방안

- 에이전트가 행동을 취할 때마다 보상을 주는 것이 아닌 모든 예측을 다하고 종합적으로 평가하여 보상을 부여
- 모든 예측에 대해 종합적으로 평가하여 보상을 부여하기 위한 Custom Reward Function 을 설계

정답	drupal	wget	dbport	icmp
예측	icmp	wget	druap	dbport

→ Reward Func.(true, pred) = reward

- 순서를 평가하기 위해 NDCG 지표를 활용하여 보상함수 설계

$$F(true, pred) = \frac{DCG - Constant\ DCG}{IDCG - Constant\ DCG}$$

$$DCG = \sum_{i}^{prediction\ order} \frac{rel_i}{\log(2+i)}, \quad IDCG = \sum_{i}^{ideal\ order} \frac{rel_i}{\log(2+i)}, \quad Constant\ DCG = \sum_{i} \frac{constant\ rel_i}{\log(2+i)}$$

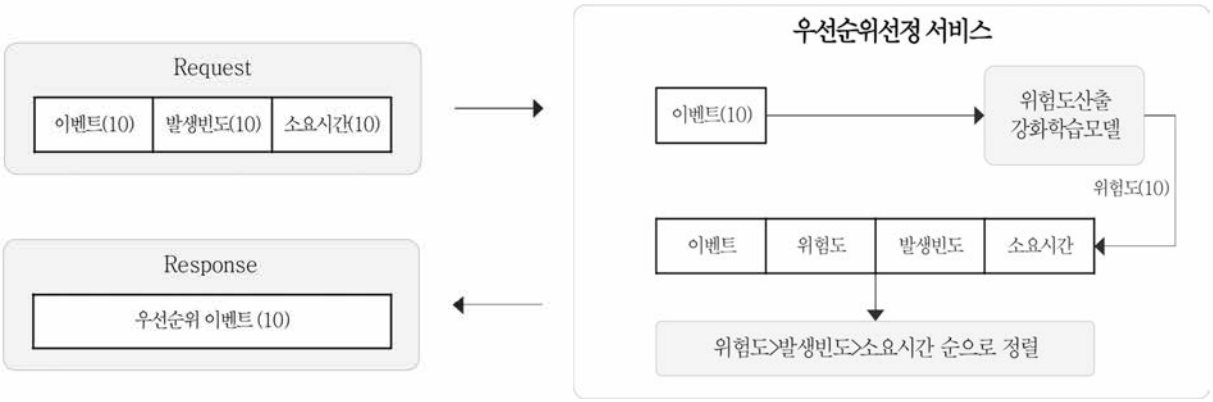
rel_i는 정답 순서 index, $constant\ rel_i$는 정답 순서에서 중간 값에 해당하는 index를 의미

o 외부 연동 서비스 API

- 의사 결정 지원 시스템의 우선순위 및 정책 선정 모델의 예측 서비스를 위협 분석

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

자동화 시스템과 같은 외부 시스템에 제공하기 위한 API



<서비스 API 구성도>

- 서비스 처리 성능 및 연동 확장성을 위해 HTTP 와 TCP 기반의 API 연동 서비스 제공

HTTP 연동

- URL
  1. 이벤트 우선 순위 요청 : http://59.18.207.245:8080/event
  2. 플레이북 우선 순위 요청 : http://59.18.207.245:8080/playbook
  3. 대응 정책 추천 요청 : http://59.18.207.245:8080/response
- 요청 메시지 형식 : {"req_list": "이벤트ID,이벤트ID,…"} -> 이벤트,대응정책
  {"req_list": "이벤트ID:잔여시간, 이벤트ID:잔여시간 , …"} -> 플레이북
- 응답 메시지 형식
  1. 이벤트 우선 순위 요청 : ["dbport","wget"]
  2. 플레이북 우선 순위 요청 : ["dbport","wget"]
  3. 대응 정책 추천 요청 : ["src_ip_block_recomm,malicious_url_block_recomm,dst_ip_info_request"]

<HTTP API 규격>

TCP 연동

- IP/Port : 59.18.207.245/9001
- 요청 메시지 형식 : 요청구분 | 메시지 일련번호 | 이벤트ID,이벤트ID,이벤트ID, … -> 요청구분:1,3
  요청구분 | 메시지 일련번호 | 이벤트ID:잔여시간,이벤트ID:잔여시간,이벤트ID:잔여시간, … -> 요청구분: 2
  - 필드 구분 자 : |
  - 이벤트 ID 구분 자 : ,
  - 요청 구분 : 이벤트 우선순위 요청 1, 플레이북 우선순위 2, 대응정책 추천 : 3

  e.g.) 1|100|kswitch,joomla,connect,smb,icmp ,dpage
  2|101|kswitch:15.33,Joomla:10.45,connect:28.17,smb:7.23,icmp:11.10
  3|102|kswitch,joomla,connect
- 응답 메시지 형식 : 메시지 일련번호 | [요청결과 리스트]

  100| ["dbport","wget"]
  101| ["src_ip_block_recomm,malicious_url_block_recomm,dst_ip_info_request"]
  102|["wget","dbport"]

<TCP API 규격>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

3) 보안 관제 경보·대응 우선순위 부여 기술 고도화 개발

o 보안 이벤트 및 대응 데이터 특성 분석
- 이벤트 자체 정보, 이벤트 위험도, 플레이북, 사용자 피드백을 분석하여 특성 값을 추출하고 종합적인 위험도 계산
- 이벤트 발생 빈도, 이벤트 영향도, 공격난이도, 대응난이도를 분석하여 이벤트에 대한 대응 우선 순위 부여

priority	event_id	event	risk	fre_ratio
1	wget	wget 이용 파일 다운로드 공격 시도	7.6	0.260884
2	icmp	ICMP를 활용한 접근 시도	7.6	0.081256
3	rport	원격 포트 접근 시도	7.6	0.072449
4	ssl	SSL-VPN 로그인 페이지 접근 시도	7.6	0.020771
5	smb	SMB(445) 포트를 통한 접근 시도	7.6	0.012463
6	viewer	TeamViewer 사용 이벤트 탐지	7.6	0.005484
7	dbport	DB 접속 포트 접근 시도 탐지	7.6	0.004819
8	joomla	Joomla 원격코드 실행 취약점 공격 시도 탐지	7.6	0.002326
9	curl	curl 이용 파일 다운로드 공격 시도	7.6	0.001662
10	p2p	P2P 사용 이벤트 탐지	7.6	0.000665
…	…	…	…	…

<이벤트 우선순위 관리 정보>

o SOC 별 경보·대응 우선순위 관리
- 개별 SOC 운영 환경에 최적화된 경보대응 우선순위를 부여하고 관리
- 경보.대응 데이터 특성 분석을 통해 도출된 위험도, 발생 빈도에 기반한 우선순위 관리 정보를 SOC 운영 환경에 따라 주기적으로 갱신

```
(base) mobigen@kisa-01:~/script.old$ ./getRedis.py EVT_RISK_TIME_RATIO
web => T_3-5,17,7,16,39,0.156697
drupal => T_3-5,21,7,23,53,0.024593
wget => T_7-2,1,7.6,24,34,0.260884
sql => T_3-7,19,7,3,32,0.082087
log4j => T_3-5,18,7,14,58,0.105683
icmp => T_1-1,2,7.6,5,38,0.081256
rport => T_1-1,3,7.6,16,43,0.072449
xss => T_3-2,20,7,19,28,0.043702
adware => T_7-3,12,7.6,17,25,0.000332
viewer => T_7-4,6,7.6,12,23,0.005484
dbport => T_1-1,7,7.6,14,34,0.004819
log11j => T_3-5,18,7,13,53,0.105683
traver => T_3-3,22,7,10,34,0.020106
mchange => T_3-5,27,7,7,41,0.010136
fckeditor => T_3-8,23,7,18,13,0.01994
smb => T_7-1,5,7.6,23,30,0.012463
woluqin => T_3-4,24,7,24,28,0.019109
(base) mobigen@kisa-01:~/script.old$ ./setRedis.py ./temp/evt-risk-time-ratio.txt EVT_RISK_TIME_RATIO
0 <built-in function id> T_3-5,17,7,17,58,0.156697
0 <built-in function id> T_3-5,21,7,3,47,0.024593
0 <built-in function id> T_7-2,2,7.6,18,33,0.260884
0 <built-in function id> T_3-7,19,7,17,5,0.082087
0 <built-in function id> T_3-5,18,7,10,16,0.105683
0 <built-in function id> T_7-2,1,7.6,9,18,0.260884
0 <built-in function id> T_7-2,1,7.6,16,51,0.260884
0 <built-in function id> T_1-1,2,7.6,11,52,0.081256
0 <built-in function id> T_7-2,1,7.6,3,26,0.260884
0 <built-in function id> T_3-5,18,7,23,25,0.105683
0 <built-in function id> T_7-2,1,7.6,23,46,0.260884
0 <built-in function id> T_1-1,3,7.6,12,49,0.072449
0 <built-in function id> T_1-1,3,7.6,21,27,0.072449
0 <built-in function id> T_1-1,2,7.6,8,44,0.081256
0 <built-in function id> T_7-2,1,7.6,12,53,0.260884
```

<경보·대응 우선순위 관리 정보 갱신 절차>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

세부 기술 ④ 보안사고 자동 대응 및 검증 요소 기술 설계 및 개발

□ 개발 기술 개요

o (개발목표) 보안사고 자동 대응 및 검증 요소 기술 설계 및 개발

1) 이기종 보안 장비의 보안사고 자동 대응 기술 개발 및 검증 기술 설계
2) 보안관제 업무 프로세스 평가를 위한 정량적 측정기술 개발
3) SOC 통합 운영 및 자동화 플랫폼 개발 요구사항 분석 및 설계

o (추진실적) 보안사고 자동 대응 및 검증 요소 기술 설계 및 개발 완료

- 이기종 보안 장비의 보안사고 자동 대응 기술 설계 및 개발 완료 **개발목표 1**
- 보안관제 업무 프로세스 평가를 위한 정량적 측정기술 개발 완료 **개발목표 2**
- SOC 통합 운영 및 자동화 플랫폼 개발 요구사항 분석 및 설계 완료 **개발목표 3**

개발목표 ①	이기종 보안 장비의 보안사고 자동 대응 기술 개발 및 검증 기술 설계

세부 내용	
	1) 이기종 보안 장비별 보안 정책 자동 생성·적용 기술 개발
	2) 이기종 보안 장비별 보안 정책 적용 상태 검증 기술 설계

1) 이기종 보안 장비별 보안 정책 자동 생성·적용 기술 개발

o 이기종 보안 장비 정책 자동 적용 관련 인증 방식 설계 및 개발

- SOAR에서 API를 통해 대응정책을 저장하기 위해 JWT(Java Web Token) 발급요청

```
POST /api/v1/users HTTP/1.1
Host: 127.0.0.1:443
User-Agent: python-requests/2.22.0
Accept-Encoding: gzip, deflate
Accept: */*
Connection: keep-alive
Content-Type: application/json
X-CSRF-TOKEN: 202bdb37-e11f-46f1-9d2e-01afec562875
Cookie: access_token_cookie=eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJmcmVzaCI6ZmFsc2...
Content-Length: 106

{"data": [{"user": "test4", "password": "!Q2w3e4r", "auth": "0", "desc": "test2", "class": "individual"}]}
```

JWT(Java Web Token) 기반 정책 등록 계정 추가 예시

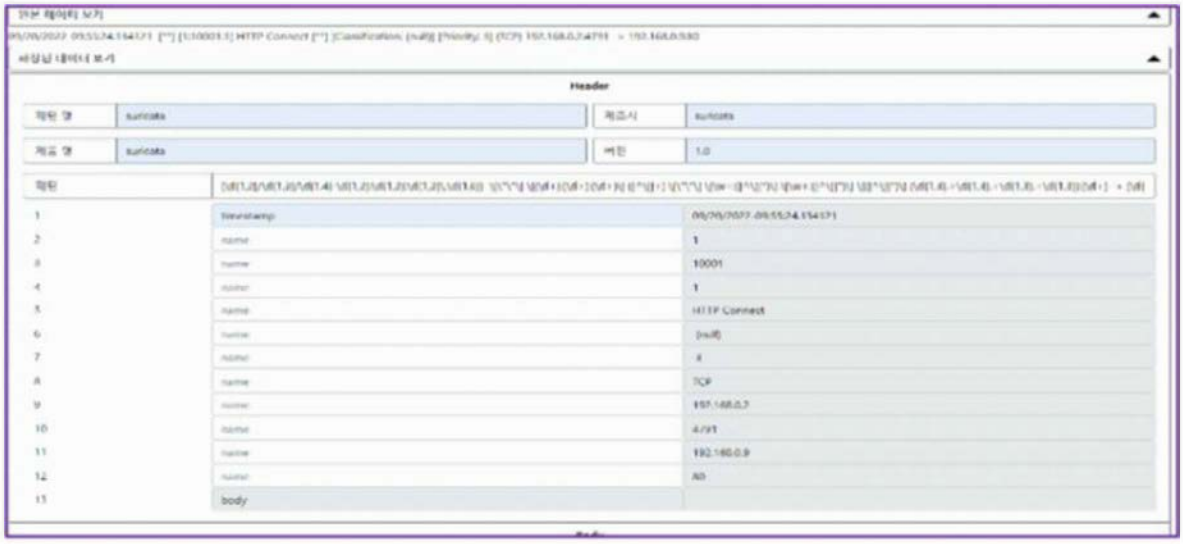
- REST API를 이용하여 대응정책 MongoDB 저장 요청
- API 서버는 Database 내에 있는 원본 대응정책을 식별·추출 등 파싱 및 정규화 시도

※ 다음과 같은 3가지 룰 기반으로 정규화 진행

1. IP 형식이 .(dot)이 아닐 경우 변환
2. ISO 시간 포맷이 아닌 경우 변환
3. 필드 맨 종결문자를 하이픈(-) 삽입

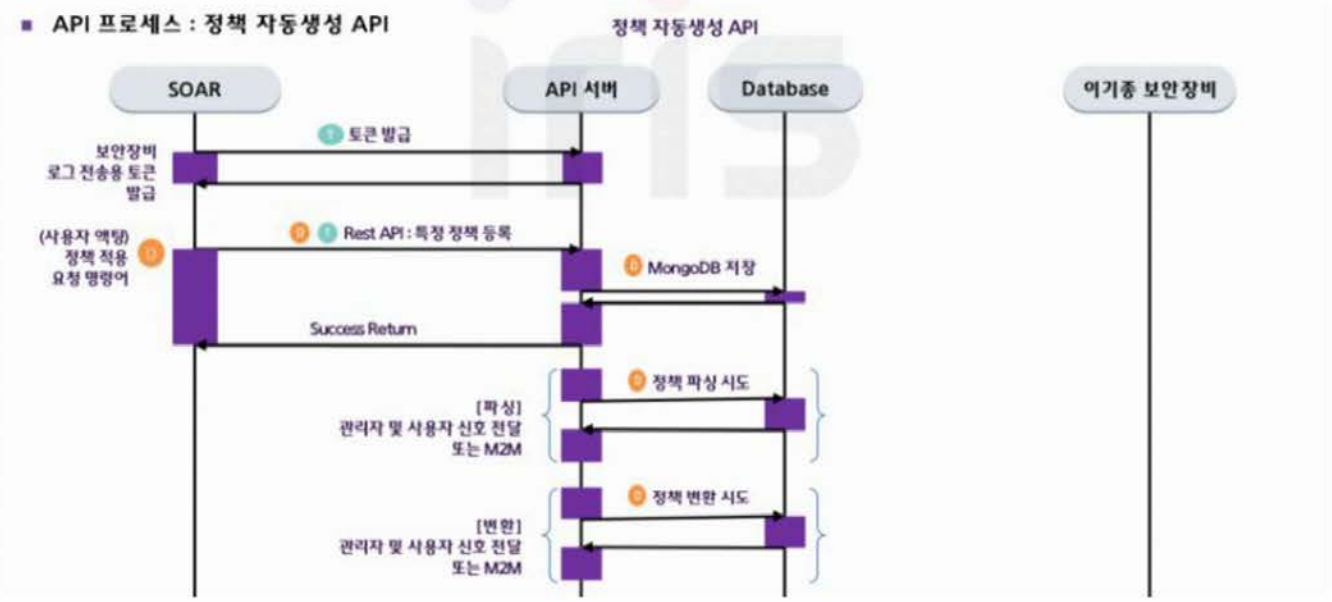
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

· 데이터 포맷 파악이 불가능 할 경우 정규표현식 기반 사용자 정의를 통해 정규화 시도



< 정규 표현식을 이용한 사용자 정의 예시 >

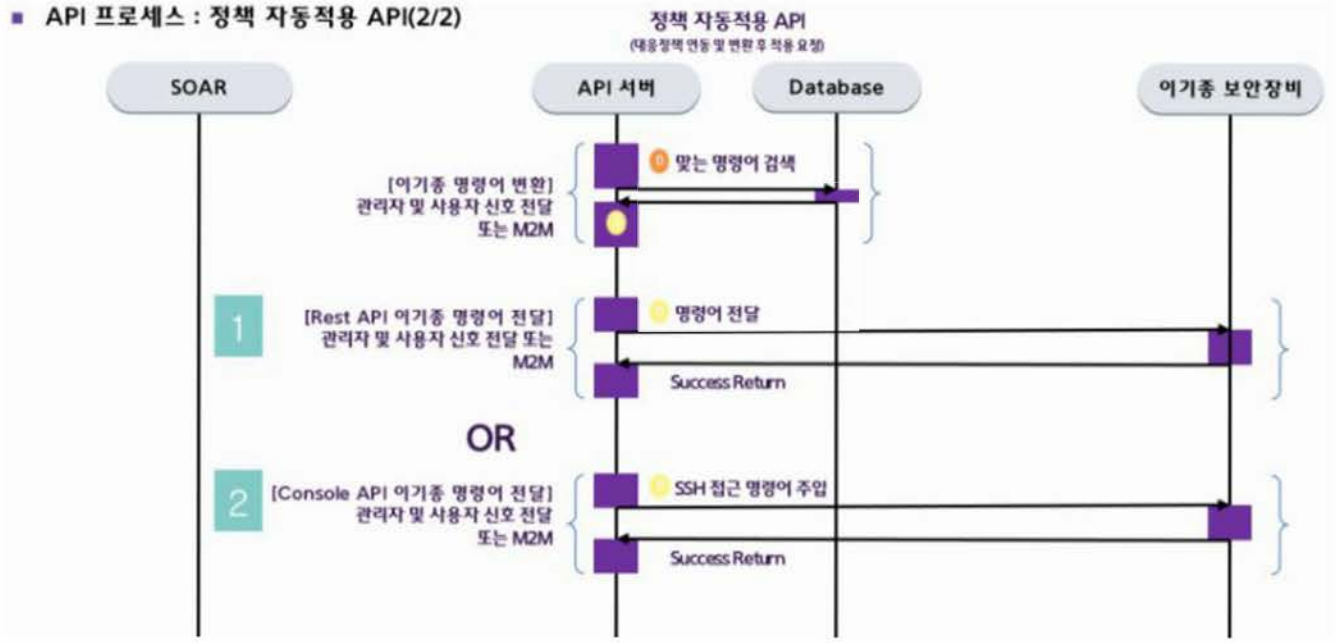
- API 서버는 파싱 완료된 결과 기반으로 정책 변환 시도



<정책 자동 생성 구성도>

- API 서버는 정책자동 적용을 위해 Database(MongoDB) 내에 이기종 보안 장비 정책에 맞는 명세서(명령어) 검색
- 각 벤더사가 등록한 API 명세서(명령어) 기반 이기종 보안 장비에게 정책 적용 요청
- API 기능이 없을 시 SSH 접근을 통해 명령어를 주입하여 정책 자동 적용 요청

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



<정책 자동 적용 구성도>

2) 이기종 보안 장비별 보안 정책 적용 상태 검증 기술 설계

o 보안 장비 정책 적용 상태 검증을 위한 Response값 설계

- 정책 자동 생성·적용 API에 정책 적용 시킬 내용을 담아 전송하면 대응 정책 등록, 파싱, 변환 상태 검증 기능

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

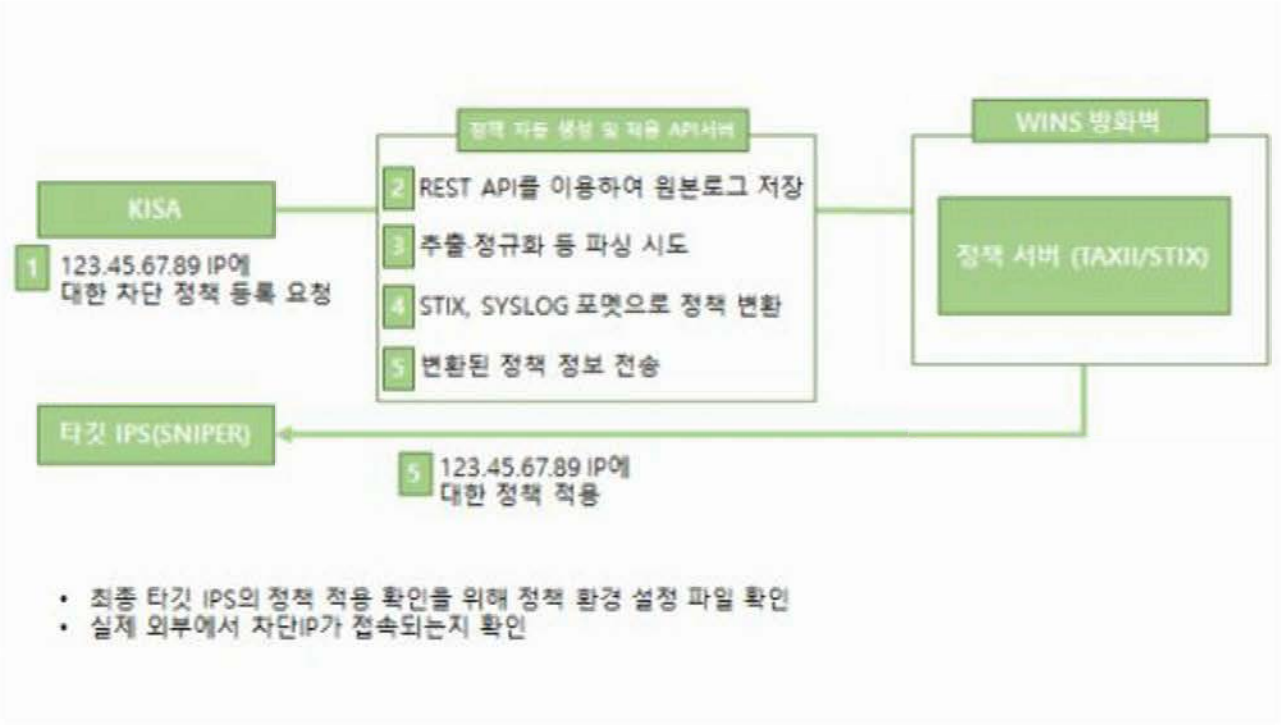
<정책 자동 적용 API 명세서 中 4개 API response 예시>

API 종류	parameter Name	value	Description
대응 정책 등록 API	status	“Success” or “Fail”	성공 혹은 실패
	error_code	“-” or “error code”	실패 시 에러코드
	data.added		저장된 정책 수
	data.total		전송받은 정책 수
대응 정책 파싱 API	status	“Success” or “Fail”	성공 혹은 실패
	error_code	“-” or “error code”	실패 시 에러코드
	data.added		파싱된 정책 수
	data.total		파싱 시도 정책 수
대응 정책 변환 API	status	“Success” or “Fail”	성공 혹은 실패
	error_code	“-” or “error code”	실패 시 에러코드
	data.converted		변환된 정책 수
	data.total		변환 시도 정책 수
패턴 추가 API	status	“Success” or “Fail”	성공 혹은 실패
	error_code	“-” or “error code”	실패 시 에러코드
	data[n].field		필드 명
	data[n].name		패턴 명
	data[n].parsed_type		파싱 방법 (body only)
	data[n].pattern		패턴
	data[n].product_name		제품 명
	data[n].product_version		제품 버전
	data[n].vendor		제품 제조사

o 보안 장비 정책 적용 상태 검증을 위한 테스트 베드 인프라 환경 설계

- 실 보안 장비 구축을 통한 정책 자동 적용 테스트 환경 구축
- API 요청 response에 현재 설정되어있는 대응정책을 담아 전송

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



<테스트 프로세스 구성도>

- CONTAINER ID 8327d00adc2b 는 taxii/stix 룰을 저장하는 MongoDB,
- CONTAINER ID 68b336e67f43 는 taxii/stix에서 제공하는 WebServer 구동

```
[#37.10][root localhost]/backup ~$ docker ps
CONTAINER ID        IMAGE                       COMMAND                  CREATED             STATUS
8327d00adc2b        mongo                       "docker-entrypoint..."   24 seconds ago      Up 23 seconds
68b336e67f43        ctitaxiiserver_medallion    "sh -c 'medallion ..."   24 seconds ago      Up 23 seconds
```

<컨테이너 기반 환경 구성>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

개발목표 ②	보안관제 업무 프로세스 평가를 위한 정량적 측정기술 개발

세부 내용	1) 보안관제 프로세스별 필수업무 범위 식별 및 요소 정의
	2) 보안관제 업무 프로세스 정량 측정기술 요구사항 분석·설계

1) 보안관제 프로세스별 필수업무 범위 식별 및 요소 정의

o 보안관제 프로세스 분류

- 보안관제는 정보자산을 해킹, 바이러스 등의 사이버 공격으로부터 보호하기 위해 수행하는 감시, 분석, 대응과 같은 일련의 활동을 의미함
- 現보안관제 프로세스는 일반적으로 3단계(수집/탐지, 분석, 대응/예방)로 구분
  - ⇒ (수집/탐지) 네트워크 장비(라우터, 스위치 등) 및 보안장비(IPS/IDS, 방화벽, SIEM 등)에서 네트워크 트래픽·보안이벤트를 수집하고 사이버 공격을 탐지하는 단계
  - ⇒ (분석) 탐지된 네트워크 트래픽·보안이벤트를 분석하여 실제 공격여부 판단, 공격유형, 피해규모 등을 파악하는 단계
  - ⇒ (대응/예방) 사이버 공격의 피해 최소화 및 피해 확산방지를 위한 사고대응, 사고/대응 이력 관리, 재발방지 및 예방조치 수행 단계
    - ※ ISO/IEC 27000 family, G-ISMS(Government-Information Security Management System), ISMS(Information Security Management System), 카네기멜론대학의 SEI IMCM(Software Engineering Institute Incident Management Capability Metrics) 참조

o 보안관제 프로세스별 필수업무 정의

- 3단계로 구분된 보안관제 체계에서 각 단계별로 수행되어야 하는 업무들을 정의하고 이에 대한 범위 설정이 필요

<보안관제 프로세스별 필수업무 범위>

프로세스	필수업무	비고
수집/탐지	네트워크 트래픽 및 보안이벤트 수집	사이버 위협을 실시간으로 탐지하기 위해 네트워크 및 보안장비들로부터 네트워크 트래픽, 보안이벤트 로그 등을 수집 ·네트워크 장비 - 라우터, 스위치를 통한 네트워크 트래픽/플로우 수집 ·보안장비 - IDS/IPS, F/W, WAF, SIEM, ESM 기타 등등의 보안로그 수집
	사이버 위협 탐지	사전에 정의된 탐지패턴 또는 비정상 행위 및 사건 기반의 사이버 위협 탐지 ·탐지패턴에 의한 사이버 위협 탐지(misuse detection) ·비정상 행위 탐지 기법을 활용한 사이버 위협 탐지(anomaly detection)
	탐지 패턴 관리	네트워크 패킷·플로우로부터 사이버 공격을 탐지할 수 있도록 보안장비의 탐지 패턴 제작·최적화·관리 수행 ·정상 상태의 기록·관리 ·보안장비에서 활용 가능한 임계치, yara, snort, PCRE기반의 룰 제작·최적화·관리
분석	공격 진위여부 판단	수집/탐지 단계에서 탐지된 사이버 공격을 분석하여 정·오탐 여부를 판단 ·공격 판단 요소 추출 ·보안관제센터의 자체적 노하우/이력 및 OSINT를 활용하여 IP, 서비스, 탐지이력, 취약점, 탐지패턴 등을 확인

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

	사고원인 조사	공격 근원지, 공격방법, 관련 취약점들을 확인 ·시스템 로그 덤프(dump), 악성파일 채취 및 분석 공격 관련정보 추출
	피해범위 파악	적절한 대응방안 도출을 위한 사이버 공격에 의한 정보자산의 피해범위 확인 ·시스템에서 유출·파괴된 전자적 문서 확인 ·lateral movement에 의한 추가 피해 여부 확인
대응/예방	보안사고 대응	보안사고에 대해 신속·정확하고 효과적인 규정화된 대응 수행 필요 ·피해사고 전파 및 사고 대응(공격자 IP차단, 피해 시스템 격리, 악성파일 삭제 등)
	피해시스템/단말 복구	피해시스템/단말의 데이터 및 서비스 복구 ·데이터 및 서비스에 대한 백업 복구 수행
	사고재발 방지 대책 수립	기술적·관리적 보안대책 강화 등을 통한 사이버 공격 재발 방지 대책 수립 ·보안 취약점 제거, 사용자 교육을 통한 보안의식 고취 등 ·유관기관 및 정보공유 시스템을 활용한 공격 정보 공유
	침해대응 이력 관리	보안사고 이력 관리를 통한 추적 관리 · 공격자 IP, 대상 서비스, PoC, 시간 등의 필수 이력 정리

2) 보안관제 업무 프로세스 정량 측정기술 요구사항 분석·설계

o 보안관제 업무 프로세스 정량 측정기술 요구사항의 필요성

- SOAR모델의 적정성 평가를 위하여 實보안관제 업무 프로세스와 비교하여 해당 모델이 프로세스별 필수업무를 얼마나 적절하게 수행하였는지 판단할 기준 필요
- 각 프로세스별 필수업무의 적절한 수행여부를 확인하기 위하여 정량적 측정지표 및 측적기술에 대한 요구사항을 다음과 같이 정의

o (수집/탐지)프로세스의 정량 측정기술 요구사항

- 네트워크 트래픽/플로우 및 보안이벤트 수집율
  - ⇒ 다양한 네트워크 장비 및 보안장비로부터 트래픽/플로우/보안이벤트 등을 수집할 수 있어야함
  - ⇒ 정량 측정 기준 : 각 장비로부터 발생된 네트워크 트래픽/플로우/보안이벤트 대비 수집된 트래픽/플로우/보안이벤트의 비율 <측정 단위 : %>
- 사이버 위협 탐지율
  - ⇒ 관제 대상 시스템을 대상으로 수행되는 사이버 공격을 다양한 보안장비/시스템을 통해 탐지할 수 있어야 함
  - ⇒ 정량 측정 기준 : 측정기간 동안 임의로 수행된 공격대비 탐지된 공격의 비율 <측정 단위: %>
- 탐지 패턴 관리
  - ⇒ 패턴/임계치 기반의 탐지를 위해서는 탐지 패턴 제작이 필수적이며, 새로운 공격에

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

대응하기 위해서는 위협 및 보안사고 분석을 통한 신규 패턴 제작과 관리가 가능해야 함

⇒ 정량 측정 기준 : 주요 사이버 공격을 탐지하기 위한 탐지패턴 및 모델 제작 가능 여부 <측정 단위 : %>

o (분석)프로세스의 정량 측정기술 요구사항

- 공격 진위여부 판단
  - ⇒ 탐지된 이상행위가 실제 보안사고에 해당하는지에 대해 분석을 통한 신속한 하고 적절한 판단이 수행되어야 함
  - ⇒ 정량 측정 기준 : 탐지된 사이버 공격 대비 보안사고로 판단한 실제 보안사고의 비율 <측정 단위 : %>
- 사고원인 분석
  - ⇒ 보안사고 분석 시, 해당 네트워크 트래픽이나 보안이벤트가 어떠한 근거로 사고로 판단되었는지에 대한 근거 분석 및 기록이 수행되어야 함
  - ⇒ 정량 측정 기준[1] : 자동 수집된 판단근거 표출 가능 여부 <측정 단위 : 가불가>
  - ⇒ 정량 측정 기준[2] : 자동 수집된 판단근거 중 실제 공격 판단의 근거로 활용되는 지표의 비율 <측정 단위 : %>
- 피해범위 파악
  - ⇒ 보안사고로 인한 대응 및 조치 수행 시, 객관적 증명이 가능한 증거를 수집 및 보유하여 제시할 수 있어야 하며, 이를 위해 사고현황 및 피해범위 파악을 수행하여야 함
  - ⇒ 정량 측정 기준 : 전체 보안사고 수 대비 사고현황 및 피해범위 파악 가능한 보안사고 수의 비율 <측정 단위 : %>

o (대응/예방)프로세스의 정량 측정기술 요구사항

- 보안사고 대응 신속성/적정성 평가
  - ⇒ 보안사고 유형별로 대응 및 피해시스템에 대한 조치가 적정하고 신속하게 이루어졌는지 평가가 수행되어야 함
  - ⇒ 정량 측정 기준[1] : 보안사고의 탐지부터 대응 완료되기까지의 소요 시간 측정 <측정 단위 : 개수>
  - ⇒ 정량 측정 기준[2] : 보안사고 대응 이후 특정 기간 내에 피해 IP에 동일한 공격 재발생 여부 측정
    <측정 단위: 이벤트 대응 완료부터 6개월* 이내>
    (* 유해 IP의 경우 일반적으로 6개월 이상 차단 수행함을 고려하여 기간 산정)
  - ⇒ 정량 측정 기준[3] : 보안사고의 탐지부터 대응 완료되기까지의 소요 시간 측정 <측정 단위 : 시간>
- 침해대응 이력 관리
  - ⇒ 보안사고 발생 이후 사고 이력 모니터링을 통한 추적 관리가 수행을 위해 사고 유형에 따라 정보탈취, 경유지 악용 등 사고에 대한 라벨링이 수행되어야 함
  - ⇒ 정량 측정 기준 : 전체 보안사고 수 대비 유형 분류 가능한 보안사고 수 <측정 단위 : %>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

개발목표 ③	SOC 통합 운영 및 자동화 플랫폼 개발 요구사항 분석 및 설계

세부 내용	1) SOC 통합 운영 및 자동화 플랫폼 개발 요구사항 분석
	2) SOC 통합 운영 및 자동화 플랫폼 설계

1) SOC 통합 운영 및 자동화 플랫폼 개발 요구사항 분석

o 주요 기능 개요

- 통합 플랫폼 구성 시스템별 주요 기능

시스템	주기능	설명
이상 행위 탐지 시스템	위협 분석 대상 이벤트 분류	- 위협 분석 대상 이벤트를 분류하여 DB에 저장하는 기능
	원본로그 응답	- 원본로그 요청 기능에 응답하는 기능
위협 분석 자동화 시스템	위협 분석 대상 이벤트 조회	- SOC에서 발생한 이벤트들 중 위협 분석이 필요한 이벤트를 SQL Query를 통해 조회하는 기능
	원본로그 요청	- SOAR 티켓을 생성하거나, 이벤트에 대한 상세 분석이 필요하여 원본 로그를 요청하는 기능
	탐지 이벤트 우선처리 요청	- 단기간 내에 탐지 이벤트가 다수 발생하였을 때 우선적으로 플레이북을 실행해야할 탐지 이벤트의 선정을 요청하는 기능
	플레이북 이벤트 우선처리 요청	- 관제원의 개입이 필요한 이벤트들이 다수 발생하였을 때 우선적으로 처리해야할 플레이북 이벤트의 선정을 요청하는 기능
	최적 대응 방안 요청	- 탐지 이벤트에 대한 분석 결과를 바탕으로 최적 대응 방안을 요청하는 기능
	보안 정책 적용 요청	- 이기종 보안 장비에 보안 정책을 적용을 요청하는 기능
의사결정 지원 시스템	탐지 이벤트 우선처리 응답	- 탐지 이벤트 우선처리 요청 기능에 응답하는 기능
	플레이북 이벤트 우선처리 응답	- 플레이북 이벤트 우선처리 요청 기능에 응답하는 기능
	최적 대응 방안 응답	- 최적 대응 방안 요청에 응답하는 기능

o 시스템 요구사항 분석

- 안정적인 시스템 운영
  · 전체 플랫폼에서 제공하는 기능의 모두 또는 일부가 동작 가능
  · 목표 시스템의 OS 동작 범위 내에서 수행 중인 프로세스는 타 프로세스의 동작에 불필요한 영향을 주지 않도록 안정성을 보장

- 안정적인 데이터 공유
  · 전체 플랫폼 내 각 시스템들의 연동 기능들이 정상적으로 동작하기 위해 연동되는 데이터가 안정적으로 공유

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- 개발 라이브러리
  · 본 플랫폼을 개발하기 위하여 Scikit-learn, TensorFlow, Keras, Pandas, Numpy, matplotlib 등의 무료 오픈소스 라이브러리들을 사용
  · 상용 라이브러리를 사용하게 되는 경우, 이를 대체할 수 있는 라이브러리에서도 동작할 수 있도록 지원하여 상용 라이브러리에 대한 종속성을 제거
  · 본 플랫폼이 설치될 때, 특정 버전의 시스템 혹은 사용자 라이브러리에 대한 의존성으로 인해 외부 연동 시스템에 기설치 되어 있는 라이브러리의 업그레이드 등 외부 시스템의 변화가 요구 불가

o 기능별 요구사항 분석

- 위협 분석 대상 이벤트 조회
  · 「이상행위 탐지 시스템」은 SOC에서 발생한 이벤트에 대한 초동 분석을 수행하여 그 결과를 이벤트 DB에 저장·관리하고 있으며, 「위협 분석 자동화 시스템」은 이벤트 DB 내에서 위협 분석이 필요한 이벤트들을 요청
  · 위협 분석 대상 이벤트를 요청하는 방법은 「이상행위 탐지 시스템」이 관리하는 이벤트 DB에 SQL Query를 활용
  · 「위협 분석 자동화 시스템」은 기존에 요청하였던 이벤트의 중복 요청 방지를 위하여 위협 분석 대상 이벤트 요청 및 조회 내역을 기록·관리

- 위협 분석 대상 이벤트 분류
  · 「이상행위 탐지 시스템」은 SOC에서 발생한 이벤트에 대한 초동 분석을 수행하여 그 결과를 이벤트 DB에 저장·관리하며, 이 중 위협 분석 대상 이벤트 여부를 별도의 필드를 통해 관리
  · 「위협 분석 자동화 시스템」이 SQL Query를 통해 위협 분석 대상 이벤트를 직접 조회 및 수집 수행

- 원본로그 요청
  · 「위협 분석 자동화 시스템」이 SOAR 티켓을 생성하거나, 이벤트에 대한 상세 분석이 필요하여 더욱 다양한 정보를 얻기 위해 「이상행위 탐지 시스템」에게 해당 이벤트와 관련된 원본 로그를 요청
  · 요청 데이터에 필수적으로 ① 원본로그 요청 메시지 ID, ② 요청 시간, ③ 원본로그 요청과 관련된 이벤트 ID를 포함

- 원본로그 응답
  · 「이상행위 탐지 시스템」은 「위협 분석 자동화 시스템」의 원본로그 요청에 대하여 응답을 수행
  · 응답 데이터에 필수적으로 ① 원본로그 응답 메시지 ID, ② 응답 시간, ③ 원본로그 요청 메시지 ID, ④ 요청한 원본로그를 포함하여야 한다.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- 탐지 이벤트 우선처리 선정 요청
  · 「위협 분석 자동화 시스템」은 단기간 내에 탐지 이벤트가 다수 발생하였을 때 「의사결정 지원 시스템」에게 우선적으로 처리해야할 탐지 이벤트 선정 요청
  · 요청 데이터에 필수적으로 ① 탐지 이벤트 우선처리 선정 요청 메시지 ID, ② 요청 시간, ③ 탐지 이벤트 우선처리 선정 대상 리스트를 포함

- 탐지 이벤트 우선처리 선정 응답
  · 「의사결정 지원 시스템」은 「위협 분석 자동화 시스템」의 탐지 이벤트 우선처리 선정 요청에 대하여 응답을 수행한다.
  · 응답 데이터에 필수적으로 ① 탐지 이벤트 우선처리 선정 응답 메시지 ID, ② 응답 시간, ③ 탐지 이벤트 우선처리 선정 요청 메시지 ID, ④ 탐지 이벤트 우선처리 순서를 배정한 리스트를 포함

- 플레이북 이벤트 우선처리 선정 요청
  · 「위협 분석 자동화 시스템」은 플레이북 실행 도중 관제원의 개입이 필요한 이벤트들이 다수 발생하였을 때 「의사결정 지원 시스템」에게 우선적으로 처리해야할 플레이북 이벤트의 선정을 요청
  · 요청 데이터에 필수적으로 ① 플레이북 이벤트 우선처리 선정 요청 메시지 ID, ② 요청 시간, ③ 플레이북 이벤트 우선처리 선정 대상 리스트를 포함

- 플레이북 이벤트 우선처리 선정 응답
  · 「의사결정 지원 시스템」은 「위협 분석 자동화 시스템」의 플레이북 이벤트 우선처리 선정 요청에 대하여 응답을 수행
  · 응답 데이터에 필수적으로 ① 플레이북 이벤트 우선처리 정 응답 메시지 ID, ② 응답 시간, ③ 플레이북 이벤트 우선처리 선정 요청 메시지 ID, ④ 플레이북 이벤트 우선처리 순서를 배정한 리스트를 포함

- 최적 대응 방안 요청
  · 「위협 분석 자동화 시스템」은 이벤트에 대한 상세 분석을 마친 뒤, 해당 이벤트에 대한 가장 적절한 대응 방안을 수행하기 위하여 「의사결정 지원 시스템」에게 최적 대응 방안을 요청
  · 요청 데이터에 필수적으로 ① 최적 대응방안 추천 요청 메시지 ID, ② 요청 시간, ③ 현재 처리 중인 이벤트 ID, ④ 현재 실행 중인 플레이북 ID를 포함

- 최적 대응 방안 응답
  · 「의사결정 지원 시스템」은 「위협 분석 자동화 시스템」의 최적 대응 방안 요청에 대하여 응답을 수행한다.
  · 응답 데이터에 필수적으로 ① 최적 대응방안 추천 응답 메시지 ID, ② 응답 시간, ③ 최적 대응방안 추천 요청 메시지 ID, ④ 최적 대응방안이 포함된 정보를 포함

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- 보안 정책 적용 요청
  · 의사결정 지원 시스템으로부터 제공받은 최적 대응 방안 중 이기종 보안 장비에 보안 정책 직접 적용 필요 시 이기종 보안 장비 연동 API에 보안 정책 적용을 요청
  · 요청 데이터에 필수적으로 ① 보안 정책 적용 요청 메시지 ID, ② 요청 시간, ③ 보안 정책 데이터를 포함

2) SOC 통합 운영 및 자동화 플랫폼 설계

o 통합 플랫폼 구성
- 통합 플랫폼은 크게 3가지 시스템과 연계 기능들로 구성

<통합 플랫폼 시스템별 주요 기능 및 구성도>

o 주요 기능 실행 흐름 및 송·수신 데이터 포맷
- 통합 플랫폼 주요 기능의 목적은 각 시스템이 내부적으로 처리하는 기능들의 결과 데이터를 요청 · 응답하는 것이며, 실행 흐름은 A 시스템*의 요청과 B 시스템*의 응답과 같이 단순한 실행 흐름으로 구성
  ※ A, B 시스템은 통합 플랫폼을 구성하는 3가지 시스템들을 의미

<위협 분석 대상 이벤트 분류-조회 기능 데이터 포맷>

송신처	수신처	속성명	항목 설명	Type
위협 분석 자동화 시스템	이상 행위 탐지 시스템 (이벤트 관리 DB)	-	위협 분석 대상 이벤트 조회 Query	SQL Query
위협 분석 자동화 시스템		select_id	위협 분석 대상 이벤트 조회 ID	bigint
		select_date	조회 시간(yyyy-MM-dd hh:mm:ss)	varchar
		lastest_event_id	위협 분석 대상 이벤트 최근 조회 결과 ID	bigint

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

<원본로그 요청-응답 기능 데이터 포맷>

송신처	수신처	속성명	항목 설명	Type
위협 분석 자동화 시스템	이상 행위 탐지 시스템	req_id	요청 ID	bigint
		req_date	요청 시간(yyyy-MM-dd hh:mm:ss)	varchar
		event_id	원본로그 요청 대상 이벤트 ID	bigint
이상 행위 탐지 시스템	위협 분석 자동화 시스템	res_id	응답 ID	bigint
		res_date	응답 시간(yyyy-MM-dd hh:mm:ss)	varchar
		req_id	요청 ID	bigint
		origin_log	조회 결과 완료된 원본로그	text

<탐지 이벤트 우선처리 선정 요청-응답 기능 데이터 포맷>

송신처	수신처	속성명	항목 설명	Type
위협 분석 자동화 시스템	의사결정 지원 시스템	req_id	요청 ID	bigint
		req_date	요청 시간(yyyy-MM-dd hh:mm:ss)	varchar
		event_list	탐지 이벤트 우선처리 선정 대상 리스트	text
의사결정 지원 시스템	위협 분석 자동화 시스템	res_id	요청 ID	bigint
		res_date	응답 시간(yyyy-MM-dd hh:mm:ss)	varchar
		req_id	응답 ID	bigint
		sort_event_list	우선처리 순서를 배정한 이벤트 리스트	text

<플레이북 이벤트 우선처리 선정 요청-응답 기능 데이터 포맷>

송신처	수신처	속성명	항목 설명	Type
위협 분석 자동화 시스템	의사결정 지원 시스템	req_id	요청 ID	bigint
		req_date	요청 시간(yyyy-MM-dd hh:mm:ss)	varchar
		event_list	플레이북 이벤트 우선처리 선정 대상 리스트	text
의사결정 지원 시스템	위협 분석 자동화 시스템	res_id	요청 ID	bigint
		res_date	응답 시간(yyyy-MM-dd hh:mm:ss)	varchar
		req_id	응답 ID	bigint
		sorted_event_list	우선처리 순서를 배정한 이벤트 리스트	text

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

<최적 대응 방안 요청-응답 기능 데이터 포맷>

송신처	수신처	속성명	항목 설명	Type
위협 분석 자동화 시스템	의사결정 지원 시스템	req_id	최적 대응방안 추천 요청 ID	bigint
		req_date	요청 시간(yyyy-MM-dd hh:mm:ss)	varchar
		event_id	현재 처리중인 이벤트 ID	bigint
		playbook_id	현재 실행 중인 플레이북 ID	bigint
의사결정 지원 시스템	위협 분석 자동화 시스템	res_id	최적 대응방안 추천 응답 ID	bigint
		res_date	응답 시간(yyyy-MM-dd hh:mm:ss)	varchar
		req_id	최적 대응방안 추천 요청 ID	bigint
		response_id_list	최적 대응을 위한 컴포넌트 배치 순서 리스트	text

<보안 정책 적용 요청 기능 데이터 포맷>

송신처	수신처	속성명	항목 설명	Type
위협 분석 자동화 시스템	이기종 보안 장비 연동 API	req_id	요청 ID	bigint
		req_date	요청 시간(yyyy-MM-dd hh:mm:ss)	varchar
		security_policy	보안 정책 요청 데이터	text

2-3. 3차년도 연구 수행 내용 및 성과

세부 기술 ① **AI·빅데이터 기반 보안 장비 이상행위 탐지 기술 고도화**

□ 연구 목표

- o 이기종 보안 장비 연동 데이터 및 대응 정책 연동 기술 실증
- o TTP 기반 이상행위 탐지 및 분류 기술 개발
- o 보안 관제 빅데이터 기반 이상행위 탐지 기술 개발 및 고도화
- o AI·빅데이터 기반 이기종 보안 장비 이상행위 탐지 성능 향상 기술 개발
- o 공개 보안 위협 인텔리전스 정보 수집 기술 개발

□ 연구 목표별 추진 실적

연구목표	이기종 보안 장비 연동 데이터 및 대응 정책 연동 기술 실증

세부 내용	1) 네트워크 보안 장비 정형·비정형 데이터 수집 및 정규화 기술 실증
	2) 이기종 보안 장비의 연동 범위 확대를 위한 기술 실증처 확보

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

1) 네트워크 보안 장비 정형·비정형 데이터 수집 및 정규화 기술 실증

o (데이터 수집) 4종(IPS, IDS, F/W, WAF) 벤더사 별 14개 네트워크 보안 장비 로그 실데이터 수집
- 네트워크 보안 장비 로그 데이터 수집 후 필수 필드 분석 및 필수 정보 선정

o (데이터 정규화 기술) 딥러닝 기반 필수 정보 개체명 인식 기술 개발
- 딥러닝 알고리즘 5종(Bi-LSTM-CRF, BERT-CRF, RoBERTa-CRF, XLM-RoBERTa 등) 구현 및 알고리즘 별 네트워크 보안 장비 필수 정보 인식 성능 분석

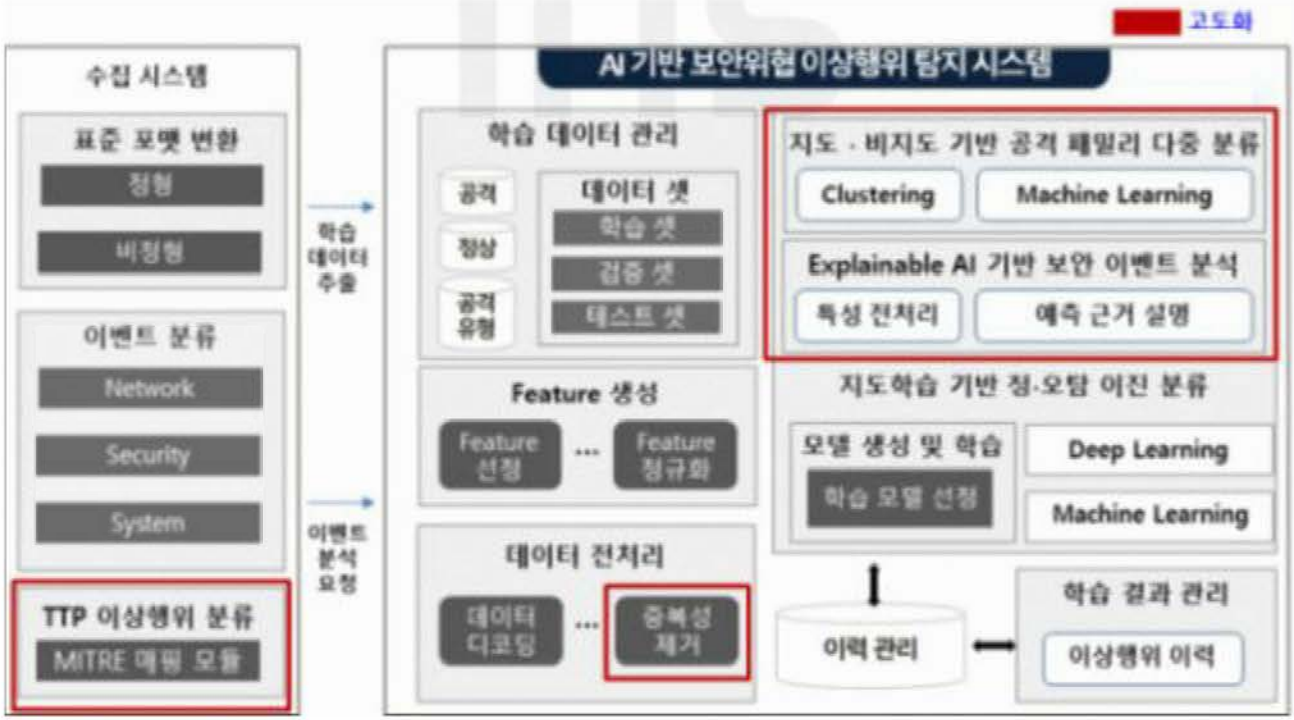
※ 학습·테스트 데이터 : 수집한 14개 네트워크 보안 장비 데이터 31,807개~63,614개

모델 / 지표	Bi-LSTM-CRF	BERT-CRF	RoBERTa	RoBERTa-CRF	XLM-RoBERTa
Accuracy	99%	97%	96%	97%	99%
Macro avg	26%	83%	91%	91%	98%
weighted avg	48.6%	96%	97%	97%	99%

o (실증) 참여기관(㈜윈스)의 자사 보안관제 환경 대상 이기종 보안 장비 연동 및 대응 정책 연동 기술 실증

※ 실증 환경 구축 완료(~10.13일), 연동 기술 실증 수행(~11월)

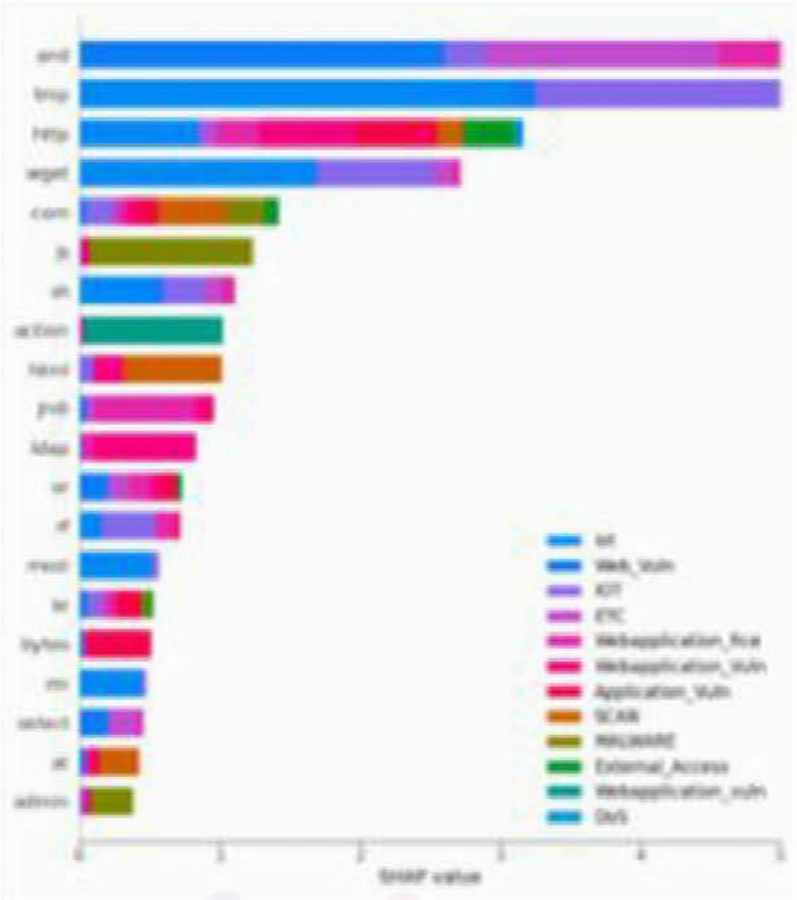
– **(기술고도화)** 보안 장비 **이상행위 탐지 기술 고도화 완료**



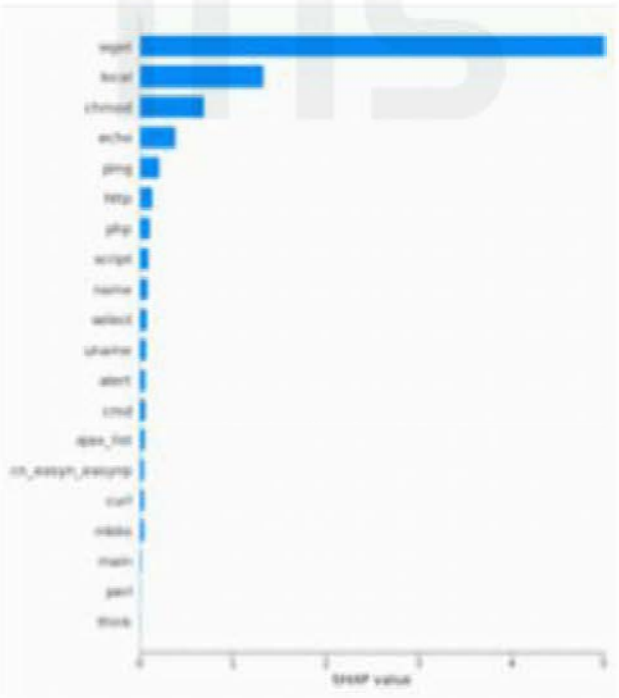
<이상행위 탐지 시스템 고도화 요소>

① 보안관제 빅데이터의 효율적인 AI 학습을 위한 클러스터링 기반 데이터 중복성 분석 및 제거 기술 개발 완료
② TTP 기반 이상행위 탐지 및 분류 기술 개발 완료
③ Explainable AI 기반 이상행위 판단 근거 설명 기술 개발 완료

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



<사이버 공격 유형별 SHAP 분석 결과>



<IoT 사이버 공격 SHAP 분석 결과>

④ 머신러닝 기반 이상행위 탐지를 위한 다중 클래스 분류 모델 설계 및 개발 완료

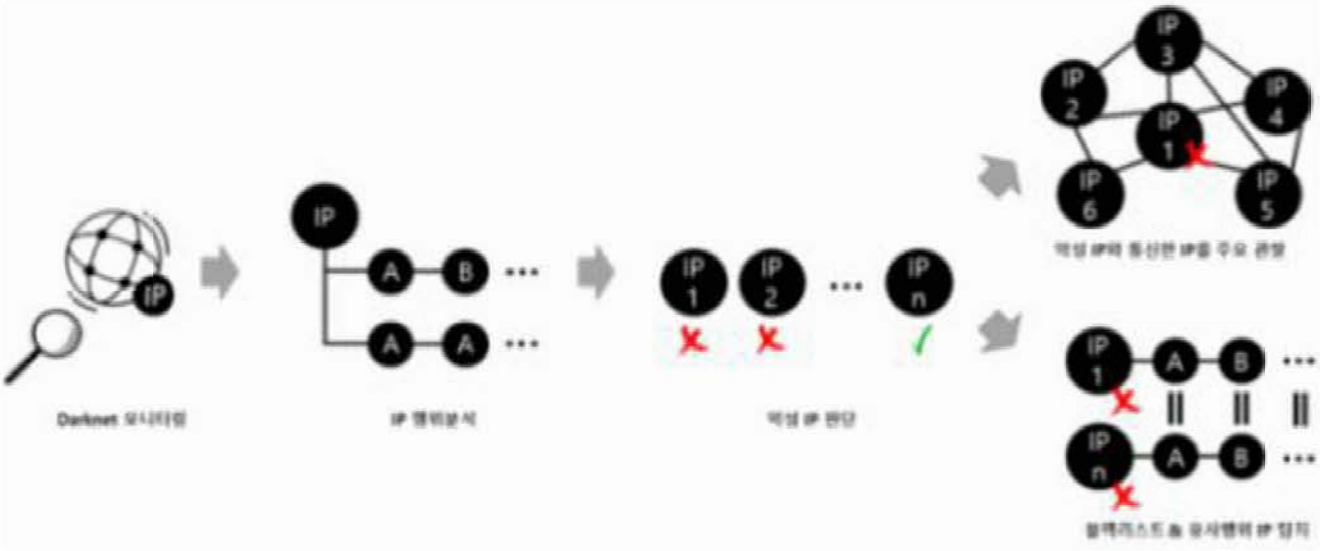
⑤ 클러스터링 기반 유사 사이버 공격 행위 분류 개발 완료

⑥ 다크넷 기반 이기종 보안장비 이상행위 분석·탐지 개발 중

※ 이기종 보안 데이터(다크넷에서 탐지된 패킷들과 라이브넷에서 탐지된 보안이벤트)간의 IP의 연관성 분석 및 이상 행위 탐지

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

※ 實보안관제 센터에서 탐지되는 주요 공격('22~'23년도 발생)을 대상으로 테스트한 결과 위협탐지모델 분류 정확도(f1-score) 0.92 달성

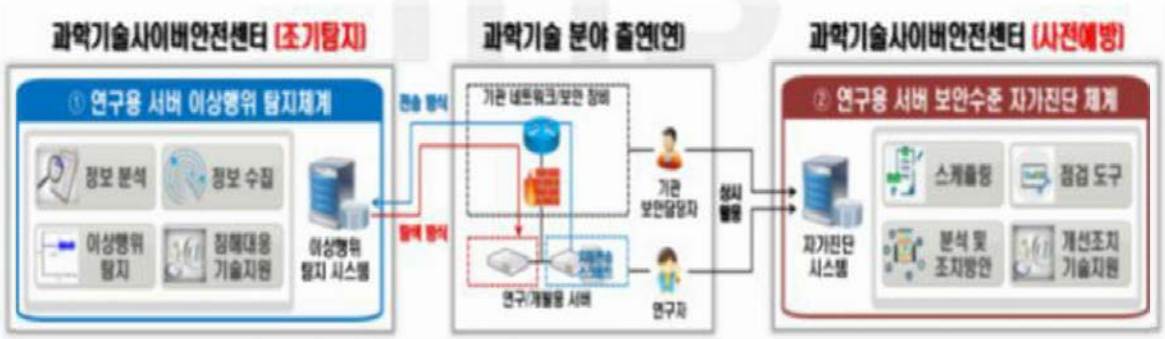


<다크넷 기반 이기종 보안장비 이상행위 분석·탐지 개념도>

2) 이기종 보안 장비의 연동 범위 확대를 위한 기술 실증처 확보

o KISTI 과학기술사이버안전센터 (Science and Technology-Cyber Security Center, S&T-CSC)

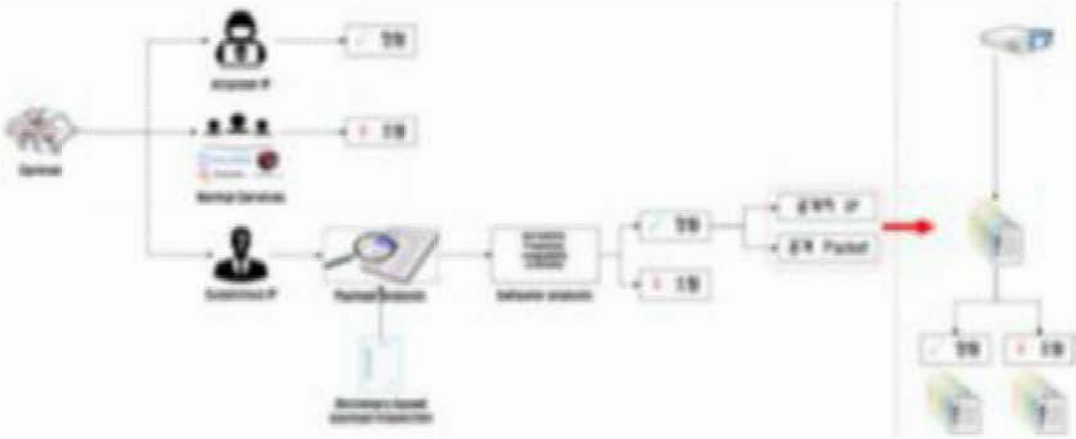
- 과학기술분야 핵심 연구정보자원을 사이버위협으로부터 보호하고 침해사고 피해 최소화 및 사전예방 능력 강화를 위해 2005년 3월 개소
- 과학기술분야 특화 정보보호 인프라 구축·고도화를 통해 출연(연)·공공기관을 대상으로 전주기적 정보보호 서비스(관제→분석→대응·예방) 제공



<KISTI S&T-CSC 전주기적 정보보호 서비스 체계도>

- KISTI S&T-CSC 자체 구축 다크넷 기반 이기종 보안장비 연동 데이터 보유
  - · 국가과학기술연구망에 설치된 N-IDS 장비와 상호 연관분석 가능
  - · 다크넷 기반 보안데이터를 통해 자체 구축 CTI의 정확도 점검
  - · 공격의심 IP의 접근주기·빈도·범위·연속성 기반 정상 및 공격자 IP 분류

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

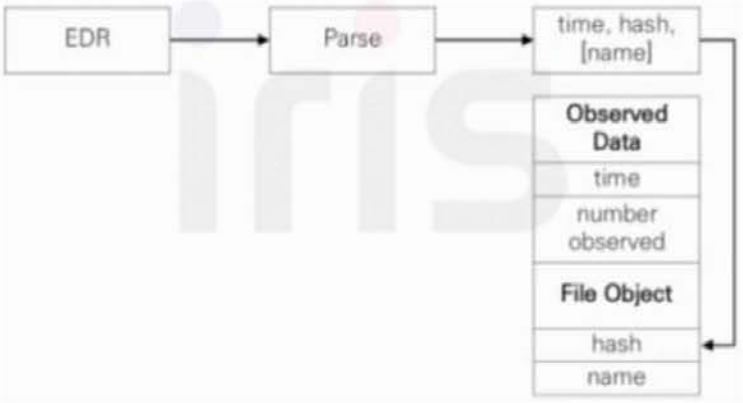


<KISTI S&T-CSC 자체 구축 다크넷 구성도>

- 實환경 기반 대량의 신·변종 악성 행위정보 수집을 통해 차세대 보안관제 및 침해대응 원천기술 연구·검증 및 적용

o (단말 보안 장비 데이터 확보) KISA 내 팀 협업을 통해 운영 중인 단말 보안 장비 실 데이터 확보 및 정규화 기능 개발

- 단말 보안 장비 필드 분석 및 변환 대상 필수 필드 선정
- 단말 보안 장비 데이터 정규화 및 변환(STIX Observed data objects 활용) 기능 개발



<EDR 데이터 변환 프로세스>

연구목표	TTP 기반 이상행위 탐지 및 분류 기술 개발

세부 내용	1) 관계 유사도 분석 및 TTP 기반 이상행위 상관관계 분석·탐지 기술 설계 및 개발
	2) 데이터 특성 상관관계 분석 기반 이상행위 분류 및 클러스터링 기술 설계 및 개발

1) 관계 유사도 분석 및 TTP 기반 이상행위 상관관계 분석·탐지 기술 설계 및 개발

o TRAM(Threat Report ATT&CK Mapper) 기술 연구 및 위협로그 데이터 수집 시 연관 분석, 탐지 기술 개발

- TRAM 기반 TTP 위협 인자 식별 기술 연구 및 구현

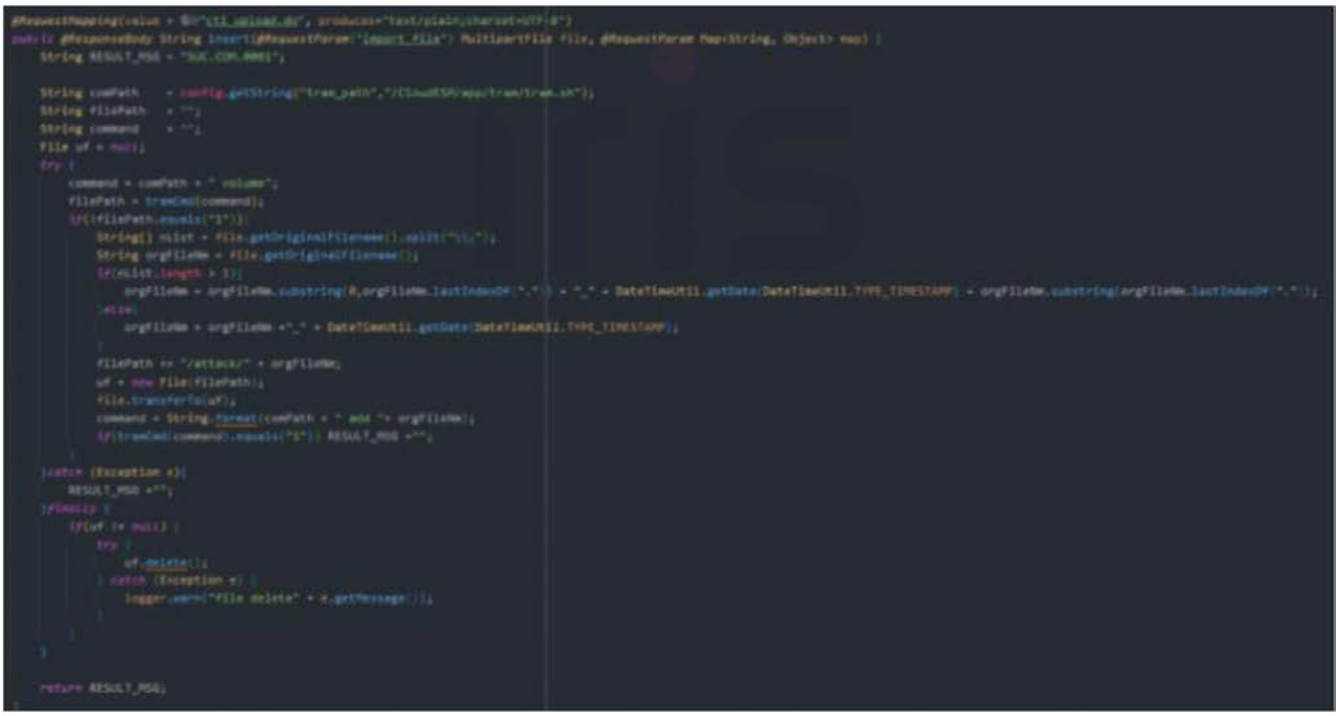
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

TRAM (Threat Report ATT&CK Mapper)

- MITRE CTID에서 제공하는 오픈소스 (https://github.com/center-for-threat-informed-defense/tram/)
- ML을 사용하여 CTI 보고서에 대한 ATT&CK 기술 식별 자동화 방법 연구

입력 데이터	CTI Report(.pdf/.docx/.html)
출력 데이터	Technique ID(MITRE ATT&CK), Confidence(predict)
학습 모델	Logistic Regression Model
	NaïveBayes Model
	~~Dummy Model~~
훈련 데이터	ATT&CK Technique ID별 reference-text(.json)
정확도	

- TRAM 기반 TTP 위협 인자 식별 기술 개발

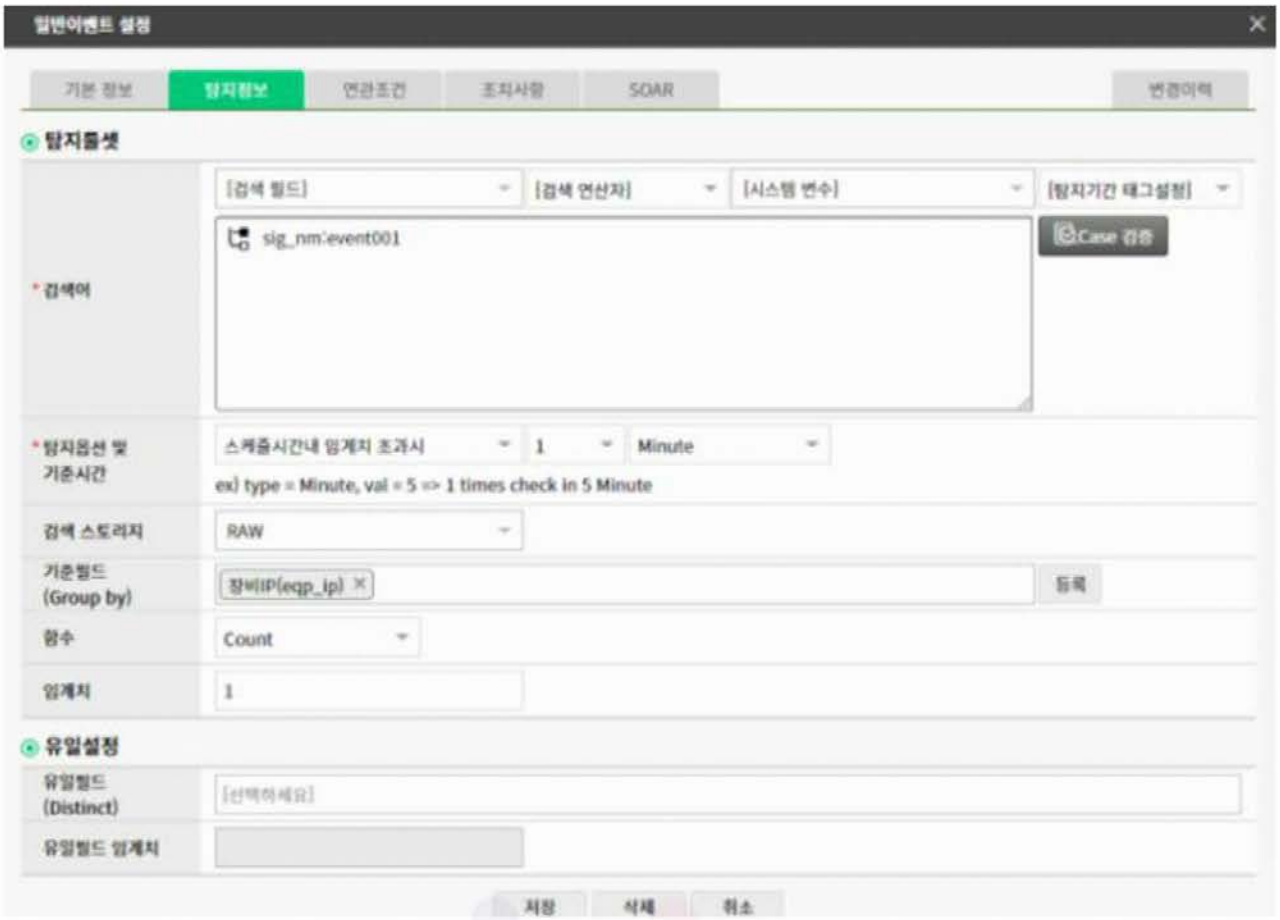


2) 데이터 특성 상관관계 분석 기반 이상행위 분류 및 클러스터링 기술 설계 및 개발

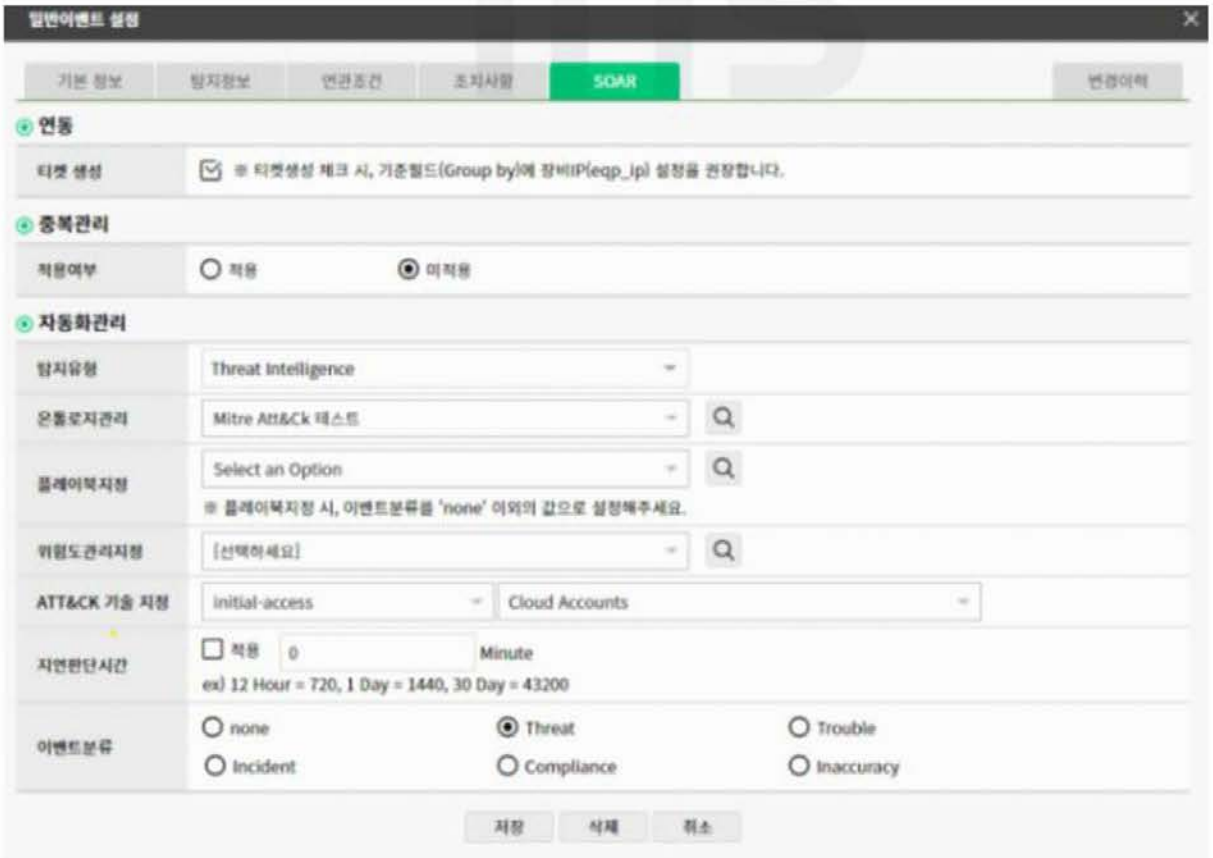
o 위협로그 데이터 대상 이상행위 분류 기술 연구 및 구현

- Query 기반 이상행위 탐지 기술 개발

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

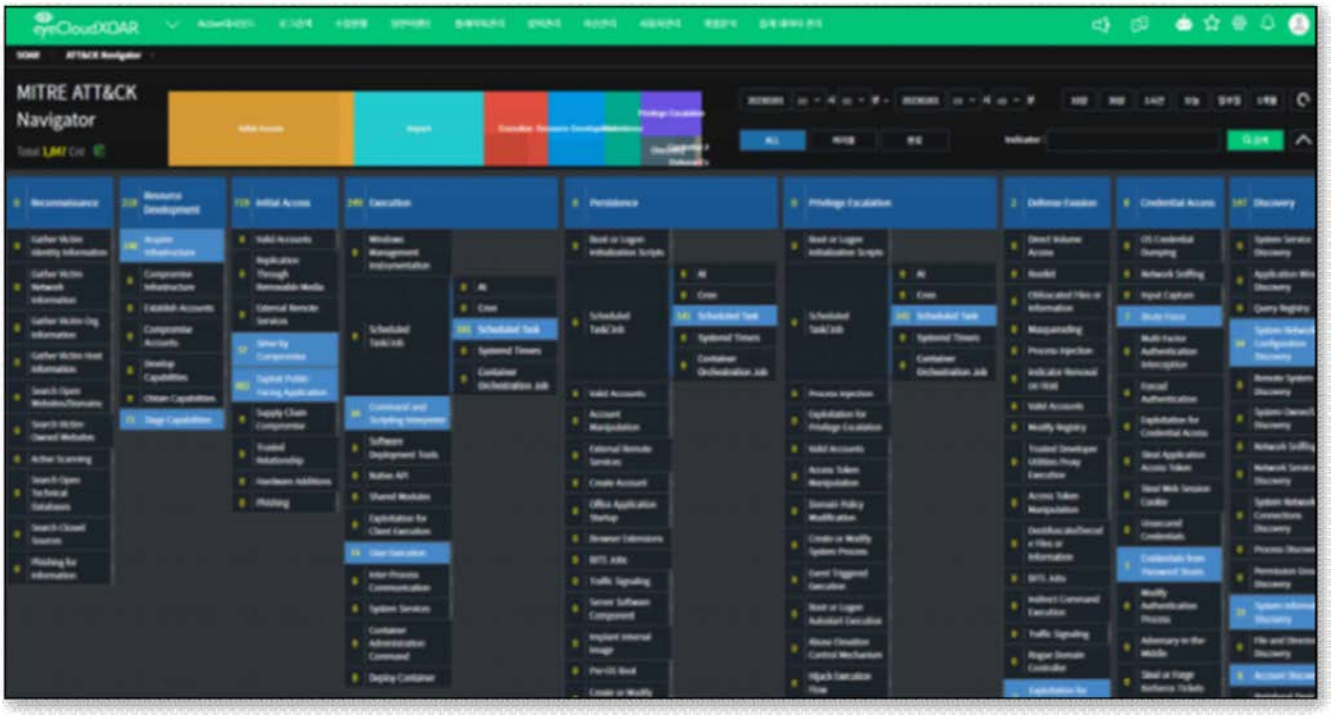


- MITRE ATT&CK 기반 이상행위 분류 기술 개발



- MITRE ATT&CK 기반 이상행위 탐지 모니터링 및 분류 가시화 개발

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



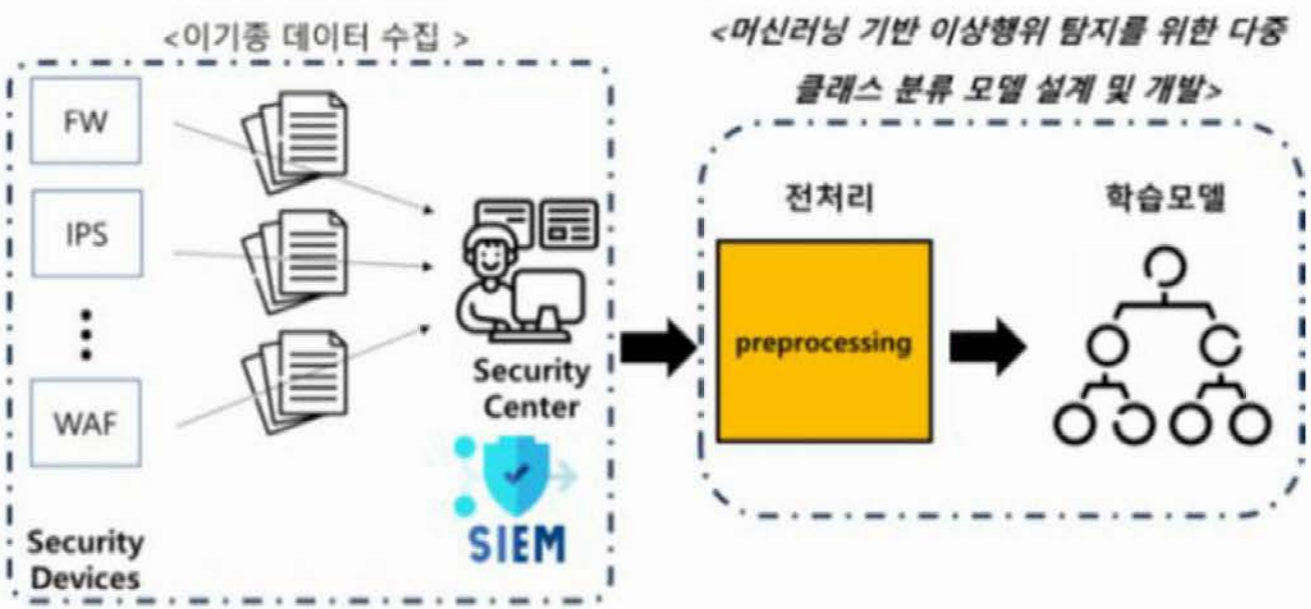
연구목표	보안 관제 빅데이터 기반 이상행위 탐지 기술 개발 및 고도화

세부 내용	1) 머신러닝 기반 이상행위 탐지를 위한 다중 클래스 분류 모델 설계 및 개발

1) 머신러닝 기반 이상행위 탐지를 위한 다중 클래스 분류 모델 설계 및 개발

o 다중 클래스 분류 모델 설계 및 개발

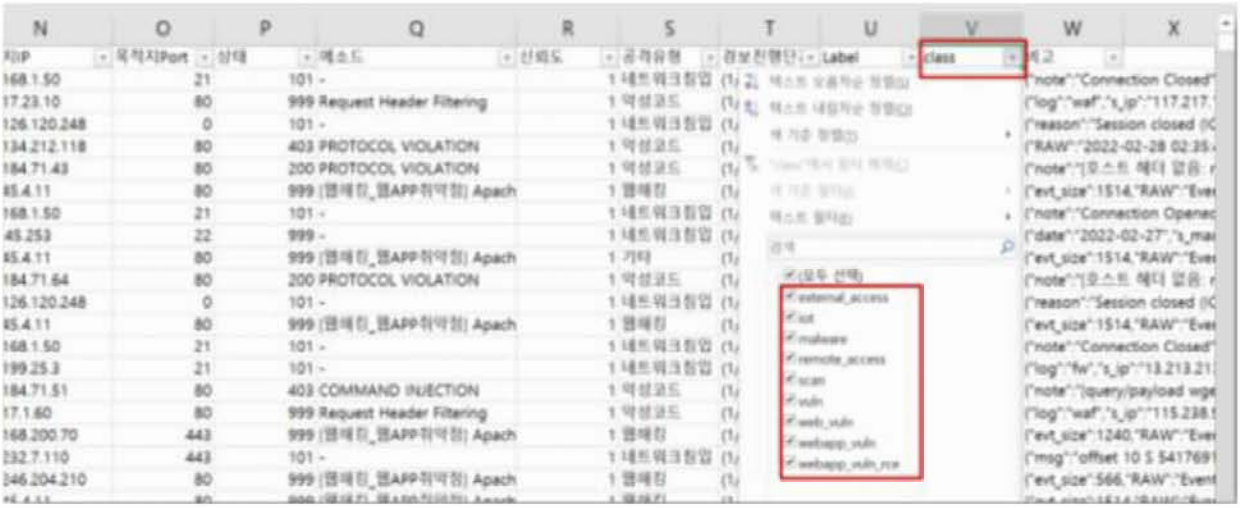
- 다양한 보안장비에서 수집된 이기종 보안관제 데이터를 사용하여 머신러닝 모델을 학습하여 다중 클래스(공격 종류) 분류가 가능한 모델을 설계하고 개발함



o 이기종 데이터 분석

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- 아래 32개의 서로 다른 보안 장비에서 탐지한 데이터를 활용



- 데이터셋은 CSV파일 형태로 관리되며, 핵심 열에 대한 설명은 아래와 같음

열 이름	설명
탐지 이벤트 접수 상태	공란 : 아무런 처리를 하지 않음 0 : 무시(중복, 영향없음, 오탐 등으로 인한 불필요 이벤트) 1 : 완료(확인 -> 대응 불필요) 2 : 티켓팅(이벤트 접수 -> 대응)
HitCount	일정 시간 동안 탐지 정책 및 방화벽 규칙에 따라 일정 횟수 이상으로 발생한 이벤트
메소드	최초 기관이 보유한 TMS 장비에서 이벤트의 메소드값을 가공한 후 사회보장정보원 SIEM 장비에서 수집하여 한 번 더 재가공한 데이터
상태	보안 장비의 대응 상태 정보 101(방화벽 허용), 102(방화벽 차단), 999(기타) 등
관제룰명	사보원의 SIEM 장비에서 출력한 관제 룰의 이름
비고	페이로드 등 SIEM 장비의 세부 내역을 담아놓음
Class	최종적으로 분류된 공격의 종류

- 모든 데이터들은 특정 기준에 따라 레이블링하며 레이블 및 기준은 다음과 같음.

클래스 이름	설명
application_vuln	- 소프트웨어 취약점을 공격하는 이벤트 - 클라이언트 소프트웨어(브라우저, 문서 뷰어 등), 서버 데몬(HTTPD 등) - 메소드 및 페이로드 기준 레이블링
db_access_attempt	- 원격에서 DB 포트에 접근한 허가되지 않은 이벤트 - 목적지 포트 기준 레이블링
dos	- 서비스 거부 공격(Flooding 등) - 메소드 기준 레이블링
etc	- 정상 이벤트, 오탐, 분류되지 않은 공격 유형들 - 메소드 및 페이로드 기준 레이블
external_access	- 내부에서 공격 서버로 접속한 이벤트 - CnC, 비인가 사이트 접속 등 - 메소드 기준 레이블링
iot	- IOT 기기를 공격하는 이벤트 - wget / curl 명령어 관련 탐지 규칙이 많아 기관에 크게 영향이 없는 IOT 이벤트가 다수 탐지

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

	- 메소드 및 페이로드 기준 레이블링
malware	- 악성코드 관련 이벤트 - 메소드 기준 레이블링
nan	- 레이블링 되지 않은 데이터
scan	- 포트 스캔, 서비스 스캔 등으로 탐지/차단된 이벤트 - 메소드 기준 레이블링
system_access_attempt	- 외부 공격자가 시스템 중요 포트(21/23/22/3389 등)에 접근한 이벤트 - 목적지 포트 기준 레이블링
web_vuln	- 웹 취약점을 공격하는 이벤트 - 메소드 및 페이로드 기준 레이블링
webapplication_rce	- 웹 어플리케이션(아파치/CMS 등)을 공격하는 이벤트 - 메소드 및 페이로드 기준 레이블링
webapplication_vuln	- 웹 어플리케이션의 원격코드실행 취약점을 공격하는 이벤트 - 메소드 및 페이로드 기준 레이블링

- 레이블들의 분포는 다음과 같음.

클래스 이름	개수
nan	130,906
etc	90,781
system_access_attempt	75,311
scan	48,798
web_vuln	38,082
external_access	25,177
malware	15,044
iot	10,338
application_vuln	5,375
db_access_attempt	5,259
webapplication_rce	4,862
webapplication_vuln	4,218
dos	3,197
총 개수	**457,348**

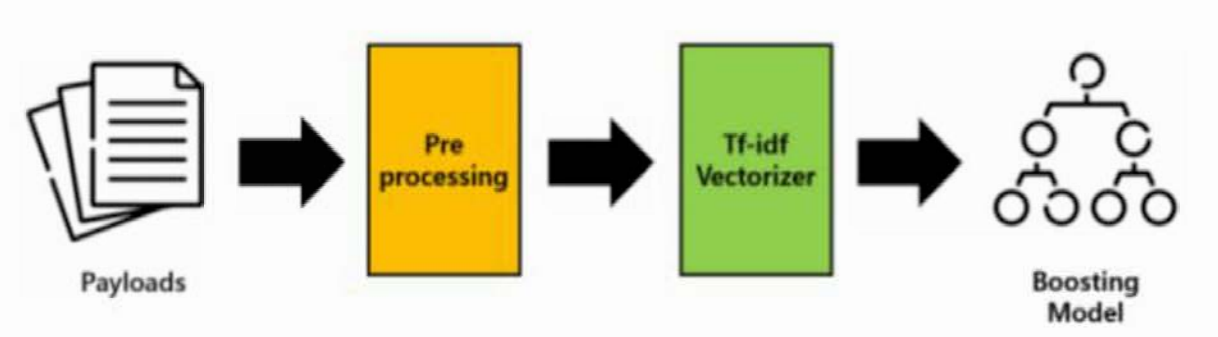
- 클래스 'nan' 레이블링이 되지 않은 데이터이므로 제외
- 그 외에도 IP와 같은 정보도 존재하나, 익명화 등의 이유로 제외
- 페이로드의 md5 값은 동일하나, 클래스가 다른 데이터는 제외

o 전처리 및 모델 학습

- 학습을 위해 데이터를 학습용 데이터와 테스트용 데이터로 나눔.

- 전체적인 학습 구조는 다음과 같음.

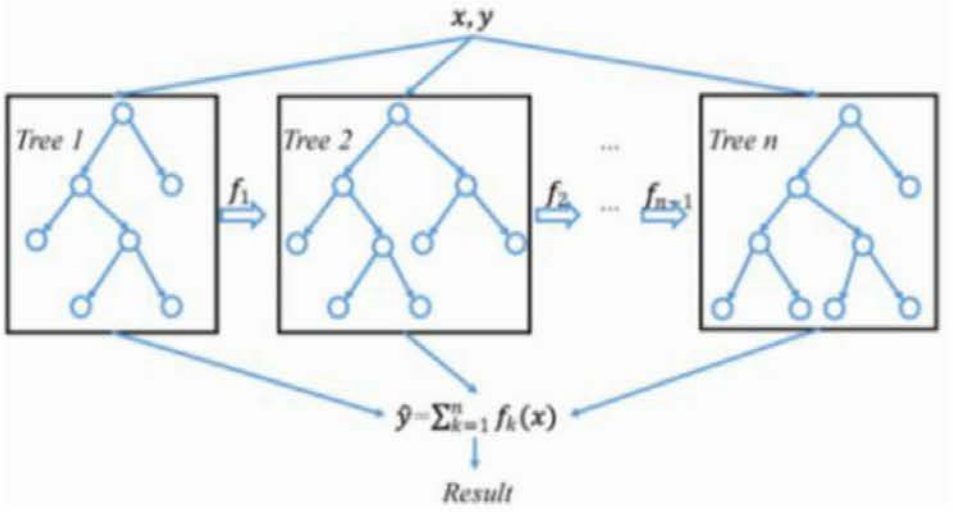
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



- 전처리 알고리즘은 ascii 범위 내의 16진수를 인코딩하는 작업 또는 IP와 같은 불용어를 제거하는 작업을 수행

$$tf(t,d) = \frac{f_{t,d}}{\sum_{t' \in d} f_{t',d}} \qquad idf(t,D) = log\frac{N}{|\{d \in D : t \in d\}|}$$

- tf-idf 알고리즘에서 tf는 term-frequency의 약자로 한 페이로드에서 나타난 단어의 개수를 의미
- idf는 inverse document-frequency의 약자로 전체 페이로드에서 그 단어가 나온 문서의 비율 값에 log를 취한 값을 뜻함.
- 단어마다 위의 두 값을 구한 후 곱하는 과정이 tf-idf 알고리즘의 과정
- 전체 페이로드에서 나올 수 있는 단어의 개수가 너무 많으므로 tf-idf값 평균 상위 512개의 단어만 가져와서 512차원의 벡터를 형성
- 학습 모델은 앙상블 기법 중 하나인 boosting 기법을 채용한 xgboost 모델 사용



- boosting 모델은 의사 결정 트리 모델을 여러 단계로 나누어서 학습을 시키며, 서서히 오류를 고쳐나가는 방식
- 학습시킨 결과 성능은 다음과 같이 나옴.

클래스 이름	precision	recall	f1-score
application_vuln	0.9830	0.9821	0.9825
db_access_attempt	0.9471	0.9525	0.9498
dos	0.9936	0.9968	0.9952

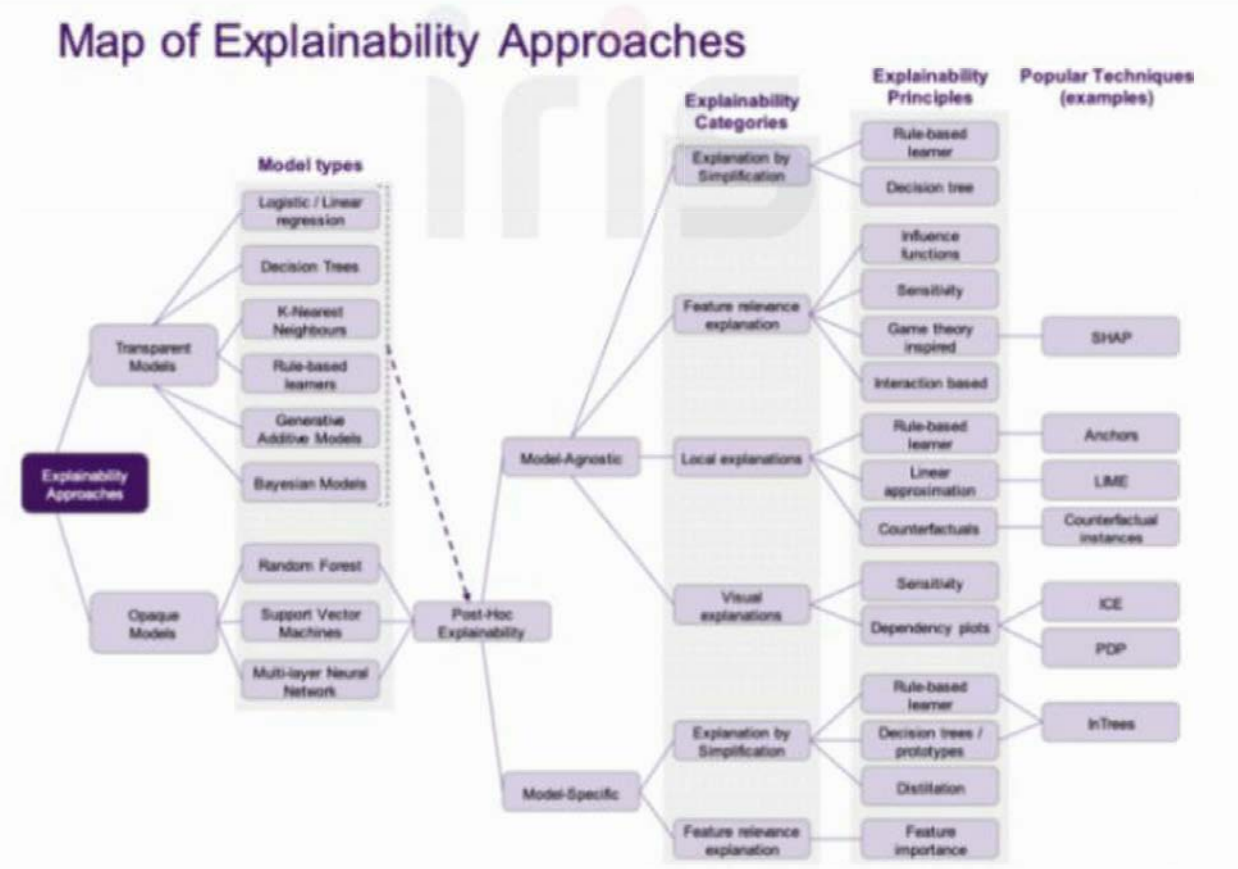
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

etc	0.9961	0.9982	0.9972
external_access	0.9977	0.9539	0.9753
iot	0.9957	0.9976	0.9966
malware	0.9331	0.9925	0.9619
scan	0.9999	0.9996	0.9997
system_access_attempt	0.9963	0.9958	0.9961
web_vuln	0.9978	0.9953	0.9965
webapplication_rce	0.9839	0.9839	0.9839
webapplication_vuln	0.9731	0.9765	0.9748
macro average	0.9831	0.9854	0.9841
weighted average	0.9925	0.9923	0.9924

- macro average는 클래스 별 지표값의 평균을 나타낸 것이고, weighted average는 각 클래스 별 지표 값에서 클래스 별 데이터 개수를 가중치로하여 평균 계산

o 설명 가능한 인공지능

- 설명가능한 인공지능(eXplainable Artificial Intelligence, 이하 XAI)를 통해 모델에 대한 신뢰성을 높이고, 디버깅을 용이하게 하고자 함.

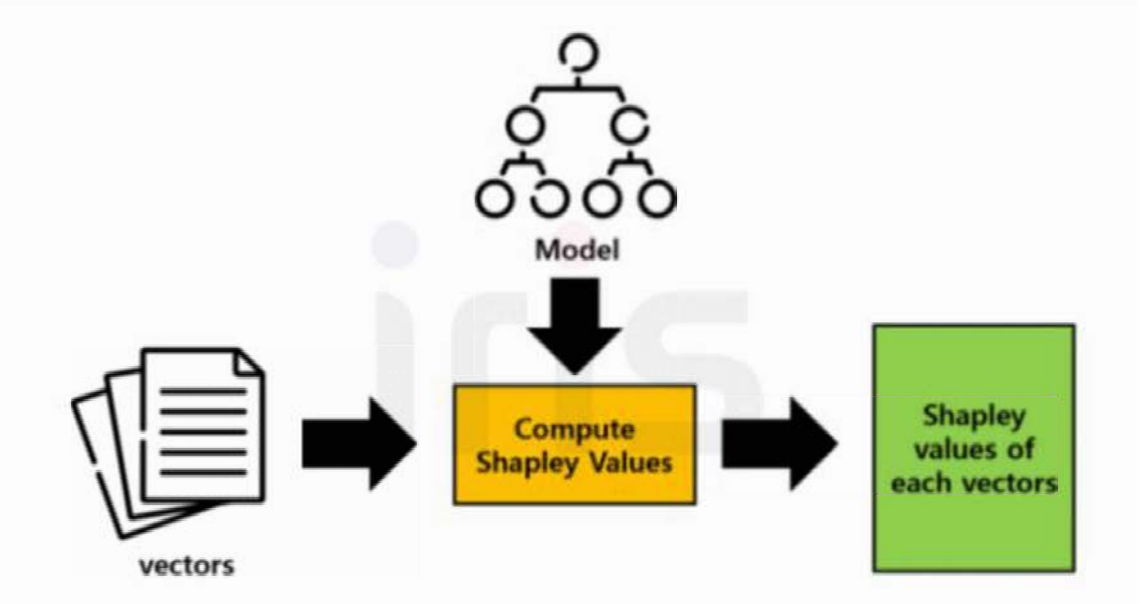


- XAI는 선형회귀 모델같이 단순한 모델을 통해 설명을 하는 방식 등 존재
- 이 중 SHAP 알고리즘을 사용하여 학습한 모델에 대하여 설명
- SHAP 알고리즘은 모델이 사용하는 피처(feature)와 모델의 예측 값을 가지고 설명하기 때문에, 모델에 구애받지 않는(model-agnostic) 알고리즘

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

$$\phi_i = \sum_{S \subset F - \{i\}} \frac{|S|!(|F| - |S| - 1)!}{|F|!} \{f(S \cup \{i\}) - f(S)\}$$

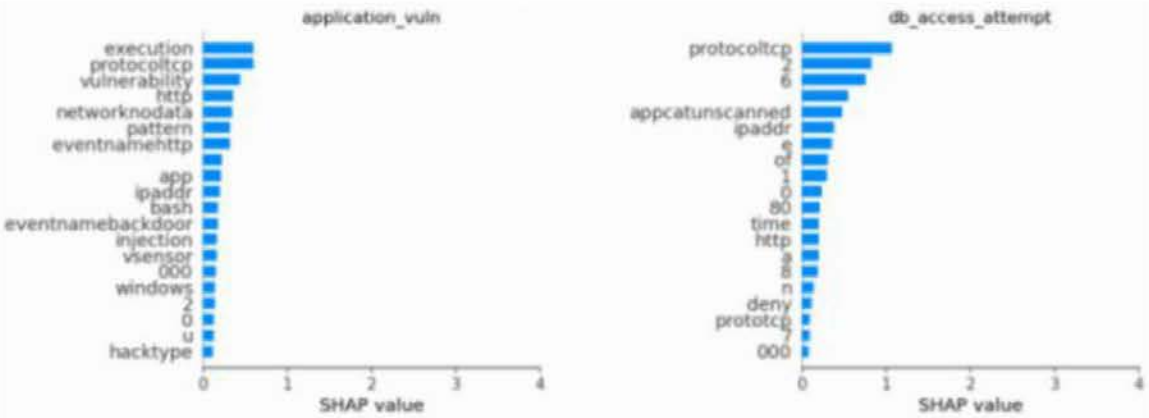
- SHAP 알고리즘은 로이드 섀플리(Lloyd Shapley)가 고안한 섀플리 값(shapley value) 사용하여, 피처가 모델에 끼치는 영향을 나타냄.
- 섀플리 값은 피처가 있을 때와 없을 때의 모델의 예측 값의 차이를 계산하고, 전체 경우의 수에 대하여 평균을 낸 값을 의미
- 섀플리 값이 양수일 경우, 피처가 모델의 예측에 도움이 됨을 의미하고, 음수일 경우 방해가 됨을 의미
- 섀플리 값은 한 데이터에 대해서 계산이 가능하며, 전체 데이터에 대한 추세를 알고 싶을 경우, 전체 데이터의 섀플리 값의 절대 값의 평균값을 계산

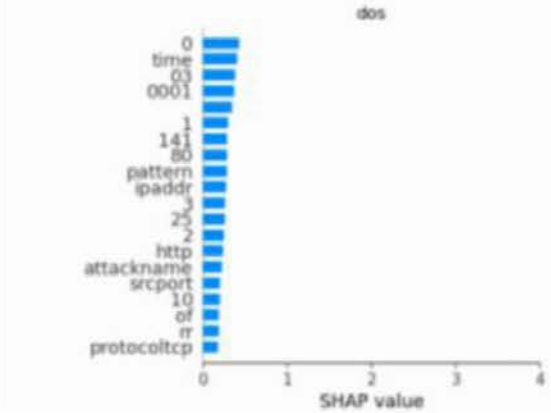


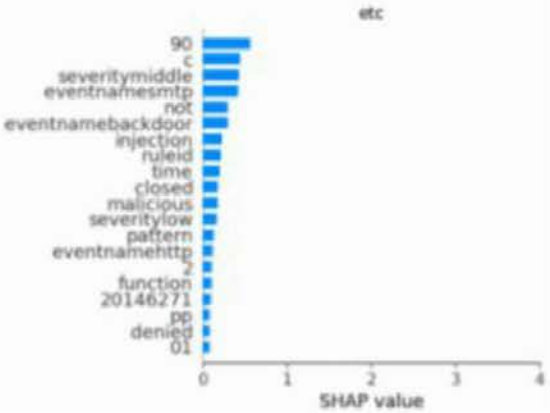
<데이터에 대한 섀플리 값 도식화>

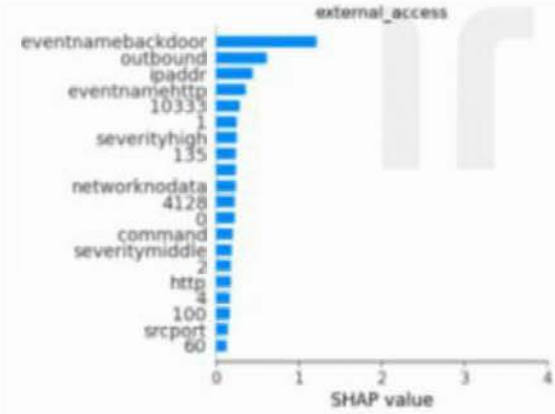
- 위의 그림을 바탕으로 앞서 소개한 데이터와 학습시킨 모델을 바탕으로 섀플리 값을 구함
- 다만, 섀플리 값은 이진 분류를 기반으로 계산하기 때문에 각 클래스 별로 섀플리 값을 계산
- 각 클래스 별 테스트 데이터의 섀플리 값의 절대값 평균은 다음과 같음.

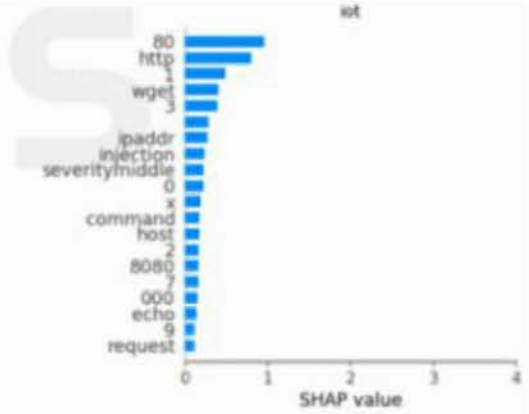
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

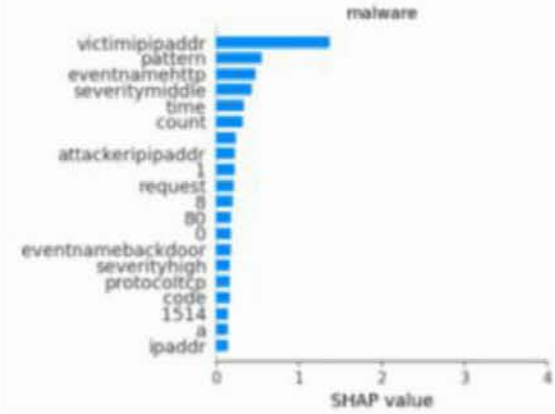


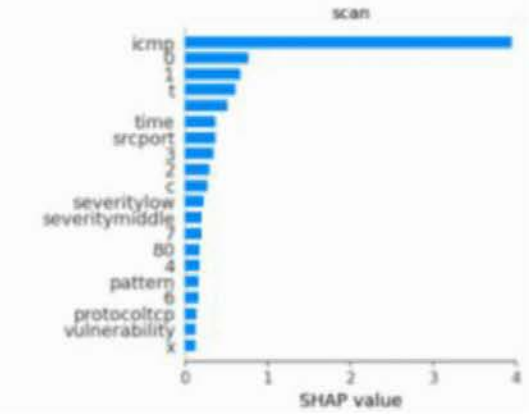




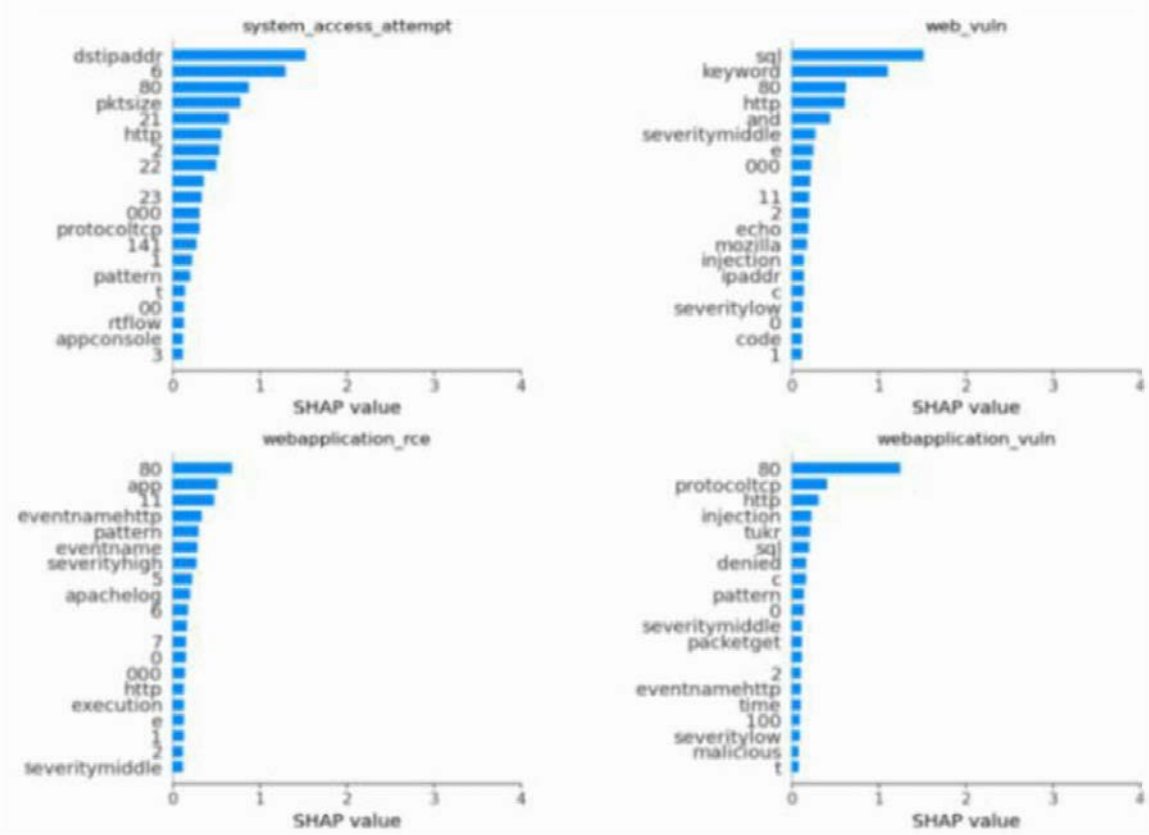








국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



- 해당 클래스를 예측하는데 중요한 피처들도 보이지만 의미 없는 피처들도 존재
- 그러한 피처들을 불용어 처리와 같은 방법으로 제거해주고 재학습을 반복하면 유의미한 피처들을 찾아낼 수 있음.

연구목표	AI・빅데이터 기반 이기종 보안 장비 이상행위 탐지 성능 향상 기술 개발

세부 내용	1) 이기종(3종) 보안장비 데이터 연관특징 기술 연구 및 설계
	2) 이상행위 자동탐지 신뢰도 향상을 위한 학습데이터 자동 레이블링 기술개발 및 검증
	3) 신·변종 이상행위 탐지를 위한 강화학습 기반 이상행위 탐지 모델 구축

1) 이기종(3종) 보안장비 데이터 연관특징 기술 연구 및 설계

o 이기종 보안장비 공통정보를 활용한 특징추출 기술 연구

- 이기종 보안장비 공통정보 분석
  - ・이기종 보안장비에서 공통으로 추출되는 5-tuple 정보 및 페이로드 분석
  - ・공통정보 기반 보안이벤트 유형별 행위특성 분석 (출발지·목적지 포트유형 중심)

<보안이벤트 포트유형별 페이로드 길이 비교>

포트번호	출발지 평균	목적지 평균	전체 평균
443	265.037	213.463	234.345
80	543.567	397.150	398.044
25	122.952	163.819	142.063
587	158.395	68.978	113.582
8080	142.103	210.300	207.869
110	86.459	76.162	85.482
21	137.798	70.608	127.136
3389	381.577	97.984	98.246

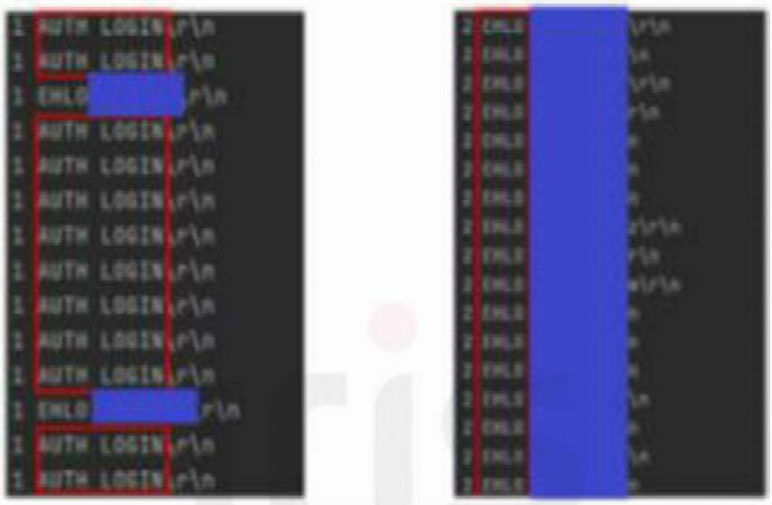
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

<보안이벤트 포트유형별 주요 사용 바이트 상위 10개 비교 예시>

80번 포트			
바이트	출발지	목적지	전체
101	147,097	14,889,484	15,036,581
116	106,626	11,347,676	11,454,302
32	105,688	10,640,818	10,746,506
110	75,683	9,919,676	9,995,359
105	60,278	9,562,556	9,622,834
99	39,329	9,243,993	9,283,322
111	69,040	9,105,133	9,174,173
47	66,791	9,000,282	9,067,073
46	34,760	8,700,137	8,734,897
112	49,635	8,443,819	8,493,454

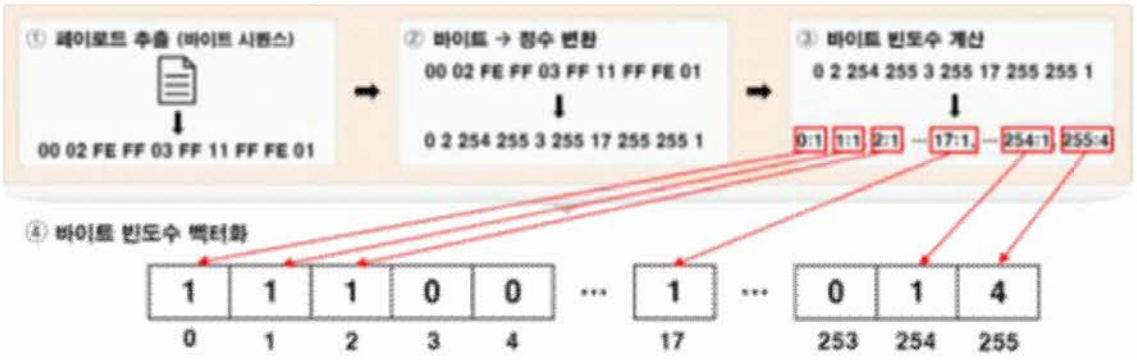
3389번 포트			
바이트	출발지	목적지	전체
0	346	518,510	518,856
115	52	92,830	92,882
111	87	74,270	74,357
104	40	73,946	73,986
61	70	62,061	62,131
13	76	58,655	58,731
108	68	58,480	58,548
8	57	57,847	57,904
3	91	57,526	57,617
64	61	57,451	57,512

· 이기종 보안장비 보안이벤트 정·오탐 유형별 행위특성 분석 (페이로드 중심)



<보안이벤트 정·오탐 유형별 페이로드 비교 예시 (좌: 정탐 / 우: 오탐)>

- 페이로드 정보 바이트 통계 기반 특징추출 기술 연구
  · 보안이벤트 페이로드 내 바이트 정보를 정·오탐 보안이벤트 행위특성으로 간주
  · 페이로드 정보 내 바이트별 빈도수(바이트 히스토그램)를 추출하여 이기종 보안장비 이상행위 탐지모델 학습에 사용



<페이로드 바이트 히스토그램 추출 방법 예시>

o 이기종 보안장비 공통 메타정보 및 페이로드 정보 공동 활용 기술 연구
  - 보안이벤트 유형별 통계분석 기반 학습에 유리한 공통 메타정보 3종 선정
    · 이기종 보안장비 공통정보 분석 단계에서 출발지·목적지 포트 및 페이로드 길이 정보 기준 페이로드 바이트 통계 및 유형이 상이한 것을 확인

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

· 선정된 공통 메타정보 3종과 페이로드 바이트 히스토그램을 결합하여 학습함으로써 이기종 보안장비 이상행위 탐지모델 성능 개선

2) 이상행위 자동탐지 신뢰도 향상을 위한 학습데이터 자동 레이블링 기술개발 및 검증

o 내·외부 CTI 정보 기반 보안이벤트 자동분류 및 레이블 정제 기술개발

- 자체 운영 중인 實보안관제 환경(S&T-CSC)에서 보안관제 대상기관 및 지역거점에 설치된 N-IDS 장비 및 국가사이버안보센터, 보안장비 벤더 社, 자체 침해위협탐지 룰을 통해 탐지된 보안이벤트 수집
- 학습데이터 자동 레이블링 기술은 크게 유사도 비교 모듈과 상세 분석 모듈로 구성되어 있고 아래 과정을 통해 자동 레이블링 수행

① 전처리 된 보안이벤트 중 旣 태깅 이벤트와 유사도 80% 이상 이벤트 분류

※ 유사도가 낮은 이벤트의 경우 HITL(Human In The Loop) 방식 태깅 진행

② 이벤트 내 페이로드를 사전정의한 구분자 기준으로 분절

③ 분절된 구간 내 특정 언어의 Syntax로 판단되는 부분이 있는 이벤트 분류

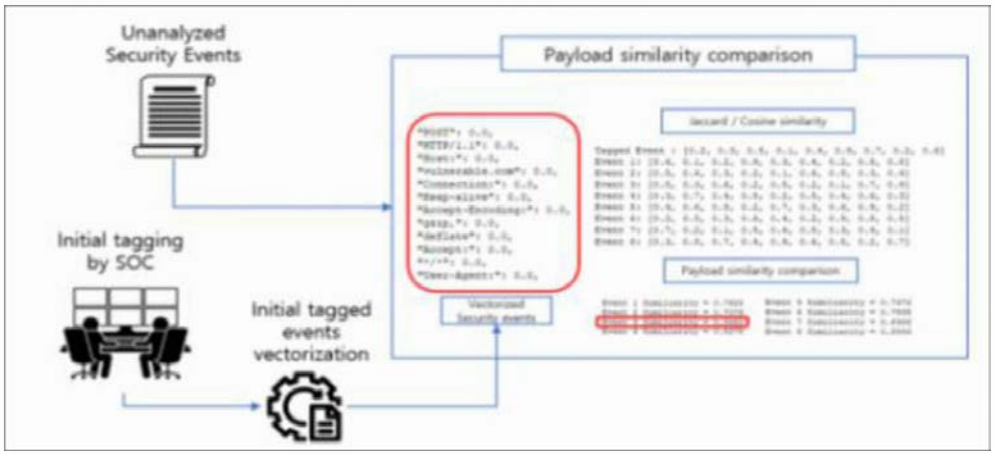
④ 해당 이벤트에 내·외부 CTI에서 수집한 STIX 데이터 내 artifact Object 중 payload_bin 혹은 url 필드 내 해당하는 문자열 존재 시 자동 정탐 분류

※ 공개 OSINT(Ailen Vault, PhishTank...) 및 기관 내부 CERT 사고조사 중 채증된 artifact 등

⑤ 존재하지 않을 경우 HITL 방식 태깅 진행 이후 태깅 이벤트 DB에 저장

<HITL 기반 CTI 정보를 활용한 보안이벤트 분류 및 레이블 정제 방법론 개념도>

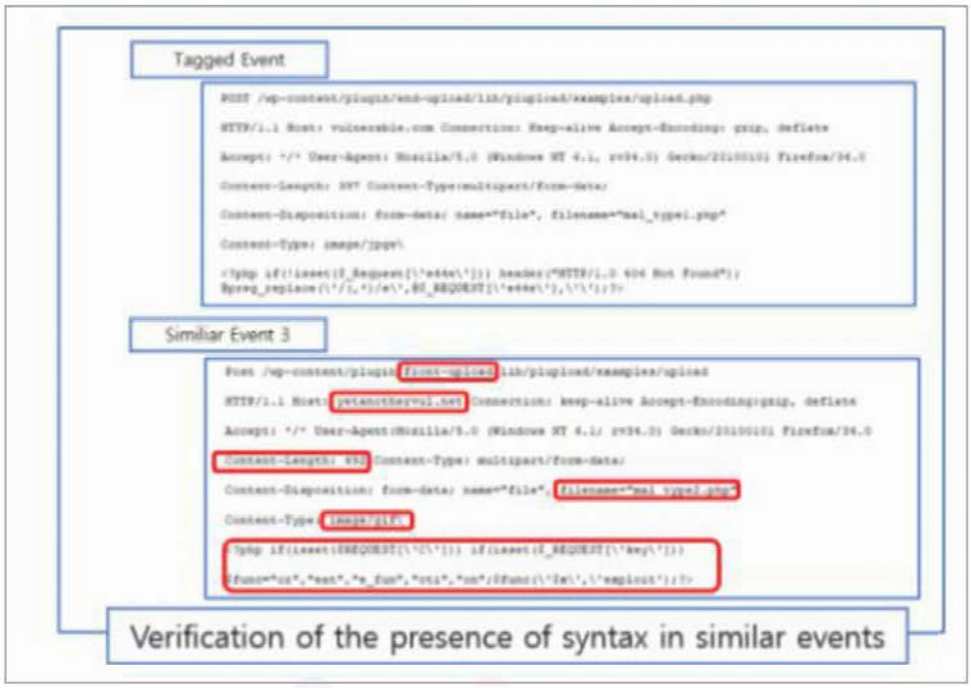
- (보안이벤트 유사도 비교 모듈) 보안이벤트 전처리, 페이로드 벡터화 및 유사도 비교를 수행하는 모듈로, 旣 태깅 이벤트 페이로드와의 유사도 사전 설정 임계치 초과 여부 판별 수행



<보안이벤트 유사도 비교 모듈 개념도>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- (보안이벤트 상세 분석 모듈) 旣 태깅 이력이 없는 보안이벤트에 대해 상세 분석을 수행하는 모듈로, 페이로드를 사전정의한 구분자로 분절하고 STIX형태로 정의된 외부 CTI 정보에서 확인 가능한 공격 artifact가 분절된 페이로드 내 존재하는지 확인 수행



<보안이벤트 상세 분석 모듈 개념도>

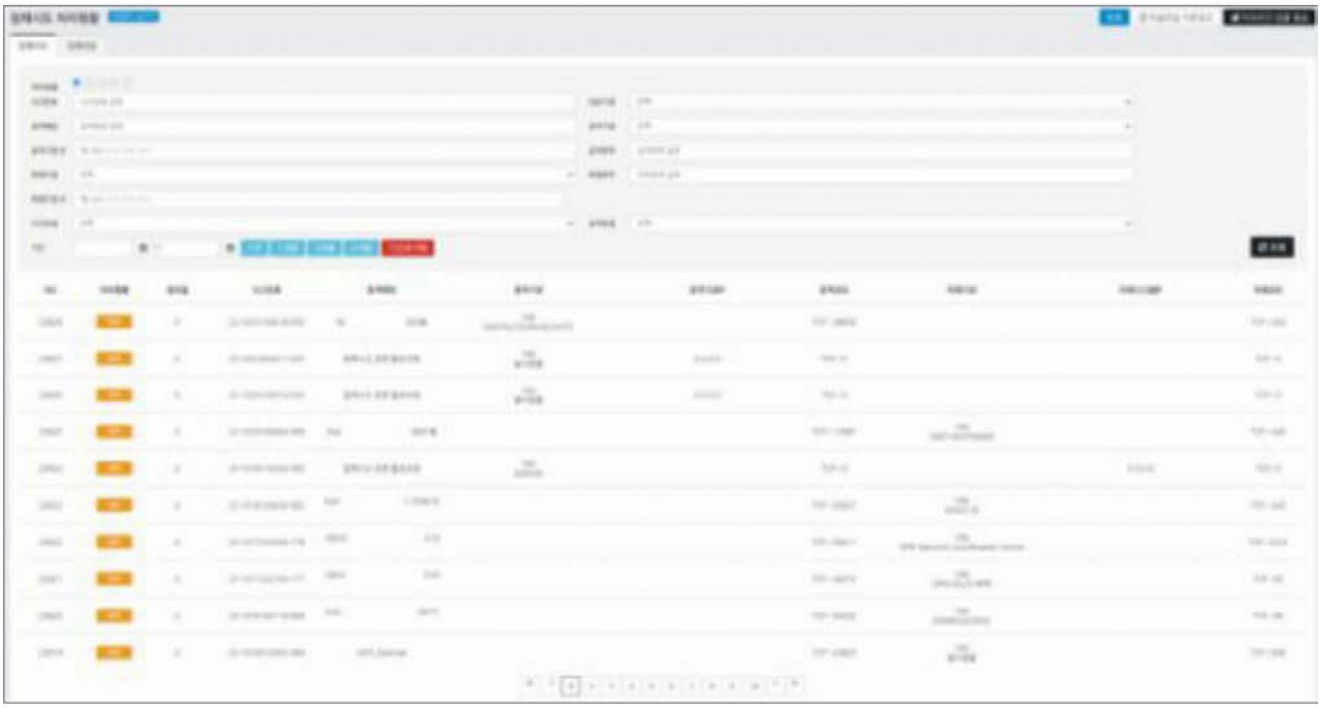
o XAI 기법 및 내·외부 CTI정보 기반 보안이벤트 분석·검증 시간 단축

- LIME, SHAP 등 XAI기법을 이상행위 자동탐지모델에 적용함으로써 AI모델 신뢰성 및 적합성 검증

<자체 구축 플랫폼 내 XAI기반 AI모델 신뢰성·적합성 검증 모듈 화면>

- KISTI 과학기술사이버안전센터 자체 구축 CTI와 NCTI 및 보안관제 유관기관들을 통해 수집된 외부 CTI정보 기반 이상행위 자동탐지모델 신뢰성 검증

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

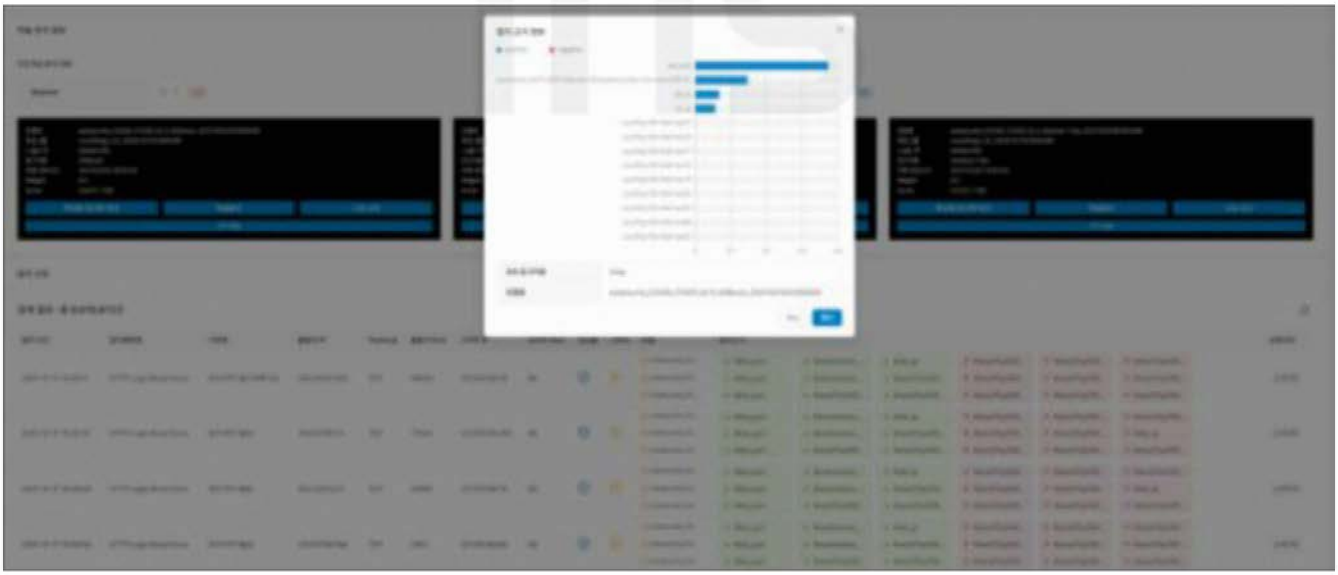


<자체 구축 플랫폼 내 내부 CTI 및 NCTI 화면>

3) 신·변종 이상행위 탐지를 위한 강화학습 기반 이상행위 탐지모델 구축

o XAI 분석 결과 기반 모델 재학습을 통한 이상행위 탐지모델 강화

- XAI 분석 결과 기반 학습 파라미터 조정 및 학습 데이터 수정



<자체 구축 플랫폼 내 XAI 분석 결과 화면>

- 주요 판별 근거 기반 학습 가중치 및 파라미터 수정 후 재학습
- 이기종 보안장비 이상행위 탐지모델 신뢰성 및 예측 정확도 강화

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

연구목표	공개 보안 위협 인텔리전스 정보 수집 기술 개발

세부 내용	1) STIX/TAXII 기반 보안 위협 인텔리전스 정보 수집 및 정형화 기술 개발
	2) 보안 위협 인텔리전스 통합 데이터베이스 구축

1) STIX/TAXII 기반 보안 위협 인텔리전스 정보 수집 및 정형화 기술 개발

o STIX/TAXII 기반 보안 위협 인텔리전스 정보 수집 및 정형화 기술 개발

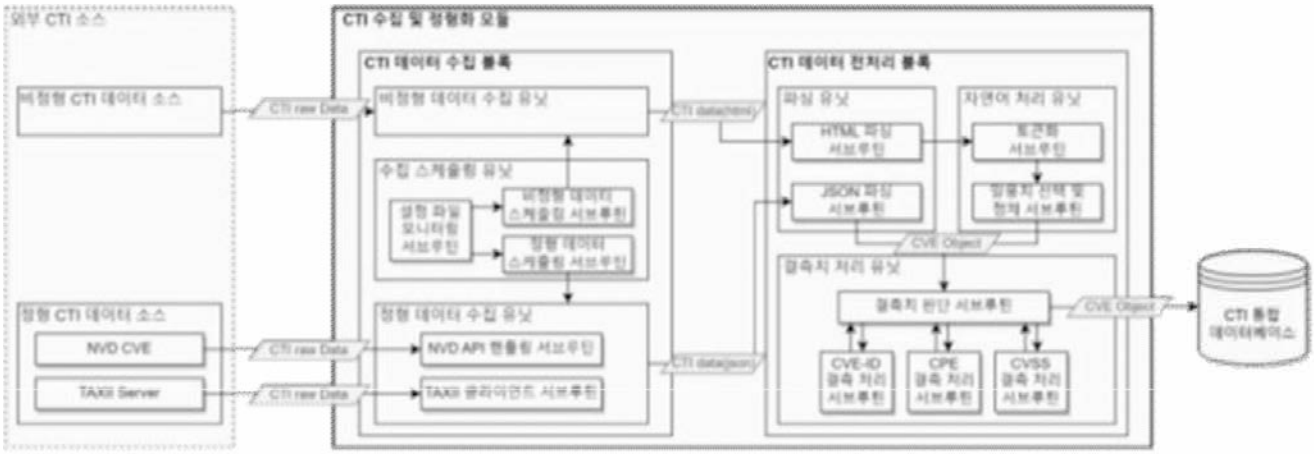
- 보안 위협 인텔리전스 정보 수집 및 정형화 모듈 설계 개선

· 모듈 목적 변경 → 3가지 포인트 설계 개선

<보안 위협 인텔리전스 정보 수집 및 정형화 모듈의 변경된 목적 및 설계 개선 포인트>

	기존 (2차년도 설계)	설계 개선
모듈 목적	시스템에서 사용하는 모든 데이터를 일괄 수집 및 정형화	선제 대응하고자 하는 CTI 데이터를 실시간 수집 및 정형화
(개선 ①) 데이터 처리 방식 개선	일괄 수집 및 정형화	스크립트 기반, 실시간 수집 및 정형화
(개선 ②) 수집 방법 구체화	- 크롤링, 파일 다운로드	- (정형) 취약점 정보: NVD API 활용 - (정형) STIX 기반 CTI 정보: TAXII 활용 - (비정형) 국내외 위협 보고서: 크롤링
(개선 ③) 모듈 내 블록/유닛 상세화	- (수집 블록) 크롤링 유닛, 파일 다운로드 유닛 - (정형화 블록) 데이터 추출 유닛	- (수집 블록) 정형 데이터 유닛, 비정형 데이터 유닛, 수집 스케줄링 유닛 - (전처리 블록) 파싱 유닛, 자연어 처리 유닛, 결측치 처리 유닛

· 모듈의 입출력 데이터 및 블록·유닛 기능 상세 설계 → 블록 2종 / 유닛 6종



<보안 위협 인텔리전스 정보 수집 및 정형화 모듈>

※ (기능) 외부 CTI 소스로부터 선제 대응이 필요한 정형/비정형 CTI raw data를 수집 및 가공(정형화)하여, 이를 CTI 통합 데이터베이스에 제공

※ (입력) CTI raw Data / (출력) CVE Object

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

<보안 위협 인텔리전스 정보 수집 및 정형화 모듈 입/출력>

	Attribute	Type	Description
Input	비정형 CTI	text	외부 Source로부터 크롤링하여 수집한 국내외 위협보고서
	취약점 정보	JSON	NVD로부터 API 활용하여 수집한 취약점 정보
	STIX CTI	STIX	TAXII Server로부터 수집한 위협 인텔리전스 정보
Output	cve_id	String	NVD에서 정의하는 CVE ID 형식의 문자열
	CPEs	List	NVD에서 정의하는 CPE 형식의 문자열이 담긴 리스트 (하나의 CVE ID에 하나 이상의 CPEs가 존재할 수 있음)
	CVSS	Dictionary	NVD에서 정의하는 CVSS (version 2와 version 3 모두 활용)
	technique (optional)	List	MITRE에서 정의하는 TTP의 Technique ID가 담긴 리스트 (하나의 CVE ID에 하나 이상의 Technique IDs가 존재할 수 있음)
	description	String	CTI에 대한 설명
	source	String	해당 Object를 생성하는데 사용된 CTI의 원본 데이터 문자열

※ 2가지 블록(① 수집 블록, ② 전처리 블록) 및 6가지 유닛 설계

① (수집 블록) 외부 CTI 소스로부터 선제 대응이 필요한 CTI의 raw 데이터를 실시간으로 수집

② (전처리 블록) 수집 블록을 통해 수집된 CTI raw 데이터를 전처리하여, CTI 통합 데이터베이스에 저장할 수 있는 CVE Object 형태로 변환

<수집 및 전처리 블록의 유닛 기능 설계>

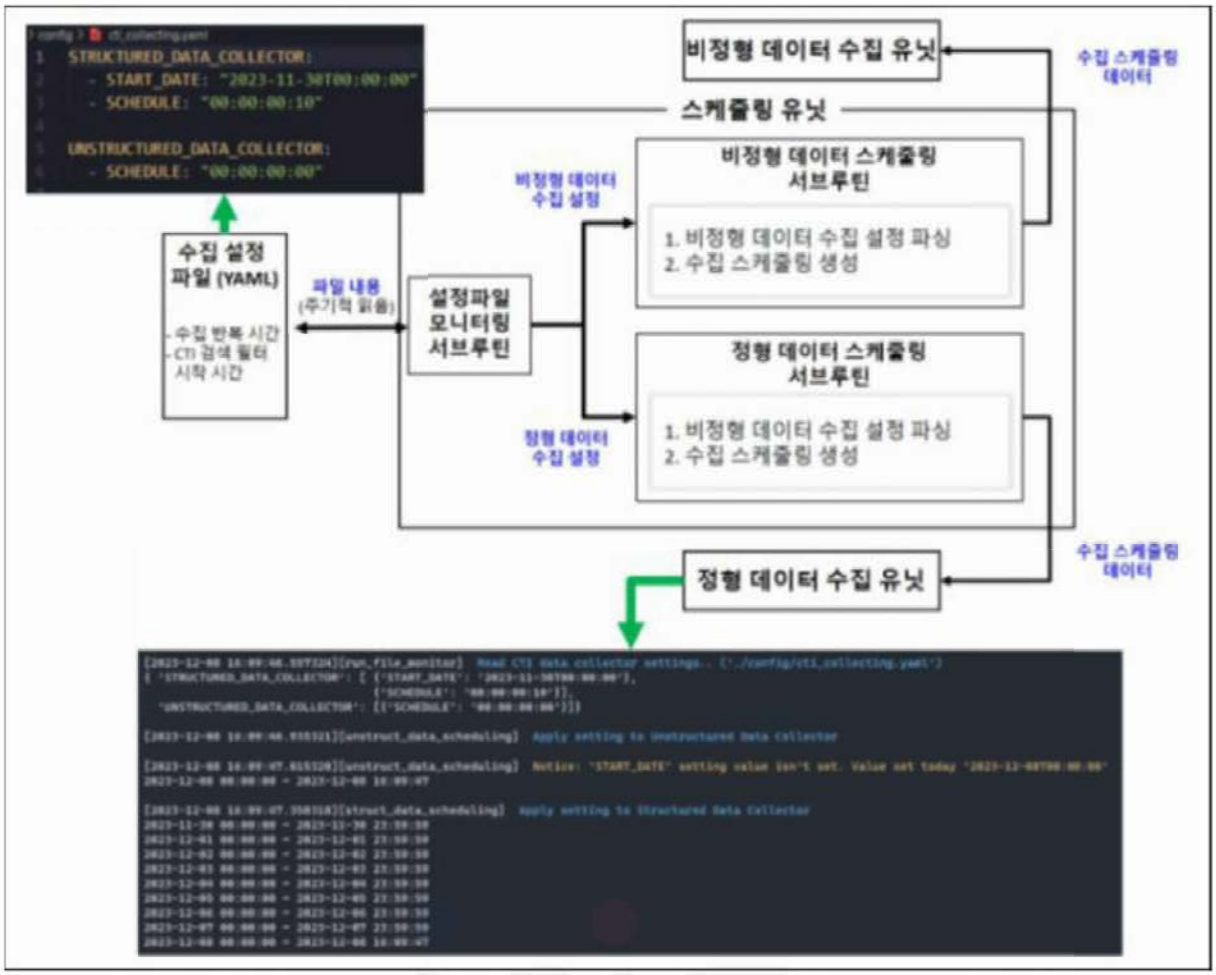
블록	유닛	기능
수집 블록	수집 스케줄링 유닛	- 데이터 수집 유닛 실행 자동화로, CTI raw 데이터 실시간 수집
	비정형 데이터 수집 유닛	- 비정형 형태의 CTI raw 데이터를 수집
	정형 데이터 수집 유닛	- 정형 형태의 CTI raw 데이터를 수집
전처리 블록	파싱 유닛	- CTI raw 데이터 내, 필요 객체* 파싱 * 수집 및 정형화 모듈의 Output인 CVE object의 fields 관련 데이터
	자연어 처리 유닛	- 비정형 형태의 CTI raw 데이터를 자연어 처리
	결측치 처리 유닛	- 파싱·자연어처리된 CTI raw 데이터인 CVE objects의 결측된 fields 판단 및 보완

- 보안 위협 인텔리전스 정보 수집 및 정형화 모듈 구현

· 보안 위협 인텔리전스 정보 수집 블록 구현 결과

※ (수집 스케줄링 유닛 구현) 일정 기간마다 정형/비정형 데이터 수집 유닛 자동 실행 → 새로운 CTI raw 데이터 실시간으로 수집

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



<수집 스케줄링 실행 플로우>

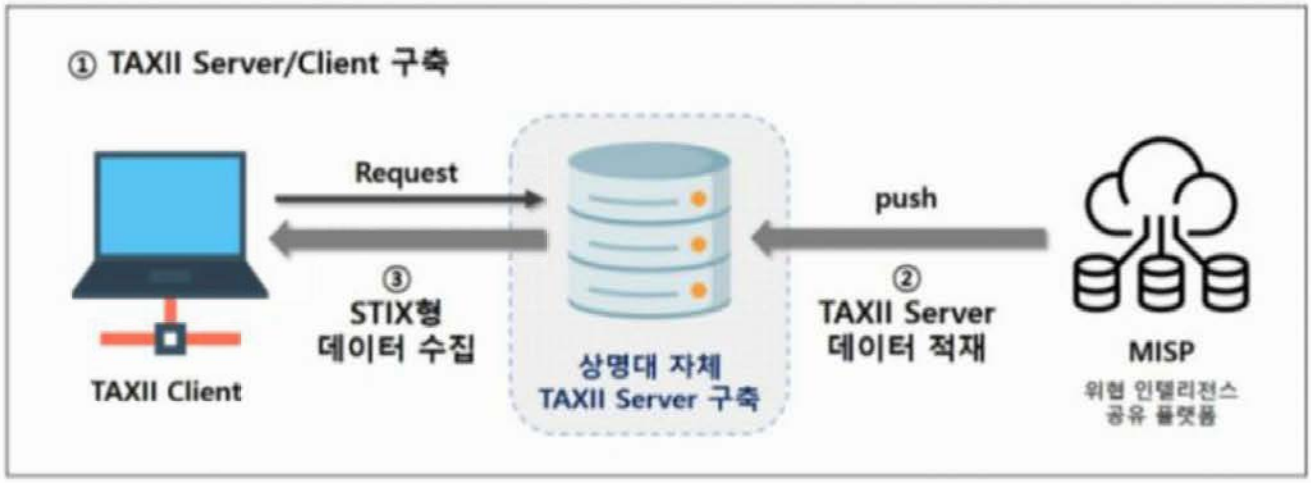
※ (정형 데이터 수집 유닛 구현) CTI raw 데이터 2종(① 취약점 정보, ② 위협 인텔리전스 정보) 수집하도록 구현

<수집한 2가지 유형의 CTI raw 데이터>

	취약점 정보	위협 인텔리전스 정보
CTI data source	NVD CVE (NVD CVE API 활용)	TAXII Server (OASIS TAXII Opensource 활용)
Type	JSON 형태	STIX 형태
수집 CTI data	[CVE ID, CPE, CVSS Score]	[ATT&CK Technique, CVE ID]
수집 완료 데이터 수	약 10만건 (upload 기간: '18 ~ '23.10)	642건 (TAXII Server에 MISP*의 위협인텔리전스 데이터 직접 적재) * MISP: 룩셈부르크 컴퓨터사고대응센터에서 개발한 위협 인텔리전스 공유 플랫폼

✓ (위협 인텔리전스 정보 수집) 해당 기능 구현은 '① TAXII Server/Client 구축, ② TAXII Server 데이터 적재, ③ STIX형 데이터 수집' 순서로 이루어짐

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



<위협 인텔리전스 데이터 수집 실행 플로우>

① (TAXII server/clinet 구축) OASIS의 TAXII Opensource 활용 → TAXII 2.1 지원 가능

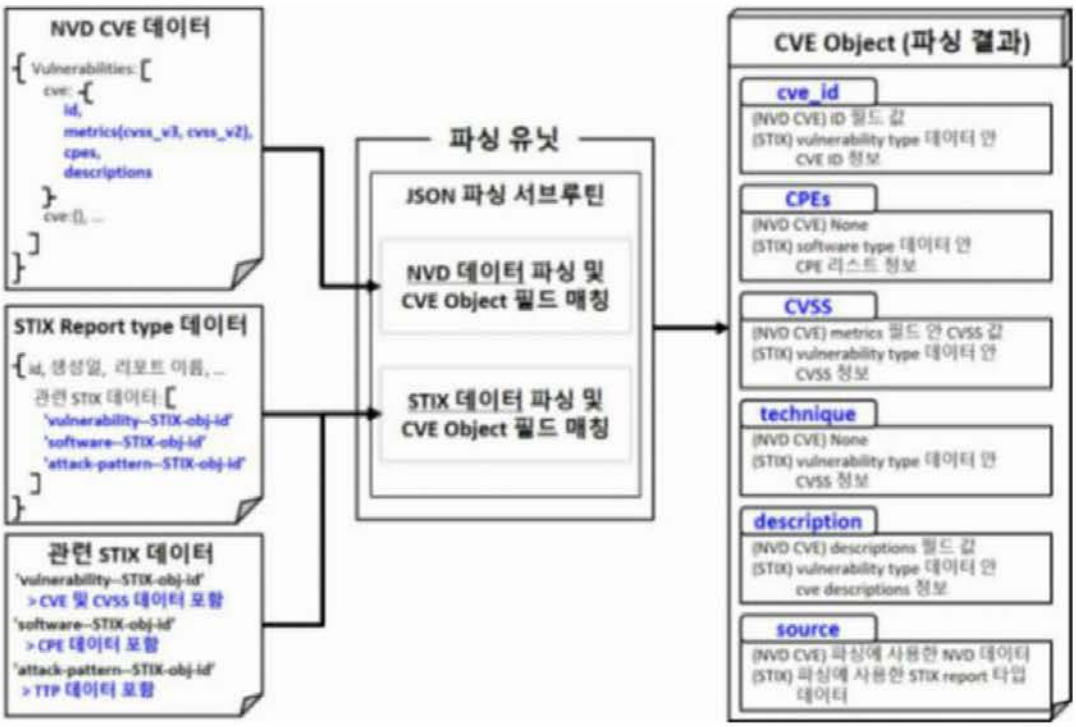
② (TAXII server 데이터 적재) MISP의 위협 인텔리전스 데이터 적재
> TAXII 활용 STIX형 데이터 수집 테스트를 위해서, 총 642개의 위협 인텔리전스 데이터 적재

③ TAXII Server로부터 STIX형 위협 인텔리전스 데이터 수집

· 보안 위협 인텔리전스 정보 전처리 블록 구현 결과

※ (CTI 파싱 유닛 구현) 수집 블록의 출력값(CTI raw 데이터)로부터 CVE object의 6개 필드 파싱

✓ (CVE Object 6개 필드) cve_id, CPEs, CVSS, technique, description, source



<NVD CVE raw 데이터의 파싱 결과 (예시)>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

※ (결측치 처리 유닛 구현) 파싱 유닛 출력값(CVE Object)의 5개 필드 중, 3가지 필드의 결측된 속성 판단 및 결측값 처리

✓ (결측 판단 대상 필드) cve_id, CPEs, CVSS

Algorithm 1: Missing Data Processing

```
keys of CVE_Object : cve_id, cpe, cvss, technique, description, source
input  : CVE Object List
output: processing_data_list(CVE Object List processed by Missing
         Data Processing)
processing_data_list ← empty list
for CVE_Object ∈ CVE_Object_List do
    if cve_id is None then
        if technique is None then
            Drop the CVE_Object
        else
            // Missing CVE Data Algorithm
            (Input technique, Output CVE_Object)
            processing_data_list ← CVE_Object
        end
    else
        processing_data_list ← CVE_Object
    end
end
for processing_data ∈ processing_data_list do
    if cpe is None then
        // Missing CPE Data Algorithm
        (Input cve_id, Output CPEs)
        if CPEs is None then
            Drop the processing_data
        end
        cpe ← CPEs
    end
    if cvss is None then
        // Missing CVSS Data Algorithm
        (Input cve_id, Output CVSS)
        if CVSS is None then
            Drop the processing_data
        end
        cvss ← CVSS
    end
end
return processing_data_list
```

<CVE Object 결측치 처리 알고리즘>

- 보안 위협 인텔리전스 정보 수집 및 정형화 모듈 테스트

· CTI 수집 블록 기능 테스트

※ (목적) CTI raw 정형 데이터의 실시간 수집 기능 테스트

※ 일정기간 동안 외부 CTI 소스에 upload된 총 1,393개의 new CTI raw 정형 데이터를 기준으로, 100%의 CTI 데이터 수집률 도출

✓ 단, 결측치 처리 불가의 경우 전처리 단계에서 CTI 데이터 드롭됨

	데이터 발생 기간	upload CTI 개수	수집 CTI 개수	수집률
취약점 정보	'23.12.07 ~ '23.12.09	1,293	1,293	100%
STIX형 CTI	'23.11.15 ~ '23.05.14	100	100	100%

· 전처리 블록 정확도 테스트

※ (목적) CTI raw 데이터의 정형화 및 결측치 처리 정확도 테스트

※ (정답셋) NVD의 JSON Feeds : 29,071 CTI 데이터

※ 수집한 CTI raw 데이터 중 CVE, CVSS, CPE가 모두 결측인 CTI(1,031개)를

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

기준으로, 결측 처리 가능 필드(CVE, CVSS, CPE)의 일치율(97.96%) 도출

✓ CVE 기준, CPE · CVSS 모두 정답셋과 100% 일치한 경우에만 정답 처리

결측 처리 대상 CTI 개수	일치된 CTI 개수	미일치 CTI 개수	일치율
1,031	1,010	21*	97.96%

* CTI 데이터 수집 시점과 정답셋 수집 시점의 차이로 인한, CTI 데이터 업데이트 반영 이슈

2) 보안 위협 인텔리전스 통합 데이터베이스 구축

o CTI 통합 데이터베이스 스키마

- CTI 통합 데이터베이스 스키마 설계 개선

· 데이터베이스 용도 변경 → 2가지 포인트 설계 개선

	기존 (2차년도 설계)	설계 개선
용도	시스템에서 사용하는 모든 데이터 보관 및 관리용	CTI 분석 및 선제대응에 필요한 데이터 보관 및 처리용
(개선 ①) 요구사항 개선	시스템에서 사용하는 모든 데이터를 보관할 수 있도록 요구사항 정의	모듈별로 필요한 데이터 등 시스템 구동에 필요한 요구사항 추가 정의
(개선 ②) 테이블 다양화	대응전략 및 CTI에 집중된 테이블 설계	요구사항 기반, 총 5가지 유형의 테이블 설계

· 모듈별 필요 데이터 요구사항을 고려하여, 5가지 엔티티 유형 설계

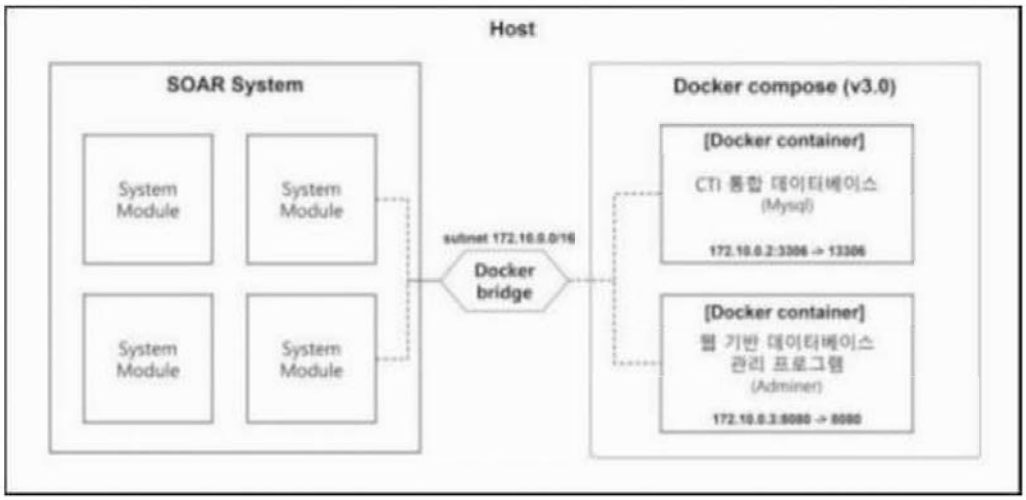
<CTI 통합 DB의 엔티티 유형 5종>

엔티티		설명
내부자산	시스템 자산	조직 내 시스템 자산 정보를 관리하기 위한 엔티티
	네트워크 자산	조직 내 네트워크 자산 정보를 관리하기 위한 엔티티
CTI		외부 CTI 소스로부터 수집한 CTI를 관리하기 위한 엔티티
대응전략	Mitigation	TTP 기반 대응전략을 관리하기 위한 엔티티 (대응전략 3종별로 다른 엔티티로 구성)
	Engage	
	D3fend	
파일관리	json 관리	시스템에서 사용되는 json 파일을 관리하기 위한 엔티티 (결측 처리 또는 룰기반 TTP 매핑 또는 대응전략 매핑에 활용됨)
	ML model 관리	시스템에서 사용되는 머신러닝 모델을 관리하기 위한 엔티티 (머신러닝 기반 TTP 매핑에 활용됨)
사용자 제공		시스템 사용자에게 최종 제공될 정보를 관리하기 위한 엔티티

- CTI 통합 데이터베이스 구축

· Mysql 8.0 기반 통합 데이터베이스 환경 구축 완료

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

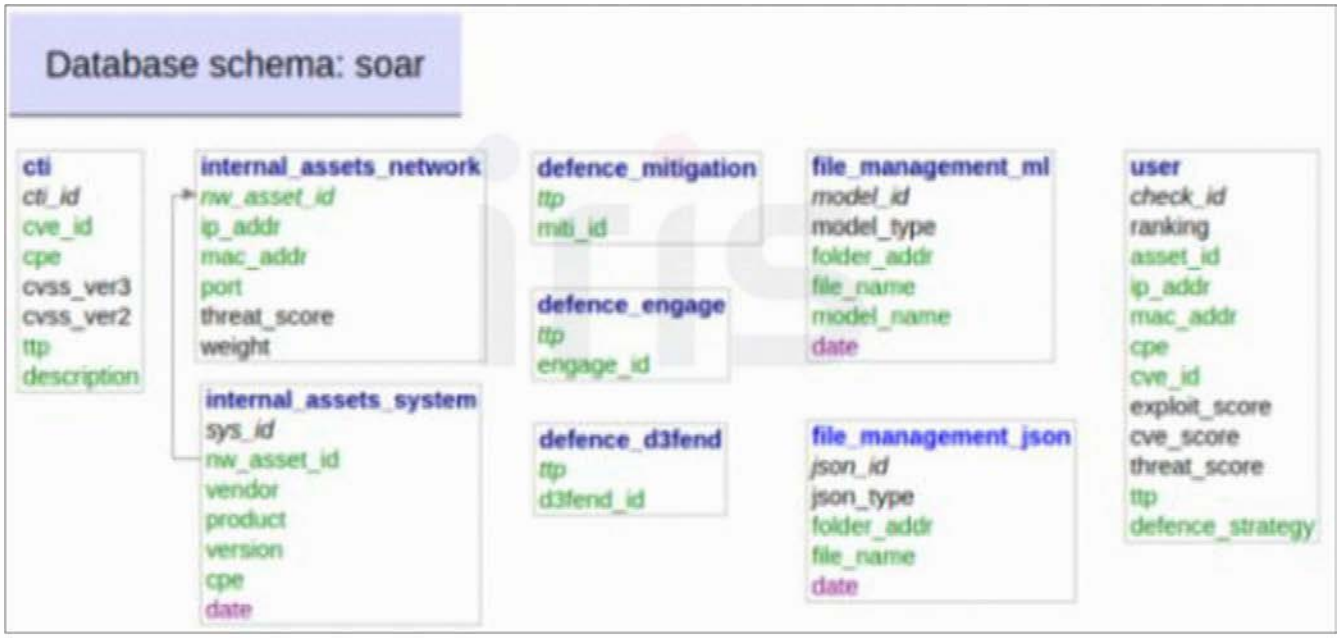


<시스템 및 통합 데이터베이스 환경 구성도>

※ Adminer 기반 데이터베이스 관리 시스템 구성 완료

※ Docker 기반 시스템 내 모듈의 데이터베이스 액세스 관리 수행

· 통합 데이터베이스 스키마 설계 기반, 9개 테이블 생성 및 관계 설정 완료



<CTI 통합 데이터베이스 9개 테이블 생성 및 관계 설정>

- CTI 통합 데이터베이스 데이터 적재 결과

· 9개 테이블(사전 적재 7개 / 실시간 적재 2개)에 데이터 적재

※ 사전 데이터 적재 테이블 7개 중, 4개 테이블에 데이터 적재 완료

※ 실시간 데이터 적재 테이블 2개 중, 1개 테이블에 실시간 데이터 적재 검증 완료

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

<CTI 통합 데이터베이스 테이블 적재 현황>

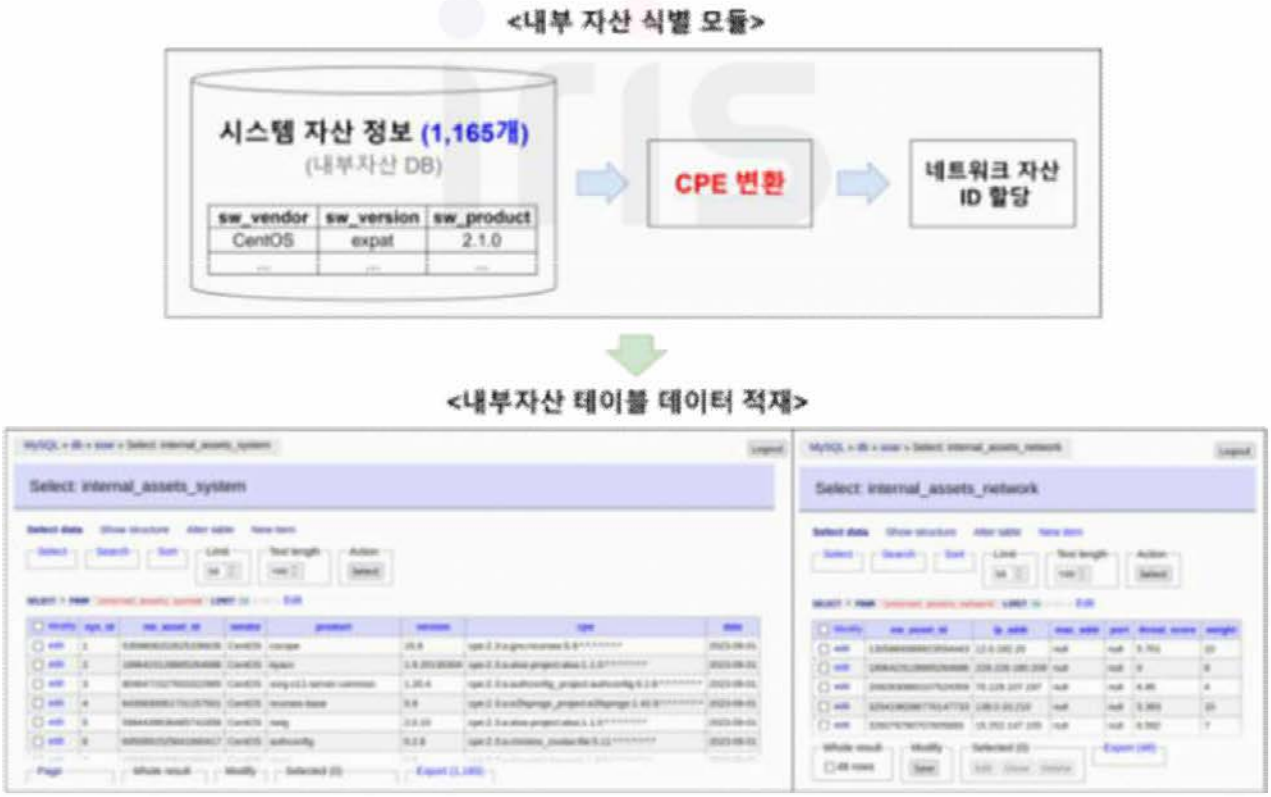
적재 유형	테이블	데이터 종류	적재 데이터 수
사전 적재	internal_assets_network	CPE 변환된 시스템 자산 데이터	1,165
	internal_assets_system	IP 기반 네트워크 자산 데이터	46
	defence_mitigation	Technique-ID 기반 mitigation 매핑 데이터	759
	defence_engage	Technique-ID 기반 Engage 매핑 데이터	-
	defence_d3fend	Technique-ID 기반 D3fend 매핑 데이터	-
	file_management_json	json 파일 정보 데이터	3
	file_management_ml	머신러닝 모델 파일 정보 데이터	-
실시간 적재	cti	실시간 수집 및 정형화된 CTI 데이터	83,763
	user	시스템 사용자에게 최종 제공되는 데이터	-

· (예제 ①) 사전 데이터 적재 결과 - 내부자산 테이블

※ 총 1,165개 내부자산에 대해 시스템 자산 및 네트워크 자산 테이블 적재

✓ (시스템 자산 테이블) CPE 변환된 1,165개 시스템 자산 데이터 적재 완료

✓ (네트워크 자산 테이블) 46개 네트워크 자산 데이터 적재 완료



<내부자산 테이블의 데이터 사전 적재 플로우 및 결과 화면 예제
(우) 시스템 자산 테이블 (좌) 네트워크 자산 테이블>

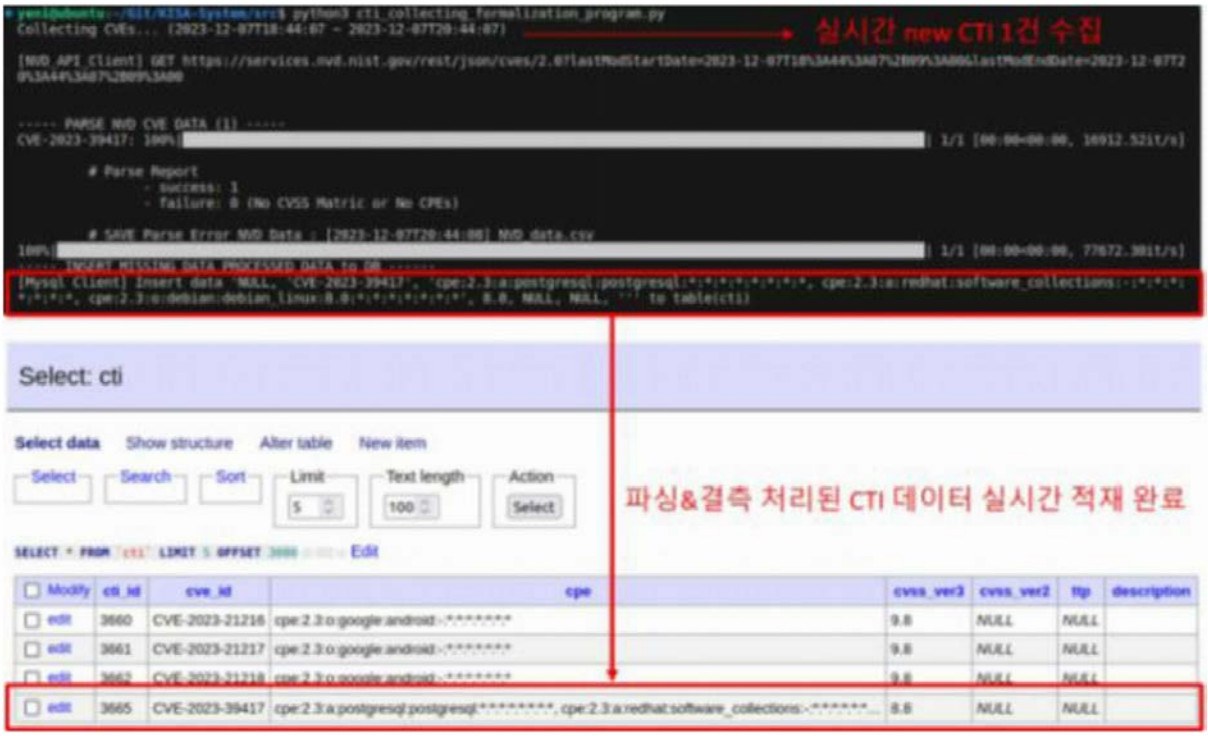
· (예제 ②) 실시간 데이터 적재 결과 - CTI 테이블

※ 취약점 정보 및 위협 인텔리전스 정보에 대해 총 83,763건 데이터 적재 완료

✓ (취약점 정보) NVD CVE로부터 81,686건 / TAXII Server로부터 2,077건

✓ (위협 인텔리전스 정보) 64건

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



<CTI 테이블의 실시간 데이터 적재 검증>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

세부 기술 ② 보안 위협 분석 및 대응을 위한 플레이북 자동 생성 기술 개발

□ 연구 목표

o TTP 기반 네트워크 자산 위험도 산출 및 고위험 TTP 분류 기술 개발

o 보안 관제 플레이북 자동 생성 기술 설계 및 개발

o 보안 관제 플레이북 검증·관리 기술 개발

□ 연구 목표별 추진 실적

연구목표	TTP 기반 네트워크 자산 위험도 산출 및 고위험 TTP 분류 기술 개발

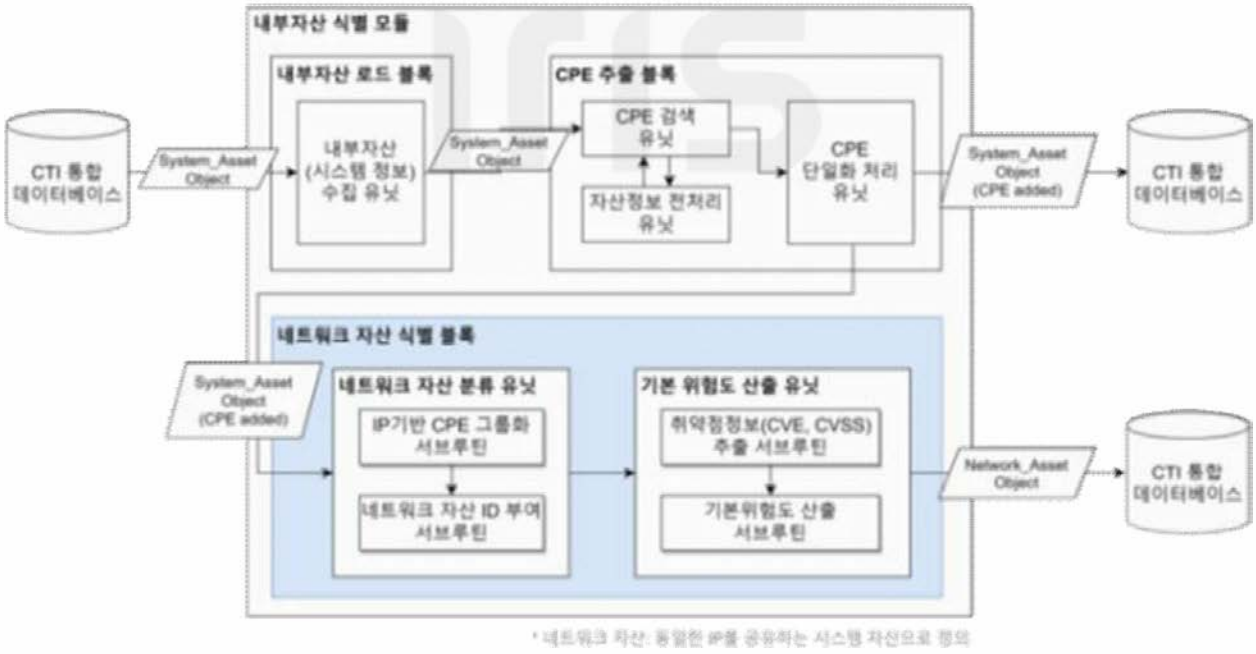
세부 내용	1) TTP 기반 네트워크 자산 위험도 산출 기술 개발
	2) 네트워크 자산 위험도를 활용한 고위험 TTP 분류 기술 개발

1) TTP 기반 네트워크 자산 위험도 산출 기술 개발

o TTP 기반 네트워크 자산 위험도 산출 기술 설계

- 네트워크 자산 위험도 산출 기술 설계

· (네트워크 자산 식별 기술 설계) 내부자산 식별 모듈 내, 네트워크 자산 식별 블록 추가 설계 완료



<내부자산 식별 모듈 내, 네트워크 자산 식별 블록>

※ (기능) 내부자산에서 네트워크 자산을 식별하고, 네트워크 자산이 갖는 기본 위험 정량화

※ (입력) CPE가 추가된 시스템 자산 Object / (출력) 네트워크 자산 Object

※ 네트워크 자산 식별 블록 내, 2가지 유닛 설계

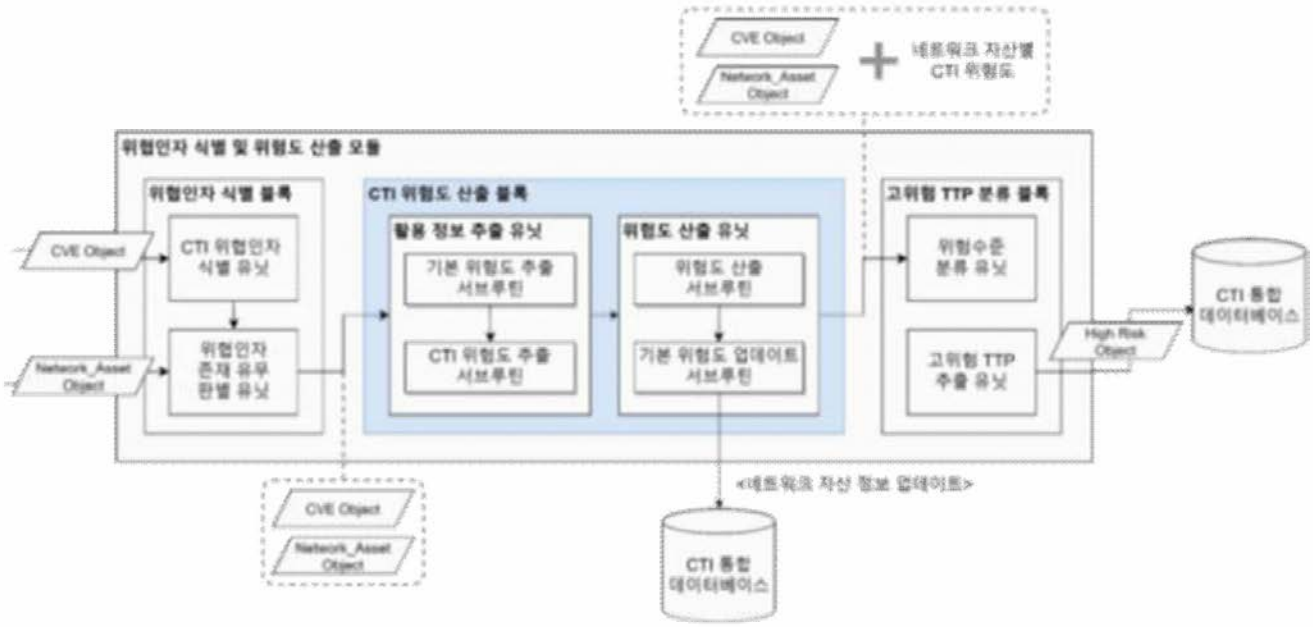
① (네트워크 자산 분류 유닛) IP 주소를 기반으로, 조직 내 자산을 그룹화하여 네트워크 자산 구성

② (기본 위험도 산출 유닛) 공통 취약점 정보를 활용하여, 네트워크 자산이

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

기본으로 갖는 위험도 산출

·(위험도 산출 방안 설계) 위협인자 식별 및 위험도 산출 모듈 내, 위험도 산출 블록 추가 설계 완료



<위협인자 식별 및 위험도 산출 모듈 내, CTI 위험도 산출 블록>

※ (기능) TTP·공통 취약점 점수 시스템을 활용하여, 수집한 CTI에 대한 네트워크 자산 위험 정량화

※ (입력) CTI, 내부자산 정보 / (출력) 네트워크 자산 위험도

※ CTI 위험도 산출 블록 내, 2가지 유닛 설계

① (활용 정보 추출 유닛) CTI 위험도 산출에 필요한, 기본 위험도·CTI 위험도를 추출

② (위험도 산출 유닛) 수집한 CTI의 위협인자 위험도를 반영하여, 조직 내 네트워크 자산의 위험도 정량화

- 네트워크 자산 위험도 산출 기술 구현

·네트워크 자산 식별 기술 구현 결과

※ (네트워크 자산 분류 유닛 구현) 내부자산의 네트워크 정보를 기준으로, 네트워크 자산을 분류하도록 구현

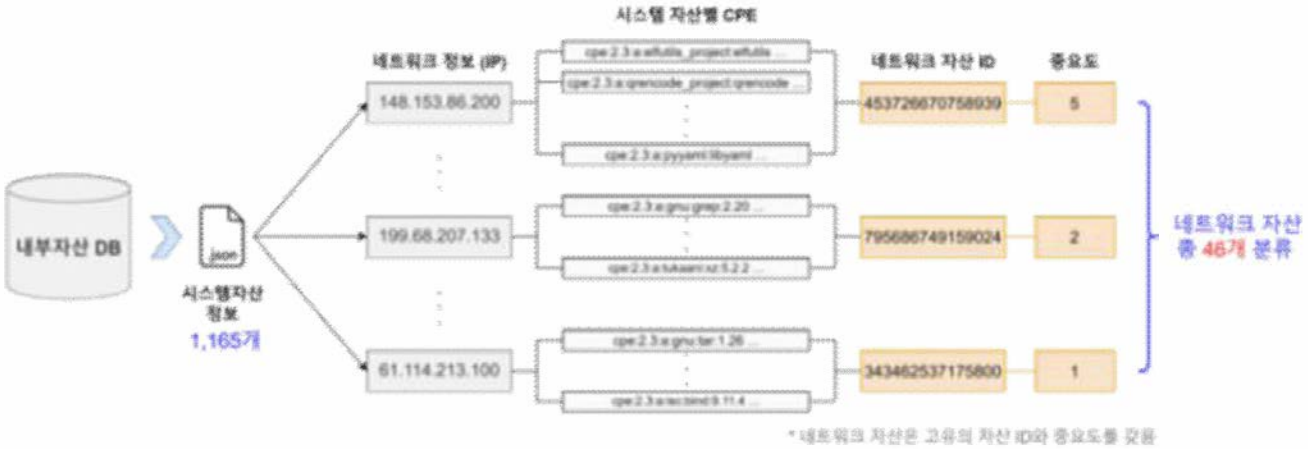
✓ 총 1,165개 시스템 자산으로부터, 총 46개의 네트워크 자산을 분류함

✓ 네트워크 자산은 고유의 자산 ID와 중요도를 갖음

<내부자산 정보 예시>

No	CPE	IP	CVE	CVSS	위험도
1	cpe:2.3:a:libexpat:expat:2.1.0:*:*:*:*:*:*:*	90.185.49.211	CVE-2022-28736	7.8	8.2
			CVE-2022-28734	9.8	
			CVE-2021-3697	7.0	
2	cpe:2.3:a:gnu:ncurses:5.9:*:*:*:*:*:*:*	108.29.141.168	CVE-2023-29491	7.8	7.45
			CVE-2022-29458	7.1	
3	cpe:2.3:a:git-scm:git:1.8.3.1:*:*:*:*:*:*:*	143.84.238.78	CVE-2023-23946	7.5	7.27
			CVE-2023-22490	5.5	
			CVE-2022-39260	8.8	

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



<내부자산 IP 기준, 네트워크 자산 분류 결과>

※ (기본 위험도 산출 유닛 구현) 네트워크 자산을 구성하는 CPEs를 활용하여, 네트워크 자산의 기본 위험도 산출 공식 정의 및 기본 위험도 산출 완료

✓ 기본 위험도 산출 공식 (n = 네트워크 자산 구성 CPE 총 개수)

$$\text{네트워크 자산 기본 위험도} = \frac{\sum(CPE_i\text{의 위험도})}{n}$$

✓ 네트워크 자산 기반, 기본 위험도 산출 완료

<네트워크 자산 식별 기술 구현 결과 (예시)>

네트워크 자산 ID	IP	기본 위험도	중요도	CPE 개수
453726670758939	148.153.86.200	4.624	5	10
626659129686095	143.84.238.78	4.897	3	10
795686749159024	199.68.207.133	6.036	2	18
537786748930849	80.199.3.116	6.474	9	29
343462537175800	61.114.213.100	7.038	1	24

· 위협인자 기반 네트워크 자산 위험도 산출 기술 구현 결과

※ (위험도 산출 유닛 구현) 위협 인자 기반 네트워크 자산 위험도 산출 공식 구현

✓ 활용 정보(CTI, 기본 위험도, 중요도)의 중요성을 고려한 가중 평균 이용

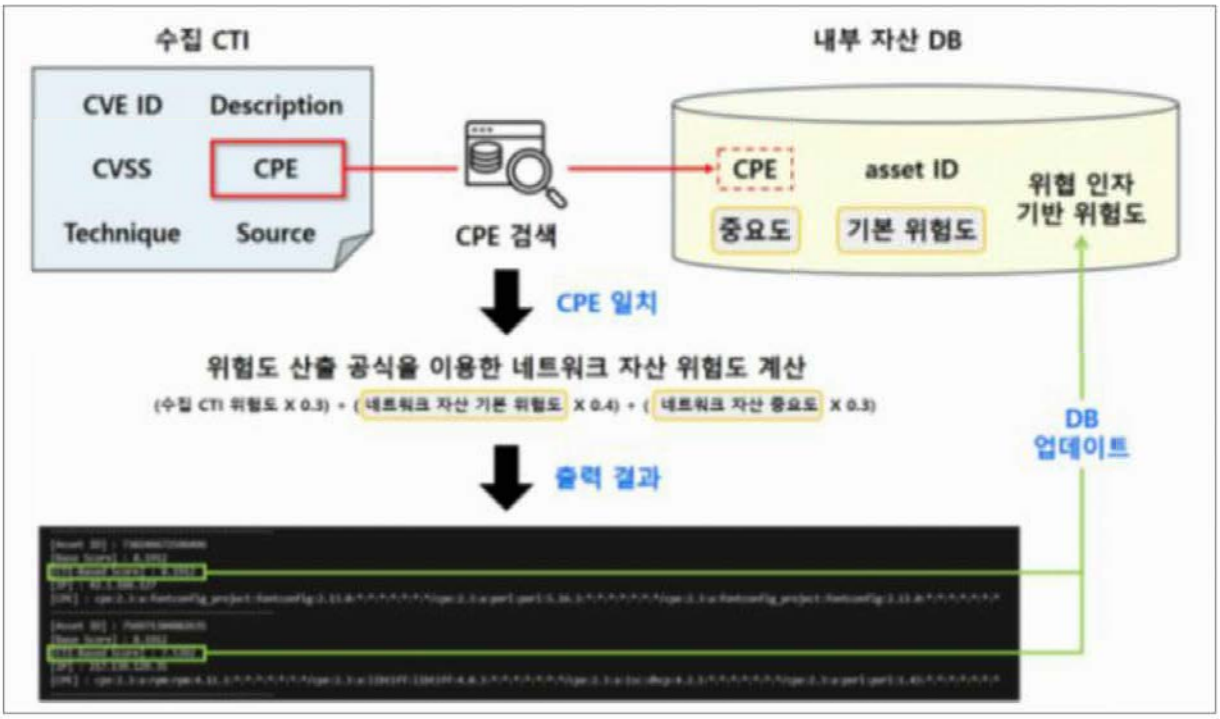
수집한 CTI 정보	네트워크 자산 정보	
	기본 위험도	중요도
0.3	0.4	0.3

<네트워크 자산 위험도 산출 가중치 설정값>

$$\text{위협 인자 기반 네트워크 자산 위험도} = (\text{수집한}\,CTI\,\text{위험도}\,X\,0.3) + (\text{네트워크 자산 기본 위험도}\,X\,0.4) + (\text{네트워크 자산 중요도}\,X\,0.3)$$

<가중치를 반영한 위험도 산출 공식>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

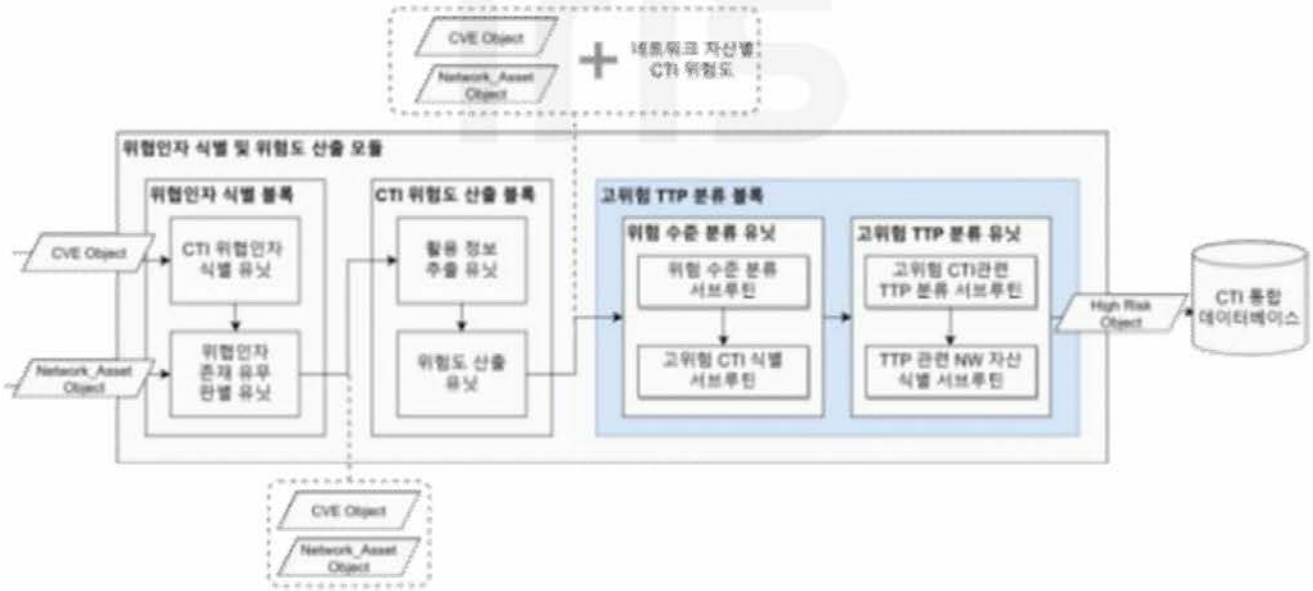


<네트워크 자산 위험도 산출 구현 결과>

2) 네트워크 자산 위험도를 활용한 고위험 TTP 분류 기술 개발

o 고위험 TTP 분류 기술 설계

- 위협인자 식별 및 위험도 산출 모듈 내, 고위험 TTP 분류 블록 추가 설계 완료



<위협인자 식별 및 위험도 산출 모듈 내, 고위험 TTP 분류 블록>

※ (기능) CTI가 내부자산에 미치는 위험 수준을 분류하고, 고위험 CTI와 관련된 네트워크 자산을 TTP를 기반으로 식별

※ (입력) CTI, 내부자산 정보, 네트워크 자산별 위험도 / (출력) 고위험 Object

※ 고위험 TTP 분류 블록 내, 2가지 유닛 설계

① (위험 수준 분류 유닛) CTI의 위험 수준을 분류하고, 그 중 Critical의 수준을 보이는 고위험 CTI를 식별

② (고위험 TTP 분류 유닛) 고위험 CTI와 관련된 TTP를 분류하고, 해당 TTP와 관련된 네트워크 자산을 식별

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- 고위험 TTP 분류 기술 구현 및 테스트
  - 고위험 TTP 분류 기술 구현 결과
    ※ (위험 수준 분류 유닛 구현) CTI의 위험도를 기반으로 3단계 위험 수준을 분류하고, 이를 통해 고위험 CTI를 식별할 수 있도록 구현
    ✓ 가중 평균 활용하여 산출한 CTI 위험도를 반영한, 위험 수준 분류 결과

<3단계 위험 수준 기반, 고위험 CTI 식별 플로우>

※ (고위험 TTP 분류 유닛 구현) 고위험으로 분류된 CTI의 TTP를 추출하고, 이와 관련된 다른 내부자산을 식별할 수 있도록 구현
✓ (고위험 CTI-TTP 룰기반 매핑 알고리즘 구현) CTI의 CVE ID를 활용하여 TTP 분류할 수 있도록 알고리즘 구현

Algorithm 1: Rule based TTP Mapping

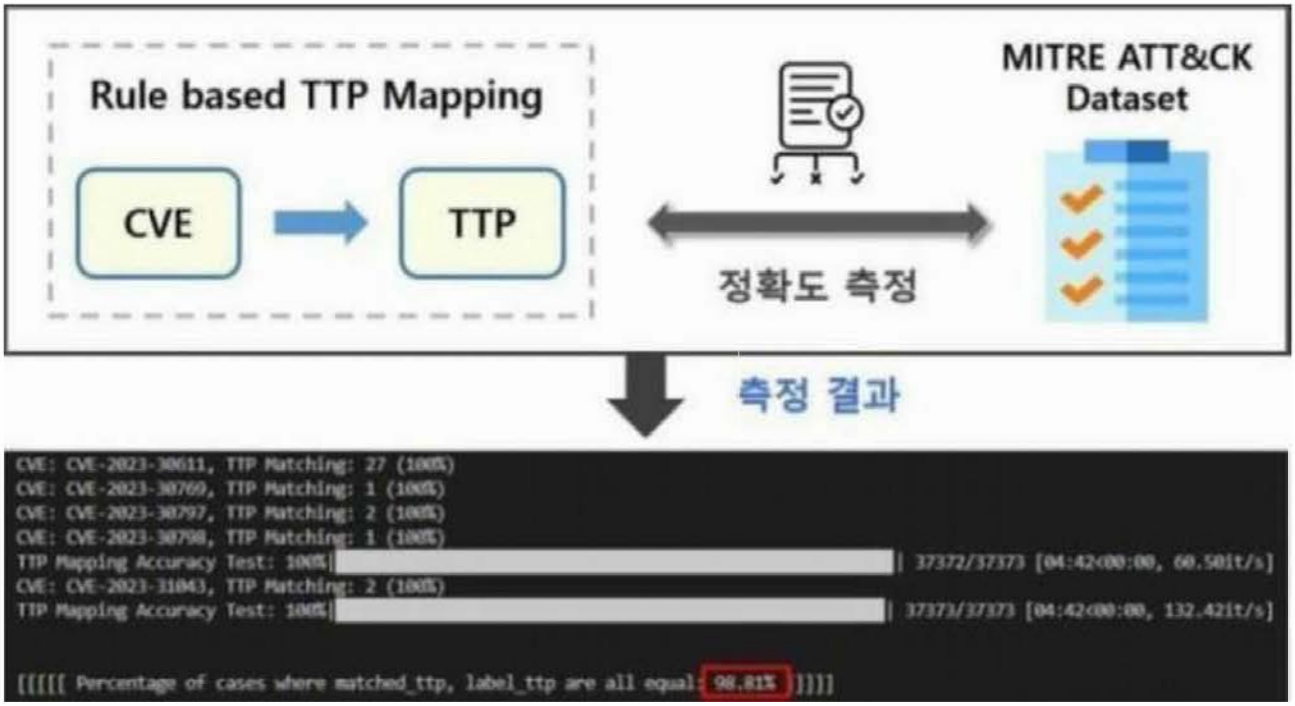
Input: CTI Object
Output: MITRE ATT&CK Technique ID

```
if Input is CVE ID then
    // CVE to CWE Mapping
    CWE_LIST ← result of CVE to CVE
    // If CWE mapping is available,
    if CWE_LIST is not Null then
        for each prosumers, cwe ← CWE_LIST do
            // CWE to CAPEC Mapping
            CAPEC_LIST ← result of CWE to CAPEC
        end
        return CAPEC_LIST
    else
        // ML TTP MAPPING Algorithm (Input: CVE ID, Output: TTP)
    end
    // If CAPEC mapping is available,
    if CAPEC_LIST is not Null then
        for each prosumers, capec ∈ CAPEC_LIST do
            // CAPEC to Technique Mapping
            Technique_LIST ← result of CAPEC to Technique
        end
        return Technique_LIST
    else
        // ML TTP MAPPING Algorithm (Input: CVE ID, Output: TTP)
    end
    // If Technique mapping is available,
    if Technique_LIST is not Null then
        // Saving Techniques_LIST to the DB
    else
        // ML TTP MAPPING Algorithm (Input: CVE ID, Output: TTP)
    end
else
    // ML TTP MAPPING Algorithm (Input: CVE ID, Output: TTP)
end
```

<룰기반 고위험 CTI-TTP 매핑 알고리즘>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

✓ (룰기반 TTP 매핑 정확도 측정) TTP와 매핑된 CVE 37,373개 기준 룰기반 매핑 알고리즘 수행 시 36,928개 일치로 98.81% 정확도 도출



<룰기반 TTP 매핑 정확도 측정 결과>

✓ (룰기반 TTP 매핑 분포) CTI-TTP 매핑 관련 정보 분포 분석 결과

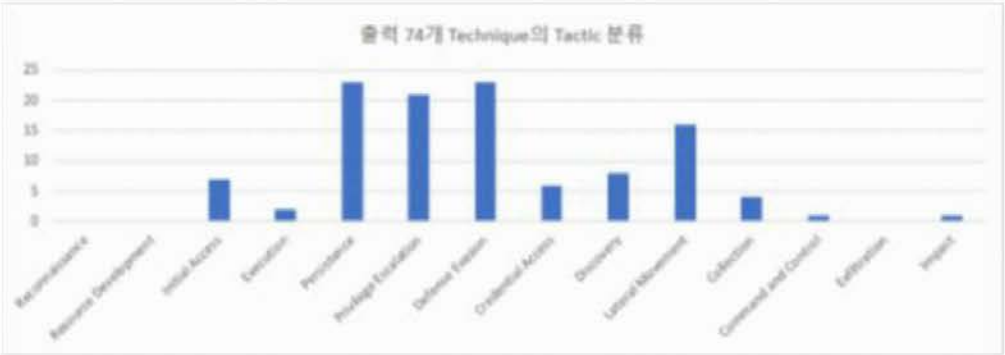
룰기반 CTI-TTP 매핑 분포 결과 시각화

CAPEC 분류 분포

CAPEC ID	Technique Count
CAPEC-555	6
CAPEC-163	5
CAPEC-471	3
CAPEC-551	3
CAPEC-564	2
CAPEC-17	2
CAPEC-634	2
CAPEC-552	2
CAPEC-187	2
CAPEC-561	2
CAPEC-558	2
CAPEC-645	2
CAPEC-639	2
CAPEC-644	2
CAPEC-479	2
...	...

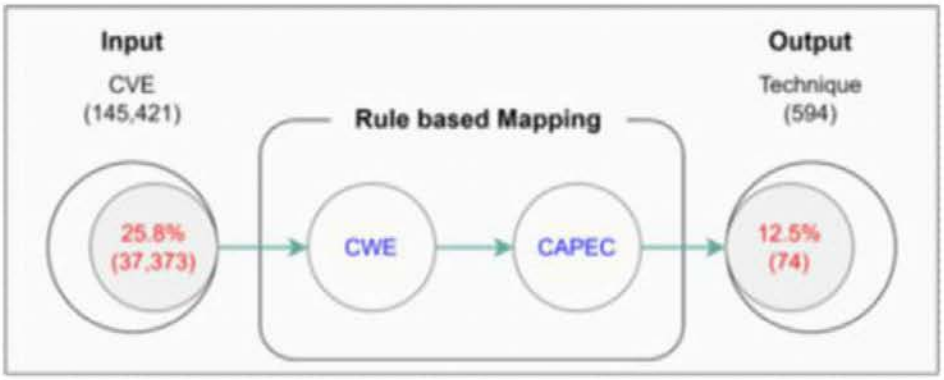
- 594개 CAPEC 중, 177개가 룰기반 매핑 가능함

Technique-ID Tactic 분포



- 14개의 Tactic 중, 11개 Tactic에 포함됨
- Persistence와 Defense Evasion에 각 23개로 가장 많이 포함됨

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

룰기반 CTI-TTP 매핑 분포 결과 시각화	
CTI-TTP 룰기반 매핑 커버리지	
	- PersisCVE 145,421개 중, MITRE ATT&CK 활용 시 37,373개 CVE-TTP 매핑 가능

✓ (고위험 TTP 관련 내부자산 식별 알고리즘 구현) 고위험 TTP와 매핑되는 내부(네트워크)자산을 도출할 수 있도록 구현

Algorithm 1: High-risk TTP Classification Algorithm

Input: CTI Object
Output: High-risk Object

```
cti_object ← get_cti_object(CTI Object)
if ttp ∈ cti_object is Null then
    ttp_list ← result of ML_based TTP Mapping
else
    ttp_list ← get_ttp_list(cti_object)
end
for each ttp ∈ ttp_list do
    cve_list ← result of ttp to CVE Mapping
    for each cve ∈ cve_list do
        network_asset_id ← find_network_asset_id(cve, internal asset DB)
        network_object ← result of select_internal_database(network_asset_id)
        return network_object
    end
end
```

<고위험 TTP 관련 내부자산 식별 알고리즘>

연구목표	보안 관제 플레이북 자동 생성 기술 설계 및 개발

세부 내용	1) 보안 위협의 대응 이력에 대한 강화학습 모델을 통한 적응형 플레이북 강화 모델 연구 및 설계
	2) TTP 정보를 연계한 템플릿 기반 플레이북 자동 생성 기술 설계 및 개발

1) 보안 위협의 대응 이력에 대한 강화학습 모델을 통한 적응형 플레이북 강화 모델 연구 및 설계

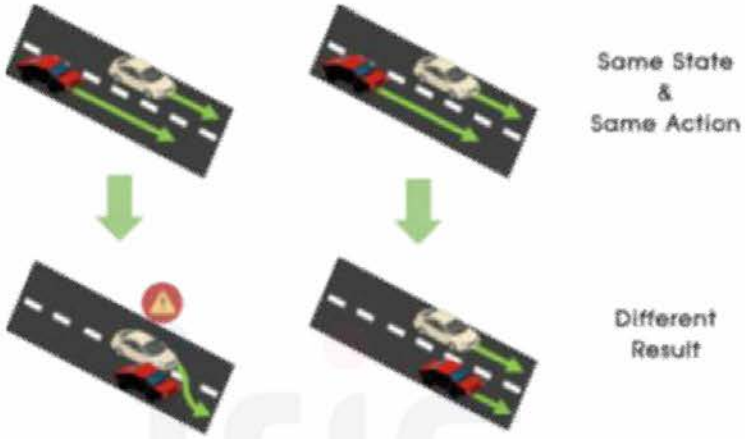
o 적응형 플레이북 강화를 위한 강화학습 모델로 Distributional RL 방법 사용

- 강화학습 알고리즘은 의사결정 기준이 무엇인지에 따라 가치 기반(value-based)와 정책 기반(policy-based)로 분류됨
- 가치 기반 강화학습은 액션-가치 함수 에 근거하여 액션(action)을 선택하며,

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

상태(state) s에서 선택할 수 있는 액션들 중에서 가장 가치(value)가 높은 액션을 선택하는 방식 (예: SARSA, Q-Learning)이며, 정책 기반 강화학습은 정책함수 $\pi(a|s)$를 보고 직접 액션을 선택하며, 에이전트가 주어진 환경에서 쌓은 경험을 이용해 학습 과정에서 π를 강화하는 방식

- DQN과 같은 기존의 가치 기반 강화학습 알고리즘은 미래에 받을 평균 보상을 하나의 숫자(scalar)로 예측하며, 이러한 예측값을 기반으로 가장 높은 보상을 받을 것이라 예측되는 액션을 선택하는 방식
- 하지만 이러한 방식은 환경이 임의성을 포함하고 있는 경우 상황에 따라 동일한 상태(state)에서 동일한 액션(action)을 취해도 다음 상태(state)에서 받는 보상(reward)이 변할 수 있는 제약이 있음



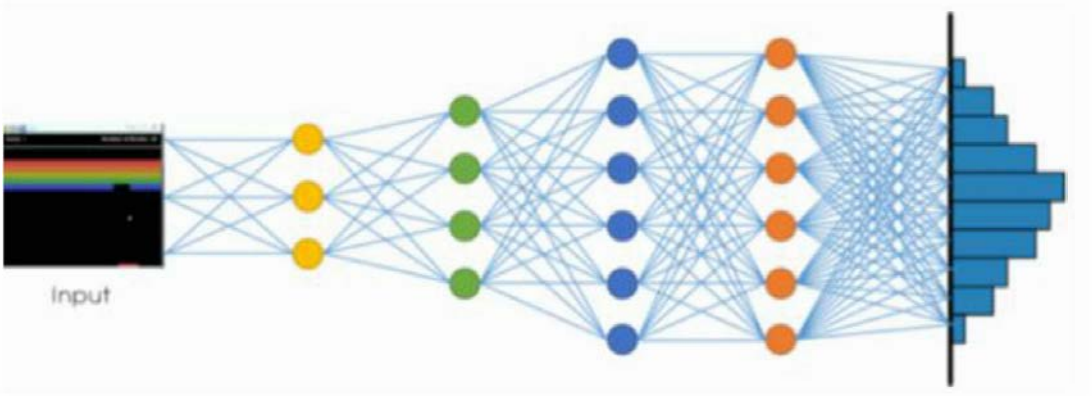
<빨간색 자동차 = 에이전트, 하얀색 자동차 = 환경의 랜덤성
(가속, 감속, 차선변경 중 하나를 랜덤하게 수행)>

- 이를 보완하기 위해서 예측되는 **보상을 분포(distribution)으로 나타내고, 미래의 보상을 분포를 통해 예측하여 확률적인 환경에서 더 정확한 예측을 수행할 수 있도록하는 Distributional RL을 적응형 플레이북 강화에 적용**하였음
- Distributional RL의 대표 종류로 C51 (Distributional Perspective on Reinforcement Learning), QR-DQN (Distributional Reinforcement Learning with Quantile Regression), IQN Implicit Quantile Networks for Distributional Reinforcement Learning 등이 있으며 본 과제에서는 C51, Categorical DQN을 사용
- Categorical DQN은 Distributional Bellman Equation을 사용하는데 기존 식에서 Value Q 대신에 Distribution Z를 사용

$$Z(x,a) = R(x,a) + \gamma Z(x',a')$$

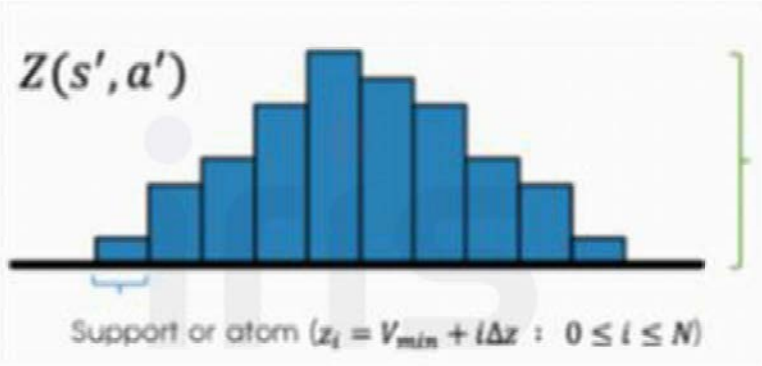
- 네트워크의 출력으로는 기존 DQN은 각 액션에 대한 Q-value를 사용하는 반면, Categorical DQN은 각 액션에 대한 value distribution이 출력되도록 설계

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



<Categorical DQN 개념도>

- Value도 Distribution 형태로 표현도는데, Support 혹은 Atom이라 부르는 상태 가치(state value)값에 대한 확률을 표현하며, 이때 하이퍼파라미터로 Support 수, Support 최댓값, Support 최솟값 등을 필요로 하는데, C51은 Support 수를 51개로 사용하여 붙여진 이름



- 기타 본 과제 강화학습 모델 학습 시 사용한 주요 하이퍼 파라미터는 다음과 같음

공통	Support 수: 51, Network 노드 수: 128, 학습률: 0.0001, 감쇠요소: 0.99, 배치 크기: 64, 반복횟수: 1,000,000
이벤트 최적 대응 도출	Support의 최소값, 최대값: -50, 30
이벤트 처리 우선순위 도출	Support의 최소값, 최대값: 0, 60
플레이북 처리 우선순위 도출	Support의 최소값, 최대값: 0, 60

- Q-Value는 이산확률분포의 기댓값을 구하는 것을 목적으로 아래와 같이 정의되며, 결과적으로 하나의 값(Scalar)를 가지게 됨

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

$$Q(x_t, a_t) = \sum_i z_i p_i(x_t, a_t)$$

- N: support의 수
- V_{min}: support의 최소값
- Δz: support간 간격
- z_i: support ($z_i = V_{min} + i\Delta z, 0 \leq i \leq N$)
- p_i: support z_i에 대한 확률

- Loss 계산은 아래와 같은 식을 따르며, 목표 값(target value)가 아닌 목표 분포(target distribution)을 통해 학습이 수행되며, Cross Entropy 식을 바탕으로 목표 분포와 추정된 분포 간 차이를 구하고 이를 줄이는 방향으로 학습 수행

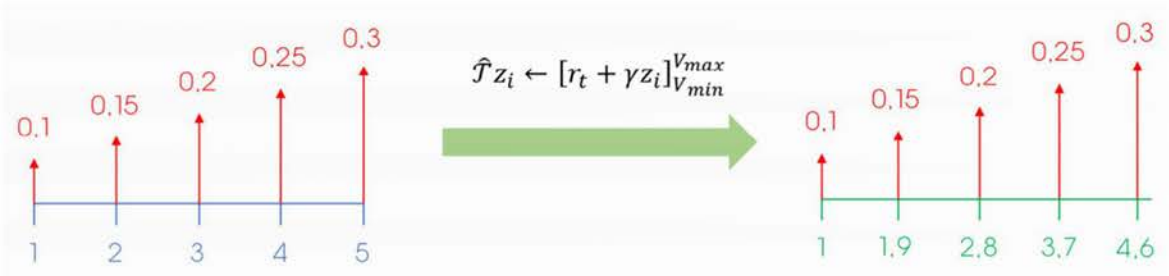
$$Loss = -\sum_i m_i log p_i(x_t, a_t)$$

- N: support의 수 ($0 \leq i \leq N$)
- m_i: 목표 분포
- p_i: support z_i에 대한 확률(네트워크의 output)

- 목표 분포(Target Distribution) 계산을 위해 각 Support에 감가율(discount factor)를 곱하고 보상(reward)를 더해주게 되며, 값이 Support의 최댓값 보다 큰 경우 최댓값과 같도록, 최솟값보다 작은 경우 최솟값과 같도록 설정함

$$\hat{\mathcal{T}} z_i \leftarrow [r_t + \gamma z_i]_{V_{min}}^{V_{max}}$$

- 위 계산대로 진행하면 감가율을 곱해주는 과정에서 Support 값이 기존 Support와 달라져 Cross Entropy 연산 수행이 어려워지기 때문에 Projection이라는 과정을 추가로 수행함
- 아래 그림은 Support가 [1, 2, 3, 4, 5]이고, 각 확률이 [0.1, 0.15, 0.2, 0.25, 0.3], 그리고 보상은 0.1, 감가율은 0.9로 설정했을 때 Projection 예임

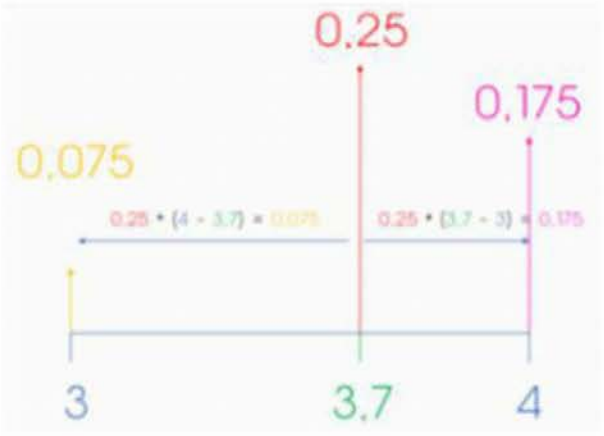


<Projection 예>

- 3.7에 해당하는 확률값인 0.25를 Support 3과 4로부터의 거리에 비례하여 분배하며, 3과 4에서부터 3.7까지의 거리비율은 7:3을 사용하면, Support 3이 할당 받는

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

확률값은 0.25 * 0.3이 되어 0.075가 되고, Support 4가 할당 받는 확률값은 0.25 * 0.7이 되어 0.175가 됨



<Project을 통한 확률 변환 예>

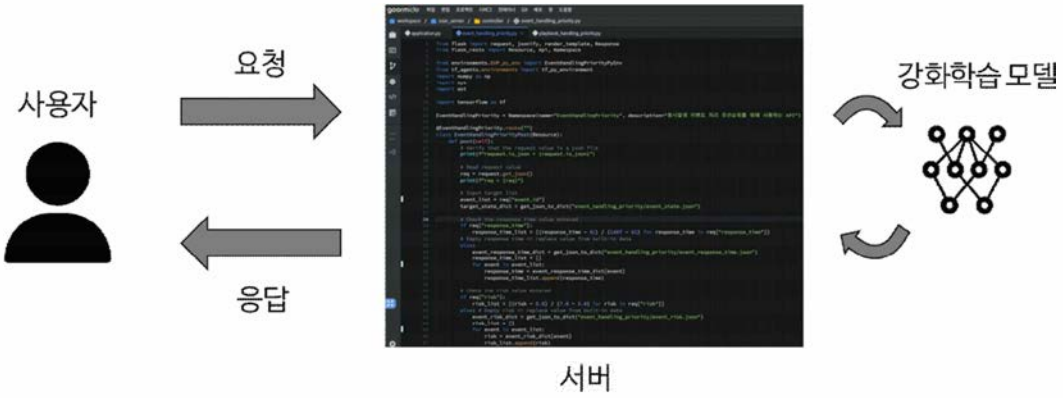
- 이러한 방식으로 Support [1, 1.9, 2.8, 3.7, 4.6]과 확률 [0.1, 0.15, 0.2, 0.25, 0.3]에 Projection을 적용한 결과 Support [1, 2, 3, 4, 5]와 확률 [0.115, 0.175, 0.235, 0.295, 0.18]이 됨

<Projection 적용 전 / 후 확률 변화>

o 적응형 플레이북 강화를 위한 강화학습 모델로 Distributional RL 방법 개발

- 강화학습을 통한 적응형 플레이북 강화를 총 세 가지 방향으로 진행: **(1) 최적 대응 시퀀스 도출 (향후 플레이북 구성 개선), (2) 이벤트 처리 우선순위 도출 (플레이북 실행 이벤트 결정 개선), (3) 플레이북 처리 우선순위 문제 (에러 발생 시 플레이북 적응적 처리)**
- 모든 개발 모델은 클라이언트에서 각 문제별 URL 주소로 HTTP 요청을 하면, 서버에 존재하는 학습된 강화학습 모델이 요청 받은 정보를 입력 받아 응답 정보를 생성하고 클라이언트에 반환하는 방식으로 클라우드에 구현

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



〈테스트 강화학습 모델 실행 환경 개념도〉

o 적응형 플레이북 강화를 위한 강화학습 모델: (1) 최적 대응 모델
- 보안 상황에서 발생하는 공격 이벤트들에 빠르고 효율적으로 대응하는 플레이북을 설계하기 위해 연구된 모델로, 사용자는 시스템에 공격 이벤트 아이디(event_id)를 필수 입력값으로 제공해야 하며, 이 아이디는 각각의 보안 위협에 대응하기 위한 고유 식별자로 작용
- 시스템은 입력 받은 이벤트 아이디를 기반으로 적절한 대응 조치를 결정하고, 그 결과를 대응 아이디(response_id)의 순차적 리스트로 출력
- 이 리스트는 보안 팀이 따라야 할 대응 조치들의 순서를 명확하게 제시하여, 보안 사고에 신속하고 체계적으로 대응할 수 있도록 도울 수 있으며, 이때 각 대응 아이디는 특정 공격 유형에 맞는 특정 대응 조치를 나타내며, 이 시스템을 통해 보안 관리자와 대응 팀은 보안 위협을 효과적으로 관리하고, 공격에 대한 대응 시간을 단축시킬 수 있음
- 이러한 프로세스 자동화는 보안 이벤트 처리의 정확성을 높이고, 인적 오류를 줄이며, 전체적인 보안 대응 프로토콜을 강화하는 데 기여 가능

```
optimal_response_url = 'https://soar-rl-agent.run.goorm.io/optimal_response'

data = {"event_id": "wget"} # ex) {"event_id": "wget"}

response = requests.post(optimal_response_url, json=data)
if response.status_code == 200:
    response_sequence = response.content.decode()
    response_sequence = ast.literal_eval(response_sequence)
    print(response_sequence)
else:
    print('Got unexpected status code {}: {!r}'.format(response.status_code, response.headers))
```

Last executed at 2022-10-04 17:27:48 in 5.64s

```
['src_ip_block_recomm', 'malicious_url_block_recomm', 'dst_ip_info_request']
```

〈강화학습 기반 최적 대응 시퀀스 도출 실행 예〉

o 적응형 플레이북 강화를 위한 강화학습 모델: (2) 이벤트 처리 우선순위 도출 모델
- 이벤트 처리 우선순위를 다루는 강화학습 모델은 동시에 발생하는 여러 보안 위협 이벤트들에 대한 대응 순서를 자동화하기 위한 목적으로 설계되었으며, 사용자는 두 가지 필수 입력값을 제공
  > 각 이벤트의 위험도와 처리 시간에 대한 가중치(alpha) 값으로 이 값은 우선순위

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

결정에 있어 위험도와 처리 시간의 중요도를 조절하는 데 사용

> 발생한 공격 이벤트의 아이디(event_id) 리스트로, 이벤트가 중복되어 발생할 수 있음

> 이벤트별 예상 위험도(risk)와 예상 처리 시간(response_time)을 선택적으로 입력할 수 있으며, 이 값들이 제공되지 않을 경우 시스템은 기존 데이터의 평균값을 활용

- 시스템의 출력은 두 가지로 구성되는데, 첫 번째는 위험도가 높고 처리 시간이 짧은 이벤트일수록 높은 우선순위(priority)를 갖도록 정렬된 이벤트 아이디(event_id) 리스트이며, 두 번째는 사용자가 입력한 이벤트 아이디의 인덱스(index) 리스트로, 입력 순서를 기준으로 함

$$priority = alpha * risk + (1 - alpha) * response_time$$

- 우선순위는 위험도와 처리 시간을 정규화한 후 가중치(alpha)를 적용하여 아래 식을 통해 계산됨

```
event_handling_priority_url = 'https://soar-rl-agent.run.goorm.io/event_handling_priority'

data = {"alpha": 0.5,
        "event_id": ["icmp", "icmp", "ssl", "wget", "ssl"],
        "risk": [5.8, 5.8, 7.6, 6.6, 7.6],
        "response_time": [1333, 125, 373, 100, 1200]} # ex) {"alpha": 0.5, "event_id": ["icmp", "icmp", 100, 1200]}

response = requests.post(event_handling_priority_url, json=data)
if response.status_code == 200:
    response_sequence = response.content.decode()
    response_sequence = ast.literal_eval(response_sequence)
    print(response_sequence)
else:
    print('Got unexpected status code {}: {!r}'.format(response.status_code, response.headers))
Last executed at 2022-10-04 19:47:33 in 3.34s
{'event_id': ['icmp', 'wget', 'ssl', 'ssl', 'icmp'], 'index': [1, 3, 2, 4, 0]}
```

<강화학습 기반 이벤트 처리 우선순위 도출 실행 예>

o 적응형 플레이북 강화를 위한 강화학습 모델: (3) 플레이북 처리 순서 도출 모델

- 이 모델은 에러가 발생한 다수의 플레이북에 대해 효율적인 대처 순서를 자동으로 정렬하는 것을 목적으로 하며, 두 가지 필수 입력 값을 제공해야 함

> 각 플레이북의 위험도와 처리 시간에 대한 가중치를 결정하는 alpha 값

> 에러가 발생한 플레이북의 식별자(ID) 목록으로, 이 목록에는 동일한 플레이북 ID가 여러 번 나타날 수 있음

> 선택적으로, 사용자는 각 플레이북의 예상 위험도와 예상 처리 시간을 리스트 형태로 제공할 수 있으며, 이 값들이 제공되지 않을 경우 시스템은 기존 데이터의 평균값을 사용

- 강화학습 모델이 만들어내는 출력 값은 두 가지로 첫째, priority라는 기준에 따라 정렬된 플레이북 ID의 목록과, 입력된 플레이북 ID의 인덱스 목록임

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- 우선순위는 위험도가 높고 처리 시간이 짧을수록 높아지며, 우선순위를 결정하기 위해, 위험도와 처리 시간은 정규화 과정을 거치고, 이후 가중치 alpha를 적용하여 계산되는 아래 식을 따름

$$priority = alpha * risk + (1-alpha) * response_time$$

```
playbook_handling_priority_url = 'https://soar-rl-agent.run.goorm.io/playbook_handling_priority'

data = {"alpha": 0.5,
        "playbook_id": ["P001", "P015", "P016", "P017"],
        "risk": [5.8, 6.4, 7.0, 6.6],
        "response_time": [986, 674, 373, 300]} # ex) {"alpha": 0.5, "playbook_id": ["P001", "P01

response = requests.post(playbook_handling_priority_url, json=data)
if response.status_code == 200:
    response_sequence = response.content.decode()
    response_sequence = ast.literal_eval(response_sequence)
    print(response_sequence)
else:
    print('Got unexpected status code {}: {!r}'.format(response.status_code, response.headers))
```

Last executed at 2022-10-04 19:55:30 in 3.03s

```
{'playbook_id': ['P016', 'P017', 'P015', 'P001'], 'index': [2, 3, 1, 0]}
```

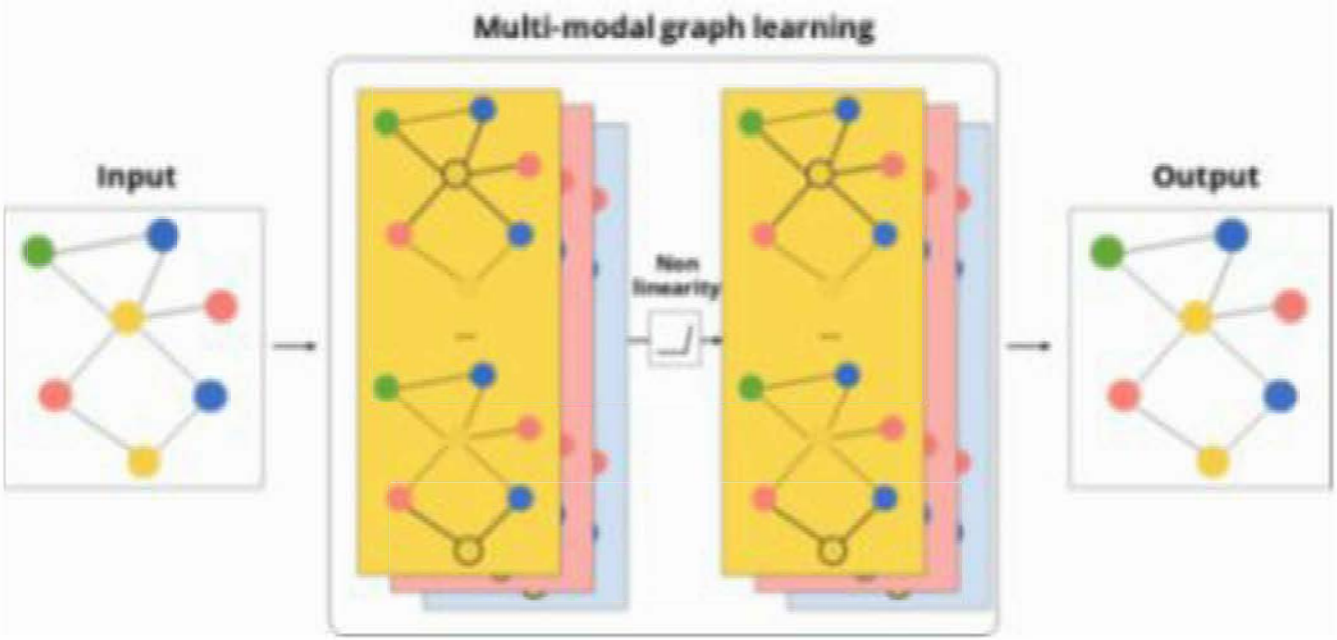
<강화학습 기반 플레이북 처리 우선순위 도출 실행 예>

o TTP 정보를 연계한 템플릿 기반 플레이북 자동 생성 기술 설계 및 개발

- 다양한 형태의 TTP 정보 반영 데이터 특징 추출 방법론 분석
  - > 다종/다량의 보안 이벤트가 포함된 TTP 정보는 다양한 형태를 띄며, 대부분 자연어로 기술된 비정형 위협 데이터로 구성
  - > 보안 위협 대응 플레이북 자동 생성을 위한 그래프 모델을 학습함에 있어 다양한 형태로 나타나는 TTP 분석 정보에 대한 반영 필요
  - > 다양한 TTP 분석 정보에 내재되어 있는 특징을 딥러닝 기반의 멀티 모달리티 학습 (Multi-modal learning) 도입
  - > TTP 정보가 이미지, 텍스트, 정형 데이터 등의 다양한 형태로 연계될 경우, 멀티 모달리티 학습을 통해 여러 형태의 데이터를 포괄할 수 있도록 함
  - > 다양한 형태의 특징들을 종합적으로 고려하여 더 효과적이고 포괄적인 보안 위협 대응 플레이북을 자동으로 생성 가능

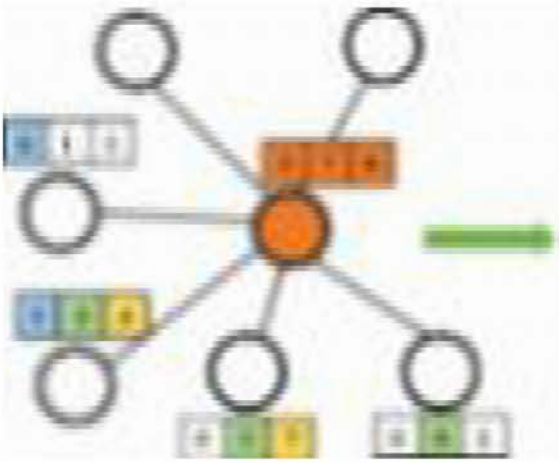
    * 멀티 모달리티 학습 (Multi-modality learning)
      - 한 형태의 데이터가 아닌 다른 특성을 갖는 데이터 타입들을 같이 활용하는 학습 접근법
      - 각각의 데이터들은 서로 다른 특성을 가지고 있기 때문에, 다른 모달리티의 정보들을 공통된 공간 (feature space)으로 보내 함께 사용
      - 이를 통해 보다 풍부하고 복합적인 정보를 고려하여 학습 가능

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



<멀티 모달 접근법을 사용한 그래프 AI 학습 구조 예시>

- 플레이북 자동 생성 AI 학습 모델 고도화
  > 다양한 형태 및 모달리티의 TTP 정보의 연계를 고려하여 멀티 모달리티 학습을 적용하여 특징 추출에 대한 확장 가능성을 향상 시키고자 함
  > 텍스트, 이미지, 수치형 혹은 범주형과 같은 정형 (tabular) 데이터 등 여러 형태의 데이터가 입력으로 들어왔을 시 데이터 형태에 맞게 특성을 고려하여 각 모달리티의 특징을 추출하는 모델을 구성
  > 추출한 특징은 그래프를 구성하고 있는 노드의 특징으로 활용하여 그래프 구축에 활용



< 노드 특징을 부여한 그래프 구조 예시>

  > 텍스트 기반 특징 추출 모델
    · 텍스트 데이터의 특징 추출 모델로는 LSTM, Bi-LSTM, KoBERT 등 다양하게 적용되고 있음
    · 문장 형태의 텍스트 데이터를 모델의 입력으로 부여하기 전, KoNLPy 패키지를 활용하여 전처리를 우선적으로 수행
      ① 형태소 토큰화: 주어진 문장을 작은 단위로 나누어주는 과정으로, 토큰의

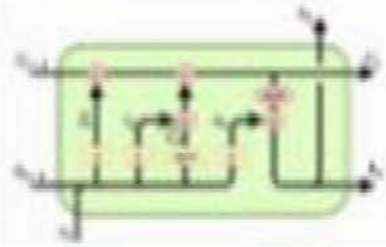
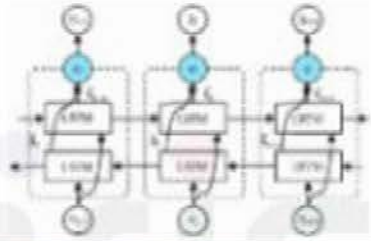
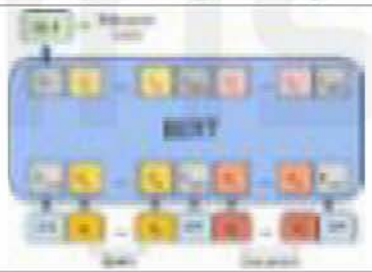
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

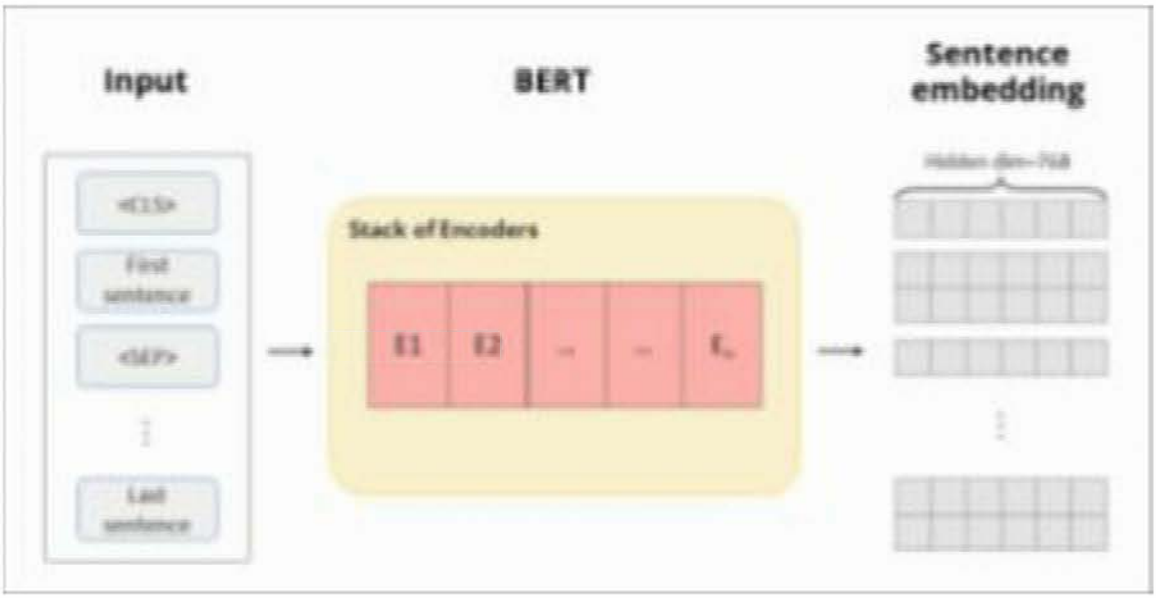
단위를 형태소로 설정하여 형태소 단위로 문장을 분할

② 불용어 제거: 자주 등장하지만 특징으로서 의미가 없는 단어인 불용어를 제거하는 과정으로, KoNLPy 패키지에 내장되어 있는 불용어 목록을 활용하여 앞서 만들어진 토큰을 대상으로 불용어를 제거

· 데이터 전처리를 거친 정제된 텍스트 데이터를 모델의 입력으로 하여 문장의 특징과 유사도를 내포하는 임베딩 벡터 추출

<텍스트 기반 신경망 계열 인공지능 모델 종류>

알고리즘	대표 그림	특징
Long Short Term Memory (LSTM) (Hochreiter & Schmidhuber, 1997)		순환 신경망(RNN) 중 한 종류로 시점 별로 달라지는 값을 모델에 순차적으로 입력함과 동시에 기존 RNN의 장기 의존성 문제를 해결
Bi-directional Long Short Term Memory (Bi-LSTM) (Zhou et al., 2016)		LSTM 구조에서 양방향 학습을 할 수 있도록 확장한 구조로, 문맥을 파악하여 맥락을 잘 표현하는 임베딩을 학습
Bidirectional Encoder Representations from Transformers (BERT) (Delvin et al., 2019)		Transformer 구조를 기반으로 하여 양방향 문맥 파악이 가능해 맥락을 고려 가능



<신경망을 통해 추출된 문장 임베딩 벡터 추출 예시>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

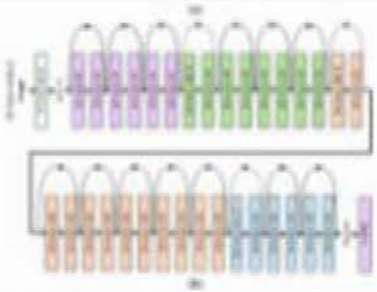
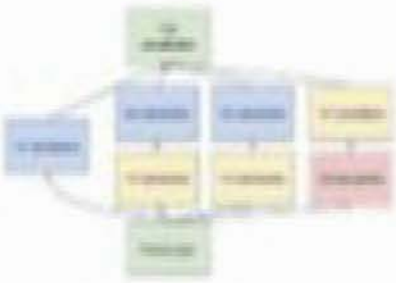
```
import torch
from transformers import BertTokenizer, BertModel
from tqdm import tqdm
# Load KoBERT model and tokenizer
kobert_model_name = 'monologg/kobert'
tokenizer = BertTokenizer.from_pretrained(kobert_model_name)
model = BertModel.from_pretrained(kobert_model_name)

# Encode sentences and extract embeddings
cre_corpus_embeddings = []

for sentence in tqdm(creator_feature):
    inputs = tokenizer(sentence, padding=True, truncation=True, return_tensors="pt")
    with torch.no_grad():
        outputs = model(**inputs)
    sentence_embedding = outputs.last_hidden_state[:, 0, :].numpy()
    cre_corpus_embeddings.append(sentence_embedding)
```

< KoBERT 기반 텍스트 특징 추출 모델 실행 코드 예시 (일부) >

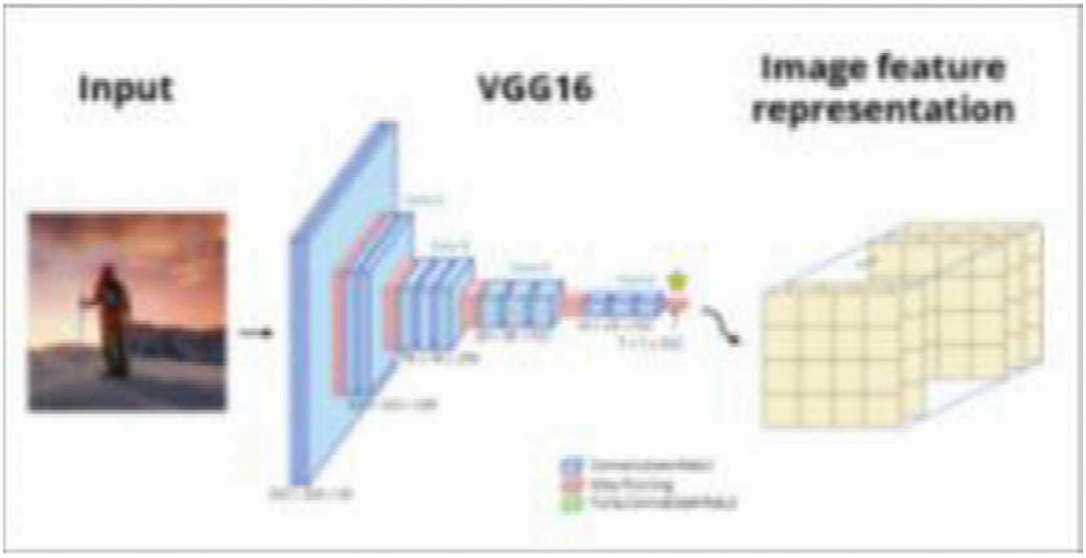
> 이미지 기반 특징 추출 모델

- 주로 이미지 분류 문제에 대한 딥러닝 기반 모델들이 사용됨
- 특히 대용량 데이터로 미리 학습한 사전학습 모델들이 일반화되고 효율적인 특징 추출을 하기 위해 다양하게 적용됨

<이미지 기반 신경망 계열 인공지능 모델 종류>

알고리즘	대표 그림	특징
VGG16 (Simonyan, 2014)		컨볼루션 신경망(CNN) 아키텍처 중 하나로 대규모 이미지 데이터셋인 Imagenet 으로 사전 학습된 이미지 기반 모델로, 16개의 합성곱(Convolutional) 및 완전 연결(Fully connected) layer) 로 구성
ResNet (He et al., 2015)		깊은 신경망을 효과적으로 학습시키기 위해 잔차 블록 (Residual block) 을 사용하여 정보 소실을 줄임
InceptionV3 (Szegedy et al., 2015)		구글에서 개발한 Imagenet 기반 사전학습 딥러닝 모델로, 인셉션 (Inception) 모듈을 통해 다양한 관점에서 특징을 추출

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



<신경망을 통해 추출된 이미지 특징 벡터 추출 예시>

```
VGGExtractor = tf.keras.applications.VGG16(
                    include_top=False,
                    weights="imagenet",
                    input_shape=(224,224,3),
                )

inp = VGGExtractor.input
x = VGGExtractor.output
x = tf.keras.layers.GlobalAveragePooling2D()(x)
x = tf.keras.layers.BatchNormalization()(x)
x = tf.keras.layers.Dense(64, activation="relu")(x)

VGG16_model = tf.keras.Model(inp, out)
```

<VGG16 기반 이미지 특징 추출 모델 실행 코드 예시 (일부)>

> 정형 데이터 특징 추출

- 정형 데이터는 연속형, 이산형, 범주형, 이진, 순서형 등 기본적인 정제 과정을 거쳐 테이블로 가능한 형태로 표현
- 정형 데이터에는 각각의 특징이 이미 수치로 표현되어 있으므로 별도의 변환 없이 사용 가능
- 필요에 따라 데이터 스케일링, 정규화 등의 전처리 수행
- 최근에는 이미지 및 텍스트 특징 추출을 위해 딥러닝 모델을 사용하는 것 처럼, 최근에는 예측 성능과 해석력을 개선하기 위하여 TabNet과 같은 정형 데이터 특징 추출을 위한 딥러닝 모델의 응용이 증가하는 추세

> 다양한 형태의 데이터 특징 연결

- 텍스트, 이미지, 수치형, 범주형 등 다양한 데이터 형태에서 추출된 특징들을 하나로 합치기 위한 단계로 단순 결합 (concatenate) 방법을 사용
- 텍스트 및 이미지 데이터에서 앞서 사전 학습 모델을 통해 추출한 특징 벡터를 학습 전에 정형 데이터와 연결하는 것

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- 각 데이터 특징들을 통합한 최종 특징을 생성하여 보다 강력하고 구별되는 특징 표현 가능

> 그래프 모델에 대한 특징 표현 적용

- 다양한 정보를 모두 가지고 있는 최종 특징을 그래프 노드의 특성으로 부여하여 초기화된 그래프를 구성
- 초기회된 그래프에 그래프 신경망을 적용하여 각 노드의 특성을 업데이트함으로서 멀티 모달 특징이 고려된 그래프를 기반으로 다양한 정보가 융합되며 새로운 노드 특성을 획득
- 플레이북 자동 생성 모델의 학습을 진행하며 노드 특징을 반영하며 계속 업데이트 될 수 있도록 최종 특징에 대해 선형 변환을 수행
- 결과적으로 다양한 형태의 정보를 담고 있는 노드로 구성된 그래프를 획득

```
import torch
from torch_geometric.data import HeteroData

# 텍스트 feature 이미지 feature 간 concatenation
seq_feature = torch.cat((text_feature,image_feature), dim = -1 )

# 그래프 구축

data = HeteroData()
data['event'].x = torch.tensor(np.one((1879,5)).tolist()) # 노드 feature 추가
data['seq'].x = torch.tensor(np.one((3795,20)).tolist())
data['event', 'connect', 'seq'].edge_index = edge_index_event_to_seq
data['event', 'connect', 'seq'].edge_weight = weight_feature
```

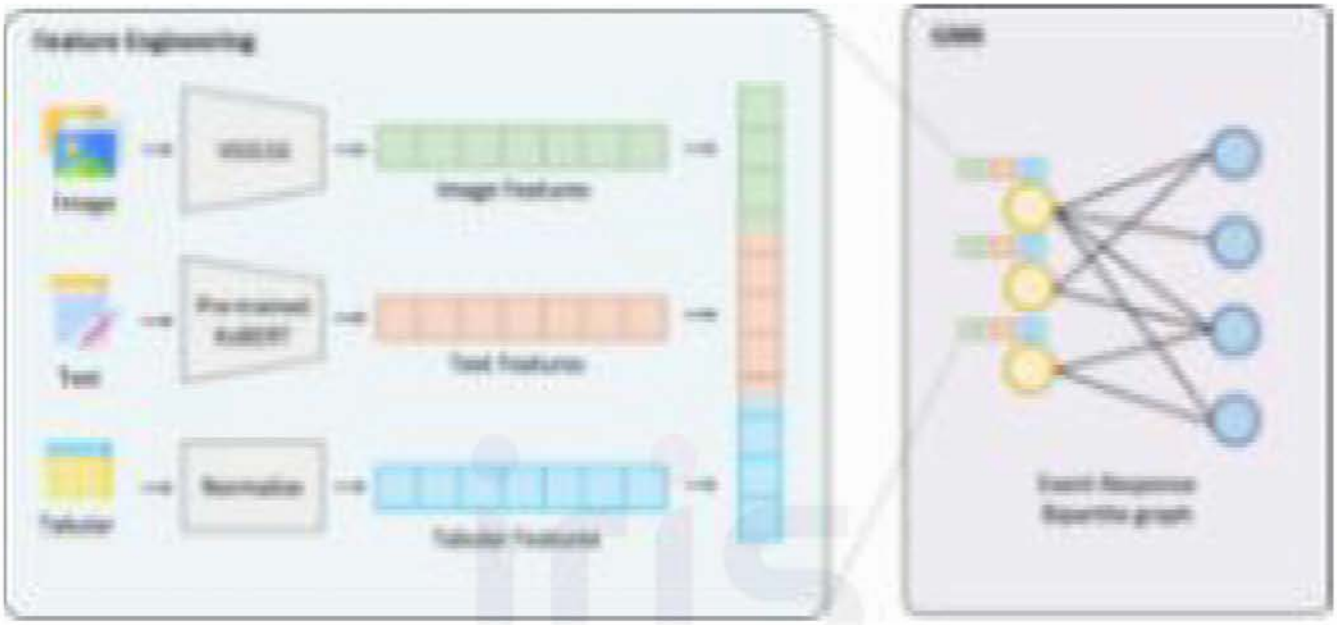
< 멀티 모달 노드 특징을 부여한 그래프 구축 실행 코드 예시 (일부) >

> 멀티 모달리티 기반 플레이북 자동 생성 AI 학습 모델 실험

- 다양한 모달리티로의 확장성을 확인하기 위하여 텍스트, 이미지, 정형 데이터의 다양한 모달리티가 나타나며, 이분 그래프 (Bipartite graph) 형태로 표현이 가능한 타 데이터로 대체하여 모델 실험 수행
- 입력 데이터가 단일 데이터 형태일 경우
  - 텍스트 데이터 정확도: 89.10%
  - 이미지 데이터 정확도: 87.24%
  - 정형 데이터 정확도: 87.84%
- 입력 데이터가 두 개의 다른 데이터 형태일 경우
  - 텍스트 + 이미지 데이터 정확도: 89.37%
  - 텍스트 + 정형 데이터 정확도: 89.18%
  - 이미지 + 정형 데이터 정확도: 88.26%
- 입력 데이터가 세 개의 다른 데이터 형태일 경우
  - 텍스트 + 이미지 + 정형 데이터 정확도: 89.51%
- 단일 데이터 형태를 사용해 그래프 모델을 학습했을 경우 모든 경우에 대해서 87% 이상의 정확도를 보임

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- 두 개 이상의 데이터 형태를 사용해 그래프 모델을 학습했을 경우 모든 경우에 대해서 88% 이상의 정확도를 보임
- 두 개 이상의 데이터 형태를 사용했을 경우 단일 데이터 형태를 사용한 경우보다 정확도가 향상됨
- 세 개의 다른 데이터 형태를 모두 사용할 경우 89.51%로 가장 높은 정확도를 보임
- 그래프 기반 플레이북 자동 생성 AI 학습 모델을 위한 특징 추출 및 활용에 있어 다양한 형태의 입력 데이터에 대한 확장 가능성을 확인



<멀티 모달 노드 특징을 부여한 그래프 모델 구조도>

2) TTP 정보를 연계한 템플릿 기반 플레이북 자동 생성 기술 설계 및 개발

o TTP 기반 플레이북 자동 생성 시스템 설계 및 개발

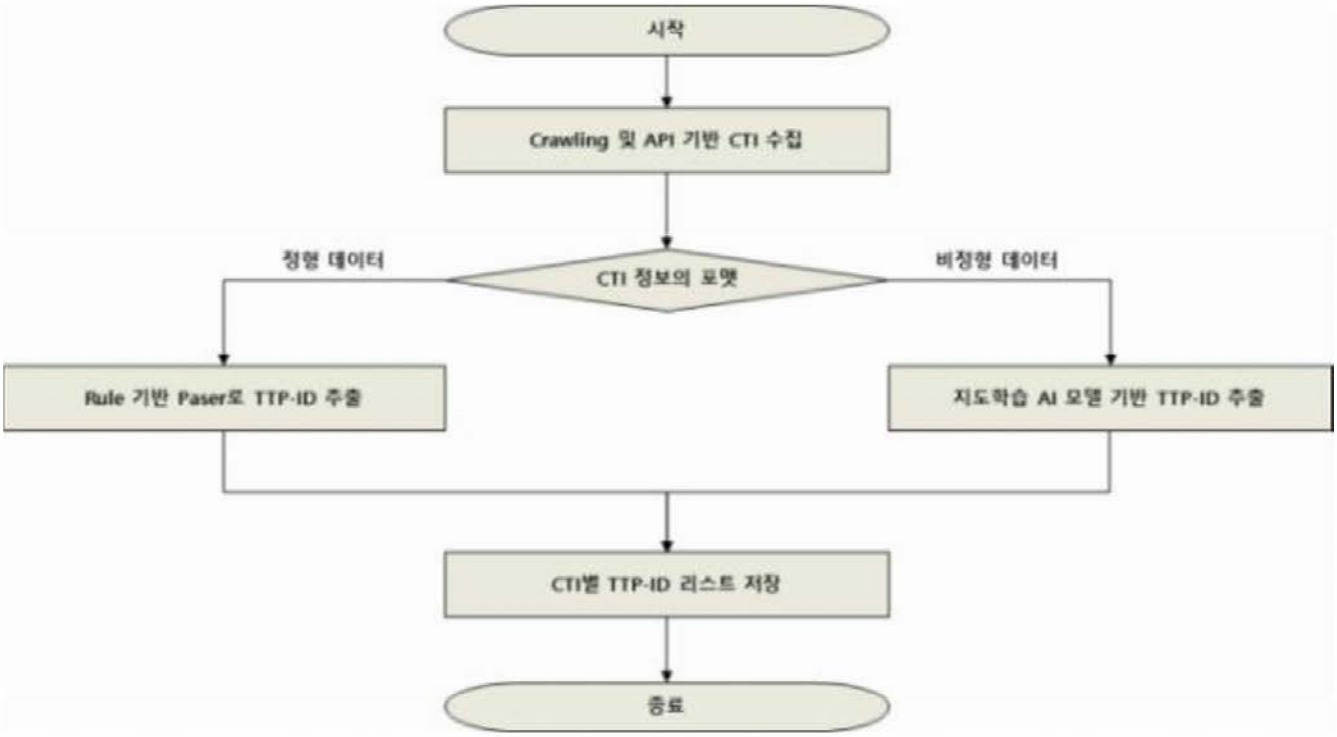
- TTP 기반 플레이북 자동 생성을 위한 데이터베이스 설계 및 개발

<DB Table별 역할 및 설명 >

DB Table 역할	설명
보호 대상 네트워크 내부 자산 정보 DB	• 보호 대상 네트워크 시스템의 역할 및 설치·운영중인 OS, SW Name, SW Version, Open Port 등 정보
CTI 정보 DB	• 외부에서 수집한 CTI 정보 • CTI에서 추출한 TTP-ID 정보
TTP-ID별 Data Source DB	• MITRE ATT&CK 프레임워크에 정의된 TTP-ID별 Detection을 위한 Data Source 매핑 정보
컴포넌트 관리 DB	• Data Source와 관련된 컴포넌트 매칭 정보
임시 플레이북 DB	• 자동 생성된 플레이북 (향후 유효성 검증 필요)
플레이북 DB	• 최종 생성 완료된 플레이북 (유효성 검증 통과)

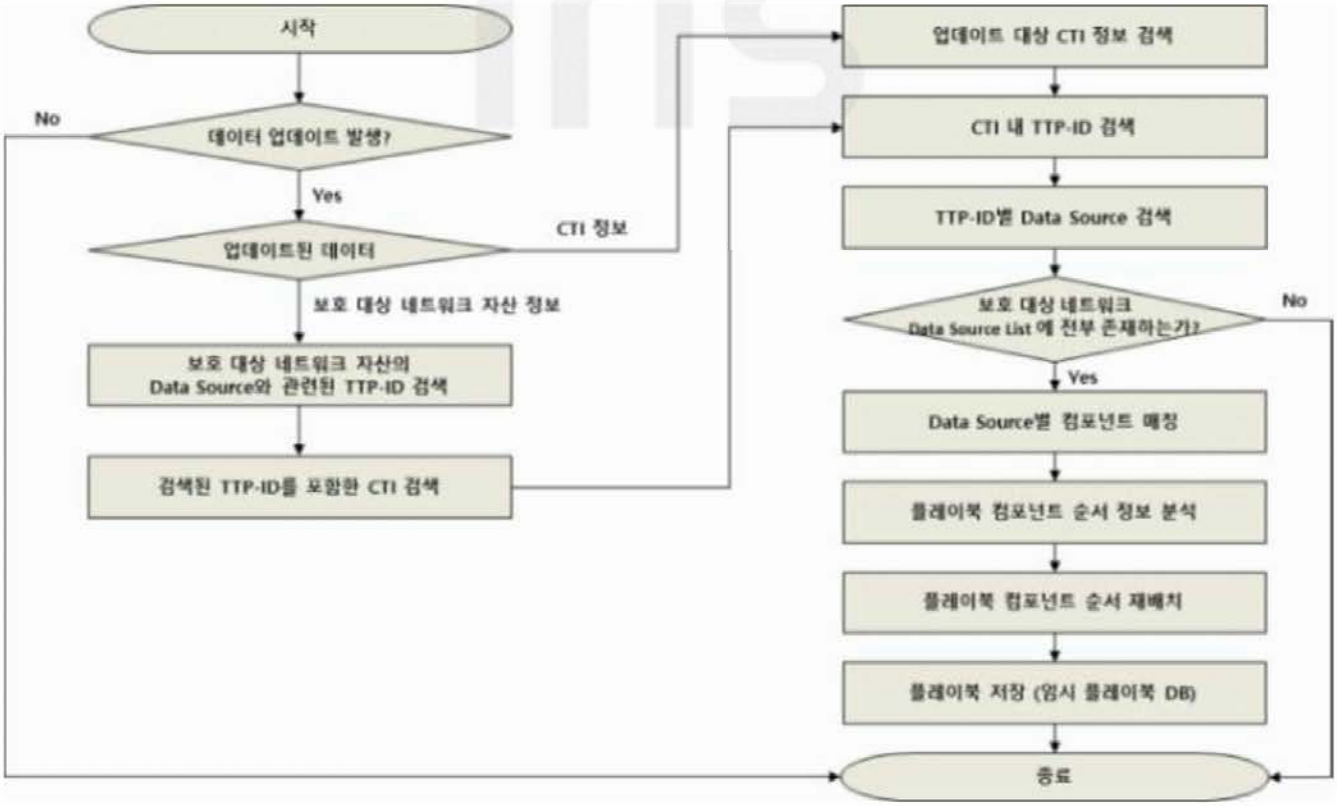
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- CTI 수집 및 TTP-ID 추출 기능 설계 및 개발



<CTI별 TTP-ID 추출 순서도>

- TTP 기반 플레이북 자동 생성 기능 설계 및 개발



<TTP 기반 플레이북 자동 생성 순서도>

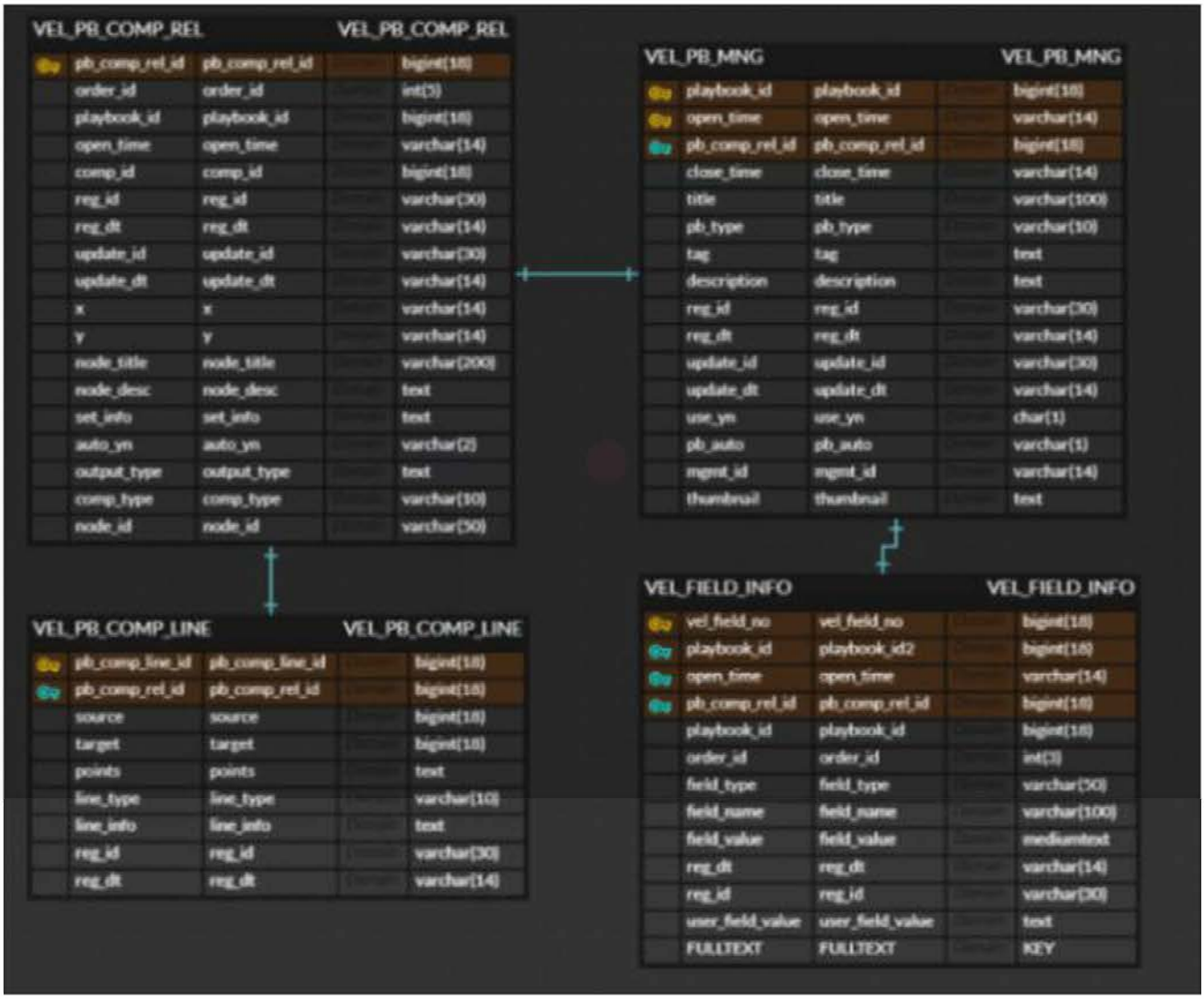
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

연구목표	보안 관제 플레이북 검증·관리 기술 개발

세부 내용	1) 시뮬레이션 기반 플레이북 요소 단위별 유효성 검증 기술 개발

1) 시뮬레이션 기반 플레이북 요소 단위별 유효성 검증 기술 개발

o 시뮬레이션 기반 플레이북 검증 기능 스키마 설계



2) 스키마 정의서

1. VEL_PB_MNG

테이블 명	한글명	검증 플레이북 정보	영문명	VEL_PB_MNG	
개요	검증 플레이북 테이블				
컬럼	컬럼명	한글컬럼명	키유형	Null	Type
	playbook_id	플레이북 아이디	PK	NN	BIGINT(18)
	open_time	생성 시간	PK	NN	VARCHAR(14)
	close_time	삭제 시간			VARCHAR(14)
	pb_type	분류			VARCHAR(100)
	tag	태그			TEXT

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

	description	설명			TEXT
	reg_id	등록자			VARCHAR(30)
	reg_dt	등록일시			VARCHAR(14)
	update_id	최종 수정자			VARCHAR(30)
	update_dt	최종 수정일시			VARCHAR(14)
	use_yn	사용여부			CHAR(1)
	pb_auto	자동			VARCHAR(1)
	mgmt_id	플레이북 관리ID			VARCHAR(14)
	thumbnail	플레이북 썸네일 경로			TEXT
색인 ID	PRIMARY KEY (‘playbook_id‘,‘open_time‘)				
참고사항					

2. VEL_PB_COMP_REL

테이블 명	한글명	검증 컴포넌트 값	영문명	VEL_PB_COMP_REL
개요	검증 플레이북 내 컴포넌트 값			
컬럼	컬럼명	한글컬럼명	키유형	Null	Type
	pb_comp_rel_id	플레이북-컴포넌트 관계 id	PK	NN	BIGINT(18)
	order_id	컴포넌트 순서			INT(5)
	playbook_id	플레이북 id			BIGINT(18)
	open_time	어떤 시점의 플레이북인지 체크			VARCHAR(14)
	comp_id	컴포넌트 id			BIGINT(18)
	reg_id	등록자			VARCHAR(30)
	reg_dt	등록일시			VARCHAR(14)
	update_dt	수정 일시			VARCHAR(14)
	x	x			VARCHAR(14)
	y	y			VARCHAR(14)
	node_title	노드 제목			VARCHAR(200)
	node_desc	노드 설명			TEXT
	set_info	설정 정보			TEXT
	auto_yn	자동 여부			VARCHAR(2)
	output_type	결과값 정보			TEXT
	comp_type	컴포넌트 타입			VARCHAR(10)
	node_id	노드 아이디			VARCHAR(50)
색인 ID	PRIMARY KEY (‘pb_comp_rel_id‘)				

3. VEL_PB_COMP_LINE

테이블 명	한글명	검증 플레이북 내 컴포넌트 라인	영문명	VEL_PB_COMP_LINE
개요	검증 플레이북 내 컴포넌트 연결 라인 정보			
컬럼	컬럼명	한글컬럼명	키유형	Null	Type
	pb_comp_line_id	플레이북-컴포넌트-라인 id	PK	NN	BIGINT(18)
	source	전 컴포넌트	PK	NN	BIGINT(18)
	target	후 컴포넌트			BIGINT(18)

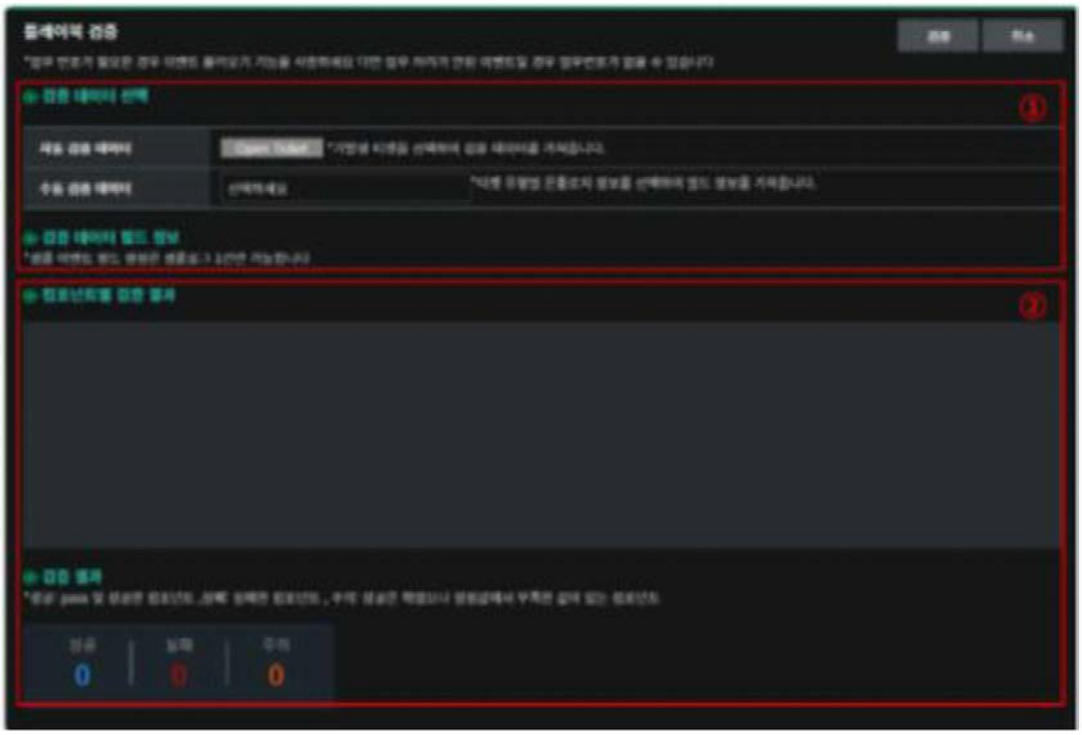
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

	points	포인트			TEXT
	line_type	분류			VARCHAR(10)
	line_info	condition이거나 insert 시 필요정보 json형태로 기입			TEXT
	reg_id	등록자			VARCHAR(30)
	reg_dt	등록일시			VARCHAR(14)
색인 ID	PRIMARY KEY (‘pb_comp_line_id‘)				

4. VEL_FIELD_INFO

테이블 명	한글명	검증 플레이북 필드 정보	영문명	VEL_FIELD_INFO
개요	검증 플레이북 필드 정보			
컬럼	컬럼명	한글컬럼명	키유형	Null	Type
	vel_field_no	필드 번호	PK	NN	BIGINT(18)
	playbook_id	플레이북 아이디			BIGINT(18)
	order_id	순서			INT(3)
	field_type	필드 타입			VARCHAR(50)
	field_name	필드 이름			VARCHAR(100)
	field_value	필드 값			MIDIUMTEXT
	reg_dt	등록자			VARCHAR(14)
	reg_id	등록일시			VARCHAR(30)
	user_field_value	사용자 필드 값			TEXT
색인 ID	PRIMARY KEY (‘vel_field_no‘)				

- 시뮬레이션 기반 플레이북 검증 연구 및 개발, 가시화

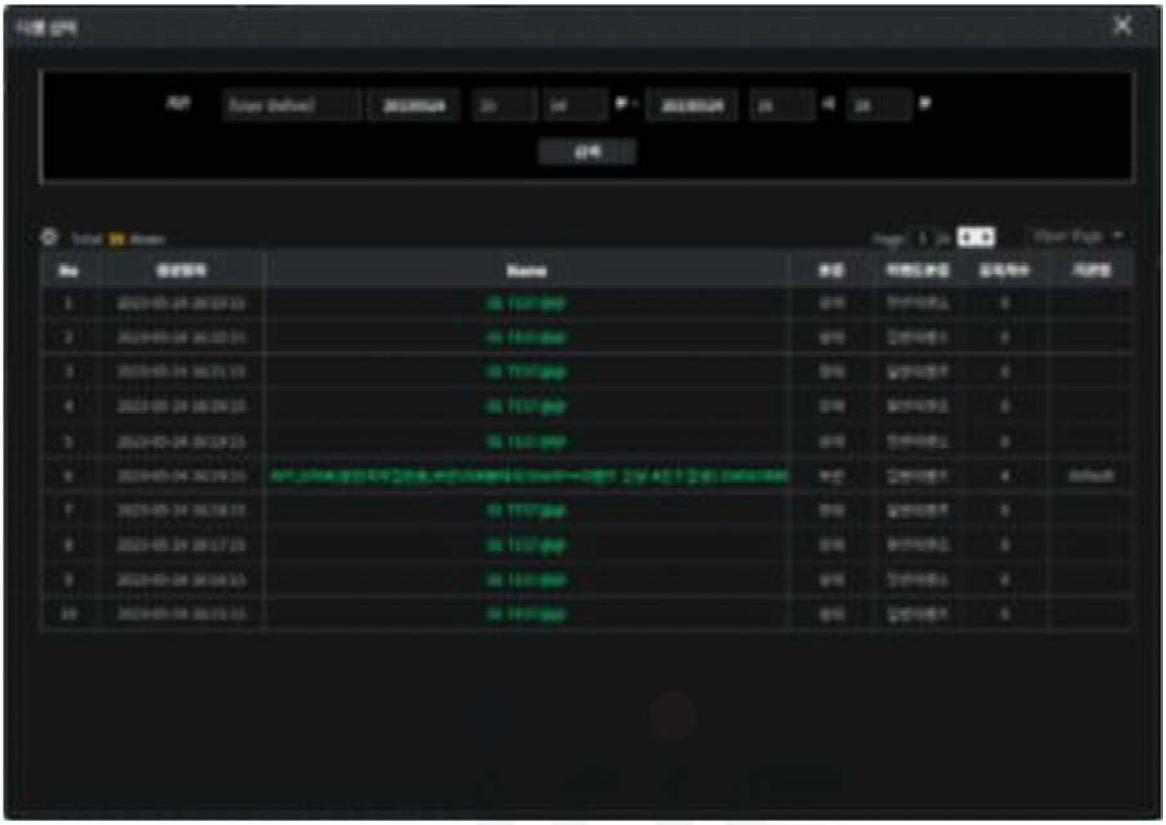


국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- 검증 데이터 정보

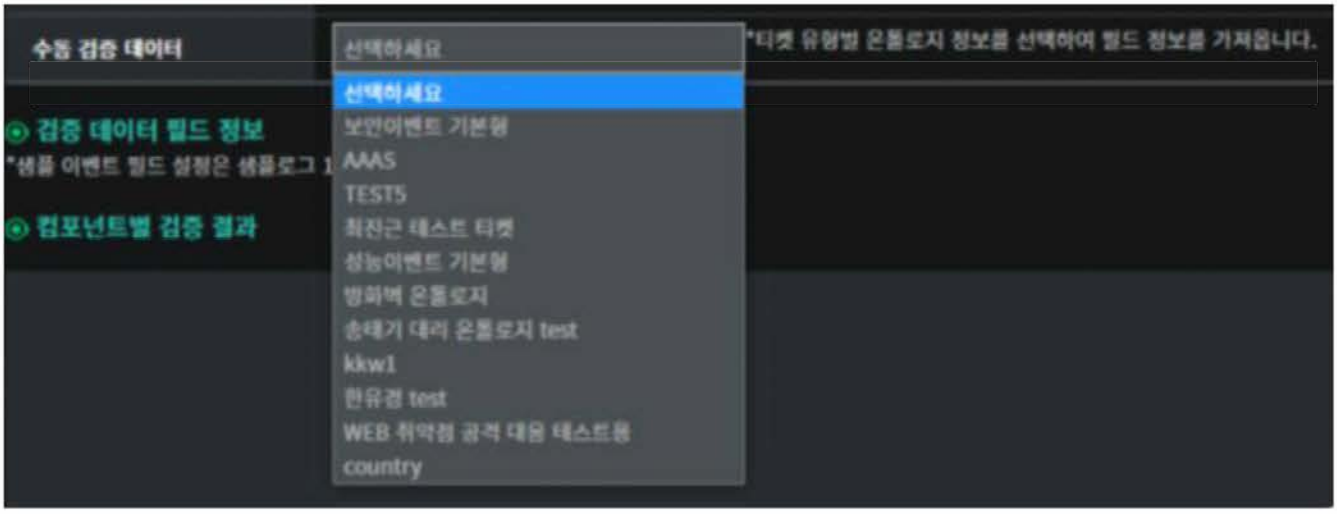
1) 자동 검증 데이터

- 실제 발생한 티켓을 선택하여 검증 데이터를 가져 올 수 있음



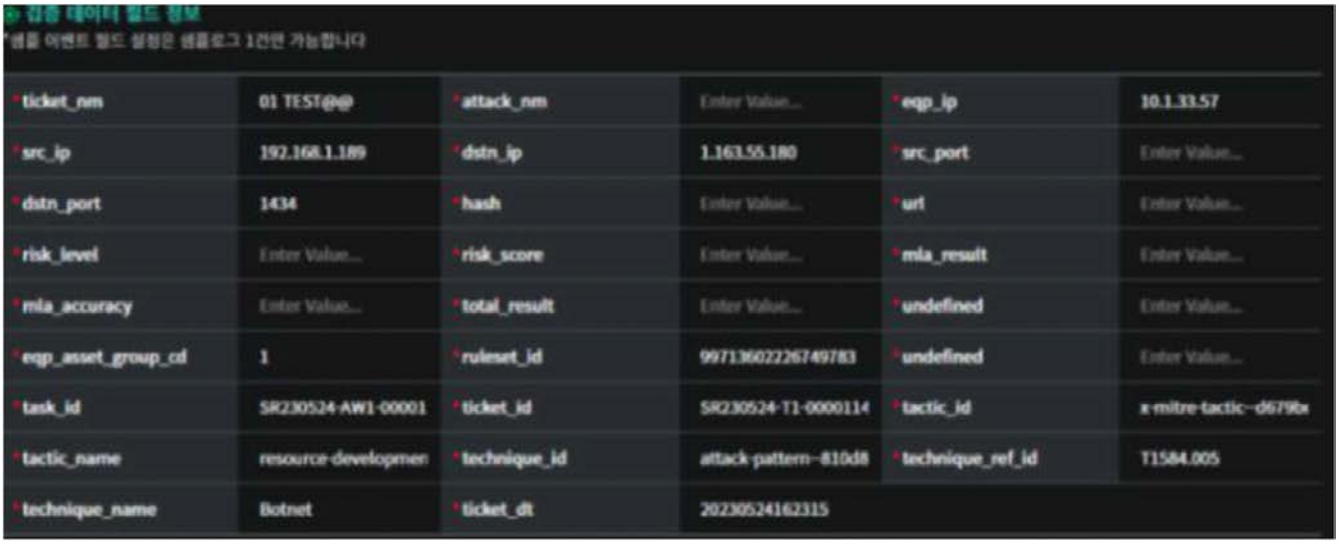
2) 수동 검증 데이터

- 티켓 유형별 온톨로지 정보를 선택하여 필드 정보를 가져 올 수 있음



- 검증 데이터 필드 정보
- 자동 검증 데이터로 실제 티켓 선택 시, 해당 티켓의 데이터 정보가 자동으로 출력
- 수동 검증 데이터로 온톨로지 정보 선택 시, 온톨로지 정보가 출력되고 해당 필드의 값을 사용자가 직접 입력 필요

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



- 검증 결과 확인

- 성공: 검증 pass 및 성공한 컴포넌트 개수
- 실패: 검증 실패한 컴포넌트 개수
- 주의: 검증 성공은 하였으나 설정 값에서 부족한 값이 있는 컴포넌트

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

세부 기술 ③ SOC 활용 시각화 기술 고도화 및 AI 기반 의사결정 검증 기술 개발

□ 연구 목표

o TTP 연관정보 및 플레이북 시각화 및 관리 기술 고도화

o 신속한 의사결정 지원을 위한 AI 모델 개발

o AI 모델에 의해 추천된 대응 정책의 관리 및 검증 기술 개발

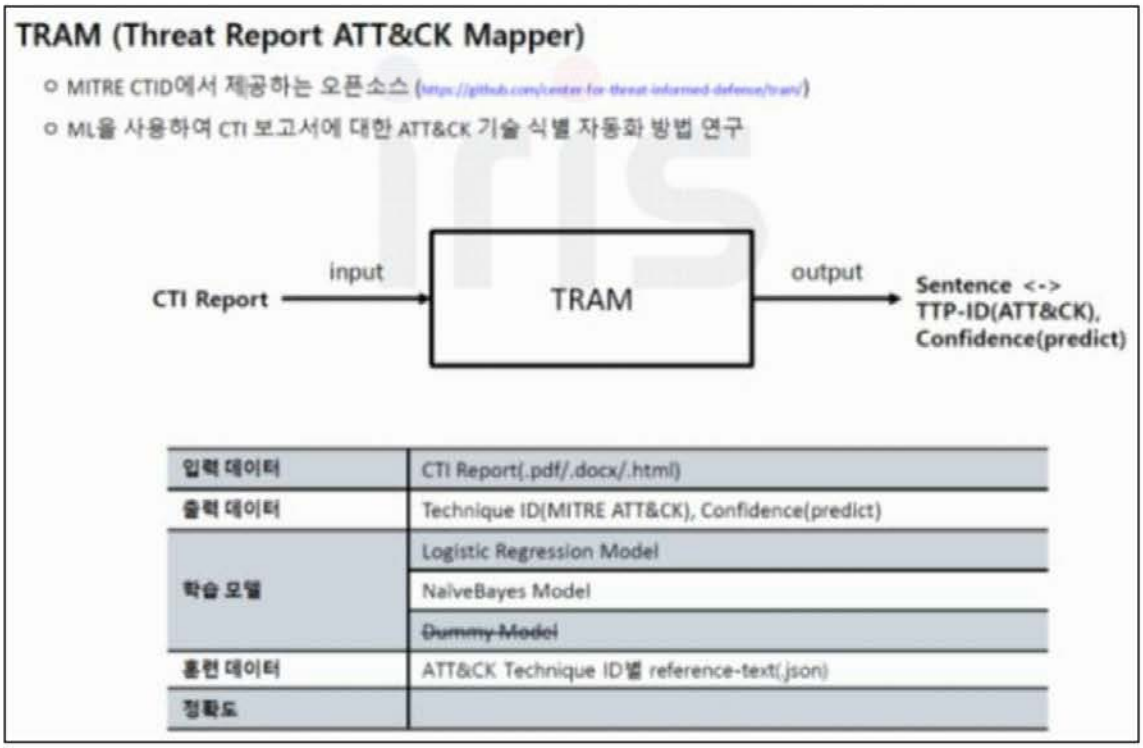
□ 연구 목표별 추진 실적

연구목표	TTP 연관정보 및 플레이북 시각화 및 관리 기술 고도화

세부 내용	1) 이기종 보안 장비 데이터 및 TTP 연관정보 가시화 기술 고도화
	2) 사용자 정의 기반 보안 관제 플레이북 생성 및 관리 도구 고도화
	3) 플레이북 요소 기술 실시간 수행 결과 시각화 도구 고도화

1) 이기종 보안 장비 데이터 및 TTP 연관정보 가시화 기술 고도화

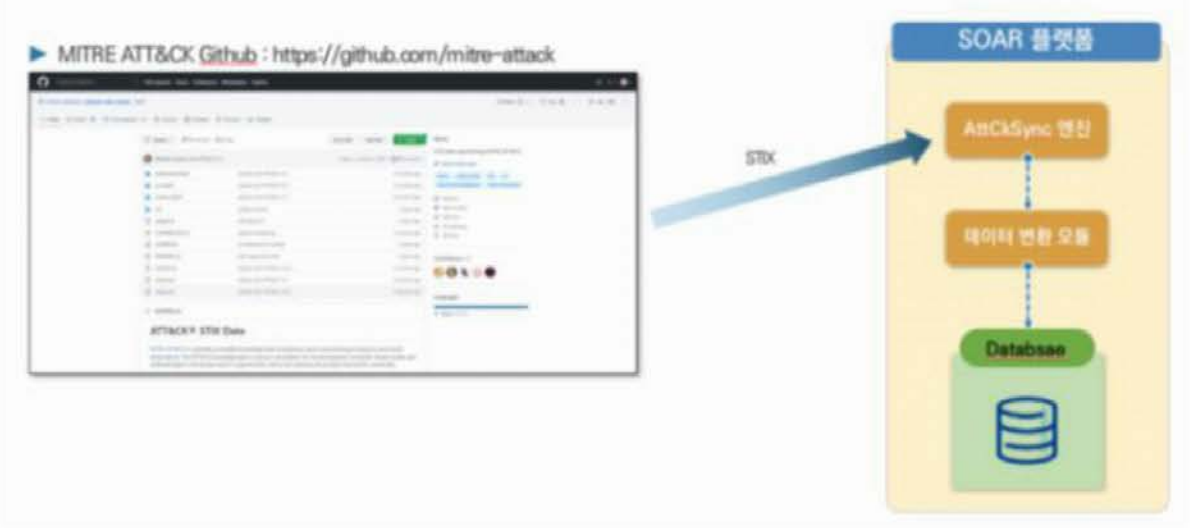
o TRAM(Threat Report ATT&CK Mapper) 기반 TTP 기반 위협 인자 식별 기술 구현



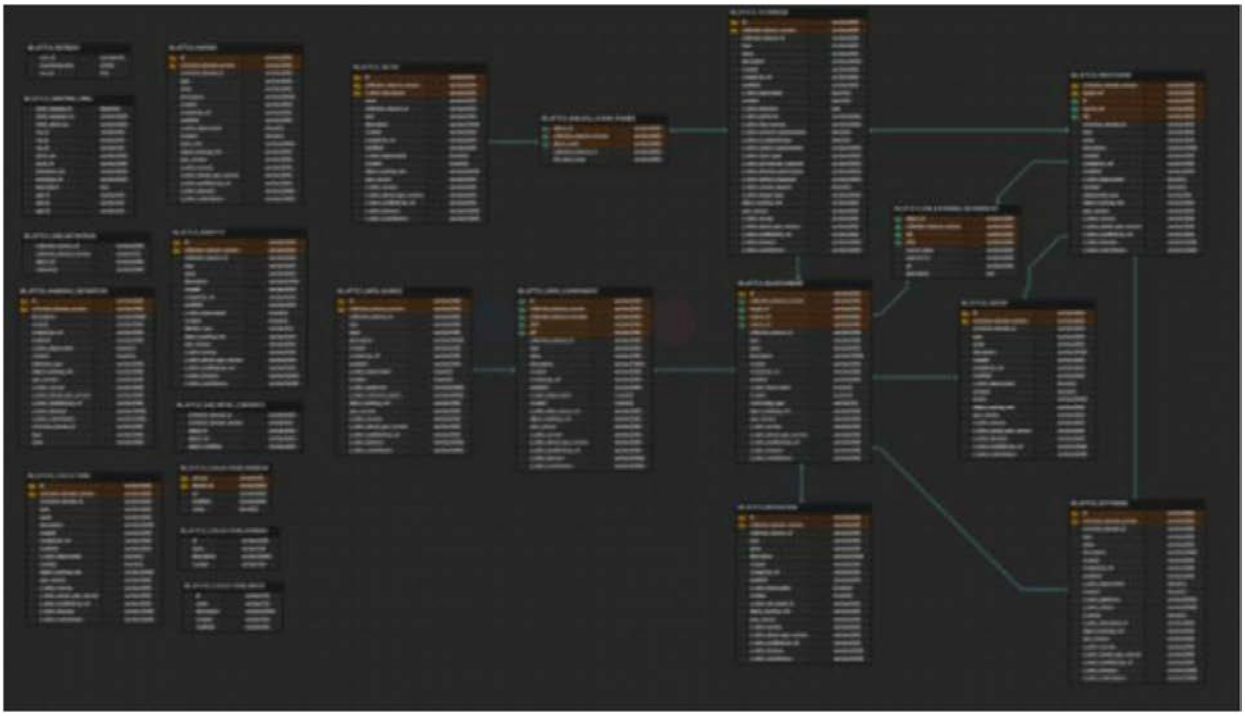
o MITRE ATT&CK 정보 수집 및 관리 기술 연구 및 구현

- 주기적 MITRE ATT&CK Matrix 정보 수집 AttCkSync 엔진 모듈 개발
- STIX 기반 데이터 정형화 기술 연구 및 개발

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



: MITRE ATT&CK Matrix 정보 RDBMS 기반 관리 스키마 설계



테이블 명	한글명	공격 전술	영문명	SR_ATTCK_TACTIC
개요	공격 전술 테이블			

컬럼	컬럼명	한글컬럼명	키유형	Null	Type
	collection_domain_id	컬렉션 도메인 ID		NN	varchar(200)
	collection_domain_version	컬렉션 도메인 버전	PK	NN	varchar(200)
	type	유형			varchar(200)
	id	ID	PK	NN	varchar(200)
	name	이름			varchar(200)
	description	설명			varchar(5000)
	created	생성일자			varchar(200)
	created_by_ref	생성일자 참조			varchar(200)
	modified	수정일자			varchar(200)

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

	x_mitre_deprecated	더 이상 사용되지 않는 마이터			tinyint(1)
	revoked	취소됨			tinyint(1)
	x_mitre_shortname	마이터 단축 이름			varchar(200)
	object_marking_refs	객체 마킹 참조			varchar(2000)
	spec_version	사양 버전			varchar(200)
	x_mitre_version	마이터 버전			varchar(200)
	x_mitre_attack_spec_version	마이터 공격 사양 버전			varchar(200)
	x_mitre_modified_by_ref	마이터 수정일자 참조			varchar(200)
	x_mitre_domains	마이터 도메인			varchar(1000)
	x_mitre_contributors	마이터 기여자			varchar(1000)
색인 ID	PRIMARY KEY (id, collection_domain_version)				

테이블 명	한글명	공격 기법	영문명	SR_ATTCK_TECHNIQUE	
개요	공격 기법 테이블				
컬럼	컬럼명	한글컬럼명	키유형	Null	Type
	collection_domain_id	컬렉션 도메인 ID		NN	varchar(200)
	collection_domain_version	컬렉션 도메인 버전	PK	NN	varchar(200)
	type	유형			varchar(200)
	id	ID	PK	NN	varchar(200)
	name	이름			varchar(200)
	description	설명			varchar(5000)
	created	생성일자			varchar(200)
	created_by_ref	생성일자 참조			varchar(200)
	modified	수정일자			varchar(200)
	x_mitre_deprecated	더 이상 사용되지 않는 마이터			tinyint(1)
	revoked	취소됨			tinyint(1)
	x_mitre_detection	마이터 감지			text
	x_mitre_platforms	마이터 플랫폼			varchar(1000)
	x_mitre_data_sources	마이터 데이터 소스			varchar(1000)
	x_mitre_network_requirements	마이터 네트워크 요구 사항			tinyint(1)
	x_mitre_is_subtechnique	마이터는 하위 기술이다			tinyint(1)
	x_mitre_system_requirements	마이터 시스템 요구 사항			varchar(1000)
	x_mitre_tactic_type	마이터 전술 유형			varchar(1000)
	x_mitre_permissions_required	마이터 권한 요청			varchar(1000)
	x_mitre_effective_permissions	마이터 유효 권한			varchar(1000)
	x_mitre_defense_bypassed	마이터 방어 우회			varchar(1000)
	x_mitre_remote_sup	마이터 원격 지원			tinyint(1)

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

	port				
	x_mitre_impact_type	마이터 충격 유형			varchar(1000)
	object_marking_refs	객체 마킹 참조			varchar(200)
	spec_version	사양 버전			varchar(200)
	x_mitre_version	마이터 버전			varchar(200)
	x_mitre_attack_spec_version	마이터 공격 사양 버전			varchar(200)
	x_mitre_modified_by_ref	마이터 수정일자 참조			varchar(200)
	x_mitre_domains	마이터 도메인			varchar(1000)
	x_mitre_contributors	마이터 기여자			varchar(1000)
색인 ID	PRIMARY KEY (id, collection_domain_version)				

테이블 명	한글명	외부 참조	영문명	SR_ATTCK_SUB_EXTERNAL_REFERENCES
개요	외부 참조 테이블			
컬럼	컬럼명	한글컬럼명	키유형	Null	Type
	collection_domain_id	컬렉션 도메인 ID		NN	varchar(200)
	collection_domain_version	컬렉션 도메인 버전		NN	varchar(10)
	object_id	객체 ID		NN	varchar(200)
	source_name	소스 이름			varchar(200)
	external_id	외부 ID			varchar(200)
	url	URL			varchar(500)
	description	설명			text

테이블 명	한글명	서브 마이터 콘텐츠	영문명	SR_ATTCK_SUB_MITRE_CONTENTS
개요	서브 마이터 콘텐츠 테이블			
컬럼	컬럼명	한글컬럼명	키유형	Null	Type
	collection_domain_id	컬렉션 도메인 ID		NN	varchar(200)
	collection_domain_version	컬렉션 도메인 버전		NN	varchar(10)
	object_id	객체 ID			varchar(200)
	object_ref	객체 참조		NN	varchar(200)
	object_modified	수정된 객체			varchar(200)

테이블 명	한글명	공격 아이덴티티	영문명	SR_ATTCK_IDENTITY
개요	공격 아이덴티티 테이블			
컬럼	컬럼명	한글컬럼명	키유형	Null	Type
	collection_domain_id	컬렉션 도메인 ID		NN	varchar(200)
	collection_domain_version	컬렉션 도메인 버전	PK	NN	varchar(200)
	type	유형			varchar(200)

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

	id	ID	PK	NN	varchar(200)
	name	이름			varchar(200)
	description	설명			varchar(5000)
	created	생성일자			varchar(200)
	created_by_ref	생성일자 참조			varchar(200)
	modified	수정일자			varchar(200)
	x_mitre_deprecated	더 이상 사용되지 않는 마이터			tinyint(1)
	revoked	취소됨			tinyint(1)
	identity_class	신원 클래스			varchar(50)
	object_marking_refs	객체 마킹 참조			varchar(200)
	spec_version	사양 버전			varchar(200)
	x_mitre_version	마이터 버전			varchar(200)
	x_mitre_attack_spec_version	마이터 공격 사양 버전			varchar(200)
	x_mitre_modified_by_ref	마이터 수정일자 참조			varchar(200)
	x_mitre_domains	마이터 도메인			varchar(1000)
	x_mitre_contributors	마이터 기여자			varchar(1000)
색인 ID	PRIMARY KEY (id, collection_domain_version)				

테이블 명	한글명	공격 그룹	영문명	SR_ATTCK_GROUP
개요	공격 그룹 테이블			

컬럼	컬럼명	한글컬럼명	키유형	Null	Type
	collection_domain_id	컬렉션 도메인 ID		NN	varchar(200)
	collection_domain_version	컬렉션 도메인 버전	PK	NN	varchar(200)
	type	유형			varchar(200)
	id	ID	PK	NN	varchar(200)
	name	이름			varchar(200)
	description	설명			varchar(5000)
	created	생성일자			varchar(200)
	created_by_ref	생성일자 참조			varchar(200)
	modified	수정일자			varchar(200)
	x_mitre_deprecated	더 이상 사용되지 않는 마이터			tinyint(1)
	revoked	취소됨			tinyint(1)
	aliases	별칭			varchar(2000)
	object_marking_refs	객체 마킹 참조			varchar(200)
	spec_version	사양 버전			varchar(200)
	x_mitre_version	마이터 버전			varchar(200)
	x_mitre_attack_spec_version	마이터 공격 사양 버전			varchar(200)
	x_mitre_domains	마이터 도메인			varchar(200)
	x_mitre_modified_by_ref	마이터 수정일자 참조			varchar(1000)
	x_mitre_contributors	마이터 기여자			varchar(1000)

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

색인 ID	PRIMARY KEY (id, collection_domain_version)

테이블 명	한글명	공격 매핑 관리	영문명	SR_ATTCK_MAPPING_MNG
개요	공격 매핑 관리 테이블			

컬럼	컬럼명	한글컬럼명	키유형	Null	Type
	attck_mapping_id	공격 매핑 ID	PK	NN	bigint(18)
	attck_mapping_nm	공격 매핑 명		NN	varchar(200)
	ticket_attck_nm	티켓 공격 명		NN	varchar(200)
	reg_id	등록 ID			varchar(40)
	reg_ip	등록 IP			varchar(39)
	reg_dt	등록 dt			varchar(14)
	tactic_nm	전술 명			varchar(200)
	tactic_id	전술 ID			varchar(200)
	technique_nm	기술 명			varchar(200)
	technique_id	기술 ID			varchar(200)
	description	설명			text
	upd_id	업데이트 아이디			varchar(40)
	upd_ip	IP 업데이트			varchar(39)
	upd_dt	업데이트 일자			varchar(14)
색인 ID	PRIMARY KEY (attck_mapping_id)				

테이블 명	한글명	공격 절차	영문명	SR_ATTCK_PROCEDURE
개요	공격 절차 테이블			

컬럼	컬럼명	한글컬럼명	키유형	Null	Type
	collection_domain_id	컬렉션 도메인 ID		NN	varchar(200)
	collection_domain_version	컬렉션 도메인 버전	PK	NN	varchar(200)
	type	유형			varchar(200)
	id	ID		NN	varchar(200)
	name	이름			varchar(200)
	description	설명			varchar(5000)
	created	생성일자			varchar(200)
	created_by_ref	생성일자 참조			varchar(200)
	modified	수정일자			varchar(200)
	x_mitre_deprecated	더 이상 사용되지 않는 마이터			tinyint(1)
	revoked	취소됨			tinyint(1)
	relationship_type	관계 유형			varchar(50)
	source_ref	소스 참조			varchar(100)
	target_ref	타겟 참조			varchar(100)
	object_marking_refs	객체 마킹 참조			varchar(200)
	spec_version	사양 버전			varchar(200)

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

	x_mitre_version	마이터 버전			varchar(200)
	x_mitre_attack_spec_version	마이터 공격 사양 버전			varchar(200)
	x_mitre_modified_by_ref	마이터 수정일자 참조			varchar(200)
	x_mitre_domains	마이터 도메인			varchar(1000)
	x_mitre_contributors	마이터 기여자			varchar(1000)
색인 ID	PRIMARY KEY (id, collection_domain_version)				

테이블 명	한글명	공격 수집 인덱스	영문명	SR_ATTCK_COLLECTION_INDEX	
개요	공격 수집 인덱스 테이블				
컬럼	컬럼명	한글컬럼명	키유형	Null	Type
	id	ID	PK	NN	varchar(50)
	name	이름			varchar(50)
	description	설명			varchar(2000)
	created	생성일자			varchar(50)
	modified	수정일자			varchar(50)
색인 ID	PRIMARY KEY (id)				

테이블 명	한글명	공격 수집 도메인	영문명	SR_ATTCK_COLLECTION_DOMAIN	
개요	공격 수집 도메인 테이블				
컬럼	컬럼명	한글컬럼명	키유형	Null	Type
	id	ID	PK	NN	varchar(100)
	name	이름			varchar(50)
	description	설명			varchar(2000)
	created	생성일자			varchar(50)
색인 ID	PRIMARY KEY (id)				

테이블 명	한글명	공격 수집 버전	영문명	SR_ATTCK_COLLECTION_VERSION	
개요	공격 수집 버전 테이블				
컬럼	컬럼명	한글컬럼명	키유형	Null	Type
	domain_id	도메인_ID	PK	NN	varchar(100)
	version	버전	PK	NN	varchar(50)
	url	URL		NN	varchar(200)
	modified	수정일자		NN	varchar(200)
	status	상태		NN	tinyint(1)
색인 ID	PRIMARY KEY (domain_id, version)				

테이블 명	한글명	공격 데이터 소스	영문	SR_ATTCK_DATA_SOURCE

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

			명	
개요	공격 데이터 소스 테이블			
컬럼	컬럼명	한글컬럼명	키 유형	Null	Type
	collection_domain_id	컬렉션 도메인 ID		NN	varchar(200)
	collection_domain_version	컬렉션 도메인 버전	PK	NN	varchar(200)
	type	유형			varchar(200)
	id	ID	PK	NN	varchar(200)
	name	이름			varchar(200)
	description	설명			varchar(5000)
	created	생성일자			varchar(200)
	created_by_ref	생성일자 참조			varchar(200)
	modified	수정일자			varchar(200)
	x_mitre_deprecated	더 이상 사용되지 않는 마이터			tinyint(1)
	revoked	취소됨			tinyint(1)
	x_mitre_platforms	마이터 플랫폼			varchar(2000)
	x_mitre_collection_layers	마이터 컬렉션 레이어			varchar(2000)
	object_marking_refs	객체 마킹 참조			varchar(200)
	spec_version	사양 버전			varchar(200)
	x_mitre_version	마이터 버전			varchar(200)
	x_mitre_attack_spec_version	마이터 공격 사양 버전			varchar(200)
	x_mitre_modified_by_ref	마이터 수정일자 참조			varchar(200)
	x_mitre_domains	마이터 도메인			varchar(1000)
	x_mitre_contributors	마이터 기여자			varchar(1000)
색인 ID	PRIMARY KEY (id, collection_domain_version)				

테이블 명	한글명	공격 데이터 컴포넌트	영문명	SR_ATTCK_DATA_COMPONENT
개요	공격 데이터 컴포넌트 테이블			
컬럼	컬럼명	한글컬럼명	키 유형	Null	Type
	collection_domain_id	컬렉션 도메인 ID		NN	varchar(200)
	collection_domain_version	컬렉션 도메인 버전	PK	NN	varchar(200)
	type	유형			varchar(200)
	id	ID	PK	NN	varchar(200)
	name	이름			varchar(200)
	description	설명			varchar(5000)
	created	생성일자			varchar(200)
	created_by_ref	생성일자 참조			varchar(200)
	modified	수정일자			varchar(200)
	x_mitre_deprecated	더 이상 사용되지 않는 마이터			tinyint(1)
	revoked	취소됨			tinyint(1)

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

	x_mitre_data_source_ref	마이터 데이터 소스 참조			varchar(200)
	object_marking_refs	객체 마킹 참조			varchar(200)
	spec_version	사양 버전			varchar(200)
	x_mitre_version	마이터 버전			varchar(200)
	x_mitre_attack_spec_version	마이터 공격 사양 버전			varchar(200)
	x_mitre_modified_by_ref	마이터 수정일자 참조			varchar(200)
	x_mitre_domains	마이터 도메인			varchar(1000)
	x_mitre_contributors	마이터 기여자			varchar(1000)
색인 ID	PRIMARY KEY (id, collection_domain_version)				

테이블 명	한글명	공격 매트릭스	영문명	SR_ATTCK_MATRIX
개요	공격 매트릭스 테이블			

컬럼	컬럼명	한글컬럼명	키유형	Null	Type
	collection_domain_id	컬렉션 도메인 ID		NN	varchar(200)
	collection_domain_version	컬렉션 도메인 버전	PK	NN	varchar(200)
	type	유형			varchar(200)
	id	ID	PK	NN	varchar(200)
	name	이름			varchar(200)
	description	설명			varchar(5000)
	created	생성일자			varchar(200)
	created_by_ref	생성일자 참조			varchar(200)
	modified	수정일자			varchar(200)
	x_mitre_deprecated	더 이상 사용되지 않는 마이터			tinyint(1)
	revoked	취소됨			tinyint(1)
	tactic_refs	전술 심판			varchar(2000)
	object_marking_refs	객체 마킹 참조			varchar(200)
	spec_version	사양 버전			varchar(200)
	x_mitre_version	마이터 버전			varchar(200)
	x_mitre_attack_spec_version	마이터 공격 사양 버전			varchar(200)
	x_mitre_modified_by_ref	마이터 수정일자 참조			varchar(200)
	x_mitre_domains	마이터 도메인			varchar(1000)
	x_mitre_contributors	마이터 기여자			varchar(1000)
색인 ID	PRIMARY KEY (id, collection_domain_version)				

테이블 명	한글명	공격 완화	영문명	SR_ATTCK_MITIGATION
개요	공격 완화 테이블			

컬럼	컬럼명	한글컬럼명	키유형	Null	Type

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

	collection_domain_id	컬렉션 도메인 ID		NN	varchar(200)
	collection_domain_version	컬렉션 도메인 버전	PK	NN	varchar(200)
	type	유형			varchar(200)
	id	ID	PK	NN	varchar(200)
	name	이름			varchar(200)
	description	설명			varchar(5000)
	created	생성일자			varchar(200)
	created_by_ref	생성일자 참조			varchar(200)
	modified	수정일자			varchar(200)
	x_mitre_deprecated	더 이상 사용되지 않는 마이터			tinyint(1)
	revoked	취소됨			tinyint(1)
	x_mitre_old_attack_id	마이터 이전 공격 ID			varchar(200)
	object_marking_refs	객체 마킹 참조			varchar(200)
	spec_version	사양 버전			varchar(200)
	x_mitre_version	마이터 버전			varchar(200)
	x_mitre_attack_spec_version	마이터 공격 사양 버전			varchar(200)
	x_mitre_modified_by_ref	마이터 수정일자 참조			varchar(200)
	x_mitre_domains	마이터 도메인			varchar(1000)
	x_mitre_contributors	마이터 기여자			varchar(1000)
색인 ID	PRIMARY KEY (id, collection_domain_version)				

테이블 명	한글명	공격 표시 정의	영문명	SR_ATTCK_MARKING_DEFINITION
개요	공격 표시 정의 테이블			
컬럼	컬럼명	한글컬럼명	키유형	Null	Type
	collection_domain_id	컬렉션 도메인 ID		NN	varchar(200)
	collection_domain_version	컬렉션 도메인 버전	PK	NN	varchar(200)
	type	유형			varchar(200)
	id	ID	PK	NN	varchar(200)
	name	이름			varchar(200)
	description	설명			varchar(5000)
	created	생성일자			varchar(200)
	created_by_ref	생성일자 참조			varchar(200)
	modified	수정일자			varchar(200)
	x_mitre_deprecated	더 이상 사용되지 않는 마이터			tinyint(1)
	revoked	취소됨			tinyint(1)
	definition_type	정의 유형			varchar(200)
	object_marking_refs	객체 마킹 참조			varchar(200)
	spec_version	사양 버전			varchar(200)
	x_mitre_version	마이터 버전			varchar(200)
	x_mitre_attack_spec	마이터 공격 사양			varchar(200)

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

	_version	버전			
	x_mitre_modified_by_ref	마이터 수정일자 참조			varchar(200)
	x_mitre_domains	마이터 도메인			varchar(1000)
	x_mitre_contributors	마이터 기여자			varchar(1000)
색인 ID	PRIMARY KEY (id, collection_domain_version)				

테이블 명	한글명	공격 수집	영문명	SR_ATTCK_COLLECTION
개요	공격 수집 테이블			

컬럼	컬럼명	한글컬럼명	키유형	Null	Type
	collection_domain_id	컬렉션 도메인 ID		NN	varchar(200)
	collection_domain_version	컬렉션 도메인 버전	PK	NN	varchar(200)
	type	유형			varchar(200)
	id	ID	PK	NN	varchar(200)
	name	이름			varchar(200)
	description	설명			varchar(5000)
	created	생성일자			varchar(200)
	created_by_ref	생성일자 참조			varchar(200)
	modified	수정일자			varchar(200)
	x_mitre_deprecated	더 이상 사용되지 않는 마이터			tinyint(1)
	revoked	취소됨			tinyint(1)
	object_marking_refs	객체 마킹 참조			varchar(2000)
	spec_version	사양 버전			varchar(200)
	x_mitre_version	마이터 버전			varchar(200)
	x_mitre_attack_spec_version	마이터 공격 사양 버전			varchar(200)
	x_mitre_modified_by_ref	마이터 수정일자 참조			varchar(200)
	x_mitre_domains	마이터 도메인			varchar(1000)
	x_mitre_contributors	마이터 기여자			varchar(1000)
색인 ID	PRIMARY KEY (id, collection_domain_version)				

테이블 명	한글명	공격 하위 킬 체인 단계	영문명	SR_ATTCK_SUB_KILL_CHAIN_PHASES
개요	공격 하위 킬 체인 단계 테이블			

컬럼	컬럼명	한글컬럼명	키유형	Null	Type
	collection_domain_id	컬렉션 도메인 ID		NN	varchar(200)
	collection_domain_version	컬렉션 도메인 버전		NN	varchar(10)
	object_id	객체 ID		NN	varchar(200)
	kill_chain_name	킬 체인 이름			varchar(200)
	phase_name	단계 이름			varchar(200)

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

테이블 명	한글명	공격 하위 정의	영문명	SR_ATTCK_SUB_DEFINITION
개요	공격 하위 정의 테이블			

컬럼	컬럼명	한글컬럼명	키유형	Null	Type
	collection_domain_id	컬렉션 도메인 ID		NN	varchar(200)
	collection_domain_version	컬렉션 도메인 버전		NN	varchar(10)
	object_id	객체 ID			varchar(200)
	statement	설명			varchar(200)

테이블 명	한글명	공격 소프트웨어	영문명	SR_ATTCK_SOFTWARE
개요	공격 소프트웨어 테이블			

컬럼	컬럼명	한글컬럼명	키유형	Null	Type
	collection_domain_id	컬렉션 도메인 ID		NN	varchar(200)
	collection_domain_version	컬렉션 도메인 버전	PK	NN	varchar(200)
	type	유형			varchar(200)
	id	ID	PK	NN	varchar(200)
	name	이름			varchar(200)
	description	설명			varchar(5000)
	created	생성일자			varchar(200)
	created_by_ref	생성일자 참조			varchar(200)
	modified	수정일자			varchar(200)
	x_mitre_deprecated	더 이상 사용되지 않는 마이터			tinyint(1)
	revoked	취소됨			tinyint(1)
	x_mitre_platforms	마이터 플랫폼			varchar(2000)
	x_mitre_aliases	마이터 별칭			varchar(2000)
	is_family	가족이에요			tinyint(1)
	x_mitre_old_attack_id	마이터 이전 공격 ID			varchar(200)
	object_marking_refs	객체 마킹 참조			varchar(200)
	spec_version	사양 버전			varchar(200)
	x_mitre_version	마이터 버전			varchar(200)
	x_mitre_attack_spec_version	마이터 공격 사양 버전			varchar(200)
	x_mitre_modified_by_ref	마이터 수정일자 참조			varchar(200)
	x_mitre_domains	마이터 도메인			varchar(1000)
	x_mitre_contributors	마이터 기여자			varchar(1000)
색인 ID	PRIMARY KEY (id, collection_domain_version)				

테이블 명	한글명	공격 관계	영문명	SR_ATTCK_RELATIONSHIP
개요	공격 관계 테이블			

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

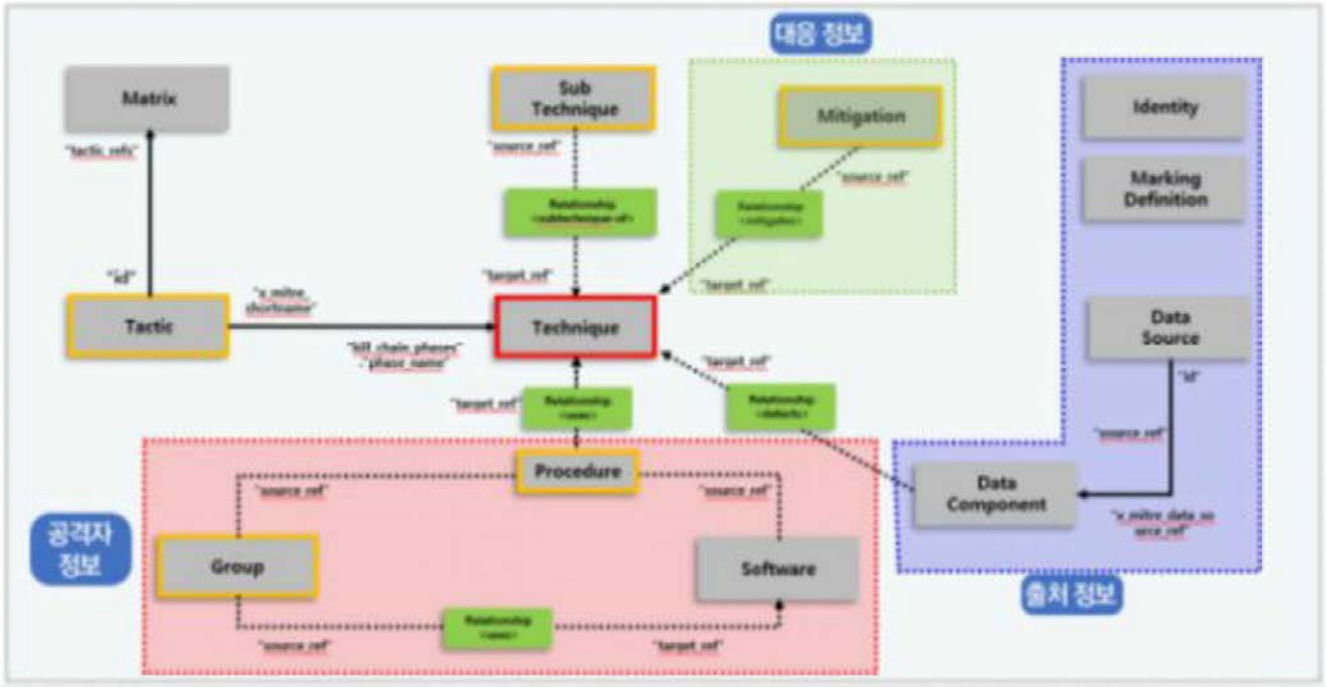
	컬럼명	한글컬럼명	키유형	Null	Type
컬럼	collection_domain_id	컬렉션 도메인 ID		NN	varchar(200)
	collection_domain_version	컬렉션 도메인 버전	PK	NN	varchar(200)
	type	유형			varchar(200)
	id	ID	PK	NN	varchar(200)
	name	이름			varchar(200)
	description	설명			varchar(5000
	created	생성일자			varchar(200)
	created_by_ref	생성일자 참조			varchar(200)
	modified	수정일자			varchar(200)
	x_mitre_deprecated	더 이상 사용되지 않는 마이터			tinyint(1)
	revoked	취소됨			tinyint(1)
	relationship_type	관계 유형			varchar(50)
	source_ref	소스 참조			varchar(100)
	target_ref	타겟 참조			varchar(100)
	object_marking_refs	객체 마킹 참조			varchar(200)
	spec_version	사양 버전			varchar(200)
	x_mitre_version	마이터 버전			varchar(200)
	x_mitre_attack_spec_version	마이터 공격 사양 버전			varchar(200)
	x_mitre_modified_by_ref	마이터 수정일자 참조			varchar(200)
	x_mitre_domains	마이터 도메인			varchar(200)
	x_mitre_contributors	마이터 기여자			varchar(200)
색인 ID	PRIMARY KEY (id, collection_domain_version)				

테이블 명	한글명	공격 새로고침	영문명	SR_ATTCK_REFRESH
개요	공격 모니터링 주기 설정 테이블			

	컬럼명	한글컬럼명	키유형	Null	Type
컬럼	user_id	유저id			VARCHAR(14)
	monitoring_time	모니터링주기			INTEGER(10)
	use_yn	사용여부			CHAR

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- MITRE ATT&CK Matrix 데이터 구조/관계 연구 및 설계



- MITRE ATT&CK 구조체 연구 및 분석

Matrix

- 공격 기술인 Tactic, Technique 개념과 관계를 시각화
- Tactic 에는 다양한 Technique 가 포함

Tactics

- 공격 목표에 따른 공격자의 행동을 나타냄
- 지속성, 탐색, 실행, 추출 등 공격자의 목적에 따라 분류

Techniques

- 공격자의 Tactic 달성하기 위한 방법을 나타냄
- Technique 을 사용함으로써 발생하는 결과/피해를 명시

공격 내용	Tactics	Technique ID
웹사이트 방문자 악성코드 감염	TA0042 Resource Development	T1608.004
DGA를 통한 C&C 연결	TA0011 Command and Control	T1568.002
배치 파일(.bat, .cmd) 실행 명령	TA0002 Execution	T1059.003
호스트 특정 위치의 파일 시스템 내의 특정 정보를 검색	TA0007 Discovery	T1083
시스템 네트워크 구성 검색	TA0007 Discovery	T1016
사용자 계정 제어 우회 위한 권한상승	TA0004 Privilege Escalation	T1548.002
원격 시스템 검색(Ping, net view 등)	TA0007 Discovery	T1018
SSH(Secure Shell)를 사용하여 원격 시스템에 로그인	TA0008 Lateral Movement	T1021.004
ftp 등의 프로토콜을 사용해 악성코드 배포	TA0011 Command and Control	T1105
PowerShell 명령 및 스크립팅 실행(난독화, 암호화 포함)	TA0002 Execution	T1059.001
수집된 데이터를 유출 전에 로컬 시스템 특정 위치에 보관	TA0009 Collection	T1074.001
C2 채널을 통한 유출	TA0010 Exfiltration	T1041

Mitigations

- 방어자(관리자)가 공격을 예방하고 탐지하기 위해 취할 수 있는 행동을 말함
- 보안의 목적과 시스템 상황에 따라 중복으로 Mitigation 을 적용할 수 있음

Groups

- 공개적으로 명칭이 부여된 해킹조직에 대한 정보와 공격 기법을 분석 정리
- 주로 사용된 공격 방법과 활동에 대한 분석 바탕으로 그룹을 특정하여 정의함
- 새로운 공격이 발생했을 경우 Matrix 를 활용하여 매핑 표와 비교 가능

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- MITRE ATT&CK Matrix Object 구조 연구 및 분석

< Matrix, type : `x-mitre-matrix` >


```
{
    "tactic_refs": [
        "x-mitre-tactic--daa0c301-bbf4-4721-a824-7f1ef89e4592",
        "x-mitre-tactic--8670cca2-e17d-4035-8050-8031c87a4480",
        "x-mitre-tactic--ffd5bcee-6e16-4dd2-8eca-7b3beedf33ca",
        "x-mitre-tactic--4ca45d45-df4d-4613-8980-bac22d278f45",
        "x-mitre-tactic--9bc1d813-693e-4823-9961-ab0bef4bda92",
        "x-mitre-tactic--5a250d91-294e-49e9-a803-dab3d73b7fd8",
        "x-mitre-tactic--78b23412-0651-4b27-a140-178a1ce8bd5a",
        "x-mitre-tactic--2558fd65-8c75-4730-94c4-11f26db1a2b3",
        "x-mitre-tactic--c17c5845-175e-4421-9713-829d0573dbc9",
        "x-mitre-tactic--7141578b-e50b-4dcc-bfa4-08a6b068ede4",
        "x-mitre-tactic--d108ce10-2419-4cf9-a774-47d1c1d6c5cf4",
        "x-mitre-tactic--f72804c5-f15a-449e-a5da-2eecd181f813",
        "x-mitre-tactic--9ada74db-3905-405c-96bf-a18dfbc5346d",
        "x-mitre-tactic--5569339b-94c2-49ee-afb3-2222936582c8"
    ],
    "object_marking_refs": [
        "marking-definition--fa42a846-8d90-4e51-bc29-71d5b4802168"
    ],
    "id": "x-mitre-matrix--eafc1b4c-5e56-4965-b364-ec6a0d8c8961",
    "type": "x-mitre-matrix",
    "created": "2018-10-17T00:14:20.652Z",
    "created_by_ref": "identity--c78cb6e5-0c4b-4611-8297-d1b8b55e40b5",
    "external_references": [
        {
            "external_id": "enterprise-attack",
            "source_name": "mitre-attack",
            "url": "https://attack.mitre.org/matrices/enterprise"
        }
    ],
    "modified": "2022-04-01T20:41:55.937Z",
    "name": "Enterprise ATT&CK",
    "description": "Below are the tactics and technique representing the MITRE ATT&CK Matrix for Enterprise. The Matrix contains information for the fo
llowing platforms: Windows, macOS, Linux, AWS, GCP, Azure, Azure AD, Office 365, SaaS.",
    "x_mitre_version": "1.0",
    "x_mitre_attack_spec_version": "2.1.0",
    "x_mitre_modified_by_ref": "identity--c78cb6e5-0c4b-4611-8297-d1b8b55e40b5",
    "spec_version": "2.1",
    "x_mitre_domains": [
        "enterprise-attack"
    ]
}
```


- MITRE ATT&CK Tactic Object 구조 연구 및 분석

< Tactic, Type : `x-mitre-tactic` >


```
{
    "x_mitre_domains": [
        "enterprise-attack"
    ],
    "object_marking_refs": [
        "marking-definition--fa42a846-8d90-4e51-bc29-71d5b4802168"
    ],
    "id": "x-mitre-tactic--ffd5bcee-6e16-4dd2-8eca-7b3beedf33ca",
    "type": "x-mitre-tactic",
    "created": "2018-10-17T00:14:20.652Z",
    "created_by_ref": "identity--c78cb6e5-0c4b-4611-8297-d1b8b55e40b5",
    "external_references": [
        {
            "external_id": "TA0001",
            "url": "https://attack.mitre.org/tactics/TA0001",
            "source_name": "mitre-attack"
        }
    ],
    "modified": "2022-04-25T14:08:08.586Z",
    "name": "Initial Access",
    "description": "The adversary is trying to get into your network.\n\nInitial Access consists of techniques that use various entry vectors to gain t
heir initial foothold within a network. Techniques used to gain a foothold include targeted spearphishing and exploiting weaknesses on public-facing we
b servers. Footholds gained through initial access may allow for continued access, like valid accounts and use of external remote services, or may be l
imited-use due to changing passwords.",
    "x_mitre_version": "1.0",
    "x_mitre_attack_spec_version": "2.1.0",
    "x_mitre_modified_by_ref": "identity--c78cb6e5-0c4b-4611-8297-d1b8b55e40b5",
    "x_mitre_shortname": "initial-access",
    "spec_version": "2.1"
}
```

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

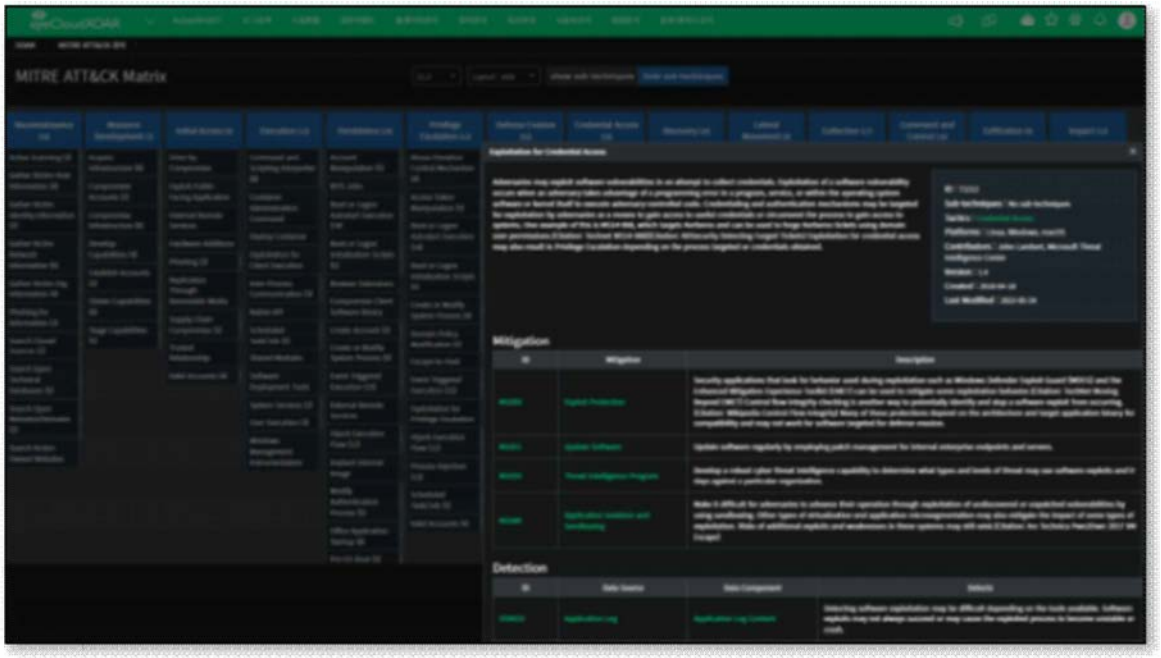
- MITRE ATT&CK Technique Object 구조 연구 및 분석

< Technique. Type : attack-pattern >

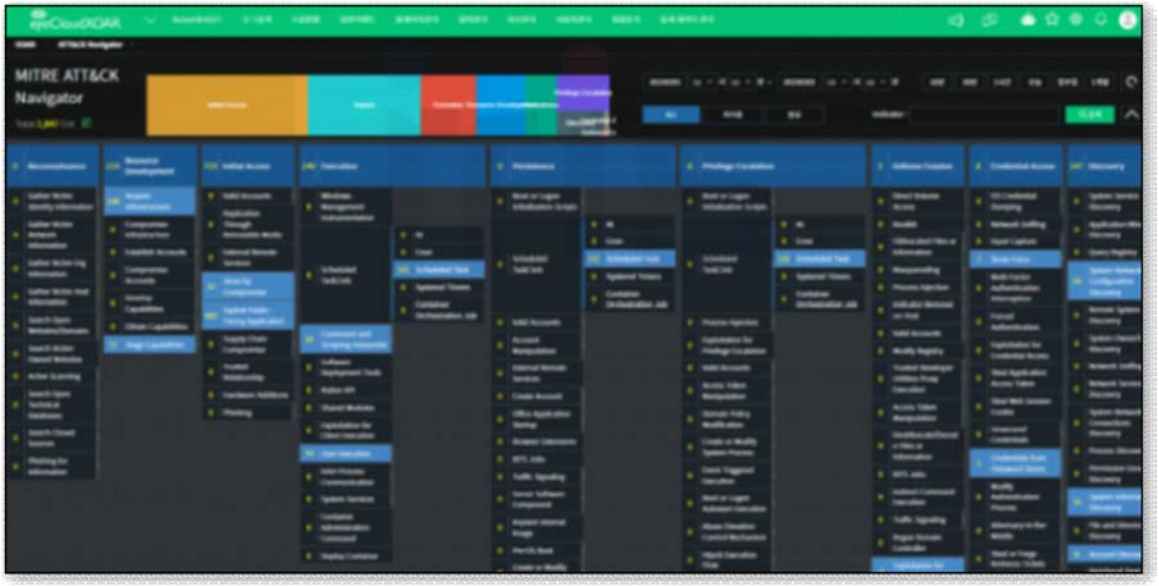

```
{
    "x_mitre_platforms": [
        "Linux",
        "macOS",
        "Windows",
        "SaaS",
        "Office 365",
        "Google Workspace"
    ],
    "x_mitre_domains": [
        "enterprise-attack"
    ],
    "x_mitre_contributors": [
        "Philip Winther"
    ],
    "object_marking_refs": [
        "marking-definition--fa42a846-8d90-4e51-bc29-71d5b4802168"
    ],
    "id": "attack-pattern--ad2a8d5-f23e-4d8f-af08-5dbc77e7813b",
    "type": "attack-pattern",
    "created": "2020-01-02T18:45:07.892Z",
    "created_by_ref": "identity--c78cb6e5-0c4b-4611-8297-d1b8b55e40b5",
    "external_references": [
        {
            "source_name": "mitre-attack",
            "external_id": "T1566",
            "url": "https://attack.mitre.org/techniques/T1566"
        },
        {
            "external_id": "CAPEC-98",
            "source_name": "capec",
            "url": "https://capec.mitre.org/data/definitions/98.html"
        },
        {
            "source_name": "Microsoft Anti Spoofing",
            "url": "https://docs.microsoft.com/en-us/microsoft-365/security/office-365-security/anti-spoofing-protection?view=o365-worldwide",
            "description": "Microsoft. (2020, October 13). Anti-spoofing protection in EOP. Retrieved October 19, 2020."
        },
        {
            "source_name": "ACSC Email Spoofing",
            "url": "https://www.cyber.gov.au/sites/default/files/2019-01/spoof_email_sender_policy_framework.pdf",
            "description": "Australian Cyber Security Centre. (2012, December). Mitigating Spoofed Emails Using Sender Policy Framework. Retrieved Octo
ber 19, 2020."
        }
    ],
    "modified": "2021-05-11T14:00:00.186Z",
    "name": "Phishing",
    "description": "Adversaries may send phishing messages to gain access to victim systems. All forms of phishing are electronically delivered social
engineering. Phishing can be targeted, known as spearphishing. In spearphishing, a specific individual, company, or industry will be targeted by the ad
versary. More generally, adversaries can conduct non-targeted phishing, such as in mass malware spam campaigns.\r\nAdversaries may send victims emails
containing malicious attachments or links, typically to execute malicious code on victim systems. Phishing may also be conducted via third-party servic
es, like social media platforms. Phishing may also involve social engineering techniques, such as posing as a trusted source.",
    "kill_chain_phases": [
        {
            "kill_chain_name": "mitre-attack",
            "phase_name": "initial-access"
        }
    ],
    "x_mitre_detection": "Network intrusion detection systems and email gateways can be used to detect phishing with malicious attachments in transit.
Detonation chambers may also be used to identify malicious attachments. Solutions can be signature and behavior based, but adversaries may construct at
tachments in a way to avoid these systems.\r\nFiltering based on DKIM+SPF or header analysis can help detect when the email sender is spoofed.(Citatio
n: Microsoft Anti Spoofing)(Citation: ACSC Email Spoofing)\r\nURL inspection within email (including expanding shortened links) can help detect links l
eading to known malicious sites. Detonation chambers can be used to detect these links and either automatically go to these sites to determine if the
y're potentially malicious, or wait and capture the content if a user visits the link.\r\nBecause most common third-party services used for phishing vi
a service leverage TLS encryption, SSL/TLS inspection is generally required to detect the initial communication/delivery. With SSL/TLS inspection intru
sion detection signatures or other security gateway appliances may be able to detect malware.\r\nAnti-virus can potentially detect malicious documents
and files that are downloaded to the user's computer. Many possible detections of follow-on behavior may take place once [User Execution](https://attac
k.mitre.org/techniques/T1204) occurs.",
    "x_mitre_version": "1.2",
    "x_mitre_modified_by_ref": "identity--c78cb6e5-0c4b-4611-8297-d1b8b55e40b5",
    "x_mitre_data_sources": [
        "File: File Creation",
        "Application Log: Application Log Content",
        "Network Traffic: Network Traffic Content",
        "Network Traffic: Network Traffic Flow"
    ],
    "spec_version": "2.1",
    "x_mitre_attack_spec_version": "2.1.0"
}
```

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

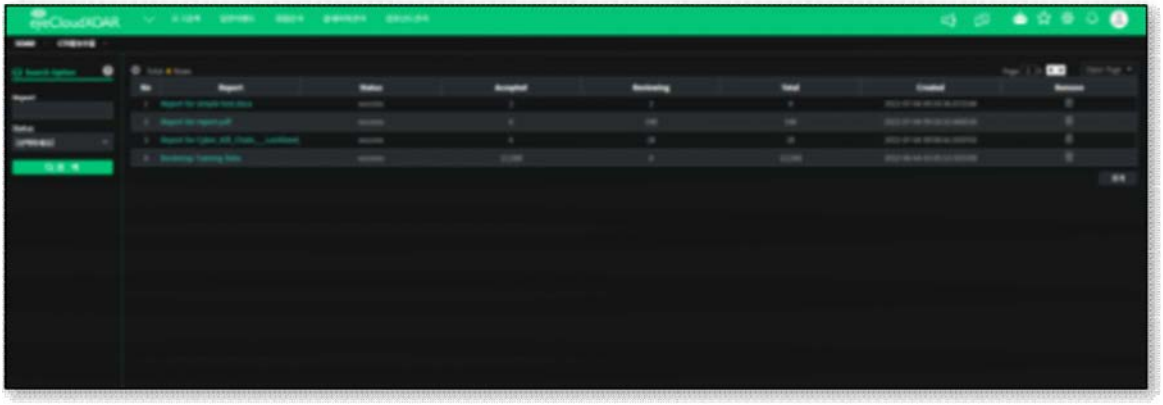
- MITRE ATT&CK Matrix 관리 가시화 기술 구현



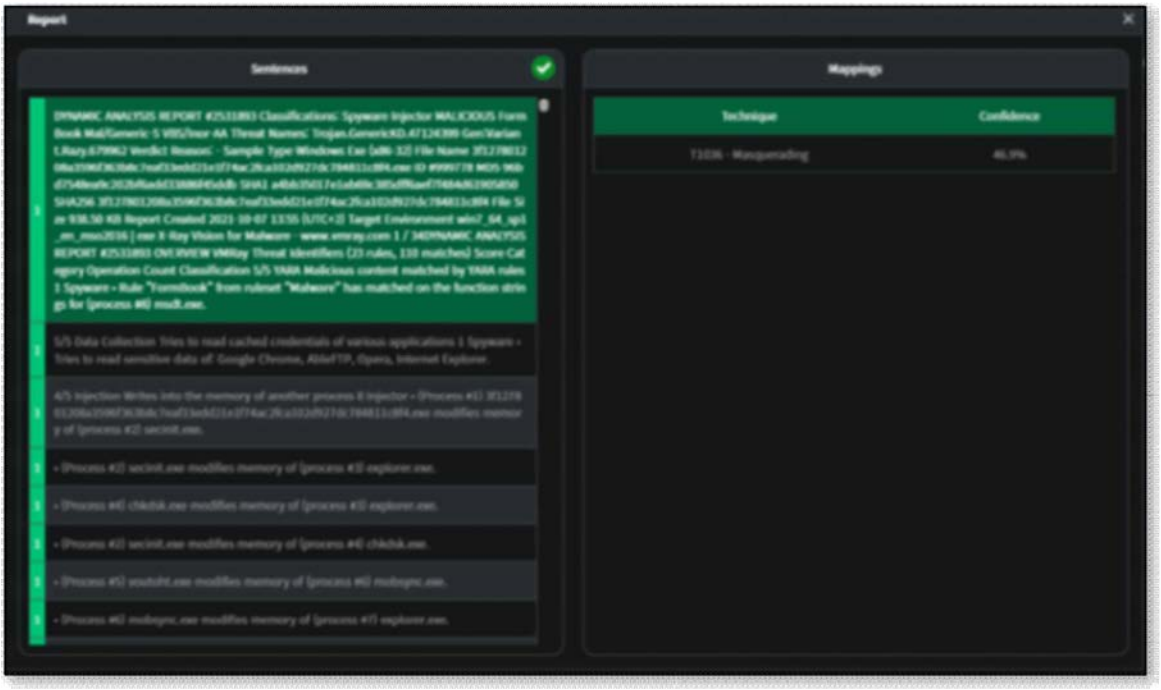
- MITRE ATT&CK Navigator 모니터링 기술 구현



- TTP 기반 위협 인자 식별 관리 가시화 구현



국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



2) 사용자 정의 기반 보안 관제 플레이북 생성 및 관리 도구 고도화

o SOAR 플레이북 컴포넌트 태그 추천 기술 연구 및 구현

- 플레이북 자동 생성을 위한 컴포넌트 태그 정보 추천

Base URL

✓ http://59.18.107.246:8080/recommend/

Input [Get]

✓ 추천을 받아보고 싶은 태그명들을 입력

✓ 태그간 구분은 ';'를 이용

✓ 띄어쓰기는 삭제 처리 (IP 조회 => IP조회)

Output [JSON]

key	설 명
0_recommendation_result	태그 추천 결과
1_center_tag	태그 추천 대상
2_co-occurrence_probability	추천 대상과 추천 결과의 동시 출현 확률
3_probability_formula	동시 출현 확률 산출식 ※ 추천 결과와 동시 출현 횟수 / 추천 대상의 전체 출현 횟수

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- SOAR 플레이북 컴포넌트 태그 추천 기술 연구 및 구현

: 컴포넌트 태그 추천 기술 관리 스키마 설계

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

테이블 명	한글명	tram_공격대상	영문명	tram_attackobject	
개요	공격대상 정보 테이블				
컬럼	컬럼명	한글컬럼명	키유형	Null	Type
	id	id	PK	NN	INTEGER
	name	name		NN	VARCHAR(200)
	stix_id	stix_id		NN	VARCHAR(128)
	attack_id	attack_id		NN	VARCHAR(128)
	attack_url	공격url		NN	VARCHAR(512)
	matrix	matrix		NN	VARCHAR(200)
	created_on	생성일자		NN	DATETIME
	updated_on	업데이트일자		NN	DATETIME
	attack_type	공격타입		NN	VARCHAR(128)
	stix_type	stix_type		NN	VARCHAR(128)
색인 ID	PRIMARY KEY (id)				

테이블 명	한글명	tram_매핑	영문명	tram_mapping	
개요	매핑 테이블				
컬럼	컬럼명	한글컬럼명	키유형	Null	Type
	id	id	PK	NN	INTEGER
	setence_id	setence_id	FK	NN	INTEGER
	report_id	report_id	FK	NN	INTEGER
	attack_object_id	attack_object_id	FK		INTEGER
	confidence	신뢰		NN	REAL
	created_on	생성일자		NN	DATETIME
	updated_on	업데이트일자		NN	DATETIME
색인 ID	PRIMARY KEY (id)				

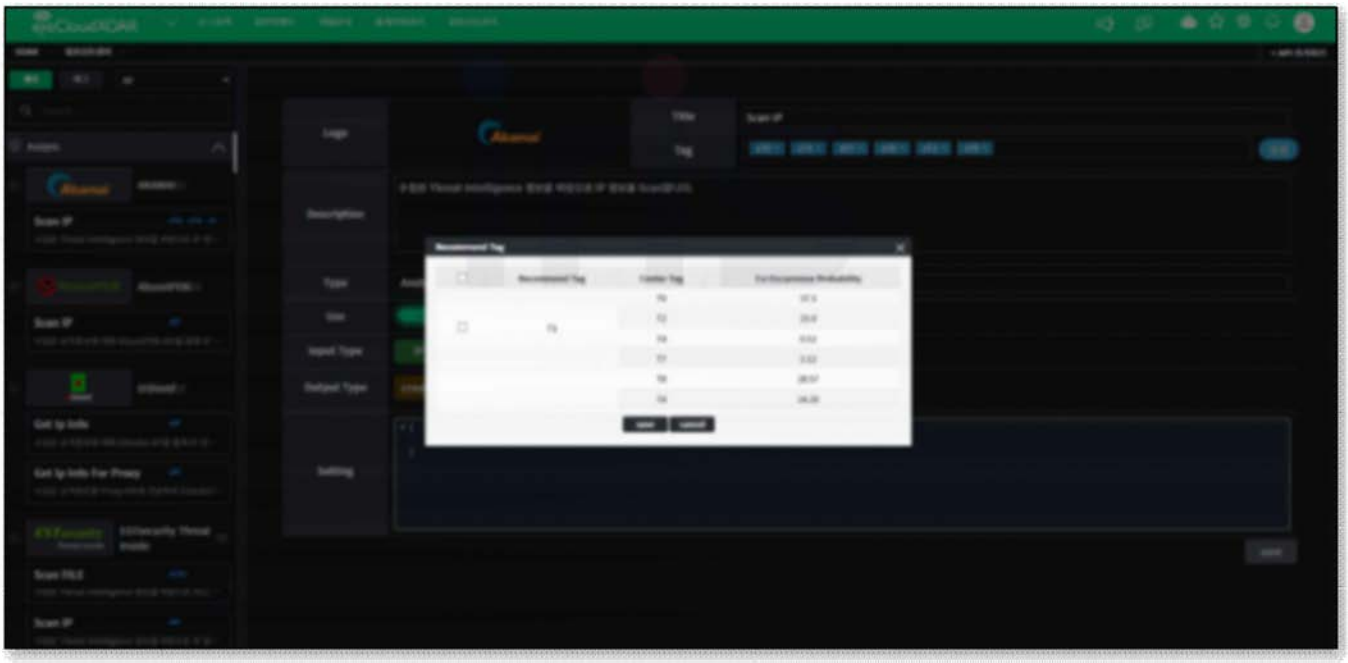
테이블 명	한글명	tram_문장	영문명	tram_sentence	
개요	공격대상 정보 테이블				
컬럼	컬럼명	한글컬럼명	키유형	Null	Type
	id	id	PK	NN	INTEGER
	report_id	report_id	FK	NN	INTEGER
	document_id	document_id	FK		VINTEGER
	text	text		NN	TEXT
	order	순서		NN	INTEGER
	disposition	처분			VARCHAR(200)
	created_on	생성일자		NN	DATETIME
	updated_on	업데이트일자		NN	DATETIME

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

색인 ID	PRIMARY KEY (id)

테이블 명	한글명	tram_보고서	영문명	tram_report	
개요	보고서 테이블				
컬럼	컬럼명	한글컬럼명	키유형	Null	Type
	id	id	PK	NN	INTEGER
	created_by_id	created_by_id	FK		INTEGER
	document_id	document_id	FK		INTEGER
	name	명칭		NN	VARCHAR(200)
	text	text		NN	TEXT
	ml_model	ml_model		NN	VARCHAR(200)
	created_on	생성일자		NN	DATETIME
	updated_on	업데이트일자		NN	DATETIME
색인 ID	PRIMARY KEY (id)				

: 플레이북 자동 생성을 위한 컴포넌트 태그 정보 추천 가시화 개발



- 위협 인자 식별을 위한 필수 정보 추출 기술

: 보호자산 정보 정의 및 자동 추출 기술 연구

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

☐ 필수 사항 (CPE에서 필요한 필수 정보)

- 수집된 자산에 대한 취약 인자 식별을 위해 CPE 내 필수 정보 리스트 명시
  - 자산정보 -> CPE -> CVE

수집항목	설명	예시
유형 (part)	소프트웨어 유형	'a' Application 'o' OS
제조사명 (vendor)	제품을 제조하거나 관리 사람 및 조직	'microsoft', 'hp', 'samsung'
제품명 (product)	제품의 가장 일반적이고 인식 가능한 이름	'internet_explorer', 'insight_diagnostics'
버전 (version)	제품의 특정 릴리스(release) 버전	

☐ 선택 사항 (동적 정보)

- 분류 1 : 시스템 장비 (Mobile, IoT Device 등)

분류	수집항목	설명
시스템 장비	OS 어플리케이션 버전 정보	탑재된 어플리케이션 목록들 어플리케이션 버전 정보들

- 분류 2 : 네트워크 장비 (Switch, Router 등)

분류	수집항목	설명
네트워크 장비	IP 정보 열린 Port 정보	

: 보호자산 대상 관리 및 위협 인자 정보 관리 스키마 설계

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

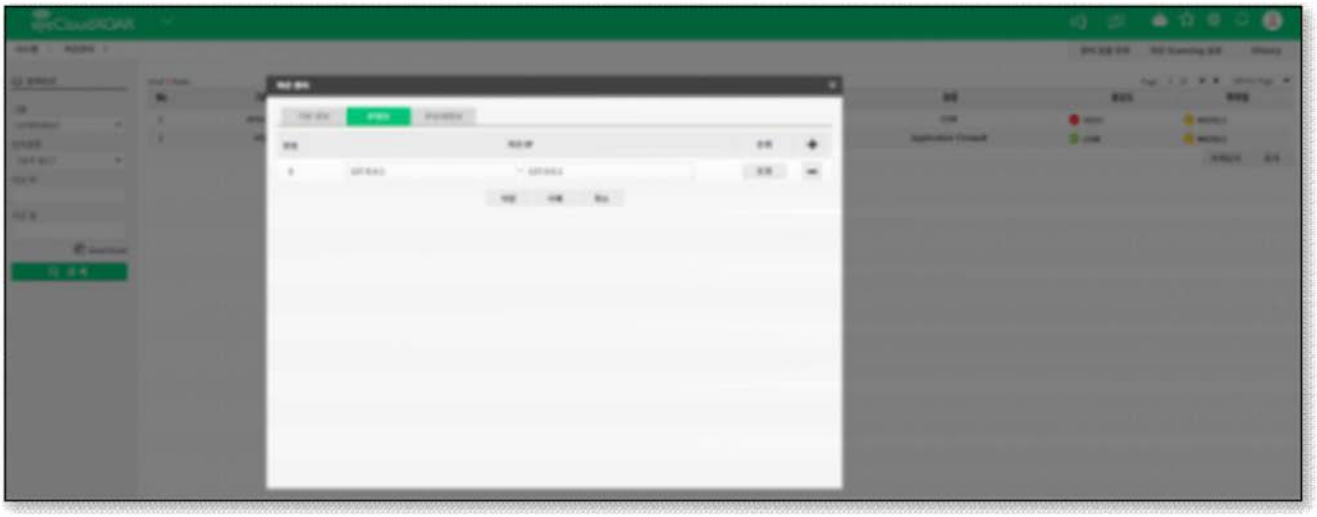
테이블 명	한글명	자산IP	영문명	MGR_ASSET_IP	
개요	자산IP 테이블				
컬럼	컬럼명	한글컬럼명	키유형	Null	Type
	asset_id	자산id	PK	NN	VARCHAR(20)
	sip	시작ip	PK	NN	VARCHAR(39)
	eip	종료ip	PK	NN	VARCHAR(39)
	sip_long	시작ip_long			BINARY(16)
	eip_long	종료ip_long			BINARY(16)
색인 ID	PRIMARY KEY (asset_id, sip, eip)				

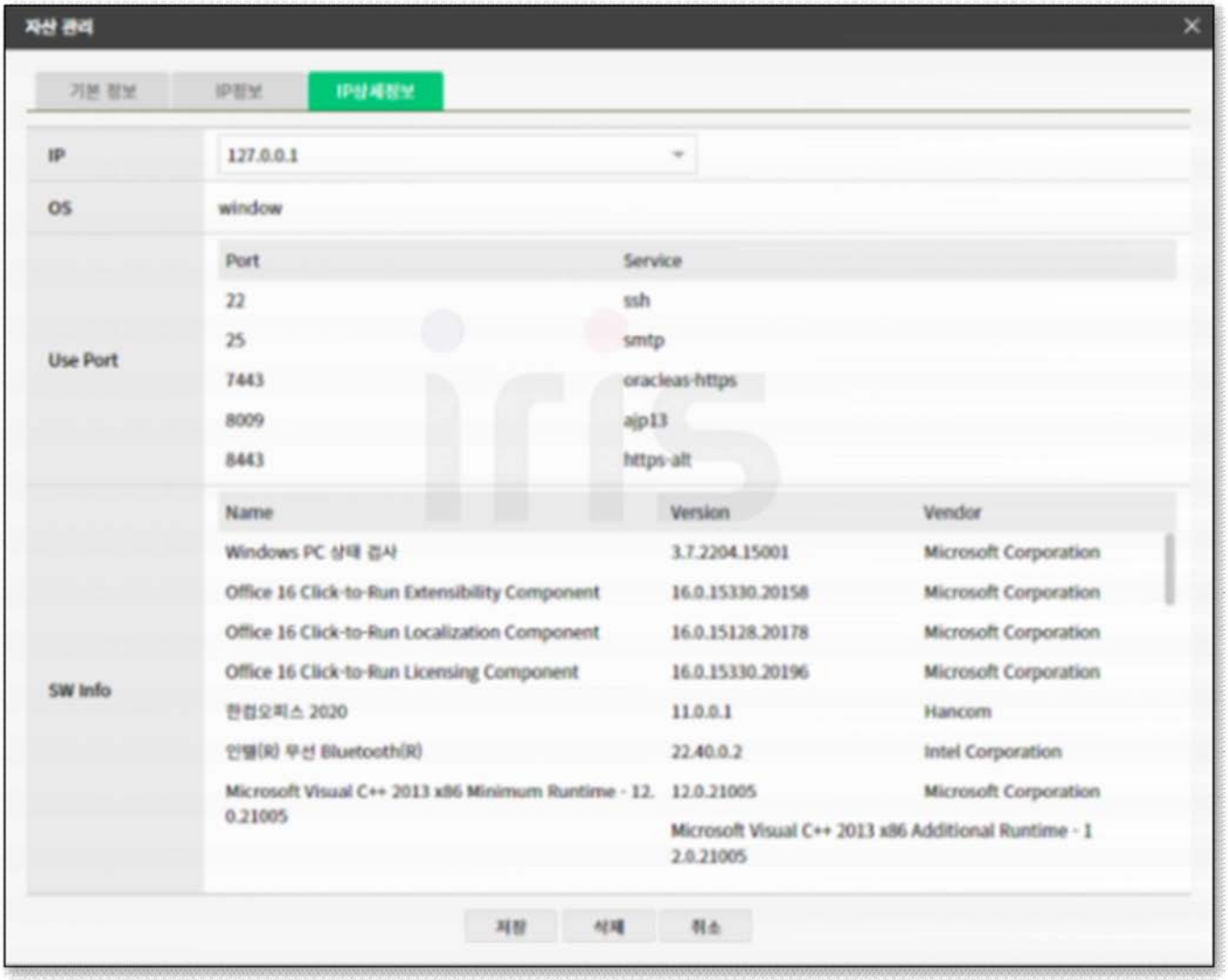
테이블 명	한글명	자산IP 정보	영문명	MGR_ASSET_IP_INFO	
개요	자산IP 정보 테이블				
컬럼	컬럼명	한글컬럼명	키유형	Null	Type
	asset_id	자산id	FK	NN	VARCHAR(20)
	ip	Ip			VARCHAR(39)
	update_dt	업데이트일자			VARCHAR(14)
	use_port	사용port			TEXT
	os	운영체제			CHAR

테이블 명	한글명	자산 소프트웨어 정보	영문명	MGR_ASSET_SW_INFO	
개요	자산 소프트웨어 정보 테이블				
컬럼	컬럼명	한글컬럼명	키유형	Null	Type
	asset_id	자산id	FK	NN	VARCHAR(20)
	ip	Ip			VARCHAR(39)
	sw_vender	sw 공급업체			VARCHAR(200)
	sw_version	sw 버전			VARCHAR(50)
	sw_product	sw 제품			VARCHAR(200)

: 보호자산 대상 관리 및 위협 인자 정보 관리 가시화 구현

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

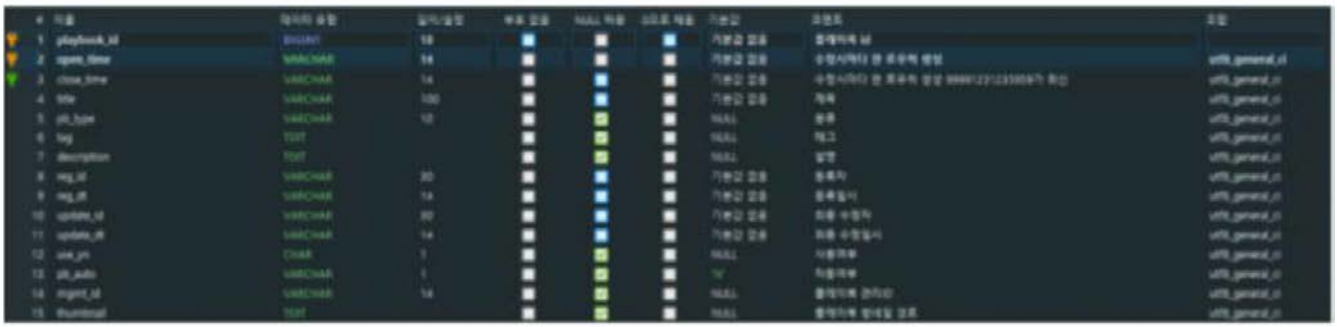


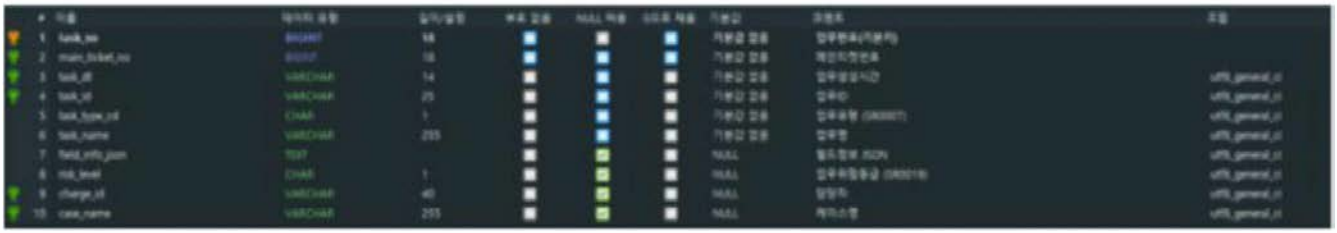


3) 플레이북 요소 기술 실시간 수행 결과 시각화 도구 고도화

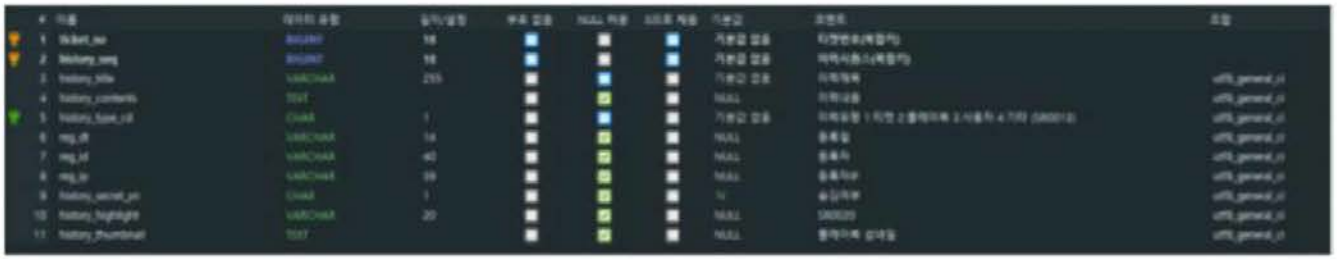
o 플레이북 실시간 수행 결과 시각화 연구 및 설계

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

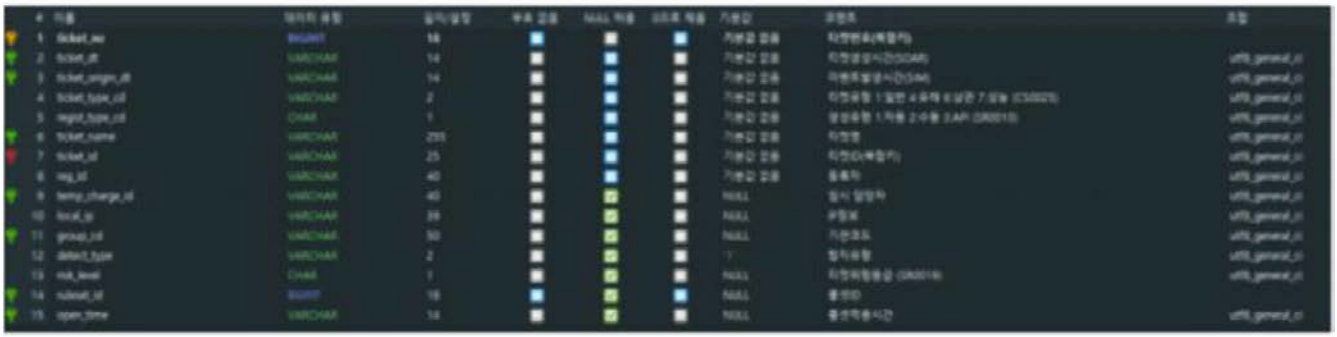




국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

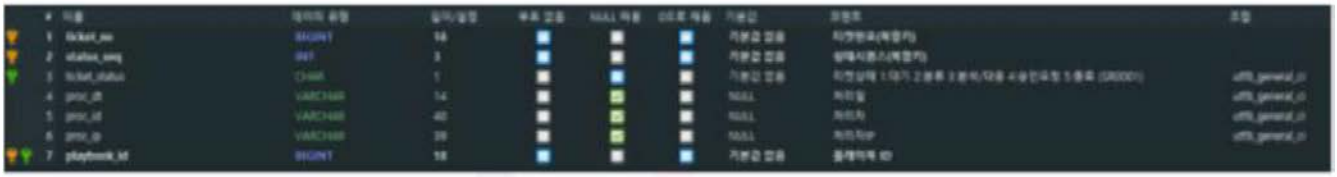


#	이름	데이터 유형	길이/설정	부호 없음	NULL 허용	0으로 채움	기본값	코멘트	조합
1	ticket_no	BIGINT	18	■	■	■	기본값 없음	티켓번호(복합키)	
2	history_seq	BIGINT	18	■	■	■	기본값 없음	이력시퀀스(복합키)	
3	history_title	VARCHAR	255	■	■	■	기본값 없음	이력제목	utf8_general_ci
4	history_contents	TEXT		■	■	■	NULL	이력내용	utf8_general_ci
5	history_type_cd	CHAR	1	■	■	■	기본값 없음	이력유형 1:직전 2:출력이력 3:사용자 4:기타 (SB001)	utf8_general_ci
6	reg_dt	VARCHAR	14	■	■	■	NULL	등록일	utf8_general_ci
7	reg_id	VARCHAR	40	■	■	■	NULL	등록자	utf8_general_ci
8	reg_ip	VARCHAR	39	■	■	■	NULL	등록자IP	utf8_general_ci
9	history_secret_yn	CHAR	1	■	■	■	N	숨김여부	utf8_general_ci
10	history_highlight	VARCHAR	20	■	■	■	NULL	SB020	utf8_general_ci
11	history_thumbnail	TEXT		■	■	■	NULL	출력이력 섬네일	utf8_general_ci

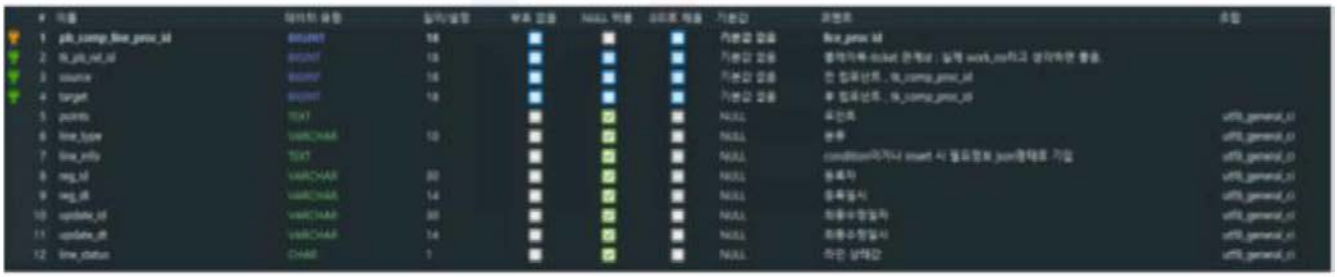


#	이름	데이터 유형	길이/설정	부호 없음	NULL 허용	0으로 채움	기본값	코멘트	조합
1	ticket_no	BIGINT	18	■	■	■	기본값 없음	티켓번호(복합키)	
2	ticket_dt	VARCHAR	14	■	■	■	기본값 없음	티켓생성시간(SDAB)	utf8_general_ci
3	ticket_origin_dt	VARCHAR	14	■	■	■	기본값 없음	티켓최초생성시간(SAA)	utf8_general_ci
4	ticket_type_cd	VARCHAR	2	■	■	■	기본값 없음	티켓유형 1:일반 4:유예 6:삭제 7:대기 (CS002)	utf8_general_ci
5	regist_type_cd	CHAR	1	■	■	■	기본값 없음	생성유형 1:직원 2:수동 3:API (SB001)	utf8_general_ci
6	ticket_name	VARCHAR	255	■	■	■	기본값 없음	티켓명	utf8_general_ci
7	ticket_id	VARCHAR	25	■	■	■	기본값 없음	티켓ID(복합키)	utf8_general_ci
8	reg_id	VARCHAR	40	■	■	■	기본값 없음	등록자	utf8_general_ci
9	temp_charge_id	VARCHAR	40	■	■	■	NULL	임시 담당자	utf8_general_ci
10	local_ip	VARCHAR	39	■	■	■	NULL	IP정보	utf8_general_ci
11	group_cd	VARCHAR	50	■	■	■	NULL	기관코드	utf8_general_ci
12	detect_type	VARCHAR	2	■	■	■	Y	탐지유형	utf8_general_ci
13	risk_level	CHAR	1	■	■	■	NULL	티켓위험등급 (SB014)	utf8_general_ci
14	ruleset_id	BIGINT	18	■	■	■	NULL	룰셋ID	
15	open_time	VARCHAR	14	■	■	■	NULL	룰셋적용시간	utf8_general_ci

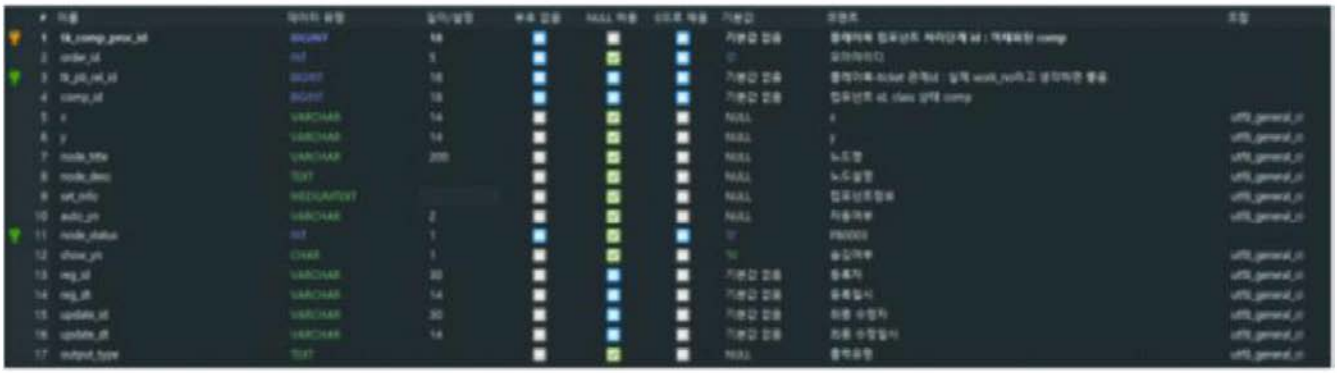
#	이름	데이터 유형	길이/설정	부호 없음	NULL 허용	0으로 채움	기본값	코멘트	조합
1	ticket_no	BIGINT	18	■	■	■	기본값 없음	티켓번호(복합키)	
2	task_no	BIGINT	18	■	■	■	기본값 없음	업무번호(복합키)	
3	main_yn	CHAR	1	■	■	■	기본값 없음	메인티켓여부 Y:main N:sub	utf8_general_ci



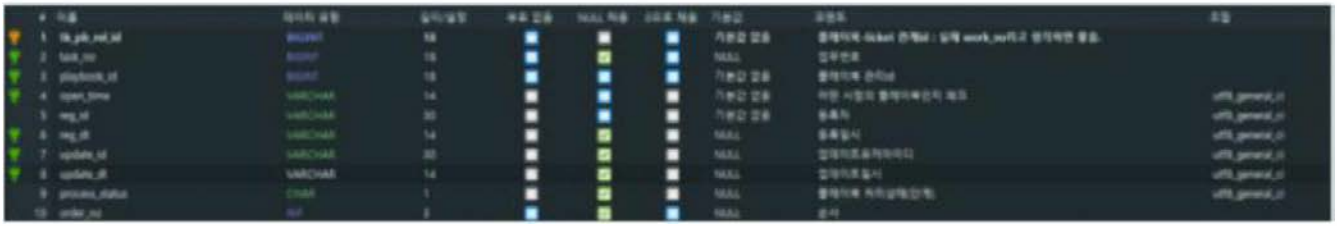
#	이름	데이터 유형	길이/설정	부호 없음	NULL 허용	0으로 채움	기본값	코멘트	조합
1	ticket_no	BIGINT	18	■	■	■	기본값 없음	티켓번호(복합키)	
2	status_seq	INT	3	■	■	■	기본값 없음	상태시퀀스(복합키)	
3	ticket_status	CHAR	1	■	■	■	기본값 없음	티켓상태 1:대기 2:분류 3:분석/작업 4:승인요청 5:종료 (SB001)	utf8_general_ci
4	proc_dt	VARCHAR	14	■	■	■	NULL	처리일	utf8_general_ci
5	proc_id	VARCHAR	40	■	■	■	NULL	처리자	utf8_general_ci
6	proc_ip	VARCHAR	39	■	■	■	NULL	처리자IP	utf8_general_ci
7	playbook_id	BIGINT	18	■	■	■	기본값 없음	플레이북 ID	



#	이름	데이터 유형	길이/설정	부호 없음	NULL 허용	0으로 채움	기본값	코멘트	조합
1	pb_comp_line_proc_id	BIGINT	18	■	■	■	기본값 없음	line_proc id	
2	fk_pb_rel_id	BIGINT	18	■	■	■	기본값 없음	플레이북-ticket 관계id : 실제 work_no하고 상이하면 활용.	
3	source	BIGINT	18	■	■	■	기본값 없음	선 입프선번 : fk_comp_proc_id	
4	target	BIGINT	18	■	■	■	기본값 없음	후 입프선번 : fk_comp_proc_id	
5	points	TEXT		■	■	■	NULL	꺾인점	utf8_general_ci
6	line_type	VARCHAR	10	■	■	■	NULL	선종	utf8_general_ci
7	line_info	TEXT		■	■	■	NULL	condition이거나 insert 시 필요정보 json형태로 기입	utf8_general_ci
8	reg_id	VARCHAR	30	■	■	■	NULL	등록자	utf8_general_ci
9	reg_dt	VARCHAR	14	■	■	■	NULL	등록일시	utf8_general_ci
10	update_id	VARCHAR	30	■	■	■	NULL	최종수정일자	utf8_general_ci
11	update_dt	VARCHAR	14	■	■	■	NULL	최종수정일시	utf8_general_ci
12	line_status	CHAR	1	■	■	■	NULL	라인 상태값	utf8_general_ci



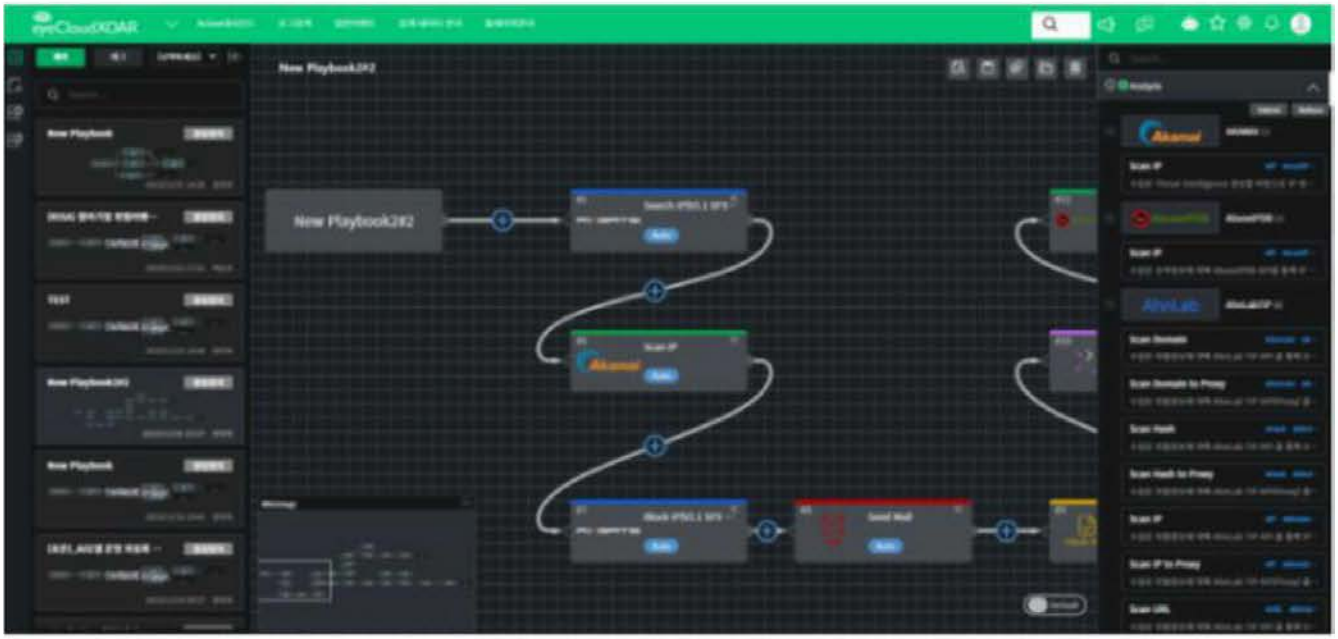
#	이름	데이터 유형	길이/설정	부호 없음	NULL 허용	0으로 채움	기본값	코멘트	조합
1	fk_comp_proc_id	BIGINT	18	■	■	■	기본값 없음	플레이북 입프선번 처리단계 id : 역해화된 comp	
2	order_id	INT	5	■	■	■	0	실행순서ID	
3	fk_pb_rel_id	BIGINT	18	■	■	■	기본값 없음	플레이북-ticket 관계id : 실제 work_no하고 상이하면 활용.	
4	comp_id	BIGINT	18	■	■	■	기본값 없음	입프선번 id. class 상태 comp	
5	x	VARCHAR	14	■	■	■	NULL	x	utf8_general_ci
6	y	VARCHAR	14	■	■	■	NULL	y	utf8_general_ci
7	node_title	VARCHAR	200	■	■	■	NULL	노드명	utf8_general_ci
8	node_desc	TEXT		■	■	■	NULL	노드설명	utf8_general_ci
9	set_info	MEDIUMTEXT		■	■	■	NULL	입프선번정보	utf8_general_ci
10	auto_yn	VARCHAR	2	■	■	■	NULL	자동여부	utf8_general_ci
11	node_status	INT	1	■	■	■	0	99000	
12	show_yn	CHAR	1	■	■	■	N	숨김여부	utf8_general_ci
13	reg_id	VARCHAR	30	■	■	■	기본값 없음	등록자	utf8_general_ci
14	reg_dt	VARCHAR	14	■	■	■	기본값 없음	등록일시	utf8_general_ci
15	update_id	VARCHAR	30	■	■	■	기본값 없음	최종 수정자	utf8_general_ci
16	update_dt	VARCHAR	14	■	■	■	기본값 없음	최종 수정일시	utf8_general_ci
17	output_type	TEXT		■	■	■	NULL	출력유형	utf8_general_ci

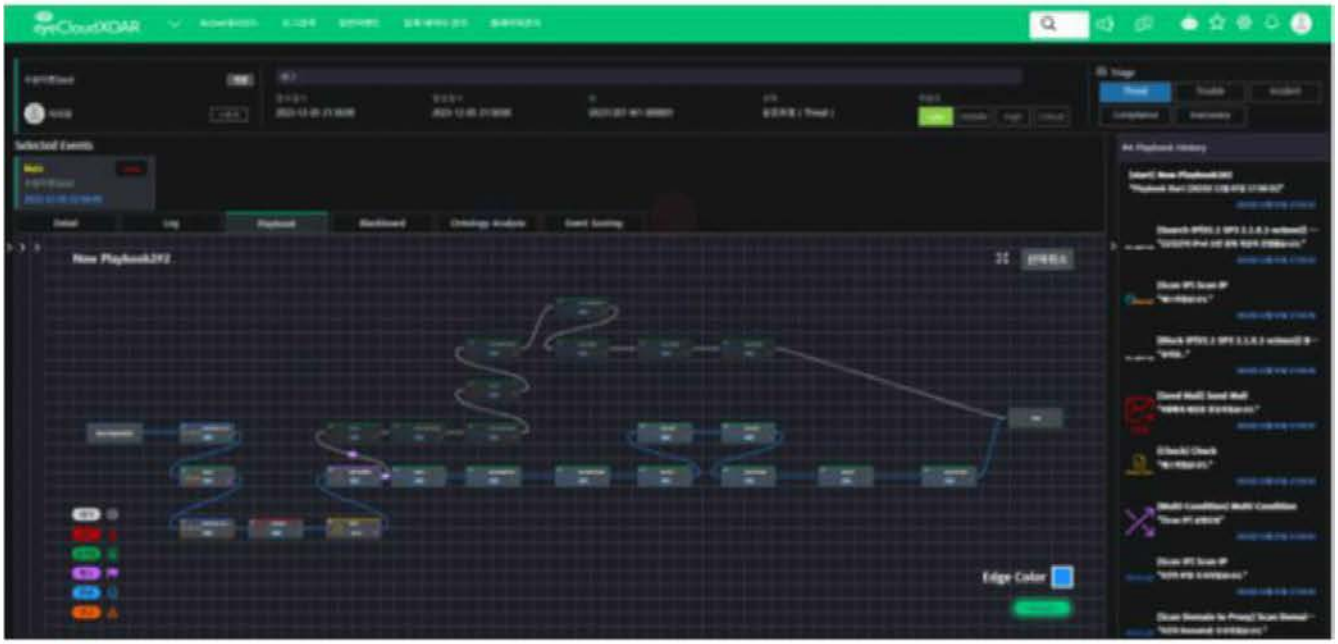


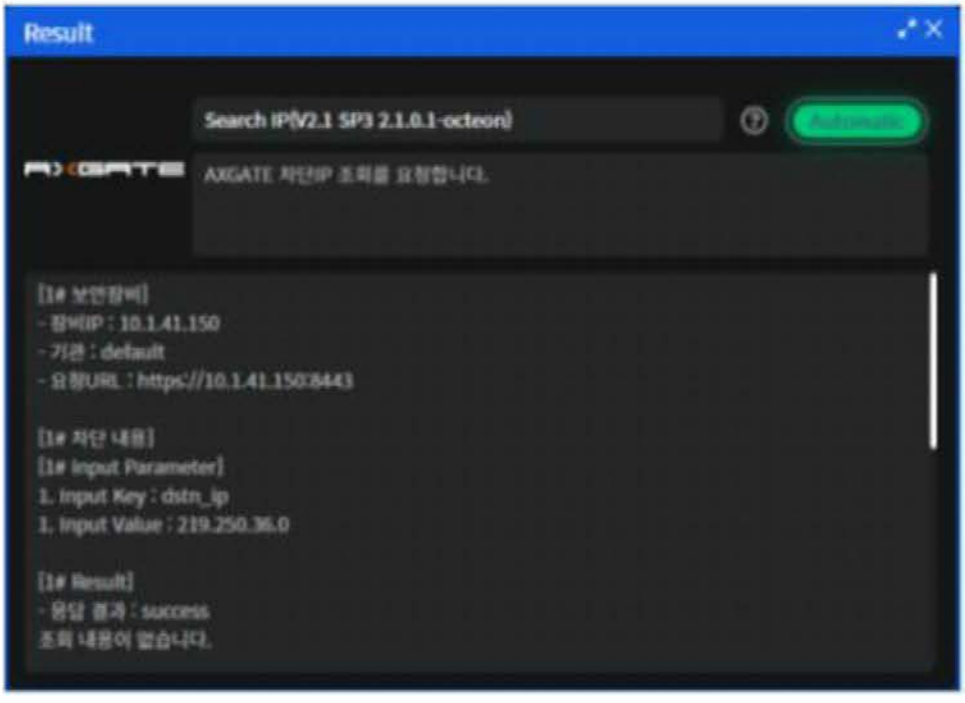
#	이름	데이터 유형	길이/설정	부호 없음	NULL 허용	0으로 채움	기본값	코멘트	조합
1	fk_pb_rel_id	BIGINT	18	■	■	■	기본값 없음	플레이북-ticket 관계id : 실제 work_no하고 상이하면 활용.	
2	task_no	BIGINT	18	■	■	■	NULL	업무번호	
3	playbook_id	BIGINT	18	■	■	■	기본값 없음	플레이북 순서id	
4	open_time	VARCHAR	14	■	■	■	기본값 없음	이전 시점의 플레이북순서 제외	utf8_general_ci
5	reg_id	VARCHAR	30	■	■	■	기본값 없음	등록자	utf8_general_ci
6	reg_dt	VARCHAR	14	■	■	■	NULL	등록일시	utf8_general_ci
7	update_id	VARCHAR	30	■	■	■	NULL	업데이트등록자아이디	utf8_general_ci
8	update_dt	VARCHAR	14	■	■	■	NULL	업데이트일시	utf8_general_ci
9	process_status	CHAR	1	■	■	■	NULL	플레이북 처리상태(진행)	utf8_general_ci
10	order_no	INT	3	■	■	■	NULL	순서	

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- 플레이북 실시간 수행 결과 시각화







국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

연구목표	신속한 의사결정 지원을 위한 AI 모델 개발

세부 내용	1) AI 학습 데이터셋 유효성 검증 및 영향도 분석
	2) 신속한 의사결정 지원 AI 분석 모델 설계 및 개발

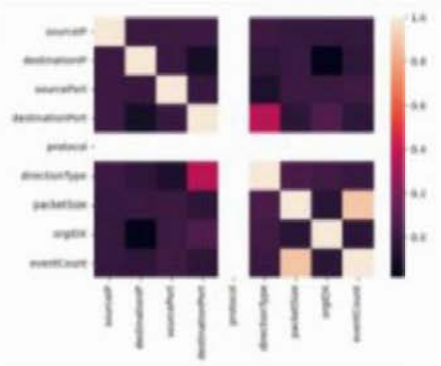
1) AI 학습 데이터셋 유효성 검증 및 영향도 분석

o 학습 데이터 특징별 중요도 추출을 통한 영향도 분석

- 데이터 feature별 예측 기여도 추출 및 특징 간 상관관계 분석

	sourceIP	destinationIP	sourcePort	destinationPort	protocol	directionType	packetSize	orgIDX	eventCount
sourceIP	1.000000	0.005341	0.007853	0.013773	NaN	0.011903	-0.007352	-0.016298	-0.016153
destinationIP	0.005341	1.000000	-0.000166	-0.107907	NaN	-0.031070	-0.002360	-0.183660	-0.028224
sourcePort	0.007853	-0.000166	1.000000	-0.006079	NaN	-0.084881	0.012710	0.008619	0.021164
destinationPort	0.013773	-0.107907	-0.006079	1.000000	NaN	0.362612	-0.036317	0.066228	-0.039872
protocol	NaN	NaN	NaN	NaN	NaN	NaN	NaN	NaN	NaN
directionType	0.011903	-0.031070	-0.084881	0.362612	NaN	1.000000	0.054663	0.025457	0.001072
packetSize	-0.007352	-0.002360	0.012710	-0.036317	NaN	0.054663	1.000000	-0.052654	0.891729
orgIDX	-0.016298	-0.183660	0.008619	0.066228	NaN	0.025457	-0.052654	1.000000	-0.038244
eventCount	-0.016153	-0.028224	0.021164	-0.039872	NaN	0.001072	0.891729	-0.038244	1.000000

<메타데이터 Feature 간 상관관계 출력>

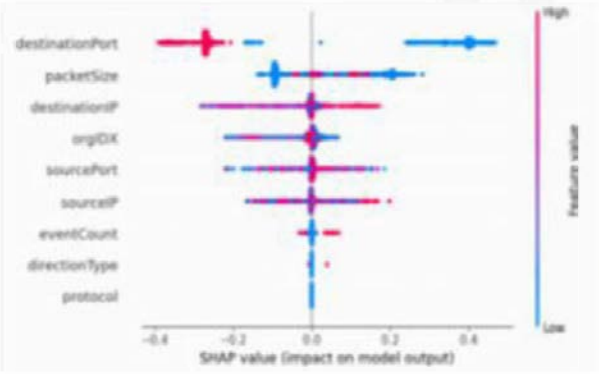


<메타데이터 Feature 간 상관관계 가시화>

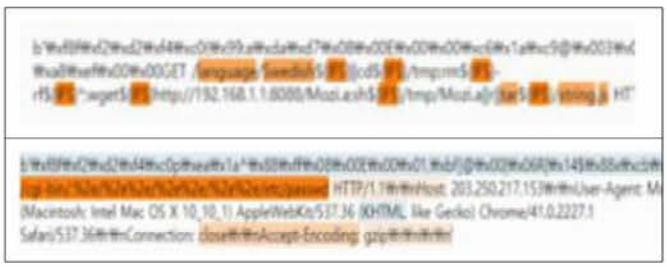
2) 신속한 의사결정 지원 AI 분석 모델 설계 및 개발

o XAI 기반 모델 주요 판단근거 추출

- XAI(LIME, SHAP) 기법을 활용하여 예측 모델의 주요 판단 근거 추출



<SHAP을 활용한 데이터별 예측기여도 가시화>



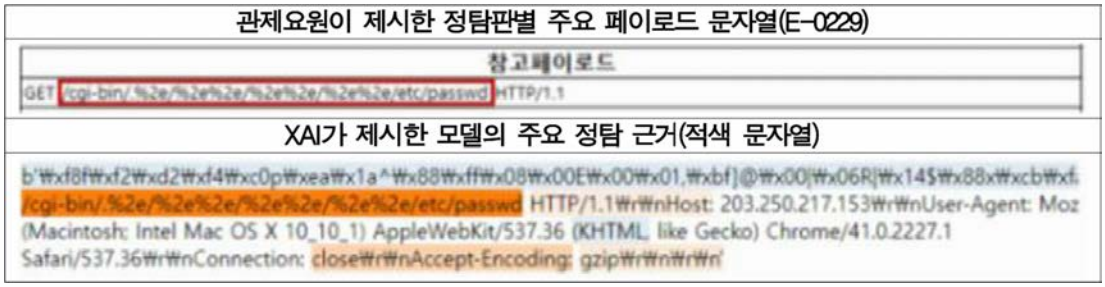
<LIME을 활용한 모델의 페이로드 예측근거 추출>

o XAI 기반 모델 판단근거와 관제요원의 판단근거 비교분석

- 보안이벤트별 XAI 기반 주요 판단근거 및 실제 관제요원 정·오탐 판단근거 비교 및 유사도 분석을 통한 학습데이터 유효성 검증

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

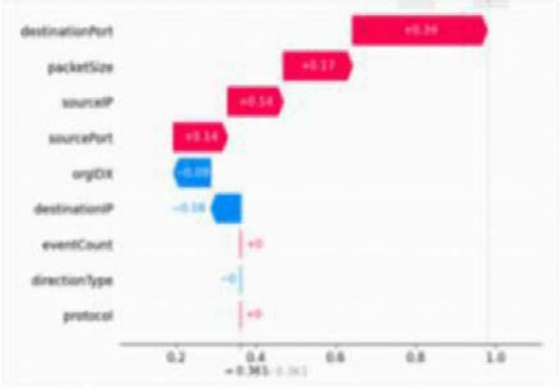
<보안관제요원과 XAI의 주요 판단 근거 비교 (E-3305)>



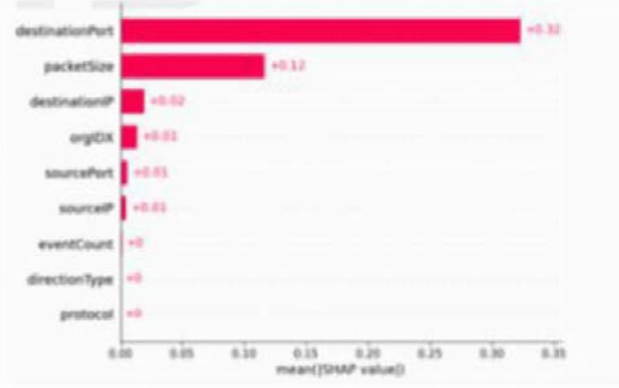
<보안관제요원과 XAI의 주요 판단 근거 비교 (E-0229)>

o XAI 기법 활용을 통한 AI 분석 모델 판단근거 가시화

- 실환경(과학기술사이버안전센터에서 설치·운영 중인 IDS/IPS)기반 주요 보안이벤트 수집
- 정·오탐 발생 비율이 적절하며 관제요원의 정·오탐 판단근거가 명확한 이벤트 선정
- 선정된 이벤트들의 메타정보(IP, Port, Protocol 등 총 9종) 및 페이로드로 모델 학습
- LIME, SHAP을 모델에 적용하여 분석 모델의 **정·오탐 판단근거 가시화**



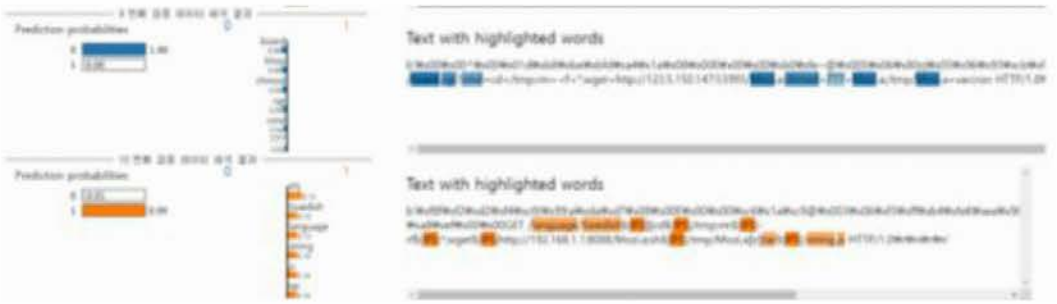
<SHAP을 활용한 AI 모델 예측 근거 가시화(Local)>



<SHAP을 활용한 AI 모델 예측 근거 가시화(Golbal)>

<LIME을 활용한 AI 모델 예측 근거 가시화(메타데이터)>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



<LIME을 활용한 AI 모델 예측 근거 가시화(페이로드)>

연구목표	AI 모델에 의해 추천된 대응 정책의 관리 및 검증 기술 개발

세부 내용	1) 추천 대응 정책의 검증·평가 모델 연구 및 지표 개발
	2) 추천 대응 정책의 강화학습 유효성 검증 기술 개발

1) 추천 대응 정책의 검증·평가 모델 연구 및 지표 개발

o 보안관제센터 대응 이력 통계 생성

- 이벤트 별 대응 정책 적용 건수
- 전체 기간 누적 건수, 기간별 누적 건수, 이벤트별 대응 행위 등

이벤트명	이벤트 ID	빈도수
wget 이용 파일 다운로드 공격 시도	wget	1570
원격 포트 접근 시도	rport	436
ICMP를 활용한 접근 시도	icmp	489
TeamViewer 사용 이벤트 탐지	viewer	33
SMB(445)포트 통한 접근 시도	smb	75
XSS 공격 시도 탐지	xss	263
웹취약점 공격 시도 탐지	web	943
SQL Injection 공격 시도 탐지	sql	494
SSL-VPN 로그인 페이지 접근 시도	ssl	125
Drupal 원격코드실행 취약점 공격 시도	drupal	148
SMTP 포트 과다 접근시도 탐지	smtp	2
스캐닝도구를 이용한 정보 수집 공격 탐지	scan	6
DB 접속 포트 접근 시도 탐지	dbport	29
경로 노출 공격 이벤트 탐지	traver	121
암호화폐채굴 이벤트 탐지	mine	100
TCP SYN Flooding 공격 시도 탐지	flood	9
Apache Struts2 원격실행코드 취약점 공격 시도 탐지	struts	49
PHP Code Injection 공격 시도 탐지	php	1
FCKeditor 취약점을 이용한 웹쉘 업로드 시도	fckeditor	120
웹쉘 업로드 공격 시도 탐지	wshell	2
내부에서 유해IP로 과다 접근 시도	access	21
메일서버 대상 무차별 대입 공격 이벤트	mail	5
윈너크라이 킬스위치 접속 시도 이벤트	kswitch	1
telnet포트를 이용한 접근시도 탐지	tport	1
워드프레스 파일 매니저 플러그인 취약점 공격시도 탐지	wplugin	115
curl 이용 파일 다운로드 공격 시도 이벤트	curl	10

BashShell 원격 명령 실행 취약점 공격 시도 이벤트 탐지	bshell	7
Joomla 원격 코드 실행 취약점 공격 시도 탐지	joomla	14
Sitecore XP 원격코드 실행 취약점 공격 시도 탐지	score	1
디폴트 페이지 공격 시도 탐지	dpage	14
Apache Log4j 2 원격코드 실행 취약점 공격 시도 탐지	log4j	636
netcat 이용 리버스쉘 공격 시도 이벤트 탐지	nshell	2
CHeditor 취약점을 이용한 파일 업로드 시도 이벤트	cheditor	4
P2P 사용 이벤트 탐지	p2p	4
익스플로잇 공격 시도 탐지	exploit	1
connect 메소드를 이용한 접근 시도 탐지	connect	1
웹 스캐닝 공격 시도 탐지	wscan	2
Spring 프레임워크 원격코드 실행 취약점 공격 시도 탐지	spring	62
Reverse Shellcode 공격 시도 탐지	rshell	5
무차별 대입 공격 이벤트 탐지	bforce	8
디폴트 인증값 공격 시도 탐지	dauth	1
D-Link 라우터 취약점을 이용한 DNS 하이재킹 공격 시도	hijack	1
ID 인증 우회 취약점 이벤트 탐지	bypass	2
gmEditor 취약점을 이용한 웹쉘 업로드 시도	gmeditor	3
Alfa Team Shell Tesla 4.1 원격 코드 실행 공격 시도 탐지	ashell	4
Guzzle 라이브러리 취약점을 이용한 공격 시도	guzzle	1
VPN 서비스 사용 의심 이벤트	vpn	2
MicroSoft Exchange 원격 코드 실행 취약점 공격 시도 탐지	mchange	61
Apache Tomcat 원격 코드 실행 취약점 공격 시도 탐지	tomcat	1
FortiOS의 인증위회 취약점을 이용한 공격 시도 탐지	fortios	1
Laravel 취약점 원격코드 실행 취약점 공격 시도 탐지	laravel	3
ADware 이벤트 탐지	adware	2
Spring Cloud Function 원격코드 실행 취약점 공격 시도 탐지	scfunc	5
Nmap 스캐닝 툴을 이용한 스캔 시도	nmap	2

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

<이벤트별 대응 이력 통계 및 대응 정책>

넘버	대응 행위(response)	response_id
1	취약점 점검 권고	vulnerability_check_recomm
2	공격지 IP 차단 정책 적용 권고	src_ip_block_recomm
3	목적지 IP 정보공유 요청	dst_ip_info_request
4	보안 최신 업데이트 권고	security_update_recomm
5	시스템 로그 요청	sys_log_request
6	악성코드 감염 여부 확인 요청	malicious_code_infect_request
7	시그니처 차단 권고	signature_block_recomm
8	악성 URL 차단 정책 적용 권고	malicious_url_block_recomm
9	임계치 설정 권고	threshold_set_recomm
10	패스워드 변경 권고	pw_change_recomm
11	네트워크 분리 권고	network_isolate_recomm
12	다단계 인증 권고	multi_auth_recomm
13	접근제어 설정 권고	access_control_set_recomm
14	임시 접근 허용 차단 권고	tmp_access_block_recomm
15	정상 통신 여부 확인 요청	normal_comm_check_request
16	원격포트 정보공유 요청	remote_port_info_request
17	악성코드 제거 요청	malicious_code_get_request
18	PC 정밀검사 권고	pc_close_exam_recomm

이벤트(event_id)	대응 정책
wget	2-6-3
rport	14-15-2-3-16
icmp	9-2-3
viewer	12-20-15-21
smb	23-17-4-18-19
xss	1-2-3-4
web	1-2-3-4
sql	1-2-3-4
ssl	10-11-12-4-13-2
drupal	1-2-3-4
smt	15-18-21
scan	24-13-10-2-8
dhport	15-2-19
trawler	1-2-3-4
mine	17-22-18-2-23-15
flood	2-3
struts	1-2-3-4
php	1-2-3-4

- 통계 기반 대응 이력 관리 정보 (메모리 DB)
  · 대응 정책 추천 모델의 유효성 검증을 위해 대응 이력 통계에서 이벤트별 대응 적용 건수를 메모리 DB에서 관리

<통계 기반 대응 이력 관리 정보>

EVENT_ID	Response_ID	적용 건수
exploit	12-2	159
exploit	14-2-9	37
viewer	12-20-15-21	23
...	...	

Response_ID	DESC	
1	취약점 점검 권고	vulnerability_check_recomm
2	공격지 IP 차단 정책 적용 권고	src_ip_block_recomm
3	목적지 IP 정보 공유 요청	dst_ip_info_request
...	...	...

o 추천 대응 정책 검증을 위한 강화학습 가중치 반영
- 보안관제 이벤트에 대해 컴포넌트화된 대응 정책을 추천하고, 추천된 대응 행위에 대한 순서가 적절한지 검증
- 보안관제 이벤트에 대해 N개의 대응 행위가 있을 경우, 대응 행위 순서에 대해 n → (n+1)위치에 대해 대응 행위가 매칭될 때마다 점수를 부여
- n=1 인 경우, 순서가 매치됐으면 $10/N$점수를 부여하고, 매치되지 않았으면 $10/N*(d_1-d_1')$ 점수를 부여
- n >1 인 경우, 우선 순위가 매치됐으면 $10/N$점수를 부여하고, 매치되지 않았으면 우선 순위가 결정된 이벤트와 기존 이벤트와의 방향 및 거리 차를 고려하여 점수를 부여
- $d_n'-d_{n+1}'$이 -1이면 정상 순서로 매치되고, $d_n'-d_{n+1}'<0$ 이면 정방향, $d_n'-d_{n+1}'>0$ 이면 역방향으로 판단
- 정방향일 경우, $\frac{10}{N}*\frac{1}{(d_{n+1}'-d_n')}$로, 역방향일 경우, $\frac{10}{N}*(d_{n+1}'-d_n')$으로 계산

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

<강화학습 가중치 반영 동작 순서도>

o 대응 정책 추천 모델 선정

- 에이전트(추천모델)가 각 상태에서 가장 큰 보상을 얻을 수 있도록 학습
  - 모델 없이 학습하는 강화 학습 기법 중 하나인 Q 러닝(Q-learning) 선정
  - Q 러닝은 주어진 상태에서 주어진 행동 수행으로 얻을 수 있는 효용의 기대값을 예측하는 함수인 Q 함수를 학습
  - 주어진 상태에서 어떤 행동을 수행할지 나타내는 규칙인 최적 정책을 학습

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

```
class QLAgent(mlflow.pyfunc.PythonModel):

    def __init__(self, env, lr_algo, n_eps):

        super(QLAgent, self).__init__()
        self.env = env
        self.lr_algo = lr_algo
        self.n_eps = n_eps

        self.reward_list = list()

    def train(self):

        for episode in range(self.n_eps):

            state = self.env.reset()
            done = False
            episode_reward = 0

            while True:

                action = self.lr_algo.act(state, train=True)
                next_state, reward, done = self.env.step(action)
                episode_reward += reward
                self.lr_algo.update(state, action, next_state, reward)

                if done:
                    break

                state = next_state

            mlflow.log_metric("reward", episode_reward, step=episode)

            self.reward_list.append(episode_reward)

    def load_context(self, context):
        pass

    def predict(self, context, data):

        total_pred_list = list()

        for event_id in data['event_id']:

            pred_list = list()

            try:
                state = self.env.reset(event_id=event_id)
            except Exception as e:
                return e.args[0]

            while True:
                action = self.lr_algo.predict(state)
                next_state, _, done = self.env.step(action)
                pred_list.append(action)

                if done:
                    break

                state = next_state

            total_pred_list.append(','.join(pred_list))

        return total_pred_list
```

<Q learning 알고리즘 적용 프로그램 코드>

o 대응 정책 추천 모델 검증

- 대응 이력 통계 정보와 정책 추천 모델의 결과의 유사도 비교
  · 일련의 대응 정책에 대해 대응 정책 ID와 순서가 일치할 경우 정확도 점수가 증가하고 불일치 할 경우 감소하는 방식으로 정확도 점수 계산

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

대응 이력 통계

exploit : 14-2-9

정책 추천 모델

exploit : 14-9-2

$$14\text{-}2\text{-}9$$

$$14\text{-}9\text{-}2$$

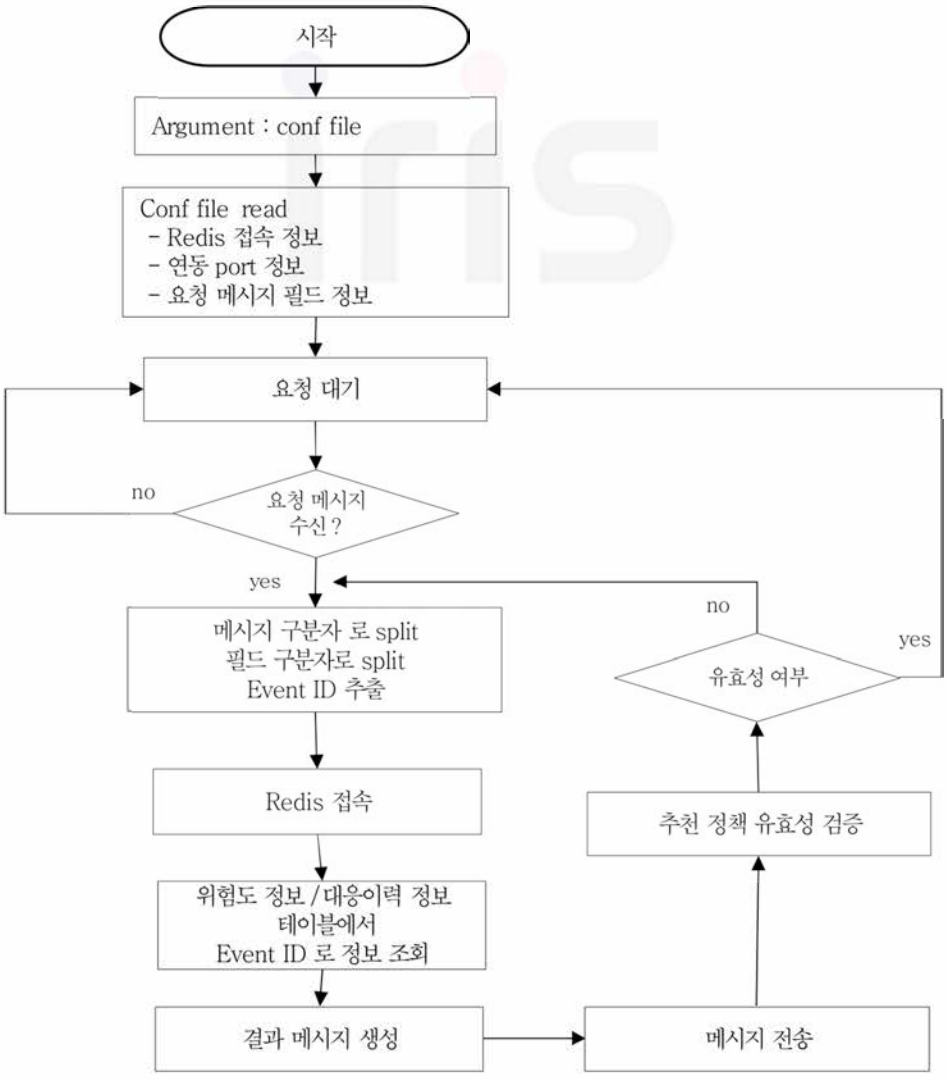
$$\frac{1}{3}\left(\frac{1}{1}+\frac{1}{2}+\frac{1}{3}\right) = 0.61$$

· 정확도 계산 프로세스에 의해 정책 추천 모델의 추천 결과 정확도를 계산

```
p2p => response id:  10 1  prediction:  1  accuracy:  1.0
mchange => response id:  27 2  prediction:  2  accuracy:  2.0
dpage => response id:  29 3  prediction:  3  accuracy:  3.0
flood => response id:  30 4  prediction:  7  accuracy:  3.75
hijack => response id:  45 5  prediction:  4  accuracy:  4.35
guzzle => response id:  46 6  prediction:  5  accuracy:  4.85
access => response id:  54 7  prediction:  6  accuracy:  5.2785714285714285
Total : 0.828
```

<정책 추천 모델의 정확도 계산 예시>

· 정확도 계산 결과 기준치(0.75) 보다 낮을 경우 정책 재 추천 프로세스 수행



<정책 재 추천 프로세스 동작 순서도>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

o 대응 정책 추천 모델 관리

- 모델 관리

· 학습이 끝난 모델의 경우 모델명을 클릭하여 학습에 사용된 파라미터와 모델 관련 정보 확인

Run Name	Created	Duration	Source	Models
recommend_2023-07-18 14:13:20	17 minutes ago	14.7min	prior	pyfunc
puzzled-newt-23	3 hours ago	14.6min	prior_spa...	soar_prior/2
bustling-vole-129	21 hours ago	59.3s	prior_spa...	-
recommend_2023-07-17 16:43:19	21 hours ago	9.0s	prior_spa...	-
recommend_2023-07-17 16:19:39	22 hours ago	14.8min	prior_spa...	soar_prior/1
recommend_2023-07-17 16:18:22	22 hours ago	23.9s	prior_spa...	-

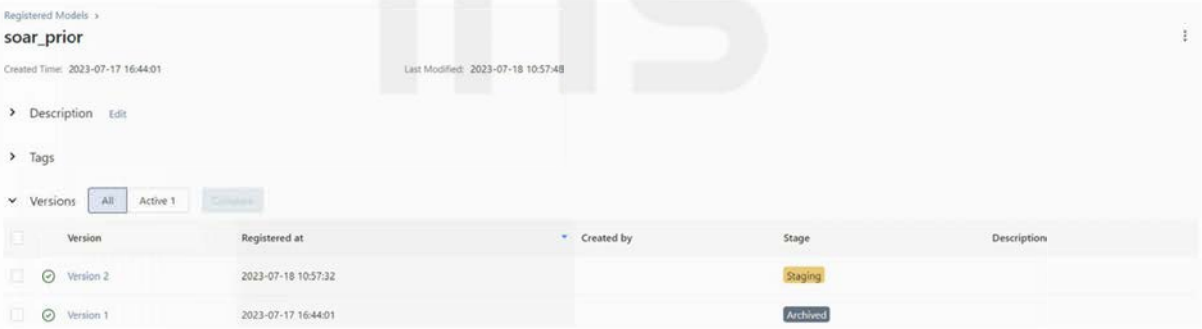
<대응 정책 추천 모델 관리 예시>

- 모델 등록

· 새로운 모델을 모델 관리 정보에 등록 및 관리하여 학습 데이터에 따라 성능의 차이를 보이는 모델로 선택하여 시스템 운용

- 모델 상태 정보 관리

· 모델 관리 정보에 등록된 모델에 대해 시스템 적용 여부, 학습 진행 여부, 개발 진행 여부 등의 상태 정보를 확인



<모델 상태 정보 관리 예시>

2) 추천 대응 정책의 강화학습 유효성 검증 기술 개발

o 강화 학습 기반 대응 정책 추천

- 강화학습 데이터 정의

· 이벤트 별 대응 이력 데이터, 보안 이벤트 처리 내역, 플레이북 실행 내역

- 강화학습 적용을 위한 준비 작업

· 상태 정보 / 상태 전이 / 알고리즘 / 보상 정의

o 상태 정의

- 학습하는 대상인 에이전트가 필요한 정보를 학습 데이터로부터 전처리 작업을 통해 매트릭스 형태로 가공

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

Event	Event_id	Risk	pp_mtime	pp_stime	Freq
ICMP를 활용한 거점 시스템 접근 시도	E001	7.6	10	45	182
SSL VPN 로그인 페이지 노출	E002	7.6	13	16	113
wget 이용 파일 다운로드 공격 시도	E003	7.6	18	54	279

대응정책 추천을 위한 이벤트 feature를 활용한 전처리

	feature1	feature2	feature3	feature4
E001	value	value	value	Value
E002	value	value	value	value
⋮	0	0	0	0
	…	…	…	…

전체 이벤트 개수(54) x feature(4) 개수 행렬

<이벤트 feature를 활용한 전처리 작업>

o 상태 전이 정의

- 강화학습의 환경이 다음 상태로 진행될 때 해당 이벤트의 feature를 삭제

	feature1	feature2	feature3	feature4
E001	value	value	value	Value
E002	value	value	value	value
⋮	0	0	0	0
	…	…	…	…

Predict : E002
Transition : E002 feature delete

	feature1	feature2	feature3	feature4
E001	value	value	value	Value
E002	0	0	0	0
⋮	0	0	0	0
	…	…	…	…

<강화학습을 위한 상태 전이 예시>

o 강화학습 알고리즘 선정

- 테스트 데이터 구성
  - 처리해야 하는 이벤트 리스트의 최대 이벤트 수 : 10
  - 이벤트 리스트 수 : 100
  - 지표 : min-max scaled nDCG
- 보상 함수 정의
  - 에이전트가 행동을 취할 때마다 보상을 주는 것이 아닌 모든 이벤트에 대한

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

예측을 완료한 후 종합적으로 평가하여 보상을 부여

· 종합적인 평가 보상을 위한 Custom Reward Function 정의

정답	drupal	wget	dbport	icmp
예측	icmp	wget	druap	dbport

➡ Reward Func.(true, pred) = reward

· 순서를 평가하기 위해 NDCG 지표를 활용하여 보상함수 정의

$$F(true, pred) = \frac{DCG - Constant\ DCG}{IDCG - Constant\ DCG}$$

$$DCG = \sum_{i}^{prediction\ order} \frac{rel_i}{\log(2+i)}, \quad IDCG = \sum_{i}^{ideal\ order} \frac{rel_i}{\log(2+i)}, \quad Constant\ DCG = \sum_{i} \frac{constant\ rel_i}{\log(2+i)}$$

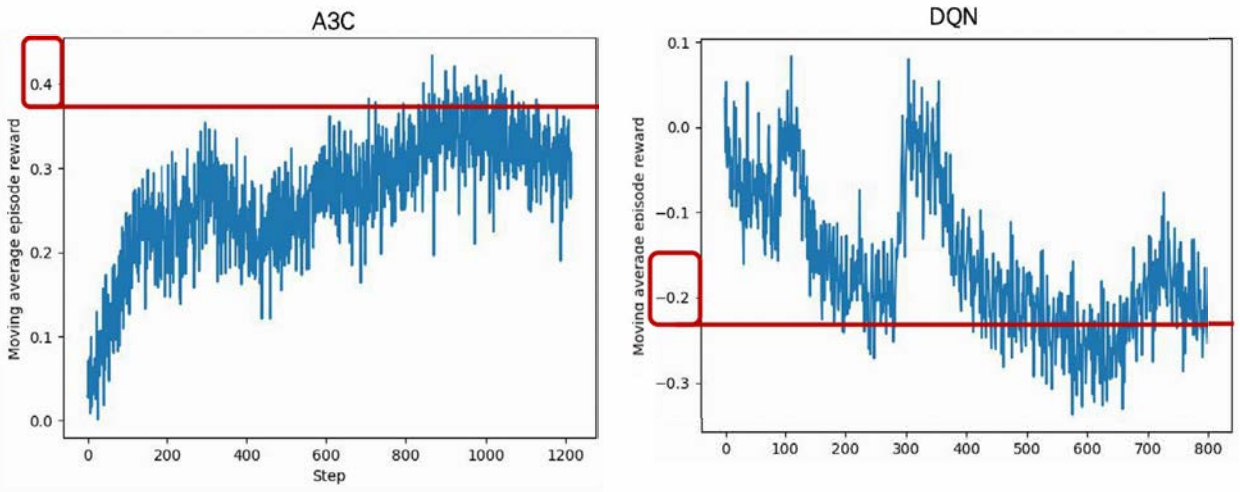
- rel_i는 정답 순서 index, $constant\ rel_i$는 정답 순서에서 중간 값에 해당하는 index를 의미함.

```
def reward_func(target, prediction):

    mdcg = cal_dcg(target, target, median=True)
    dcg = cal_dcg(target, prediction)
    idcg = cal_dcg(target, target)

    return (dcg - mdcg)/(idcg - mdcg)

def cal_dcg(target, prediction, median=False):

    dcg = 0
    for i, item in enumerate(prediction):
        if median:
            relevance_score = (len(target) + 1)/2
        else:
            relevance_score = (len(target) - target.index(item))
            idx = target.index(item)
            target[idx] = target[idx] + "__"
        dcg += relevance_score/(math.log10(i + 2))

    return dcg

def reward_func(true, pred):

    equal_cnt = 0
    cnt_list = list()

    for i,x in enumerate(zip(true, pred)):
        if x[0] == x[1]:
            equal_cnt += 1
        cnt_list.append(equal_cnt/(i+1))

    return sum(cnt_list)/len(cnt_list)
```

<보상 함수 정의 및 적용 프로그램 코드>

- DQN, A3C, PPO 등과 같은 알고리즘을 대상으로 비교 실험 진행
- A3C, DQN 학습 결과 비교
  · 학습을 진행하는 동안 획득한 보상 점수 비교
  · A3C는 점진적 증가하였으나 DQN은 감소

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



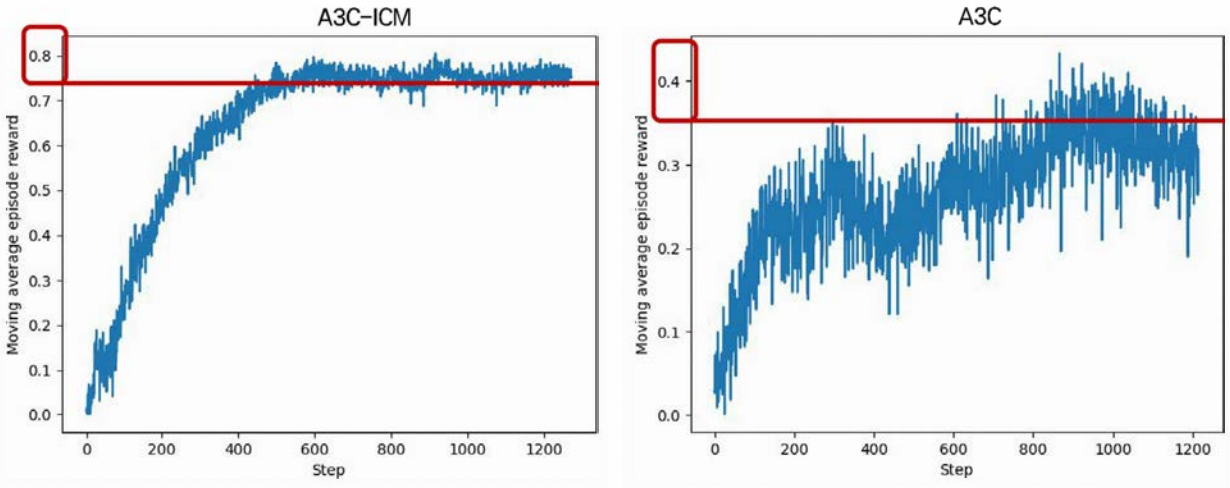
<A3C, DQN 알고리즘 대상 비교 실험을 통한 학습 결과 비교>

```
while self.curr_episode < self.num_episodes:
    obs, _, _ = self.env.reset() epi_seed = self.curr_episode % len(self.env.episode_ids))
    buffer_s, buffer_a, buffer_r, buffer_s_, buffer_a_onehot = [], [], [], [], []
    epi_reward = 0

    while True:
        obs = torch.tensor(obs)
        obs = obs.unsqueeze(0).float()

        act = self.select_action(obs)
        next_obs, reward, done = self.env.step(act)
        epi_reward += reward

          add intrinsic reward
         next_obs_tensor = torch.tensor(next_obs).unsqueeze(0).float()
         action_onehot = F.one_hot(torch.tensor([act]), num_classes=self.n_actions).float()
         intrinsic_reward = self.compute_intrinsic_reward(obs, next_obs_tensor, action_onehot)
         reward += intrinsic_reward/10

        buffer_s.append(obs)
        buffer_a.append(act)
        buffer_r.append(reward)
         buffer_s_.append(next_obs_tensor)
         buffer_a_onehot.append(action_onehot)

        if done or self.step_done & self.update_gradient == 0:
            self.update_global_gradient_and_pull_parameter(next_obs, done, buffer_s, buffer_a, buffer_r, buffer_s_, buffer_a_onehot)
            self.update_global_gradient_and_pull_parameter(next_obs, done, buffer_s, buffer_a, buffer_r)

        if done:
            break

        obs = next_obs
        self.step_done += 1
    self.curr_episode += 1

    save_and_record(self.client, self.run_id, self.global_episode_id, self.global_episode_reward, epi_reward, self.log_period)

self.reward_queue.put(None)
```

<A3C 알고리즘 적용 프로그램 코드>

- A3C-ICM , A3C 학습 결과 비교
  - 학습을 진행하는 동안 획득한 보상 점수 비교
  - A3C-ICM은 점진적 증가하다 일정 수준을 유지하며 A3C보다 높은 보상 획득

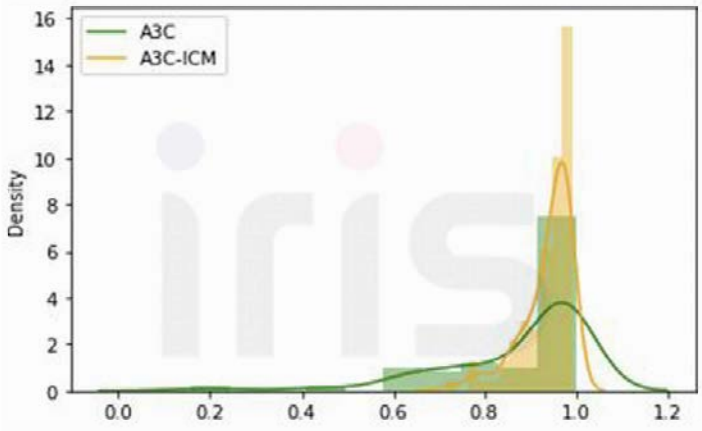
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



<A3C-ICM, A3C 알고리즘 대상 비교 실험을 통한 학습 결과 비교>

- 결과 분석

  · A3C, A3C-ICM 알고리즘을 비교한 결과, A3C-ICM의 점수 분포가 1에 가깝게 분포하며 상대적으로 A3C-ICM의 예측이 정확함



<A3C, A3C-ICM 알고리즘 대상 비교 실험 결과>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

세부 기술 ④ SOC 통합 운영 및 자동화 플랫폼 개발

□ 연구 목표

o 이기종 보안장비의 보안사고 자동 대응 - 검증 기술 개발

o 보안관제 업무 프로세스 최적화를 위한 프로세스 마이닝 기술 개발

o SOC 통합 운영 및 자동화 플랫폼 개발

□ 연구 목표별 추진 실적

연구목표	이기종 보안장비의 보안사고 자동 대응 - 검증 기술 개발

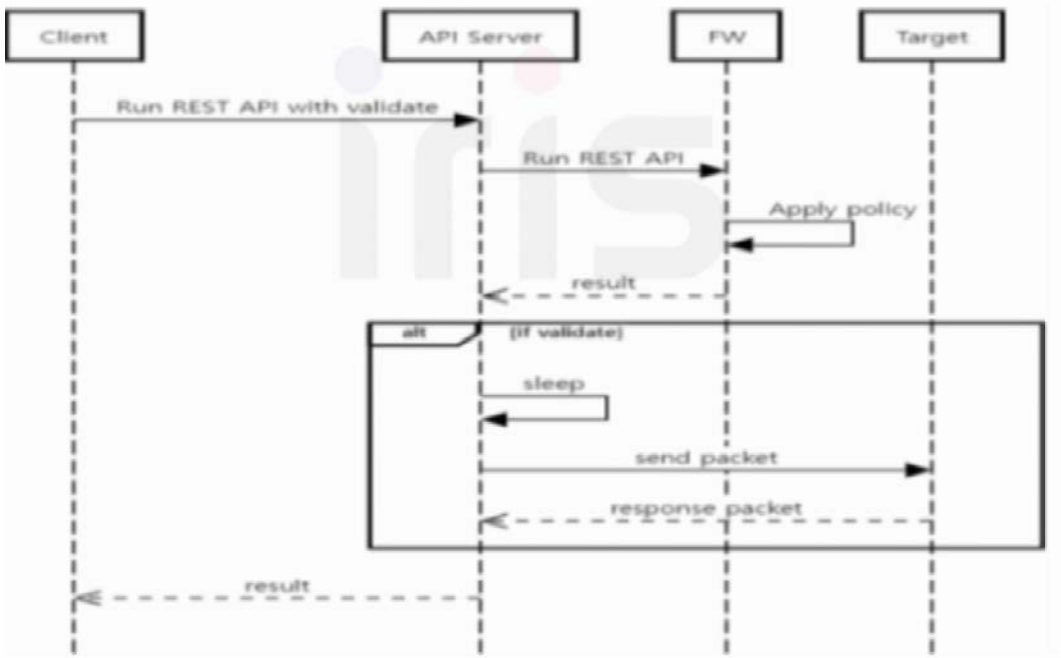
세부 내용	
	1) 이기종 보안 장비별 보안 정책(탐지·차단) 적용 상태(반영 여부) 검증 기술 개발
	2) 보안 정책(탐지·차단) 적용에 따른 보안위협 탐지 및 차단 검증 기술 개발

o 이기종 보안 장비별 보안 정책 적용 상태 검증 API 개발 기술 설계 및 개발

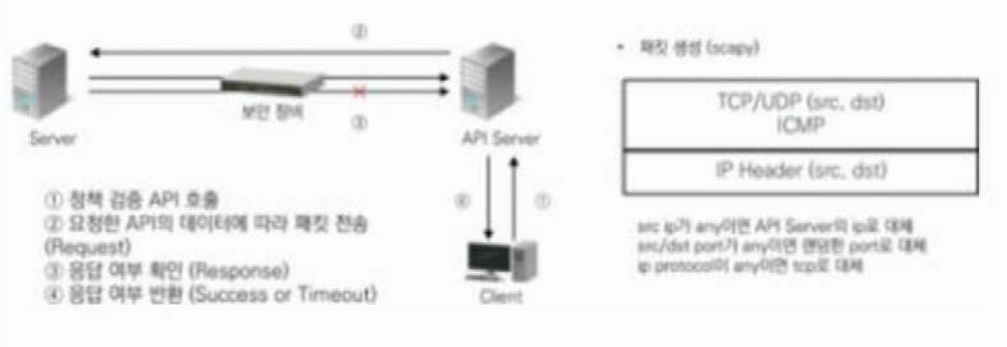
- 보안 장비에 검증 기능이 있는 경우와 없는 경우를 구분하여 정책 적용 검증 수행

① 정책 검증 기능이 존재할 경우 REST API 규격 실행 시 인자 값을 통해 자동 검증을 수행

※ 보안 장비에 정책 적용 까지 sleep 모드 후 적용이 완료되면, 정책 검증 반환 값 확인



② 정책 검증 기능이 존재하지 않는 경우 차단된 ip, port등의 정보를 기반으로 패킷 생성하여 전송하는 기능 개발



국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

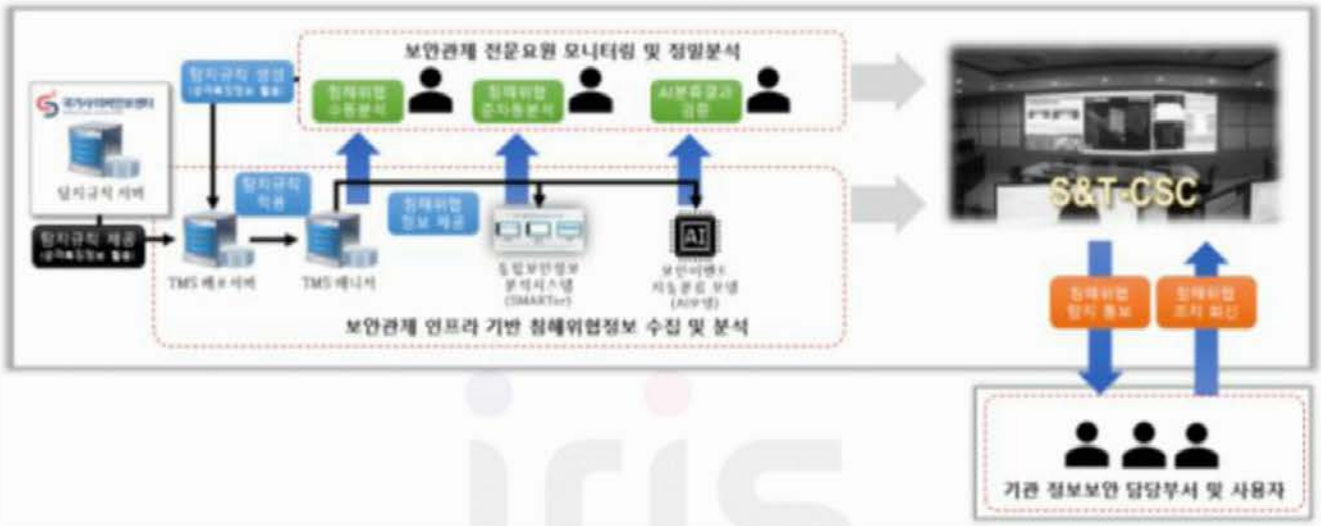
연구목표	보안관제 업무 프로세스 최적화를 위한 프로세스 마이닝 기술 개발

세부 내용	1) 사이버 위협정보 탐지 기술과 업무 프로세스 간의 상관관계 분석
	2) 사이버 보안관제 업무 프로세스 최적화 모델 설계
	3) 보안관제 프로세스 별 필수업무 특징화 및 자동분류 모델 구축

1) 사이버 위협정보 탐지 기술과 업무 프로세스 간의 상관관계 분석

o 사이버 위협정보 탐지 기술별 업무 프로세스 영향도 분석

- CTI활용에 따른 업무 프로세스 개선도 분석
- 보안이벤트 자동분석 모델 개발에 따른 업무 프로세스 개선도 분석



2) 사이버 보안관제 업무 프로세스 최적화 모델 설계

o 보안관제 단계별 필수업무 정의 및 단위업무 별 소요시간 측정

- 단위업무 분석 및 보안관제 전문 인력 인터뷰를 통한 업무 병목 포인트 점검
- 각 병목 포인트 해결 방안 도출 및 업무 프로세스 최적화 방안 설계
- 보안이벤트명/보안이벤트 카테고리별 자동분류 모델 개발 및 적용 방안 설계

3) 보안관제 프로세스 별 필수업무 특징화 및 자동분류 모델 구축

o 보안관제 단계별 필수업무 자동화 및 템플릿화

- 업무 개선방안(보안사고별 대응 방안 및 자동처리 가능한 업무 도출, 사고별 메일 양식 템플릿화, 보안이벤트 중복 처리 방지 방안) 도출

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- 인공지능 기반 보안이벤트 자동분류 모델 구축·적용을 통한 이벤트 분석 속도 향상
- CTI/XAI 적용을 통한 보안이벤트 수동분석 및 검증 시간 단축
- 업무 개선방안 적용 전후 비교 및 침해사고 대응 신속도 개선율 도출

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

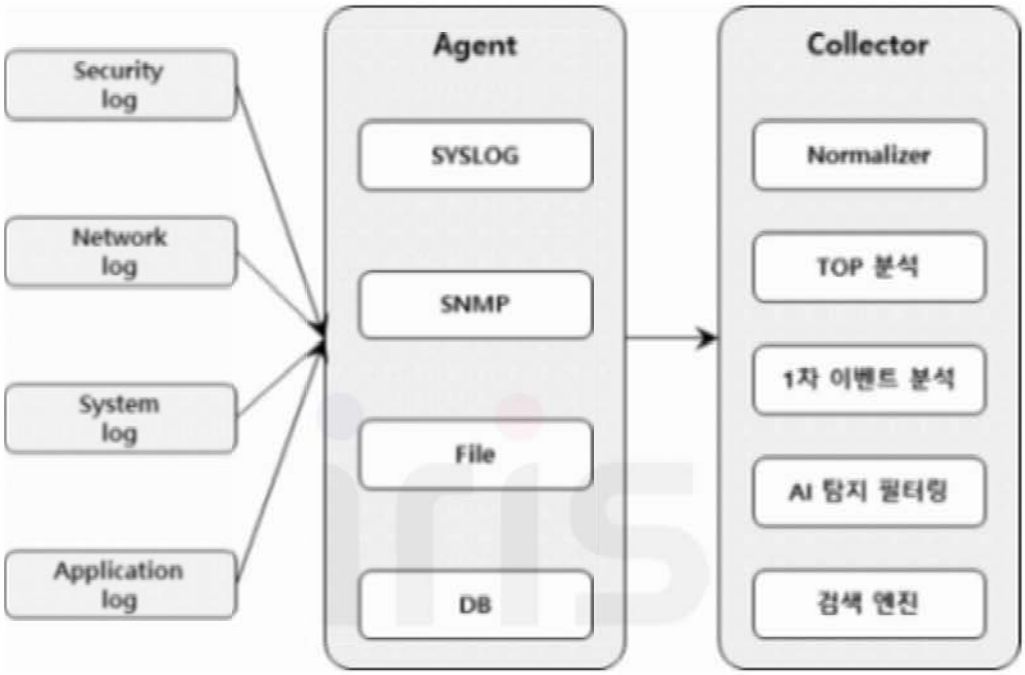
연구목표	SOC 통합 운영 및 자동화 플랫폼 개발

세부 내용	1) 연동·탐지, 분석, 대응 기술의 연동 인터페이스 설계 및 개발
	2) 연동·탐지, 분석, 대응 기술의 통합 연동 및 자동화 플랫폼 개발
	3) 단위 시간별 통계 및 관련 보고서 자동 생성 기술 개발

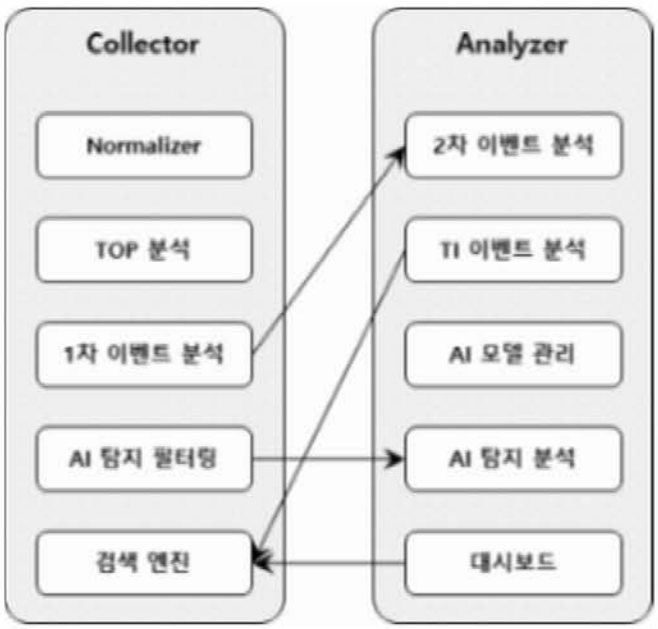
1) 연동·탐지, 분석, 대응 기술의 연동 인터페이스 설계 및 개발

o 연구용 SOAR 시스템 기반 주요 기능 통합 인터페이스 설계 및 개발

- 수집/저장 기능 인터페이스 설계 및 개발



- 분석/탐지 기능 인터페이스 설계 및 개발

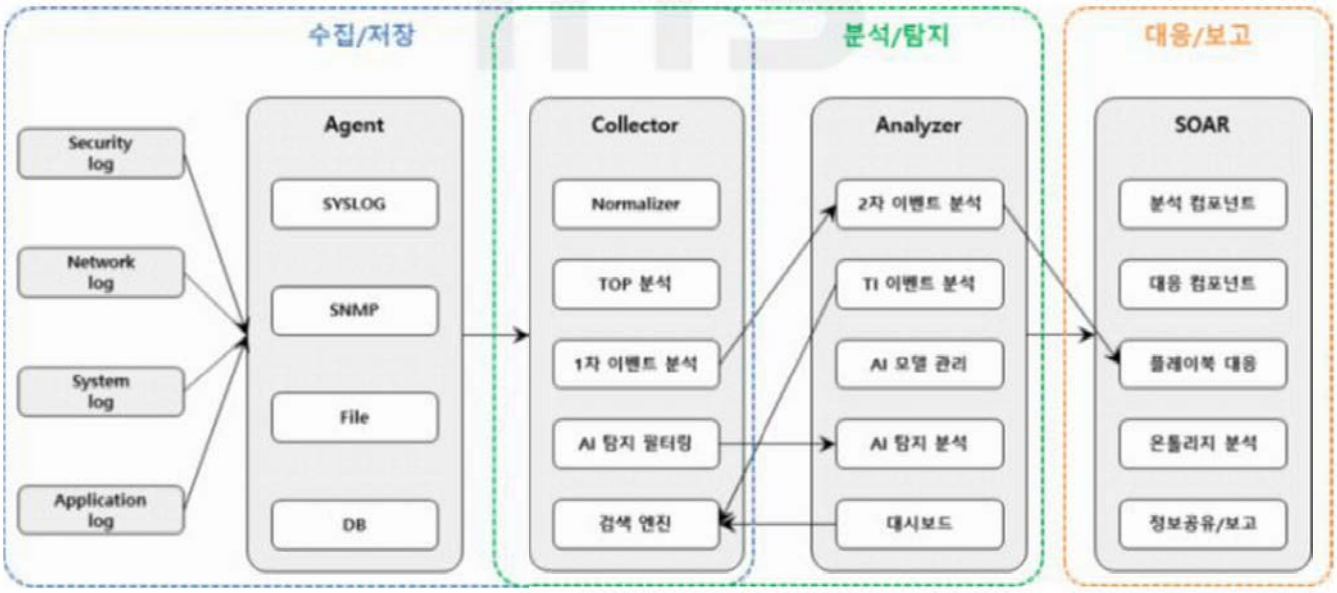


국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- 대응/보고 기능 인터페이스 설계 및 개발

2) 연동·탐지, 분석, 대응 기술의 통합 연동 및 자동화 플랫폼 개발

o 연동·탐지, 분석, 대응 기술 통합 플랫폼 개발



<연동 인터페이스의 주요 기능과 주요 기술 연동 방안>

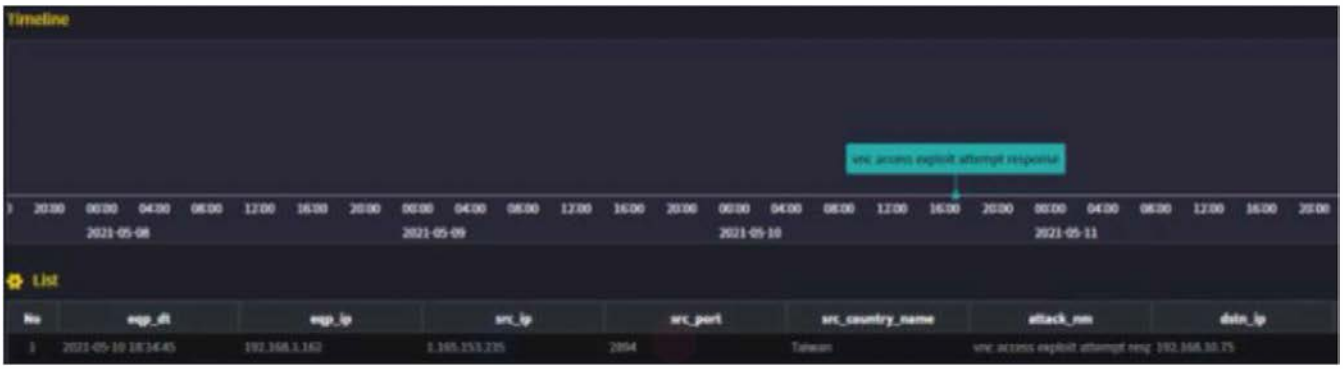
주요 기능	설명
AI 탐지 필터링, AI 탐지 분석	· 정오탐 분류 AI 모델 연동
대시보드	· 플레이북 이벤트 우선 순위 추천 기능 연동
SOAR	· 플레이북 생성 및 검증용 REST API 연동
대응 컴포넌트	· 최적 대응 추천 기능을 대응 컴포넌트 형태로 호출하여 연동
플레이북 대응	· 탐지 이벤트 우선 순위 추천 기능 연동

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

3) 단위 시간별 통계 및 관련 보고서 자동 생성 기술 개발

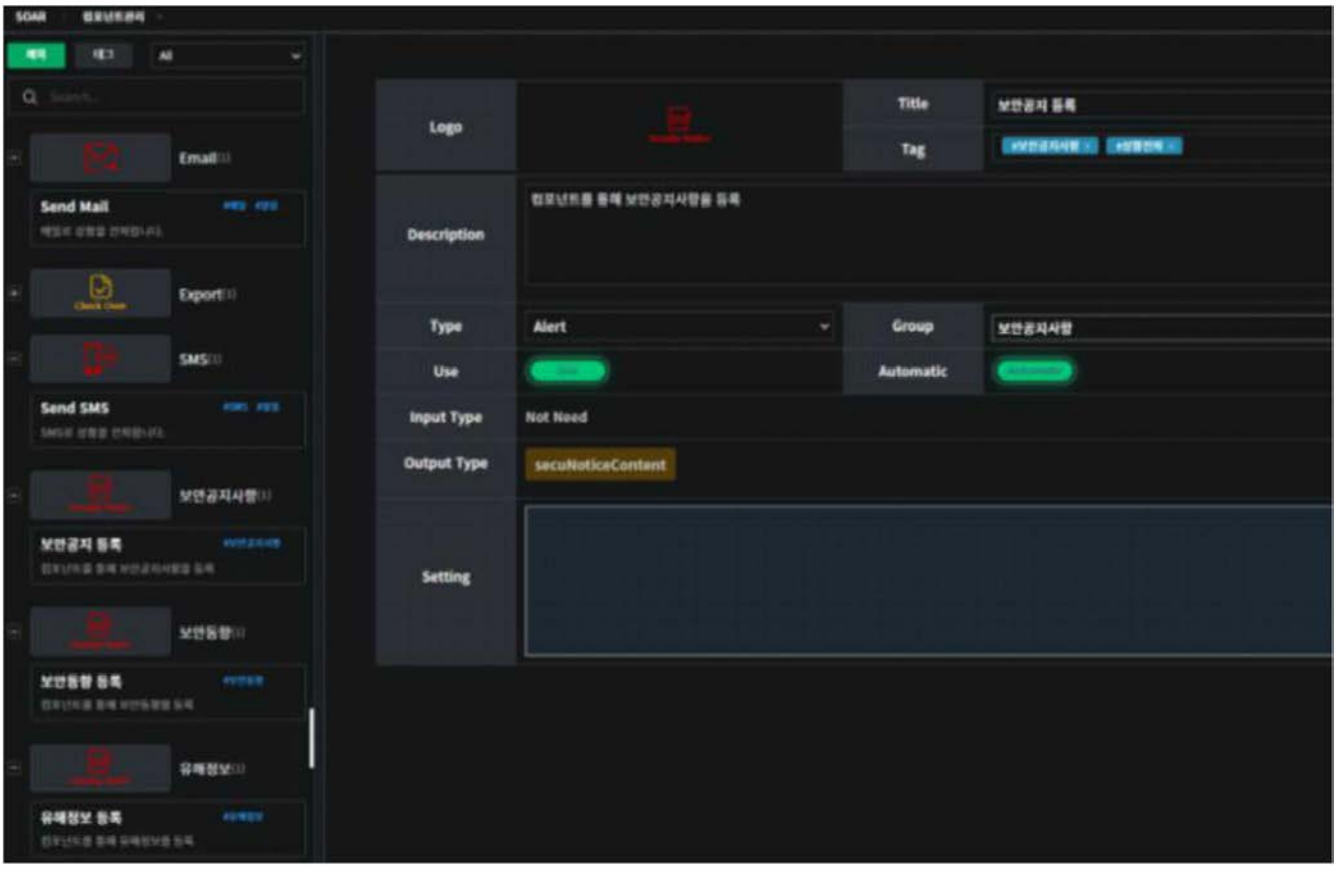
o 이벤트 로그 수집 및 단위 시간별 통계 분석 기술 개발

o 보안 이벤트별 시계열 분석 기술 개발



o 보안 이벤트 분석 및 대응 결과 보고서 생성 컴포넌트 개발

- 관제 대상마다 요구하는 결과 보고서(E-Mail, SMS, 게시글 등록 등)의 유형이 상이함
- 위와 같은 요구사항을 반영하여 다양한 유형의 결과 보고서 생성용 컴포넌트 개발



국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

세부 기술 ⑤ 사이버 보안 오케스트레이션 및 자동 대응 요소 기술 실증

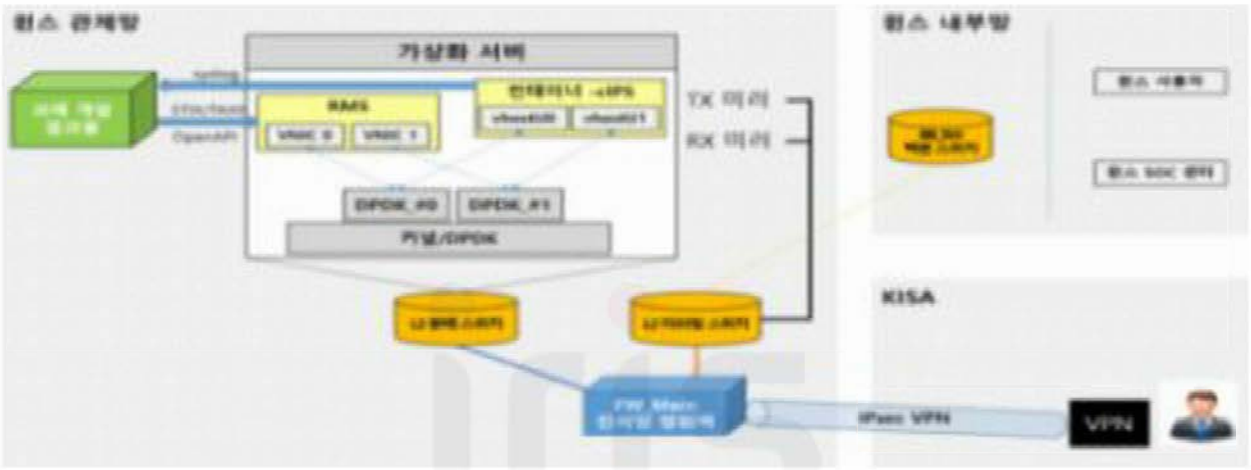
□ 연구 목표

- o 이기종 보안 장비 연동·탐지 및 자동 대응 요소 기술 실증
- o 보안 관제 플레이북 자동 생성 및 의사결정 자동 추천 기술 실증
- o 국가과학기술연구망을 활용한 SOC 통합 플랫폼 요소기술 실증

□ 연구 목표별 추진 실적

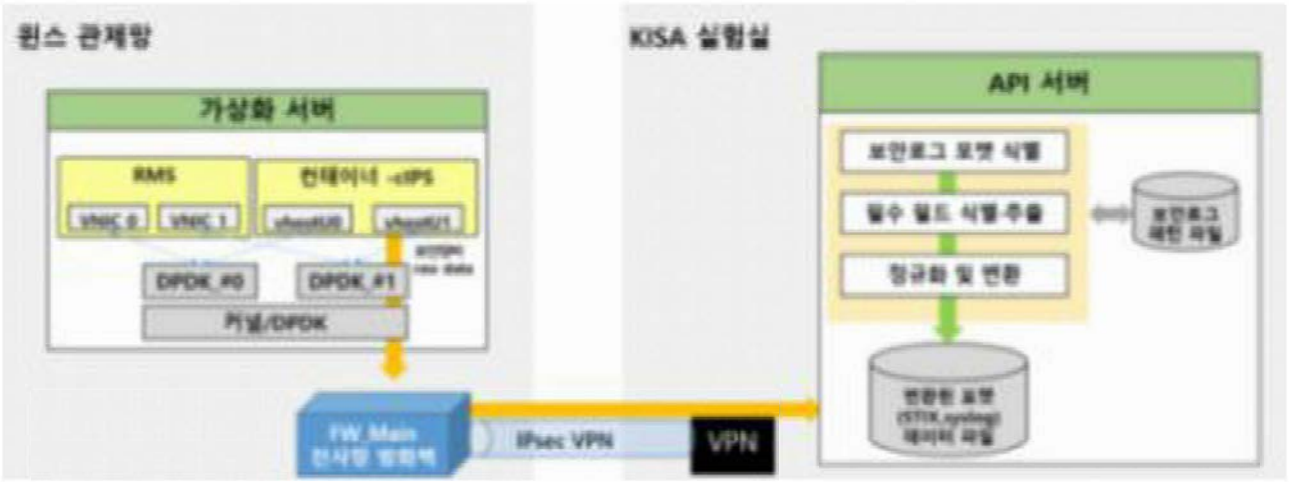
연구목표	이기종 보안 장비 연동·탐지 및 자동 대응 요소 기술 실증

o (실증 환경 구축) 민간 SOC 업체 실증 환경 인터뷰 분석 및 원격 접속용 VPN, 포트포워딩, 내·외부 접근 정책 구현



<실증 환경 구성도>

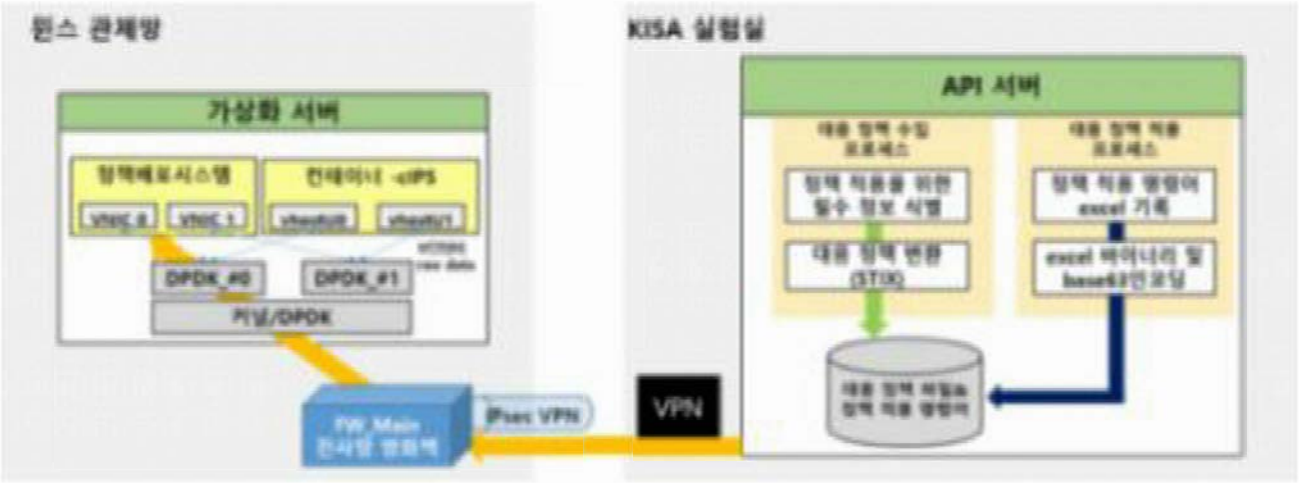
- (연동 시스템 실증) 연동 API 기반 SOC 보안 장비 raw data 수신 후 보안 로그 포맷 식별, 필수 필드 식별·추출, 데이터 파싱, 변환(sitx, syslog)



<연동 시스템 실증 환경 구성>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

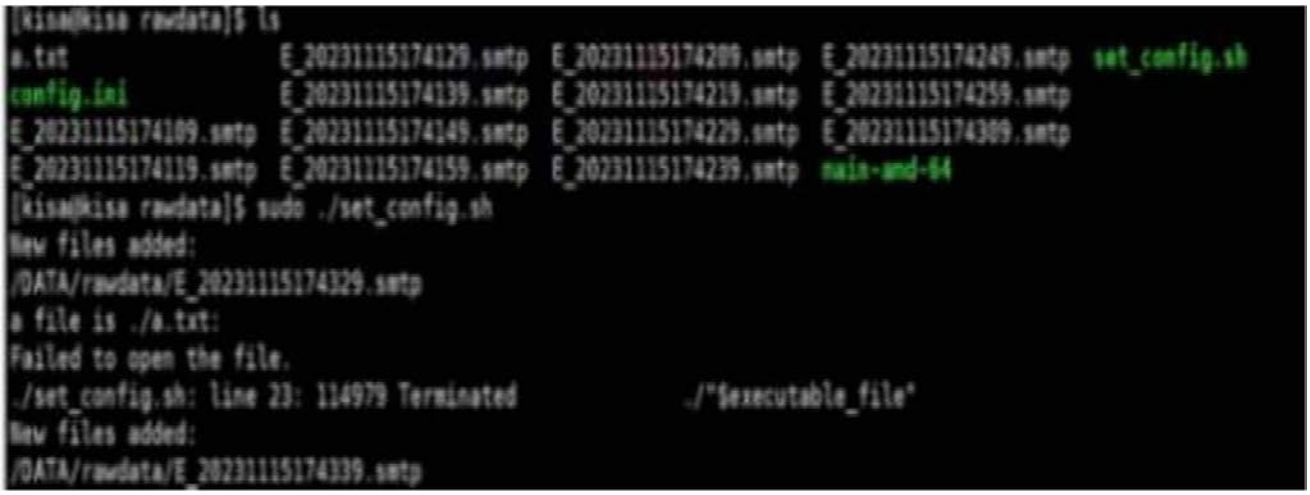
- (정책 자동 적용 시스템 실증) SOC 보안 정책 전송용 명령어 정보 매핑 및 보안 정책 적용/검증 환경설정 후 실증



<정책 자동 적용 시스템 실증>

o (실증 결과) 민간 SOC 업체 환경 구성 기반 연동 및 정책 적용 API 성능 측정

- (연동 API) 민간 SOC 업체 IPS 보안 장비 raw data 대상 STIX 또는 syslog 변환율 100% 측정 (24시간 수집 기준, 원본:864,000개, 변환 864,000개)



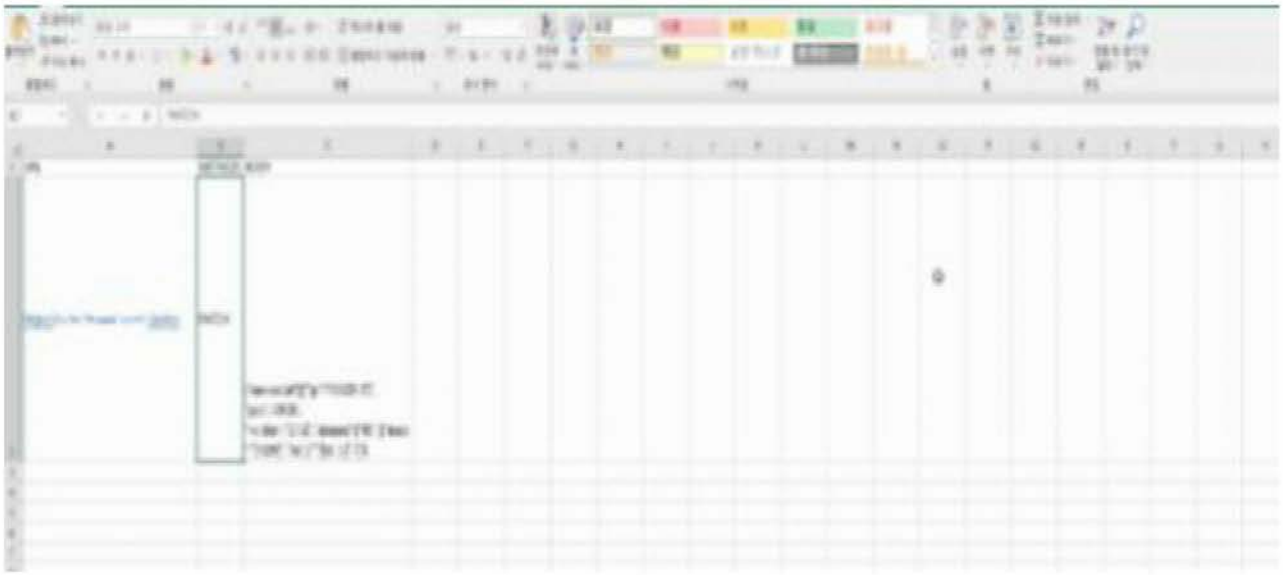
<보안 장비 내 송수신 모듈 삽입>

<로그 연동 전체 결과>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

<로그 연동 상세 결과>

- (정책 적용 API) 민간 SOC 업체의 정책 관리 시스템에 정책 적용 API를 통해 명령어 전송
- (정책 적용 API 프로세스) 정책 적용을 위한 REST API 규격서 등록 →API 토큰 발급→REST API 규격 id 조회 →정책 저장 API 호출→ 정책 적용 API 호출 → 명령어 전달 및 적용



<정책 적용을 위한 명령어 저장>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

<명령어 저장된 파일 업로드>

<IP 차단 명령어 전송 API request>

<정책 적용 완료 화면>

연구목표	・보안 관제 플레이북 자동 생성 및 의사결정 자동 추천 기술 실증 ・국가과학기술연구망을 활용한 SOC 통합 플랫폼 요소기술 실증

o 국가과학기술연구망 및 실제 SOC 데이터를 활용한 통합 플랫폼 요소 기술 실증

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- 실증을 위한 요소 기술 설치 서버 상세 성능

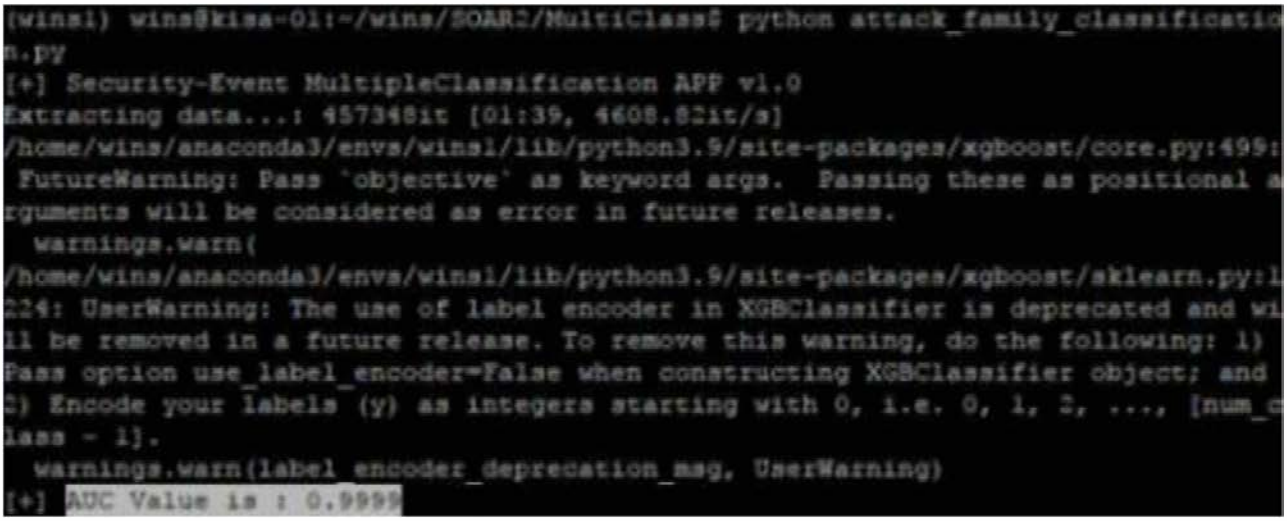
<실증 환경 서버 상세 성능>

	성능	
서버 (3식)	CPU	Intel(R) Xeon(R) Gold 6246R CPU @ 3.40 Ghz
	RAM	256 GB
	HDD	48 TB
	OS	Ubuntu 20.04.3 LTS 64 bit
	성능	
서버 (1식)	CPU	Intel(R) Xeon(R) Gold 6246R CPU @ 3.40 Ghz
	RAM	256 GB
	HDD	48 TB
	OS	CentOS Linux release 7.9.2009

- 이기종 보안장비 연동 기술 실증
  - 이기종 보안 장비 14종에서 수집한 787개 유형의 로그를 학습 데이터로 전처리
  - 이기종 보안 장비에 대한 로그 인식 및 변환율 95.9% 측정 완료

<이기종 보안 장비 로그 인식 및 변환율 측정 결과>

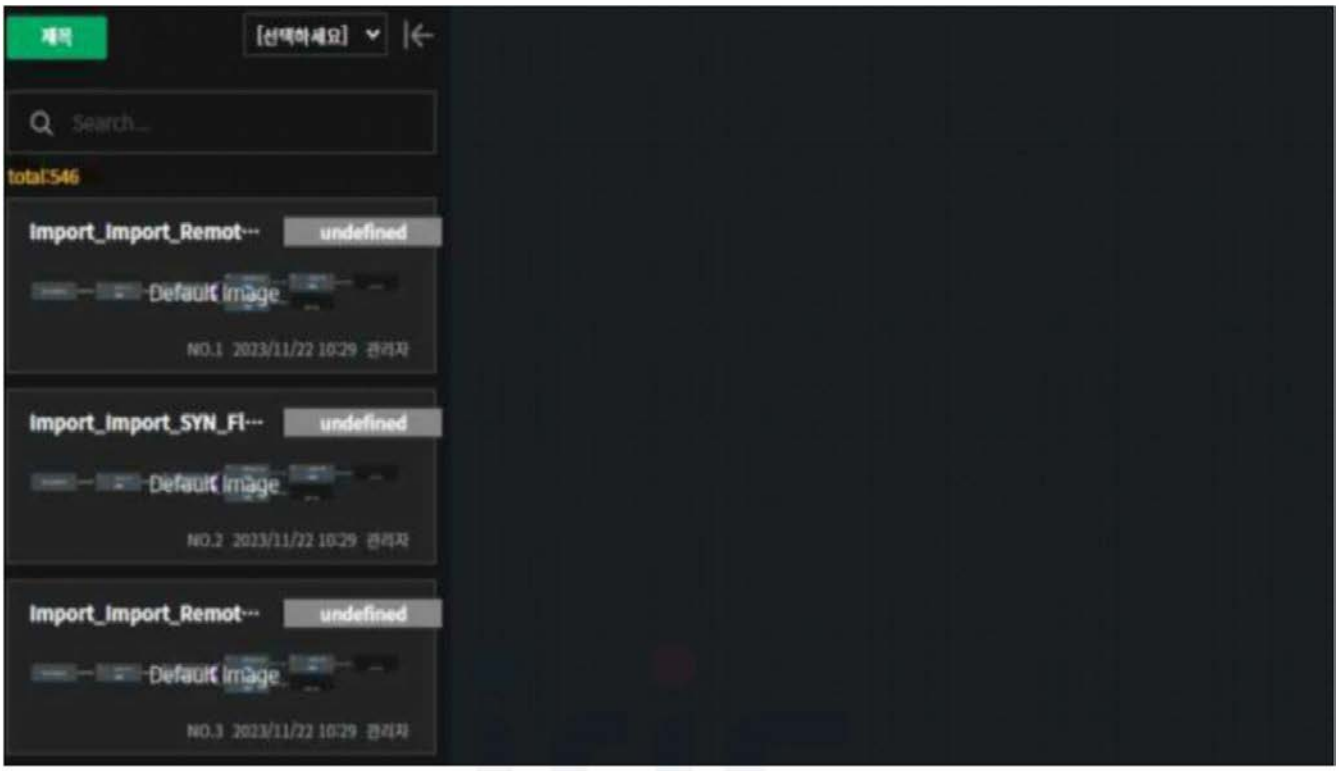
- 이상행위 탐지 기술 실증
  - 이기종 보안 장비에서 수집한 16,661,447개의 이벤트를 학습 데이터로 전처리
  - 이상행위 탐지 정확도 측정 결과 AUC 0.9999 측정 완료



<이상행위 탐지 정확도 측정 결과>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- 위협분석 자동화 및 의사결정 지원 기술 실증
  - 공동연구기관 및 업무협약체결 기관의 대응이력 데이터 수집
  - 대응이력 데이터를 학습하는 플레이북 자동 생성용 AI 모델 설계 및 개발
  - 플레이북 자동 생성 결과 평균 538개의 플레이북 자동 생성 완료



<플레이북 자동 생성 결과>

  - 대응이력 데이터를 학습하는 보안 이벤트 우선순위 선정용 AI 모델 설계 및 개발
  - 보안 이벤트 우선순위 선정 결과 정확도 83.3% 측정 완료

<이벤트 우선순위 선정 기능 실행 결과>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

2-4. 4차년도 연구 수행 내용 및 성과

세부 기술 ① **이기종 보안장비 연동 API 공개 및 이상행위 탐지 모델 고도화**

□ 연구 목표

o 이기종 보안 장비 데이터 정규화 및 대응 정책 적용 API 개발·공개

o AI·빅데이터 기반 이기종 보안 장비 이상행위 탐지 성능 향상 기술 고도화 개발

o 공개 보안 위협 인텔리전스 정보 수집 기술 고도화

□ 연구 목표별 추진 실적

연구목표	이기종 보안 장비 데이터 정규화 및 대응 정책 적용 API 개발·공개

세부 내용	1) 네트워크 보안 장비의 대응 정책 적용을 위한 연동 포맷 공개
	2) 실증처를 통해 수집된 보안 장비 로그 데이터 정규화 API 개발·공개

1) 네트워크 보안 장비의 대응 정책 적용을 위한 연동 포맷 공개

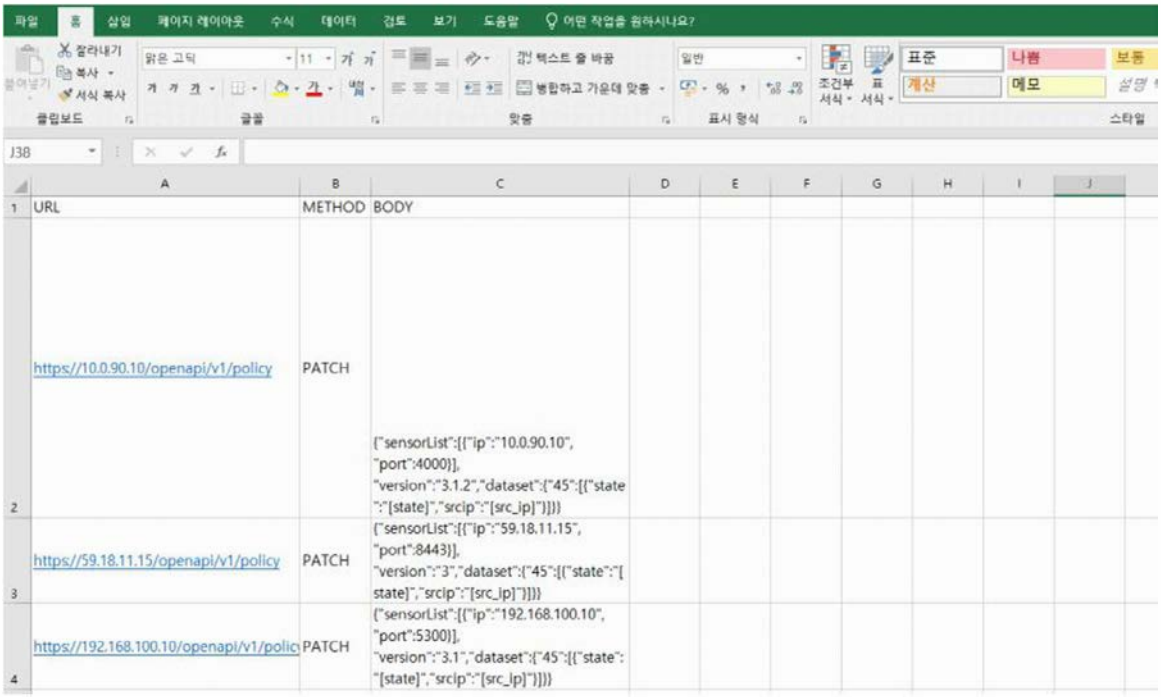
o 주요 보안 장비 제조사(윈스, 안랩, 시큐아이 등)의 정책 적용 및 상호운용성 방안 분석

- API 명세서를 이용한 정책 자동 적용 기술 호환성 검토

```python
import hashlib···

# API 키 및 시크릿 키 설정
access_key = '                                          9'
secret_key = '                                          s='

try:
    # 메서드 및 API URL 설정
    method = sys.argv[1]
    api_url = sys.argv[2]

    if method is None or api_url is None:
        raise ValueError("Usage: python apikey_genr.py <Method> <Api URL>")

    # timestamp 값을 1700200195로 고정
    timestamp = '1700200195'

    # 메시지 생성
    msg = f"{method} {api_url}\n{timestamp}\n{access_key}"

    print(f"msg: {msg}")

    # 서명 생성
    signature = hmac.new(secret_key.encode('utf-8'), msg.encode('utf-8'), hashlib.sha256)

    # 중간 결과 출력
    print(f"Intermediate Result: {signature.hexdigest()}")

    # 서명을 Base64로 인코딩
    signature_base64 = base64.b64encode(signature.digest()).decode('utf-8')

    print(f"x-openapi-access-key: {access_key}")
    print(f"x-openapi-timestamp: {timestamp}")
    print(f"x-openapi-signature: {signature_base64}")

except Exception as e:
    print(e)
    raise ValueError('Signature generation failed')
```

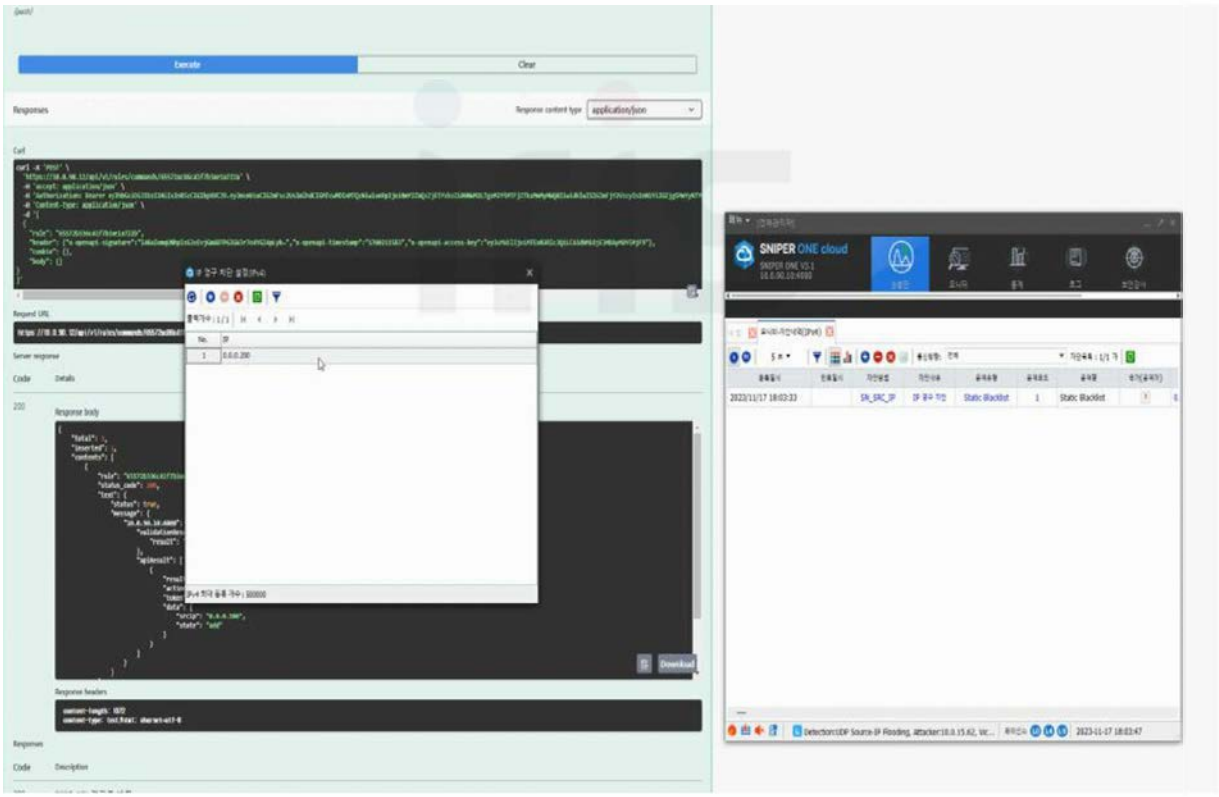
<상호 연동을 위한 API 키 및 환경 설정>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



	A	B	C
1	URL	METHOD	BODY
2	https://10.0.90.10/openapi/v1/policy	PATCH	{"sensorList":[{"ip":"10.0.90.10", "port":4000}], "version":"3.1.2","dataset":{"45":[{"state":"[state]","srcip":"[src_ip]"}]}}
3	https://59.18.11.15/openapi/v1/policy	PATCH	{"sensorList":[{"ip":"59.18.11.15", "port":8443}], "version":"3","dataset":{"45":[{"state":"[state]","srcip":"[src_ip]"}]}}
4	https://192.168.100.10/openapi/v1/polic	PATCH	{"sensorList":[{"ip":"192.168.100.10", "port":5300}], "version":"3.1","dataset":{"45":[{"state":"[state]","srcip":"[src_ip]"}]}}

<정책 적용을 위해 csv파일에 명세서 기입>



<정책 적용 성공 화면>

- 호환성 검토 결과 API 기능을 통해 정책 적용이 가능한 모든 네트워크 보안 장비에 차단, 경고 등 정책 적용 가능함을 확인함

2) 실증처를 통해 수집된 보안 장비 로그 데이터 정규화 API 개발·공개

o 정규화 API 사용 가이드 등 기술 문서 작성 및 API 시범 운영을 위한 가상 환경 구축

- 정규화 API 호출 방식 및 요청/응답 형식, 데이터 규격 명세

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- 공동연구기관 대상 공개 및 추가 기능 요구사항 분석 및 의견 수렴

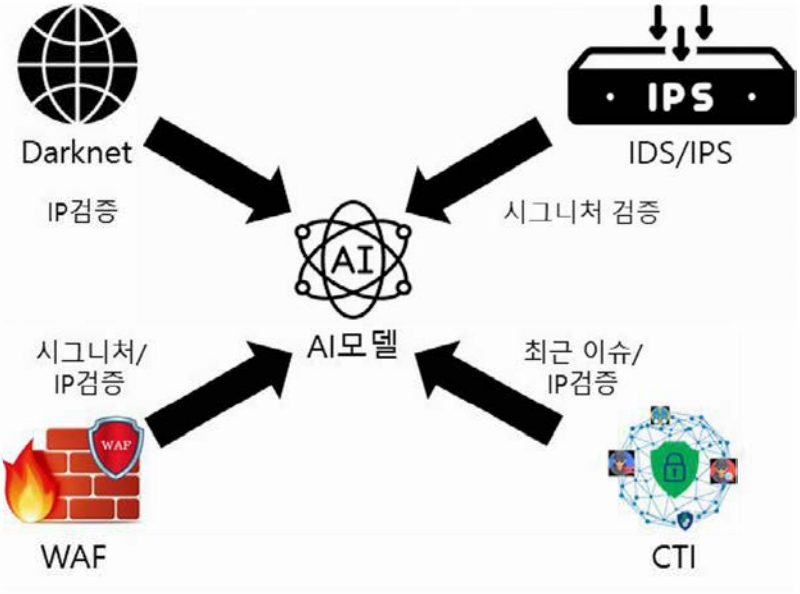
연구목표	AI·빅데이터 기반 이기종 보안 장비 이상행위 탐지 성능 향상 기술 고도화 개발

세부 내용	1) 이기종(3종 이상) 보안장비 데이터를 활용한 AI 연관분석 모델 개발·검증 및 구축
	2) 신속한 의사결정 지원을 위한 탐지 모델 성능평가 및 검증
	3) 신속한 의사결정 지원을 위한 AI 분석 및 탐지모델 최적화

1) 이기종(3종 이상) 보안장비 데이터를 활용한 AI 연관분석 모델 개발·검증 및 구축

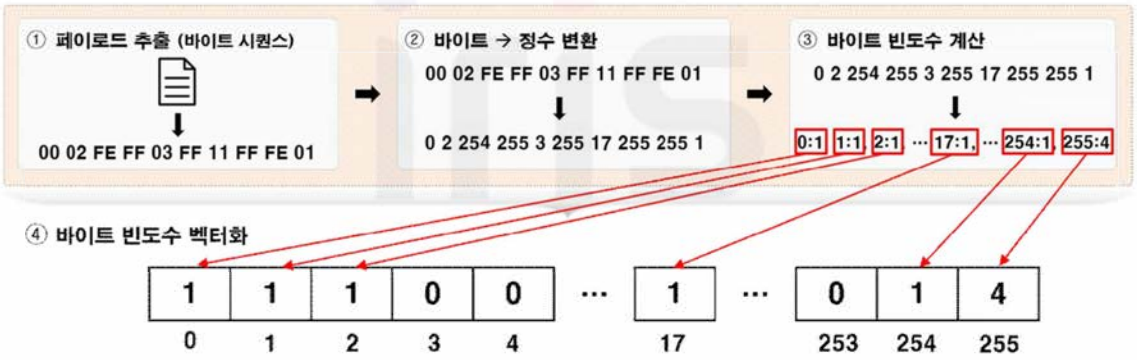
- AI 연관분석 모델 개발 및 검증을 위한 데이터 분석
  - NIDS, WAF, 다크넷*, CTI를 통해 수집된 데이터를 통합하여 AI모델 검증 및 최종 분류결과 도출 시 활용(연관분석 수행)
    * 미사용 IP의 집합, KISTI 과학기술사이버안전센터(Science and Technology-Cyber Security Center, S&T-CSC)에서 자체 구축 후 활용 중
  - 이를 위해 이기종 보안장비에서 공통으로 추출 가능한 5-tuple 및 페이로드 분석 후 AI모델 개발에 활용
  - 공통정보 기반 보안이벤트 유형별 행위특성 분석 (출발지·목적지 포트유형 중심)
  - KISTI 과학기술사이버안전센터(Science and Technology-Cyber Security Center, S&T-CSC) 자체 구축 다크넷 기반 비정상 트래픽 데이터 분석
  - 다크넷으로 유입된 패킷들을 분석, 패킷 송신자들을 유해의심 IP로 등록 및 관리
  - 불특정 다수를 대상으로 공격을 수행하는 공격자 IP일 가능성을 고려하여 AI·빅데이터 기반 이상행위 탐지 시 레퍼런스(Reference)로 활용
  - 과학기술연구망에 설치 및 운영 중인 NID(P)S(Network Intrusion Detection/Prevention System)의 보안로그를 분석하여 정/오탐 분류 및 AI모델 학습 데이터로 활용
  - 웹 애플리케이션을 대상으로 수행되는 사이버 공격들을 탐지·분석하기 위하여 기관별로 설치된 WAF(Web Application Firewall) 데이터 활용
    ※ SQL Injection, XSS 등 웹 어플리케이션 계층 공격 데이터 포함
  - 특정 기관을 타겟팅하여 침투를 시도하는 공격자와 그들의 공격패턴을 분석
  - CTI(Cyber Threat Intelligence) 정보 활용, 이기종 장비 간 탐지된 이벤트 데이터 신뢰도 향상

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



이기종 장비를 통한 AI모델의 분류 성능 향상 방안

- 페이로드 정보 바이트 통계 기반 특징추출 기술 연구
  - 보안이벤트 페이로드 내 바이트 정보를 정·오탐 보안이벤트 행위특성으로 간주
  - 페이로드 정보 내 바이트별 빈도수(바이트 히스토그램)를 추출하여 이기종 보안장비 이상행위 탐지모델 학습에 사용



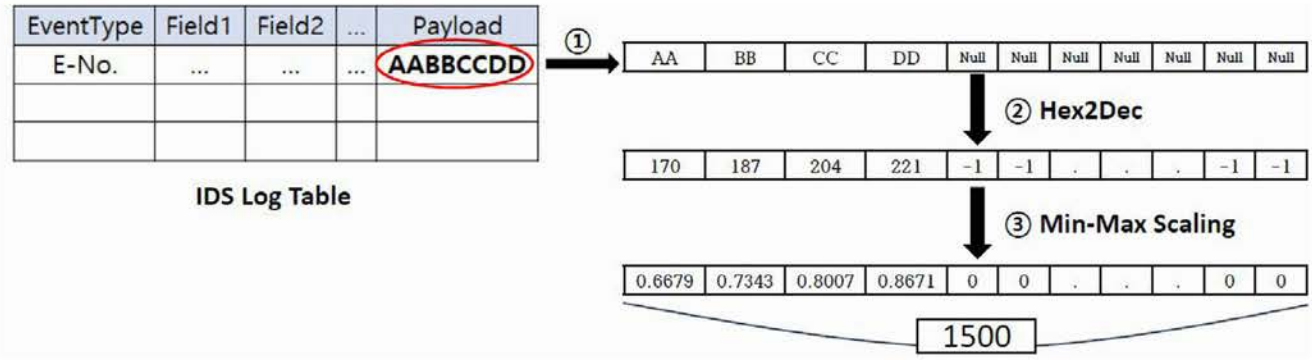
<페이로드 바이트 히스토그램 추출 방법 예시>

- 보안이벤트 유형별 통계분석 기반 학습에 유리한 공통 메타정보 3종 선정
  - 이기종 보안장비 공통정보 분석 단계에서 출발지·목적지 포트 및 페이로드 길이 정보 기준 페이로드 바이트 통계 및 유형이 상이한 것을 확인
  - 선정된 공통 메타정보 3종(출발지/목적지 포트, 페이로드 길이)과 페이로드 바이트 히스토그램을 결합하여 학습함으로써 이기종 보안장비 이상행위 탐지모델 성능 개선에 활용

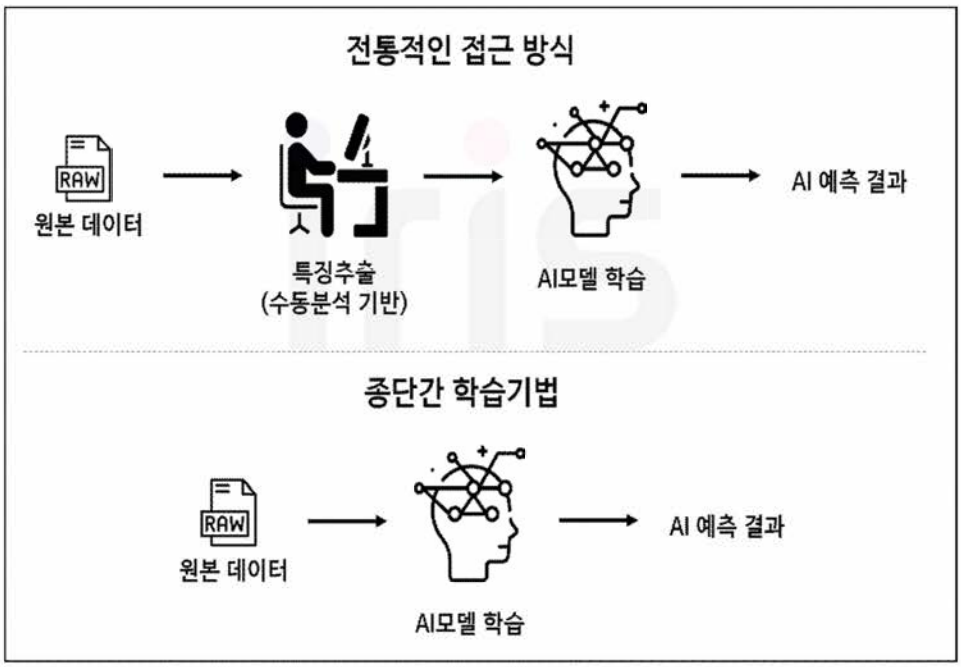
- 딥러닝 모델 기반 이기종 보안 이벤트 페이로드 종단간 학습기법 연구
  - 종단간 학습은 데이터 입력부터 결과 출력까지 사람의 개입 없이 수행되는 학습 기법으로 보안장비의 보안로그들을 사람의 개입 없이 정·오탐 판별이 가능하게 함
  - 데이터 분석, 특징 정보 추출 등 과정 생략 → 원본 데이터를 입력으로 사용
    ※ 이기종 보안장비에서 공통으로 추출되는 원시 페이로드를 사용

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- 종단간 학습 기법을 통해 AI 모델이 이기종 데이터로부터 특징정보 자동 추출 및 학습
- 유효한 종단간 학습 기반 AI 모델 생성을 위해 충분히 많은 데이터 필요
- 實 보안관제 환경의 이기종 보안장비에서 수집된 대량의 보안 이벤트를 활용한 네트워크 페이로드 종단간 학습 기반 보안관제 모델 생성·검증 기술 연구
  ※ 보안이벤트의 원본 페이로드를 특징공학 과정 없이 모델의 입력으로 사용



이기종 보안장비에서 추출한 페이로드 전처리과정 예시



기존 AI모델 학습기법과 종단간 학습기법 비교

o 신속한 의사결정 지원을 위한 탐지 모델 성능평가 및 검증

- 실환경 보안관제 데이터를 통한 탐지모델 학습
  - 실제 보안관제센터에서 수집된 이기종 보안장비 로그를 활용하여 페이로드 바이트 통계기반 학습 및 페이로드 종단간 학습을 통한 모델 개발
  - 모델 학습을 위해 정·오탐이 혼재된 41종 보안이벤트 선정(정·오탐 비율 약 3 : 97)
  * 모델 학습에 사용된 보안이벤트의 이벤트명(탐지패턴명)은 비공개 정보이므로 이벤트명 별 고유번호를 부여하여 임의 작성

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

Event-No	TP	FP	Event-No	TP	FP
E-269	2,509	10,252	E-2201	49	849
E-270	9,111	6,387	E-2256	2,092	1,616
E-311	2,912	4,874	E-2294	28,666	26,938
E-316	178	7,476	E-2312	6,532	53,282
E-320	1,062	2,721	E-2379	6,663	919,811
E-345	5,848	3,975	E-2510	271	8,587
E-552	396	5,303	E-2514	366	12,956
E-964	2,901	845	E-2515	1,026	31,501
E-1092	151	7,579	E-2522	934	4,236
E-1290	1,653	1,499	E-3138	296	23,668
E-1563	156	1,779	E-3171	357	45,063
E-1566	195	13,071	E-3200	3,707	188,264
E-1576	926	1,297,940	E-3247	10,881	36,752
E-1594	358	9,393	E-3289	716	122,737
E-1762	24,550	1,236,068	E-3291	15,238	1,735,209
E-1783	248	3,281,722	E-3343	256	2,890
E-1908	3,163	1,070,410	E-3451	196	97
E-1934	21	4,148	E-3461	1,468	470,344
E-2136	200	1,344	E-3463	243	3,904
E-2145	4,676	10,824	E-3554	148,141	25,821
E-2152	236	5,760	**총**	**289,548**	**10,697,895**

검증을 위해 사용된 실환경 데이터셋 구성(41종)

- 알고리즘 비교를 통한 의사결정 지원 탐지 모델 성능 평가
  - 이기종 보안장비에서 수집된 데이터로부터 정·오탐을 효과적으로 분류(판별)할 수 있는 인공지능 알고리즘 파악을 위하여 실험 및 비교 분석 수행
  - 바이트 히스토그램을 활용한 모델의 성능을 측정하기 위하여 3개의 모델(일반적인 성능이 가장 높은 알고리즘 3종 선별)
  - 알고리즘별로 특징을 다르게 부여하고 각 모델의 성능을 측정
  - 페이로드만 활용하는 경우, 페이로드 간의 관계를 학습하기 위하여 Tree또는 Boosting계열의 알고리즘보다는 1차원 데이터에서 지역적 패턴을 감지하는데 효과적인 1D-CNN (One Dimensional Convolutional Neural Network) 선전하고 이를 가장 기본적인 딥러닝 모델인 MLP(Multi Layer Perceptron)와 비교
  - 실험결과 바이트 히스토그램과 원본 페이로드를 단독으로 사용하는 모델들의 성능이 높았으며, 이 중에서도 원본 페이로드만을 활용한 모델의 성능이 가장 우수하였음
  - 이러한 고성능 모델을 통해 이기종 보안데이터 정·오탐 분류를 신속하게 수행함으로써 보안관제의 정확도·신속도를 향상시킴

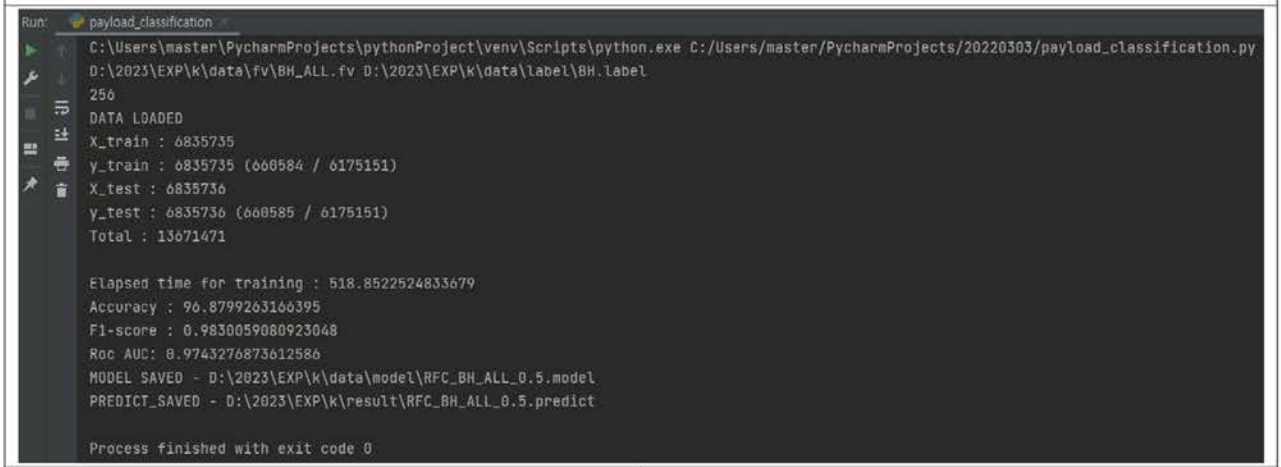
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

구분	실증 대상	알고리즘	활용특징	실증 기간	탐지 정확도(%) (모델별 최고 AUC)
1	보안이벤트 41종	RandomForest	바이트 히스토그램	24.04.01 ~ 24.10.22	0.9743
2		LightGBM			0.9162
3		xgboost			0.9234
4		RandomForest	바이트 히스토그램 + 출발지/목적지 포트		0.9752
5		LightGBM			0.9186
6		xgboost			0.9264
7		RandomForest	바이트 히스토그램 + 페이로드 길이		0.9751
8		LightGBM			0.9199
9		xgboost			0.9257
10		**RandomForest**	**바이트 히스토그램 + 출발지/목적지 포트 + 페이로드 길이**		**0.9761**
11		LightGBM			0.9221
12		xgboost			0.9282
13		**CNN**	**원본 페이로드**		**0.9896**
14		MLP	원본 페이로드		0.9875

<이기종(3종 이상) 보안장비 데이터를 활용한 모델 정확도 실험 결과>

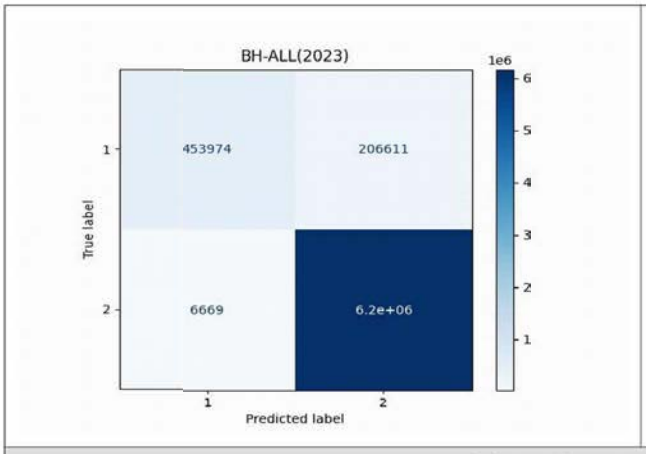
바이트 히스토그램 – RandomForest

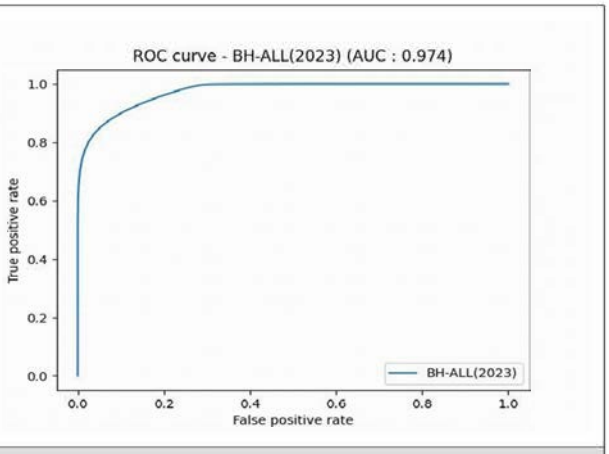
모델별 평가검증 프로그램 실행화면 캡처



혼동행렬 결과 캡처	ROC 커브 생성결과 캡처

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



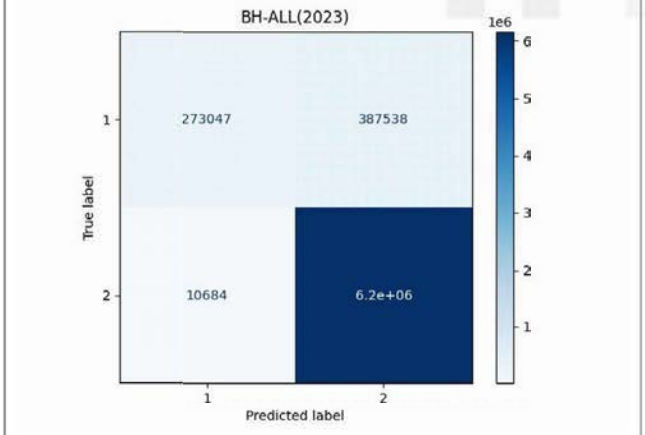


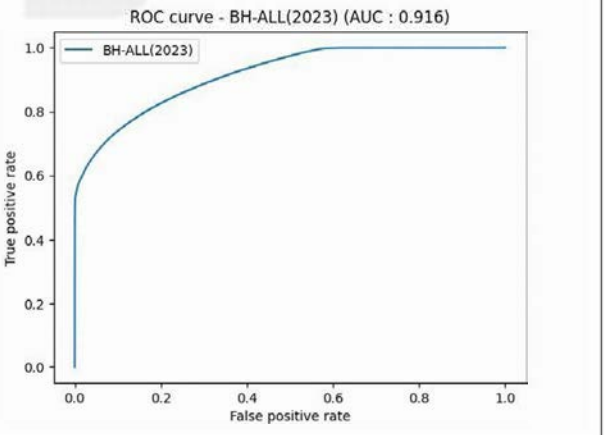
바이트 히스토그램 – LightGBM

모델별 평가검증 프로그램 실행화면 캡처

혼동행렬 결과 캡처

ROC 커브 생성결과 캡처





바이트 히스토그램 – xgboost

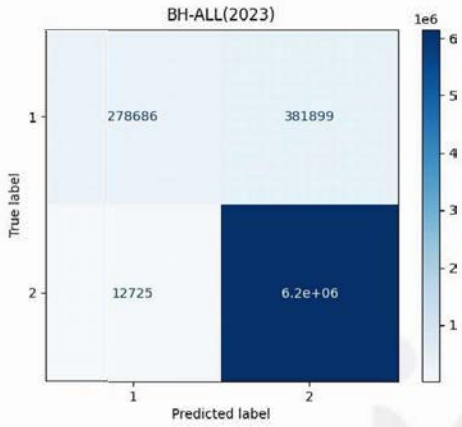
모델별 평가검증 프로그램 실행화면 캡처

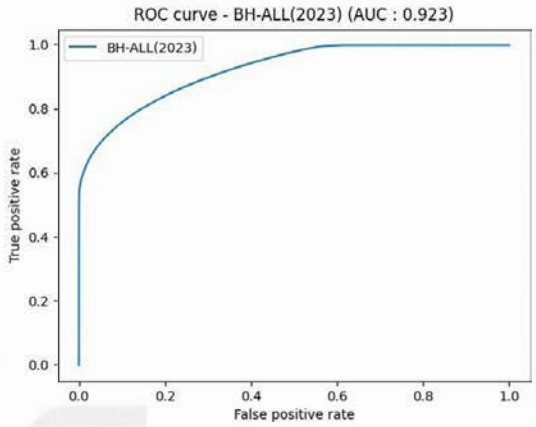
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

```
Run:  payload_classification
C:\Users\master\PycharmProjects\pythonProject\venv\Scripts\python.exe C:/Users/master/PycharmProjects/20220303/payload_classification.py
D:\2023\EXP\k\data\fv\BH_ALL.fv D:\2023\EXP\k\data\label\BH.label
256
DATA LOADED
X_train : 6835735
y_train : 6835735 (660584 / 6175151)
X_test : 6835736
y_test : 6835736 (660585 / 6175151)
Total : 13671471

Elapsed time for training : 451.66714119911194
Accuracy : 94.22704446163515
F1-score : 0.9689748225477213
Roc AUC: 0.92344584668468
MODEL SAVED - D:\2023\EXP\k\data\model\XGB_BH_ALL_0.5.model
PREDICT_SAVED - D:\2023\EXP\k\result\XGB_BH_ALL_0.5.predict

Process finished with exit code 0
```

혼동행렬 결과 캡처

ROC 커브 생성결과 캡처





바이트 히스토그램 + 출발지/목적지 포트 – RandomForest

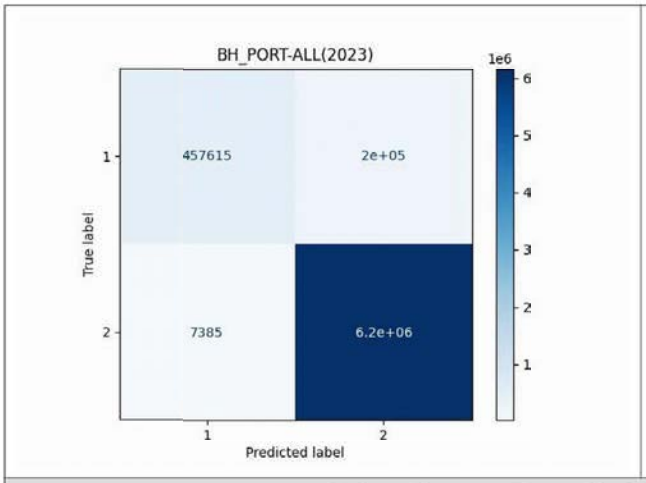
모델별 평가검증 프로그램 실행화면 캡처

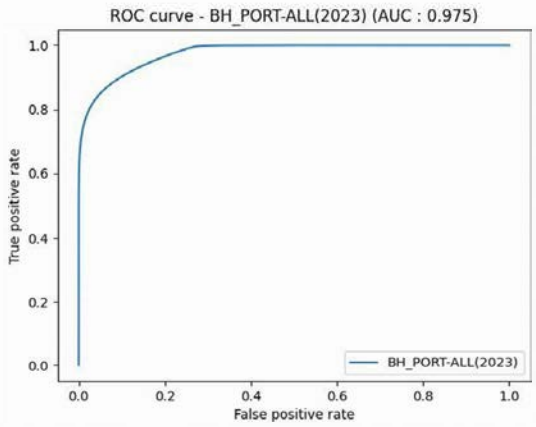
```
Run:  payload_classification
C:\Users\master\PycharmProjects\pythonProject\venv\Scripts\python.exe C:/Users/master/PycharmProjects/20220303/payload_classification.py
D:\2023\EXP\k\data\fv\BH_PORT_ALL.fv D:\2023\EXP\k\data\label\BH.label
258
DATA LOADED
X_train : 6835735
y_train : 6835735 (660584 / 6175151)
X_test : 6835736
y_test : 6835736 (660585 / 6175151)
Total : 13671471

Elapsed time for training : 517.3411202430725
Accuracy : 96.92271614936563
F1-score : 0.9832331504340825
Roc AUC: 0.9751897448603658
MODEL SAVED - D:\2023\EXP\k\data\model\RFC_BH_PORT_ALL_0.5.model
PREDICT_SAVED - D:\2023\EXP\k\result\RFC_BH_PORT_ALL_0.5.predict

Process finished with exit code 0
```

혼동행렬 결과 캡처

ROC 커브 생성결과 캡처

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



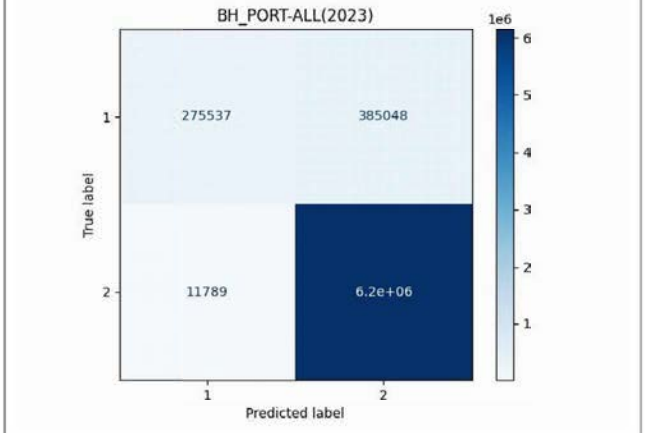


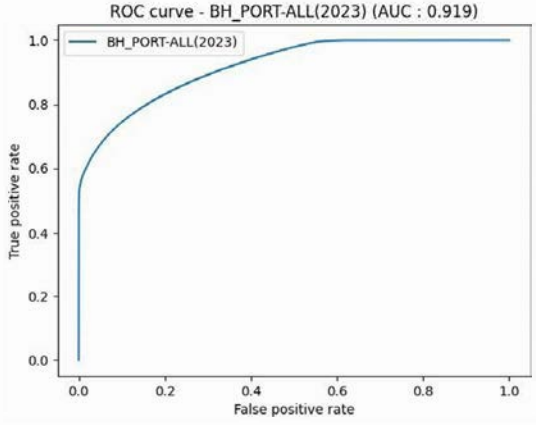
바이트 히스토그램 + 출발지/목적지 포트 – LightGBM

모델별 평가검증 프로그램 실행화면 캡처

혼동행렬 결과 캡처

ROC 커브 생성결과 캡처





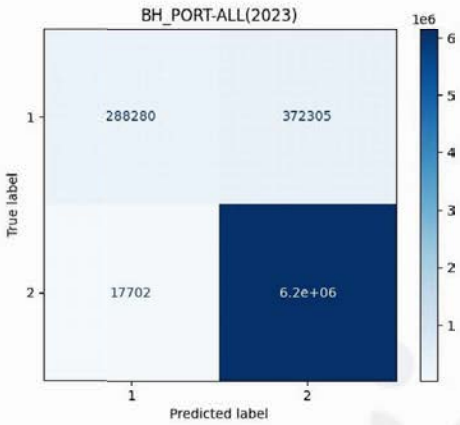
바이트 히스토그램 + 출발지/목적지 포트 – xgboost

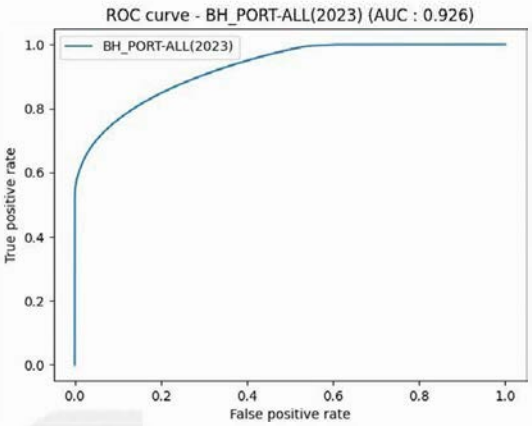
모델별 평가검증 프로그램 실행화면 캡처

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

```
Run:  payload_classification
C:\Users\master\PycharmProjects\pythonProject\venv\Scripts\python.exe C:/Users/master/PycharmProjects/20220303/payload_classification.py
D:\2023\EXP\k\data\fv\BH_PORT_ALL.fv D:\2023\EXP\k\data\label\BH.label
258
DATA LOADED
X_train : 6835735
y_train : 6835735 (660584 / 6175151)
X_test : 6835736
y_test : 6835736 (660585 / 6175151)
Total : 13671471

Elapsed time for training : 490.58771562576294
Accuracy : 94.29458656683055
F1-score : 0.9693026433491632
Roc AUC: 0.9264385684227
MODEL SAVED - D:\2023\EXP\k\data\model\XGB_BH_PORT_ALL_0.5.model
PREDICT_SAVED - D:\2023\EXP\k\result\XGB_BH_PORT_ALL_0.5.predict

Process finished with exit code 0
```

혼동행렬 결과 캡처	ROC 커브 생성결과 캡처





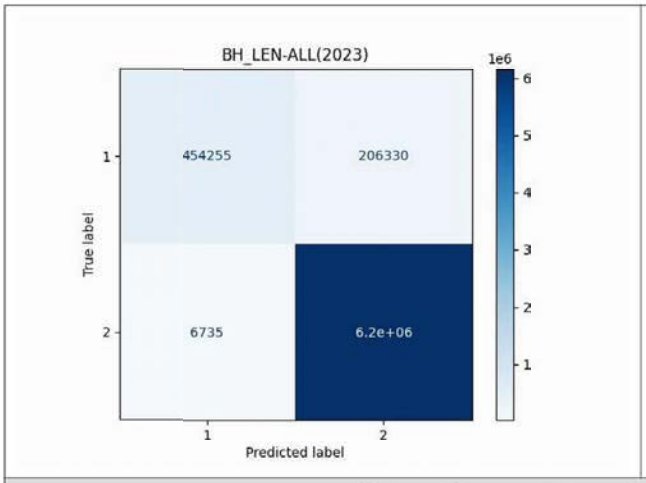
바이트 히스토그램 + 페이로드 길이 – RandomForest

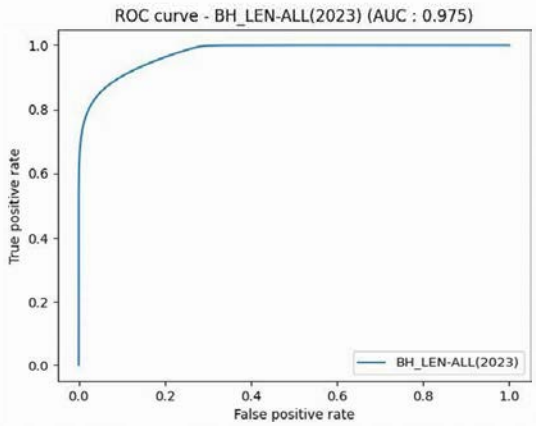
모델별 평가검증 프로그램 실행화면 캡처

```
Run:  payload_classification
C:\Users\master\PycharmProjects\pythonProject\venv\Scripts\python.exe C:/Users/master/PycharmProjects/20220303/payload_classification.py
D:\2023\EXP\k\data\fv\BH_LEN_ALL.fv D:\2023\EXP\k\data\label\BH.label
257
DATA LOADED
X_train : 6835735
y_train : 6835735 (660584 / 6175151)
X_test : 6835736
y_test : 6835736 (660585 / 6175151)
Total : 13671471

Elapsed time for training : 513.2820882797241
Accuracy : 96.8830715522074
F1-score : 0.9830225698206688
Roc AUC: 0.975087088571551
MODEL SAVED - D:\2023\EXP\k\data\model\RFC_BH_LEN_ALL_0.5.model
PREDICT_SAVED - D:\2023\EXP\k\result\RFC_BH_LEN_ALL_0.5.predict

Process finished with exit code 0
```

혼동행렬 결과 캡처	ROC 커브 생성결과 캡처

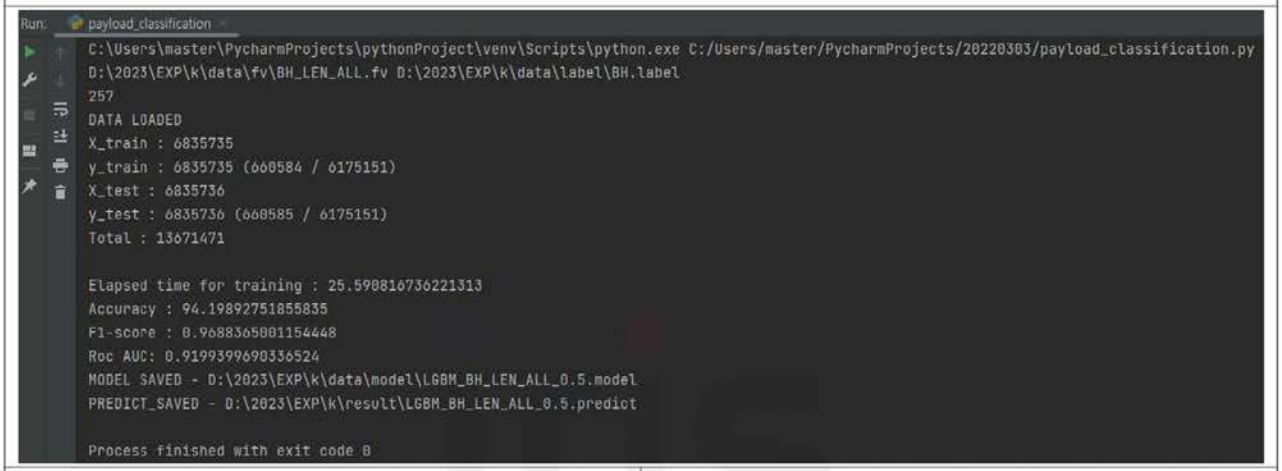
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다





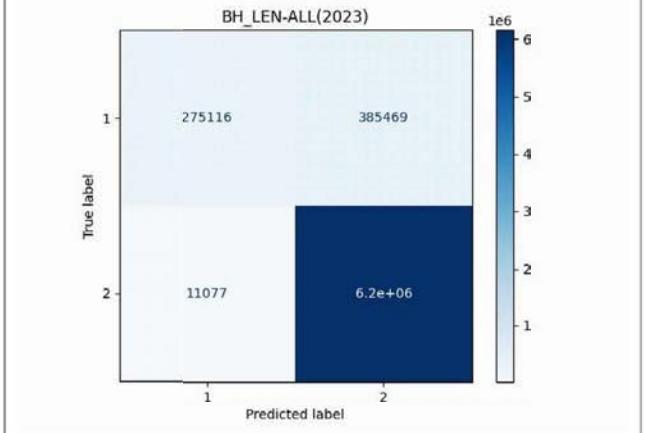
바이트 히스토그램 + 페이로드 길이 – LightGBM

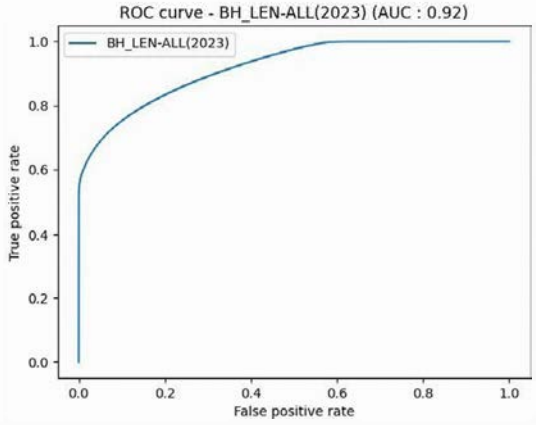
모델별 평가검증 프로그램 실행화면 캡처



혼동행렬 결과 캡처

ROC 커브 생성결과 캡처





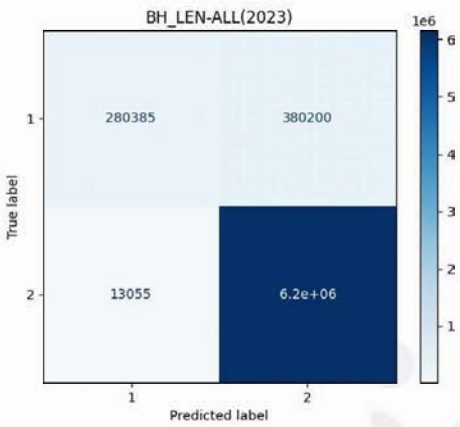
바이트 히스토그램 + 페이로드 길이 – xgboost

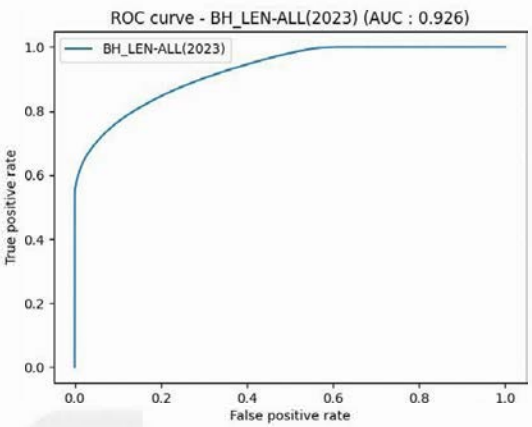
모델별 평가검증 프로그램 실행화면 캡처

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

```
Run:  payload_classification
C:\Users\master\PycharmProjects\pythonProject\venv\Scripts\python.exe C:/Users/master/PycharmProjects/20220303/payload_classification.py
D:\2023\EXP\k\data\fv\BH_LEN_ALL.fv D:\2023\EXP\k\data\label\BH.label
257
DATA LOADED
X_train : 6835735
y_train : 6835735 (660584 / 6175151)
X_test : 6835736
y_test : 6835736 (660585 / 6175151)
Total : 13671471

Elapsed time for training : 470.7337746620178
Accuracy : 94.24707156625124
F1-score : 0.9690775200399891
Roc AUC: 0.9257320228401567
MODEL SAVED - D:\2023\EXP\k\data\model\XGB_BH_LEN_ALL_0.5.model
PREDICT_SAVED   D:\2023\EXP\k\result\XGB_BH_LEN_ALL_0.5.predict

Process finished with exit code 0
```

혼동행렬 결과 캡처	ROC 커브 생성결과 캡처





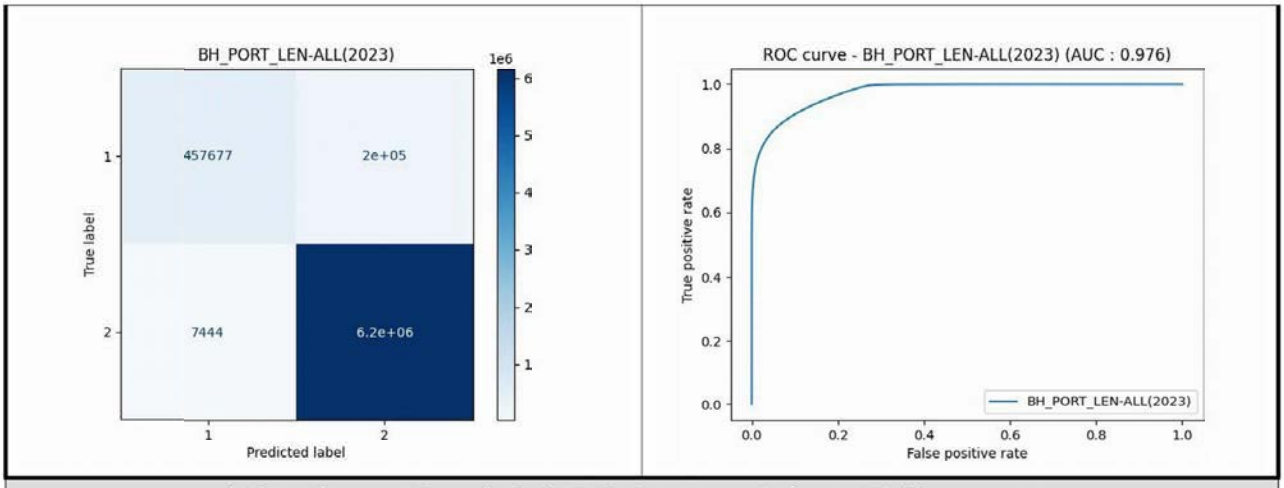
(최종 선정 모델) 바이트 히스토그램 + 출발지/목적지 포트 + 페이로드 길이 – RandomForest

모델별 평가검증 프로그램 실행화면 캡처

```
Run:  payload_classification
C:\Users\master\PycharmProjects\pythonProject\venv\Scripts\python.exe C:/Users/master/PycharmProjects/20220303/payload_classification.py
D:\2023\EXP\k\data\fv\BH_PORT_LEN_ALL.fv D:\2023\EXP\k\data\label\BH.label
259
DATA LOADED
X_train : 6835735
y_train : 6835735 (660584 / 6175151)
X_test : 6835736
y_test : 6835736 (660585 / 6175151)
Total : 13671471

Elapsed time for training : 515.9237008094788
Accuracy : 96.92276003637356
F1-score : 0.9832332278475463
Roc AUC: 0.9760734150415536
MODEL SAVED - D:\2023\EXP\k\data\model\RFC_BH_PORT_LEN_ALL_0.5.model
PREDICT_SAVED - D:\2023\EXP\k\result\RFC_BH_PORT_LEN_ALL_0.5.predict

Process finished with exit code 0
```

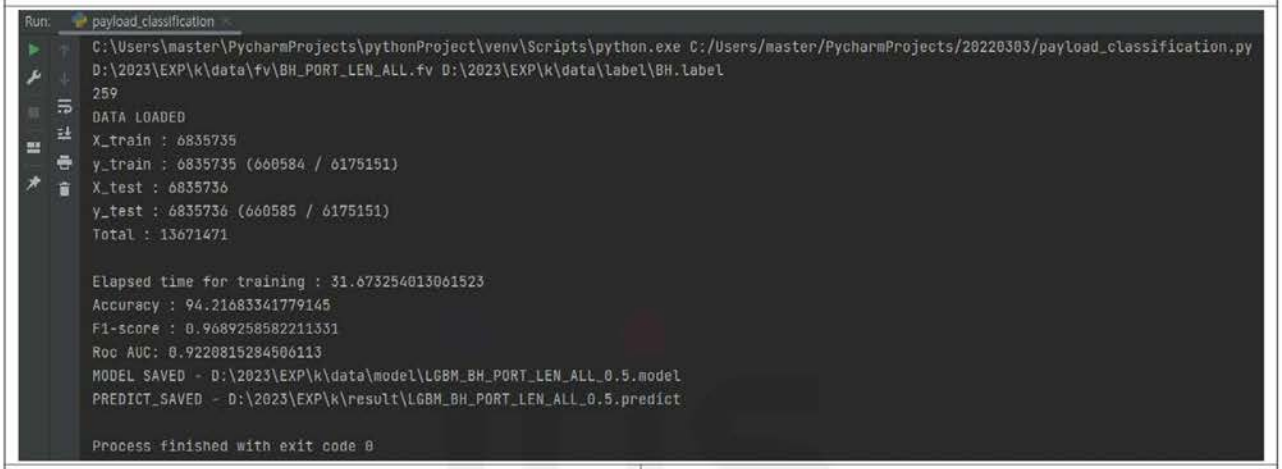
혼동행렬 결과 캡처	ROC 커브 생성결과 캡처

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



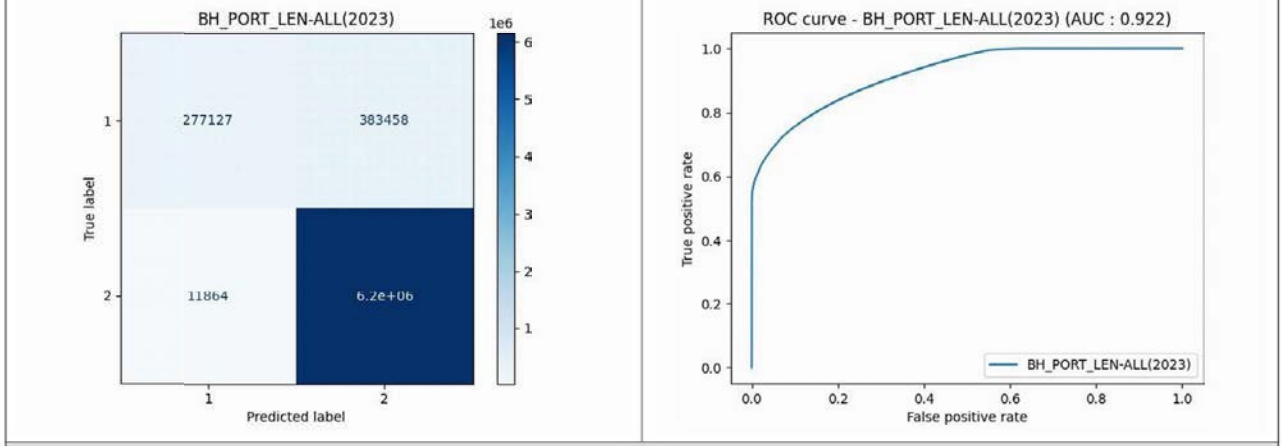
바이트 히스토그램 + 출발지/목적지 포트 + 페이로드 길이 – LightGBM

모델별 평가검증 프로그램 실행화면 캡처



혼동행렬 결과 캡처

ROC 커브 생성결과 캡처



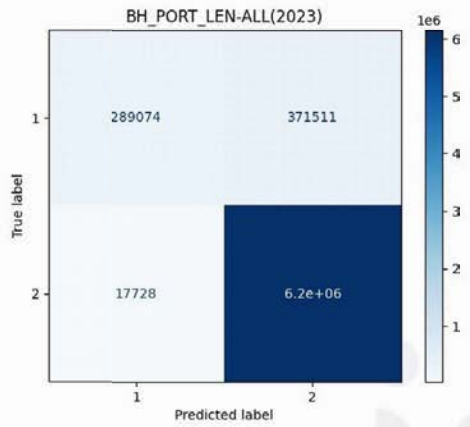
바이트 히스토그램 + 출발지/목적지 포트 + 페이로드 길이 – xgboost

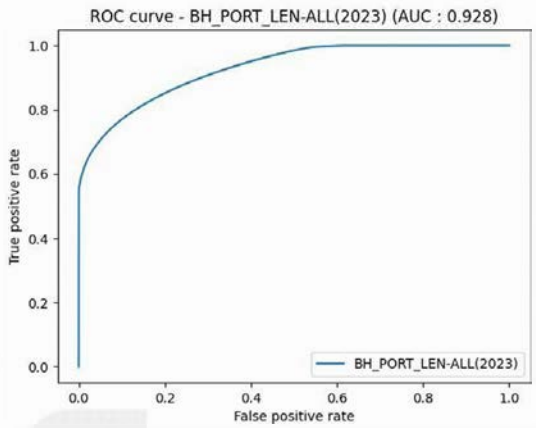
모델별 평가검증 프로그램 실행화면 캡처

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

```
Run:  payload_classification
C:\Users\master\PycharmProjects\pythonProject\venv\Scripts\python.exe C:/Users/master/PycharmProjects/20220303/payload_classification.py
D:\2023\EXP\k\data\fv\BH_PORT_LEN_ALL.fv D:\2023\EXP\k\data\label\BH.label
259
DATA LOADED
X_train : 6835735
y_train : 6835735 (660584 / 6175151)
X_test : 6835736
y_test : 6835736 (660585 / 6175151)
Total : 13671471

Elapsed time for training : 472.82402300834656
Accuracy : 94.30582164085915
F1-score : 0.9693611149484594
Roc AUC: 0.9281962511834185
MODEL SAVED - D:\2023\EXP\k\data\model\XGB_BH_PORT_LEN_ALL_0.5.model
PREDICT_SAVED - D:\2023\EXP\k\result\XGB_BH_PORT_LEN_ALL_0.5.predict

Process finished with exit code 0
```

혼동행렬 결과 캡처	ROC 커브 생성결과 캡처





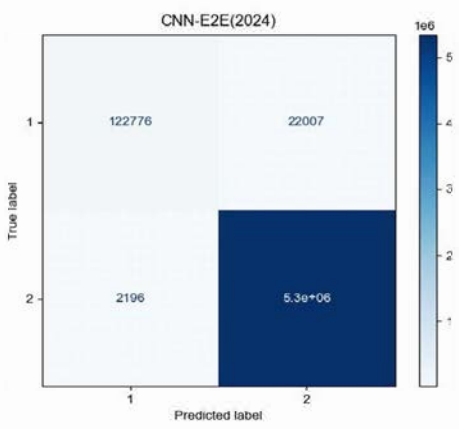
원본 페이로드 – CNN

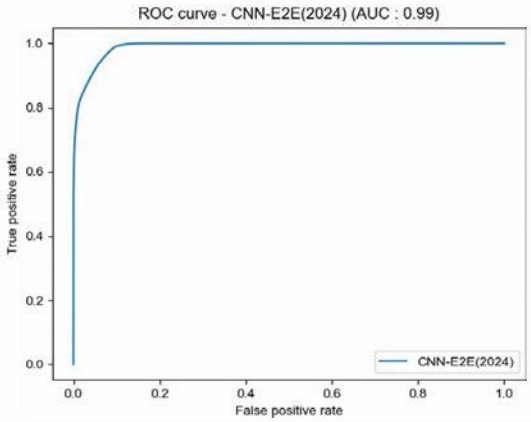
모델별 평가검증 프로그램 실행화면 캡처

```
CNN Model setting with fc_2_nodes_2048_kernel_4_convlayers_4
Train data length :  5493713
Epoch [1/5], Loss: 0.0290, Accuracy: 99.35%, Time: 4656.13 seconds
Epoch [2/5], Loss: 0.0217, Accuracy: 99.50%, Time: 4591.57 seconds
Epoch [3/5], Loss: 0.0205, Accuracy: 99.53%, Time: 4586.63 seconds
Epoch [4/5], Loss: 0.0197, Accuracy: 99.55%, Time: 4588.23 seconds
Epoch [5/5], Loss: 0.0190, Accuracy: 99.56%, Time: 4590.90 seconds
Training complete.
Test data length :  5493730
Accuracy : 0.9956
AUC : 0.9896
F1-Score : 0.9103
Model saved as CNN_model_fc_2_nodes_2048_kernel_4_layers_4_1101_0.5.pth
```

혼동행렬 결과 캡처	ROC 커브 생성결과 캡처

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



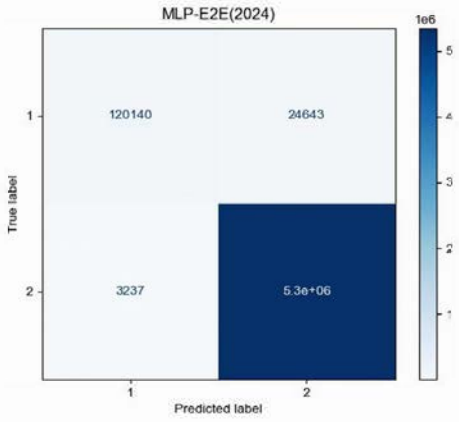


원본 페이로드 – MLP

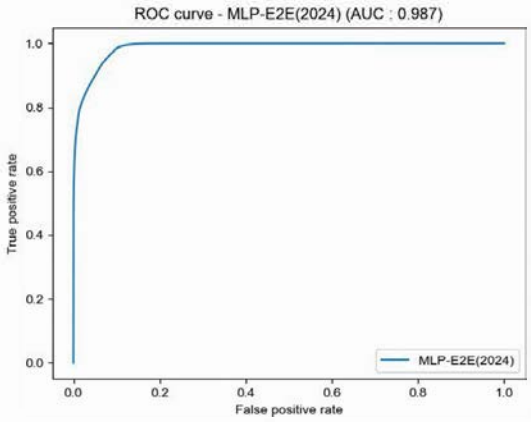
모델별 평가검증 프로그램 실행화면 캡처

```
MLP Model setting with 1024 nodes and 3 layers...
Train data length :  5493713
Epoch [1/5], Loss: 0.0316, Accuracy: 99.23%, Time: 4483.70 seconds
Epoch [2/5], Loss: 0.0264, Accuracy: 99.36%, Time: 4372.72 seconds
Epoch [3/5], Loss: 0.0248, Accuracy: 99.41%, Time: 4382.87 seconds
Epoch [4/5], Loss: 0.0238, Accuracy: 99.43%, Time: 4377.49 seconds
Epoch [5/5], Loss: 0.0230, Accuracy: 99.46%, Time: 4391.71 seconds
Test data length :  5493730
Accuracy : 0.9949
AUC : 0.9875
F1-Score : 0.8960
recall : 0.8298
precision : 0.9738
Model saved as MLP_model_fc_3_nodes_1024_1119.pth
```

혼동행렬 결과 캡처



ROC 커브 생성결과 캡처



o 신속한 의사결정 지원을 위한 AI 분석 및 탐지모델 최적화

- 딥러닝 모델의 학습 하이퍼파라미터 및 모델 구조 개선을 통한 탐지모델 성능 최적화
  - · 딥러닝 모델의 성능은 알고리즘뿐만 아니라 학습 하이퍼파라미터*와 모델 구조에 크게 의존

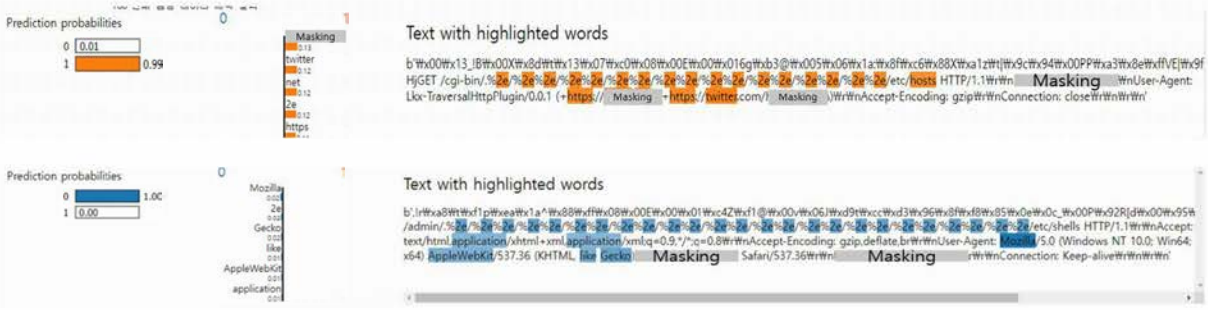
    * 학습 하이퍼파라미터: 학습률(Learning rate), 배치 크기(batch size), 에포크(epoch) 등

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

※ 데이터 크기가 큰 보안 트래픽 데이터는 효율적 학습 전략 필요

- 네트워크 트래픽을 분류하는 AI 탐지 모델은 데이터 크기가 크고 특성이 복잡하기 때문에 학습 관련 파라미터를 실험적으로 조정해 학습 시간 감소 및 안정적인 학습을 유지함.
- 실험에서 상대적으로 높은 성능을 보인 1-CNN은 데이터의 공간적 특성을 학습하는 데 강력한 성능을 보임
- AI 탐지모델은 깊이와 구조에 따라 학습 데이터의 특성을 잘 파악할 수 있으며, 지나치게 얕은 구조는 과소 적합을, 지나치게 깊은 구조는 과대 적합을 유발할 수 있음
- CNN은 합성곱 알고리즘을 통해 입력 데이터에 필터를 적용하여 특징을 학습하며 필터의 크기를 통해 국소적 또는 전역적 패턴을 학습
- 필터 크기, 합성곱 계층의 수 (# of C Layer), 완전 연결 계층의 레이어 수 (# of FC Layer), 완전 연결 계층의 노드 수 (# of FC Layer Node) 등 1D-CNN의 모델 구조 조정을 통해 탐지 모델 성능 최적화 시도
- 적절한 하이퍼파라미터 설정 및 모델 구조 조정을 통해 데이터에 최적화된 모델 설계, 관제 요원의 AI 탐지모델에 대한 신뢰성을 높여 신속한 의사결정을 지원

- XAI기법을 활용한 학습데이터 조정 및 모델 성능 최적화
  - XAI기법은 인공지능 모델이 판단한 결과에 대하여 판단근거를 제시함으로써 모델의 예측 결과를 이해하는 것을 가능하게 함
  - 이외에도 XAI기법이 제시하는 탐지근거들을 분석하여 오류를 포함한 학습 데이터를 파악하여 레이블을 보정하거나 제외하는 등의 작업을 통해 탐지모델 성능 개선이 가능함
  - XAI결과를 통해 도출된 판단근거 중 오류가 포함된 데이터를 확인하여 이를 학습데이터에서 제거함으로써 전체적인 학습데이터의 순도(purity)를 개선하고 학습모델의 성능을 개선함



<모델 재학습 전 예측 결과(LIME)>

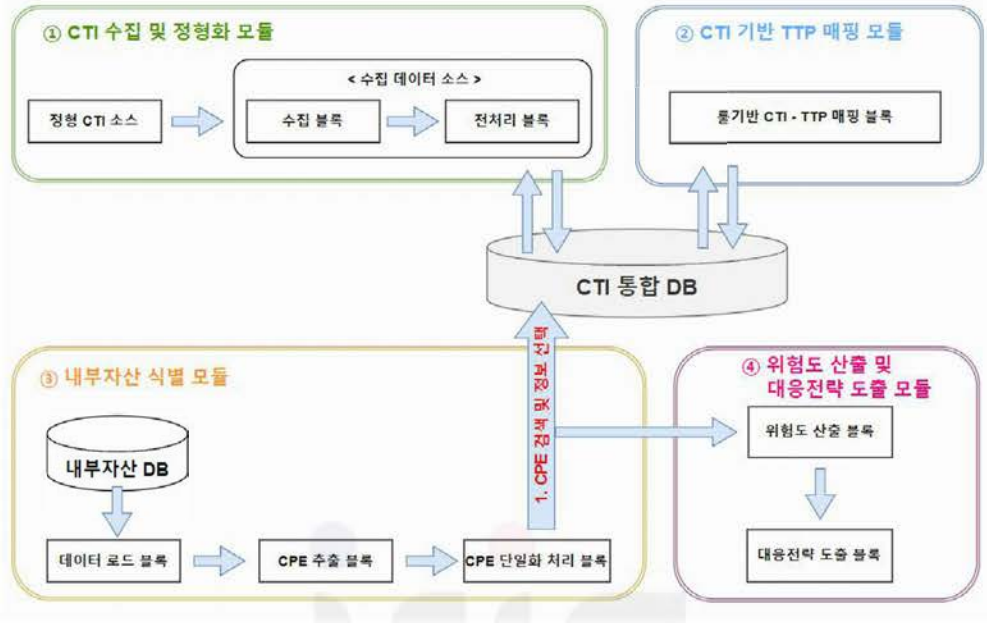
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

연구목표	공개 보안 위협 인텔리전스 정보 수집 기술 고도화

세부 내용	1) STIX/TAXII 기반 보안 위협 인텔리전스 정보 수집 및 정형화 기술 고도화
	2) 보안 위협 인텔리전스 통합 데이터베이스 운영 및 고도화

o STIX/TAXII 기반 보안 위협 인텔리전스 정보 수집 및 정형화 기술 고도화

- CTI 통합 프로세스 구성도



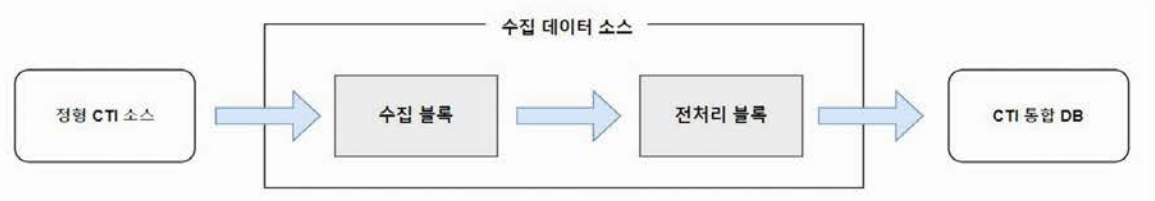
< 4가지 모듈 기반 전체 프로세스 흐름도 >

1. CTI 수집 및 정형화 모듈
   : 외부 CTI 데이터를 수집하고 정형화 및 결측치 보완 후 CTI에 저장
2. CTI 기반 TTP 매핑 모듈
   : CVE와 TTP 데이터를 상호 매핑하여 연계성을 확보하고 CTI에 저장
3. 내부자산 식별 모듈
   : 내부자산 정보를 기반으로 CPE 정보를 추출하고 조합하여 CTI 데이터와 연결
4. 위험도 산출 및 대응전략 도출 모듈
   : 매핑된 데이터를 활용해 자산별 위협도를 산출하고 이에 따른 대응 전략 도출

- CTI 수집 및 정형화 모듈 구현

1. 모듈 개요

・STIX/TAXII 기반의 외부 CTI 데이터를 정형화하여, 분석과 데이터베이스 적재에 필요한 포맷으로 변환하고, 결측치를 처리하는 것
이 과정에서 데이터를 CVE, CPE, TTP로 분류하여, 각 유형에 맞게 결측치 보완 및 정형화



< CTI 정보 수집 및 정형화 모듈 프로세스 >

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

2. 설계 및 구현

· 외부 CTI 데이터 소스 정의 및 연결 방식 개선

› TAXII Server에서 제공하는 데이터를 JSON 파일 형식으로 변환하여, 후속 프로세스에서 사용하기 위한 데이터 준비

```
if ref_object:
    if ref_object["type"] == "vulnerability":
        cve_id = ref_object.get("external_references", [{}])[0].get("external_id", ref_object.get("name"))
        cpe_ids = ref_object.get("x_misp_vulnerable_configuration", None)
        if cpe_ids:
            cpes.extend(cpe_ids)
        cvss3 = ref_object.get("x_misp_cvss_score") if "CVSS:3" in ref_object.get("x_misp_cvss_string", "") else None
        cvss2 = ref_object.get("x_misp_cvss_score") if "CVSS:2" in ref_object.get("x_misp_cvss_string", "") else None
        description = ref_object.get("description", None)

        report_temp_results.append({
            "cve_id": cve_id,
            "cpe": cpe_ids,
            "cvss_ver3": cvss3,
            "cvss_ver2": cvss2,
            "technique": None,
            "description": description,
            "source": report_object['id']
        })
        yes_cve += 1

    elif ref_object["type"] == "attack-pattern":
        technique = ref_object.get("external_references", [{}])[0].get("external_id", ref_object.get("name", "").split(" ")[-1])
        techniques.append(technique)

    elif ref_object["type"] == "software":
        cpe = ref_object.get("cpe", None)
        cpes.append(cpe)

    elif ref_object["type"] == "x-misp-attribute" and ref_object.get("x_misp_type") == "cpe":
        cpe = ref_object.get("x_misp_value", None)
        cpes.append(cpe)
```

CVE

TTP

CPE

› STIX Report 데이터를 기반으로 CVE, CPE, TTP 데이터를 추출하는 과정

(STIX Report 형식) report 객체로 제공되며, 관련 인디케이터와 참조 데이터를 포함

(주요 필드) id: 보고서 ID/ object_refs: 연결된 객체(ID 리스트) 등

(데이터 수집) object_refs에 나열된 모든 객체를 순회하며 데이터 수집

각 객체를 조회하여 vulnerability, software, x-misp-attribute, attack-pattern 등의 데이터를 가져옴

(객체별 필터링) 객체 유형에 따라 CVE, CPE, TTP로 구분

vulnerability → CVE

software, x-misp-attribute → CPE

attack-pattern → TTP

(CPE 버전 전환) CPE 버전이 2.0으로 들어온 값은 2.3으로 변환하여 저장

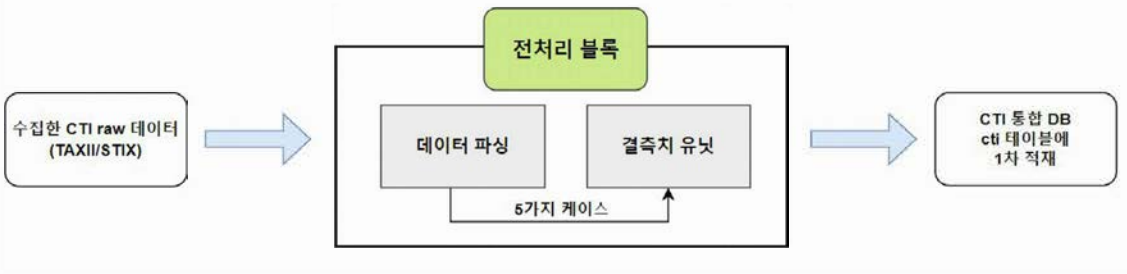
예시: cpe:/h:cisco:wrvs4400n:- → cpe:2.3:h:cisco:wrvs4400n:-:*:*:*:*:*:*:*

CPE 2.0 버전 6개 3.0 버전으로 변환 완료

```
report--5a2b0fe8-6900-412e-a9b6-2facc0a8ab16:   7%|▋                | 150/2233 [00:00<00:04, 422.53it/s]['cpe:/h:cisco:wrvs4400n:-', 'cpe:/h:netgear:r6400:-', 'cpe:/h:netgear:r8000:-', 'cpe:/h:netgear:r7000:-', 'cpe:/h:netgear:wnr1000v3:-', 'cpe:/h:netgear:wnr2000:-']
['cpe:2.3:h:cisco:wrvs4400n:-:*:*:*:*:*:*:*', 'cpe:2.3:h:netgear:r6400:-:*:*:*:*:*:*:*', 'cpe:2.3:h:netgear:r8000:-:*:*:*:*:*:*:*', 'cpe:2.3:h:netgear:r7000:-:*:*:*:*:*:*:*', 'cpe:2.3:h:netgear:wnr1000v3:-:*:*:*:*:*:*:*', 'cpe:2.3:h:netgear:wnr2000:-:*:*:*:*:*:*:*']
```

< cpe 6개 3.0 버전 변환 과정>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



< CTI 데이터 전처리 및 적재 흐름도 >

· 데이터 정형화 프로세스에서 결측치 처리 설계

› CVE, CPE, TTP 데이터를 구분하여 상위 조합이 많이 등장하는 상위 5개를 선정하고, 결측치 처리의 우선순위를 설정

› 각 데이터 유형에 대해 결측치를 처리하는 알고리즘을 설계하고, CTI 통합 데이터베이스에 1차 결과를 적재

<table>
<tr><th>하위 블록</th><th>기능 설명</th></tr>
<tr><td>수집 블록</td><td>외부 CTI 소스에서 JSON 포맷으로 CVE, CPE, TTP 데이터를 수집</td></tr>
<tr><td>전처리 블록</td><td>1. 수집된 데이터의 결측치 보완 및 파싱
2. 결측치 처리 알고리즘 설계 및 구현: 결측치 판단 및 보완 과정
<table><tr><td>결측치 판단</td><td>CVE Object의 주요 필드(cve_id, cpe, ttp)가 비어있는 경우</td></tr><tr><td>결측치 보완</td><td>CTI의 cve_detail를 활용해 부족한 데이터를 채움 → 전처리 결과를 CTI 통합 데이터베이스에 1차 저장</td></tr></table>*CVE Object : key값이 cve_id, cpe, cvss, ttp로 구성된 하나의 딕셔너리 형태
*cve_detail 테이블 : 현존하는 모든 cve에 대한 cpe, cvss 정보를 담은 저장소</td></tr>
</table>

< 하위 블록 2가지에 대한 기능 설명 >

<table>
<tr><th></th><th>결측값</th><th>결측치 처리 방법</th><th>1차 결측치 처리 후</th></tr>
<tr><td>① CVE만 존재</td><td>CPE,CVSS, TTP</td><td rowspan="3">cve_detail테이블에서
CVE, CPE, CVSS
데이터 결측 처리 후
TTP만 NULL값으로 CTI 저장</td><td rowspan="3">TTP만 NULL값
(다른 값도 NULL허용)</td></tr>
<tr><td>② CPE만 존재</td><td>CVE,CVSS, TTP</td></tr>
<tr><td>③ CVE, CPE 존재</td><td>CVSS, TTP</td></tr>
<tr><td>④ CVE, TTP 존재</td><td>CPE,CVSS</td><td>cve_detail테이블에서
CPE, CVSS데이터 결측 처리</td><td>모든 값 존재
(NULL허용)</td></tr>
<tr><td>⑤ TTP 존재</td><td>CVE,CPE, CVSS</td><td>나머지 NULL값으로
TTP값만 CTI 저장</td><td>TTP 값만 존재</td></tr>
</table>

< 5가지 케이스별 결측치 처리 세부 과정>

· 데이터 파싱 알고리즘

› TAXII 서버에서 CVE, CPE, TTP 데이터를 수집하고, 이를 5가지 케이스로 분류

(1) CVE_ID만 존재하는 경우
(2) CPE만 존재하는 경우
(3) CVE_ID와 CPE가 존재하는 경우
(4) CVE_ID와 TTP가 존재하는 경우
(5) TTP만 존재하는 경우

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

Algorithm 1 Taxii to CTI

```
taxii_to_cticve_id, ttp, cpecursor ← OPEN database cursor if cve_id is not NULL then
if ttp is NULL AND cpe is NULL then
  Case: CVE only
  result ← EXECUTE SQL query to get cpe, cvss_ver3, cvss_ver2
  if result is not NULL then
    CALL insert_cti(cve_id, cpe, cvss_ver3, cvss_ver2, NULL)
  end if

else if ttp is not NULL then
  Case: CVE and TTP
  result ← EXECUTE SQL query to get cpe, cvss_ver3, cvss_ver2
  if result is not NULL then
    CALL insert_cti(cve_id, cpe, cvss_ver3, cvss_ver2, ttp)
  end if

else if cpe is not NULL then
  Case: CVE and CPE
  result ← EXECUTE SQL query to get cpe, cvss_ver3, cvss_ver2
  if result is not NULL then
    CALL insert_cti(cve_id, cpe, cvss_ver3, cvss_ver2, NULL)
  end if

 end if
else if ttp is not NULL then
  Case: TTP
  CALL insert_cti(NULL, NULL, NULL, NULL, ttp)

else if cpe is not NULL then
  Case: CPE
  results ← EXECUTE SQL query to get cve_id, cpe, cvss_ver3, cvss_ver2
  for each result in results do
    CALL insert_cti(cve_id, cpe, cvss_ver3, cvss_ver2, NULL)
  end for

end if
CLOSE cursor
```

결측치 처리 알고리즘

› (결측치 판단) cve_id, cpe, cvss_ver3, cvss_ver2, ttp 필드 중 누락된 항목이 있는 경우 결측치로 간주

› (결측치 보완) cve_detail 테이블을 활용하여 결측된 데이터를 보완

› (결과) 보완된 데이터를 CTI 통합 데이터베이스 저장· 후속 처리 과정 대기

3. 실험 결과

· 기능 실험

› (목표) 각 데이터가 정상적으로 수집되고, 결측치가 제대로 보완되어 저장되었는지 확인

› (실험 절차) 외부 CTI 소스 → 5가지 유형 분류 → 결측치 보완 → CTI 통합 데이터베이스에 1차 저장

› (기능 시험 결과)

(1) 1차 전처리 cti 매핑율

	Case별 CTI 개수	CTI 1차로 저장되는 매핑률
Case(1) CVE	2,673	98.765%
Case(2) CPE	1	100%
Case(3) CVE,CPE	2	100%
Case(4) CVE,TTP	6	100%
Case(5) TTP	64	100%
총합 및 평균	2,746	99.753%

CTI 통합 데이터베이의 cti 테이블에 저장된 매핑 성공률 : **99.753%**

5가지 케이스 중 (1) CVE_ID만 존재하는 경우만 98.765%

2,673개의 데이터 중에서 33개의 CVE는 CPE, CVSS 값이 없음

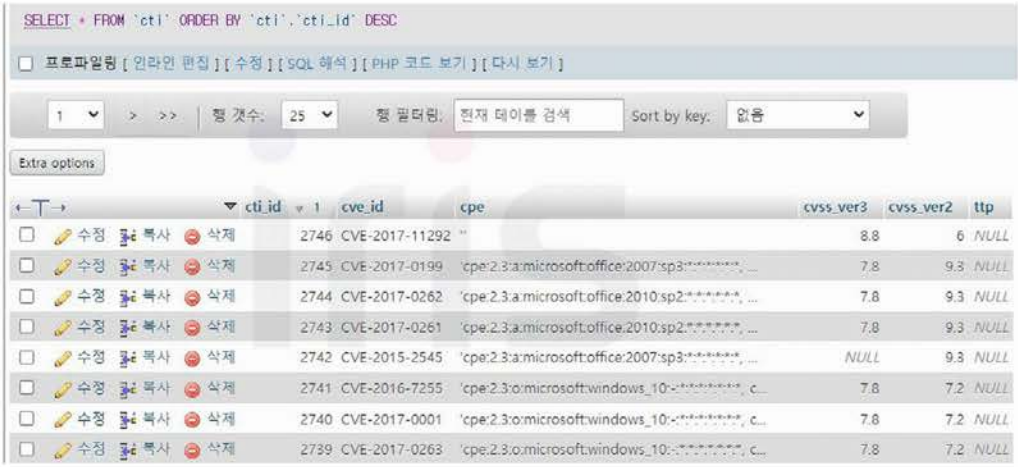
그 외 나머지 케이스는 전부 100% 매핑률을 보임

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

cve_id	cpe	cvss_ver3	cvss_ver2	ttp
CVE-2017-11882	'cpe:2.3:a:microsoft:office:2007:sp3:*:*:*:*:*:*:*:*', ...	7.8	9.3	
CVE-2018-4878	''	9.8	7.5	
CVE-2018-8174	'cpe:2.3:o:microsoft:windows_10:-:*:*:*:*:*:*:*:*', c...	7.5	7.6	
CVE-2018-8174	'cpe:2.3:o:microsoft:windows_10:-:*:*:*:*:*:*:*:*', c...	7.5	7.6	
CVE-2014-0160	'cpe:2.3:a:openssl:openssl:*:*:*:*:*:*:*:*:*'	7.5	5	
NULL	*NULL*	*NULL*	*NULL*	T1122,T1114

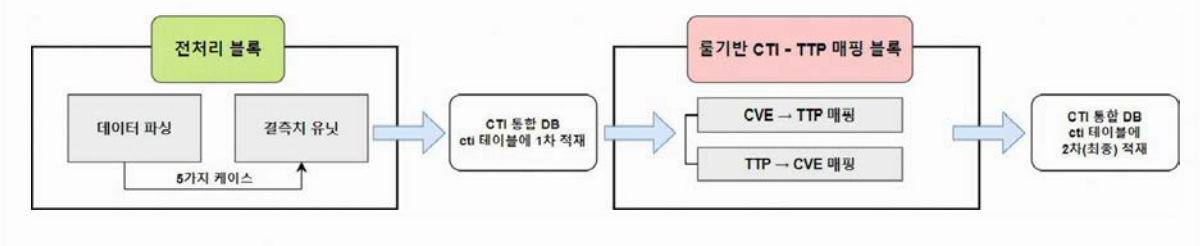
위의 5개와 같이 ttp를 제외한 모든 결측치를 처리하여 저장하고,
마지막 경우와 같이 ttp는 결측치를 처리하지 않고 저장

· 성능 실험
› (목표) 데이터 처리 속도 및 성능을 측정하여 시스템의 효율성을 확인
› (실험 항목) 파싱 및 결측치 처리 속도, 데이터베이스 적재 시간 측정
› (성능 실험 결과) 데이터 파싱 및 결측치 처리 시간: **37.33 seconds**
총 2,746개의 report를 분석하여 CVE, CPE, TTP로 분류하고,
5가지 유형에 맞게 결측치를 처리하여 2,764개의 객체가 cti에 저장됨



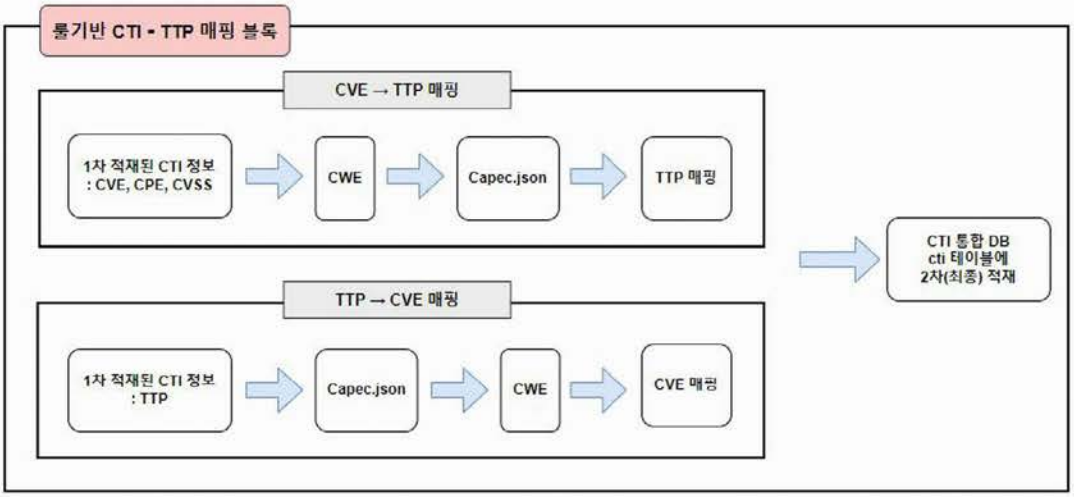
< 2,746개의 데이터가 cti에 저장된 모습 >

- CTI 기반 TTP 매핑 모듈 구현
1. 모듈 개요
· CTI 데이터 내 CVE와 TTP 간 매핑을 통해 보안 위협의 전술, 기법, 절차를 식별하고 보안 대응을 강화
2. 설계 및 구현



< CTI 데이터 전처리 과정에 이은 룰 기반 TTP 매핑 흐름도 >

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



< 룰 기반 CTI-TTP 매핑 프로세스 흐름도 >

- CVE → TTP 매핑:
  - CVE 정보를 기반으로 NVD에서 CWE 정보를 찾은 후, Capec.json에서 CWE 정보를 매핑하여 관련 TTP를 식별

CVE→CWE

```
def cve2cwe(self, cve_id):
    try:
        soup = self.nvd_cve_html_parser(cve_id)
        if soup is None:
            return []
        cwe_list = []
        table_id = soup.find('table', {"data-testid": "vuln-CWEs-table"})
        if table_id is None:
            return []
        td_tags = table_id.find_all('td', {'nowrap': ""})
        for td_tag in td_tags:
            a_tag = td_tag.find('a', href=lambda href: href and href.startswith('http://cwe.'))
            if a_tag is not None:
                cwe_list.append(a_tag.text)
        return cwe_list
    except Exception as e:
        print(f"Error occurred in cve2cwe: {e}")
        return []
```

CWE→TTP

```
def cwe2capec_ttp(self, cwe_list):
    json_object = self.file_load(r"C:\Users\ICSR\Desktop\연구실\KISA_testbed\KISA-System\src\MitreToCVE\stix-capec(update).json")
    stix_df = pd.json_normalize(json_object['objects'])
    capec_list = []
    ttp_list = []
    for cwe in cwe_list:
        for stix_entry in stix_df['external_references'].dropna():
            if any(sitx_ref['source_name']=='cwe' and sitx_ref['external_id']==cwe for sitx_ref in stix_entry):
                stix_capec_ids = [sitx_ref['external_id'] for sitx_ref in stix_entry if sitx_ref.get('source_name') == 'capec']
                capec_list.extend(stix_capec_ids)
                stix_ttp_ids = [sitx_ref['external_id'] for sitx_ref in stix_entry if sitx_ref.get('source_name') == 'ATTACK']
                ttp_list.extend(stix_ttp_ids)
    return list(set(capec_list)), list(set(ttp_list))
```

- TTP → CVE 매핑:
  - TTP 정보를 기반으로 Capec.json에서 CWE 정보를 찾은 후, Capec.json에서 CWE 정보를 이용하여 관련 CVE를 식별

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

```python
def extract_t_references_and_matching_cwe(self, ttp_id):
    json_object = self.file_load(r"C:\Users\ICSK\Desktop\연구실\KISA_testbed\KISA-System\src\MitreToCVE\stix-capec(update).json")
    stix_df = pd.json_normalize(json_object['objects'])
    t_references = {}
    for stix_entry in stix_df['external_references'].dropna():
        for stix_ref in stix_entry:
            if stix_ref.get('external_id', '').startswith('T'):
                t_id = stix_ref['external_id']
                if t_id not in t_references:
                    t_references[t_id] = []
                for stix_ref_inner in stix_entry:
                    if stix_ref_inner.get('source_name') == 'cwe':
                        t_references[t_id].append(stix_ref_inner['external_id'])
    return t_references.get(ttp_id, [])

def cwe2cve(self, cwe_id):
    try:
        url = f"https://nvd.nist.gov/vuln/search/results?searchType=all&query={cwe_id}"
        response = requests.get(url)
        response.raise_for_status()
        soup = BeautifulSoup(response.content, 'html.parser')

        print(f"Processing CWE ID: {cwe_id}")

        cve_list = []
        table_id = soup.find('table', {"data-testid": "vuln-results-table"})
        if table_id is None:
            print(f"No results found for CWE ID: {cwe_id}")
            return []

        tr_tags = table_id.find_all('tr')
        for tr_tag in tr_tags:
            cve_tag = tr_tag.find('a', href=lambda href: href and href.startswith('/vuln/detail/'))
            if cve_tag is not None:
                cve_id = cve_tag.text.strip()
                cve_list.append(cve_id)

        print(f"Found CVEs for CWE ID {cwe_id}: {cve_list}")
        return cve_list

    except requests.exceptions.RequestException as e:
        print(f"ERROR while fetching CWE {cwe_id}: {e}")
        return []
    except Exception as e:
        print(f"Error occurred in cwe2cve: {e}")
        return []
```

TTP→CWE

CWE→CVE

3. 실험 결과

· 기능 실험

› CVE↔TTP 매핑 기능 테스트

(데이터) cti 테이블에 있는 CVE-TTP 데이터 784개를 사용

(실험 방법) CVE 데이터만 저장 후, CVE-CPE-TTP 매핑 과정을 수행
매핑 성공률과 정확성을 검증

(결과) 총 784개의 데이터 중 782개의 TTP 매핑 성공, 매핑 성공률 **99.74%**
실패 사례는 TTP 매핑에 필요한 CWE 데이터가 누락된 경우로 확인

· 성능 실험

› CVE↔TTP 매핑 성능 테스트

(데이터) CTI 수집 및 정형화 성능 실험과 같이 총 2,746개의 report

(실험 방법) CTI 수집 및 정형화 모듈과 CTI 기반 TTP 매핑 모듈 2개를
거쳐 CTI 통합 DB에 2차로 적재되는 시간을 측정

(실험 항목) CVE↔TTP 매핑까지 진행한 시간 측정

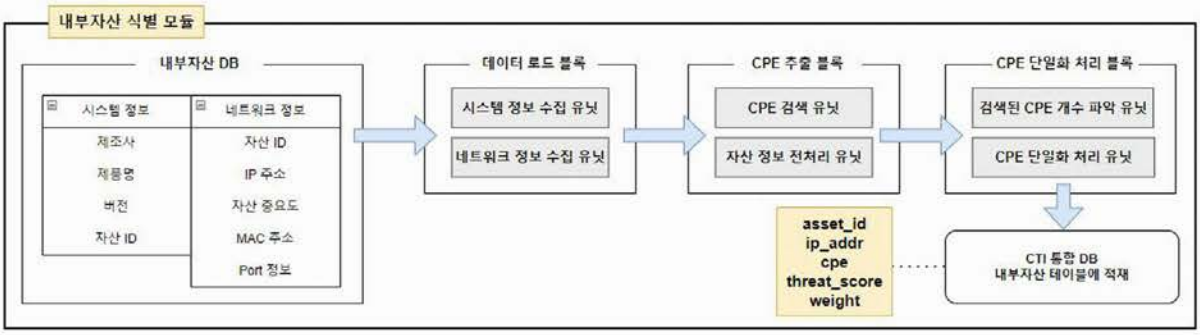
(성능 실험 결과) TAXII Server의 데이터가 CTI에 최종적으로 적재되는
전체 시간: **272.01 seconds**

- 내부 자산 CPE와 CTI 비교를 통한 위험도 산출 모듈 구현

1. 모듈 개요

· 내부자산의 CPE정보를 CTI와 비교하여 위험도 공식을 통한 위험도 산출

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



< 내부자산 식별 및 CPE 조합 프로세스 흐름도 >

2. 설계 및 구현

· 내부 자산 CPE 데이터 생성

(정의) 내부 자산 시스템 정보를 활용해 조합하여 CPE를 생성

(내부 자산 기존 데이터 형식) {

"sw_vendor": "CentOS",
"sw_product": "byacc",
"sw_version": "1.9.20130304",
"asset_id": "23509377352728582",
"ip": "228.226.180.209"

}

위 내용을 조합하여 CPE 생성 후 CTI 통합 DB의 internal_assets_network 테이블에 삽입

asset_id	ip_addr	cpe	threat_score	weight
109909062852688089	101.223.226.223	cpe:2.3:a:gnu:grub2:2.02:*:*:*:*:*:*:*	6.69	8
1339774888316368765	37.41.196.10	cpe:2.3:a:libdwarf_project:libdwarf:2013-02-07:*:*...	7.165	9
1520616660871029555	9.211.141.101	cpe:2.3:a:fontconfig_project:fontconfig:2.13.0:*:*...	7.186	6
159401821392642049	217.139.129.35	cpe:2.3:a:rpm:rpm:4.11.3:*:*:*:*:*:*:*	6.587	1
1709665186869270670	12.0.192.20	cpe:2.3:a:rsyslog:rsyslog:8.24.0:*:*:*:*:*:*:*	8.467	2
1733336611724310522	73.208.219.197	cpe:2.3:a:x.org:libxi:1.7.9:*:*:*:*:*:*:*	5.5	9
1783565520547009759	61.114.213.100	cpe:2.3:a:gnu:tar:1.26:*:*:*:*:*:*:*	6.14	3
1893219405672901887	82.5.142.255	cpe:2.3:a:git-scm:git:1.8.3.1:*:*:*:*:*:*:*	7.965	3

< 내부자산 정보 및 생성된 CPE로 기본 위험도와 중요도를 적재 >

```
def calculate_final_exploit_score(self, base_score, weight, cti_score):
    if cti_score is None:
        print("CTI Score is None, cannot calculate final exploit score.")
        return None
    else:
        final_exploit_score = (cti_score * 0.3) + (base_score * 0.4) + (weight * 0.3)
        print(f"Final Exploit Score calculated: {final_exploit_score}")  # 계산된 점수 출력
        return final_exploit_score
```

< 위험도 산출 공식을 적용하여 최종 위험도를 도출하는 코드 >

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다


```
{
    "Asset ID": "23509377352728582",
    "Asset CPE": "cpe:2.3:a:gnu:ncurses:5.9:*:*:*:*:*:*:*",
    "Asset Base Score": 2.0,
    "Asset Weight": 5.0,
    "CTI Base Score": 3.0,
    "Final Risk Score": 3.2
},
```


< 내부 자산 정보를 이용해 위험도 산출 공식을 거쳐 위험도를 얻어낸 결과>

· 위험도 산출 공식

(공식) 네트워크 내부 자산 위험도 =

(수집한 CTI 위험도 × 0.3)

+ (네트워크 자산 기본 위험도 × 0.4)

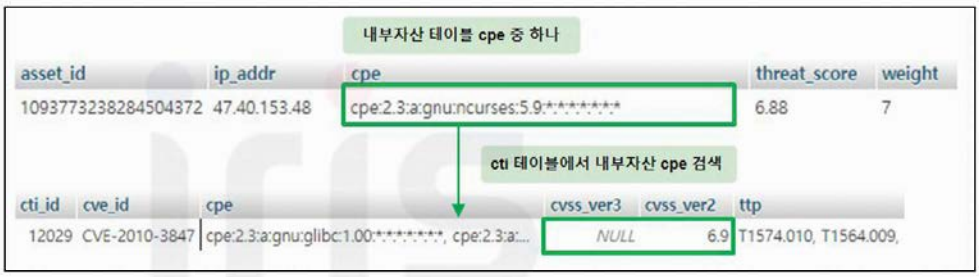
+ (자산 중요도 × 0.3)

(1) 수집한 CTI 위험도

(정의) 네트워크 내부자산의 cpe를 수집한 cti 테이블에서 검색했을 때 나오는 cve_id에 대한 cvss값

(입력) 내부자산 cpe (내부자산 식별 모듈을 거쳐 조합된 cpe)

(출력) cti 테이블에서 검색 후 일치하는 cpe를 가진 cve_id에 대한 cvss값

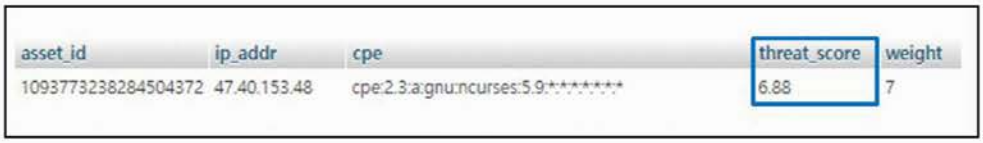


(2) 네트워크 자산 기본 위험도

(정의) 내부자산 cpe로 NVD에서 검색해 찾은 모든 cve들의 cvss값의 평균

*cvss값의 평균: cvss_ver3를 기준으로 평균 계산

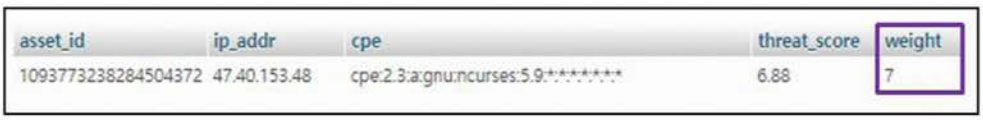
cvss_ver3의 값이 없다면 cvss_ver2 사용



(3) 네트워크 자산 중요도

(정의) 내부자산 cpe가 갖는 고유의 중요도

*고유값이므로 계산을 위해 랜덤값으로 임시 지정



(4) 위험도 산출 예시 결과:

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

3. 실험 결과

· CPE Level별 위험도 산출 실험

(정의) CPE의 Level별 위험도 산출 성공 개수를 측정

(결과) 내부자산의 45개 cpe 중 Level2의 cpe 4개가 cti의 cpe와 매핑이 성공
내부자산의 45개 cpe 중 Level3의 cpe 13개가 cti의 cpe와 매핑이 성공

	내부자산cpe의 level 분류 기준	예시) cpe:2.3:a:gnu:tar:1.26:*:*:*:*:*:*:*	내부자산cpe와 cti의 cve매핑 및 위험도 산출 성공 개수
Level 3	제품 버전 번호까지의 cpe	cpe:2.3:a:gnu:tar:1.26:	0
Level 2	제품명까지의 cpe	cpe:2.3:a:gnu:tar:	4
Level 1	제품제조사명까지의 cpe	cpe:2.3:a:gnu:	13

- TTP 매핑 모듈 기반 대응 전략 모듈 구현

1. 모듈 개요

· 내부자산의 정보와 연관된 TTP를 활용해서 대응 전략을 매핑하여 제공

2. 설계 및 구현

· TTP → 대응 전략 매핑:

(1) MITRE ATT&CK의 Mitigation을 활용하여 TTP와 매핑

(2) 매핑된 대응 전략 데이터를 CTI 통합 데이터베이스에 저장

```python
def asset_cpe2ttp_in_cti(self, cpe_value):  # 내부자산 cpe와 cti의 cpe를 비교하여 일치한다면, ttp값 받아오기
    cpe_parts = cpe_value.split(':')

    if len(cpe_parts) > 5:
        cpe_parts = cpe_parts[:5]

    cpe_prefix = ':'.join(cpe_parts) + ':'
    print(cpe_prefix)
    with self.db.cursor() as cursor:
        cursor.execute(f"SELECT ttp FROM cti WHERE cpe LIKE '{cpe_prefix}%'")
        result = cursor.fetchall()
        return [row[0] for row in result]

def get_miti_list(self, ttp_list):  # 받아온 ttp에 연관된 Mitigation 가져오기
    mitigation_data_path = r"C:\Users\ICSR\Desktop\연구실\KISA_testbed\KISA-System\lib\Providing_Response_Strategies_Module\Providing_Mitigation\att_to_miti_RE.json

    with open(mitigation_data_path, 'r') as json_file:
        mitigation_data = json.load(json_file)

    results = []
    for ttp in ttp_list:
        for entry in mitigation_data:
            if entry['technique_id'] == ttp:  # technique_id가 일치하는 경우
                results.append(entry.get('miti_list', []))
                print(results)
    return results
```

asset_id	ip_addr	mac_a	cpe	cve_id	asset_base_score	cti_score	final_exploit_score	ttp	defense_strategy
1468312967383570620	73.208.219.197	NULL	cpe:2.3:a:x.org:libxi:1.7.9:*:*:*:*:*:*:*	CVE-1999-0526	5.5	10	7.3	NULL	NULL
1613749196818874243	65.132.208.45	NULL	cpe:2.3:a:logrotate_project:logrotate:3.8.6:*:*:...	NULL	7.57	NULL	NULL	NULL	NULL
1787739514041864085	42.1.166.127	NULL	cpe:2.3:a:fontconfig_project:fontconfig:2.13.0:*:...	NULL	7.186	NULL	NULL	NULL	NULL
1796915856217602762	9.211.141.101	NULL	cpe:2.3:a:fontconfig_project:fontconfig:2.13.0:*:...	NULL	7.186	NULL	NULL	NULL	NULL
1963508261204695028	98.114.180.198	NULL	cpe:2.3:a:avahi:avahi:0.6.31:*:*:*:*:*:*:*	CVE-2008-5081	6.237	5	6.3948	NULL	NULL
2035045584574329074	108.29.141.168	NULL	cpe:2.3:a:gnu:ncurses:5.9:*:*:*:*:*:*:*	CVE-2010-3847	6.88	6.9	5.122	T1027.009, T1574.010, T1547.009, T1027.006, T1564...	M1054, M1032, M1017
2113138781456077935	47.40.153.48	NULL	cpe:2.3:a:gnu:ncurses:5.9:*:*:*:*:*:*:*	CVE-2010-3847	6.88	6.9	7.222	T1027.009, T1574.010, T1547.009, T1027.006, T1564...	M1054, M1032, M1017
2349380848552148285	60.120.46.80	NULL	cpe:2.3:a:alsa-project:alsa:1.1.8:*:*:*:*:*:*:*	NULL	7	NULL	NULL	NULL	NULL

3. 실험 및 결과

· 대응 전략 매핑 테스트:

(정의) 내부자산의 45개 cpe들 중 Level1에 해당하는 cpe만 활용하여 ttp 및 대응 전략 매핑 테스트 진행

(결과) 총 45개 cpe 중 Level1에 해당하는 cpe 7개가 ttp 및 대응전략 매핑됨

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

o 보안 위협 인텔리전스 통합 데이터베이스 구축

- CTI 통합 데이터베이스 스키마 개선

· 불필요한 소스는 배제하고, CTI와 내부자산 간의 연관성을 간결하게 유지

› 이전 주요 테이블 5개 중 파일 관리 테이블, 대응전략 테이블 삭제
→ 대응 전략 테이블은 JSON 파일로 매핑하여 USER 테이블에 저장
CVE_Detail 테이블 추가
→ 결측치를 처리할 때, NVD 웹크롤링을 반복하지 않고 테이블에서 값을 빠르게 가져오기 위함

› CTI 통합 데이터베이스 핵심 테이블 구조

(1) cti 테이블 스키마

	#	이름	종류	데이터정렬방식	보기	Null	기본값	설명	추가	실행
☐	1	cti_id	int			아니오	없음		AUTO_INCREMENT	변경 삭제 더보기
☐	2	cve_id	varchar(100)	utf8mb3_general_ci		예	NULL			변경 삭제 더보기
☐	3	cpe	longtext	utf8mb3_general_ci		예	NULL			변경 삭제 더보기
☐	4	cvss_ver3	float			예	NULL			변경 삭제 더보기
☐	5	cvss_ver2	float			예	NULL			변경 삭제 더보기
☐	6	ttp	longtext	utf8mb3_general_ci		예	NULL			변경 삭제 더보기

(2) cve_detail 테이블 스키마

	#	이름	종류	데이터정렬방식	보기	Null	기본값	설명	추가	실행
☐	1	cve_id	longtext	utf8mb4_0900_ai_ci		예	NULL			변경 삭제 더보기
☐	2	cpe	longtext	utf8mb4_0900_ai_ci		예	NULL			변경 삭제 더보기
☐	3	cvss_ver3	longtext	utf8mb4_0900_ai_ci		예	NULL			변경 삭제 더보기
☐	4	cvss_ver2	longtext	utf8mb4_0900_ai_ci		예	NULL			변경 삭제 더보기

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

(3) internal_assets_network 테이블 스키마

#	이름	종류	데이터정렬방식	보기	Null	기본값	설명	추가	실행
1	asset_id	varchar(20)	utf8mb3_general_ci		아니오	없음			변경 삭제 더보기
2	ip_addr	varchar(39)	utf8mb3_general_ci		아니오	없음			변경 삭제 더보기
3	cpe	longtext	utf8mb3_general_ci		예	NULL			변경 삭제 더보기
4	threat_score	longtext	utf8mb3_general_ci		예	NULL			변경 삭제 더보기
5	weight	int			아니오	없음			변경 삭제 더보기

(4) user 테이블 스키마

#	이름	종류	데이터정렬방식	보기	Null	기본값	설명	추가	실행
1	check_id	int			아니오	없음		AUTO_INCREMENT	변경 삭제 더보기
2	asset_id	varchar(20)	utf8mb3_general_ci		아니오	없음			변경 삭제 더보기
3	ip_addr	varchar(39)	utf8mb3_general_ci		아니오	없음			변경 삭제 더보기
4	cpe	longtext	utf8mb3_general_ci		예	NULL			변경 삭제 더보기
5	cve_id	longtext	utf8mb3_general_ci		예	NULL			변경 삭제 더보기
6	asset_base_score	longtext	utf8mb3_general_ci		예	NULL			변경 삭제 더보기
7	cti_score	longtext	utf8mb3_general_ci		예	NULL			변경 삭제 더보기
8	final_exploit_score	longtext	utf8mb3_general_ci		예	NULL			변경 삭제 더보기
9	ttp	longtext	utf8mb3_general_ci		예	NULL			변경 삭제 더보기
10	defence_strategy	longtext	utf8mb3_general_ci		예	NULL			변경 삭제 더보기

› 테이블 간 관계

① cti ↔ cve_detail: cve_detail의 정보를 이용해 결측치 해결

② cti ↔ internal_assets_network: 내부자산 cpe 비교 일치 확인 및 정보 선택

③ cti & internal_assets_network ↔ user: 수집한 모든 정보를 user에 정리

- CTI 통합 데이터베이스 구축 결과

· 4가지 주요 테이블 구현

(1) cti 테이블 데이터 저장 결과

cti_id	cve_id	cpe	cvss_ver3	cvss_ver2	ttp
3423	CVE-2023-5631	'cpe:2.3:a:roundcube:webmail:*:*:*:*:*:*:*:*', cpe:...	6.1	NULL	T1203,T1083,T1212,T1571,T1056,T1078,T1114,T1566
3424	CVE-2024-21412	'cpe:2.3:o:microsoft:windows_10_1809:*:*:*:*:*:*:a...	8.1	NULL	T1611, T1083, T1574.005, T1574.010, T1565.002, T10...
3428	CVE-2024-21413	'cpe:2.3:a:microsoft:365_apps:-:*:*:*:enterprise:*...	9.8	NULL	T1574.007, T1539, T1574.006, T1553.002, T1562.003,...
3429	CVE-2024-21410	'cpe:2.3:a:microsoft:exchange_server:2016:cumulati...	9.8	NULL	T1550.001, T1134, T1563, T1548, T1185, T1505.003, ...
3430	CVE-2023-23397	'cpe:2.3:a:microsoft:365_apps:-:*:*:*:enterprise:*...	9.8	NULL	T1574.007, T1021.002, T1558.003, T1574.006, T1114....
3431	CVE-2023-35636	'cpe:2.3:a:microsoft:365_apps:-:*:*:*:enterprise:*...	6.5	NULL	T1016, T1550.004, T1217, T1082, T1134.001, T1574.0...
3434	CVE-2012-1258	'cpe:2.3:a:plixer:scrutinizer_net_&_s_analyzer:*:*...	6.5	4	T1550.001, T1134, T1563, T1548, T1185, T1505.003, ...
3444	CVE-2012-0158	'cpe:2.3:a:microsoft:office:2003:sp3:*:*:*:*:*:*', ...	NULL	9.3	T1027.006, T1027.009, T1564.009

(2) cve_detail 테이블 데이터 저장 결과

cve_id	cpe	cvss_ver3	cvss_ver2
CVE-2021-31601	'cpe:2.3:a:hitachi:vantara_pentaho:*:*:*:*:*:*:*:*...	7.1	4.0
CVE-2021-31602	'cpe:2.3:a:hitachi:vantara_pentaho:*:*:*:*:*:*:*:*...	5.3	5.0
CVE-2021-31604	'cpe:2.3:a:openvpn-monitor_project:openvpn-monitor...	6.5	4.3
CVE-2021-31605	'cpe:2.3:a:openvpn-monitor_project:openvpn-monitor...	7.5	7.8
CVE-2021-31606	'cpe:2.3:a:openvpn-monitor_project:openvpn-monitor...	7.5	5.0
CVE-2021-31607	'cpe:2.3:a:saltstack:salt:*:*:*:*:*:*:*:*'	7.8	4.6

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

(3) internal_assets_network 테이블 데이터 저장 결과

asset_id	ip_addr	cpe	threat_score	weight
5476817706246407670	15.252.147.105	cpe:2.3:a:netfilter:libnfnetlink:1.0.1:*:*:*:*:*:*...	4.567	6
5613478068052280523	90.185.49.211	cpe:2.3:a:libexpat:expat:2.1.0:*:*:*:*:*:*:*	6.69	3
5691826251326918083	91.105.4.177	cpe:2.3:a:selinuxproject:libsemanage:2.5:*:*:*:*:*:...	5.683	9
5700115262114765907	138.0.33.210	cpe:2.3:a:baseurl:yum:3.4.3:*:*:*:*:*:*:*	7.4	2
6036251880965953415	152.169.72.189	cpe:2.3:a:libuser_project:libuser:0.60:*:*:*:*:*:*...	5.9	5
6088775335108469304	63.42.125.37	cpe:2.3:a:utempter_project:utempter:1.1.6:*:*:*:*:...	6.45	2
6604541689382149709	240.99.67.28	cpe:2.3:a:perl:perl:5.16.3:*:*:*:*:*:*:*	8.125	2

(4) user 테이블 데이터 저장 결과

check_id	ranking	asset_id	ip_addr	mac_a	cpe	cve_id	asset_base_score	ctl_score	final_exploit_score	ttp	defense_strategy
8	NULL	1466912967383570620	73.208.219.197	NULL	cpe:2.3:a:x.org:libxi:1.7.9:*:*:*:*:*:*:*	CVE-1999-0526	5.5	10	7.3	NULL	NULL
9	NULL	1613749196818874243	65.132.208.45	NULL	cpe:2.3:a:logrotate_project:logrotate:3.8.6:*:*:...	NULL	7.57	NULL	NULL	NULL	NULL
10	NULL	1787739514041664065	42.1.166.127	NULL	cpe:2.3:a:fontconfig_project:fontconfig:2.13.0:*:...	NULL	7.186	NULL	NULL	NULL	NULL
11	NULL	1796915856217602762	9.211.141.101	NULL	cpe:2.3:a:fontconfig_project:fontconfig:2.13.0:*:...	NULL	7.186	NULL	NULL	NULL	NULL
12	NULL	1963508261204695028	98.114.180.198	NULL	cpe:2.3:a:avahi:avahi:0.6.31:*:*:*:*:*:*:*	CVE-2008-5081	6.237	5	6.3948	NULL	NULL
13	NULL	2035045584574329074	108.28.141.168	NULL	cpe:2.3:a:gnu:ncurses:5.9:*:*:*:*:*:*:*	CVE-2010-3847	6.88	6.9	5.122	T1027.009, T1574.010, T1547.009, T1027.006, T1564...	M1054, M1032, M1017
14	NULL	2113138781456077935	47.40.153.48	NULL	cpe:2.3:a:gnu:ncurses:5.9:*:*:*:*:*:*:*	CVE-2010-3847	6.88	6.9	7.222	T1027.009, T1574.010, T1547.009, T1027.006, T1564...	M1054, M1032, M1017
15	NULL	2349380848552148285	60.120.46.80	NULL	cpe:2.3:a:alsa-project:alsa:1.1.8:*:*:*:*:*:*:*	NULL	7	NULL	NULL	NULL	NULL

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

세부 기술 ② 보안 위협 분석 및 대응을 위한 플레이북 자동 생성 기술 고도화

□ 연구 목표

o 보안 관제 플레이북 자동 생성 기술 고도화

o 보안 관제 플레이북 검증·관리 기술 고도화

□ 연구 목표별 추진 실적

연구목표	보안 관제 플레이북 자동 생성 기술 고도화

세부 내용	1) 보안 위협의 대응 이력에 대한 강화학습 모델을 통한 적응형 플레이북 강화 기술 개발

o 강화학습 모델 적용을 위한 데이터 분석 및 전처리

- 강화학습을 위해서 입력 데이터와 출력 데이터의 명확한 데이터 정의가 필요하며, 이에 맞게 데이터 구성
  > 이벤트 데이터 (event_id) - 보안 이벤트에 대한 고유 식별자
  > 대응 데이터 (response_id) - 각 이벤트에 대응하는 보안 조치
- 이러한 데이터를 처리하기 위해서 이벤트와 대응 데이터를 인코딩하여 모델에 입력 가능하도록 변환
  > 이벤트 데이터의 인코딩 - event_id_encoded
  > 대응 데이터의 인코딩 - response_id_encoded
- LabelEncoder를 사용하여 이벤트와 대응 데이터를 정수 형태로 변환
- 텍스트 데이터 처리 후 강화학습 환경에 맞게 매핑된 구조로 설정

```python
import numpy as np
import pandas as pd
from sklearn.preprocessing import LabelEncoder
import gym
from gym import spaces
import time
from tensorflow.keras import layers, models, optimizers
from collections import deque
import random

# 데이터 로드 및 전처리
file_path = '대응_학습데이터_선별.xlsx'
data = pd.read_excel(file_path, index_col=0)

# Label Encoding for categorical variables
event_id_encoder = LabelEncoder()
response_id_encoder = LabelEncoder()

data['event_id_encoded'] = event_id_encoder.fit_transform(data['event_id'])
data['response_id_encoded'] = response_id_encoder.fit_transform(data['response_id'])
```

< 강화학습 모델 적용을 위한 데이터 분석 및 전처리 코드 예시 >

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

o 플레이북 추천 기술을 위한 강화학습 환경 설정

- 환경 클래스: ResponseEnv
  > 인코딩된 이벤트 데이터를 입력으로 받음
  > 인코딩된 대응 데이터를 출력으로 반환
- 환경 구조는 Observation Space와 Action Space로 구성되어 있음
  > Observation Space는 이벤트의 고유 ID를 정수화한 값
  > Action Space는 대응책의 고유 ID를 정수화한 값

```python
# Gym 환경 설정
class ResponseEnv(gym.Env):
    def __init__(self, data):
        super(ResponseEnv, self).__init__()

        self.data = data
        self.action_space = spaces.Discrete(len(response_id_encoder.classes_))
        self.observation_space = spaces.Discrete(len(event_id_encoder.classes_))

        self.current_idx = 0

    def reset(self):
        self.current_idx = 0
        return self.data['event_id_encoded'].iloc[self.current_idx]

    def step(self, action):
        done = False
        reward = 0
        response = self.data['response_id_encoded'].iloc[self.current_idx]

        if action == response:
            reward = 1

        self.current_idx += 1
        #         print('current_dix', self.current_idx)
        #         print('self.data', len(self.data))
        if self.current_idx >= len(self.data):
            done = True
            self.current_idx = 0  # Reset for next episode

        next_state = self.data['event_id_encoded'].iloc[self.current_idx]

        return next_state, reward, done, {}

    def render(self, mode='human', close=False):
        pass
```

< 플레이북 추천 기술을 위한 강화학습 환경 설정 코드 예시 >

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

o 적응형 플레이북 강화학습 모델 구현

- 사용 알고리즘은 DQN 기반 모델을 사용
- 모델 구조
  > Embedding 레이어를 사용하여 이벤트 ID를 64차원 벡터로 변환
  > Fully Connected (Dense) 레이어를 통해 학습
  > 가능한 모든 대응책에 대한 Q-value가 계산
  > 따라서, 가장 적절한 대응의 시퀀스 집합이 출력
- 모델 하이퍼파라미터
  > 학습률: 0.001
  > 할인율 (Gamma): 0.99
  > 초기 탐색 비율 (Epsilon): 1.0 (감소 비율: 0.995)
  > 배치 크기: 32
  > 메모리 크기: 2000

```
# 환경 인스턴스 생성
env = ResponseEnv(data)

# 하이퍼파라미터 설정
num_actions = len(response_id_encoder.classes_)
num_states = len(event_id_encoder.classes_)
gamma = 0.99
epsilon = 1.0
epsilon_min = 0.01
epsilon_decay = 0.995
batch_size = 32
learning_rate = 0.001
memory = deque(maxlen=2000)


# 모델 정의
def build_model():
    model = models.Sequential()
    model.add(layers.Embedding(num_states, 64, input_length=1))
    model.add(layers.Flatten())
    model.add(layers.Dense(64, activation='relu'))
    model.add(layers.Dense(128, activation='relu'))
    model.add(layers.Dense(num_actions, activation='linear'))
    model.compile(optimizer=optimizers.Adam(learning_rate=learning_rate), loss='mse')
    return model


model = build_model()
target_model = build_model()
target_model.set_weights(model.get_weights())
```

< 적응형 플레이북 강화학습 모델 구현 코드 예시 >

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

o 적응형 플레이북 강화학습 모델 학습과정

- 초기화를 진행하여 환경 리셋 및 상태 관찰
- 강화학습 중 다음과 두 가지 학습을 혼합하여 진행
  > 탐험(Exploration) 과정을 거쳐서 일부 과정에서는 랜덤 선택을 따름
  > 활용(Exploitation) 과정을 거쳐서 일부 과정에서는 Q-value 기반 최적 행동 선택을 따름
- 보상 계산 및 메모리 저장도 함께 수행
- 위와 같은 과정들을 통해서 최종적으로 강화학습 네트워크 학습 수행
  > 타겟 모델과의 예측 차이 최소화
  > 코사인 유사도 기반 이벤트와 대응 라벨 매칭

```
# 메인 학습 루프
episodes = 200

start = time.time()
for e in range(episodes):
    print('episodes : ', e)
    state = env.reset()
    done = False
    total_reward = 0

    while not done:
        if np.random.rand() <= epsilon:
            action = np.random.choice(num_actions)
        else:
            q_values = model.predict(np.array([state]))
            action = np.argmax(q_values[0])

        next_state, reward, done, _ = env.step(action)
        memory.append((state, action, reward, next_state, done))
        state = next_state
        total_reward += reward

        train_model(model, target_model, memory, batch_size, gamma)

        if done:
            target_model.set_weights(model.get_weights())
            if epsilon > epsilon_min:
                epsilon *= epsilon_decay
            print(f"Episode: {e + 1}/{episodes}, Reward: {total_reward}, Epsilon: {epsilon:.2f}")

end = time.time()
print(f"{end - start:.5f} sec")

print(model.predict(data['event_id_encoded'].values))
```

< 적응형 플레이북 강화학습 모델 학습과정 코드 예시 >

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

o 강화학습 모델 결과 및 성능 평가
- 총 200 에피소드 학습
- 최종 평균 보상 및 Epsilon 값 확인
- 약 90%의 정확도 달성

```
from sklearn.metrics import accuracy_score
accuracy_score(true, pred)
```

```
0.8611111111111112
```

```
true
```

```
array([12, 14, 13,  5,  3, 16, 16, 16,  9, 16,  6,  0,  7, 16,  2, 11, 16,
       16, 16, 16,  6,  1,  3, 11, 16, 12, 16, 16, 17, 15, 10, 16, 16,  8,
        4, 16])
```

```
pred
```

```
array([13, 13, 13,  5, 13, 16, 16, 16,  9, 16, 13, 13,  7, 16,  2, 11, 16,
       16, 16, 16,  6,  1,  3, 11, 16, 12, 16, 16, 17, 15, 10, 16, 16,  8,
        4, 16], dtype=int64)
```

< 강화학습 모델 결과 및 성능 평가 예시 >

o 적응형 플레이북 시범 사용 데이터셋 분석 및 재구성
- 플레이북 추천 기술의 성능 시험을 위하여 이분 그래프(Bipartite graph) 형태로 표현 가능한 보안 관제 분야 타 데이터셋 후보 선정
- 실제 보안 관제 데이터셋의 경우, attack-response 의 형태를 갖춘 데이터가 한정적
- 이러한 점을 고려하여, 기존 데이터셋으로 훈련 후 타 데이터셋으로 테스트를 수행
  > 보안 이벤트 데이터를 입력으로 받아, 기존 데이터셋에서 유사도를 계산
  > 이를 통해 유사도 점수가 높은 순으로 이벤트와 대응책을 매칭하여 테스트 데이터로 활용
- 시범 데이터 활용을 위한 데이터셋 재구성 과정
  > 시범 데이터셋 분석
    · 보안 위협 탐지 및 대응 자동화에 활용할 수 있는 텍스트 기반 사이버 위협 탐지 데이터셋 활용
    · 발생한 보안 위협과 이에 대한 탐지 및 대응의 쌍으로 구성된 476개의 데이터 항목을 포함함
      ① 텍스트 기반 위협 정보
        - 다양한 보안 이벤트 및 위협 정보를 텍스트 형식으로 제공함
        - 위협의 상세한 설명, 발생 시간, 영향받은 시스템 구성 요소 등을 포함
        - 데이터 예시: “Phishing email containing malicious attachment targeting employees.”
        - 이러한 데이터는 비정형 텍스트 형식으로 제공되며, 이를 정형화하고 벡

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

터화하는 과정이 필요함

② 위협 대응 데이터

- 각 위협 이벤트에 대한 대응책(action-response)의 예시를 포함
- 대응책은 특정 위협에 대한 예방, 탐지, 완화 전략을 제안
- 데이터 예시: “Block the IP address and initiate multi-factor authentication.”
- 대응책은 단순한 대응 단계를 넘어 복합적인 보안 절차를 포함함

③ 구조적 데이터와의 관계 정보

- 위협과 대응 간의 관계를 구조적으로 정의하여 데이터 분석과 모델 학습에 활용 가능
- 이를 통해 위협과 대응 간의 매칭 및 연계성을 기반으로 데이터셋 재구성 및 확장이 가능함

Title Name of incident	Date date	Affiliations organization responsible	Description A description	Response Type of response	Victims Target
477 unique values	2005-08-25 2020-11-14	[null] 28% Believed to be the ... 3% Other (332) 69%	479 unique values	[null] 82% Criminal charges h... 0% Other (84) 17%	[null] 6% United States 4% Other (432) 90%
Attack on Austrian foreign ministry	2/13/2020	Turla	The suspected Russian hackers conducted a weeks-long attack on Austria's foreign ministry.	Confirmation https://www.theregister.co.uk/2020/02/14/austria_foreign_ministry_hack_turla_group_al...	Austrian Foreign Ministry
Spear-phishing campaign against unnamed U.S. government agency	1/23/2020	Konni Group	The suspected North Korean threat actor Konni Group attempted to trick employees of an unnamed U.S. ...		Employees of the U.S. government
Australian Signals Directorate	4/6/2020		Responsible for attacking infrastructure that cyber criminals abroad were using to target Australian...		
Catfishing of Israeli soldiers	2/16/2020	APT-C-23	The Hamas-associated threat actor APT-C-23 targeted Israeli soldiers by pretending to be women looki...	Hack Back https://www.bleepingcomputer.com/news/security/hacker-group-catfishes-israeli-soldiers-i...	Israeli Defense Forces (IDF) soldiers

< 플레이북 추천 기술 성능 시험을 위한 시범 데이터 예시 >

> 데이터 전처리 과정

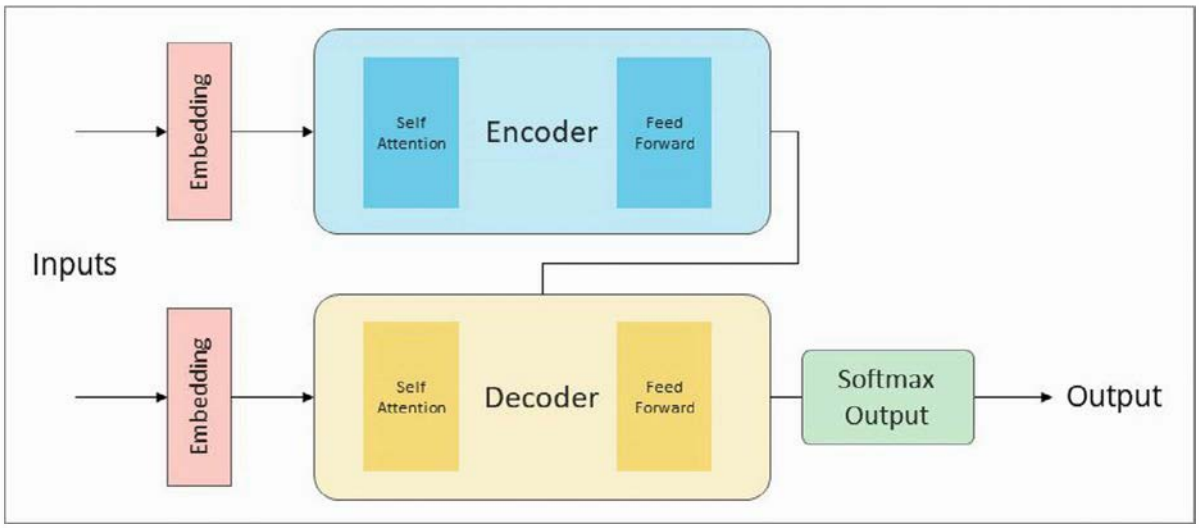
- 텍스트 데이터를 모델이 학습 가능한 벡터 형태로 변환하는 과정이 필요함. 이를 위해, 자연어 처리(NLP) 기술과 딥러닝 모델을 활용
- 자연어 문장 형태의 원시 데이터(raw data)를 벡터화하기 위하여 트랜스포머(Transformer) 기반 모델인 Sentence Transformer를 사용

* 트랜스포머 모델

- 자연어 처리(NLP) 분야에서 혁신적인 딥러닝 모델로, 문장 간의 관계와 문맥을 파악하는 데 매우 효과적임
- 이전의 RNN (Recurrent Neural Network) 모델은 문장을 순차적으로 처리했기 때문에 긴 문장이나 복잡한 문맥을 이해하는 데 한계가 존재
- 트랜스포머 모델은 주의(attention) 메커니즘을 통해 모든 단어 간의 관계

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

를 동시에 분석하여 문장 전체를 한 번에 분석하여 단어의 의미를 더 정확히 이해할 수 있음



< 트랜스포머 모델 구조도 >

- Sentence Transformer는 단어 단위의 단순 비교 대신, 문자의 맥락과 구조를 고려하여 384차원의 벡터를 생성함
- 사전학습된 다양한 Sentence Transformer 모델들 중, all-MiniLM-L6-v2 모델 활용
- 해당 모델은 빠르고 효율적인 텍스트 간 유사성 계산에 적합한 모델로, 텍스트 데이터를 384차원의 벡터로 변환함
- 생성된 벡터는 텍스트 간 유사성 계산을 통해 학습 데이터셋과 새로운 시범 데이터셋 간의 의미적 비교를 수행하는 데 사용

```
from sentence_transformers import SentenceTransformer
from sentence_transformers import util

model = SentenceTransformer('sentence-transformers/all-MiniLM-L6-v2')
df1_event_embeddings = model.encode(df_label_123, convert_to_tensor=True)
df2_event_embeddings = model.encode(df2_event, convert_to_tensor=True)
```

< Sentence Transformer 기반 데이터 전처리 실행 코드 예시 (일부) >

> 코사인 유사도(cosine similarity) 기반 공격 이벤트(event) 라벨 매칭 과정

- 기존 학습 데이터셋의 텍스트 임베딩과 새로운 데이터셋의 임베딩 벡터 간의 코사인 유사도를 계산함. 유사도 값은 -1에서 1 사이의 값으로 나타나며, 1에 가까울수록 두 텍스트의 의미가 비슷함을 의미함
- 예를 들어, "비정상적인 로그인 시도가 탐지되었습니다."라는 문장이 "비정상적인 접속 경로가 감지 되었습니다." 와 매우 유사한 의미를 지닐 경우, 두 문장 간의 코사인 유사도 값은 1에 가까운 값을 가짐.
- 코사인 유사도 계산을 통해 단순한 문자열 일치 여부를 넘어 문장의 전체적

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

인 의미를 고려하여 유사성을 판단할 수 있음

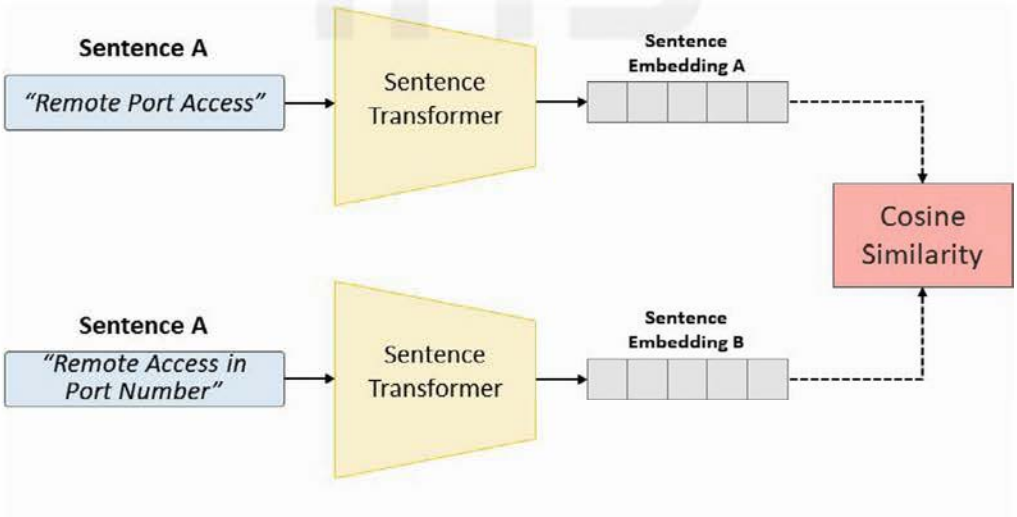
· 각 텍스트에 대해 가장 높은 코사인 유사도를 가진 기존 데이터셋의 보안 사건 라벨을 찾아 매칭함

```python
from numpy import dot
from numpy.linalg import norm

def cosine_similarity(emb1, emb2):
    cos_sim = dot(emb1, emb2) / (norm(emb1) * norm(emb2))

    return cos_sim
```

< 코사인 유사도 계산 실행 코드 예시 (일부) >

```python
best_sim_seq = []
for i in range(len(df_prep_solutions)):
    df1_res_embeddings = model.encode(df_prep_solutions[i], convert_to_tensor=True)
    best_sim_res = []
    for i in range(df1_res_embeddings.shape[0]):
        cos_sim = util.pytorch_cos_sim(df1_res_embeddings[i], df2_res_embeddings.to(device))
        best_sim_idx = int(np.argmax(cos_sim.detach().cpu().numpy()))
        best_sim_res.append(best_sim_idx)
    best_sim_seq.append(best_sim_res)
```

< 코사인 유사도 기반 라벨 매칭 실행 코드 예시 (일부) >




```python
sent_a = model.encode("Remote Port Access")
sent_b = model.encode("Remote Access in port number")
cos_sim = util.pytorch_cos_sim(sent_a, sent_b).detach().cpu().numpy()
print("코사인 유사도 결과:", cos_sim)
```

```
코사인 유사도 결과: 0.8784515
```

< 코사인 유사도 계산을 위한 문장 임베딩 간 비교 예시 >

> 순서 유사도(sequence similarity) 기반 대응(response) 라벨 매칭 과정

· 보안 대응 절차는 여러 개의 순차적인 컴포넌트로 구성되며, 기존 데이터셋

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

의 대응 절차와의 매칭을 위하여 순서 유사도를 계산함

- 순서 유사도는 주로 단계적 절차(예: 대응책의 순서)를 비교할 때 유용하며, 데이터를 시퀀스로 간주하고 공통된 부분을 분석
- 파이썬의 difflib 패키지에서 제공되는 SequenceMatcher 알고리즘을 사용하여, 두 텍스트 간의 시퀀스를 비교하여 유사도를 계산
- 해당 알고리즘은 두 시퀀스 간의 공통된 부분(서브시퀀스)을 찾아내는 방식으로, 공통된 부분의 비율을 계산하여 0과1 사이의 값으로 유사도를 반환하여 0에 가까울 시 완전히 다름, 1에 가까울 시 완전히 같음을 의미함
- 예를 들어, “1-2-4-5” 와 “1-2-4-3-5” 의 두 대응 절차를 비교할 때, 두 텍스트 간의 공통된 컴포넌트와 구조를 찾아내어 유사성을 0과 1 사이의 값으로 반환
- 각 텍스트에 대해 가장 높은 순서 유사도를 가진 기존 데이터셋의 대응 라벨을 찾아 매칭

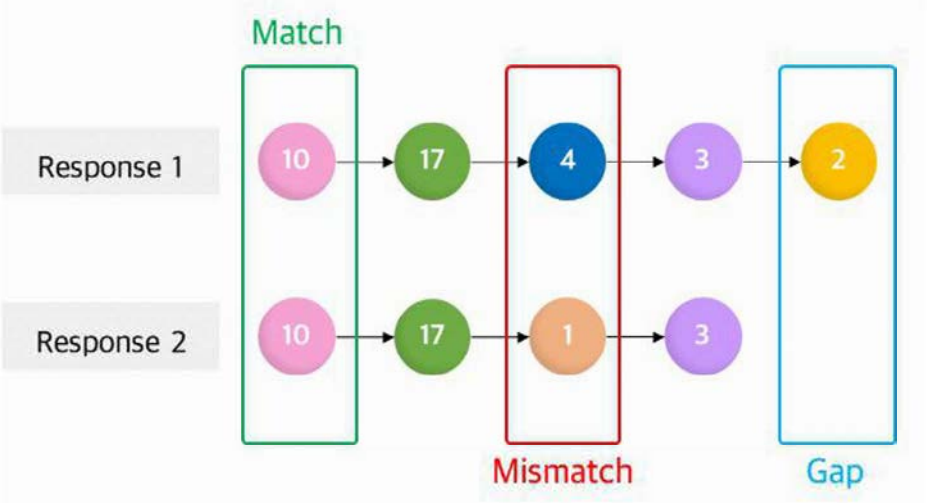
```python
from difflib import SequenceMatcher

def sequence_similarity(emb1, emb2):
    seq_sim = SequenceMatcher(None, emb1, emb2)

    return seq_sim.ratio()
```

< 순서 유사도 계산 실행 코드 예시 (일부) >

```python
best_res_sequences = []

for i in range(len(best_sim_seq)):
    temp = []
    for j in range(len(li_df_seq)):
        seq_sim = sequence_similarity(best_sim_seq[i], li_df_seq[j])
        temp.append(seq_sim)
    best_seq_sim = int(np.argmax(temp))
    best_res_sequences.append(best_seq_sim)
```

< 코사인 유사도 계산 실행 코드 예시 (일부) >

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다




```
seq_sim = sequence_similarity([10, 17, 4, 3, 2], [10, 17, 1, 3])
print("순서 유사도 결과:", seq_sim)
```

```
순서 유사도 결과: 0.6666666666666666
```

< 순서 유사도 계산을 위한 대응 절차 간 비교 예시 >

> 라벨 매칭 기반 데이터셋 재구성

- 공격 이벤트와 대응 라벨의 유사도 기반 매칭을 통해 기존 데이터셋의 라벨과 구조를 따르도록 재구성
- NLP와 딥러닝 기반의 데이터셋 재구성 기술은 추후 다양한 도메인의 텍스트 기반 자동화에도 적용 가능할 것으로 예상

event_id	response_seq	response_id
Remote_Port_Access_Suspicion	[2, 11, 6, 3]	14
Remote_Port_Access_Suspicion	[2, 6]	41
Remote_Port_Access_Suspicion	[2, 6]	41
Remote_Port_Access_Suspicion	[2, 6]	41
Remote_Port_Access_Suspicion	[2, 6]	41
...	...	...
Over_Access_from_Suspicion_IP_in_Malware	[2, 2, 2, 3]	23
URI	[2, 2, 2, 2]	0
Attack_Attempts_from_Harmful_IP	[2, 2, 2, 18]	30
Attack_More_3Type_from_Harmful_IP	[2, 2, 2, 0, 2, 7]	1
Over_Access_from_Suspicion_IP_in_Malware	[16, 2, 2, 16, 2]	0

< 재구성된 보안 위협 탐지 데이터셋 예시 (일부) >

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

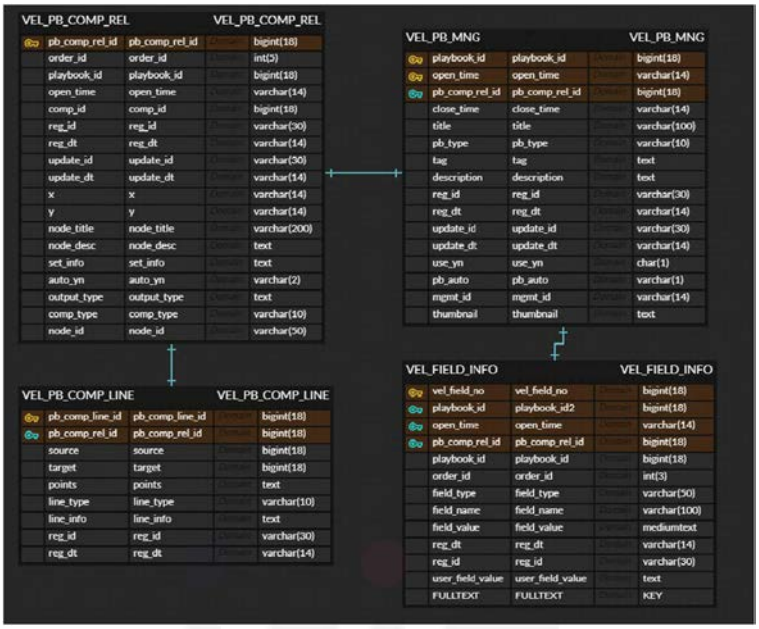
연구목표	보안 관제 플레이북 검증·관리 기술 고도화

세부 내용	1) 시뮬레이션 기반 플레이북 유효성 검증 기술 개발

1) 시뮬레이션 기반 플레이북 유효성 검증 기술 개발

> 시뮬레이션 기반 플레이북 검증 기능 영역 스키마 구현

> ERD 정보



> 스키마 정의서 및 DB 구현

- VEL_PB_MNG 테이블 : 검증 대상 플레이북 기본 정보

테이블 명	한글명	검증 플레이북 정보	영문명	VEL_PB_MNG	
개요	검증 플레이북 테이블				
컬럼	**컬럼명**	**한글컬럼명**	**키유형**	**Null**	**Type**
	playbook_id	플레이북 아이디	PK	NN	BIGINT(18)
	open_time	생성 시간	PK	NN	VARCHAR(14)
	close_time	삭제 시간			VARCHAR(14)
	pb_type	분류			VARCHAR(100)
	tag	태그			TEXT
	description	설명			TEXT
	reg_id	등록자			VARCHAR(30)
	reg_dt	등록일시			VARCHAR(14)
	update_id	최종 수정자			VARCHAR(30)
	update_dt	최종 수정일시			VARCHAR(14)
	use_yn	사용여부			CHAR(1)
	pb_auto	자동			VARCHAR(1)
	mgmt_id	플레이북 관리ID			VARCHAR(14)
	thumbnail	플레이북 썸네일 경로			TEXT
색인 ID	PRIMARY KEY (`playbook_id`,`open_time`)				
참고사항					

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

· VEL_PB_COMP_REL 테이블 : 검증 플레이북 내 단위 컴포넌트 정보

테이블 명	한글명	검증 컴포넌트 값	영문명	VEL_PB_COMP_REL
개요	검증 플레이북 내 컴포넌트 값			

컬럼	컬럼명	한글컬럼명	키유형	Null	Type
	pb_comp_rel_id	플레이북-컴포넌트 관계 id	PK	NN	BIGINT(18)
	order_id	컴포넌트 순서			INT(5)
	playbook_id	플레이북 id			BIGINT(18)
	open_time	어떤 시점의 플레이북인지 체크			VARCHAR(14)
	comp_id	컴포넌트 id			BIGINT(18)
	reg_id	등록자			VARCHAR(30)
	reg_dt	등록일시			VARCHAR(14)
	update_dt	수정 일시			VARCHAR(14)
	x	x			VARCHAR(14)
	y	y			VARCHAR(14)
	node_title	노드 제목			VARCHAR(200)
	node_desc	노드 설명			TEXT
	set_info	설정 정보			TEXT
	auto_yn	자동 여부			VARCHAR(2)
	output_type	결과값 정보			TEXT
	comp_type	컴포넌트 타입			VARCHAR(10)
	node_id	노드 아이디			VARCHAR(50)
색인 ID	PRIMARY KEY (`pb_comp_rel_id`)				
참고사항					

· VEL_PB_COMP_LINE 테이블 : 검증 플레이북 내 단위 컴포넌트 Relationship Line 정보

테이블 명	한글명	검증 플레이북 내 컴포넌트 라인	영문명	VEL_PB_COMP_LINE
개요	검증 플레이북 내 컴포넌트 연결 라인 정보			

컬럼	컬럼명	한글컬럼명	키유형	Null	Type
	pb_comp_line_id	플레이북-컴포넌트-라인 id	PK	NN	BIGINT(18)
	source	전 컴포넌트	PK	NN	BIGINT(18)
	target	후 컴포넌트			BIGINT(18)
	points	포인트			TEXT
	line_type	분류			VARCHAR(10)
	line_info	condition이거나 insert 시 필요정보 json형태로 기입			TEXT
	reg_id	등록자			VARCHAR(30)
	reg_dt	등록일시			VARCHAR(14)
색인 ID	PRIMARY KEY (`pb_comp_line_id`)				
참고사항					

· VEL_FIELD_INFO 테이블 : 검증 플레이북 내 컴포넌트 필드 Value 정보

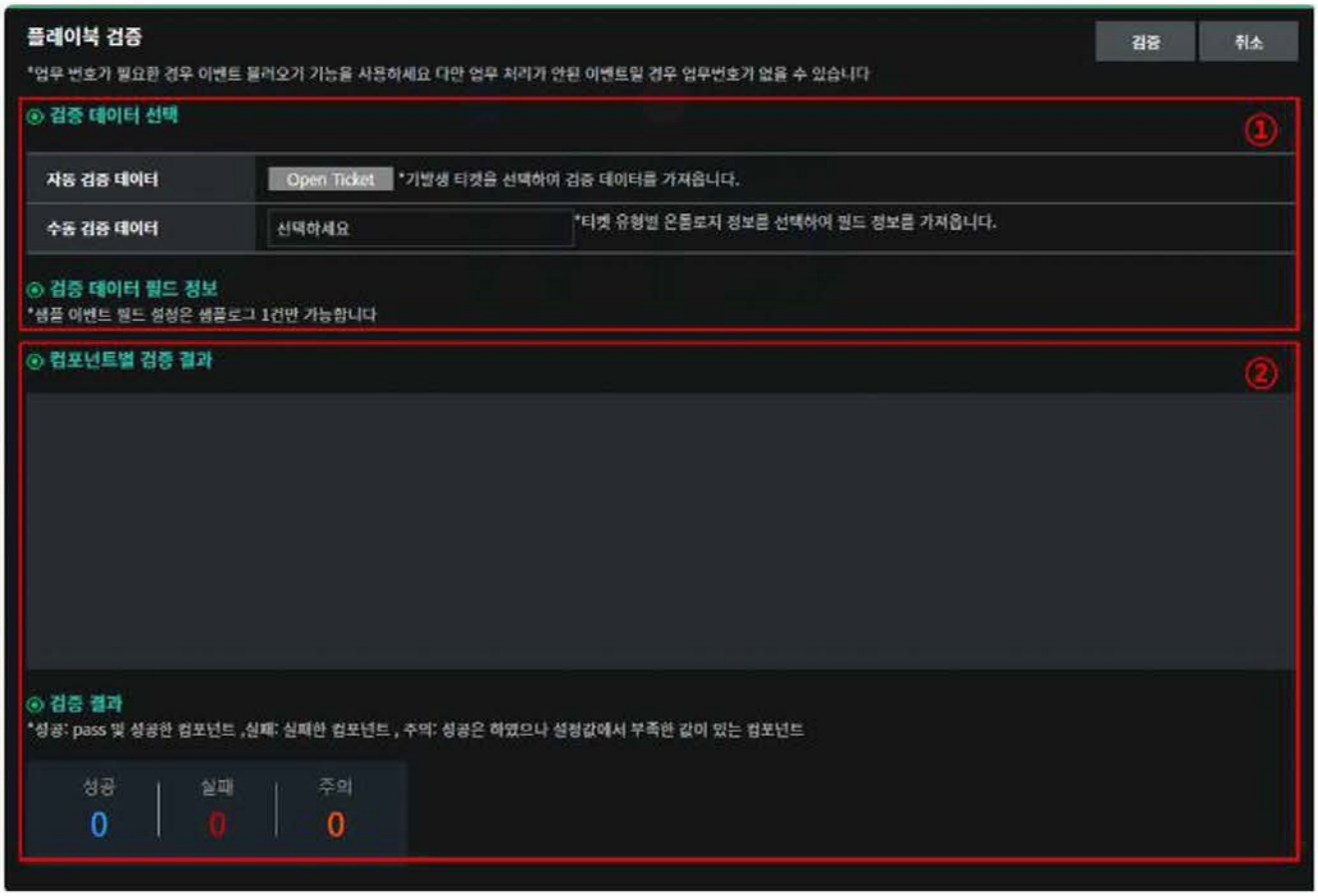
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

테이블 명	한글명	검증 플레이북 필드 정보	영문명	VEL_FIELD_INFO
개요	검증 플레이북 필드 정보			

컬럼	컬럼명	한글컬럼명	키유형	Null	Type
	vel_field_no	필드 번호	PK	NN	BIGINT(18)
	playbook_id	플레이북 아이디			BIGINT(18)
	order_id	순서			INT(3)
	field_type	필드 타입			VARCHAR(50)
	field_name	필드 이름			VARCHAR(100)
	field_value	필드 값			MIDIUMTEXT
	reg_dt	등록자			VARCHAR(14)
	reg_id	등록일시			VARCHAR(30)
	user_field_value	사용자 필드 값			TEXT

색인 ID	PRIMARY KEY (`vel_field_no`)
참고사항	

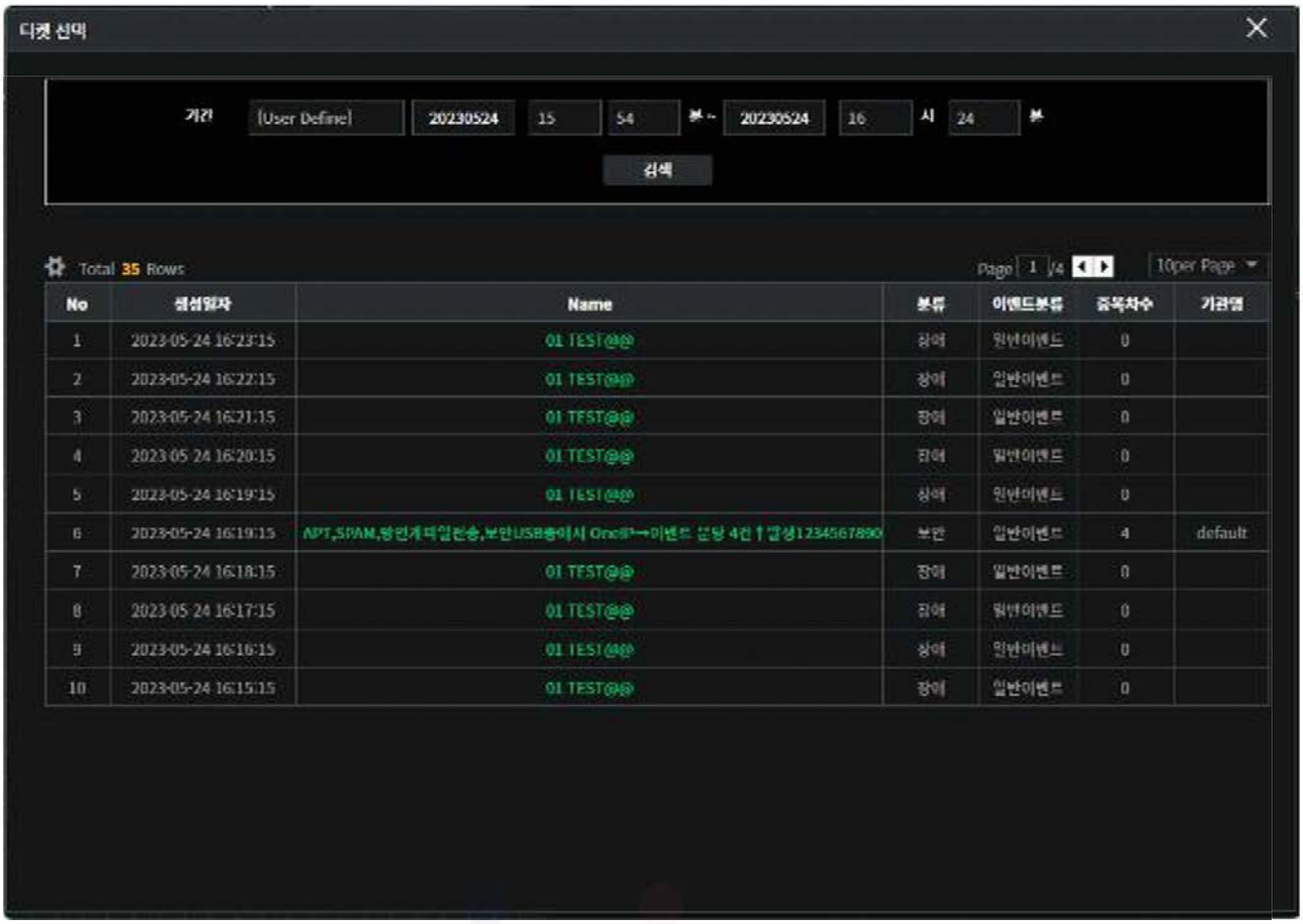
> 시뮬레이션 기반 플레이북 검증 연구 및 개발, 가시화 고도화



> 플레이북 검증용 데이터 선택 기능 개발

- 자동 검증 데이터
  - 기 발생 위협 티켓을 선택하여 검증 데이터를 가져 올 수 있음

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



- 수동 검증 데이터
  - 티켓 유형별 온톨로지 정보를 선택하여 필드 정보를 가져 올 수 있음

- 검증 데이터 필드 정보
- 자동 검증 데이터로 실제 티켓 선택 시, 해당 티켓의 데이터 정보가 자동으로 출력
- 수동 검증 데이터로 온톨로지 정보 선택 시, 온톨로지 정보가 출력되고 해당 필드의 값을 사용자가 직접 입력 필요

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

검증 데이터 필드 정보

*샘플 이벤트 필드 설정은 샘플로그 1건만 가능합니다

*ticket_nm	01 TEST@@	*attack_nm	Enter Value...	*eqp_ip	10.1.33.57
*src_ip	192.168.1.189	*dstn_ip	1.163.55.180	*src_port	Enter Value...
*dstn_port	1434	*hash	Enter Value...	*url	Enter Value...
*risk_level	Enter Value...	*risk_score	Enter Value...	*mla_result	Enter Value...
*mla_accuracy	Enter Value...	*total_result	Enter Value...	*undefined	Enter Value...
*eqp_asset_group_cd	1	*ruleset_id	99713602226749783	*undefined	Enter Value...
*task_id	SR230524-AW1-00001	*ticket_id	SR230524-T1-0000114	*tactic_id	x-mitre-tactic--d679b
*tactic_name	resource-developmen	*technique_id	attack-pattern--810d8	*technique_ref_id	T1584.005
*technique_name	Botnet	*ticket_dt	20230524162315		

> 플레이북 검증 결과 확인 가시화 기능 개발

- 컴포넌트별 검증 결과
- 컴포넌트별 검증 성공 유무와 결과 확인 가능
- 검증 결과

(1) 성공 : 검증 pass 및 성공한 컴포넌트 개수

(2) 실패 : 검증 실패한 컴포넌트 개수

(3) 주의 : 검증 성공은 하였으나 설정값에서 부족한 값이 있는 컴포넌트

세부 기술 ③ AI 기반 의사결정 추천 기술 및 분석 모델 고도화

□ 연구 목표

o AI 기반 최적 의사결정 자동 추천 기술 고도화

o 사이버 보안관제 업무 프로세스 평가 및 정량적 측정기술 개발

□ 연구 목표별 추진 실적

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

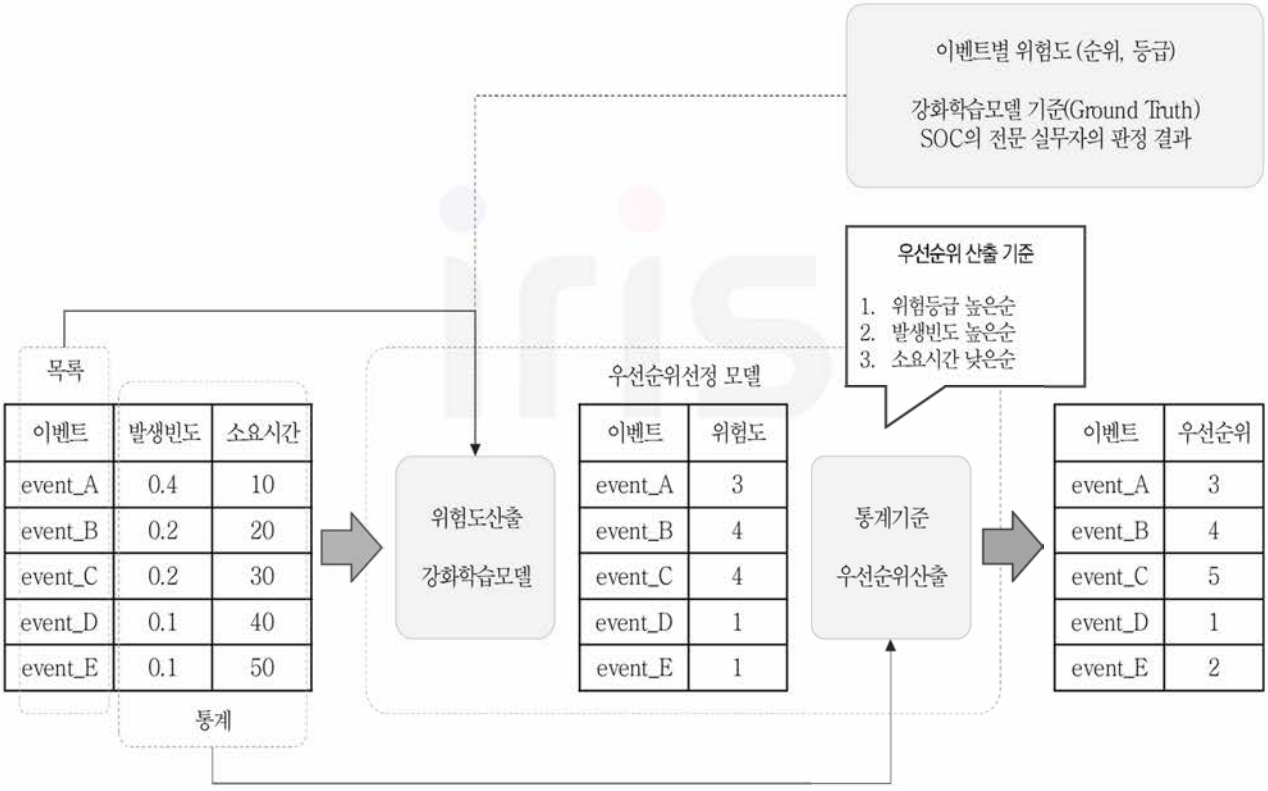
연구목표	AI 기반 최적 의사결정 자동 추천 기술 고도화

세부 내용	1) 강화 학습 기반 우선처리 이벤트 중요도 산정 및 자동 분류 모델 고도화 개발
	2) 강화 학습 기반 최적 대응 정책 추천 기술 고도화 개발
	3) 보안 관제 경보·대응 우선순위 부여 기술 고도화 개발

1) 강화 학습 기반 우선처리 이벤트 중요도 산정 및 자동 분류 모델 고도화 개발

o 모델 개요

- 다수의 보안 이벤트들을 대상으로 SOC의 전문인력의 판정 결과 데이터 대상으로 강화학습 모델을 개발하여 처리 우선순위 산출 자동화
- 이벤트별 위험도의 산출은 강화학습모델을 활용하고, 산출된 위험도와 시의성있는 통계 결과를 조합하여 최종 우선순위를 산출



<우선 순위 선정 모델 개념도>

o 우선순위를 부여한 이벤트 반환 강화학습을 위한 데이터 전처리

- 이벤트 및 대응 데이터는 사전 학습된 DQN 모델을 통해 매칭되도록 설계
  - 이벤트 목록(event_id_list)은 다양한 보안 이벤트를 나타내는 고유 ID 집합을 의미
  - 대응 목록(response_id_list)은 각 이벤트에 대한 다중 대응 방안의 집합임
  - 따라서, 총 데이터 샘플 수는 len(event_id_list)개 이며,
  - 사용자는 선호하는 대응 조치(response_id)를 제공할 수 있으며, 해당 데이터는 학습된 모델의 기본 추천 결과에 우선적으로 반영

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

```
# 학습에 사용한 event_list
event_id_list = ['access',
 'bshell',
 'cheditor',
 'connect',
 'curl',
 'dbport',
 'dpage',
 'drupal',
 'exploit',
 'fckeditor',
 'flood',
 'icmp',
 'joomla'
```

```
# 학습에 사용한 response_list
response_id_list = [['log_connect_record_request', 'access_control_set_recomm', 'pw_c
 ['log_connect_record_request', 'src_ip_block_recomm', 'server_security_set_recomm'],
 ['malicious_code_get_request', 'malicious_page_restric_recomm', 'pc_close_exam_recom
 ['malicious_code_infec_check_request', 'malicious_code_get_request', 'security_updat
 ['multi_auth_recomm', 'src_ip_block_recomm'],
 ['multi_auth_recomm', 'sw_delete_recomm', 'normal_comm_check_request', 'src_ip_info_
 ['normal_comm_check_request', 'pc_close_exam_recomm', 'src_ip_info_request'],
 ['normal_comm_check_request', 'src_ip_block_recomm', 'remote_port_block_recomm'],
 ['normal_comm_check_request', 'src_ip_info_request'],
 ['pw_change_recomm', 'network_isolate_recomm', 'multi_auth_recomm', 'security_update
 ['security_update_recomm', 'sys_log_request', 'malicious_code_infect_request', 'sign
 ['src_ip_block_recomm', 'dst_ip_info_request'],
 ['src_ip_block_recomm', 'malicious_url_block_recomm', 'dst_ip_info_request'],
 ['threshold_set_recomm', 'src_ip_block_recomm', 'dst_ip_info_request'],
 ['tmp_access_block_recomm', 'normal_comm_check_request', 'src_ip_block_recomm', 'dst
 ['tmp_access_block_recomm', 'src_ip_block_recomm'],
 ['vulnerability_check_recomm', 'src_ip_block_recomm', 'dst_ip_info_request', 'securi
 ['vulnerability_check_recomm', 'src_ip_block_recomm', 'malicious_url_block_recomm']]
```

< 우선순위를 고려한 강화학습을 위한 데이터 전처리 코드 예시 >

o 강화학습을 위한 데이터 특징

- 학습 데이터의 성격에 따라서 강화학습(위험도 산출)에 사용되는 항목들과 서비스(우선순위 산출)에 사용되는 항옥들로 구분
- 강화학습(위험도 산출) 사용 항목 : 이벤트별 정적 속성, priority(레이블)
- 서비스(우선순위 산출) 사용 항목 : 이벤트별 정적 속성 및 동적 속성(소요시간), priority(레이블)
- 강화학습 환경은 기존 적응형 플레이북 강화학습 모델 환경을 기반으로 사용하고, 환경 클래스는 기존 DQN 기반 학습 환경에서 확장
  - 기존 학습된 모델(iqn_response_model) 불러오기
  - 사용자 입력 이벤트와 대응을 추가로 처리할 수 있도록 구성

항목	사용구분		설명
	모델	서비스	
event_id	O	O	54개의 위협 이벤트 식별자(wget, xss, php, …)
event_desc	X	X	이벤트 설명(참고 정보)
threat_id	X	X	분류코드로 공격 유형에 따라 일부 중복될 수 있음
risk	O	O	이벤트별 위험도 (Ground Truth), 4개 값으로 등급 개념
fre_ratio	O	O	발생빈도로 높을수록 우선순위를 높임
pp_mtime	X	O	pp_mtime(분)x60 + pp_stime(초) → 초단위 단일 항목 변환 (동일 위험도, 동일 발생빈도일 경우 소요시간이 작은 이벤트부터 처리)
pp_stime	X	O	
priority	O	O	대응 우선순위, 입력 이벤트들의 위험도, 발생빈도, 소요시간 순으로 정렬한 결과

<학습 데이터 필드 및 feature>

```
# 저장한 모델 불러오기
new_model = tf.keras.models.load_model('iqn_response_model')
```

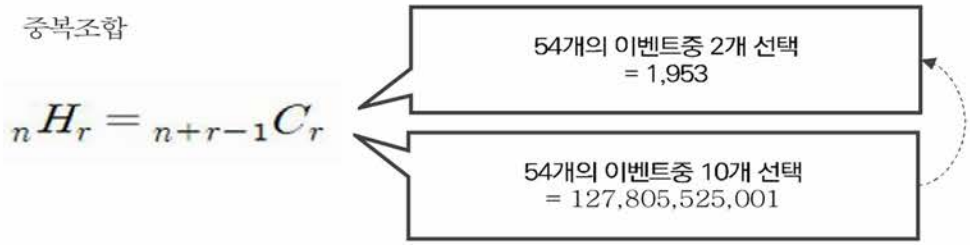
< 기존 적응형 플레이북 강화학습 모델 환경 사용 코드 예시 >

o 강화 학습 적용 방안

- risk(위험도) : SOC 전문인력들이 판단한 이벤트간의 중요도값
- 강화학습모델은 다수의 이벤트들을 입력 받은 후 이벤트들의 위험도 순서를 출력

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- 해결하려고 하는 문제를 다수 이벤트들을 대상으로 위험도의 순서를 맞추었을 때, 보상(Reward)이 제공되는 강화학습 모델로 설정
- 동시에 입력되는 최대 이벤트의 개수에 따라서 학습범위가 달라짐



- 사용자 선호 보안관제 경보·대응 우선순위 반영
  - 기존 DQN 기반 강화학습 모델을 확장하여 사용자 입력값 우선 처리
  - 사용자가 선호하는 대응 시퀀스 집합(my_response_id)이 주어진 경우, 이 집합을 우선적으로 출력
  - 선호 대응 시퀀스가 없을 경우, 기존 학습된 모델 결과를 사용

```
# event_id 입력
event_id = 'connect'
# 내가 선호하는 response_id 리스트 형태로 입력 (개수 제한 없음, 1개도 가능하며 없는 경우 빈 리스트)
my_response_id = ['src_ip_block_recomm']
```

< 사용자 선호 보안 관제 경보·대응 우선순위 반영 코드 예시 >

- 사용자 선호를 고려한 이벤트 중요도 산정 및 자동 분류 예시
  - 이벤트 입력 (예: “connect “)
  - 선호 대응 시퀀스 (예: [’tmp_access_block_recomm’, ’normal_comm_check_request’, ’src_ip_block_recomm’])
  - 사용자가 선호하는 대응 시퀀스가 모델의 출력 상단에 위치

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

```
# 선호하는 리스트를 맨 앞에 두기 위해서 사용
# 기존의 response_id 결과를 복사해서 사용
out = response_id.copy()
# reponse_id 하나씩 꺼내서 내가 선호하는 response_id에 해당하는지 확인
for response in out:
    if response in my_response_id:
        # 내가 선호하는 response_id에 해당하는게 있으면 해당 response_id를 삭제
        response_id.remove(response)
        # 가장 앞에 내가 선호하는 response_id를 다시 추가
        response_id.insert(0, response)
```

```
response_id
```

```
['src_ip_block_recomm',
 'vulnerability_check_recomm',
 'dst_ip_info_request',
 'security_update_recomm']
```

< 사용자 선호를 고려한 이벤트 중요도 산정 및 자동 분류 예시 >

o 모델 성능 측정

- 정확하게 우선 순위가 일치할 경우에만 점수를 부여하는 기존 모델 성능 측정 방법의 문제점을 보완

▪ n=이벤트개수, i : 이벤트별 순서 (1~n), y_i : i 번째 이벤트의 실제순위, $\hat{y}_i$: i번째 이벤트의 예측순위

$$\frac{1}{n}\sum_{i=1}^{n}\frac{\sum_{1}^{i}(y_i == \hat{y}_i)}{i}$$

i번째 이벤트까지의 일치 여부의 합계

<기존 모델 정확도 측정 식>

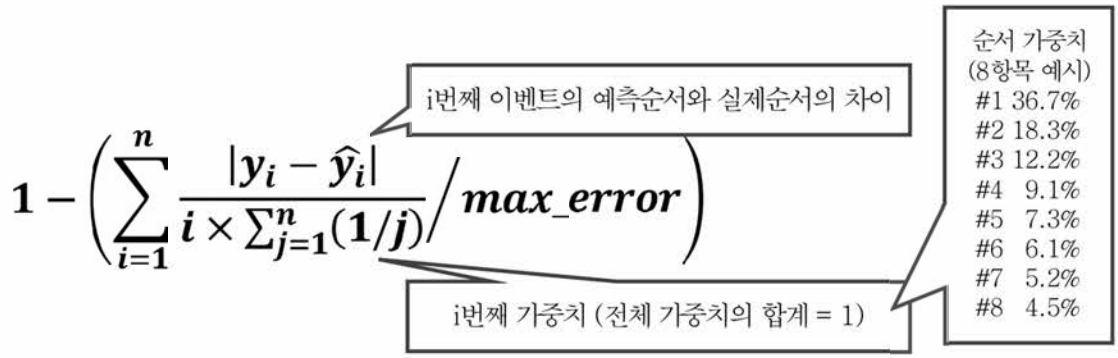
- 예측 순서와 정답 순서의 차이를 반영하여 맞으면 1 틀리면 0을 부여했던 방식을 개선하여 예측 순서가 정답 순서에 얼마나 근접하는지 측정하고 평가하도록 보완
- 이벤트들의 순서에 따른 가중치 반영

▪ n=이벤트개수, i : 이벤트별 순서 (1~n), y_i : i 번째 이벤트의 실제순위, $\hat{y}_i$: i번째 이벤트의 예측순위

n개의 이벤트 기준 최대오차

$$max_error = \sum_{i=1}^{n}\frac{|y_i - \hat{y}_i|}{i \times \sum_{j=1}^{n}(1/j)}$$

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



$$1 - \left(\sum_{i=1}^{n} \frac{|y_i - \hat{y}_i|}{i \times \sum_{j=1}^{n} (1/j)} \Big/ max_error \right)$$

<개선된 모델 정확도 측정 식>

```
def get_prediction_score2(true, pred, max_error):
    num_event = len(true)
    max_cell_error = num_event-1 # Max cell error

    div_weight = 0
    for i in range(num_event):
        div_weight += 1/(i+1)

    tot_error = 0

    for i, x in enumerate(zip(true, pred)):
        cell_error = np.abs(x[0]-x[1])
        cell_weight = (1/(i+1))/div_weight
        # print(cell_weight)
        tot_error += cell_error*cell_weight
    return 1-(tot_error/max_error)
```

<우선순위 예측 정확도 측정 함수>

- 정답을 알고 있는 3개~10개의 이벤트들을 이용하여 학습용 데이터셋 생성
- 학습용 데이터셋을 대상으로 반복적으로 학습 및 정확도 측정

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

	PRED1	PRED2	PRED3	PRED4	PRED5	PRED6	PRED7	PRED8	PRED9	PRED10	TRUE1	TRUE2	TRUE3	TRUE4	TRUE5	TRUE6
0	viewer	drupal	fckeditor	spring	cheditor	ashell	hijack	guzzle	bforce	nmap	viewer	drupal	fckeditor	spring	cheditor	ashell
1	wget	icmp	p2p	tport	log4j	connect	fckeditor	cheditor	ashell	nmap	wget	icmp	p2p	tport	connect	log4j
2	wget	smb	adware	scfunc	gmeditor	ashell	wshell	vpn	guzzle	tomcat	wget	smb	adware	scfunc	ashell	gmeditor
3	icmp	viewer	web	sql	drupal	spring	gmeditor	bshell	fortios	bforce	icmp	viewer	web	sql	drupal	spring
4	dbport	ssl	fckeditor	mchange	scfunc	bshell	wshell	guzzle	tomcat	fortios	ssl	dbport	fckeditor	mchange	bshell	scfunc
...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...	...
95	curl	smtp	exploit	web	drupal	xss	spring	gmeditor	score	scan	curl	smtp	exploit	web	xss	drupal
96	wget	ssl	p2p	kswitch	flood	scfunc	gmeditor	laravel	dauth	scan	wget	ssl	p2p	kswitch	flood	scfunc
97	curl	smtp	adware	tport	connect	scfunc	wshell	score	bforce	scan	curl	smtp	adware	tport	connect	scfunc
98	curl	kswitch	web	xss	mine	score	bshell	guzzle	wscan	nmap	curl	kswitch	web	xss	mine	bshell
99	curl	p2p	smtp	tport	spring	dpage	flood	nshell	php	dauth	curl	p2p	smtp	tport	spring	dpage

<예측 이벤트 순서와 정답 이벤트 순서의 데이터 프레임>

2) 강화 학습 기반 최적 대응 정책 추천 기술 고도화 개발

o 모델 개요

- 에이전트(추천모델)가 각 상태에서 가장 큰 보상을 얻을 수 있도록 학습
- 모델 없이 학습하는 강화 학습 기법 중 하나인 Q 러닝(Q-learning) 선정
- Q 러닝은 주어진 상태에서 주어진 행동 수행으로 얻을 수 있는 효용의 기대값을 예측하는 함수인 Q 함수를 학습
- 주어진 상태에서 어떤 행동을 수행할지 나타내는 규칙인 최적 정책을 학습

o 학습 데이터

- 특정 SOC를 대상으로 일정 기간 발생한 보안 이벤트에 대한 대응 내역을 수집하여 학습에 필요한 필드를 구성하고 가공

event_id	event	reponse_id	response
wget	wget 이용 파일 다운로드 공격 시도	src_ip_block_recomm	공격지 IP 차단 정책 적용 권고
wget	wget 이용 파일 다운로드 공격 시도	malicious_urlblock_recomm	악성 URL 차단 정책 적용 권고
…	…	…	…
wget	wget 이용 파일 다운로드 공격 시도	dst_ip_info_request	목적지 IP 정보공유 요청
rport	원격 포트 접근 시도	tmp_access_block_recomm	임시 접근 허용 차단 권고
rport	원격 포트 접근 시도	normal_comm_check_request	정상 통신 여부 확인 요청
…	…	…	…
rport	원격 포트 접근 시도	remote_port_info_request	원격포트 정보공유 요청
icmp	ICMP를 활용한 접근 시도	threshold_set_recomm	임계치 설정 권고
icmp	ICMP를 활용한 접근 시도	src_ip_block_recomm	공격지 IP 차단 정책 적용 권고
icmp	ICMP를 활용한 접근 시도	dst_ip_info_request	목적지 IP 정보공유 요청
…	…	…	…

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

o 데이터 전처리

- 학습하는 대상인 에이전트가 필요한 정보를 학습 데이터로부터 전처리 작업을 통해 매트릭스 형태로 가공

Event	Event_id	Risk	pp_mtime	pp_stime	Freq
ICMP를 활용한 거점 시스템 접근 시도	E001	7.6	10	45	182
SSL VPN 로그인 페이지 노출	E002	7.6	13	16	113
wget 이용 파일 다운로드 공격 시도	E003	7.6	18	54	279

대응정책 추천을 위한 이벤트 feature를 활용한 전처리

	feature1	feature2	feature3	feature4
E001	value	value	value	Value
E002	value	value	value	value
⋮	0	0	0	0
	...	...	...	...

전체 이벤트 개수(54) x feature(4) 개수 행렬

o 강화 학습 적용 방안

- 에이전트가 행동을 취할 때마다 보상을 주는 것이 아닌 모든 예측을 다하고 종합적으로 평가하여 보상을 부여
- 모든 예측에 대해 종합적으로 평가하여 보상을 부여하기 위한 Custom Reward Function 을 설계

정답	drupal	wget	dbport	icmp
예측	icmp	wget	druap	dbport

→ Reward Func.(true, pred) = reward

- 순서를 평가하기 위해 NDCG 지표를 활용하여 보상함수 설계

$$F(true, pred) = \frac{DCG - Constant\ DCG}{IDCG - Constant\ DCG}$$

$$DCG = \sum_{i}^{prediction\ order} \frac{rel_i}{\log(2+i)}, \quad IDCG = \sum_{i}^{ideal\ order} \frac{rel_i}{\log(2+i)}, \quad Constant\ DCG = \sum_{i} \frac{constant\ rel_i}{\log(2+i)}$$

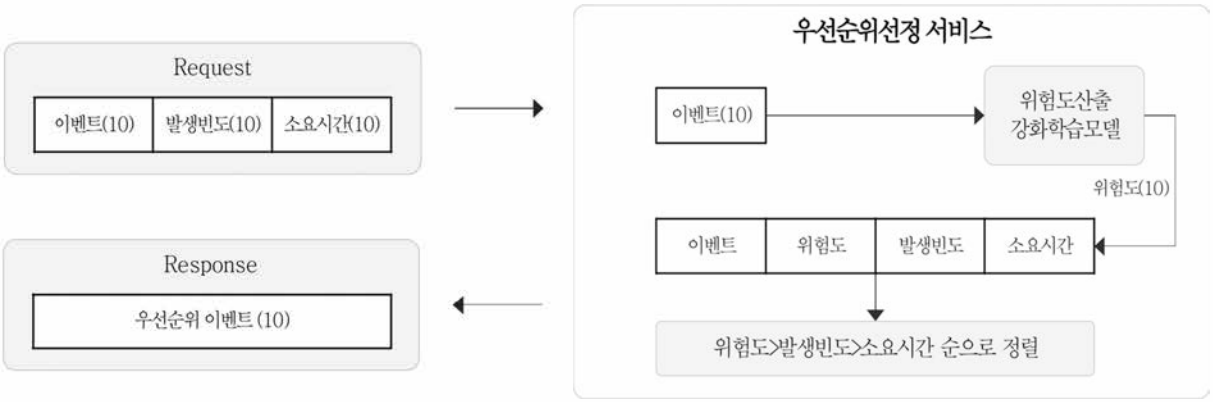
rel_i는 정답 순서 index, $constant\ rel_i$는 정답 순서에서 중간 값에 해당하는 index를 의미

o 외부 연동 서비스 API

- 의사 결정 지원 시스템의 우선순위 및 정책 선정 모델의 예측 서비스를 위협 분석

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

자동화 시스템과 같은 외부 시스템에 제공하기 위한 API



<서비스 API 구성도>

- 서비스 처리 성능 및 연동 확장성을 위해 HTTP 와 TCP 기반의 API 연동 서비스 제공

HTTP 연동

- URL
  1. 이벤트 우선 순위 요청 : http://59.18.207.245:8080/event
  2. 플레이북 우선 순위 요청 : http://59.18.207.245:8080/playbook
  3. 대응 정책 추천 요청 : http://59.18.207.245:8080/response
- 요청 메시지 형식 : {"req_list": "이벤트ID,이벤트ID,…"} -> 이벤트,대응정책
  {"req_list": "이벤트ID:잔여시간, 이벤트ID:잔여시간 , …"} -> 플레이북
- 응답 메시지 형식
  1. 이벤트 우선 순위 요청 : ["dbport","wget"]
  2. 플레이북 우선 순위 요청 : ["dbport","wget"]
  3. 대응 정책 추천 요청 : ["src_ip_block_recomm,malicious_url_block_recomm,dst_ip_info_request"]

<HTTP API 규격>

TCP 연동

- IP/Port : 59.18.207.245/9001
- 요청 메시지 형식 : 요청구분 | 메시지 일련번호 | 이벤트ID,이벤트ID,이벤트ID, … -> 요청구분:1,3
  요청구분 | 메시지 일련번호 | 이벤트ID:잔여시간,이벤트ID:잔여시간,이벤트ID:잔여시간, … -> 요청구분: 2
  - ↘ 필드 구분 자 : |
  - ↘ 이벤트 ID 구분 자 : ,
  - ↘ 요청 구분 : 이벤트 우선순위 요청 1, 플레이북 우선순위 2, 대응정책 추천 : 3

  e.g.) 1|100|kswitch,joomla,connect,smb,icmp ,dpage
  2|101|kswitch:15.33,Joomla:10.45,connect:28.17,smb:7.23,icmp:11.10
  3|102|kswitch,joomla,connect
- 응답 메시지 형식 : 메시지 일련번호 | [요청결과 리스트]

  100| ["dbport","wget"]
  101| ["src_ip_block_recomm,malicious_url_block_recomm,dst_ip_info_request"]
  102|["wget","dbport"]

<TCP API 규격>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

3) 보안 관제 경보·대응 우선순위 부여 기술 고도화 개발

o 보안 이벤트 및 대응 데이터 특성 분석
- 이벤트 자체 정보, 이벤트 위험도, 플레이북, 사용자 피드백을 분석하여 특성 값을 추출하고 종합적인 위험도 계산
- 이벤트 발생 빈도, 이벤트 영향도, 공격난이도, 대응난이도를 분석하여 이벤트에 대한 대응 우선 순위 부여

priority	event_id	event	risk	fre_ratio
1	wget	wget 이용 파일 다운로드 공격 시도	7.6	0.260884
2	icmp	ICMP를 활용한 접근 시도	7.6	0.081256
3	rport	원격 포트 접근 시도	7.6	0.072449
4	ssl	SSL-VPN 로그인 페이지 접근 시도	7.6	0.020771
5	smb	SMB(445) 포트를 통한 접근 시도	7.6	0.012463
6	viewer	TeamViewer 사용 이벤트 탐지	7.6	0.005484
7	dbport	DB 접속 포트 접근 시도 탐지	7.6	0.004819
8	joomla	Joomla 원격코드 실행 취약점 공격 시도 탐지	7.6	0.002326
9	curl	curl 이용 파일 다운로드 공격 시도	7.6	0.001662
10	p2p	P2P 사용 이벤트 탐지	7.6	0.000665
…	…	…	…	…

<이벤트 우선순위 관리 정보>

o SOC 별 경보·대응 우선순위 관리
- 개별 SOC 운영 환경에 최적화된 경보대응 우선순위를 부여하고 관리
- 경보.대응 데이터 특성 분석을 통해 도출된 위험도, 발생 빈도에 기반한 우선순위 관리 정보를 SOC 운영 환경에 따라 주기적으로 갱신

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

```
(base) mobigen@kisa-01:~/script.old$ ./getRedis.py EVT_RISK_TIME_RATIO
web => T_3-5,17,7,16,39,0.156697
drupal => T_3-5,21,7,23,53,0.024593
wget => T_7-2,1,7.6,24,34,0.260884
sql => T_3-7,19,7,3,32,0.082087
log4j => T_3-5,18,7,14,58,0.105683
icmp => T_1-1,2,7.6,5,38,0.081256
rport => T_1-1,3,7.6,16,43,0.072449
xss => T_3-2,20,7,19,28,0.043702
adware => T_7-3,12,7.6,17,25,0.000332
viewer => T_7-4,6,7.6,12,23,0.005484
dbport => T_1-1,7,7.6,14,34,0.004819
log11j => T_3-5,18,7,13,53,0.105683
traver => T_3-3,22,7,10,34,0.020106
mchange => T_3-5,27,7,7,41,0.010136
fckeditor => T_3-8,23,7,18,13,0.01994
smb => T_7-1,5,7.6,23,30,0.012463
wpluqin => T_3-4.24.7.24.28.0.019109
(base) mobigen@kisa-01:~/script.old$ ./setRedis.py ./temp/evt-risk-time-ratio.txt EVT_RISK_TIME_RATIO
0 <built-in function id> T_3-5,17,7,17,58,0.156697
0 <built-in function id> T_3-5,21,7,3,47,0.024593
0 <built-in function id> T_7-2,2,7.6,18,33,0.260884
0 <built-in function id> T_3-7,19,7,17,5,0.082087
0 <built-in function id> T_3-5,18,7,10,16,0.105683
0 <built-in function id> T_7-2,1,7.6,9,18,0.260884
0 <built-in function id> T_7-2,1,7.6,16,51,0.260884
0 <built-in function id> T_1-1,2,7.6,11,52,0.081256
0 <built-in function id> T_7-2,1,7.6,3,26,0.260884
0 <built-in function id> T_3-5,18,7,23,25,0.105683
0 <built-in function id> T_7-2,1,7.6,23,46,0.260884
0 <built-in function id> T_1-1,3,7.6,12,49,0.072449
0 <built-in function id> T_1-1,3,7.6,21,27,0.072449
0 <built-in function id> T_1-1,2,7.6,8,44,0.081256
0 <built-in function id> T_7-2,1,7.6,12,53,0.260884
```

<경보·대응 우선순위 관리 정보 갱신 절차>

연구목표	사이버 보안관제 업무 프로세스 평가 및 정량적 측정기술 개발

세부 내용	1) 보안관제 프로세스별 중요도 기반 가중치 정의 및 항목수립
	2) 최적의 프로세스 도출을 위한 정량적 측정기술 개발 및 검증

1) 보안관제 프로세스별 중요도 기반 가중치 정의 및 항목수립

- 보안관제 프로세스 평가·측정 지표 개발 기존 선행연구 분석
  - 보안관제 업무의 평가를 위한 기준·관련 지표의 개발을 수행한 국내 선행연구(3건)들을 조사하였으며, 각 연구의 주요 내용은 아래와 같음

Ⅰ. 이현도, 이상진. “보안관제 업무에 대한 평가지표 개발 연구”, 정보보호학회 논문지, 22(5), pp.1133-1143, 2012.

<table>
<tr><td colspan="2">연구 목표 및 주요 내용</td><td>- 국내 사이버안전센터의 업무수행 수준 파악 및 측정을 위한 보안관제 업무 평가 지표 개발</td></tr>
<tr><td rowspan="2">상세 연구 내용</td><td>① 평가분야 정의</td><td>- 보안관제 업무평가 대분류
· 전반적인 보안관제 프로세스를 두 가지로 분류
<table><tr><th>분류</th><th>정의</th></tr><tr><td>보안관제 업무관리</td><td>정책, 조직, 시스템, 인력 등의 관리</td></tr><tr><td>침해사고 관리</td><td>침해사고 예방, 탐지, 분석, 대응, 보고 등</td></tr></table>
- 보안관제 평가부분 및 분야 정의
· G-ISMS 및 ISO/IEC27001의 통제분야 기반의 평가 분야 도출</td></tr>
</table>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

<table>
<tr><td></td><td></td><td>
<table>
<tr><th>업무 분류</th><th>평가부분</th><th>평가분야</th></tr>
<tr><td rowspan="5">보안관제
업무관리</td><td rowspan="2">보안관제
조직부분</td><td>보안관제 정책 및 조직</td></tr>
<tr><td>보안관제 인력관리</td></tr>
<tr><td rowspan="3">관제시스템
관리부분</td><td>관제시스템 자산관리</td></tr>
<tr><td>관제시스템 운영관리</td></tr>
<tr><td>관제시스템 접근통제</td></tr>
<tr><td rowspan="6">침해사고
관리</td><td rowspan="6">침해사고
관리부분</td><td>침해사고 예방관리</td></tr>
<tr><td>침해사고 탐지관리</td></tr>
<tr><td>침해사고 대응관리</td></tr>
<tr><td>침해사고 분석관리</td></tr>
<tr><td>보안관제 서비스 관리</td></tr>
</table>
</td></tr>
<tr><td></td><td>② 평가항목 수립</td><td>- SEI IMCM, CSIRTS, NIST 등의 표준 및 침해사고관리 문헌 및 실제 보안관제 업무 환경을 반영하여 평가 분야별 항목 세부 수립
<table>
<tr><th>평가
분야</th><th>평가항목</th><th>항목
수</th></tr>
<tr><td>침해
사고
예방
관리</td><td>- (기술적 부분) 주기적 취약점 분석 평가, 예방 진단 활동 계획 수립 시행 등
- (관리적 부분) 취약점 분석 결과, 모의훈련 및 관제 정보를 통한 동향분석 정보 제공, 관제 대상시스템 및 자료 등의 중요도 식별, 목록 관리 등</td><td>8</td></tr>
<tr><td>침해
사고
탐지
관리</td><td>- 실시간 보안이벤트 모니터링 및 분석 실시
- 외부 위협환경 변화에 따른 보안장비의 보안정책 및 탐지기준 등 변경 및 공유 등</td><td>4</td></tr>
<tr><td>침해
사고
대응
관리</td><td>- 침해사고 위급상황에 따른 보고체계 수립 시행
- 침해사고 및 보안이벤트 처리 정책 및 절차 수립, 수행 능력 보유
- 침해사고에 대한 탐지결과 및 로그, 운영기록 일별 관리 등</td><td>8</td></tr>
<tr><td>침해
사고
분석
관리</td><td>- 사고분석을 위한 디지털 포렌식 분석기법 활용
- 보안이벤트 간 관계 이용한 상관분석 실시 등</td><td>5</td></tr>
<tr><td>보안
관제
서비
스
관리</td><td>- 보안관제 업무성과 평가절차 수립 시행
- 관제시스템 연도별 고도화 계획 수립 시행
- 관제업무의 중단·장애 후 유지·복구 등 업무 연속성 계획 수립 등</td><td>6</td></tr>
</table>
</td></tr>
<tr><td></td><td>③ 평가점수 산정</td><td>- 분야별 항목 답변에 따른 평가 분야별 점수 및 종합 점수 산정을 위한 계산식 도출
- 수식 내 ‘가중치’는 사이버안전센터의 업무 방향성에 따라 평가 분야별로 중요도를 반영하여 개별로 임의 할당</td></tr>
</table>

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

		평가항목 답변 수 / 답변에 따른 점수

평가항목 답변 수		답변에 따른 점수
4개	①	100
	②	67
	③	33
	④	0
3개	①	100
	②	50
	③	0

[평가항목 답변에 따른 점수]

평가분야 별 점수 = $((\sum_{i=1}^{n} T_i) / n) \times$ 가중치

※ T_i: 평가항목 별 평가점수, n: 평가항목 개수

종합점수 = 평가분야 별 점수 / 10

II. 김진홍. "공공기관의 아웃소싱 보안관제 수준 측정지표에 관한 연구", 국내 박사학위논문 숭실대학교, 2014.

연구 목표 및 주요 내용		- 공공기관 위탁 보안관제의 업무 수준 측정을 위한 지표 및 평가 수준 개발
상세 연구 내용	**① 예비 측정지표 수립**	- 보안관제 수준 측정 영역 및 세부 지표 도출 · SEI IMCM 카테고리 및 조달청 관제센터 위탁운영 용역 공고의 제안요청서 종합 분석 기반의 관제 수준 측정 영역 도출 · 보안관제 전문가(5인) 회의를 통한 측정 영역별 총 69개의 예비 측정지표 도출
	② 측정지표 검증	- 도출된 예비 측정지표의 적합성 및 타당성 검증 수행 · (적합성 검증) 측정지표에 대한 *SMART 기준 **전문가(10인) 기반의 델파이 조사 진행 · (타당성 검증) 적합성 검증이 완료된 지표를 대상으로 ***의미차별척도 기반의 ****전문가(180인) 설문 진행, 이후 탐색적·확인적 요인분석 수행 *제시한 측정 지표의 명확성(Specific), 측정가능성(Measurable), 수용가능성(Acceptable), 연관성(Relevant), 적시성(Timely) 으로 구성 **보안관제 업무 10년 이상의 수행 경험이 있는 발주기관 소속 전문가, 보안관제 전문업체 소속 전문가(PM 이상)로 구성 *** 적합도에 대한 7단계의 주관적 평가 수행 (매우높음~매우낮음) **** 공공기관 보안관제 담당 전문가, 보안관제 전문업체 및 정보보호컨설팅 전문업체 전문가로 구성
	③ 가중치 도출	- 지표별 중요도 산정 · 전문가(180인) 대상으로 각 측정지표에 대한 중요도(1~5점으로 응답)에 대한 설문 진행 · 설문 결과 기반의 지표별 가중치 산출 공식 적용(아래) $IE_j = \frac{E_j}{\sum_{i=1}^{n} E_i} \times 100$

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

		IE_j : 지표 j의 가중치 점수 E_j : 지표 j의 중요도 점수 합계 n : 전체 측정지표 항목 수 · 계산된 가중치를 그대로 측정지표별 배점에 사용 · 지표 j의 가중치 점수를 백분율로 환산하여 전체 지표별 가중치 합이 100이 되도록 함.
	④ 측정방식 및 평가 수준 제시	- 측정지표 값 기준 평가 등급 정의 · KISA '정보보호수준평가의 평가단계'를 기반으로 측정지표별 평가 등급을 6단계로 제시(5~0) · 지표별 등급 값 및 지표별 가중치를 기반으로 점수를 계산하여 최종 보안관제 평가 수준을 5단계로 구분(100~80/79~60/59~40/39~20/19~0)

Ⅲ. 최환주, 박용석 "지방자치단체 보안관제에 대한 품질관리 평가지표 연구", 융합보안 논문지, 제21권 제5호

<table>
<tr><td colspan="2">연구 목표 및 주요 내용</td><td>- 지방자치단체의 보안관제 품질향상 및 안전한 서비스 제공을 위한 보안관제 품질관리 지표 도출</td></tr>
<tr><td rowspan="2">상세 연구 내용</td><td>① 평가부분 및 분야 도출</td><td>- 지자체 보안관제 품질 지표 평가 부분 및 분야 도출
· 부분 및 분야는 연구 'Ⅰ'과 동일
※ 연구 'Ⅰ' 및 ISMS-P의 통제항목을 참고하여 연구 수행</td></tr>
<tr><td>② 상세 평가 항목 수립</td><td>- '침해사고 관리' 평가 부분의 상세 평가항목 도출
· 총 32개의 상세 항목 자체 정의
· 정의된 항목 일부의 예시는 아래와 같음
<table>
<tr><th>평가부분 (개수)</th><th>평가분야 (개수)</th><th>평가항목</th></tr>
<tr><td rowspan="10"></td><td rowspan="6">침해사고 예방 관리</td><td>주기적은 취약점 분석평가 등 예방진단 활동을 수립하고 시행하고 있는가?</td></tr>
<tr><td>취약점 분석평가 등 예방진단 결과에 따른 대응 조치를 지원하는가?</td></tr>
<tr><td>중요시스템에 대한 모의해킹 진단계획을 수립하고 이행하였는가?</td></tr>
<tr><td>취약점 분석결과, 모의훈련 또는 관제정보를 통한 동향 분석 정보를 제공하였는가?</td></tr>
<tr><td>관제 대상기관을 대상으로 정보보안 관련 교육 계획을 수립하고 제공하였는가?</td></tr>
<tr><td>최신 보안정보, 상위 감독기관의 공지사항 등을 신속히 수집·제공하였는가?</td></tr>
<tr><td rowspan="4">침해사고 탐지 관리</td><td>모든 관제 대상 시스템을 대상으로 보안 이벤트의 실시간 모니터링 및 분석을 하는가?</td></tr>
<tr><td>외부 위협환경 변화에 따른 보안장비의 보안정책 및 탐지기준 등 변경 시 보고하였는가?</td></tr>
<tr><td>관제 대상기관의 외부 서비스 홈페이지에 대한 위·변조 등 실시간 모니터링을 실시하였는가?</td></tr>
<tr><td>침해사고 발생 시 즉시 보고할 수 있도록 관련</td></tr>
</table>
</td></tr>
</table>

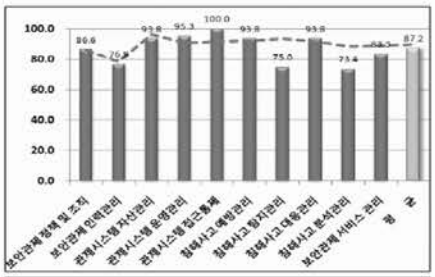
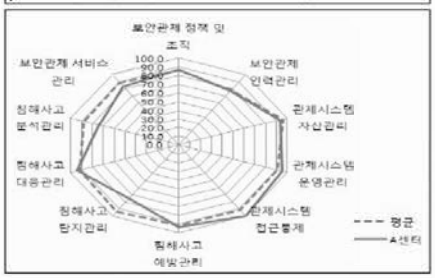
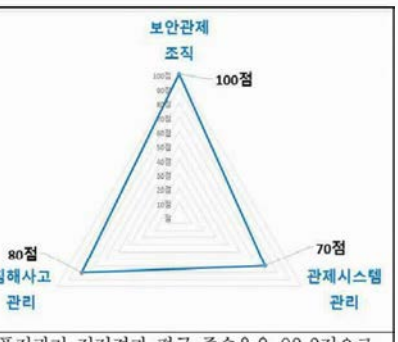
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

<table>
<tr><td></td><td></td><td>
<table>
<tr><td></td><td></td><td>절차를 마련하였는가?
IPS, ESM, SIEM, 방화벽 등 주요 관제시스템에 대해 주기적 정책 최적화 및 관리를 수행하는가?</td></tr>
</table>
</td></tr>
<tr><td></td><td>③ 항목별 가중치 정의</td><td>
- *전문가 인터뷰 기반의 항목별 우선순위 도출 및 가중치 계수 정의
· 정의된 우선순위별 가중치 계수는 아래와 같음
<table>
<tr><th>우선순위</th><th>가중치</th></tr>
<tr><td>A</td><td>4</td></tr>
<tr><td>B</td><td>3</td></tr>
<tr><td>C</td><td>2</td></tr>
<tr><td>D</td><td>1</td></tr>
</table>
[우선순위별 가중치 계수]
*지자체 보안관제 PM, 관제 사업담당 공무원, 정보보호 시스템 운영 담당 공무원으로 구성
</td></tr>
<tr><td></td><td>④ 평가 방법 및 기준 정의</td><td>
- 평가항목별 준수율에 따른 점수 및 평가 방법 정의
· (평가점수) 각 항목별 준수율에 따른 평가 점수(5점 만점)를 아래와 같이 정의
· (평가방법) “항목별 점수” = “항목별 가중치 * 평가점수”로 계산
<table>
<tr><th>평가 기준</th><th>점수</th><th>비고</th></tr>
<tr><td>규정 및 절차를 주기적 시행(과업 충족)</td><td>5</td><td>우수</td></tr>
<tr><td>규정 및 절차를 주기적 시행(일부 누락)</td><td>4</td><td>양호</td></tr>
<tr><td>비정기적으로 시행하거나 일부 수행</td><td>3</td><td>보통</td></tr>
<tr><td>과업을 거의 시행하지 않음(30% 미만)</td><td>2</td><td>미흡</td></tr>
<tr><td>과업을 시행하지 않음</td><td>1</td><td>불량</td></tr>
</table>
[평가 기준 및 평가 점수]
<table>
<tr><th>등급</th><th>우수</th><th>양호</th><th>보통</th><th>미흡</th><th>불량</th></tr>
<tr><td>항목별 준수율</td><td>98% 이상</td><td>90~ 97%</td><td>85~ 89%</td><td>80~ 84%</td><td>80% 미만</td></tr>
<tr><td>평가점수</td><td>5점</td><td>4점</td><td>3점</td><td>2점</td><td>1점</td></tr>
</table>
[품질관리 항목별 준수율 및 점수]
- 품질관리 종합평가 기준 정의
· 모든 평가 분야별 준수율의 평균을 매기고, 해당 평균값을 기반으로 한 달성도를 아래와 같이 정의
<table>
<tr><th>달성도</th><th>목표수준</th><th>기대수준</th><th>허용수준</th><th>미달수준</th></tr>
<tr><td>종합평가</td><td>98%이상</td><td>90%이상</td><td>80%이상</td><td>80%미만</td></tr>
</table>
[품질관리 달성도별 종합평가 가중치]
</td></tr>
</table>

· 각 연구별 도출된 지표를 실제 보안관제 현장에 적용한 결과는 아래와 같음

연구	(1)	(2)	(3)

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

적용 결과	  〔그림 2〕 A 기관 사이버안전센터 평가결과	현장 적용 사례 없음	<표 11> OO지자체 품질관리 결과 방사형 차트 점검 결과  품질관리 점검결과 평균 준수율은 83.3점으로 전반적으로 "허용" 수준인 것으로 평가

2) 최적의 프로세스 도출을 위한 정량적 측정기술 개발 및 검증

- 기존 선행연구의 공통 내용 및 현 보안관제 업무의 특성을 고려하여 측정 과정을 아래와 같이 '측정 분야·항목 도출' -> '항목별 가중치 부여 및 검증' -> '측정방식 정의' -> '측정' 총 4단계로 구분

① 측정 분야 및 항목 도출 → ② 항목별 가중치 부여 및 검증 → ③ 측정 방식 정의 → ④ 측정

① 측정 분야·항목 도출

- 사전에 정의한 보안관제 필수업무 프로세스 3단계 (수집/탐지, 분석, 대응/예방)를 측정 분야로 정의
- 측정 분야별 주요 업무에 대한 세부 측정항목 수립
  - · 관련 선행연구에서 지표 수립 시 활용한 보안사고 관리 표준문서, 침해사고 관련 대응 문헌, 보안 인증제도 등을 참고
    - o 카네기 멜론 대학 SEI(Software Engineering Institute) IMCM(Incident Management Capability Metrics) 및 IMCA(Incident Management Capability Assessment)
    - o CSIRTS(Computer Security Incident Response Teams), NIST Cybersecurity Framework
    - o ISMS-P 보호대책 요구사항
  - · 국내 보안관제 실제 수행 업무 내용 반영
    - o KISTI 과학기술사이버안전센터 운영 지식 기반의 조달청 사이버 보안 관제사업 및 위탁운영 용역 공고 등 제안요청서 분석을 통한 측정 항목 수립

측정 분야	세부 측정항목
수집/탐지	※ 24시간 365일 실시간 모니터링 수행을 통한 네트워크 트래픽 및 이벤트 로그 수

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

	집·탐지 여부 확인 (실제 모니터링 수행 시간에 비례하여 가중치 부여) **ㅇ 탐지 정확성 측정** - 보안장비에서 공격(의심)으로 탐지된 전체 트래픽 중 실제 공격으로 판별된 트래픽의 비율 측정 (측정 단위 : %) **ㅇ 탐지 신속도 측정** - 보안장비의 트래픽 수집부터 탐지 결과 도출까지의 소요 시간 측정 (측정 단위 : sec)
분석	**ㅇ 분석 정확성 및 신뢰성 측정** - 자동분석 기술의 예측(정·오탐) 정확도 측정 (측정 단위 : %) - 자동분석으로 제시된 전체 판단 근거가 보안관제 요원이 제시한 주요 판단 근거와 일치하는 비율 측정 (측정 단위 : %) **ㅇ 분석 신속도 측정** - 최종 공격/정상 여부 확정까지 소요되는 분석 시간 측정 (측정 단위 : sec)
대응/예방	**ㅇ 대응 신속도 측정** (측정 단위 : sec) - (기준1) 사고 발생 후 상위·유관 기관으로의 보고까지의 소요 시간 측정 - (기준2) 사고 발생 후 대응 완료까지의 소요 시간 측정 - (기준3) 사고 대응 완료 후 발생 원인 및 처리 결과 등을 상위·유관 기관으로 공유·보고까지의 소요 시간 측정 - (기준4) 사고 대응 후 업데이트된 보안장비 정책 및 탐지패턴 적용·공유까지의 소요 시간 측정(*※ 사고 발생 이후 보안장비 정책(패턴)의 추가·수정 등이 요구되는 경우에만 해당)*

[보안관제 필수 프로세스별 정량 측정 지표]

② 항목별 가중치 부여 및 검증

- 보안관제 분야 전문가 중심의 측정항목별 가중치 부여 및 검증
  - · 개별 관제센터의 업무수행 현황 및 방향성을 고려하여 평가 항목별 중요도를 산정하여 가중치 부여 (전문가 인터뷰, 리커트 척도 등을 활용한 설문 진행 등)
  - · 최종 부여된 가중치를 고려한 항목별 측정 적절성 및 실효성 검증

③ 측정 방식 정의

- 보안관제 프로세스의 정량적 측정을 위한 점수 계산 방식 및 측정 수준 정의
  - · 가중치를 고려한 측정 분야·항목별 점수 및 합계 계산 방식 정의
  - · 측정 점수에 기반한 관제 업무 프로세스 수행 수준 정의 (합계 점수 구간별 평가 등급 차등 부여 등)

④ 측정

- 정의된 방식으로 측정된 최종 결과(합계 및 평가 등급) 기반의 관제 프로세스의 수행도를 수치적으로 도출
  - · 세부 항목별 측정 결과 기반의 관제 업무 프로세스 개선도 확인·평가
  - · 추가 개선 필요시 세부 개선 방안 수립 등을 통한 효율적인 관제 프로세스 수립·운영

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

세부 기술 ④ SOC 통합 운영 및 자동화 플랫폼 고도화

□ 연구 목표

o SOC 통합 운영 및 자동화 플랫폼 실증 기반 고도화

□ 연구 목표별 추진 실적

연구목표	SOC 통합 운영 및 자동화 플랫폼 실증 기반 고도화

세부 내용	
	1) 보안장비 연동상태 시각화(실시간 장비 헬스체크, 빅데이터 보안로그 수집·축약·분석 흐름도 등) 고도화 기술 개발
	2) 보안관제 대상기관 정보(네트워크 구성현황, IP주소, 정보시스템, 보안담당자 등) 등록/수정 DB스키마 및 침해대응 연계기술 개발

1) 보안장비 연동상태 시각화(실시간 장비 헬스체크, 빅데이터 보안로그 수집·축약·분석 흐름도 등) 고도화 기술 개발

1-1 . (실시간 장비 헬스체크를 위한 연동 기술) 아키텍처 및 구성 요소

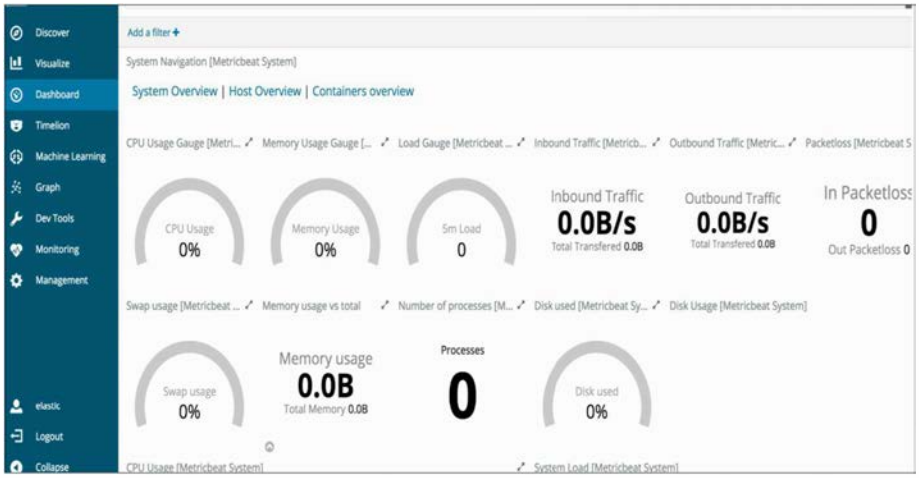
o SNMP Manager (중앙 서버)

- 기술 스택: CentOS 7 이상의 리눅스 기반 서버, Net-SNMP 라이브러리 활용
- 데이터베이스: InfluxDB(시계열 데이터 관리), Redis(캐시 및 알람 큐 관리)
- 모니터링/알람 모듈: 자체 개발된 Python Flask REST API + Celery(비동기 테스크), Grafana 대시보드
- SNMP 프로토콜을 통해 보안 장비의 주요 성능 지표(CPU, 메모리, 인터페이스 트래픽, 에러 패킷 등) 수집
- 수집된 데이터는 InfluxDB에 저장한 뒤, 임계값이 초과되는 경우 Celery 큐를 통해 알람 모듈 호출

o Syslog 서버(SIEM)연동

- 기술 스택: Rsyslog 또는 Syslog-ng 기반 로그 수집, Elasticsearch/Kibana를 포함한 SIEM 솔루션 연동

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



< Kibana로 구현한 보안 장비의 리소스 사용량 대시보드 >

- Syslog 서버는 보안 장비에서 발생하는 모든 로그를 실시간으로 수신하고, 보안 위협 레벨(Critical, Error, Warning 등) 및 메시지 패턴 분석
- SIEM과 연동되어 로그 인덱싱, 이상 탐지 룰, 시각화 대시보드 구성
- Critical 이상의 이벤트가 감지될 경우 Python 스크립트를 통해 중앙 서버에 REST API를 통한 경고 발생

o 보안 장비 (Agentless 방식)

- SNMP 에이전트 활성화: 장비 관리 인터페이스에서 SNMPv3로 설정하여 보안성 확보(암호화, 인증)
- Syslog 전송 설정: Syslog 서버 IP와 포트를 입력, Critical 이상의 로그가 발생하면 즉시 전송되도록 구성
- 보안 장비 펌웨어 버전 또는 OS 버전에 따라 MIB/OID가 상이하므로, 실제 운영 시 장비별 OID 매핑표 작성

1-2. (실시간 장비 헬스체크를 위한 연동 기술) 데이터 흐름(Flow)

o SNMP Polling

- 중앙 서버에서 Net-SNMP 명령(snmpget, snmpwalk)를 이용해 5분 간격으로 장비에 get 요청
- OID를 통해 CPU, 메모리, 인터페이스, 트래픽, 패킷 에러율 등 확인
- 수집된 지표는 시계열 DB(InfluxDB)에 각 장비별, 지표별로 저장

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

< InfluxDB 시각화 대시보드 >

- Kibana 기반의 대시보드에 각 자원 별 리소스 현황 연동
- Syslog 서버(SIEM 연동): 보안 장비에서 전송하는 Syslog 메시지를 실시간으로 수신
- 사용자가 설정한 보안 수준 이상의 에러나 이벤트 메시지를 식별하고, 해당 정보를 분석 모듈 또는 SIEM을 통해 중앙 서버에 전달

o Syslog Event 실시간 수집

- 장비 내부에서 Critical 등급 에러 발생 시 Rsyslog 또는 Syslog-ng 서버로 UDP/TCP 패킷 전송
- Syslog 서버는 로그를 수신 후, 분석 파이프라인(분류, 필터링, 정규화)을 거쳐 Elasticsearch/Kibana(SIEM)에 인덱싱
- SIEM 내 Rule-Based Engine에서 “Critical” 키워드 로그가 연속 10회 이상 발생하면 중앙 서버의 알림 모듈에 의해 Webhook/REST API 호출
- 중앙 서버는 알람 정보를 전달받아 Celery 태스크를 생성, 알림 전송

o 중앙 서버의 알람 생성

- 시계열 DB에서 CPU 지표 90% 초과 + SIEM에서 Critical 로그 N회 이상의 조건이 동시에 만족되면 “복합 트리거” 이벤트 발생
- Celery 태스크가 SNS, Slack, Email 등으로 장애 알람 푸시
- 알람 내용에는 발생 시각, 장비명, CPU 사용률, Critical 로그 개수, 사용자 지정 로그 등 상세 정보가 포함됨

1-3. (실시간 장비 헬스체크를 위한 연동 기술) 임계치 설정 및 이벤트 연동

o SNMP 지표 임계값

- CPU 80% 초과 시 경고(warning), 90% 초과 시 심각(critical)으로 구분
- InfluxDB + Kapacitor(알람 엔진)으로 TICK 스크립트 작성, 임계값 초과 시 HTTP POST 호출
- 메모리, 네트워크 인터페이스별 사용률, 패킷 드롭율 등도 동일한 방식으로 임계값 지정

o Syslog 레벨 기반 필터링

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- Rsyslog/syslog-ng에서 “critical” 문자열을 포함한 로그를 별도 파일 또는 큐로 라우팅
- 과도한 이벤트 발생 시 CPU, 메모리 사용량을 고려해 로깅 자체가 시스템에 부담되지 않도록 압축, 집계 사용
- SIEM에서 “critical” 레벨 메시지 5분 내 10회 이상 발생 시 REST API 콜

o 복합 트리거

- CPU 사용률 90% 초과 + Critical 레벨 로그 10회 이상 발생 시 장애 경고
- “cpu_usage>90 AND critical_log_count>10” 만족 시 운영 담당자에게 심각 알람 전송

2-1. (빅데이터 수집·축약·분석 기술) 아키텍처 및 구성 요소

o 기술 스택

- Logstash를 통한 로그 수집 파이프라인 구성
- syslog 서버로부터 데이터를 받아 파싱, 필터링 후 메시지 큐(Kafka) 전달

o 전처리 프로세스

- Logstash의 Grok 플러그인을 통해 “Action=Block”, “SrcIP=192.168.0.10” 와 같은 특정필드를 사용자 정의 방식 필드 추출 기능 구현
- 중복 제거를 위한 규칙 추가 (Logstash의 throttle 필터 플러그인 활용)

※ 초당 1000건 이상 반복되는 동일 로그는 일정 횟수이상이면 1건으로 축약하고 count 필드 추가(count=1000)

o 공통 스키마 매핑

- 보안 로그를 표준화된 필드로 매핑 (s_ip → src_ip, d_ip → dst_ip 등)

1-3 로그 저장 구조

o 계층형 스토리지

- 핫 스토리지: 최근 7일 로그를 Elasticsearch 클러스터에 저장

※ elasticsearch-py 라이브러리를 활용하여 security-logs-yyyy.mm.dd 일별 인덱스 구성

- 콜드 스토리지: 1개월 이상 지난 로그는 별도 스토리지 이전

※ Hadoop HDFS + Hive/Presto를 통해 장기관 보관, 배치 쿼리의 효율성 보장

1-4 로그 분석 단계

o 실시간 분석

- Apache Spark Streaming을 통해 로그 스트림을 5초 단위로 받아 마이크로배치 후 분석
- 블랙리스트 ip 등장 시 경고 등 규칙 기반 분석과 ML 모델을 적용한 이상치 탐지 수행

o 배치 분석

- 주간/월간 트렌드, 장기 공격 패턴, 머신러닝 모델 학습 등에 활용

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- MapReduce를 이용해 대량 히스토리 로그 분석

1-5 시각화 및 알림 기능

o 대시보드

- Grafana 기반 대시보드를 구현하여 이벤트 발생 빈도, CPU/메모리 자원 모니터링 병행
- 추후 다른 보안 장비(SIEM, SOAR 등)과 연동을 위해 API 기능 구현

2) 보안관제 대상기관 정보(네트워크 구성현황, IP주소, 정보시스템, 보안담당자 등) 등록/수정 DB스키마 및 침해대응 연계기술 개발

o 보안관제 대상기관 DB 스키마 설계 및 개발

테이블 명	한글명	기관 정보	영문명	tb_organization	
개요	보안관제 대상이 되는 회사·기관정보				
컬럼	컬럼명	한글컬럼명	키유형	Null	Type
	org_id	기관 ID	PK	NN	BIGINT(18)
	org_name	기관명		NN	VARCHAR(255)
	org_type	기관 유형		NN	VARCHAR(100)
	address	주소		YY	VARCHAR(255)
	phone	대표 전화번호		YY	VARCHAR(50)
	email	대표 이메일		NN	VARCHAR(100)
	is_active	활성 여부		NN	BOOLEAN
	created_at	생성 시각		NN	timestamp
	updated_at	수정 시각		NN	timestamp
색인 ID	PRIMARY KEY (`org_ids`)				
참고사항					

테이블 명	한글명	네트워크세그먼트	영문명	tb_network_segment	
개요	기관 내 세부 네트워크 구간(서브넷, DMZ, 내부망 등)을 관리				
컬럼	컬럼명	한글컬럼명	키유형	Null	Type
	segment_id	네트워크 세그먼트 ID	PK	NN	BIGINT(18)
	org_id	기관 ID	FK	NN	BIGINT(18)
	segment_name	네트워크 세그먼트명		NN	VARCHAR(100)
	cidr_block	CIDR 블록		NN	VARCHAR(50)
	description	설명		YY	VARCHAR(255)
	is_active	활성 여부		NN	BOOLEAN
	created_at	생성 시각		NN	timestamp
	updated_at	수정 시각		NN	timestamp
색인 ID	PRIMARY KEY (`segment_id`)				
참고사항					

테이블 명	한글명	자산정보	영문명	tb_asset

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

개요	기관에 소속된 서버, 네트워크 장비, 보안장비 등 IT 자산 정보 저장				
컬럼	**컬럼명**	**한글컬럼명**	**키유형**	**Null**	**Type**
	asset_id	자산 ID	PK	NN	BIGINT(18)
	org_id	기관 ID	FK	NN	BIGINT(18)
	asset_name	자산명		NN	VARCHAR(200)
	asset_type	자산 유형		YY	VARCHAR(100)
	criticality	중요도		YY	VARCHAR(50)
	location	물리적 위치		YY	VARCHAR(255)
	os_info	운영체제 정보		YY	VARCHAR(100)
	is_active	활성 여부		NN	BOOLEAN
	created_at	생성 시각		NN	TIMESTAMP
	updated_at	수정 시각		NN	TIMESTAMP
색인 ID	PRIMARY KEY (`asset_id`)				
참고사항					

테이블 명	**한글명**	IP주소 정보	**영문명**	tb_ip_address	
개요	자산별로 할당된 IP 주소, 포트 정보 저장				
컬럼	**컬럼명**	**한글컬럼명**	**키유형**	**Null**	**Type**
	ip_id	IP 정보 ID	PK	NN	BIGINT(18)
	asset_id	자산 ID	FK	NN	BIGINT(18)
	ip_address	IP 주소		NN	VARCHAR(45)
	subnet_mask	서브넷 마스크		YY	VARCHAR(45)
	mac_address	MAC 주소		YY	VARCHAR(20)
	network_role	네트워크 용도		YY	VARCHAR(100)
	port_info	포트 정보		YY	VARCHAR(50)
	is_active	활성 여부		NN	BOOLEAN
	created_at	생성 시각		NN	TIMESTAMP
	updated_at	수정 시각		NN	TIMESTAMP
색인 ID	PRIMARY KEY (`ip_id`)				
참고사항					

테이블 명	**한글명**	보안담당자	**영문명**	tb_security_contact	
개요	기관별 보안담당자 정보 저장				
컬럼	**컬럼명**	**한글컬럼명**	**키유형**	**Null**	**Type**
	contact_id	보안담당자 ID	PK	NN	BIGINT(18)
	org_id	기관 ID	FK	NN	BIGINT(18)
	name	담당자 이름		NN	VARCHAR(100)
	role	담당자 직위/역할		YY	VARCHAR(100)
	phone	전화번호		YY	VARCHAR(50)
	email	이메일		YY	VARCHAR(100)

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

	is_active	활성 여부		NN	BOOLEAN
	created_at	생성 시각		NN	TIMESTAMP
	updated_at	수정 시각		NN	TIMESTAMP
색인 ID	PRIMARY KEY (`contact_id`)				
참고사항					

테이블 명	**한글명**	침해사고	**영문명**	tb_incident	
개요	SIEM 등에서 발생한 침해사고 기록				
컬럼	**컬럼명**	**한글컬럼명**	**키유형**	**Null**	**Type**
	incident_id	침해사고 ID	PK	NN	BIGINT(18)
	org_id	기관 ID	FK	NN	BIGINT(18)
	asset_id	자산 ID	FK	YY	BIGINT(18)
	incident_type	침해사고 유형		NN	VARCHAR(100)
	severity	심각도		NN	VARCHAR(50)
	status	진행 상태		NN	VARCHAR(50)
	detected_time	최초 탐지 시각		NN	TIMESTAMP
	reported_time	관제센터 보고 시각		YY	TIMESTAMP
	description	침해사고 상세설명		YY	TEXT
	created_at	생성 시각		NN	TIMESTAMP
	updated_at	수정 시각		NN	TIMESTAMP
색인 ID	PRIMARY KEY (`incident_id`)				
참고사항					

테이블 명	**한글명**	침해대응이력	**영문명**	tb_incident_action	
개요	SIEM 등에서 발생한 침해사고 기록				
컬럼	**컬럼명**	**한글컬럼명**	**키유형**	**Null**	**Type**
	action_id	대응조치 ID	PK	NN	BIGINT(18)
	incident_id	침해사고 ID	FK	NN	BIGINT(18)
	action_type	조치 유형		NN	VARCHAR(100)
	action_desc	조치 상세 내용		YY	TEXT
	performed_by	조치 수행자		YY	VARCHAR(100)
	performed_time	조치 실행 시각		YY	TIMESTAMP
	result_status	조치 결과 상태		YY	varchar(50)
	created_at	생성 시각		NN	TIMESTAMP
색인 ID	PRIMARY KEY (`action_id`)				
참고사항					

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

세부 기술 ⑤ AI·빅데이터 기반 사이버보안 오케스트레이션 및 자동 대응 통합 기술 실증

□ 연구 목표

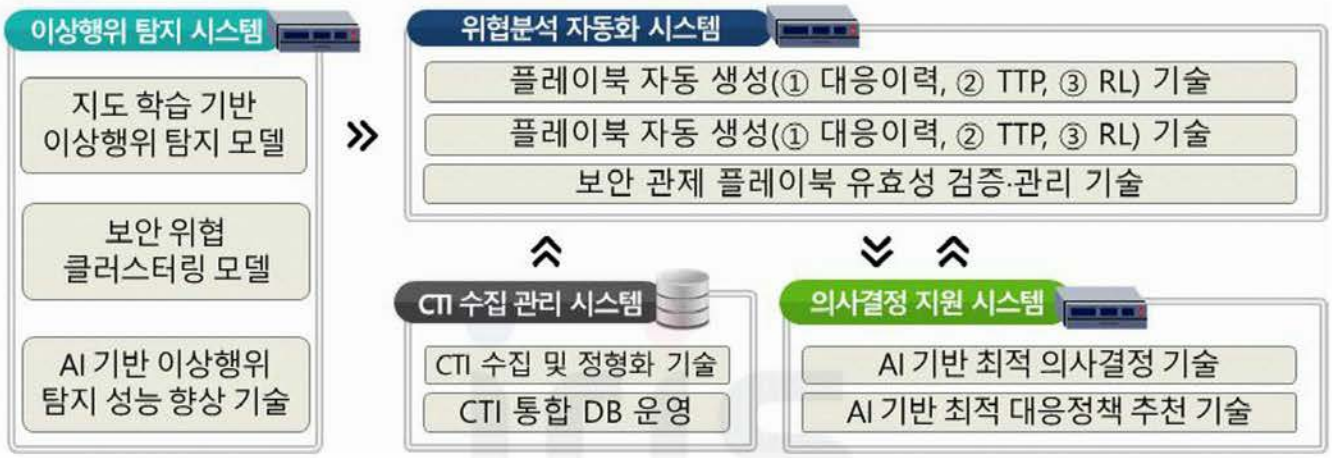
o 보안관제센터 오케스트레이션 및 자동 대응 플랫폼의 보안관제센터 실증

□ 연구 목표별 추진 실적

연구목표	보안관제센터 오케스트레이션 및 자동 대응 플랫폼의 보안관제센터 실증

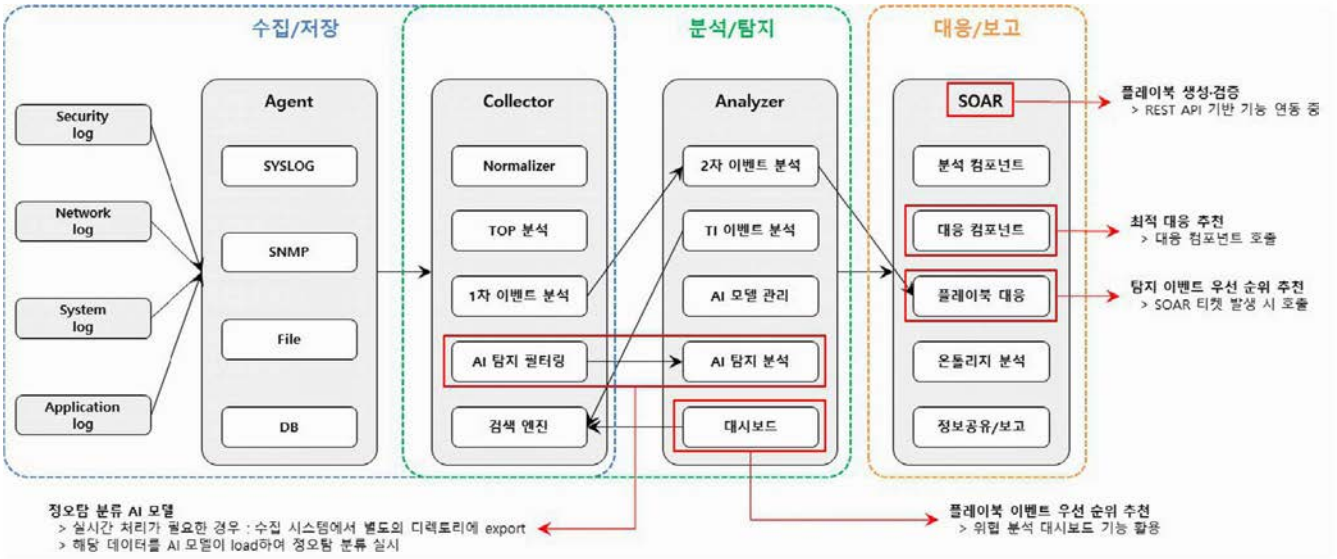
o 국가과학기술연구망 및 실제 SOC 데이터를 활용한 통합 플랫폼 실증

- 통합 플랫폼 실증 주요 기능 및 주요 시스템 간 구성도



<통합 플랫폼 구성도>

- 통합 플랫폼 내부 모듈 연계 구조 및 주요 기능



<통합 플랫폼 내부 모듈>

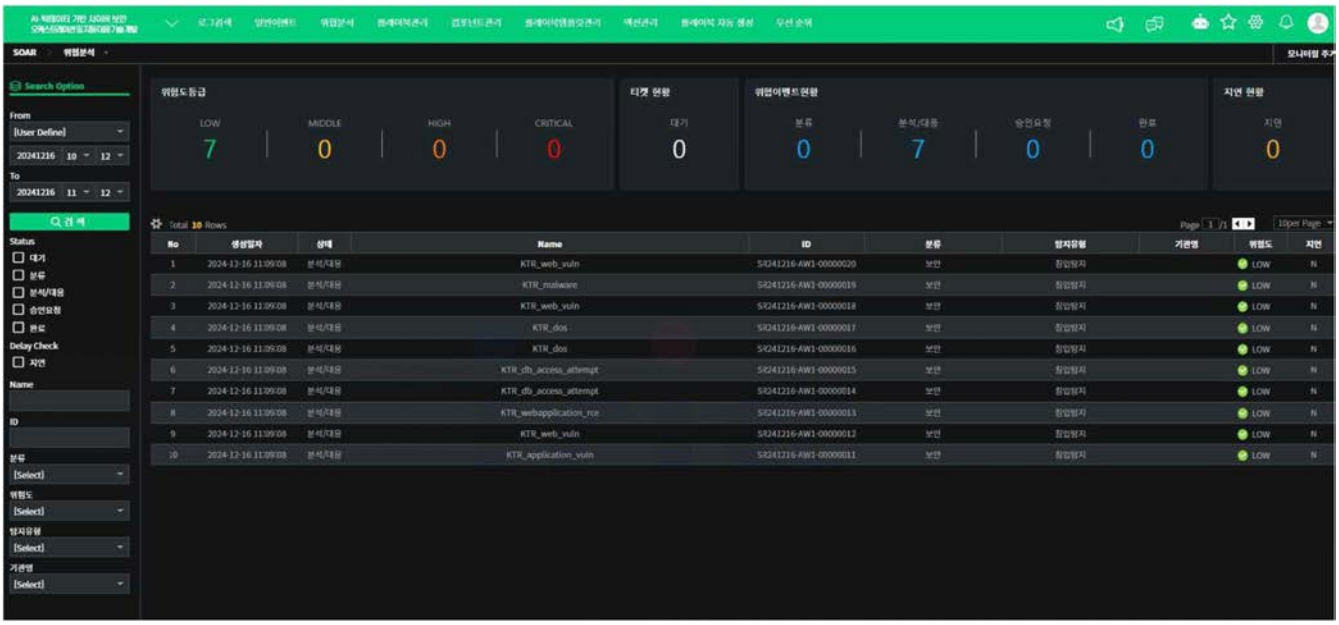
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- 실증을 위한 주요 시스템 설치 서버 상세 성능

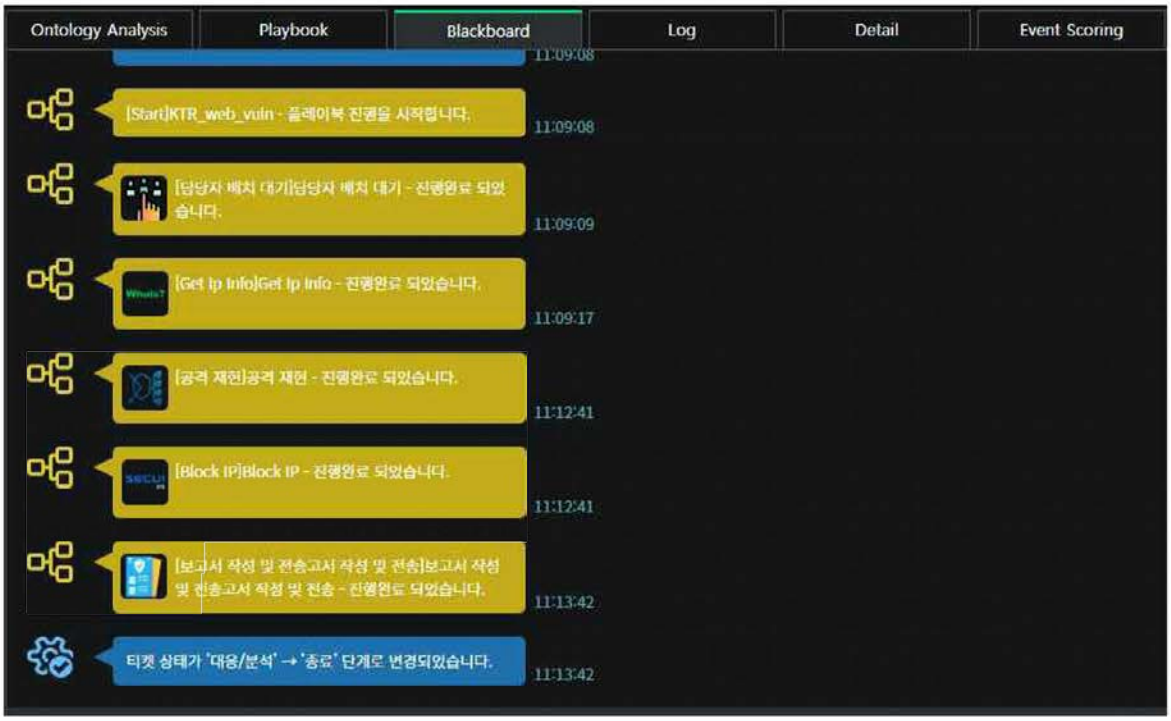
<실증 환경 서버 상세 성능>

	성능	
서버 (3식)	CPU	Intel(R) Xeon(R) Gold 6246R CPU @ 3.40 Ghz
	RAM	256 GB
	HDD	48 TB
	OS	Ubuntu 20.04.3 LTS 64 bit
	성능	
서버 (1식)	CPU	Intel(R) Xeon(R) Gold 6246R CPU @ 3.40 Ghz
	RAM	256 GB
	HDD	48 TB
	OS	CentOS Linux release 7.9.2009

- 통합플랫폼 실증 절차 ① : 임의의 보안 이벤트 발생



- 통합플랫폼 실증 절차 ② : 플레이북 자동 실행 및 분석·대응 종료



국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- 통합플랫폼 실증 절차 ③ : 보안 이벤트 위협별 평균 수행시간 측정

<실증 시험 회차 및 보안 이벤트별 수행시간>

실증 시험 회차	이벤트 명	시작 시간	종료 시간	수행 시간
1	Web_vuln	11:09:08	11:13:42	04분 34초
	Malware	11:09:08	11:15:12	06분 04초
	Web_vuln	11:09:08	11:13:57	04분 49초
	DoS	11:09:08	11:16:16	07분 08초
	DoS	11:09:08	11:16:39	07분 31초
	DB_Access_Attempt	11:09:08	11:15:09	06분 01초
	DB_Access_Attempt	11:09:08	11:16:03	06분 55초
	Webapplication_RCE	11:09:08	11:19:25	10분 17초
	Web_vuln	11:09:08	11:14:02	04분 54초
	Application_vuln	11:09:08	11:15:09	06분 01초
2	Web_vuln	13:42:15	13:47:11	04분 56초
	Web_vuln	13:42:15	13:46:53	04분 38초
	Malware	13:42:15	13:48:18	06분 03초
	DoS	13:42:15	13:49:43	07분 28초
	DoS	13:42:15	13:49:26	07분 11초
	Application_vuln	13:42:15	13:48:18	06분 03초
	Webapplication_rce	13:42:15	13:51:51	09분 36초
	Web_vuln	13:42:15	13:46:27	04분 12초
	DB_Access_Attempt	13:42:15	13:48:17	06분 02초
	DB_Access_Attempt	13:42:15	13:47:29	05분 14초
3	Webapplication_rce	14:15:45	14:25:06	09분 21초
	Web_vuln	14:15:45	14:20:22	04분 37초
	Web_vuln	14:15:45	14:20:28	04분 43초
	Web_vuln	14:15:45	14:20:08	04분 23초
	Malware	14:15:45	14:21:47	06분 02초
	DoS	14:15:45	14:23:24	07분 39초
	DB_Access_Attempt	14:15:45	14:22:11	06분 26초
	DB_Access_Attempt	14:15:45	14:22:10	06분 25초
	DoS	14:15:45	14:21:46	06분 01초
	Application_vuln	14:15:45	14:23:33	07분 48초
전체 평균 수행 시간				**06분 18초**

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

3. 연구개발과제의 수행 결과 및 목표 달성 정도

1) 연구수행 결과

(1) 정성적 연구개발성과

목표 1	이기종 보안장비 연동 API 공개 및 이상행위 탐지 모델 고도화	완료(100%)
사업계획서 목표 및 달성 정도		
· 이기종 보안 장비 데이터 정규화 및 대응 정책 적용 API 개발·공개 (완료, 100%) · AI·빅데이터 기반 이기종 보안 장비 이상행위 탐지 성능 향상 기술 고도화 개발 (완료, 100%) · 공개 보안 위협 인텔리전스 정보 수집 기술 고도화 (완료, 100%)		

목표 2	보안 위협 분석 및 대응을 위한 플레이북 자동 생성 기술 고도화	완료(100%)
사업계획서 목표 및 달성 정도		
· 보안 관제 플레이북 자동 생성 기술 고도화 (완료, 100%) · 보안 관제 플레이북 검증·관리 기술 고도화 (완료, 100%)		

목표 3	AI 기반 의사결정 추천 기술 및 분석 모델 고도화	완료(100%)
사업계획서 목표 및 달성 정도		
· AI 기반 최적 의사결정 자동 추천 기술 고도화 (완료, 100%) · 사이버 보안관제 업무 프로세스 평가 및 정량적 측정기술 개발 (완료, 100%)		

목표 4	SOC 통합 운영 및 자동화 플랫폼 고도화	완료(100%)
사업계획서 목표 및 달성 정도		
· SOC 통합 운영 및 자동화 플랫폼 실증 기반 고도화 (완료, 100%)		

목표 5	AI · 빅데이터 기반 사이버보안 오케스트레이션 및 자동 대응 통합 기술 실증	완료(100%)
사업계획서 목표 및 달성 정도		
· 보안관제센터 오케스트레이션 및 자동 대응 플랫폼의 보안관제센터 실증 (완료, 100%)		

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

(2) 정량적 연구개발성과

1. SCI(E) 논문 게재 : 목표 평균 mrnIF 65.52 → 실적 평균 mrnIF 69.37

번호	논문명	학술지명	발행기관	mrnIF
1	Integrating Deep Learning and Machine Translation for Understanding Unrefined Languages	Computers, Materials & Continua	TECH SCIENCE PRESS	41.76
2	A Design of Automated Vulnerability Information Management System for Secure use of Internet-Connected Devices based on Internet-Wide Scanning Methods	IEICE Transaction Information and Systems	IEICE-INSTELECTRONICS INFORMATION COMMUNICATIONS	2.74
3	Deep learning model based on expectation-confirmation theory to predict customer satisfaction in hospitality service	Information Technology & Tourism	Springer	87.71
4	MultiEmo: Multi-task framework for emoji prediction. Knowledge-Based Systems	Knowledge-Based Systems	Elsevier	87.5
5	Movie Recommendation Systems using Actor-based Matrix Computations in South Korea	IEEE Transactions on Computational Social Systems	IEEE	78.26
6	A harmless webtoon for all: An automatic age-restriction prediction system for webtoon contents	Telematics and Informatics	Elsevier	95.18
7	CRNet: a multimodal deep convolutional neural network for customer revisit prediction	Journal of Big Data	Elsevier	93.63
8	Real-time Korean Voice Phishing Detection based on Machine Learning Approaches	Journal of Ambient Intelligence and Humanized Computing	Springer	55.82
9	D-HRSP: Dataset of helpful reviews for service providers	Telematics and Informatics	Springer	95.18
10	iMovieRec: a hybrid movie recommendation method based on a user-image-item model	International Journal of Machine Learning and Cybernetics	Springer	69.44
11	Detecting Wireless Signal Noise in Mobile Radio Communications Using Spatiotemporal AnoGAN-Based Approaches	IEEE Canadian Journal of Electrical and Computer Engineering	IEEE	32.11
12	STAD-GCN: Spatial-Temporal Attention-based Dynamic Graph Convolutional Network for Retail Market Price Prediction	Expert Systems with Applications	Elsevier	93.18

2. 지적재산권 확보

- 국제 특허 출원 목표 7건 / 실적 9건
- 국제 특허 등록 목표 3건 / 실적 2건(총 6건의 국제 특허 등록 심사 진행 중)
- 국내 특허 출원 목표 14건 / 실적 19건
- 국내 특허 등록 목표 8건 / 실적 12건

3. 소프트웨어 등록 : 목표 15건 / 실적 16건

4. 기술이전 : 목표 11건 / 실적 37건 달성

5. 기술료 : 목표 150백만원 / 실적 303백만원 달성

6. 상용화 : 목표 300백만원 / 실적 823백만원 달성

<정량 성과지표별 기대 목표>

구분	특허				표준화						기술이전	상용화(백만원)	기술료(백만원)	성과홍보	시제품	S/W등록	기술문서
	국제		국내		국제			국내									
	출원	등록	출원	등록	기고서제출	기고서채택	표준안채택	기고서제출	기고서채택	표준안채택							
1차년도(2021년)	0/0	0/0	3/5	0/0							0/4	0/0	0/18	1/1	1/1	2/3	5/7
2차년도(2022년)	2/3	0/0	4/4	2/5							3/6	0/0	40/43	2/5	2/4	4/4	8/12
3차년도(2023년)	3/3	1/0	4/7	3/0							4/13	100/113	50/143	2/6	4/5	4/4	8/12
4차년도(2024년)	2/3	2/2	3/3	3/7							4/14	200/710	60/99	2/2	5/5	5/5	10/12
합계	7/9	3/2	14/19	8/12							11/37	300/823	150/303	7/14	12/15	15/16	31/43

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

< 연구개발성과 성능지표 >

평가 항목 (주요성능)		단위	전체 항목에서 차지하는 비중 (%)	세계 최고		연구 개발 전 국내 성능 수준	1단계				2단계				목표설정 근거
				보유국/ 보유기관	성능 수준	성능 수준	1차년도 (2021년)		2차년도 (2022년)		3차년도 (2023년)		4차년도 (2024년)		
							목표치	달성치	목표치	달성치	목표치	달성치	목표치	달성치	
1	AI 기반 이상행위 탐지 정확도	AUC	25	미국/ ACM SIGSAC 2019	0.93	-	0.75	0.93	0.85	0.98	0.90	0.99	0.95	0.99	세계 최고수준 대비 3% 향상
2	침해사고 대응 절차 자동화 수행 시간	분	25	미국/ Fortinet	20	-	-	-	-	-	25	5	15	6	세계 최고수준 대비 33% 향상
3	보안 이벤트 분석 및 대응 플레이북	개	25	미국/ XSOAR	600	-	-	-	200	200	450	520	720	769	세계 최고수준 대비 20% 향상
4	최적 의사결정을 위한 이벤트 중요도 산정/ 분류 정확도	Accuracy	25	NSL-KDD	0.81	-	-	-	-	-	0.75	0.83	0.85	0.91	세계 최고수준 대비 5% 향상

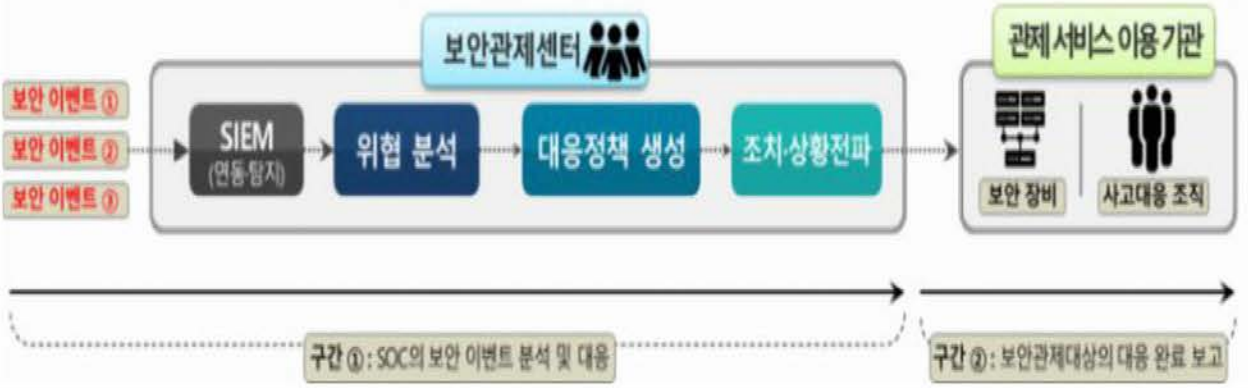
<연구개발성과 성능지표> 中 2024 공인시험성능평가 수검 항목 및 결과

시험 항목		측정 결과	평가 항목
1	AI 기반 이상행위 탐지 정확도 **→ · 보안 이벤트 정오탐 분류 정확도**	· (단일 장비) AUC 평균 0.996 · (이기종 장비) AUC 평균 0.996	성능지표 1
2	**· 침해사고 대응 절차 자동화 수행 시간**	· 전체 평균 수행 시간 06분 18초	성능지표 2
3	보안 이벤트 분석 및 대응 플레이북 **→ · 보안 이벤트 분석 및 대응 플레이북 자동 생성 개수**	· 생성 개수 평균 769개	성능지표 3
4	최적 의사결정을 위한 이벤트 중요도 산정/ 분류 정확도 **→ · 보안 이벤트 우선순위 선정 정확도**	· 정확도 평균 91%	성능지표 4

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

<연구개발성과 성능지표> 中 평가항목 2 침해사고 대응 절차 자동화 수행시간 측정 기준

o 수행시간 측정 기준 차이점



<침해사고 대응 절차 자동화 수행시간 측정 구간>

- 침해사고 대응 절차 자동화 수행시간 측정 방법의 차이점

<본 과제 성능 측정 방법 비교표>

측정 기관	측정 방법
미국/Fortinet	· 구간① 과 구간②의 수행시간 합계
본 과제 컨소시엄	· 구간①의 수행시간

- 수행시간 측정의 차이점 발생원인

· **(국외 SOC 환경)** 국외 보안관제 환경은 SOC가 대응정책 적용 대상 보안 장비까지 직접 다룰 수 있는 권한을 보유하고 있는 **자사 관제 형태가 다수** 존재

· **(국내 SOC 환경)** 대부분의 국내 보안관제 유형은 하나의 SOC에서 많은 수의 관제 서비스 이용 기관을 관제하고 있는 **원격 관제 형태로 운영**되고 있음

· **(국내 · 외 SOC 역할 고려)** 국내 SOC의 역할은 보안 이벤트 발생 시 해당 이벤트에 대한 위협 분석과 대응 정책 마련 후 관제 서비스 이용 기관에게 조치사항과 상황 전파까지 한정되어 있기 때문에 **해당 구간까지의 자동화 수행시간**을 측정

- 평가항목 2의 측정법 현행화 이유 및 24년 목표 설정

· **(측정법 현행화)** 본 과제는 '보안 이벤트 발생 → 위협탐지 → 위협분석 → 대응정책 적용' 의 자동화가 최종 목표이며, 국내 SOC의 역할 및 범위는 해당 프로세스이기 때문에 평가항목 2의 측정 방법을 국내 환경에 적합하도록 현행화하였음

· **(성능 향상 목표)** ' 23년 말 성능 수준 대비 정보보호 핵심요소기술의 성능을 **15% 상향**하여 목표 설정 (' 23년 말 : 8분 ☞ ' 24년 말 : 6분 40초)

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

(3) 세부 정량적 연구개발성과

[과학적 성과]

□ 논문(국내외 전문 학술지) 게재

번호	논문명	학술지명	발행기관	mrnIF
1	Integrating Deep Learning and Machine Translation for Understanding Unrefined Languages	Computers, Materials & Continua	TECH SCIENCE PRESS	41.76
2	A Design of Automated Vulnerability Information Management System for Secure use of Internet-Connected Devices based on Internet-Wide Scanning Methods	IEICE Transaction Information and Systems	IEICE-INSTELECTRONICS INFORMATION COMMUNICATIONS	2.74
3	Deep learning model based on expectation-confirmation theory to predict customer satisfaction in hospitality service	Information Technology & Tourism	Springer	87.71
4	MultiEmo: Multi-task framework for emoji prediction. Knowledge-Based Systems	Knowledge-Based Systems	Elsevier	87.5
5	Movie Recommendation Systems using Actor-based Matrix Computations in South Korea	IEEE Transactions on Computational Social Systems	IEEE	78.26
6	A harmless webtoon for all: An automatic age-restriction prediction system for webtoon contents	Telematics and Informatics	Elsevier	95.18
7	CRNet: a multimodal deep convolutional neural network for customer revisit prediction	Journal of Big Data	Elsevier	93.63
8	Real-time Korean Voice Phishing Detection based on Machine Learning Approaches	Journal of Ambient Intelligence and Humanized Computing	Springer	55.82
9	D-HRSP: Dataset of helpful reviews for service providers	Telematics and Informatics	Springer	95.18
10	iMovieRec: a hybrid movie recommendation method based on a user-image-item model	International Journal of Machine Learning and Cybernetics	Springer	69.44
11	Detecting Wireless Signal Noise in Mobile Radio Communications Using Spatiotemporal AnoGAN-Based Approaches	IEEE Canadian Journal of Electrical and Computer Engineering	IEEE	32.11
12	STAD-GCN: Spatial-Temporal Attention-based Dynamic Graph Convolutional Network for Retail Market Price Prediction	Expert Systems with Applications	Elsevier	93.18

□ 국내 및 국제 학술회의 발표

번호	회의 명칭	발표자	발표 일시	장소	국명
1	한국정보보호학회 충청지부학술대회	김예은	2021-08-27	대전	대한민국
2	한국정보보호학회 하계학술대회	손기종	2022-06-16	부산	대한민국
3	한국정보보호학회 하계학술대회	이새움	2022-06-17	부산	대한민국
4	한국정보보호학회 하계학술대회	김태현	2022-06-17	부산	대한민국
5	한국정보과학회 한국컴퓨터종합학술대회	최슬기	2023-06-20	제주도	대한민국
6	한국정보과학회 한국컴퓨터종합학술대회	김태현	2023-06-20	제주도	대한민국
7	한국정보보호학회 하계학술대회	손기종	2023-06-23	춘천	대한민국
8	한국정보보호학회 하계학술대회	이새움	2023-06-23	춘천	대한민국
9	한국인터넷정보학회 APIC-IST	최슬기	2023-06-27	후쿠오카	일본
10	한국인터넷정보학회 APIC-IST	김태현	2023-06-27	후쿠오카	일본
11	MobiSec 2023	김보람	2023-12-20	오키나와	일본
12	한국정보보호학회 하계학술대회	김태현	2024-06-21	세종	대한민국
13	한국정보보호학회 하계학술대회	이준영	2024-06-21	세종	대한민국
14	한국정보보호학회 충청지부학술대회	유현수	2024-09-27	대전	대한민국
15	한국인터넷정보학회 추계학술대회	김원준	2024-10-24	제주도	대한민국
16	한국정보보호학회 동계학술대회	최슬기	2024-11-29	광주(경기도)	대한민국

□ 기술 요약 정보

연도	기술명	요약 내용	기술 완성도	등록 번호	활용 여부	미활용사유	연구개발기관 외 활용여부	허용방식

□ 보고서 원문

연도	보고서 구분	발간일	등록 번호

□ 생명자원(생물자원, 생명정보)/화합물

번호	생명자원(생물자원, 생명정보)/화합물 명	등록/기탁 번호	등록/기탁 기관	발생 연도

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

[기술적 성과]

□ 지식재산권(특허, 실용신안, 의장, 디자인, 상표, 규격, 신품종, 프로그램)

번호	지식재산권 등 명칭 (건별 각각 기재)	국명	출원				등록			기여율	활용 여부
			출원인	출원일	출원 번호	등록 번호	등록인	등록일	등록 번호		
1	인터랙티브 시뮬레이션 기반 플레이북을 통한 보안 이벤트 대응 지원 방법 및 장치	대한민국	㈜시큐레이어	2021-10-07	10-2021-0133538	-	㈜시큐레이어	2022-05-23	10-2402166	100	
2	인공지능 기반 보안위협 이상행위 탐지 시스템 및 방법	대한민국	한국인터넷진흥원	2021-11-10	10-2021-0153916	-	한국인터넷진흥원	2022-08-12	10-2433830	100	
3	인공지능 기반 위협 분석 자동화 시스템 및 방법	대한민국	한국인터넷진흥원	2021-11-17	10-2021-0158551	-	한국인터넷진흥원	2022-07-06	10-2419451	100	
4	보안관제 의사결정 지원 시스템 및 방법	대한민국	한국인터넷진흥원	2021-11-17	10-2021-0158552	-	한국인터넷진흥원	2022-08-12	10-2433831	100	
5	DNS 트래픽 분석을 통한 자동화 DDoS 감지 방법 및 장치	대한민국	주식회사 윈스	2021-12-21	10-2021-0183344	-	주식회사 윈스	2024-02-14	10-2638308	100	
6	보안 이벤트 대응을 위한 플레이북의 검증을 수행하는 방법 및 장치	대한민국	㈜시큐레이어	2022-04-14	10-2022-0046579	-	㈜시큐레이어	2022-09-08	10-2443400	100	
7	인공 지능에 기반한 보안관제 환경에서 의사 결정 지원 방법	대한민국	한국인터넷진흥원	2022-11-09	10-2022-0148493	-	한국인터넷진흥원	2024-09-20	10-2709588	100	
8	인공 지능에 기반한 플레이북 자동 생성과 유효성 검증을 위한 시스템과 방법	대한민국	한국인터넷진흥원	2022-11-09	10-2022-0148494		한국인터넷진흥원			100	
9	이기종 보안 이벤트를 이용한 인공지능 기반 사이버 공격 자동 분류 장치	대한민국	한국인터넷진흥원	2022-11-09	10-2022-0148492		한국인터넷진흥원			100	
10	SYSTEM AND METHOD OF DETECTING ABNORMAL ACT THREATENING TO SECURITY BASED ON ARTIFICIAL INTELLIGENCE	미국	한국인터넷진흥원	2022-10-25	17/972,655	-	-	-	-	100	
11	SYSTEM AND METHOD OF AUTOMATIZING A THREAT ANALYSIS BASED ON ARTIFICIAL INTELLIGENCE	미국	한국인터넷진흥원	2022-10-25	17/972,634	-	-	-	-	100	
12	SYSTEM AND METHOD OF SUPPORTING DECISION MAKING FOR SECURITY MANAGEMENT	미국	한국인터넷진흥원	2022-10-25	17/972,640	-	-	-	-	100	
13	이기종 보안 이벤트를 이용한 인공지능 기반 사이버 공격 자동 분류 장치	대한민국	한국인터넷진흥원	2023-11-09	10-2022-0148492	-	한국인터넷진흥원	2025-01-09	10-2754330	100	

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

14	사이버 공격 패밀리 다중 예측을 위한 방법 및 이를 수행하는 장치	대한민국	한국인터넷진흥원	2023-09-25	10-2023-0128221	-	한국인터넷진흥원	2025-01-02	10-2750599	100	
15	TTP 기반 플레이북 자동 생성 방법 및 이를 수행하는 시스템	대한민국	한국인터넷진흥원	2023-09-25	10-2023-0128228	-	한국인터넷진흥원	2024-06-17	10-2676806	100	
16	이벤트 처리 방법 및 그 시스템	대한민국	한국인터넷진흥원	2023-09-25	10-2023-0128230	-	한국인터넷진흥원	2025-01-02	10-2750606	100	
17	로그 표준화 방법 및 그 시스템	대한민국	한국인터넷진흥원	2023-11-14	10-2023-0156963	-	-	-	-	100	
18	위협 TI 기반 온톨로지 생성과 시각화 방법 및 이를 이용한 컴퓨팅 장치	대한민국	㈜시큐레이어	2023-09-27	10-2023-0130973	-	㈜시큐레이어	2024-06-10	10-2675087	100	유
19	플레이북 자동생성 과정의 성능 향상을 위한 XAI 기반 플레이북 검증 환경 구성방법 및 장치	대한민국	한국과학기술정보연구원	2023-12-08	10-2023-0177513	-	-	-	-	100	
20	이기종 보안 이벤트를 이용한 인공지능 기반 사이버 공격 자동 분류 장치	미국	한국인터넷진흥원	2023-10-31	18/385,384	-	-	-	-	100	
21	인공 지능에 기반한 보안관제 환경에서 의사 결정 지원 방법	미국	한국인터넷진흥원	2023-10-31	18/385,387	-	-	-	-	100	
22	인공 지능에 기반한 플레이북 자동 생성과 유효성 검증을 위한 시스템과 방법	미국	한국인터넷진흥원	2023-10-31	18/385,388	-	-	-	-	100	
23	TTP BASED AUTOMATED PLAYBOOK GENERATION METHOD AND SYSTEM PERFORMING THE SAME	미국	한국인터넷진흥원	2024-01-23	18/420,458	-	한국인터넷진흥원	2024-10-01	12,107,899	100	
24	METHOD FOR CYBER ATTACK FAMILY MULTIPLE PREDICTION AND APPARATUS PERFORMING THE SAME	미국	한국인터넷진흥원	2024-01-23	18/420,333	-	-	-	-	100	
25	EVENT PROCESSING METHOD AND SYSTEM	미국	한국인터넷진흥원	2024-01-24	18/420,905	-	한국인터넷진흥원	2024-10-22	12,124,573	100	
26	강화학습 기반 플레이북 자동 생성 방법 및 그 시스템	대한민국	한국인터넷진흥원	2024-11-25	10-2024-0169706	-	-	-	-	100	
27	보안 관제 환경에서 인공지능 모델을 이용한 이벤트에 대한 대응 정책 생성 방법 및 그 시스템	대한민국	한국인터넷진흥원	2024-12-03	10-2024-0176975	-	-	-	-	100	
28	공격 패턴에 대한 플레이북을 실행하는 방법 및 이를 이용한 시스템	대한민국	시큐레이어	2024-12-06	10-2024-0181018	-	-	-	-	50	

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

○ 지식재산권 활용 유형

※ 활용의 경우 현재 활용 유형에 √ 표시, 미활용의 경우 향후 활용 예정 유형에 √ 표시합니다(최대 3개 중복선택 가능).

번호	제품화	방어	전용실시	통상실시	무상실시	매매/양도	상호실시	담보대출	투자	기타
1	√									
2				√						
3				√						
4				√						
5	√									
6	√									
7				√						
8				√						
9				√						
10				√						
11				√						
12				√						
13				√						
14				√						
15				√						
16				√						
17				√						
18				√						
19				√						
20				√						
21				√						
22				√						
23				√						
24				√						
25				√						
26				√						
27				√						
28				√						
29				√						
30				√						

□ 저작권(소프트웨어, 서적 등)

번호	저작권명	창작일	저작자명	등록일	등록 번호	저작권자명	기여율
1	양질의 인공지능 학습데이터 생성을 위한 보안이벤트 전처리 프로그램	2021-09-30	한국과학기술정보연구원	2021-10-15	C-2021-040945	한국과학기술정보연구원	100
2	보안 위협 탐지를 위한 부스팅 AI 모델(보안 위협 탐지를 위한 부스팅 에이아이 모델)	2021-10-12	주식회사 윈스	2021-11-23	C-2021-049434	주식회사 윈스	100
3	보안 위협 탐지를 위한 LSTM 모델(보안 위협 탐지를 위한 엘에스티엠 모델)	2021-10-12	주식회사 윈스	2021-11-23	C-2021-049435	주식회사 윈스	100
4	우선순위 선정 및 정책 추천 프로세스	2022-10-21	주식회사 모비젠	2022-10-31	C-2022-04226	주식회사 모비젠	100

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

5	딥러닝 모델 기반 보안관제 이벤트 정오탐 예측	2022-11-01	한국인터넷진흥원	2022-11-22	C-2022-046528	한국인터넷진흥원	100
6	부스팅 모델 기반 보안관제 이벤트 정오탐 예측	2022-11-01	한국인터넷진흥원	2022-11-22	C-2022-046529	한국인터넷진흥원	100
7	플레이북 컴포넌트 관리용 태그 추천 프로그램	2022-11-08	한국인터넷진흥원	2022-11-22	C-2022-047005	한국인터넷진흥원	100
8	사이버 위협 인텔리전스 기반 플레이북 자동 생성 프로그램	2023-11-01	한국인터넷진흥원	2023-11-08	C-2023-050109	한국인터넷진흥원	100
9	지도학습 기반 사이버 공격 패밀리 자동 예측 모듈	2023-11-01	한국인터넷진흥원	2023-11-08	C-2023-051067	한국인터넷진흥원	100
10	클러스터링 기반 데이터 셋 중복성 분석 및 제거 모듈	2023-11-01	한국인터넷진흥원	2023-11-08	C-2023-050108	한국인터넷진흥원	100
11	의사 결정 지원 프로세스	2023-11-10	모비젠	2023-11-23	C-2023-054100	모비젠	100
12	암호화 트래픽 분석 연구	2023-12-01	KISTI	2023-12-01			
13	대응이력 데이터 학습 기반 플레이북 템플릿 생성 프로그램	2024-11-18	한국인터넷진흥원	2024-12-10	C-2024-052002	한국인터넷진흥원	100
14	플레이북 템플릿 기반 플레이북 자동 생성 프로그램	2024-11-18	한국인터넷진흥원	2024-12-10	C-2024-052003	한국인터넷진흥원	100
15	딥러닝 모델 기반 보안관제 데이터 정오탐 분류 프로그램	2024-11-18	한국인터넷진흥원	2024-12-10	C-2024-052004	한국인터넷진흥원	100
16	딥러닝 및 의사레이블을 활용한 보안 위협 유형 분류 프로그램	2024-11-18	한국인터넷진흥원	2024-12-10	C-2024-052005	한국인터넷진흥원	100
17	보안관제 이벤트 우선순위 선정 정확도 측정 모듈	2024-11-25	한국인터넷진흥원	2024-12-10	C-2024-052006	한국인터넷진흥원	100

□ 신기술 지정

번호	명칭	출원일	고시일	보호 기간	지정 번호

□ 기술 및 제품 인증

번호	인증 분야	인증 기관	인증 내용		인증 획득일	국가명
			인증명	인증 번호		

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

□ 표준화

○ 국제표준 및 사실표준

번호	표준화 기구명	표준화 분과명	표준 종류	표준 단계		제안(기고)한 표준		반영(채택)된 표준		제안자	승인(채택) 일자
				구분	단계명	표준번호	표준명	표준번호	표준명		

○ 국가표준 및 단체표준

번호	표준화 기구명	표준종류	표준명	표준번호	제안자	승인(채택) 일자

○ 국제표준 정책기고

번호	표준화 기구명	표준화 정책위원회명	문서종류	문서반영 단계구분	결의안/기고명	문서번호	제안자	승인(채택) 일자

○ 오픈소스 연계 표준개발

번호	구분	표준문서 및 오픈소스 정보								과제검증 시험 결과서 번호
1	표준	표준화 기구명	표준화 분과명	표준 종류	표준단계		반영(채택)된 표준		승인(채택) 일자	
					구분	단계명	표준번호	표준명		
	오픈 소스	프로젝트명			반영 소스명				승인(Commit) 일자	

○ 표준특허

번호	표준특허 구분	표준						특허				
		표준화 기구	표준 단계		표준명	표준번호	승인/개발 일자	IPR 선언 일자	특허 단계 구분	특허명	특허번호	국명	출원/등록 일자
			구분	단계명									

○ 표준 국제협력

번호	의장단 수임						위원회/그룹 신설			국제회의 국내유치		
	표준화 기구명	표준화 분과명	의장단 직위	신규/계속 여부	수임자	수임기간	표준화 기구명	표준화 분과명	신설일자	표준화 기구명	표준화 회의명	회의일자

[경제적 성과]

□ 시제품 제작

번호	시제품명	출시/제작일	제작 업체명	설치 장소	이용 분야	사업화 소요 기간	인증기관 (해당 시)	인증일 (해당 시)
1	AI기반 보안위협 이상행위 탐지 모듈	2021.11	한국인터넷진흥원 ,윈스	한국인터넷진흥원	보안 제품 (IPS,SIEM 등)	-	-	-
2	AI기반 보안위협 이상행위 탐지 시스템	2022.11	한국인터넷진흥원 , 윈스	한국인터넷진흥원	보안 제품 (IPS,SIEM 등)	-	-	-
3	보안 관제 자동화 시스템	2022.11	한국인터넷진흥원 ,시큐레이어	한국인터넷진흥원	보안 제품 (IPS,SIEM 등)	-	-	-
4	의사결정 지원 시스템	2022.11	한국인터넷진흥원 ,윈스	한국인터넷진흥원	보안 제품 (IPS,SIEM 등)	-	-	-
5	이기종 보안장비 연동 및 자동대응 API	2022.11	한국인터넷진흥원	한국인터넷진흥원	보안 제품 (IPS,SIEM 등)	-	-	-

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

6	AI·빅데이터 기반 보안 장비 이상행위 탐지 고도화 기능 모듈	2023.12	한국인터넷진흥원,윈스	한국인터넷진흥원	보안 제품 (IPS,SIEM 등)	6개월	-	-
7	보안 위협 분석 및 대응을 위한 플레이북 자동 생성 고도화 모듈	2023.12	한국인터넷진흥원,상명대,시큐레이어	한국인터넷진흥원	보안 제품 (IPS,SIEM 등)	6개월	-	-
8	SOC 활용 시각화 기술 고도화 및 AI 기반 의사결정 검증 기술 고도화 모듈	2023.12	한국인터넷진흥원,모비젠	한국인터넷진흥원	보안 제품 (IPS,SIEM 등)	6개월	-	-
9	SOC 통합 운영 및 자동화 플랫폼 시스템 시작품	2023.12	한국인터넷진흥원,시큐레이어	한국인터넷진흥원	보안 제품 (IPS,SIEM 등)	12개월	-	-
10	이기종 보안 장비 비정형 로그 데이터 정규화 및 정책 검증 API	2023.12	한국인터넷진흥원	한국인터넷진흥원	보안 제품 (IPS,SIEM 등)	12개월	-	-
11	보안 이벤트 우선순위 선정 모듈	2024.12	한국인터넷진흥원,모비젠	한국인터넷진흥원	보안 제품 (IPS,SIEM 등)	12개월	-	-
12	보안 이벤트 분석 및 대응 플레이북 자동 생성 모듈	2024.12	한국인터넷진흥원,시큐레이어	한국인터넷진흥원	보안 제품 (IPS,SIEM 등)	12개월	-	-
13	단일 보안장비 데이터 셋을 이용한 AI 기반 이상행위 탐지 모듈	2024.12	한국인터넷진흥원	한국인터넷진흥원	보안 제품 (IPS,SIEM 등)	8개월	-	-
14	이기종 보안장비 이벤트 셋을 이용한 AI 기반 이상행위 탐지 모듈	2024.12	한국인터넷진흥원	한국인터넷진흥원	보안 제품 (IPS,SIEM 등)	8개월	-	-
15	침해사고 대응 통합 플랫폼	2024.12	한국인터넷진흥원,시큐레이어	한국인터넷진흥원	보안 제품 (IPS,SIEM 등)	12개월	-	-

□ 기술 실시(이전)

번호	기술 이전 유형	기술 실시 계약명	기술 실시 대상 기관	기술 실시 발생일	기술료 (해당 연도 발생액)	누적 징수 현황
1	기술 사용	[세부기술 1] 딥러닝(Bi-LSTM) 기반 보안 이벤트 정오탐 학습 및 예측 기술 [모듈1] 멀티 프로세싱 기반 데이터 전처리 모듈	㈜모비젠	2021-12-01	6,667,000원	-
2	기술 사용	[세부기술 1] 딥러닝(Bi-LSTM) 기반 보안 이벤트 정오탐 학습 및 예측 기술 [모듈2] 딥러닝(Bi-LSTM) 기반 정오탐 분류 모듈	㈜모비젠	2021-12-01	6,667,000원	-
3	기술 사용	[세부기술 3] 보안관제 경보대응 우선순위 분석 기술 [모듈1] 지도학습 기반 우선처리 이벤트 분류 모듈	㈜모비젠	2021-12-01	3,200,000원	-

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

4	기술 사용	[세부기술 3] 보안관제 경보대응 우선순위 분석 기술 [모듈2] 이벤트 위험도 추출 및 라벨링 모듈	㈜모비젠	2021-12-01	2,133,000원	-
5	기술 사용	[기술1] 보안관제 이벤트 기반 이상행위 탐지 및 위협 예측 기술 [모듈 4] 이기종 보안 이벤트를 이용한 비지도학습 기반 유사 사이버 공격 유형 클러스터링 기술	㈜윈스	2022-12-28	4,488,000원	-
6	기술 사용	[기술2] 템플릿 기반 보안관제 플레이북 자동 생성 기술 [모듈1] AI 기반 보안관제 플레이북 템플릿 자동 생성 모듈	㈜윈스	2022-12-28	7,480,000원	-
7	기술 사용	[기술3] 보안관제 경보대응 우선순위 분석 기술 [모듈1] 이벤트 및 플레이북 우선순위 선정 모듈	㈜윈스	2022-12-28	9,299,000원	-
8	기술 사용	[기술3] 보안관제 경보대응 우선순위 분석 기술 [모듈1] 이벤트 및 플레이북 우선순위 선정 모듈	㈜모비젠	2022-12-26	9,299,000원	-
9	기술 사용	[기술3] 보안관제 경보대응 우선순위 분석 기술 [모듈2] 보안 이벤트별 대응정책 추천 모듈	㈜모비젠	2022-12-26	7,861,000원	-
10	기술 사용	[기술1] 보안관제 이벤트 기반 이상행위 탐지 및 위협 예측 기술 [모듈 4] 이기종 보안 이벤트를 이용한 비지도학습 기반 유사 사이버 공격 유형 클러스터링 기술	㈜모비젠	2022-12-26	4,488,000원	-
11	기술 사용	[세부기술 2] 템플릿 및 TTP 기반 보안관제 플레이북 자동 생성 기술 [모듈 2] 대응이력 학습형 보안관제 플레이북 자동 생성 모듈	윈스	2023-12-22	18,121,000원	-
12	기술 사용	[세부기술 2] 템플릿 및 TTP 기반 보안관제 플레이북 자동 생성 기술 [모듈 3] 내부 위협 자산 식별 모듈	윈스	2023-12-22	1,757,000원	-
13	기술 사용	[세부기술 1] 보안관제 이벤트 기반 수집 및 이상행위 탐지 예측 기술 [모듈 1] 이기종 보안 이벤트를 이용한 지도학습 기반 사이버 공격 패밀리 예측 모듈	시큐레이어	2023-12-22	18,443,000원	-

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

14	기술 사용	[세부기술 2] 템플릿 및 TTP 기반 보안관제 플레이북 자동 생성 기술 [모듈 1] 대응이력 기반 보안관제 플레이북 템플릿 자동 생성 모듈	시큐레이어	2023-12-22	18,121,000원	-
15	기술 사용	[세부기술 2] 템플릿 및 TTP 기반 보안관제 플레이북 자동 생성 기술 [모듈 2] 대응이력 학습형 보안관제 플레이북 자동 생성 모듈	시큐레이어	2023-12-22	18,121,000원	-
16	기술 사용	[세부기술 2] 템플릿 및 TTP 기반 보안관제 플레이북 자동 생성 기술 [모듈 3] 내부 위협 자산 식별 모듈	시큐레이어	2023-12-22	1,757,000원	-
17	기술 사용	[세부기술 2] 템플릿 및 TTP 기반 보안관제 플레이북 자동 생성 기술 [모듈 4] TTP 기반 보안관제 플레이북 자동 생성 모듈	시큐레이어	2023-12-22	3,515,000원	-
18	기술 사용	[세부기술 2] 템플릿 및 TTP 기반 보안관제 플레이북 자동 생성 기술 [모듈 5] 보안관제 플레이북 컴포넌트 최적 배치 모듈	시큐레이어	2023-12-22	1,757,000원	-
19	기술 사용	[세부기술 2] 템플릿 및 TTP 기반 보안관제 플레이북 자동 생성 기술 [모듈 6] Tag 정보 관리 모듈	시큐레이어	2023-12-22	8,621,000원	-
20	기술 사용	[세부기술 3] 보안관제 이벤트 기반 우선순위 선정 및 대응 정책 추천 기술 [모듈 1] 대응이력 기반 보안관제 이벤트 우선순위 선정 모듈	시큐레이어	2023-12-22	10,337,000원	-
21	기술 사용	[세부기술 4] 비정형 보안 장비 원본 이벤트 데이터 자동 식별 및 정규화 기술 [모듈 1] AI 기반 보안장비 비정형 raw data 필드명 식별 및 정규화 모듈	시큐레이어	2023-12-22	9,380,000원	-
22	기술 사용	[세부기술 3] 보안관제 이벤트 기반 우선순위 선정 및 대응 정책 추천 기술 [모듈 1] 대응이력 기반 보안관제 이벤트 우선순위 선정 모듈	모비젠	2023-12-22	10,337,000원	-

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

23	기술 사용	[세부기술 3] 보안관제 이벤트 기반 우선순위 선정 및 대응 정책 추천 기술 [모듈 2] 대응이력 기반 플레이북 우선순위 선정 모듈	모비젠	2023-12-22	10,337,000원	-
24	기술 사용	[세부기술 1] 인공지능 기술 기반 보안 이상행위 탐지 및 분류 기술 [모듈 3] 딥러닝 모델 기반 보안관제 데이터 정오탐 분류 모델	모비젠	2024-12-23	6,457,000원	-
25	기술 사용	[세부기술 3] 인공지능 기반 의사결정 자동 추천 및 정확도 검증 기술 [모듈 1] 인공지능 기반 우선순위 자동 추천 모듈	모비젠	2024-12-23	10,762,400원	-
26	기술 사용	[세부기술 3] 인공지능 기반 의사결정 자동 추천 및 정확도 검증 기술 [모듈 2] 보안관제 이벤트별 최적 대응 정책 추천 모듈	모비젠	2024-12-23	6,457,000원	-
27	기술 사용	[세부기술 3] 인공지능 기반 의사결정 자동 추천 및 정확도 검증 기술 [모듈 2] 보안관제 이벤트 우선순위 선정 정확도 검증 모듈	모비젠	2024-12-23	4,304,300원	-
28	기술 사용	[세부기술 1] 인공지능 기술 기반 보안 이상행위 탐지 및 분류 기술 [모듈 1] 머신러닝 및 딥러닝·의사 레이블을 활용한 보안 위협 유형 분류 모듈	시큐레이어	2024-12-20	8,609,700원	-
29	기술 사용	[세부기술 1] 인공지능 기술 기반 보안 이상행위 탐지 및 분류 기술 [모듈 2] 머신러닝 모델 기반 보안관제 데이터 정오탐 분류 모듈	시큐레이어	2024-12-20	6,457,000원	-
30	기술 사용	[세부기술 1] 인공지능 기술 기반 보안 이상행위 탐지 및 분류 기술 [모듈 3] 딥러닝 모델 기반 보안관제 데이터 정오탐 분류 모듈	시큐레이어	2024-12-20	6,457,000원	-
31	기술 사용	[세부기술 2] 사이버 보안관제 플레이북 자동 생성 및 관리 기술 [모듈 1] AI 기반 플레이북 템플릿 자동 생성 모듈	시큐레이어	2024-12-20	8,610,800원	-

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

32	기술 사용	[세부기술 2] 사이버 보안관제 플레이북 자동 생성 및 관리 기술 [모듈 2] 수집 정보 기반 플레이북 자동 생성 모듈	시큐레이어	2024-12-20	8,610,800원	-
33	기술 사용	[세부기술 2] 사이버 보안관제 플레이북 자동 생성 및 관리 기술 [모듈 3] 관제원 피드백 정보 기반 플레이북 관리 모듈	시큐레이어	2024-12-20	5,739,800원	-
34	기술 사용	[세부기술 2] 사이버 보안관제 플레이북 자동 생성 및 관리 기술 [모듈 4] 플레이북 실행 정보 기반 플레이북 관리 모듈	시큐레이어	2024-12-20	5,739,800원	-
35	기술 사용	[세부기술 3] 인공지능 기반 의사결정 자동 추천 및 정확도 검증 기술 [모듈 1] 인공지능 기반 우선순위 자동 추천 모듈	시큐레이어	2024-12-20	10,762,400원	-
36	기술 사용	[세부기술 3] 인공지능 기반 의사결정 자동 추천 및 정확도 검증 기술 [모듈 2] 보안관제 이벤트별 최적 대응 정책 추천 모듈	시큐레이어	2025-01-20	6,457,000원	-
37	기술 사용	[세부기술 3] 인공지능 기반 의사결정 자동 추천 및 정확도 검증 기술 [모듈 3] 보안관제 이벤트 우선순위 선정 정확도 검증 모듈	시큐레이어	2025-01-20	4,304,300원	-

□ 사업화 투자실적

번호	추가 연구개발 투자	설비 투자	기타 투자	합계	투자 자금 성격*

□ 사업화 현황

번호	사업화 방식	사업화 형태	지역	사업화명	내용	업체명	매출액		매출 발생 연도	기술 수명
							국내 (천원)	국외 (달러)		
1	자기실시	기존 제품 개선	국내	AI기반 자동화 보안관제 대응 시스템 구축	AI/빅데이터 기반 보안 장비 이상행위 탐지 기술 고도화	한국동서발전 주식회사	113,256	-	2023	10
2	자기실시	기존 공정 개선	국내	통합로그관리솔루션 구축	AI/빅데이터 기반 보안 장비 연관분석, 이상행위 탐지 기술 고도화	에스케이쉴더스	61,380	-	2024	10

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

3	자기실시	기존 공정 개선	국내	통합보안 모델 개발 시범사업	AI/빅데이터 기반 보안 장비 연관분석, 이상행위 탐지 기술 적용	한국인터넷진흥원	165,000	-	2024	10
4	자기실시	기존 공정 개선	국내	사이버위협 공동대응 플랫폼 구축사업	AI/빅데이터 기반 보안 장비 연관분석, 이상행위 탐지 기술 적용	한국인터넷진흥원	339,825	-	2024	10
5	자기실시	기존 공정 개선	국내	통합로그분석시스템 구축	AI/빅데이터 기반 보안 장비 연관분석, 이상행위 탐지 기술 적용	에스케이쉴더스	31,152	-	2024	10

□ 매출 실적(누적)

사업화명	발생 연도	매출액		합계	산정 방법
		국내(천원)	국외(달러)		
AI기반 자동화 보안관제 대응 시스템 구축	2023	113,256	0	113,256	전체 매출액 514,800천원 대비 연구과제로 발생한 매출액 (기술기여도 22%)
통합로그관리솔루션 구축(한국토지주택공사)	2024	61,380	0	61,380	전체 매출액 204,600천원 대비 연구과제로 발생한 매출액 (기술기여도 30%)
통합보안 모델 개발 시범사업(한국인터넷진흥원)	2024	165,000	0	165,000	전체 매출액 550,000천원 대비 연구과제로 발생한 매출액 (기술기여도 30%)
사이버위협 공동대응 플랫폼 구축사업 (한국인터넷진흥원)	2024	339,825	0	339,825	전체 매출액 1,132,750천원 대비 연구과제로 발생한 매출액 (기술기여도 30%)
통합로그분석시스템 구축(파라다이스그룹)	2024	31,152	0	31,152	전체 매출액 103,840천원 대비 연구과제로 발생한 매출액 (기술기여도 30%)
합계		710,613	0	710,613	-

□ 사업화 계획 및 무역 수지 개선 효과

성과					
사업화 계획	사업화 소요기간(년)				
	소요예산(천원)				
	예상 매출규모(천원)		현재까지	3년 후	5년 후
	시장 점유율	단위(%)	현재까지	3년 후	5년 후
		국내			
		국외			
	향후 관련기술, 제품을 응용한 타 모델, 제품 개발계획				
무역 수지 개선 효과(천원)	수입대체(내수)		현재	3년 후	5년 후
	수출				

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

□ 고용 창출

순번	사업화명	사업화 업체	고용창출 인원(명)				합계
			1차년도 (2021년)	2차년도 (2022년)	3차년도 (2023년)	4차년도 (2024년)	
1		시큐레이어	3	4	4	0	11
2		모비젠	2	0	0	0	2
합계			5	4	4	0	

□ 고용 효과

구분			고용 효과(명)
고용 효과	개발 전	연구인력	
		생산인력	
	개발 후	연구인력	
		생산인력	

□ 비용 절감(누적)

순번	사업화명	발생연도	산정 방법	비용 절감액(천원)
합계				

□ 경제적 파급 효과

(단위: 천원/년)

구분	사업화명	수입 대체	수출 증대	매출 증대	생산성 향상	고용 창출 (인력 양성 수)	기타
해당 연도							
기대 목표							

□ 산업 지원(기술지도)

순번	내용	기간	참석 대상	장소	인원

□ 기술 무역

(단위: 천원)

번호	계약 연월	계약 기술명	계약 업체명	계약업체 국가	기 징수액	총 계약액	해당 연도 징수액	향후 예정액	수출/ 수입

[사회적 성과]

□ 법령 반영

번호	구분 (법률/시행령)	활용 구분 (제정/개정)	명 칭	해당 조항	시행일	관리 부처	제정/개정 내용

□ 정책활용 내용

번호	구분 (제안/채택)	정책명	관련 기관 (담당 부서)	활용 연도	채택 내용

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

□ 설계 기준/설명서(시방서)/지침/안내서에 반영

번호	구 분 (설계 기준/설명서/지침/안내서)	활용 구분 (신규/개선)	설계 기준/설명서/ 지침/안내서 명칭	반영일	반영 내용

□ 전문 연구 인력 양성

번호	분류	기준 연도	현황										
			학위별				성별		지역별				
			박사	석사	학사	기타	남	여	수도권	충청권	영남권	호남권	기타

□ 산업 기술 인력 양성

번호	프로그램명	프로그램 내용	교육 기관	교육 개최 횟수	총 교육 시간	총 교육 인원

□ 다른 국가연구개발사업에의 활용

번호	중앙행정기관명	사업명	연구개발과제명	연구책임자	연구개발비

□ 국제화 협력성과

번호	구분 (유치/파견)	기간	국가	학위	전공	내용

□ 홍보 실적

번호	홍보 유형	매체명	제목	홍보일
1	언론보도	보안뉴스 외 15개 언론사	AI·빅데이터 기반 SOAR 국내 원천기술 확보 및 정보보호 신시장 개척을 위한 과제 추진 홍보	2021-06-22
2	발표	세계보안엑스포 (SECON 2022)	국가 정보보호 R&D 우수 기술 홍보 및 기술이전 설명회	2022-04-20
3	발표	AI보안연구회	사이버 보안 오케스트레이션 과제 소개	2022-07-14
4	발표	인천공항공사	사이버 보안 오케스트레이션 과제 소개	2022-07-26
5	언론보도	보안뉴스 외 7개 언론사 (대한민국 4차산업 혁명 페스티벌)	정보보호 R&D 핵심기술 이전 설명회	2022-09-15
6	발표	세계보안엑스포 (SECON 2023)	국가 정보보호 R&D 우수 기술 홍보 및 기술이전 설명회	2023-03-29
7	언론보도	보안뉴스	[2023 AI 보안관제 리포트] 챗GPT로 핫한 AI 기술로 보안위협에 '대반격'	2023-06-30

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

8	발표	디지털미래혁신대전	국가 정보보호 R&D 우수 기술 홍보	2023-09-25
9	언론보도	데일리시큐 외 1개 언론사	시큐레이어, 보안 대응 속도 높이는 SOAR 특허 출원	2023-10-13
10	발표	2023 세종 사이버보안 워크숍	AI를 활용한 사이버 보안 관제 자동화 기술 개발 과제 홍보	2023-10-27
11	발표	AI 보안 기술 전문가 워킹그룹	AI를 활용한 사이버 보안 관제 자동화 기술 개발 과제 홍보	2023-11-09
12	언론보도	데이터넷 외 2개 언론사	시큐레이어-KISA, 기술 이전 협약 체결...'산·연 협력' 모범 사례	2023-12-22
13	발표	세계보안엑스포 (SECON 2024)	AI·빅데이터 기반 사이버 보안 오케스트레이션 및 자동 대응 기술 개발	2024-03-20
14	발표	2024 핵테온 세종 국제 사이버보안 위크	AI·빅데이터 기반 사이버 보안 오케스트레이션 및 자동 대응 기술 개발	2024-06-19
15	발표	2024 IT21 글로벌 컨퍼런스	AI·빅데이터 기반 사이버 보안 오케스트레이션 및 자동 대응 기술 개발	2024-07-04
16	발표	디지털 혁신 페스타 2024	AI·빅데이터 기반 사이버 보안 오케스트레이션 및 자동 대응 기술 개발	2024-10-10

□ 포상 및 수상 실적

번호	종류	포상명	포상 내용	포상 대상	포상일	포상 기관

[인프라 성과]

□ 연구시설 • 장비

구축기관	연구시설/ 연구장비명	규격 (모델명)	개발여부 (○/×)	연구시설 • 장비 종합정보시스템 등록여부	연구시설 • 장비 종합정보시스템 등록번호	구축일자 (YY.MM.DD)	구축비용 (천원)	비고 (설치 장소)

[그 밖의 성과]

해당사항 없음

(4) 계획하지 않은 성과 및 관련 분야 기여사항

해당사항 없음

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

2) 목표 달성 수준

추 진 목 표	달 성 내 용	달성도 (%)
<기술 별 개발목표> ○ 이상행위 탐지 기술	○ 보안 장비 데이터 수집 및 보안 정책 적용 기술 개발 ○ 빅데이터 기반 이상행위 탐지 요소 기술 개발 ○ 이기종 보안 장비 이상행위 탐지 성능 향상 기술 개발 ○ 보안 위협 인텔리전스 기반 침해사고 지표 정보 수집 분석	100%
○ 위협 분석 자동화 기술	○ 공개 CTI 및 MITRE ATT&CK Matrix 기반 TTP 생성 기술 개발 ○ TTP 정보 기반 위협 인자 및 자산 식별 기술 개발 ○ TTP 정보 기반 이상행위 위협 인자 식별 기술 설계 ○ 보안 관제 플레이북 자동 생성·검증·관리 기술 개발 ○ 플레이북을 통한 자동화 분석 절차 관리 및 시각화 기술 개발	100%
○ 의사결정 지원 기술	○ 이기종 보안 장비 데이터 및 TTP 연관정보 가시화 기술 개발 ○ 의사결정 지원을 위한 고성능 AI 분석 모델 개발 및 데이터셋 구축 ○ AI 기반 최적 의사결정 자동 추천 모델 개발	100%
○ 자동대응 및 검증 기술	○ 이기종 보안 장비별 보안 정책(탐지·차단) 자동 생성 기술 개발 ○ 보안사고 자동 대응 기술 개발 및 검증 기술 개발 ○ 보안관제 업무 프로세스 평가를 위한 정량적 측정 기술 개발 ○ SOC 통합 운영 및 자동화 플랫폼 개발	100%
<정량적 성능 목표> ○ AI 기반 이상행위 탐지 정확도	○ (최종목표) 0.95 AUC / (실적) 0.99 AUC	100%
○ 침해사고 대응 절차 자동화 수행 시간	○ (최종목표) 15분 / (실적) 6분	100%
○ 보안 이벤트 분석 및 대응 플레이북	○ (최종목표) 720개 / (실적) 769개	100%
○ 최적 의사결정을 위한 이벤트 중요도 산정·분류 정확도	○ (최종목표) 0.85 Accuracy / (실적) 0.91 Accuracy	100%

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

4. 목표 미달 또는 미흡한 사항에 대한 원인분석

1) 목표 미달 또는 미흡한 연구결과에 대한 원인(사유) 자체분석 내용

- 국제특허 출원/등록 진행 과정에서 발생하는 심사관 변경, 추가 의견 제출 요구 등 많은 변수로 인한 심사 전체 프로세스 지연

2) 미달 또는 미흡한 결과물에 대한 보완 활동

- '22년 미국 특허 출원 3건, '23년 미국 특허 출원 3건에 대한 등록 심사가 진행 중이며, 총 6건의 국제 특허 추가 등록 예정

※ '22년 미국 특허 출원 3건, ' 23년 미국 특허 출원 3건 진행 중이며, 6건의 국제 특허 출원이 완료되면 특허 등록 진행

3) 연구개발 과정의 성실성

- 확보된 기술 및 연구결과를 국내외 학술대회, 기술이전설명회 등을 통해 공유하고, 해외 기술 교류에 적극 참여하여 산업협력 및 사업화 기회 발굴

5. 연구개발성과의 관련 분야에 대한 기여 정도

□ 기술이전을 통한 민간 기업의 정보보호 사업 참여 확대 기여

o 개요

- 최근 글로벌 보안 시장은 통합보안 플랫폼으로 빠르게 변화하고 있어 글로벌 기업들은 막대한 자금을 바탕으로 타사 솔루션과 기술 제휴 등을 통해 시장 변화에 대응하고 있음
- 국내 기업들은 협소한 내수·공공시장을 두고 단품 위주의 보안 솔루션으로 폭증하는 사이버위협에 대응하고 있어 협업 활성화가 어려운 글로벌 트렌드에 뒤쳐질 우려 존재

※ 22년 정보보안 매출액(5.6조원)중 수출은 2.76%(1,552억 원), 전체 매출액 중 공공부문은 약 41.4%를 차지(정보보호산업실태조사, `23.9)

o 주요 내용

- 연구개발 결과물의 활용성 제고를 위해 기술이전을 받은 업체를 대상으로 기술 사업화 지원
- 보안관제 센터 내 전체 업무 프로세스 자동화 및 대규모 사이버 위협 의심 정보를 자동으로 분류·대응하는 사이버보안 자동 대응 기술 등에 대한 기술이전 계약 체결
- AI기반 이상행위 탐지 및 보안관제 全 업무 프로세스 자동화 기술 등 이전으로 국가 인프라 보안을 위한 보안관제센터 핵심기술 제공
- 기술이전 사후 지원으로 실무인력 대상 기술전수 교육 및 이전받은 기술 활용을 위한 기술 컨설팅 등을 통해 이전받은 기술 사업화 지원
- 참여기관 ㈜시큐레이어는 이전받은 기술을 기반으로 한국형 보안 오케스트레이션 자동화 및 대응 솔루션(SOAR)을 고도화하여 사업화 추진

o 추진 성과

- **과기정통부·한국인터넷진흥원의 K-시큐리티 얼라이언스 「통합보안 모델 개발 시범사업」의 'OPEN XDR 통합플랫폼 개발' 과제 선정 및 다수의 사업화 성과 창출**

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

6. 연구개발성과의 관리 및 활용 계획

< 연구개발성과 활용계획표 >

구분(정량 및 정성적 성과 항목)		연구개발 종료 후 5년 이내
국외논문	SCIE	매년 목표치
	비SCIE	-
	계	-
국내논문	SCIE	-
	비SCIE	-
	계	-
특허출원	국내	-
	국외	-
	계	-
특허등록	국내	-
	국외	6
	계	6
인력양성	학사	-
	석사	-
	박사	-
	계	-
사업화	상품출시	-
	기술이전	-
	공정개발	-
제품개발	시제품개발	-
국제 표준화	기고서 제출	-
	기고서 채택	-
	표준안 채택	-
국내 표준화	기고서 제출	-
	기고서 채택	-
	표준안 채택	-
성과홍보		-
포상 및 수상실적		-
정성적 성과 주요 내용		-

※ 국외 특허 출원 6건 완료하였으며, 해당 출원 완료 건 대상으로 특허 등록 진행 예정

① 특허 명: SYSTEM AND METHOD OF DETECTING ABNORMAL ACT THREATENING TO SECURITY BASED ON ARTIFICIAL INTELLIGENCE SYSTEM AND METHOD OF AUTOMATIZING

※ 출원 완료일: 2022년 10월 25일

② 특허 명: A THREAT ANALYSIS BASED ON ARTIFICIAL INTELLIGENCE

※ 출원 완료일: 2022년 10월 25일

③ 특허 명: SYSTEM AND METHOD OF SUPPORTING DECISION MAKING FOR SECURITY MANAGEMENT

※ 출원 완료일: 2022년 10월 25일

④ 특허 명: DEVICE FOR AUTOMATICALLY SORTING CYBER ATTACK BASED ON ARTIFICIAL INTELLIGENCE USING SECURITY EVENT OF DIFFERENT KINDS OF SECURITY DEVICES

※ 출원 완료일: 2023년 10월 31일

⑤ 특허 명: METHOD FOR SUPPORTING DECISION-MAKING IN SECURITY CONTROL ENVIRONMENT BASED ON ARTIFICIAL INTELLIGENCE

※ 출원 완료일: 2023년 10월 31일

⑥ 특허 명: SYSTEM AND METHOD FOR AUTOMATICALLY GENERATING PLAYBOOK AND VERIFYING VALIDITY OF PLAYBOOK BASED ON ARTIFICIAL INTELLIGENCE

※ 출원 완료일: 2023년 10월 31일

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

1) 향후 5년간 성과활용·확산 활용방안 및 계획(활동계획)

□ 참여기관1 : 모비젠

o 자사 빅데이터 플랫폼과 보안 솔루션 융합
- 2025년 2월: 계획 수립/ 목표 설정 / 시장 분석
- 2025년 4월: 요구사항 분석 / 설계
- 2025년 10월: 기술 개발
- 2025년 12월: 시스템 통합 및 시험
- 인력운영 : 상용 서비스 기획자 1명, 개발자 2명

o AI 기반 보안 분석 플랫폼 고도화
- 2026년 2월: 계획 수립/ 목표 설정 / 시장 분석
- 2026년 5월: 요구사항 분석 / 설계
- 2026년 11월: 분석 라이브러리 개발
- 2026년 12월: 시스템 통합 및 시험
- 인력운영 : 상용 서비스 기획자 1명, 개발자 2명, 분석가 1명

o 제품 실증 및 패키징
- 2027년 3월: 제품 실증 협업 사 확보 / 실증 계획 수립
- 2027년 7월: 제품 실증 및 안정화
- 2027년 10월: 패키징 / 매뉴얼 및 영업자료 작성
- 인력운영 :전담 영업 1명, 개발자 1명, 디자이너 1명

o 국내 마케팅
- 2028년 : 자사 빅데이터 플랫폼을 판매하는 유통 채널을 구축하고, 최소 5개 이상의 판매 채널 확보

o 해외 마케팅
- 2029년 : 모기업의 해외 영업망을 통해 해외 시장 개척

<연도별 주요 활동계획(요약표)>

구분	종료+1 (2025년)	종료+2 (2026년)	종료+3 (2027년)	종료+4 (2028년)	종료+5 (2029년)
기 상용화 제품 기술 추가 계획	자사 빅데이터 플랫폼과 보안 솔루션 융합	AI 기반 보안 분석 플랫폼으로 고도화	제품 실증 및 패키징	국내 마케팅	해외 마케팅

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

□ 참여기관2 : 시큐레이어

o 사업화를 위한 시장 환경 및 경쟁력 분석(SWOT 분석)

- 강점(S) : 빅데이터, AI 기반 보안 관제 자동화 서비스에 최적화된 기술과 인력을 보유함. 국내 최대 규모 구축 운영 노하우를 보유한 기업으로 빅데이터, AI 기반 플랫폼을 자체개발 및 판매함. SIEM, SOAR 등 기보유한 보안 관제 자동화 솔루션과 인프라를 활용해 시장성과 상품성을 성공적으로 확보할 수 있음
- 약점(W) : 시장·고객을 선제적으로 리딩하기에 규모의 경제에서 부족한 부분이 있음. 서비스의 복잡도가 증가함에 따라 인건비 또한 증가하는 구조도 리스크로 작용함
- 기회(O) : 클라우드의 발전과 각 기관의 IT 자산과 보안장비증가, 초연결 사회로 접어들며 네트워크 및 기기 보안의 중요성이 주목받으면서 AI 기반 보안 관제 시장규모가 지속적으로 성장함
- 위기(T) : Big Data, AI 기반 보안 관제 자동화 솔루션 시장 경쟁 심화 및 단가 하락 가속화. 공격 역시 AI를 이용한 자동화 공격이 증가하며 사이버 공격 표면이 증가함으로 보안 위협 심화

o 성과 활용 시장 규모

- SOAR 시장은 꾸준히 성장하고 있으나, SOAR는 보안 성숙도가 높은 조직에서 도입하는 것으로 관찰됨
- SOAR 시장은 차세대 SOC 환경에 가장 적절한 솔루션으로 손꼽히며 지속 성장할 전망. 단, 보안 성숙도가 낮은 기업에서 활용하기에는 기술적으로 복잡하기 때문에 각 조직에 맞는 프로그래밍을 통해 최적화할 필요성 존재
- SIEM 밴더 사(社)는 보안 관제 자동화에 대한 필요성을 인지하고, 자사 SIEM 솔루션에 SOAR 솔루션을 적용·채택·통합하는 경향을 보임
- 글로벌 SOAR 시장 규모가 2025년까지 18억 1,700만 달러를 상회할 것으로 예상하며, 2018년부터 2025년 사이 연평균 성장률은 15% 이상을 기록할 것으로 전망
- 기업연구소 kt경제경영연구소에 따르면 국내 AI 시장 규모는 2020년 2조2천억 원, 2025년 11조 원, 2030년 27.5조 원을 기록할 것으로 전망

o 사업화 전략

- 공공 기관 레퍼런스, 지자체 그리고 금융사 제품 공급을 통한 즉시 국내 상용화 및 향후 해외수출 교두보 마련
- 본 과제 수행으로 얻어지는 핵심 기술인 AI·빅데이터 기반의 SOAR 통합 시스템은 국내 SOC 환경에 특화된 SOAR 제품으로 상용 제품화 전략
- 지역 총판 및 전국 50여 개의 파트너 업체를 활용한 판매 채널 확장 및 프로모션 진행

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

<사업화를 위한 주요 수요처>

- 보안 솔루션 파트너사 대상 B2B 홍보 및 보안 솔루션 Line-up 구축
- 기 보유한 비즈니스 파트너를 위해 Business Partner ‘s Day(비즈니스 파트너스 데이) 행사를 개최. SOAR의 비전과 전략을 홍보하는 한편, 동반 성장을 위한 구체적인 청사진을 제시하고, IT 보안 관련 최신 트렌드와 지식 등을 교류하는 등 밀도 높은 관계를 결속함으로써 중·장기적 파트너십 강화 도모

<연도별 주요 활동계획(요약표)>

구분	종료+1 (2025년)	종료+2 (2026년)	종료+3 (2027년)	종료+4 (2028년)	종료+5 (2029년)
보안관제 오케스트레이션 및 대응 자동화 기술 상용화 추진 계획	-비지니스 모델 정의 -보안 및 규정 준수 확인 -마케팅 및 홍보 전략 수립	-고객 서비스 및 지원 체계 구축 -타겟 시장 변화 조사 및 대응 전략 수립	-세일즈 및 유통 채널 확장 -사용자 교육 및 트레이닝 프로그램 개선	-지속적인 제품/서비스 개선 -고객 서비스 지원 체계 강화	-파트너십 강화 및 확장 -성과 평가 및 KPI 모니터링
보안관제 오케스트레이션 및 대응 자동화 기술 후속 연구	-고도화된 이상행위 탐지를 위한 최신 인공지능 알고리즘 연구	-위협분석 및 자동화 알고리즘 고도화 연구	-보안관제 센터에 특화된 UI/UX 개선 작업 진행	-신속한 의사결정 지원을 위한 인공지능 기술 고도화	-이기종 보안장비 및 클라우드 환경의 자동 대응 기술 고도화 연구

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

2) 주요 성과활용 (기대)성과목표

□ 참여기관1 : 모비젠

(1) 정성적 목표

o 자사 빅데이터 플랫폼의 부가가치 증대를 통한 판매 시장 다변화

o 다양한 업무 분야의 분석 기능 추가를 통해 분석 플랫폼으로서 위상 제고

(2) 정량적 목표

<연도별 성과활용 (기대)성과목표(요약표)>

구분	종료+1 (2025년)	종료+2 (2026년)	종료+3 (2027년)	종료+4 (2028년)	종료+5 (2029년)
매출액	-	-	5억	15억	30억
고용	1명	2명	2명	3명	5명

3) 성과활용·관리 추진체계

□ 참여기관2 : 시큐레이어

(1) 정성적 목표

o 글로벌 SOAR 시장에서의 국제 경쟁력 확보

- 2025년 현재, 글로벌 SOAR 시장은 빠르게 성장하고 있으며, 다양한 벤더들이 차세

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

대 SOAR 솔루션을 제공하고 있음. 글로벌 AI 시장전망은 2025년 기준 898억5천만 달러 규모(8조 2649억)로, 가파르게 성장할 것으로 전망. 이러한 시장 전망에서 고도화된 SOAR 기술은 다양한 기관 SOC의 사이버 보안 능력을 한 단계 끌어올릴 수 있는 핵심기술. 비용과 인력을 투입하여 고도화된 기술을 확보할 경우 First Mover로서 세계시장 점유율을 확보하고, 차세대 AI 사이버 보안 기업으로서 포지셔닝을 도모할 수 있음

o 자동화된 솔루션으로 폭넓은 소비자층 및 보안 대응 인력 확보

- 보안관제 오케스트레이션 및 대응 자동화 기술은 비전문가인 의사 결정권자는 물론 Citizen scientists와 같은 일반 소비자의 수요까지 충족시킬 수 있음. 즉, 인공지능 진입장벽을 낮춤으로써 폭넓은 소비자층을 확보하여 4차 산업혁명의 견인차 역할을 할 수 있으며, 부족한 보안 전문인력의 부담을 경감시켜주어 효율적이고 체계적인 대응 프로세스를 구축하고 복잡한 위협에 대한 대응 능력을 향상

o 보안 가시성 향상으로 인한 신속한 대응 의사결정 가능

- 다양한 보안 데이터를 통합하여 위협 상황에 대한 종합적인 가시성을 확보하고, 보다 정확한 판단을 내릴 수 있도록 도우며, IT 부서 및 보안 팀 간 협업을 자동화하여 신속한 정보 공유 및 의사결정 가능. 보안 사고 대응 절차의 투명성을 높이고 운영 프로세스를 표준화하여 좀 더 명확한 대응이 가능

(2) 정량적 목표

<연도별 성과활용 (기대)성과목표(요약표)>

구분	종료+1 (2025년)	종료+2 (2026년)	종료+3 (2027년)	종료+4 (2028년)	종료+5 (2029년)
매출액	1,000백만원	1,300백만원	1,700백만원	2,200백만원	2,900백만원
고용	10명	13명	17명	22명	29명

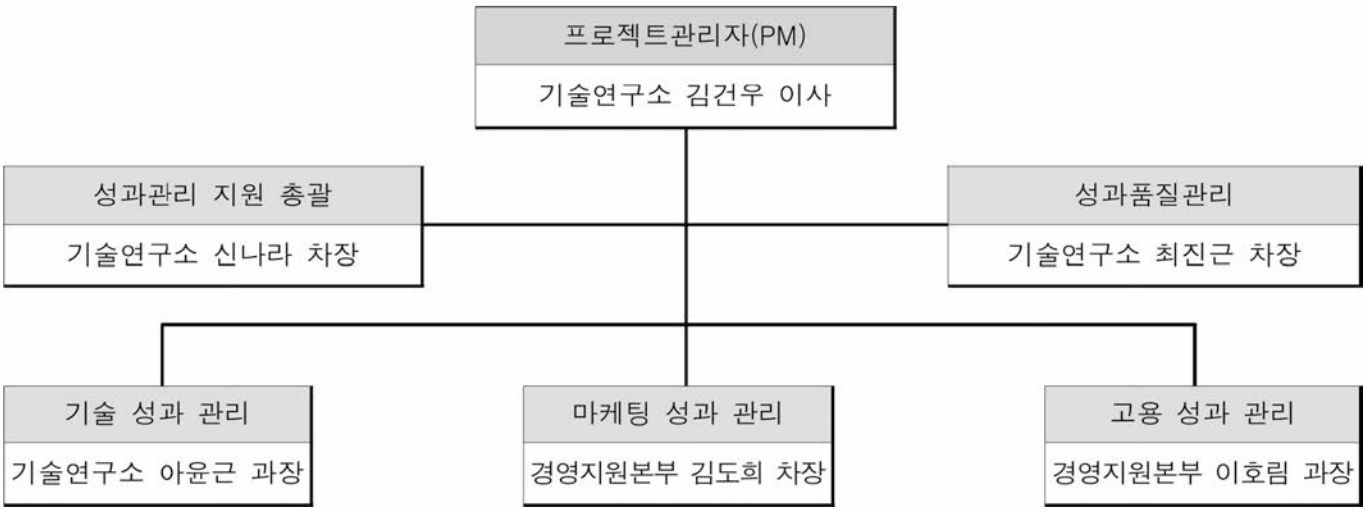
o 글로벌 시장 및 국내 시장 성장에 의한 정량적 목표 설정

- Value Market Research에 따르면 세계의 SOAR(보안 오케스트레이션 자동화 대응) 시장 규모는 2022년에 23억 9,000만 달러에 이르렀으며, 2023년부터 2030년에 걸쳐 CAGR 16.21%로 성장하여 2030년에는 약 79억 5,000만 달러에 달할 것으로 예측
- Wise Guy Research는 2023년 SOAR 시장규모는 약 14억 8,900만 달러로 추산되며, 2024년부터 2032년까지 연평균 성장률 21.21%로 증가하여 2032년에는 약 84억 1천만 달러에 도달할 것으로 전망함. 또한 북미 지역은 2023년 SOAR 시장의 약 35%를 차지하며, 지속적인 사이버위협의 증가와 복잡성으로 인해 2032년까지 꾸준한 성장이 예상됨
- 따라서 당사는 인공지능 기술을 활용한 보안관제 오케스트레이션 및 대응 자동화 기술에 대한 폭발적인 수요에 의해 2030년까지 지속적인 시장의 성장세를 예측하여 연평균 30% 이상 성장하는 매출 및 고용 성장 수치를 예상하여 설정함

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

o 성과 활용 관리 조직 구성

- 본 과제의 공동 연구기관 ㈜시큐레이어는 체계적인 성과관리를 위해 다음과 같이 조직 구성을 수립



o 성과 활용 관리 추진 일정

<성과활용 관리 추진 계획·일정>

성과 관리 내용		추진일정 (연도별)				
		2025년	2026년	2027년	2028년	2029년
1. 기술 성과관리	위협분석 및 자동화 알고리즘 고도화 연구	■	■			
	보안관제 센터에 특화된 UI/UX 개선 작업 진행		■	■	■	
	이기종 보안장비 및 클라우드 환경의 자동 대응 기술 고도화 연구			■	■	■
2. 마케팅 성과관리	고객 서비스 및 지원 체계 구축	■	■			
	세일즈 및 유통 채널 확장		■	■	■	
	파트너십 강화 및 확장			■	■	■
3. 고용 성과 관리	연구 홍보를 통한 전문 인력 채용 및 관리	■	■	■	■	■

4) 기타

- 해당사항 없음

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

7. 연구개발성과에 대한 후속연구 및 추가 개발 계획

□ 참여기관1 : 모비젠

- 해당사항 없음

□ 참여기관2 : 시큐레이어

o 인공지능 기술을 활용한 자동화 대응 및 플레이북 고도화

- 차세대 보안관제 오케스트레이션 및 대응 자동화 기술을 위해 더 높은 자동화 수준 및 지능적인 위협 대응을 목표로 추가 후속연구가 필요할 것으로 예상함
- 과거의 다양한 보안 사고 데이터를 학습하여 최적의 대응 플레이북을 추천해주는 기술을 더욱 고도화 하고, 실시간으로 더욱 자연스럽게 대응하도록 연구하며, 급변하는 보안 환경 변화에 맞춰 플레이북을 자동 업데이트 할 수 있도록 연구
- 또한 인공지능 및 머신러닝 기술을 활용하여 워크플로우를 동적으로 조정하고, 상황에 따라 필요한 작업들을 자동으로 추가하거나 생략할 수 있도록 고도화 필요

o XDR (Extended Detection and Response)과의 통합 강화

- 엔드포인트, 네트워크, 클라우드 등 다양한 영역의 데이터를 XDR과 통합하여 위협에 대한 종합적인 가시성을 확보하고, XDR의 탐지 기능을 활용하여 알려지지 않은 위협까지 신속하게 탐지하고, SOAR를 통해 자동 대응하는 기술 연구 필요

o 클라우드 네이티브 보안관제 오케스트레이션 및 대응 자동화 기술 개발

- 급변하는 클라우드 환경에서 발생하는 보안 위협에 특화된 보안관제 오케스트레이션 및 대응 자동화 솔루션 개발이 필요함
- 클라우드 기반 SOAR는 필요에 따라 자원을 확장하고, 다양한 클라우드 환경에 유연하게 대응할 수 있게 하며, 개발 단계부터 보안을 고려하는 DevSecOps 환경을 지원하여 애플리케이션 개발과 보안 운영을 통합한 설계로 개발하는 것이 필요함

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

8. 연구개발비 사용실적

가. 총괄

1. 연구개발비 사용명세서

(단위 : 원, %)

항목 \ 구분		연구개발비 현황					사용 금액 ⑥	사용 잔액 (⑤-⑥)	사용률 (⑥/⑤ ×100)	다음단계 이월액 (해당 시)
		전단계 이월액 (해당 시) ①	당초 연구개발비 ②	변경 연구개발비 ③	발생이자 중 연구개발비 산입금 ④	소계 ⑤ (①+②+③+④)				
가. 직접비	현금	-	8,435,463,000	-558,526,993	847,259	7,877,783,266	7,780,177,887	97,605,379	98.76	-
	현물	-	1,620,300,000	-317,971,200	0	1,302,328,800	1,302,328,800	0	100.00	-
	소계	-	10,055,763,000	-876,498,193	847,259	9,180,112,066	9,082,506,687	97,605,379	98.94	-
1) 인건비	현금	-	5,100,000,000	181,091,949	0	5,281,091,949	5,204,468,318	76,623,631	98.55	-
	현물	-	1,620,300,000	-317,971,200	0	1,302,328,800	1,302,328,800	0	100.00	-
2) 학생인건비	현금	-	310,660,000	121,388,586	30,980	432,079,566	432,079,566	0	100.00	-
3) 연구시설·장비비	현금	-	1,304,100,000	-571,507,800	0	732,592,200	732,494,169	98,031	99.99	-
	현물	-	0	0	0	0	0	0	0.00	-
4) 연구재료비	현금	-	22,000,000	149,196,600	0	171,196,600	162,882,600	8,314,000	95.14	-
	현물	-	0	0	0	0	0	0	0	-
5) 위탁연구개발비	현금	-	-	-	-	-	-	-	-	-
6) 국제공동연구개발비	현금	-	-	-	-	-	-	-	-	-
7) 연구개발부담비	현금	-	-	-	-	-	-	-	-	-
8) 연구활동비	현금	-	1,151,983,000	-299,703,328	816,279	853,095,951	841,375,114	11,720,837	98.63	-
	현물	-	0	0	0	0	0	0	0.00	-
9) 연구수당	현금	-	546,720,000	-138,993,000	0	407,727,000	406,878,120	848,880	99.79	-
나. 간접비	현금	-	1,064,237,000	-140,390,668	0	923,846,332	917,506,332	6,340,000	99.31	-
	소계	-	1,064,237,000	-140,390,668	0	923,846,332	917,506,332	6,340,000	99.31	-
합계	현금	-	9,499,700,000	-698,917,661	847,259	8,801,629,598	8,697,684,219	103,945,379	98.82	-
	현물	-	1,620,300,000	-317,971,200	0	1,302,328,800	1,302,328,800	0	100.00	-
	합계	-	11,120,000,000	-1,016,888,861	847,259	10,103,958,398	10,000,013,019	103,945,379	98.97	-

2. 발생이자 사용명세서

(단위 : 원)

구분	발생금액 (A)	사용용도	사용금액 (B)	사용잔액 (A-B)
연구개발기간 중 발생이자	12,644,464	국고반납/과제산입	12,532,804	111,660
연구개발기간 후 발생이자	49,463	국고반납	49,463	0
합계	12,693,927	-	12,582,267	111,660

3. 반납액 명세서

(단위 : 원, %)

연구개발비 반납액				발생이자 반납액		총 반납액 (C+E)
구분	현금	현물	소계			
사용잔액	103,833,719	-	103,833,719	연구개발기간 중	11,908,865	-
불인정 사용금액	54,545	-	54,545	연구개발기간 후	49,463	-
소계(A)	103,888,264	-	103,888,264	소계(D)	11,938,328	-
정부지분율(B)	-	-	-	정부지분율(B)	-	-
정부지분액(C=A×B)	103,888,264	-	103,888,264	정부지분액(E=D×B)	11,938,328	115,826,592

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

나. 주관연구개발기관(한국인터넷진흥원 김태은 연구책임자)

1. 연구개발비 사용명세서

(단위 : 원, %)

항목 \ 구분		연구개발비 현황					사용금액 ⑥	사용잔액 (⑤-⑥)	사용률 (⑥/⑤ ×100)	다음단계 이월액 (해당 시)
		전단계 이월액 (해당 시) ①	당초 연구개발비 ②	변경 연구개발비 ③	발생이자 중 연구개발비 산입금 ④	소계 ⑤ (①+②+③+④)				
가. 직접비	현금	-	2,693,000,000	-427,600,000	0	2,265,400,000	2,185,980,405	79,419,595	96.49	-
	현물	-	565,500,000	-188,500,000	0	377,000,000	377,000,000	0	100	-
	소계	-	3,258,500,000	-616,100,000	0	2,642,400,000	2,562,980,405	79,419,595	96.99	-
1) 인건비	현금	-	943,000,000	160,900,000	0	1,103,900,000	1,031,279,368	72,620,632	93.42	-
	현물	-	565,500,000	-188,500,000	0	377,000,000	377,000,000	0	100	-
2) 학생인건비	현금	-	0	0	0	0	0	0	0	-
3) 연구시설・장비비	현금	-	1,070,000,000	-473,050,000	0	596,950,000	596,851,969	98,031	99.98	-
	현물	-	0	0	0	0	0	0	0	-
4) 연구재료비	현금	-	0	153,000,000	0	153,000,000	146,798,300	6,201,700	95.95	-
	현물	-	0	0	0	0	0	0	0	-
5) 위탁연구개발비	현금	-	-	-	-	-	-	-	-	-
6) 국제공동연구개발비	현금	-	-	-	-	-	-	-	-	-
7) 연구개발부담비	현금	-	-	-	-	-	-	-	-	-
8) 연구활동비	현금	-	680,000,000	-268,450,000	0	411,550,000	411,050,768	499,232	99.88	-
	현물	-	0	0	0	0	0	0	0	-
9) 연구수당	현금	-	0	0	0	0	0	0	0	-
나. 간접비	현금	-	457,000,000	-79,000,000	0	378,000,000	378,000,000	0	100	-
	소계	-	457,000,000	-79,000,000	0	378,000,000	378,000,000	0	100	-
합계	현금	-	3,150,000,000	-506,600,000	0	2,643,400,000	2,563,980,405	79,419,595	97.00	-
	현물	-	565,500,000	-188,500,000	0	377,000,000	377,000,000	0	100	-
	합계	-	3,715,500,000	-695,100,000	0	3,020,400,000	2,940,980,405	79,419,595	97.37	-

2. 발생이자 사용명세서

(단위 : 원)

구분	발생금액 (A)	사용용도	사용금액 (B)	사용잔액 (A-B)
연구개발기간 중 발생이자	2,553,139	국고반납	2,553,139	-
연구개발기간 후 발생이자	8,640	국고반납	8,640	-
합계	2,541,779	-	2,541,779	-

3. 반납액 명세서

(단위 : 원, %)

연구개발비 반납액				발생이자 반납액		총 반납액 (C+E)
구분	현금	현물	소계			
사용잔액	79,419,595	-	-	연구개발기간 중	2,553,139	-
불인정 사용금액	-	-	-	연구개발기간 후	8,640	-
소계(A)	79,419,595	-	-	소계(D)	2,541,779	-
정부지분율(B)	100	-	-	정부지분율(B)	100	-
정부지분액(C=A×B)	79,419,595	-	79,419,595	정부지분액(E=D×B)	2,541,779	81,961,374

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

나. 주관연구개발기관(한국과학기술정보연구원 송중석 연구책임자)

1. 연구개발비 사용명세서

(단위 : 원, %)

항목 \ 구분		연구개발비 현황					사용금액 ⑥	사용잔액 (⑤-⑥)	사용률 (⑥/⑤ ×100)	다음단계 이월액 (해당 시)
		전단계 이월액 (해당 시) ①	당초 연구개발비 ②	변경 연구개발비 ③	발생이자 중 연구개발비 산입금 ④	소계 ⑤ (①+②+③+④)				
가. 직접비	현금	-	1,487,250,000	-111,897,661	0	1,375,352,339	1,368,318,836	7,033,503	99.49	-
	현물	-	0	0	0	0	0	0	0	-
	소계	-	1,487,250,000	-111,897,661	0	1,375,352,339	1,368,318,836	7,033,503	99.49	-
1) 인건비	현금	-	938,000,000	-124,235,161	0	813,764,839	810,757,261	3,007,578	99.63	-
	현물	-	0	0	0	0	0	0	0	-
2) 학생인건비	현금	-	70,000,000	-29,881,304	0	40,118,696	40,118,696	0	100	-
3) 연구시설·장비비	현금	-	55,000,000	-9,040,800	0	45,959,200	45,959,200	0	100	-
	현물	-	0	0	0	0	0	0	0	-
4) 연구재료비	현금	-	22,000,000	-5,089,960	0	16,910,040	14,797,740	2,112,300	87.51	-
	현물	-	0	0	0	0	0	0	0	-
5) 위탁연구개발비	현금	-	-	-	-	-	-	-	-	-
6) 국제공동연구개발비	현금	-	-	-	-	-	-	-	-	-
7) 연구개발부담비	현금	-	-	-	-	-	-	-	-	-
8) 연구활동비	현금	-	200,650,000	94,989,564	0	295,639,564	293,725,939	1,913,625	99.35	-
	현물	-	0	0	0	0	0	0	0	-
9) 연구수당	현금	-	201,600,000	-38,640,000	0	162,960,000	162,960,000	0	100	-
나. 간접비	현금	-	312,750,000	-34,980,000	0	277,770,000	277,770,000	0	100	-
	소계	-	312,750,000	-34,980,000	0	277,770,000	277,770,000	0	100	-
합계	현금	-	1,800,000,000	-146,877,661	0	1,653,122,339	1,646,088,836	7,033,503	99.57	-
	현물	-	0	0	0	0	0	0	0	-
	합계	-	1,800,000,000	-146,877,661	0	1,653,122,339	1,646,088,836	7,033,503	99.57	-

2. 발생이자 사용명세서

(단위 : 원)

구분	발생금액 (A)	사용용도	사용금액 (B)	사용잔액 (A-B)
연구개발기간 중 발생이자	333,491	국고반납	333,491	-
연구개발기간 후 발생이자	2,964	국고반납	2,964	-
합계	336,455	-	336,455	-

3. 반납액 명세서

(단위 : 원, %)

연구개발비 반납액				발생이자 반납액		총 반납액 (C+E)
구분	현금	현물	소계			
사용잔액	7,033,503	-	-	연구개발기간 중	333,491	-
불인정 사용금액	-	-	-	연구개발기간 후	2,964	-
소계(A)	7,033,503	-	-	소계(D)	336,455	-
정부지분율(B)	100	-	-	정부지분율(B)	100	-
정부지분액(C=A×B)	7,033,503	-	7,033,503	정부지분액(E=D×B)	336,455	7,369,958

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

나. 주관연구개발기관((주)시큐레이어 김건우 연구책임자)

1. 연구개발비 사용명세서

(단위 : 원, %)

항목 \ 구분		연구개발비 현황					사용금액 ⑥	사용잔액 (⑤-⑥)	사용률 (⑥/⑤ ×100)	다음단계 이월액 (해당 시)
		전단계 이월액 (해당 시) ①	당초 연구개발비 ②	변경 연구개발비 ③	발생이자 중 연구개발비 산입금 ④	소계 ⑤ (①+②+③+④)				
가. 직접비	현금	-	1,661,200,000	482,400,000	619,859	2,144,219,859	2,142,568,214	1,651,645	99.92	-
	현물	-	465,300,000	55,800,000	0	521,100,000	521,100,000	0	100	-
	소계	-	2,126,500,000	538,200,000	619,859	2,665,319,859	2,663,668,214	1,651,645	99.94	-
1) 인건비	현금	-	1,512,200,000	528,880,000	0	2,041,080,000	2,040,084,579	995,421	99.95	-
	현물	-	465,300,000	55,800,000	0	521,100,000	521,100,000	0	100	-
2) 학생인건비	현금	-	0	0	0	0	0	0	0	-
3) 연구시설·장비비	현금	-	0	0	0	0	0	0	0	-
	현물	-	0	0	0	0	0	0	0	-
4) 연구재료비	현금	-	0	0	0	0	0	0	0	-
	현물	-	0	0	0	0	0	0	0	-
5) 위탁연구개발비	현금	-	-	-	-	-	-	-	-	-
6) 국제공동연구개발비	현금	-	-	-	-	-	-	-	-	-
7) 연구개발부담비	현금	-	-	-	-	-	-	-	-	-
8) 연구활동비	현금	-	3,000,000	0	619,859	3,619,859	2,963,635	656,224	81.87	-
	현물	-	0	0	0	0	0	0	0	-
9) 연구수당	현금	-	146,000,000	-46,480,000	0	99,520,000	99,520,000	0	100	-
나. 간접비	현금	-	18,000,000	0	0	18,000,000	18,000,000	0	100	-
	소계	-	18,000,000	0	0	18,000,000	18,000,000	0	100	-
합계	현금	-	1,679,200,000	482,400,000	619,859	2,162,219,859	2,160,568,214	1,651,645	99.92	-
	현물	-	465,300,000	55,800,000	0	521,100,000	521,100,000	0	100	-
	합계	-	2,144,500,000	538,200,000	619,859	2,683,319,859	2,681,668,214	1,651,645	99.94	-

2. 발생이자 사용명세서

(단위 : 원)

구분	발생금액 (A)	사용용도	사용금액 (B)	사용잔액 (A-B)
연구개발기간 중 발생이자	5,399,378	국고반납	5,399,378	-
	619,859	과제산입	619,859	-
연구개발기간 후 발생이자	11,115	국고반납	11,115	-
합계	6,030,352	-	6,030,352	-

3. 반납액 명세서

(단위 : 원, %)

연구개발비 반납액				발생이자 반납액		총 반납액 (C+E)
구분	현금	현물	소계			
사용잔액	1,651,645	-	1,651,645	연구개발기간 중	5,399,378	-
불인정 사용금액	54,545	-	54,545	연구개발기간 후	11,115	-
소계(A)	1,706,190	-	1,706,190	소계(D)	5,410,493	-
정부지분율(B)	97.2	-	-	정부지분율(B)	99.9	-
정부지분액(C=A×B)	1,658,417	-	1,658,417	정부지분액(E=D×B)	5,405,083	7,063,499

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

나. 주관연구개발기관((주)윈스 주은영 연구책임자)

1. 연구개발비 사용명세서

(단위 : 원, %)

항목 \ 구분		연구개발비 현황					사용금액 ⑥	사용잔액 (⑤-⑥)	사용률 (⑥/⑤ ×100)	다음단계 이월액 (해당 시)
		전단계 이월액 (해당 시) ①	당초 연구개발비 ②	변경 연구개발비 ③	발생이자 중 연구개발비 산입금 ④	소계 ⑤ (①+②+③+④)				
가. 직접비	현금	-	846,600,000	-398,900,000	0	447,700,000	447,095,819	604,181	99.87	-
	현물	-	239,400,000	-126,000,000	0	113,400,000	113,400,000	0	100	-
	소계	-	1,086,000,000	-524,900,000	0	561,100,000	560,495,819	604,181	99.89	-
1) 인건비	현금	-	678,600,000	-289,300,000	0	389,300,000	389,300,000	0	100	-
	현물	-	239,400,000	-126,000,000	0	113,400,000	113,400,000	0	100	-
2) 학생인건비	현금	-	0	0	0	0	0	0	0	-
3) 연구시설・장비비	현금	-	57,600,000	-19,100,000	0	38,500,000	38,500,000	0	100	-
	현물	-	0	0	0	0	0	0	0	-
4) 연구재료비	현금	-	0	0	0	0	0	0	0	-
	현물	-	0	0	0	0	0	0	0	-
5) 위탁연구개발비	현금	-	-	-	-	-	-	-	-	-
6) 국제공동연구개발비	현금	-	-	-	-	-	-	-	-	-
7) 연구개발부담비	현금	-	-	-	-	-	-	-	-	-
8) 연구활동비	현금	-	58,900,000	-49,000,000	0	9,900,000	9,295,819	604,181	93.90	-
	현물	-	0	0	0	0	0	0	0	-
9) 연구수당	현금	-	51,500,000	-41,500,000	0	10,000,000	10,000,000	0	100	-
나. 간접비	현금	-	15,000,000	-8,500,000	0	6,500,000	3,106,400	3,393,600	47.79	-
	소계	-	15,000,000	-8,500,000	0	6,500,000	3,106,400	3,393,600	47.79	-
합계	현금	-	861,600,000	-407,400,000	0	454,200,000	450,202,219	3,997,781	99.12	-
	현물	-	239,400,000	-126,000,000	0	113,400,000	113,400,000	0	100	-
	합계	-	1,101,000,000	-533,400,000	0	567,600,000	563,602,219	3,997,781	99.30	-

2. 발생이자 사용명세서

(단위 : 원)

구분	발생금액 (A)	사용용도	사용금액 (B)	사용잔액 (A-B)
연구개발기간 중 발생이자	1,535,255	국고 반납	1,535,255	-
연구개발기간 후 발생이자	26,744	국고 반납	26,744	-
합계	1,561,999	-	1,561,999	-

3. 반납액 명세서

(단위 : 원, %)

연구개발비 반납액				발생이자 반납액		총 반납액 (C+E)
구분	현금	현물	소계			
사용잔액	3,997,781	-	-	연구개발기간 중	1,535,255	-
불인정 사용금액	-	-	-	연구개발기간 후	26,744	-
소계(A)	3,997,781	-	-	소계(D)	1,561,999	-
정부지분율(B)	96.7	-	-	정부지분율(B)	100	-
정부지분액(C=A×B)	3,865,845	-	3,865,845	정부지분액(E=D×B)	1,561,999	5,427,853

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

나. 주관연구개발기관((주)모비젠 박관영 연구책임자)

1. 연구개발비 사용명세서

(단위 : 원, %)

항목 \ 구분		연구개발비 현황					사용금액 ⑥	사용잔액 (⑤-⑥)	사용률 (⑥/⑤ ×100)	다음단계 이월액 (해당 시)
		전단계 이월액 (해당 시) ①	당초 연구개발비 ②	변경 연구개발비 ③	발생이자 중 연구개발비 산입금 ④	소계 ⑤ (①+②+③+④)				
가. 직접비	현금	-	687,400,000	-10,440,000	0	676,960,000	669,043,049	7,916,951	98.83	-
	현물	-	192,600,000	-29,160,000	0	163,440,000	163,440,000	0	100	-
	소계	-	880,000,000	-39,600,000	0	840,400,000	832,483,049	7,916,951	99.06	-
1) 인건비	현금	-	665,500,000	-7,440,000	0	658,060,000	658,060,000	0	100	-
	현물	-	192,600,000	-29,160,000	0	163,440,000	163,440,000	0	100	-
2) 학생인건비	현금	-	0	0	0	0	0	0	0	-
3) 연구시설・장비비	현금	-	0	0	0	0	0	0	0	-
	현물	-	0	0	0	0	0	0	0	-
4) 연구재료비	현금	-	0	0	0	0	0	0	0	-
	현물	-	0	0	0	0	0	0	0	-
5) 위탁연구개발비	현금	-	-	-	-	-	-	-	-	-
6) 국제공동연구개발비	현금	-	-	-	-	-	-	-	-	-
7) 연구개발부담비	현금	-	-	-	-	-	-	-	-	-
8) 연구활동비	현금	-	21,900,000	-3,000,000	0	18,900,000	10,983,049	7,916,951	58.11	-
	현물	-	0	0	0	0	0	0	0	-
9) 연구수당	현금	-	0	0	0	0	0	0	0	-
나. 간접비	현금	-	9,000,000	0	0	9,000,000	6,053,600	2,946,400	67.26	-
	소계	-	9,000,000	0	0	9,000,000	6,053,600	2,946,400	67.26	-
합계	현금	-	696,400,000	-10,440,000	0	685,960,000	675,096,649	10,863,351	98.42	-
	현물	-	192,600,000	-29,160,000	0	163,440,000	163,440,000	0	100	-
	합계	-	889,000,000	-39,600,000	0	849,400,000	838,536,649	10,863,351	98.72	-

2. 발생이자 사용명세서

(단위 : 원)

구분	발생금액 (A)	사용용도	사용금액 (B)	사용잔액 (A-B)
연구개발기간 중 발생이자	1,975,942	국고반납	1,975,942	-
연구개발기간 후 발생이자	-	-	-	-
합계	1,975,942	-	1,975,942	-

3. 반납액 명세서

(단위 : 원, %)

연구개발비 반납액				발생이자 반납액		총 반납액 (C+E)
구분	현금	현물	소계			
사용잔액	10,863,351	-	-	연구개발기간 중	1,975,942	-
불인정 사용금액	-	-	-	연구개발기간 후	-	-
소계(A)	10,863,351	-	-	소계(D)	1,975,942	-
정부지분율(B)	97.34	-	-	정부지분율(B)	100	-
정부지분액(C=A×B)	10,574,386	-	10,574,386	정부지분액(E=D×B)	1,975,942	12,550,328

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

나. 주관연구개발기관(성균관대학교 산학협력단 박은일 연구책임자)

1. 연구개발비 사용명세서

(단위 : 원, %)

항목 \ 구분		연구개발비 현황					사용금액 ⑥	사용잔액 (⑤-⑥)	사용률 (⑥/⑤ ×100)	다음단계 이월액 (해당 시)
		전단계 이월액 (해당 시) ①	당초 연구개발비 ②	변경 연구개발비 ③	발생이자 중 연구개발비 산입금 ④	소계 ⑤ (①+②+③+④)				
가. 직접비	현금	-	579,244,000	-47,551,000	199,850	531,892,850	531,808,740	84,110	99.98	-
	현물	-	22,500,000	0	0	22,500,000	22,500,000	0	100	-
	소계	-	601,744,000	-47,551,000	199,850	554,392,850	554,308,740	84,110	99.98	-
1) 인건비	현금	-	362,700,000	-93,172,890	0	269,527,110	269,527,110	0	100	-
	현물	-	22,500,000	0	0	22,500,000	22,500,000	0	100	-
2) 학생인건비	현금	-	102,560,000	74,389,890	30,980	176,980,870	176,980,870	0	100	-
3) 연구시설·장비비	현금	-	0	0	0	0	0	0	0	-
	현물	-	0	0	0	0	0	0	0	-
4) 연구재료비	현금	-	0	0	0	0	0	0	0	-
	현물	-	0	0	0	0	0	0	0	-
5) 위탁연구개발비	현금	-	-	-	-	-	-	-	-	-
6) 국제공동연구개발비	현금	-	-	-	-	-	-	-	-	-
7) 연구개발부담비	현금	-	-	-	-	-	-	-	-	-
8) 연구활동비	현금	-	20,984,000	-16,395,000	168,870	4,757,870	4,673,760	84,110	98.23	-
	현물	-	0	0	0	0		0	0	-
9) 연구수당	현금	-	93,000,000	-12,373,000	0	80,627,000	80,627,000	0	100	-
나. 간접비	현금	-	170,756,000	-12,449,000	0	158,307,000	158,307,000	0	100	-
	소계	-	170,756,000	-12,449,000	0	158,307,000	158,307,000	0	100	-
합계	현금	-	750,000,000	-60,000,000	199,850	690,199,850	690,115,740	84,110	99.99	-
	현물	-	22,500,000	0	0	22,500,000	22,500,000	0	100	-
	합계	-	772,500,000	-60,000,000	199,850	712,699,850	712,615,740	84,110	99.99	-

2. 발생이자 사용명세서

(단위 : 원)

구분	발생금액 (A)	사용용도	사용금액 (B)	사용잔액 (A-B)
연구개발기간 중 발생이자	199,850	학생 인건비 및 연구활동비	115,740	84,110
연구개발기간 후 발생이자	-	-	-	-
합계	199,850	-	115,740	84,110

3. 반납액 명세서

(단위 : 원, %)

연구개발비 반납액				발생이자 반납액		총 반납액 (C+E)
구분	현금	현물	소계			
사용잔액	-	-	-	연구개발기간 중	84,110	-
불인정 사용금액	-	-	-	연구개발기간 후	-	-
소계(A)	-	-	-	소계(D)	84,110	-
정부지분율(B)	-	-	-	정부지분율(B)	100	-
정부지분액(C=A×B)	-	-	-	정부지분액(E=D×B)	84,110	84,110

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

나. 주관연구개발기관(국민대학교 산학협력단 김환국 연구책임자)

1. 연구개발비 사용명세서

(단위 : 원, %)

항목 \ 구분		연구개발비 현황					사용금액 ⑥	사용잔액 (⑤-⑥)	사용률 (⑥/⑤ ×100)	다음단계 이월액 (해당 시)
		전단계 이월액 (해당 시) ①	당초 연구개발비 ②	변경 연구개발비 ③	발생이자 중 연구개발비 산입금 ④	소계 ⑤ (①+②+③+④)				
가. 직접비	현금	-	480,769,000	-44,538,332	27,550	436,258,218	435,362,824	895,394	99.79	-
	현물	-	135,000,000	-30,111,200	0	104,888,800	104,888,800	0	100.00	-
	소계	-	615,769,000	-74,649,532	27,550	541,147,018	540,251,624	895,394	99.83	-
1) 인건비	현금	-	0	5,460,000	0	5,460,000	5,460,000	0	100.00	-
	현물	-	135,000,000	-30,111,200	0	104,888,800	104,888,800	0	100.00	-
2) 학생인건비	현금	-	138,100,000	76,880,000	0	214,980,000	214,980,000	0	100.00	-
3) 연구시설・장비비	현금	-	121,500,000	-70,317,000	0	51,183,000	51,183,000	0	100.00	-
	현물	-	0	0	0	0	0	0	0	-
4) 연구재료비	현금	-	0	1,286,560	0	1,286,560	1,286,560	0	100.00	-
	현물	-	0	0	0	0	0	0	0	-
5) 위탁연구개발비	현금	-	-	-	-	-	-	-	-	-
6) 국제공동연구개발비	현금	-	-	-	-	-	-	-	-	-
7) 연구개발부담비	현금	-	-	-	-	-	-	-	-	-
8) 연구활동비	현금	-	166,549,000	-57,847,892	27,550	108,728,658	108,682,144	46,514	99.96	-
	현물	-	0	0	0	0	0	0	0	-
9) 연구수당	현금	-	54,620,000	0	0	54,620,000	53,771,120	848,880	98.45	-
나. 간접비	현금	-	81,731,000	-5,461,668	0	76,269,332	76,269,332	0	100.00	-
	소계	-	81,731,000	-5,461,668	0	76,269,332	76,269,332	0	100.00	-
합계	현금	-	562,500,000	-50,000,000	27,550	512,527,550	511,632,156	895,394	99.83	-
	현물	-	135,000,000	-30,111,200	0	104,888,800	104,888,800	0	100.00	-
	합계	-	697,500,000	-80,111,200	27,550	617,416,350	616,520,956	895,394	99.85	-

2. 발생이자 사용명세서

(단위 : 원)

구분	발생금액 (A)	사용용도	사용금액 (B)	사용잔액 (A-B)
연구개발기간 중 발생이자	27,550	과제산입	-	27,550
연구개발기간 후 발생이자	-	-	-	-
합계	27,550	-	-	27,550

3. 반납액 명세서

(단위 : 원, %)

연구개발비 반납액				발생이자 반납액		총 반납액 (C+E)
구분	현금	현물	소계			
사용잔액	867,844	-	-	연구개발기간 중	27,550	-
불인정 사용금액	-	-	-	연구개발기간 후	-	-
소계(A)	867,844	-	-	소계(D)	27,550	-
정부지분율(B)	100	-	-	정부지분율(B)	100	-
정부지분액(C=A×B)	867,844	-	867,844	정부지분액(E=D×B)	27,550	895,394

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

붙임 1. 사업화대상기술별 기술명세서(해당과제 작성)

1. 과제정보

과 제 명	국문	AI·빅데이터 기반 사이버 보안 오케스트레이션 및 자동 대응 기술 개발				
	영문	AI·Big data based Cyber Security Orchestration and Automated Response Technology Development				
기술분류	대분류	네트워크 시스템 보안	중분류	서비스/응용 보안	소분류	공통 보안기술
주관연구개발기관	한국인터넷진흥원		연구책임자	김태은		
연락처(책임자)	(사무실) 061-820-1273		이메일(책임자)	tekim31@kisa.or.kr		

2 사업화대상기술 목록

순번	개발기술(Product)명 (관련 기술의 Know-how 및 특허 등)		보유특허(기술별로 중복기재 가능)		
			특허		발명의 명칭
			출원번호	등록번호	
1	국문	AI·빅데이터 기반 사이버 보안 오케스트레이션 및 자동 대응 기술	10-2021-0133538	10-2402166	인터랙티브 시뮬레이션 기반 플레이북을 통한 보안 이벤트 대응 지원 방법 및 장치
	영문	AI·Big data based Cyber Security Orchestration and Automated Response Technology			Method And Device For Supporting Managing Security Event By Using Playbook Based On Interactive Simulation
			10-2022-0046579	10-2443400	보안 이벤트 대응을 위한 플레이북의 검증을 수행하는 방법 및 장치
					Method And Device For Validating Playbook To Cope With Security Event
			10-2023-0130973	10-2675087	위협 TI 기반 온톨로지 생성과 시각화 방법 및 이를 이용한 컴퓨팅 장치
					Method For Generating And Visualizing Threat Intelligence-Based Ontology And Computing Device Using The Same
			10-2024-0181018	-	공격 패턴에 대한 플레이북을 실행하는 방법 및 이를 이용한 시스템
					Method Of Executing A Playbook For Attack Patterns And System Using The Same

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

3. 사업화 대상기술

개발기술 1	국문	AI·빅데이터 기반 사이버 보안 오케스트레이션 및 자동 대응 기술
	영문	AI·Big data based Cyber Security Orchestration and Automated Response Technology

공개	☑	비공개	☐ (사유)

① (예상) 결과물

개발목표 시기	2023.09		기술성숙도 (TRL)	개발 전	개발 후
				4	6
결과물 형태	SW-System, SW-Platform, Patent, SW Service		검증방법	자체검증, 3자 검증(TTA, KOTCA)	
색인어 (Keywords)	국문	보안 관제, 인공지능, 빅데이터, 자동화, 위협 분석			
	영문	Security Monitoring, Artificial Intelligence, Big Data, Automation, Threat Analysis			
외부 기술요소	100% 개발기술		권리성	특허, SW, SW-IP	

② 기술의 개념(Concept) 및 구성

국문

☐ **기술의 개념**

- 사이버 보안 위협, 보안 오퍼레이션, 응답 및 대응, 위협 인텔리전스 정보를 효율적으로 관리하고 활용하는 솔루션
- 다양한 사이버 보안 솔루션 및 IT 운영 솔루션을 통합하여 사이버 보안 위협을 탐지하고 관리
- 탐지된 위협 정보를 외부 위협 정보와 관계하여 상관분석 및 온톨로지 분석 등을 수행하는 자동화 분석
- 위협 대응 시 다양한 형태의 수행 및 대응 Case인 플레이북 기능을 제공하고 보안 응답 기능을 가진 다양한 솔루션들을 마치 하나의 동일한 시스템, 서비스, 프로그램과 같이 조율

☐ **기술의 구성**

o 보안관제센터의 탐지 - 위협분석 - 대응 全 업무 프로세스를 자동화하는 보안관제 오케스트레이션 및 대응 자동화 기술 개발

- **(연동·탐지)** 이기종 보안 장비 연동 API 및 이상행위 탐지 기술
  - 이기종 보안 장비 데이터 수집 및 보안 정책 적용 API
  - 보안관제 빅데이터 기반 이기종 보안 장비 데이터의 정규화·분류 및 이상행위 탐지
  - AI·빅데이터 기반 이기종 보안 장비 이상행위 탐지 성능 향상
  - 국내외 공개 보안 위협 인텔리전스 정보 수집
- **(위협분석·자동화)** 빅데이터 기반 全 주기적 사이버 보안관제 업무 프로세스를 위한 플레이북 생성 및 자동화 기술
  - 공개 보안 위협 인텔리전스 정보 및 MITRE ATT&CK Matrix 기반 TTP 생성
  - TTP 정보 기반 이상행위 탐지 자산의 분석 방법·절차 및 위협 인자 식별
  - 보안 관제 플레이북 자동 생성·실행·검증·관리 기술
- **(의사결정)** SOC에 특화된 AI 기반 보안사고 대응 의사결정 지원 및 판단 기술
  - 플레이북을 통한 자동화 분석 절차의 관리 및 시각화
  - 이종 보안 장비 데이터 및 TTP 정보의 연관정보 가시화

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

· 신속한 의사결정 지원을 위한 고성능 AI 분석 모델 및 활용
· AI기반 최적 의사결정 자동 추천 및 대응 정책 관리·검증
- **(대응)** 이기종 보안 장비의 보안사고 자동 대응 기술
· 이기종 보안 장비의 보안사고 자동 대응(탐지·차단 정책 적용) 및 검증
· 사이버 보안관제 업무 프로세스 전반에 대한 정량적 측정
· SOC 통합 운영 및 자동화 플랫폼

<기술개념도>

③ 기술적 경쟁력

○ 기술의 특성 및 성능

o 기술적 특징

- 국내 공용 포맷 기준의 이기종 보안장비와의 연동 및 정책 연계 기술
- 기존에 수동으로 수행해야 하는 일반적이고 반복적인 위협 분석/대응 업무를 플레이북 형태로 관리하여 자동화된 수행으로 분석 및 대응 시간을 줄이고 분석가들의 개입이 필요한 조치에 집중할 수 있도록 지원
- 각 사이버안전센터에 특화된 사이버 위협별 플레이북을 쉽고 유연하게 생성·관리

o 기술적 성능

- 빅데이터 플랫폼 기반 기술 구현(데이터 수집·정형화·분산 저장·고속 검색 기술/분석 대상 데이터의 연동 방법 및 분석 항목 정의·분석 기술/UI 기반 데이터 정형화 및 실시간 전처리 기술/클라우드 기반 데이터 분산저장 및 메모리 캐싱 기술을 활용한 고속 검색 엔진 기술/도메인 별 빅데이터 스토리지 관리 기술)
- 빅데이터 고속 분석 엔진 기술 개발(다중 분석 모델링을 위한 In-Memory 기반의 고속 엔진/실시간 데이터 조회를 위한 고성능 분석 검색 엔진/대용량 빅데이터 실시간 처리 기술)
- 수집된 빅데이터 대상 단일 생성조건 룰셋의 위협이벤트 뿐만 아니라 다양한 조건과 시계열 관계를 갖는 상관관계 기반의 상관분석 룰셋 위협이벤트 등 다양한 위협이벤트(보안티켓)를 생성하는 기술
- SOAR 기술(플레이북 및 보안 관제 프로세스 Task 단위 컴포넌트 기술 분석 및 설계) 등 AI·빅데이터 기반 사이버 보안 오케스트레이션 및 자동 대응 기술

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

○ 경쟁기술/대체기술 동향 및 현황

o **(국내 기술 동향)** 국내의 AI 기반 통합보안 관리시스템의 기술력 수준 저조

- SIEM 중심의 보안관제 기술들은 고도화되었지만, 보안 오케스트레이션·자동화 및 대응 단계에서의 AI 활용 정도는 기초적인 개념이나 학술적 모델을 제안하는 수준임
- AI 도입의 지연으로 인해 국내 보안관제 기술력의 수준이 국외 기술력과의 큰 격차를 보이고 있어, 이를 해소하기 위한 방안으로 AI 기반의 보안관제 기술 연구 및 개발이 시급한 상황임

o **(국외 기술 동향)** AI 기술의 보안관제 활용에 대해 개념과 모델을 제안하는 수준을 넘어서 실제로 도입 및 운용하고 있지만, 국내 보안관제 프로세스 적용 문제 및 국내 보안장비와 연동 및 연계 분석 문제 등 국내 보안관제 최적화에는 한계 존재

- 연동 및 탐지 단계에서 기계 학습, 자연어 처리 등 AI 관련 기술들을 활용하여 CTI 정보를 추출하고, 이를 활용해 위협을 예측·탐지하는 기술들이 다수 연구되고 개발됨
- 현재는 보안관제 시스템에 AI 기술이 제한적으로 활용되고 있으나, 대응 및 자동화 영역 등에 대한 AI 기술의 확장 적용을 목적으로 적극적인 연구가 이루어지고 있음

o (소셜데이터 기반 CTI 추출) 새로운 유형의 침해 지표를 식별하기 위한 소셜데이터 기반 CTI 추출 및 공유 프레임워크 연구

※ "TIMiner: Automatically Extracting and Analyzing Categorized Cyber Threat Intelligence from Social Data", Computers & Security (2020)

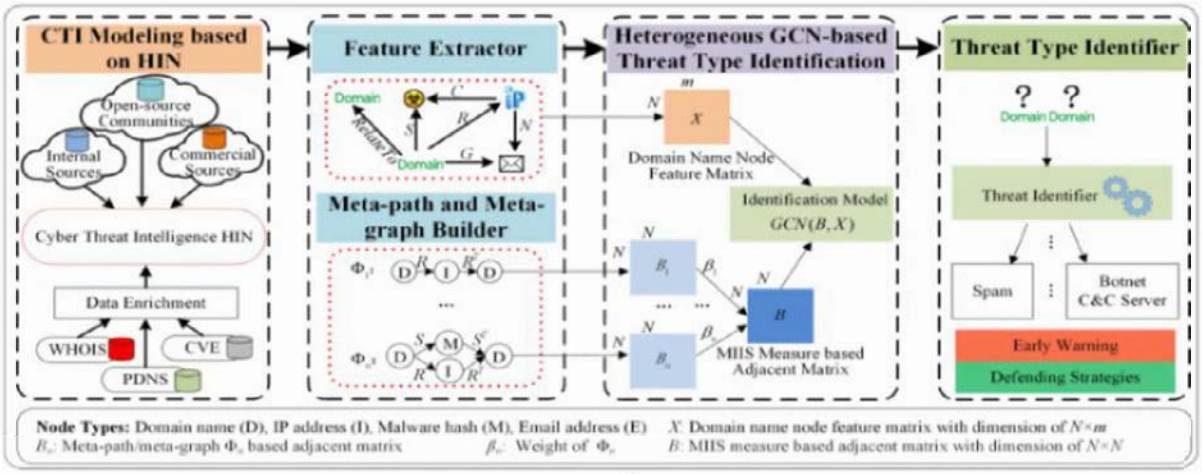
- 소셜데이터의 단어와 구문 의존성에 기반한 IOC 추출을 기반으로 도메인에 대한 위협 심각도를 표현함
- IOC 추출이 94%를 초과하는 정확도를 달성했으며, 이를 통해 여러 도메인에서 사이버 공격의 진화에 대한 새로운 통찰력을 제공함

o (이기종 CTI 통합) 이기종 CTI를 학습하여, 사이버 위협을 식별하는 프레임워크 연구

※ "HinCTI: A Cyber Threat Intelligence Modeling and Identification System Based on Heterogeneous Information Network", IEEE Transactions on Knowledge and Data Engineering(2020)

- 이기종 정보 네트워크 (HIN)에서 CTI를 모델링한 후, 수행원, 위협 인프라 노드 간의 메타 경로 및 메타 그래프 인스턴스 기반 위협 인프라 유사성(MIIS) 측정을 정의함
- CTI에 관련된 인프라 노드의 위협 유형을 식별하기 위한 MIIS 측정 기반 이기종 GCN(graph convolutional network) 접근 방식을 제시함

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



<HinCTI 개요도>

○ 우수성 및 차별성

경쟁기술	본 기술의 우수성/차별성
- AI·빅데이터 기반 SOC 구성 시 예측되는 장애요소는 연동되는 국내·외의 다양한 이기종 보안장비 대상의 정책 연계의 어려움이 존재함 - 보안사고 대응 시 의사결정 지원 및 판단을 하는 컴포넌트 개발과 원시데이터와 위협정보와의 연계 분석으로 다양한 자동 연계 분석의 어려움이 존재함 - 해외의 우수 솔루션들은 국내에 특화되어 있지 않아 국내 수요처에 알맞은 서비스를 제공하기 쉽지 않음	- 연동되는 대상의 정책 연계 요소 해결 방안은 이기종 보안 장비와의 공통 포맷 기반의 공개 API 연계와 SOAR 컴포넌트를 구성하여, 정책을 적용하고 로그 분석 연계를 통해 예상되는 장애요소를 해결할 수 있음 - 보안사고 대응 시 의사결정 지원 및 판단 가능한 컴포넌트 개발 및 원시데이터의 연계 분석 역량은, 연계된 국내·외 사이버 위협 인텔리전스 정보(CTI)와 MITRE ATT&CK 기반 TTP 분류 정보를 토대로 보안사고 대응 시 자동 연계 분석이 가능한 다양한 플레이북 적용과 기능 적용으로 해결할 수 있음

④ 표준화 및 특허

○ 표준화 동향

□ 국내 표준화 현황

o **(TTA)** 한국정보통신기술협회(TTA)에서 국내 보안 오케스트레이션 및 자동 대응 기술들과 관련된 정보통신 단체표준 개발

- 한국정보통신기술협회의 'TTA 사이버보안 PG(PG503)에서는 침해사고 정보 전달 포맷 및 프로토콜에 대한 표준이 제정되었으며, 악성코드 및 사이버위협정보 공유와 관련된 표준화를 진행하여 침해사고 정보 전달 포맷 및 프로토콜에 대한 표준을 제정함
- 또한, 사이버 위협정보 공유와 관련하여 STIX 2.0 표준과 유스케이스(Use Case)에 대한 표준을 개발함

□ 국외 표준화 현황

o **(ITU-T/JTC1)** ITU-T, ISO/IEC 중심 사이버 위협정보 공유 포맷 및 프로토콜, 네트워크

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

관리 및 오케스트레이션 등 관련 표준화 개발

- 'ITU-T SG17' 에서는 사이버 보안에 대한 정보공유 프레임워크(CYBEX)에 대한 표준이 제정되었으며, 관련 메커니즘에 대한 표준화 작업이 지속적으로 진행 중임
- 'ITU-T SG13' 에서 IMT-2020의 네트워크 관리 및 오케스트레이션에 대한 요구사항과 설계, 배포 및 운영을 위한 아키텍처 및 기능 구성 요소를 제공함
- 'JTC1 SC27' 에서 침입 탐지 및 방지 시스템(IDPS)의 선택, 배포 및 운영에 대한 지침 및 방법에 대한 표준화를 제정함

○ 관련 보유특허

□ 국내·외 특허 동향

o **(현황 분석)** 국내·외 모두 AI 기술을 활용한 보안관제 관련된 특허들은 위협에 대한 탐지와 그 성능을 높이기 위한 목적들로 치중되어있음

o **(향후 방향)** 탐지한 위협에 대하여 AI 기술을 활용한 자동 대응 기술들에 대한 특허 출원 및 등록을 목표로 진행하여 국내뿐만 아니라 세계적으로 주요 기술을 선점할 수 있을 것으로 예상함

o **(보유 영역)** 보안 로그/이벤트 수집, 분석, 자동 대응의 전 주기적 보안관제 프로세스에 대한 특허 보유 중이며, 나아가 제로트러스트, 클라우드, 빅데이터, 통합보안(XDR) 등 최신 사이버 보안 트렌드 기술을 반영하여 지속적으로 특허 출원·등록 중

No.	국가	출원·등록번호(출원·등록일)	상태	명칭
1	대한민국	10-2402166 (2022.05.23)	등록	인터랙티브 시뮬레이션 기반 플레이북을 통한 보안 이벤트 대응 지원 방법 및 장치
2	대한민국	10-2443400 (2022.09.08)	등록	보안 이벤트 대응을 위한 플레이북의 검증을 수행하는 방법 및 장치
3	대한민국	10-2675087 (2024.06.10)	등록	위협 TI 기반 온톨로지 생성과 시각화 방법 및 이를 이용한 컴퓨팅 장치
4	대한민국	10-2024-0181018 (2024.12.06)	출원	공격 패턴에 대한 플레이북을 실행하는 방법 및 이를 이용한 시스템

⑤ 시장성

○ 국내외 시장동향 및 전망

□ 시장 전망

o **(글로벌 보안 시장)** 사이버보안 내 AI 시장 규모는 '19년 87억 달러에서 ' 26년 382억 달러로 성장할 것으로 전망

※ "AI in Cybersecurity Market & Global Forecast to 2026", MarketsAndMarkets(2019)

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

o **(국내 AI 보안 관련 시장 현황)** 보안 데이터 양의 증가와 사이버 공격 증가에 따른 보안 시스템에 대한 요구사항 증가로 빅데이터 보안 시장은 '17년 229억 달러에서 '25년 433억 달러로 전망

- 국내 AI 기술의 진입장벽과 양질의 보안데이터 부족으로 AI 보안 기술개발 한계 존재

o **(아시아 SOAR 시장)** 국내 포함 3개 국가의 SOAR 시장은 2021년부터 2027년까지 2.9배 성장할 것으로 전망

- 대한민국·말레이시아·싱가포르 보안 오케스트레이션 자동 대응 기술(SOAR) 시장은 2021년 0.9억 달러(한화 957억원)에서 2027년까지 2.6억 달러(한화 2,914원)로 연평균 20.4%씩 성장하여 2021년에서 2027년까지 2.9배 성장할 것으로 전망

※ Markets and Markets(2019)

o **(글로벌 SOAR 시장)** 2021년부터 2027년까지 2.4배 성장할 것으로 전망

- 세계 보안 오케스트레이션 자동 대응 기술(SOAR) 시장은 2021년 11.6억 달러(한화 1.2조원)에서 2027년까지 27.7억 달러(한화 3조원)로 연평균 15.6%씩 성장하여 2021년에서 2027년까지 2.4배 성장할 것으로 전망

※ Markets and Markets(2019)

□ 시장 동향

o **(국내 보안 기관·기업 현황)** 국내 보안관제 관련 기업들을 중심으로 위협에 대한 분석 및 탐지와 해당 과정에 대한 시각화 기술을 통합 시스템을 제품화하였음

o (**국외 보안 기관·기업 현황)** 다국적 기업들이 주축이 되어 자동화된 보안 데이터 수집 및 분석, 위협 정보를 기반으로 지능형 위협 탐지, 자동 대응을 위한 플레이북 관리 등 보안 오케스트레이션 및 자동 대응 기술을 위한 구체적인 기술들을 개발하여 제품화하였음

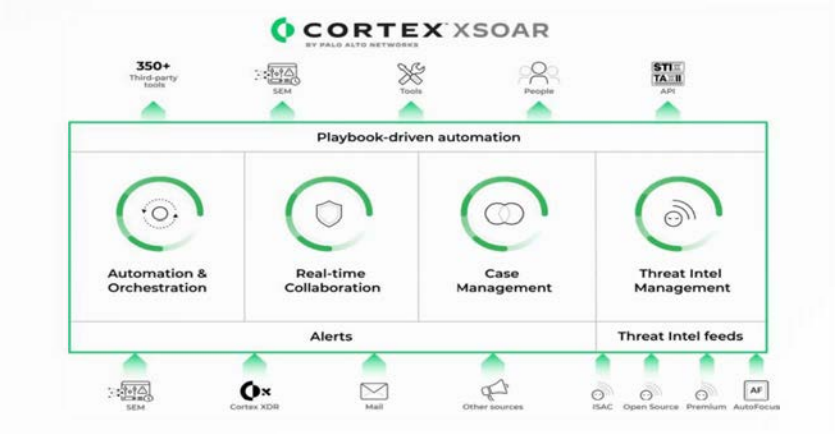
o **(기업 분석) 팔로알토 XSOAR**

- 팔로알토 네트웍스에서는 사례관리, 자동화, 실시간 협업 및 위협 인텔리전스 관리를 통합하는 포괄적인 SOAR 플랫폼으로 코어텍스 XSOAR 출시

· **(인공지능 기반 자동화)** 위협 인텔리전스 관리를 핵심 요소로 보안 오케스트레이션, 자동화, 대응 범주를 통합하고, 인공지능을 추가함으로써 고객의 보안 운영 자동화 구현

· **(위협 상관관계 및 CTI 연관분석)** 지능형 위협 경보 상관관계 자동 분석 및 CTI 연관 분석·위협 예측 기술 보유

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



< 팔로알토 네트웍스의 '코어텍스 XSOAR(Cortex™ XSOAR)' >

○ 제품화 및 활용분야

활용분야(제품/서비스)		제품 및 활용분야 세부내용
1	차세대 보안관제 서비스	각 정부부처 및 기업들의 보안관제 효율 향상을 위한 차세대 보안 관제 시스템으로 적용

○ 시장규모(추정치)

활용분야(제품/서비스)		관련 시장 규모(5년), 단위: 억원				
		종료+1 (2025년)	종료+2 (2026년)	종료+3 (2027년)	종료+4 (2028년)	종료+5 (2029년)
1	보안 자동대응 시스템 (SOAR)	20	40	60	80	100

⑥ 기술이전 조건 및 고려사항

개발상태	아이디어 창안	특허만 신청(등록)	기술개발 진행중	기술개발 완료	시제품 단계	실용화 단계	시장개척 단계	기타
				√		√	√	
기술이전 금액	무료 -5백만원 이하	5백만원 초과 -1천만원 이하	1천만원 초과 -2천만원 이하	2천만원 초과 -3천만원 이하	3천만원 초과 -5천만원 이하	5천만원 초과 -1억원 이하	1억원 초과	기타
							√	
희망거래 유형	기술매매	라이센스	기술협력	기술지도	M&A	기타		
		√	√					

○ 고려사항

- 해당사항 없음

⑦ 기대효과

○ 기술도입으로 인한 경제적 효과

- 고성능 AI 기반 이상행위 탐지 기술을 토대로 신속·정확한 사이버 위협분석을 통해 **보안사고 복구에 소요되는 막대한 사회적 비용 절감**에 기여
- 국내 보안관제 프로세스 자동화 핵심 원천기술 확보를 통한 해외 기술 사용료 절감 기대

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

○ 기술사업화로 인한 파급효과

o 국가 기술 경쟁력 확보

- AI 기반 이상행위 탐지 기술, 보안관제 全 업무 프로세스 자동화 연구결과의 상용화로 국가 인프라 보안을 위한 보안관제센터 핵심**기술 국산화**

o 국내 보안관제 산업 구조 개선

- 수 천만건의 사이버 위협정보를 실시간으로 판별 및 보안관제 운영 자동화를 이루어 기존 인력기반 체계에서 AI 시스템 기반의 **新 정보보호 시장 개척** 기대
- 공공·민간에서 보안관제센터를 운영하고 있는 기관의 보안관제 품질 향상

o 국가 보안수준 향상에 따른 국민 편익 향상

- AI·빅데이터 기반으로 신·변종 이상행위 공격에 대해 신속·정확하게 대응이 가능하여 **선제적으로 사이버위협을 예방**하는 善순환 효과를 기대

⑧ 기술사업화 적용 및 제약사항

○ 사업화 적용실적

- 전체 상용화 실적 리스트

성과발생	사업명	가격(원)	기여도(%)	사업화성과	고객사
3차년도	AI 기반 자동화 보안관제 대응 시스템 구축	514,800,000	22	113,256,000	한국동서발전 주식회사
4차년도	통합로그관리솔루션 구축	204,600,000	30	61,380,000	한국토지주택공사
	통합보안 모델 개발 시범사업	550,000,000	30	165,000,000	한국인터넷진흥원
	사이버위협 공동대응 플랫폼 구축사업	1,132,750,000	30	339,825,000	한국인터넷진흥원
	통합로그분석시스템 구축	103,840,000	30	31,152,000	파라다이스그룹
합 계					710,613,000

○ 사업화 제약사항

- 해당사항 없음

○ 지원 필요사항

- 해당사항 없음

⑨ 기타

기술세미나 발표 가능 여부(O/X)	O	매칭 희망 여부(O/X) (R&D 바우처 사업 등)	O

담당	구분	성명	소속	직위	회사 전화번호	회사 이메일
	판매자 (TLO 등)	김건우	㈜시큐레이어	이사	********	kunwoo.kim@seculayer.com
	연구자	이시아	㈜시큐레이어	사원	********	sa.lee@seculayer.com

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

붙임 2. 자체 보안관리 진단표

구분	체크항목	결과 체크 (√표)	비고 (미실시 사유)
보안관리 체계	o 기관 내 보안관리규정을 제정/적용하고 있다	O(√), X( )	
	o 보안관리 조직이 있으며, 자체 보안점검실시 등 잘 운영되고 있다	O(√), X( )	
	o 보안교육을 정기적(1회이상/연)으로 실시하고 있다	O(√), X( )	
	o 보안사고에 대한 방지대책 및 비상시 대응계획이 준비되어 있다	O(√), X( )	
참여연구원 관리	o 참여연구원에 대하여 보안서약서를 받았다	O(√), X( )	
	o 참여연구원에게 보안관리의 중요성 등을 인식시키고 있다	O(√), X( )	
연구개발 내용/결과 관리	o 주요 연구자료 및 성과물의 무단유출 방지대책을 수립하고 있다	O(√), X( )	
	o 보안성 검토 방법 및 절차를 이행하고 있다	O(√), X( )	
	o 기술이전 관련 내부규정 및 절차를 준수하고 있다	O(√), X( )	
연구시설 관리	o 연구시설 보안관련 내부규정 또는 지침을 이행하고 있다	O(√), X( )	
	o 주요 시설에는 보안장비가 설치되어 있다	O(√), X( )	
	o 보호구역이 지정되어 있다	O(√), X( )	
정보통신망 관리	o 정보통신망 보안관련 내부규정 또는 지침이 구비되어 있다	O(√), X( )	
	o 보안관리 책임자의 승인 항목이 구분되어 있다	O(√), X( )	
	o 주요 데이터에 대해 백업을 실시하고 있다	O(√), X( )	
	o 개인용 정보통신장비(노트북, USB메모리)에 대하여 인가/관리중이다	O(√), X( )	
	o 전산망 보호를 위한 HW 및 SW 등을 도입하여 적용하고 있다	O(√), X( )	
	o 직책, 임무별 열람 권한을 차등화하여 부여하고 있다	O(√), X( )	

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

주 의

1. 이 보고서는 과학기술정보통신부에서 시행한 정보통신 · 방송연구개발사업의 AI·빅데이터 기반 사이버 보안 오케스트레이션 및 자동 대응 기술 개발과제 최종보고서이다.

2. 이 연구개발내용을 대외적으로 발표할 때에는 반드시 과학기술정보통신부(정보통신기획평가원)에서 시행한 정보통신 · 방송연구개발사업의 결과임을 밝혀야 한다.

3. 국가과학기술 기밀 유지에 필요한 내용은 대외적으로 발표 또는 공개하여서는 안 된다.